PRADITA University

Course Module · IT40813

IT Governance, Risk & Compliance

Alfa Yohannis



Master of Information Technology
Pradita University

Daftar Isi

1 Orientasi Mata Kuliah dan Dasar-Dasar GRC **9**
- 1.1 Pendahuluan . . . 9
- 1.2 Mengapa Organisasi Membutuhkan Tata Kelola TI . . . 10
- 1.3 Tata Kelola dan Manajemen . . . 12
- 1.4 Istilah Dasar GRC . . . 14
- 1.5 GRC sebagai Satu Kesatuan . . . 17
- 1.6 Peta Kerangka dan Regulasi . . . 19
- 1.7 Capstone Bersama dan Kasus Medikara Health . . . 21
- 1.8 Pemangku Kepentingan dan Pemicu GRC . . . 22
- 1.9 Cara Belajar Mandiri dan Menilai Bukti . . . 24
- 1.10 Aktivitas: Profil Organisasi dan Peta Pemangku Kepentingan . . . 26
- 1.11 Ringkasan . . . 28
- 1.12 Latihan . . . 28

2 Prinsip Tata Kelola TI dan Peran Direksi **33**
- 2.1 Pendahuluan . . . 33
- 2.2 Tata Kelola Korporat dan Posisi TI . . . 34
- 2.3 ISO/IEC 38500:2024 dan Model Evaluate, Direct, Monitor . . . 38
- 2.4 Hak Keputusan TI . . . 41
- 2.5 Struktur, Proses, dan Mekanisme Relasional . . . 45
- 2.6 Keselarasan Bisnis dan TI serta Penciptaan Nilai . . . 48
- 2.7 Aktivitas: Matriks Hak Keputusan dan Piagam Komite Pengarah TI 51
- 2.8 Ringkasan . . . 53
- 2.9 Latihan . . . 54

3 Lanskap Regulasi dan Kewajiban Kepatuhan **59**
- 3.1 Pendahuluan . . . 59
- 3.2 Membaca Regulasi Indonesia . . . 60
- 3.3 Pelindungan Data Pribadi dan Sistem Elektronik . . . 64
- 3.4 Regulasi Sektor Kesehatan . . . 67

3.5 Keamanan Siber Nasional dan Infrastruktur Informasi Vital . . . 71
3.6 Regulasi yang Mengikat Mitra: OJK dan SPBE 73
3.7 Register Kewajiban Kepatuhan 75
3.8 Aktivitas: Register Kewajiban Kepatuhan 79
3.9 Ringkasan 80
3.10 Latihan 81

4 COBIT 2019: Sistem Tata Kelola dan Faktor Desain 85
4.1 Pendahuluan 85
4.2 COBIT 2019 sebagai Kerangka Tata Kelola 86
4.3 Prinsip dan Komponen Sistem Tata Kelola 88
4.4 Model Inti: 40 Objektif dalam Lima Domain 90
4.5 Faktor Desain dan Focus Area 92
4.6 Goals Cascade dan Pemilihan Prioritas 95
4.7 Penilaian Kapabilitas Berdasarkan Bukti 98
4.8 Kaitan dengan ITIL 4 dan Tata Kelola Arsitektur 101
4.9 Pengendalian Versi dan Transisi COBIT 7 102
4.10 Aktivitas: Faktor Desain, Goals Cascade, dan Potret Kapabilitas . 104
4.11 Ringkasan 105
4.12 Latihan 106

5 Manajemen Risiko Enterprise dan Risiko TI 109
5.1 Pendahuluan 109
5.2 Risiko Berawal dari Tujuan Organisasi 110
5.3 Proses ISO 31000 dan Konteks Penilaian 113
5.4 Risk Appetite, Risk Tolerance, dan Kapasitas Risiko 116
5.5 Skenario, Kontrol, dan Risk Register 119
5.6 Matriks Risiko dan Kelemahannya 121
5.7 Gambaran Pengukuran Kuantitatif 124
5.8 Penanganan, Risiko Sisa, dan Pemantauan 128
5.9 Aktivitas: Risk Appetite dan Risk Register Kondisi Saat Ini 131
5.10 Ringkasan 132
5.11 Latihan 133

6 Keamanan Informasi: ISO/IEC 27001 dan NIST CSF 2.0 137
6.1 Pendahuluan 137
6.2 Kerahasiaan, Integritas, dan Ketersediaan 138
6.3 Sistem Manajemen ISO/IEC 27001 140
6.4 Annex A, SoA, dan Panduan Kontrol 142
6.5 Enam Fungsi NIST CSF 2.0 146
6.6 Profil Saat Ini dan Tier 149
6.7 Dari Bukti ke Celah Kontrol 153

6.8 Aktivitas: Profil Keamanan Saat Ini dan Daftar Celah 157
6.9 Ringkasan 158
6.10 Latihan 159

7 Pelindungan Data Pribadi dalam Praktik 163
7.1 Pendahuluan 163
7.2 Data, Tujuan, dan Dasar Pemrosesan 164
7.3 Pengendali, Prosesor, dan Pengendali Bersama 168
7.4 Hak Subjek Data dan Batas Tanggapan 171
7.5 Catatan Pemrosesan dan Retensi 173
7.6 Pusat Data dan Transfer ke Luar Wilayah Hukum 175
7.7 Penilaian Dampak Pelindungan Data Pribadi 176
7.8 Kegagalan Pelindungan dan Pemberitahuan 178
7.9 Status Aturan, Sanksi, dan Sistem Manajemen Privasi 183
7.10 Aktivitas: Catatan Pemrosesan dan Analisis Insiden Vendor . . . 188
7.11 Ringkasan 189
7.12 Latihan 190

8 Merancang Sistem Tata Kelola Target 195
8.1 Pendahuluan 195
8.2 Dari Temuan C2 ke Keputusan Target 196
8.3 Menetapkan Target Kapabilitas COBIT 199
8.4 Profil Target NIST CSF 202
8.5 Struktur, Forum Keputusan, dan Pemisahan Tugas 205
8.6 Matriks RACI yang Dapat Dipakai 209
8.7 Arsitektur dan Siklus Hidup Kebijakan 211
8.8 COBIT dan ITIL 4 dalam Operasi Layanan 213
8.9 Bukti Penerimaan dan Simulasi Keputusan 215
8.10 Aktivitas: Model Tata Kelola Target 217
8.11 Ringkasan 218
8.12 Latihan 219

9 Risiko Pihak Ketiga dan Cloud 223
9.1 Pendahuluan 223
9.2 Rantai Pasok Digital dan Konsentrasi Risiko 224
9.3 Siklus Hidup Risiko Pihak Ketiga 228
9.4 Klausul Kontrak dan Kewajiban Prosesor 233
9.5 Cloud dan Tanggung Jawab Bersama 237
9.6 Berbagi Data dan Penilaian Dampak 241
9.7 Aktivitas: Kerangka Pihak Ketiga, Matriks Cloud, dan DPIA 245
9.8 Ringkasan 246
9.9 Latihan 247

10 Kelangsungan Bisnis dan Ketahanan Operasional **251**
10.1 Pendahuluan . . . 251
10.2 Ketahanan Operasional sebagai Tanggung Jawab Direksi . . . 253
10.3 Sistem Manajemen: ISO 22301 dan DSS04 . . . 255
10.4 Analisis Dampak Bisnis . . . 258
10.5 Strategi Kelangsungan . . . 264
10.6 Insiden Siber dan Manajemen Krisis . . . 267
10.7 Latihan dan Pengujian . . . 270
10.8 Aktivitas: BIA dan Strategi Kelangsungan Layanan . . . 273
10.9 Ringkasan . . . 274
10.10 Latihan . . . 275

11 Tata Kelola Kecerdasan Artifisial **279**
11.1 Pendahuluan . . . 279
11.2 Peluang dan Risiko AI di Layanan Kesehatan . . . 280
11.3 ISO/IEC 42001:2023 dan Standar Pendukung . . . 285
11.4 NIST AI RMF . . . 287
11.5 EU AI Act dan Pendekatan Berbasis Risiko . . . 290
11.6 Posisi Regulasi AI di Indonesia . . . 295
11.7 Inventaris AI, Pengawasan Manusia, dan Kebijakan . . . 297
11.8 Aktivitas: Inventaris AI dan Kebijakan Pemakaian AI . . . 301
11.9 Ringkasan . . . 303
11.10 Latihan . . . 304

12 Audit TI dan Asurans **307**
12.1 Pendahuluan . . . 307
12.2 Konsep Asurans . . . 308
12.3 Three Lines Model . . . 310
12.4 Standar Profesi: GIAS dan ITAF . . . 313
12.5 Perencanaan Audit Berbasis Risiko . . . 315
12.6 Program Audit dan Pengujian Kontrol . . . 318
12.7 Bukti dan Sampel . . . 320
12.8 Pelaporan Temuan dan Tindak Lanjut . . . 324
12.9 Audit Eksternal, Sertifikasi, dan Laporan Pihak Ketiga . . . 327
12.10 Aktivitas: Rencana Asurans dan Pengujian Satu Kontrol . . . 328
12.11 Ringkasan . . . 330
12.12 Latihan . . . 331

13 KPI, KRI, dan Pelaporan ke Direksi **335**
13.1 Pendahuluan . . . 335
13.2 KPI, KRI, dan KCI . . . 336
13.3 Merancang Indikator yang Baik . . . 340

13.4 Ambang Batas dan Eskalasi 342
13.5 Metrik Tata Kelola, Keamanan, dan Privasi 346
13.6 Mutu Data dan Risiko Manipulasi 349
13.7 Dashboard dan Prinsip Visualisasi 351
13.8 Laporan Satu Halaman ke Direksi 353
13.9 Aktivitas: Dashboard KPI dan KRI serta Laporan Satu Halaman . 356
13.10 Ringkasan 358
13.11 Latihan 359

14 Alat GRC dan Peta Jalan Tata Kelola Terpadu 363
14.1 Pendahuluan 363
14.2 GRC Terpadu 364
14.3 Fungsi dan Pilihan Alat GRC 368
14.4 Menyusun Peta Jalan GRC 372
14.5 Manajemen Perubahan dan Budaya 381
14.6 Mempresentasikan Rekomendasi kepada Direksi 383
14.7 Aktivitas: Peta Jalan GRC dan Gladi Presentasi C4 386
14.8 Ringkasan 387
14.9 Latihan 388

Daftar Pustaka 393

Bab 1

Orientasi Mata Kuliah dan Dasar-Dasar GRC

Tujuan Pembelajaran

- Membedakan tata kelola, manajemen, risiko, kontrol, kepatuhan, dan asurans dengan contoh dari organisasi tempat bekerja.
- Menjelaskan peran mata kuliah ini dalam capstone bersama dan luaran yang disumbangkan ke tiap tonggak.
- Memetakan pemangku kepentingan dan pemicu GRC pada organisasi yang dipilih tim.

1.1 Pendahuluan

Insiden data sering memunculkan tiga jawaban yang berbeda. Unit teknologi menunjuk konfigurasi, pengadaan menunjuk kontrak, dan vendor menunjuk instruksi pelanggan. Ketiganya mungkin benar, tetapi organisasi masih belum menjawab siapa yang harus memutuskan perbaikan dan siapa yang memeriksa hasilnya. Medikara Health menghadapi keadaan ini setelah kebocoran data pasien lewat vendor pada 2025. Tata kelola diperlukan agar keputusan, pelaksanaan, dan pertanggungjawaban saling terhubung.

Mata kuliah ini memakai istilah teknologi informasi (TI) untuk seluruh pemanfaatan informasi dan teknologi dalam layanan organisasi. *Governance, Risk, and Compliance* (GRC) menghubungkan arah organisasi, ketidakpastian yang mengancamnya, serta kewajiban yang harus dipenuhi. Analisis dimulai dari layanan pasien dan keputusan organisasi, bukan dari daftar produk keamanan. Bab ini sekaligus

membuka semester: tim terbentuk, organisasi terpilih, dan profil awal masuk ke tonggak C1 capstone.

Gambar 1.1 merangkum hubungan komponen dan konsep utama bab ini.



Kebijakan saja belum menunjukkan kontrol bekerja. Keputusan menyebut pemilik hasil, dasar bukti, dan waktu peninjauan.

Gambar 1.1: Dari tujuan layanan ke kontrol dan bukti GRC

Dua rujukan utama bab ini berasal dari International Organization for Standardization (ISO) bersama International Electrotechnical Commission (IEC), serta dari ISACA. ISO/IEC 38500:2024 menjadi acuan arah dan pengawasan pemanfaatan TI. Control Objectives for Information and Related Technologies (COBIT) 2019 membantu menghubungkan tujuan organisasi dengan sistem tata kelola. Istilah GRC mengikuti Open Compliance and Ethics Group (OCEG) serta Racz, Weippl, dan Seufert. Pembagian peran asurans mengikuti Three Lines Model dari The Institute of Internal Auditors (IIA). Semua rujukan dipakai sebagai alat berpikir, lalu diuji terhadap bukti pada kasus Medikara Health [79, 64, 117, 129, 151].

1.2 Mengapa Organisasi Membutuhkan Tata Kelola TI

Tata kelola TI menetapkan arah, hak keputusan, dan cara meminta pertanggungjawaban atas pemanfaatan TI. Weill dan Ross memandangnya sebagai penghubung antara keputusan TI dan tujuan perusahaan, sekaligus pemantau kinerja dan akuntabilitas [164]. Masalah teknis menjadi masalah tata kelola ketika pilihan tersebut memengaruhi manfaat, risiko, sumber daya, atau hak pihak lain. Membeli aplikasi tidak menyelesaikan masalah bila pemilik manfaat dan batas risikonya belum ditentukan.

Keputusan yang baik menyebut masalah layanan, alternatif, pihak terdampak, dasar keputusan, serta waktu peninjauan. Satu pihak boleh mengusulkan pembelian dan pihak lain menyetujuinya. Organisasi tetap membutuhkan pemilik hasil

bisnis yang bertanggung jawab setelah proyek selesai.

Analoginya seperti pengelola gedung. Pengelola tidak cukup membeli alarm kebakaran. Pengelola menetapkan siapa memeriksa alarm, siapa memimpin evakuasi, dan bagaimana penghuni mengetahui jalur keluar. Tata kelola TI memerlukan hubungan serupa antara tujuan, pelaksana, dan pemeriksa.

Dua contoh penerapannya:

1. Misalkan antrean pendaftaran pada 18 klinik turun dari 40 menjadi 25 menit setelah perubahan proses dan aplikasi. Direktur pelayanan menjadi pemilik hasil, sedangkan kepala TI bertanggung jawab pada kesiapan sistem. Bila waktu tunggu naik lagi dari 25 menit, direksi tahu siapa yang pertama diminta menjelaskan.
2. Misalkan integrasi baru untuk Medikara+ menelan Rp450 juta per tahun. Dengan 28.000 janji temu per bulan, atau 336.000 per tahun, biayanya sekitar Rp1.340 per janji temu. Keputusan menyetujuinya harus dibandingkan dengan nilai layanan serta biaya mempertahankan integrasi lama, bukan hanya harga implementasi.

Tiga gejala yang memaksa organisasi bertanya

Pertanyaan kemudian muncul: kapan kekosongan tata kelola mulai terasa? Umumnya lewat tiga gejala, yaitu proyek gagal, data bocor, dan temuan audit.

Gejala pertama adalah proyek gagal. Flyvbjerg dan Budzier mempelajari 1.471 proyek TI. Rata-rata pembengkakan biaya hanya 27 persen. Namun sekitar satu dari enam proyek masuk kelompok ekstrem, dengan pembengkakan biaya rata-rata 200 persen dan keterlambatan jadwal hampir 70 persen [41]. Misalkan Medikara menganggarkan Rp10 miliar untuk modernisasi. Angka rata-rata berarti Rp12,7 miliar. Angka kelompok ekstrem berarti Rp30 miliar. Selisih sebesar itu bukan lagi urusan jadwal. Organisasi perlu tahu siapa yang berhak menghentikan proyek dan pada batas apa.

Gejala kedua adalah data bocor. Laporan Verizon 2026 mencatat keterlibatan pihak ketiga pada 48 persen pelanggaran data, naik dari 30 persen pada edisi sebelumnya [160]. Laporan IBM 2026 mencatat rata-rata biaya pelanggaran data global 4,99 juta dolar Amerika Serikat, dari 602 organisasi [56]. Kedua angka tidak boleh langsung dipindahkan ke Medikara, karena populasi dan cara hitungnya berbeda. Laporan industri dipakai untuk mengajukan pertanyaan yang tepat, bukan untuk meramal kerugian satu organisasi.

Gejala ketiga adalah temuan audit. Fakta dasar Medikara memuat temuan audit internal tentang kontrol akses yang lemah. Misalkan audit memeriksa 30 dari 120 akun vendor dan menemukan 6 akun masih aktif setelah penugasan

berakhir, atau 20 persen sampel. Bila sampel mewakili populasi, sekitar 24 akun bermasalah. Bila sampel dipilih tidak acak, perkiraan itu gugur. Temuan baru bermakna ketika punya pemilik, tenggat, dan bukti penutupan.

Tabel 1.1 merangkum empat pemicu GRC Medikara dan pertanyaan keputusan yang menyertainya.

Tabel 1.1: Pemicu GRC dan pertanyaan keputusan

Pemicu	Pertanyaan organisasi	Bukti awal
Kebocoran vendor 2025	Siapa membatasi akses vendor?	Kontrak dan daftar akun
Temuan kontrol akses	Siapa menutup temuan dan kapan?	Laporan audit
Antrean panjang	Siapa memiliki hasil layanan?	Waktu tunggu agregat
Biaya integrasi tinggi	Integrasi mana yang memberi nilai?	Biaya dan manfaat

Kasus Medikara Health: Insiden Vendor 2025 dalam Data Latihan

Fakta dasar kasus hanya menyebut kebocoran data pasien skala kecil lewat vendor pada 2025. Mata kuliah IT40613 menambahkan data latihan berikut, dan bab ini memakai angka yang sama. Misalkan kontrak pekerjaan vendor sudah selesai, tetapi akun dukungan vendor tetap aktif. Selama 8 malam akun itu memanggil data kunjungan pada dua rumah sakit, 155 panggilan per malam, sehingga 1.240 rekam kunjungan terbaca tanpa hubungan layanan dengan pekerjaan vendor. Medikara baru mengetahuinya pada hari ke-11, lewat keluhan pasien.

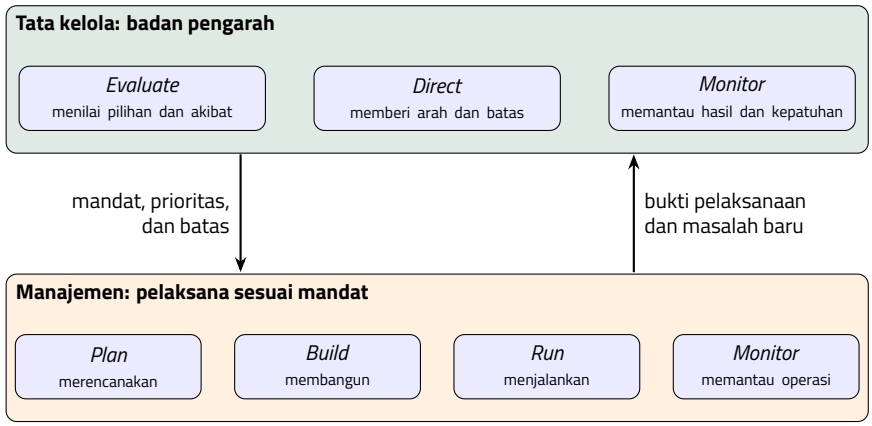
Angka 1.240 setara sekitar 0,1 persen dari 1,2 juta kunjungan per tahun. Biaya langsung latihan ini hanya Rp23,7 juta, belum termasuk sanksi, kehilangan kepercayaan, dan akibat bagi pasien. Dua angka kecil itu tidak menjawab pertanyaan tata kelola. Siapa berwenang mencabut akun ketika kontrak berakhir? Siapa memantau pemakaiannya? Siapa memutuskan pemberitahuan kepada pasien? Bab 7 memakai data latihan ini dan menambahkan jamnya: hari ke-1 Selasa pukul 20.00 WIB dan hari ke-11 Jumat pukul 20.00 WIB, lalu menghitung tenggat dari kronologi itu.

1.3 Tata Kelola dan Manajemen

Pertanyaan berikutnya: siapa menetapkan arah, dan siapa menjalankannya? Tata kelola menilai pilihan, memberi arah, dan memantau hasil. Manajemen menerjemahkan arah menjadi rencana, pelaksanaan, serta pengendalian operasi. Kedua-

nya bekerja berulang: manajemen membawa bukti dan masalah baru, lalu pihak berwenang meninjau keputusan bila konteks berubah.

COBIT 2019 memisahkan keduanya secara tegas. Tata kelola bekerja lewat *Evaluate, Direct, and Monitor*. Manajemen bekerja lewat *Plan, Build, Run, and Monitor*, sesuai arah dari badan pengarah. Dari 40 objektif dalam lima domain, satu domain berisi tata kelola dan empat domain berisi manajemen [64]. ISO/IEC 38500:2024 memakai tiga tugas yang sama untuk badan pengarah [79]. Bab 2 dan Bab 4 membahas rinciannya. Gambar 1.2 memperlihatkan pembagian dan arus informasi di antara keduanya.



Gambar 1.2: Pembagian tugas dan arus informasi antara tata kelola dan manajemen

Analoginya seperti pemilik restoran dan manajer dapur. Pemilik menentukan jenis layanan, batas harga, dan standar kebersihan. Manajer dapur menyusun giliran kerja dan memeriksa bahan setiap pagi. Pemilik tetap meminta laporan mutu, tetapi tidak perlu memilih urutan memasak setiap pesanan.

Dua contoh penerapannya:

1. Misalkan direksi menyetujui modernisasi lima rumah sakit dengan syarat layanan tetap berjalan. Manajemen menyusun jadwal migrasi bertahap dan prosedur pemulihan. Syarat itu keputusan tata kelola. Urutan kelima rumah sakit adalah keputusan manajemen.
2. Misalkan komite hanya menerima laporan 90 persen pekerjaan selesai. Tanpa menilai manfaat dan risiko yang tersisa, komite belum memiliki dasar untuk mengizinkan peluncuran. Sisa 10 persen bisa saja berisi pekerjaan yang paling menentukan.

Tabel 1.2 merangkum pembagian arah dan pelaksanaan pada tiga keputusan Medikara.

Tabel 1.2: Pembagian arah dan pelaksanaan

Keputusan	Tata kelola	Manajemen
Identitas pasien tunggal	Tetapkan tujuan dan pemilik manfaat	Susun rencana integrasi
Akses vendor	Tetapkan batas dan penanggung jawab	Berikan dan cabut akun
Investasi layanan	Pilih prioritas dan batas biaya	Kelola kontrak dan jadwal

Jabatan bukan penentu

Dua hal sering tertukar: jabatan penanda tangan dan jenis keputusan. Pembagiannya begini. Memberi persetujuan atas batas investasi berbeda dari menyetujui jadwal pemasangan server. Keputusan pertama mengalokasikan sumber daya dan menerima konsekuensi organisasi. Keputusan kedua menjalankan rencana dalam kewenangan yang sudah diberikan. Seorang direktur yang menandatangani jadwal sedang menjalankan manajemen. Seorang kepala TI yang ikut memilih prioritas investasi di komite sedang ikut dalam tata kelola.

Pembedaan ini punya dua konsekuensi. Pertama, batas eskalasi harus tertulis. Misalkan direksi menyetujui integrasi Rp450 juta per tahun dengan toleransi 10 persen, sehingga batas atasnya Rp495 juta. Kenaikan menjadi Rp480 juta masih dalam kewenangan manajemen. Kenaikan menjadi Rp540 juta, atau 20 persen, kembali ke direksi. Kedua, isi laporan ke direksi berubah. Laporan tidak perlu memuat jadwal pemasangan di 18 klinik satu per satu. Laporan memuat manfaat, risiko sisa, dan pilihan yang menunggu keputusan.

1.4 Istilah Dasar GRC

Keputusan dan pelaksanaan memerlukan bahasa yang sama. Apa beda risiko, kontrol, kepatuhan, dan asurans? ISO 31000:2018 mendefinisikan risiko sebagai efek ketidakpastian terhadap tujuan, dan kontrol sebagai tindakan yang mempertahankan atau mengubah risiko [69]. Kepatuhan adalah pemenuhan kewajiban yang berlaku, baik dari hukum, kontrak, maupun komitmen yang dipilih organisasi. Asurans, menurut IIA, adalah pernyataan yang dimaksudkan untuk meningkatkan keyakinan pemangku kepentingan atas proses tata kelola, manajemen risiko, kepatuhan, dan kontrol [151]. Keyakinan itu lahir dari penilaian berbasis bukti. Keempat istilah terhubung, tetapi menjawab pertanyaan berbeda.

Analoginya seperti aturan kas kecil. Aturan menetapkan batas pengeluaran, bukti kuitansi, dan pihak yang menyetujui. Kuitansi menunjukkan transaksi terjadi. Pemeriksaan silang terhadap buku kas memberi keyakinan bahwa aturan benar-

benar dijalankan.

Dua contoh penerapannya:

1. Misalkan risiko R-01 adalah akses vendor yang berlebihan menyebabkan pengungkapan data pasien. Kontrol AC-01 berupa peninjauan akses berkala menguji apakah hak akses masih diperlukan. Kode R-01 dan AC-01 tetap dipakai sampai Bab 14.
2. Misalkan seluruh karyawan yang berjumlah sekitar 4.800 orang sudah menandatangani kebijakan akses, tetapi 6 dari 30 akun vendor yang diperiksa belum dicabut setelah penugasan berakhir. Kepatuhan administratif belum membuktikan efektivitas pencabutan akses.

Tabel 1.3 merangkum istilah GRC dan bukti penerapannya.

Tabel 1.3: Istilah GRC dan bukti penerapannya

Istilah	Pertanyaan	Contoh bukti
Tata kelola	Siapa memutuskan arah dan batas?	Notulen dan delegasi
Manajemen	Bagaimana arah dijalankan?	Rencana dan laporan kerja
Risiko	Apa yang mengancam tujuan?	Skenario R-01
Kontrol	Apa yang mengubah risiko?	Hasil peninjauan AC-01
Kepatuhan	Kewajiban mana yang dipenuhi?	Register kewajiban
Asurans	Mengapa hasil layak dipercaya?	Kertas kerja pengujian

Kasus Medikara Health: Dari Insiden ke Pemilik Keputusan

Kebocoran data skala kecil melalui vendor pada 2025 adalah fakta kasus. Misalkan tim menelusuri insiden itu ke akun dukungan yang masih aktif setelah kontrak pekerjaan selesai. Tim mencatat R-01, menetapkan pemilik risiko pada fungsi bisnis yang menentukan pemrosesan, dan mengusulkan AC-01. Bukti yang diminta adalah daftar akun, dasar pemberian akses, hasil peninjauan, serta tindakan pencabutan. Besar kecilnya insiden tidak menghilangkan kebutuhan menilai kewajiban hukum. Pasal 46 Undang-Undang (UU) Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi (PDP) mengatur pemberitahuan tertulis paling lambat 3×24 jam [136]. Bab 7 mengujinya dengan kronologi.

Kebijakan, standar, prosedur, dan pedoman

Empat dokumen ini sering tertukar. Pembagiannya begini. Kebijakan menyatakan arah dan batas. Standar organisasi menetapkan persyaratan minimum. Prosedur menjelaskan urutan kerja. Pedoman membantu memilih cara yang sesuai, tanpa mengikat. Kata "standar" di sini berarti aturan internal organisasi, berbeda dari standar internasional seperti ISO/IEC 27001. Tabel 1.4 memakai kontrol AC-01 sebagai contoh.

Tabel 1.4: Dokumen dan catatan untuk kontrol AC-01 (angka pengandaian)

Jenis	Isi pada AC-01
Kebijakan	Akses vendor hanya berlaku selama penugasan
Standar organisasi	Akun dicabut paling lambat 1 hari kerja setelah penugasan berakhir, dan ditinjau setiap bulan
Prosedur	Pengelola vendor menarik daftar akun, pemilik layanan menandai akun yang masih perlu, admin mencabut sisanya
Pedoman	Pakai akun per orang, bukan akun bersama, bila sistem memungkinkan
Catatan sebagai bukti	Peninjauan bulan berikutnya: 120 akun ditinjau, 24 akun dicabut, tanggal dan penanggung jawab tercatat

Kebijakan tanpa prosedur dan bukti pelaksanaan belum menunjukkan bahwa kontrol bekerja. Baris terakhir pada tabel itulah yang dibaca auditor.

Siapa memberi keyakinan?

Pertanyaan kemudian muncul: siapa yang memeriksa, kalau pelaksana tidak boleh menilai pekerjaannya sendiri? Three Lines Model dari IIA membedakan peran, bukan departemen. Manajemen sebagai lini pertama memiliki dan mengelola risiko. Peran lini kedua memberi keahlian, dukungan, pemantauan, dan tantangan. Audit internal sebagai lini ketiga memberi asurans yang independen dan objektif. Badan pengarah memberi arah strategis dan pengawasan [151]. Tabel 1.5 menerapkannya pada AC-01, dengan contoh pemilik Sistem Informasi Manajemen Rumah Sakit (SIMRS). Bab 12 membahas model ini lebih dalam.

Tabel 1.5: Three Lines Model pada kontrol AC-01

Peran	Contoh pemilik	Tanggung jawab
Badan pengarah	Direksi dan dewan komisaris sesuai kewenangan	Menetapkan arah dan meminta laporan
Lini pertama	Pemilik SIMRS dan layanan	Menjalankan kontrol AC-01
Lini kedua	Risiko, privasi, keamanan	Memantau dan menantang
Lini ketiga	Audit internal	Menguji secara independen

Pembedaan ini berlaku juga untuk vendor. IIA menegaskan bahwa kegiatan yang dialihkan ke penyedia luar tidak berubah perannya dalam model, dan akuntabilitas badan pengarah atas kegiatan itu tidak berubah [151]. Medikara dapat menyerahkan pekerjaan kepada vendor, tetapi tidak dapat menyerahkan pertanggungjawaban atas keputusannya.

1.5 GRC sebagai Satu Kesatuan

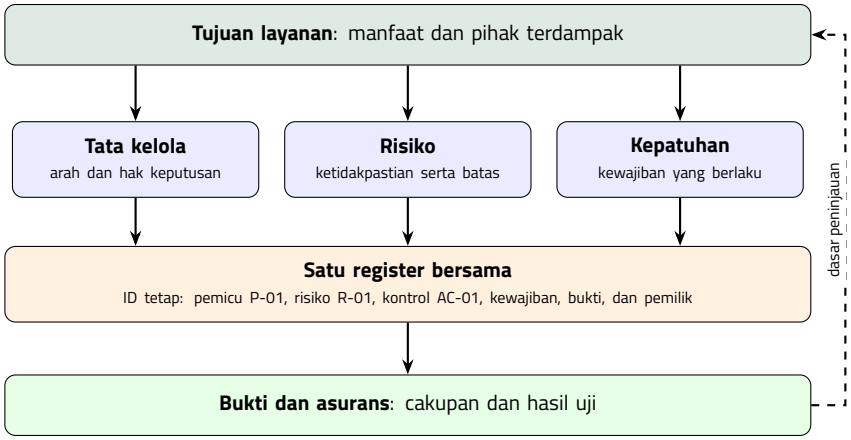
Bila tiap istilah menjawab pertanyaan berbeda, mengapa ketiganya disatukan dalam satu singkatan? OCEG mendefinisikan GRC sebagai kumpulan kemampuan terpadu yang memungkinkan organisasi mencapai tujuan secara andal, sekaligus menangani ketidakpastian dan bertindak dengan integritas [117]. Racz, Weippl, dan Seufert merumuskan GRC sebagai pendekatan terpadu dan menyeluruh terhadap tata kelola, risiko, dan kepatuhan di seluruh organisasi. Pendekatan itu memastikan organisasi bertindak etis dan sesuai dengan *risk appetite*, kebijakan internal, serta regulasi, lewat penyelarasan strategi, proses, teknologi, dan orang [129, 128]. Kedua definisi menyimpulkan hal yang sama: GRC bukan tiga unit yang terpisah, dan bukan satu produk perangkat lunak.

Analoginya seperti pasien yang berobat ke tiga dokter tanpa rekam medis bersama. Tiap dokter meminta pemeriksaan darah sendiri, memberi resep sendiri, dan tidak tahu obat dari dokter lain. Setiap dokter bekerja benar menurut catatannya, tetapi pasien menanggung biaya berlipat dan risiko obat yang saling berbenturan.

Dua contoh penerapannya:

1. Misalkan audit internal, bagian kepatuhan, dan keamanan informasi masing-masing meminta daftar akun kepada 5 rumah sakit dan 18 klinik setiap triwulan. Jumlahnya $3 \times 23 \times 4 = 276$ permintaan per tahun untuk bukti yang sama. Dengan satu register dan satu jadwal, permintaan turun menjadi $23 \times 4 = 92$. Bila satu permintaan memakan 2 jam kerja, fasilitas menghemat $184 \times 2 = 368$ jam per tahun.
2. Misalkan kontrol AC-01 mendukung tiga acuan sekaligus: UU 27/2022 Pasal 35, 36, 37, dan 39, dengan Pasal 39 sebagai acuan utama, ISO/IEC 27001:2022 Annex A 5.18, dan National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) 2.0 PR.AA-05. Tanpa register bersama, satu kontrol tercatat tiga kali dengan tiga nama. Pemetaan ini menunjukkan kontribusi, bukan kesetaraan, sehingga tiap acuan tetap diperiksa pada Bab 14.

Gambar 1.3 memperlihatkan bentuk kerja terpadu. Ketiga fungsi berangkat dari tujuan layanan yang sama dan mencatat hasilnya pada satu register. Tabel 1.6 membandingkannya dengan cara kerja terpisah.



Gambar 1.3: GRC terpadu: tiga fungsi berbagi satu tujuan, satu register, dan satu dasar peninjauan

Tabel 1.6: Cara kerja terpisah dan terpadu

Aspek	Terpisah	Terpadu
Pengenal	Tiap unit punya nama sendiri	ID tetap: R-01, AC-01
Permintaan bukti	276 permintaan per tahun	92 permintaan per tahun
Laporan ke direksi	Tiga laporan, tiga skala	Satu gambaran, sumber dapat ditelusuri
Peninjauan	Menurut jadwal tiap unit	Menurut tujuan layanan dan pemicu

Alur yang sama tampak pada Gambar 1.1. Tujuan layanan memberi dasar prioritas bagi tata kelola, dan konteks penilaian bagi risiko dan kewajiban. Tata kelola memberi mandat kepada manajemen. Risiko dan kewajiban menjadi dasar penanganan, yang diwujudkan dalam kontrol yang dijalankan. Kontrol menjadi persyaratan operasi bagi manajemen. Manajemen menghasilkan bukti pelaksanaan, yang dinilai dalam bukti dan asurans. Hasilnya menjadi dasar peninjauan bagi tata kelola, dan siklus berulang.

Terpadu tidak berarti dilebur

Dua hal pada GRC sering tertukar: terpadu dan dilebur. Pembagiannya begini. Terpadu berarti memakai tujuan, pengenal, dan bukti yang sama. Dilebur berarti satu unit mengerjakan semua peran. Peleburan justru merusak asurans, karena pelaksana menilai pekerjaannya sendiri. IIA menempatkan independensi sebagai dasar asurans yang dapat dipercaya, sekaligus mengingatkan bahwa independensi tidak boleh ditafsirkan sebagai isolasi [151].

Keputusan memakai satu register punya dua konsekuensi. Pertama, register memerlukan pemilik dan aturan perubahan, karena satu kesalahan kini terbaca

oleh semua unit. Kedua, organisasi menanggung biaya menyamakan istilah di awal. Misalkan menyamakan 40 baris risiko memakan 20 jam kerja. Biaya itu sebanding bila menghemat 368 jam per tahun seperti pada contoh di atas, tetapi belum tentu sebanding bagi organisasi yang hanya punya satu lokasi. Bab 14 membahas alat GRC, setelah cara kerjanya jelas.

1.6 Peta Kerangka dan Regulasi

Rujukan mana yang dipakai untuk pertanyaan tertentu? Kerangka menyediakan cara mengelompokkan masalah. Standar menyediakan prinsip, panduan, atau persyaratan sesuai jenisnya. Regulasi menetapkan kewajiban hukum dalam ruang lingkup tertentu. Organisasi memilih kerangka berdasarkan pertanyaan yang perlu dijawab, lalu menelusuri kewajiban ke sumber hukum aslinya.

Analoginya seperti peta jalan, aturan lalu lintas, dan buku servis kendaraan. Peta membantu memilih rute. Aturan mengikat pengguna jalan. Buku servis membantu merawat kendaraan. Ketiganya dapat dipakai dalam satu perjalanan tanpa saling menggantikan.

Dua contoh penerapannya:

1. Misalkan Medikara perlu menetapkan siapa menerima risiko layanan. ISO/IEC 38500 dan COBIT membantu merancang hak keputusan. Daftar konfigurasi server tidak menjawab pertanyaan tersebut. Medikara juga tidak perlu menjalankan semuanya sekaligus: bila 52 staf TI menanggung 40 objektif COBIT, satu objektif hanya kebagian 1,3 orang. Karena itu Bab 4 memilih objektif prioritas.
2. Misalkan tim perlu menentukan masa simpan rekam medis. Tim membaca peraturan sektor kesehatan terlebih dahulu, lalu mencari kontrol dan arsitektur yang mendukungnya. Urutan terbalik membuat 5 rumah sakit membangun fitur untuk kewajiban yang belum dibaca.

Tabel 1.7 merupakan peta belajar, bukan daftar yang harus diterapkan seluruhnya. Nama standar dicantumkan bersama versinya agar keputusan dapat ditelusuri ketika rujukan berubah. Tabel itu memakai beberapa singkatan: Information Technology Infrastructure Library (ITIL), Peraturan Menteri Kesehatan (Permenkes), Peraturan Pemerintah (PP), Committee of Sponsoring Organizations of the Treadway Commission (COSO), *Enterprise Risk Management* (ERM), dan *Artificial Intelligence* (AI).

Tabel 1.7: Peta pertanyaan dan rujukan semester

Pertanyaan	Rujukan	Jenis	Bab
Siapa memberi arah dan memutuskan?	ISO/IEC 38500:2024 [79]	Prinsip	2, 8
Bagaimana sistem tata kelola disusun?	COBIT 2019 [64], ITIL [7]	Kerangka	4, 8
Aturan mana yang mengikat?	UU 27/2022 [136], Permenkes 24/2022 [88], PP 71/2019 [134]	Hukum	3, 7
Ketidakpastian mana yang mengancam tujuan?	ISO 31000:2018 [69], COSO ERM 2017 [23]	Panduan	5
Apakah informasi dan vendor aman?	ISO/IEC 27001:2022 [75], NIST CSF 2.0 [104]	Persyaratan, kerangka	6, 9
Apakah layanan bertahan saat gangguan?	ISO 22301:2019 [70]	Persyaratan	10
Bagaimana AI dikendalikan?	ISO/IEC 42001:2023 [78]	Persyaratan	11
Mengapa hasil layak dipercaya?	Global Internal Audit Standards [150], Three Lines Model [151]	Standar profesi, model peran	12, 13, 14

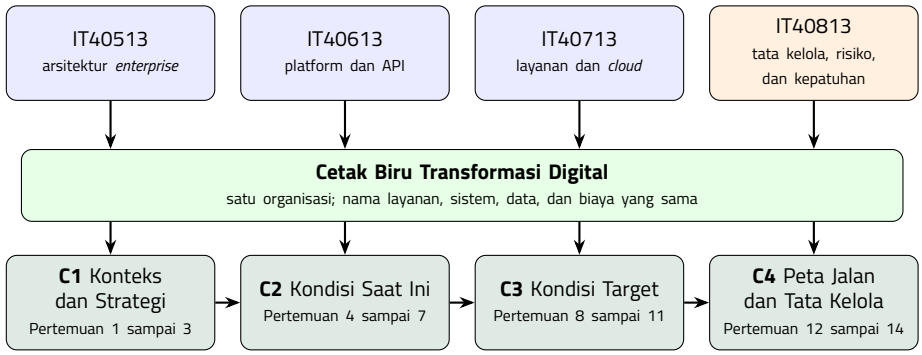
Patuh dan bersertifikat

Dua hal sering tertukar: mematuhi hukum dan memegang sertifikat. Pembagiannya begini. Regulasi berlaku karena organisasi masuk ruang lingkupnya, tanpa perlu memilih. Standar seperti ISO/IEC 27001 dipilih organisasi, atau diminta oleh mitra lewat kontrak. Sertifikat menunjukkan sistem manajemen memenuhi persyaratan untuk ruang lingkup tertentu. Sertifikat tidak membuktikan pemenuhan seluruh kewajiban UU PDP. Sebaliknya, memenuhi satu pasal hukum juga belum berarti risikonya terkendali, dan Latihan 2 menguji hal ini.

Versi rujukan perlu diperiksa ulang. Per 30 Oktober 2026, informasi produk ISACA telah menyebut COBIT 7, sementara halaman kerangka resminya masih menyediakan publikasi COBIT 2019. PeopleCert menerbitkan ITIL (Version 5) pada 2026. ISO 31000 dan ISO 22301 sedang direvisi. Modul ini memakai versi yang tertulis pada tabel. Tim mencatat versi yang dipakai dan tanggal pemeriksaannya, bukan menebak isi versi berikutnya.

1.7 Capstone Bersama dan Kasus Medikara Health

Di mana semua konsep itu diterapkan? Capstone menghasilkan satu Cetak Biru Transformasi Digital yang dipelihara bersama empat mata kuliah. IT40513 menyusun arsitektur *enterprise*, IT40613 menyusun platform dan *Application Programming Interface* (API), IT40713 merancang layanan serta infrastruktur *cloud*, dan IT40813 menetapkan tata kelola, risiko, serta kepatuhan. Artefak harus menggunakan nama layanan, sistem, data, dan angka biaya yang sama. Gambar 1.4 memperlihatkan hubungan keempat mata kuliah dengan tonggak C1 sampai C4.



Gambar 1.4: Empat mata kuliah mengisi satu cetak biru lewat empat tonggak

Analoginya seperti satu rancangan gedung. Gedung memerlukan gambar arsitektur, struktur, listrik, dan jalur evakuasi yang memakai ukuran sama. Empat gambar yang bagus tetapi berbeda letak pintunya tidak membentuk rancangan yang dapat dibangun.

Dua contoh penerapannya:

1. Misalkan IT40613 membuka API hasil laboratorium dari 1 laboratorium rujukan ke 18 klinik. GRC harus menilai penerima data, tujuan akses, dan kontrolnya sebelum arsitektur target disepakati.
2. Misalkan IT40713 memindahkan Medikara+, dengan 28.000 janji temu per bulan, ke *cloud*. GRC meninjau tanggung jawab vendor dan persyaratan lokasi data, lalu mengembalikan batasan kepada tim arsitektur.

Tabel 1.8 merangkum tonggak dan kontribusi GRC. Perubahan pada satu tonggak bisa kembali ke tonggak sebelumnya. Bila arsitektur berubah pada C3, daftar risiko dari C2 ikut ditinjau.

Tabel 1.8: Tonggak dan kontribusi GRC

Tonggak	Pertemuan	Luaran utama
C1 Konteks dan Strategi	1 sampai 3	Profil, hak keputusan, kewajiban
C2 Kondisi Saat Ini	4 sampai 7	Kapabilitas, risiko, celah keamanan dan privasi
C3 Kondisi Target	8 sampai 11	Tata kelola target, vendor, kelangsungan, AI
C4 Peta Jalan dan Tata Kelola	12 sampai 14	Asurans, indikator, peta jalan

Kasus Medikara Health: Profil yang Dipakai Bersama

PT Medikara Nusa Sehat ("Medikara Health") adalah organisasi fiktif, jaringan layanan kesehatan swasta dengan 5 rumah sakit (Jakarta, Bekasi, Depok, Bogor, Bandung), 18 klinik pratama, 1 laboratorium rujukan, dan 12 apotek. Sekitar 4.800 karyawan melayani sekitar 1,2 juta kunjungan pasien per tahun. Mata kuliah lain menambahkan rincian sekitar 640 dokter, 52 staf TI dengan tim platform 6 orang, dan 28.000 janji temu per bulan lewat Medikara+.

SIMRS berjalan *on-premise* di tiap rumah sakit dengan versi berbeda karena hasil akuisisi. *Enterprise Resource Planning* (ERP) keuangan sudah terpusat. Medikara+ dibuat oleh vendor. Integrasi ke Badan Penyelenggara Jaminan Sosial (BPJS) Kesehatan dan SATUSEHAT berbentuk *point-to-point*. Data pasien tersebar, dan banyak laporan manajemen masih disusun dengan *spreadsheet*.

Strategi 2026 sampai 2030 bernama "Satu Pasien, Satu Rekam Medis". Pemicunya ada empat: insiden kebocoran vendor pada 2025, temuan audit internal tentang kontrol akses, antrean layanan yang panjang, dan biaya integrasi yang tinggi. Fakta dasar ini tetap. Rincian tambahan dalam bab ini ditandai "Misalkan" atau "data latihan".

1.8 Pemangku Kepentingan dan Pemicu GRC

Setelah organisasi dipilih, siapa saja yang harus diperhitungkan? Freeman mendefinisikan pemangku kepentingan sebagai kelompok atau individu yang dapat memengaruhi, atau terpengaruh oleh, pencapaian tujuan organisasi [42]. Definisi itu memuat dua arah, yaitu pengaruh dan dampak. Peta pemangku kepentingan menampilkan keduanya, lalu menunjukkan siapa berkepentingan, siapa memutuskan, dan siapa terdampak. Pemicu GRC adalah peristiwa atau keadaan yang memaksa organisasi mengambil keputusan, misalnya insiden, temuan audit, atau

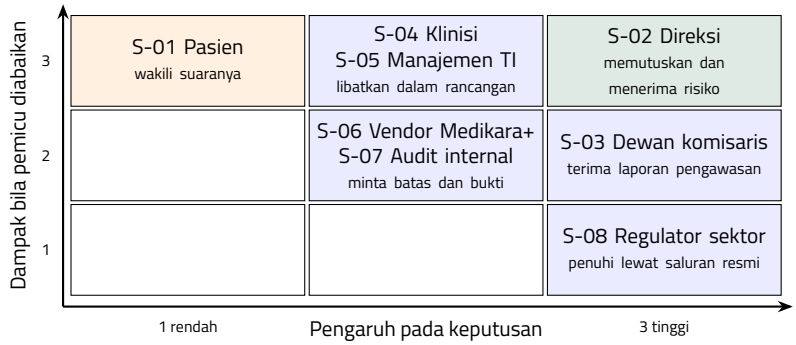
aturan baru.

Analoginya seperti rapat RT yang memutuskan jam penutupan portal. Ketua dan pengurus hadir, lalu keputusan diambil dengan sah. Warga di ujung gang yang pulang malam tidak hadir, padahal merekalah yang paling terdampak. Keputusan yang sah belum tentu sudah mendengar pihak yang menanggung akibatnya.

Dua contoh dari Medikara Health:

1. Pada insiden vendor, data latihan mencatat 1.240 rekam kunjungan terbaca. Pasien menanggung dampak tinggi, tetapi tidak hadir di rapat. Bila rapat hanya melihat biaya langsung Rp23,7 juta, insiden tampak selesai. Bila kepentingan pasien diwakili, pertanyaan berpindah ke pemberitahuan dan pemulihan kepercayaan.
2. Pada pemicu antrean, misalkan 720.000 dari 1,2 juta kunjungan terjadi di 18 klinik. Penurunan antrean 15 menit berarti $720.000 \times 15 \div 60 = 180.000$ jam waktu tunggu pasien per tahun. Angka sebesar ini tidak muncul bila laporan hanya menghitung biaya TI.

Gambar 1.5 memetakan delapan pemangku kepentingan Medikara untuk pemicu insiden vendor. Skala 1 sampai 3 adalah penilaian tim, bukan pengukuran. Sel oranye menandai pihak yang berdampak tinggi tetapi berpengaruh rendah, sehingga perlu wakil yang jelas.



Gambar 1.5: Peta pemangku kepentingan Medikara untuk pemicu insiden vendor (penilaian contoh)

Dua hal pada peta ini sering tertukar: pengaruh dan dampak. Pembagiannya begini. Pengaruh adalah kemampuan mengubah keputusan. Dampak adalah besarnya akibat yang ditanggung bila pemicu diabaikan. Regulator sektor berpengaruh tinggi, tetapi bukan pihak yang kehilangan kerahasiaan. Pasien mengalami sebaliknya. Pemetaan ini punya dua konsekuensi. Pertama, tim tidak boleh mengurutkan pihak hanya menurut jabatan. Kedua, sel kosong perlu dibaca. Sel kiri bawah yang kosong wajar, tetapi sel kiri atas yang kosong patut dicurigai, karena tim mungkin belum mencari pihak yang tidak hadir di rapat.

Menulis pemicu tanpa mencampur fakta dan dugaan

Pemicu yang berguna menyebut tujuan terdampak, status informasi, sumber dengan tanggal, dan keputusan yang diperlukan. Tim mencatat tiga sampai lima pemicu. Kurang dari tiga membuat profil terlalu sempit, dan lebih dari lima membuat prioritas kabur. Status informasi menjaga kejujuran analisis. Tabel 1.9 memperlihatkan empat status pada pemicu P-01.

Tabel 1.9: Status informasi pada pemicu P-01 insiden vendor

Status	Isi	Dasar atau bukti
Fakta kasus	Kebocoran data pasien skala kecil lewat vendor pada 2025	Profil kasus
Data latihan	Akun dukungan vendor, 8 malam, 1.240 rekam	Kronologi IT40613
Dugaan	Kredensial dipakai bersama, karena catatan hanya memuat ID aplikasi	Perlu keterangan vendor
Belum diketahui	Apakah data disalin keluar dari sistem vendor	Perlu pemeriksaan di sisi vendor, sesuai kontrak

Keputusan menuliskan status punya dua konsekuensi. Pertama, dugaan tidak berubah menjadi fakta hanya karena sering diulang dalam rapat. Kedua, baris "belum diketahui" berubah menjadi daftar pekerjaan pengumpulan bukti, lengkap dengan pemiliknya.

1.9 Cara Belajar Mandiri dan Menilai Bukti

Bagaimana semua ini dikerjakan secara mandiri, dan kapan sebuah bukti layak dipercaya? Belajar mandiri dimulai dari membaca masalah, menelaah konsep, memeriksa satu sumber primer, lalu mengerjakan artefak. Pertemuan hari Sabtu dipakai untuk menguji keputusan tim dan menyelesaikan perbedaan penafsiran. Slide membantu mengingat alur. Naskah bab dan sumber primer menjelaskan alasan serta batasannya. Folder `sources/` menyediakan templat dan data latihan untuk tiap bab.

Bukti perlu memiliki asal, tanggal, ruang lingkup, dan pemilik. Wawancara adalah titik awal, bukan pengganti seluruh dokumen. Ketiadaan bukti ditulis "belum diverifikasi". Data organisasi nyata memerlukan izin dan anonimisasi, dan identitas pasien serta karyawan tidak dimasukkan ke repositori.

Analoginya seperti memeriksa struk belanja. Pemeriksa memerlukan tanggal, toko, barang, dan jumlah. Foto selembar kertas tanpa asal tidak cukup untuk menguji pengeluaran. Bukti GRC memerlukan konteks yang sama jelasnya.

Dua contoh penerapannya:

1. Misalkan wawancara menyatakan semua akun ditinjau setiap bulan. Tim meminta hasil dua periode dan mencocokkan populasi 120 akun dengan daftar penugasan aktif. Sampel 30 akun baru mencakup 25 persen populasi, sehingga kesimpulannya ditulis sebatas cakupan itu.
2. Misalkan regulasi ditemukan melalui berita. Tim menyimpan berita sebagai petunjuk pencarian, lalu memeriksa judul, naskah, perubahan, dan tanggal berlakunya pada sumber resmi.

Bukti juga punya umur. Pada data latihan insiden vendor, catatan rinci hanya disimpan 7 hari. Ketika kejadian diketahui pada hari ke-11, yang tersisa hanya rekam malam ke-5 sampai ke-8, yaitu 620 dari 1.240 rekam. Separuh rekam tidak lagi dapat ditelusuri. Keputusan masa simpan catatan akses, yang tampak teknis, ternyata menentukan apa yang dapat dibuktikan kepada pasien dan regulator. Tabel 1.10 merangkum empat pertanyaan untuk tiap bukti.

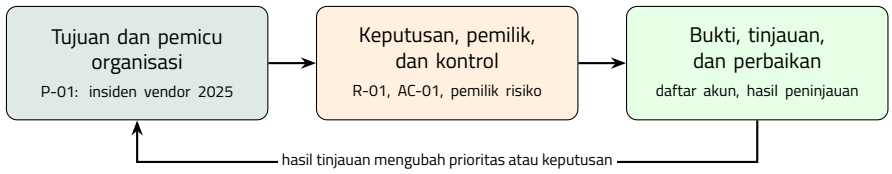
Tabel 1.10: Empat pertanyaan untuk tiap bukti, dengan contoh AC-01

Unsur	Pertanyaan	Contoh jawaban (pengandaian)
Asal	Dari sistem atau orang mana?	Ekspor daftar akun SIMRS
Tanggal	Kapan dan untuk periode apa?	Oktober 2026, satu bulan
Ruang lingkup	Apa yang tercakup dan tidak?	Akun vendor, satu rumah sakit
Pemilik	Siapa dapat menjelaskannya?	Kepala operasi TI

Tabel 1.11 merangkum ritme belajar mingguan, dan Gambar 1.6 menghubungkan langkah utama bab ini menjadi satu siklus.

Tabel 1.11: Ritme belajar mingguan

Tahap	Pekerjaan	Hasil yang diperiksa
Sebelum diskusi	Baca bab dan sumber primer	Catatan masalah dan pertanyaan
Kerja tim	Isi lembar kerja dengan bukti	Draf artefak bertanggal
Sabtu	Uji alasan dan alternatif	Keputusan serta tindak lanjut
Sesudah diskusi	Perbarui artefak bersama	Versi siap masuk capstone



Gambar 1.6: Siklus tujuan, keputusan, dan bukti untuk pekerjaan GRC

1.10 Aktivitas: Profil Organisasi dan Peta Pemangku Kepentingan

Tujuan. Menetapkan konteks dan pemicu GRC yang akan dipakai sepanjang semester, sehingga artefak keempat mata kuliah berangkat dari organisasi dan istilah yang sama.

Pembagian peran. Tim campuran terdiri atas empat peran yang dipakai sampai Bab 14. Tiap anggota memegang satu peran. Tabel 1.12 merangkumnya.

Tabel 1.12: Peran tim sepanjang semester

Peran	Tanggung jawab	Luaran pada bab ini
Pemilik konteks	Anggota yang paling mengenal organisasi, menyusun profil dan mengurus izin	Profil satu halaman
Analis regulasi	Membaca aturan dan menelusuri pemicu hukum	Sumber resmi tiap pemicu hukum
Analis risiko	Menilai dampak dan merumuskan akibat terhadap layanan	Daftar pemicu, peta dampak
Analis teknologi	Memahami sistem dan hubungan vendor	Daftar sistem dan vendor

Langkah kerja.

1. Bentuk tim campuran dan pilih organisasi: tempat kerja salah satu anggota, dengan izin dan data yang dianonimkan, atau Medikara Health.
2. Bila memakai organisasi nyata, isi panduan izin sebelum mengambil data apa pun.
3. Isi profil satu halaman: layanan, skala, strategi, sistem utama, dan batas analisis.
4. Catat tiga sampai lima pemicu. Pisahkan fakta, dugaan, dan rincian pengandaian.
5. Isi peta pemangku kepentingan berdasarkan pengaruh, dampak, dan keputusan yang diperlukan. Tandai siapa berkepentingan, siapa memutuskan, dan siapa terdampak.
6. Tinjau silang dengan profil di tiga mata kuliah lain, lalu samakan nama layanan, sistem, dan data.
7. Simpan versi bertanggal dan daftar bukti yang masih dibutuhkan untuk tinjauan hari Sabtu.

Luaran. Profil organisasi satu halaman, daftar tiga sampai lima pemicu GRC,

dan peta pemangku kepentingan.

Kaitan dengan tonggak capstone. Ketiga luaran menjadi bagian C1 Konteks dan Strategi. Artefak ini dipakai kembali pada Bab 2 ketika menyusun hak keputusan, dan pada Bab 3 ketika menyusun kewajiban.

Kriteria penilaian. Kejelasan konteks 25 persen; hubungan pemicu dengan tujuan 30 persen; kelengkapan pemangku kepentingan 25 persen; keterlacakan bukti dan konsistensi lintas mata kuliah 20 persen.

Berkas pendukung.

- `sources/chapter01/templat-profil-organisasi.md`: profil, pemicu, dan daftar periksa C1.
- `sources/chapter01/peta-pemangku-kepentingan.csv`: contoh delapan pemangku kepentingan.
- `sources/chapter01/panduan-izin-dan-anonimisasi.md`: izin dan pengolahan bukti.
- `sources/chapter01/register-grc-awal.csv`: register awal untuk pendalaman teknis.

Etika. Data organisasi nyata wajib seizin organisasi dan dianonimkan. Data pribadi pasien atau karyawan, kredensial, dan rincian kerentanan tidak boleh masuk ke artefak tim.

Pendalaman Teknis (opsional)

Register awal dapat memakai *Comma-Separated Values* (CSV) dengan pengenal tetap, misalnya R-01 dan AC-01. Listing 1.1 memperlihatkan empat baris yang saling tertaut lewat kolom `terkait`. Register disimpan di bawah kendali versi, sehingga riwayat perubahan menunjukkan siapa mengubah status dan alasannya. *YAML Ain't Markup Language* (YAML) juga dapat dipakai bila tim lebih menyukai struktur bersarang.

Listing 1.1: Register GRC awal (data latihan), tersedia di `sources/chapter01/register-grc-awal.csv`

```
# Kegunaan: register GRC awal Bab 01 (data latihan). Salin, lalu ganti isinya.
id,jenis,judul,pemilik,status_informasi,terkait
P-01,pemicu,Insiden vendor 2025,Direktur pelayanan,fakta kasus,R-01
R-01,risiko,Akun vendor di luar penugasan,Pemilik Medikara+,pengandaian,AC-01
AC-01,kontrol,Peninjauan hak akses,Kepala operasi TI,pengandaian,B-01
B-01,bukti,6 dari 30 akun sampel belum dicabut,Audit internal,pengandaian,AC-01
```

Open Security Controls Assessment Language (OSCAL) adalah inisiatif yang dipimpin NIST bersama industri. OSCAL menyediakan format terbuka yang dapat dibaca mesin, termasuk YAML, untuk menyatakan informasi kontrol

secara terstruktur. Format tersebut diperkenalkan sebagai pilihan interoperabilitas, bukan syarat capstone [107].

1.11 Ringkasan

Tata kelola TI menghubungkan tujuan organisasi dengan keputusan yang memiliki pemilik dan dapat ditinjau. Kekosongannya biasanya terasa lewat proyek gagal, data bocor, dan temuan audit. Masalah layanan menjadi titik masuk, sehingga analisis tidak berhenti pada pembelian perangkat atau aplikasi.

Manajemen menjalankan arah yang telah diberikan, dan jenis keputusan lebih menentukan daripada jabatan penanda tangannya. Risiko, kontrol, kepatuhan, dan asurans membantu menilai konsekuensi serta dasar keyakinan atas pelaksanaan tersebut. Kebijakan saja belum menunjukkan kontrol bekerja, seperti terlihat pada 6 dari 30 akun yang belum dicabut.

GRC bekerja sebagai satu kesatuan. Ketiga fungsi berbagi tujuan layanan, pengenal, dan bukti, tanpa meleburkan peran yang harus tetap independen. Kerangka, standar, dan regulasi punya fungsi berbeda. Pemilihan rujukan mengikuti pertanyaan organisasi dan ruang lingkup kewajiban, lalu diperiksa terhadap sumber primer.

Capstone memerlukan satu konteks bersama dan artefak yang diperbarui secara konsisten lintas empat mata kuliah. Peta pemangku kepentingan menunjukkan bahwa pihak yang paling berpengaruh tidak selalu menanggung akibat terbesar, dan catatan pemicu memisahkan fakta dari dugaan. Bukti perlu asal, tanggal, ruang lingkup, serta pemilik, dan bukti juga punya umur.

Pesan utama bab ini: keputusan GRC yang berguna menyebut pemilik hasil, dasar bukti, dan waktu peninjauan. Tanpa ketiganya, organisasi hanya memiliki dokumen, belum memiliki kendali.

1.12 Latihan

Latihan 1: Memisahkan Arah dan Pelaksanaan

Ambil satu keputusan TI yang baru terjadi di tempat kerja. Tentukan bagian mana yang termasuk tata kelola dan bagian mana yang termasuk manajemen, beserta alasannya.

Latihan ini membuktikan bahwa klasifikasi bergantung pada isi kewenangan, bukan jabatan penandatangan.

1. Pilih satu keputusan tanpa memuat informasi rahasia.
2. Pisahkan keputusan menjadi penetapan tujuan, alokasi kewenangan, dan langkah pelaksanaan.
3. Tulis bukti serta alasan klasifikasi pada setiap bagian.
4. Tetapkan batas perubahan yang harus kembali ke pihak pemberi mandat.

Tabel 1.13 berisi contoh terisi dari Medikara, dan Tabel 1.14 adalah lembar isian.

Tabel 1.13: Contoh terisi Latihan 1 (angka pengandaian)

Bagian keputusan	Kategori	Alasan dan bukti
Batas integrasi Rp450 juta per tahun	Tata kelola	Batas sumber daya disetujui direksi; notulen keputusan
Direktur pelayanan sebagai pemilik hasil antrean	Tata kelola	Alokasi kewenangan; surat delegasi
Jadwal pemasangan di 18 klinik	Manajemen	Pelaksanaan dalam batas yang disetujui; rencana kerja
Kenaikan biaya menjadi Rp540 juta	Kembali ke tata kelola	Melewati batas atas Rp495 juta; usulan perubahan

Tabel 1.14: Lembar isian Latihan 1

Bagian keputusan	Kategori	Alasan dan bukti
…	…	…
…	…	…
…	…	…
…	…	…

Pertanyaan analisis.

1. Apakah jadwal dapat berubah tanpa persetujuan direksi? Pada batas perubahan mana eskalasi diperlukan, dan mengapa?
2. Pada tabel contoh, baris mana yang berubah kategori bila toleransi 10 persen dinaikkan menjadi 25 persen? Hitung batas atas barunya.

Latihan 2: Kepatuhan dan Risiko Sisa

Jelaskan dengan contoh mengapa organisasi yang patuh pada regulasi belum tentu risikonya terkendali.

Latihan ini membuktikan perbedaan antara bukti pemenuhan kewajiban dan efektivitas kontrol.

1. Pilih satu kewajiban dan satu risiko layanan yang berkaitan.

2. Tetapkan bukti pemenuhan kewajiban yang benar-benar tersedia.
3. Nilai kontrol dengan data pelaksanaan, lalu nyatakan risiko yang masih tersisa.

Tabel 1.15 berisi contoh terisi, dan Tabel 1.16 adalah lembar isian.

Tabel 1.15: Contoh terisi Latihan 2 (keadaan pengandaian)

Keadaan pengandaian	Bukti kepatuhan	Risiko tersisa
Kebijakan akses sudah disahkan	Dokumen bertanggal	6 dari 30 akun sampel belum dicabut
Kontrak vendor memuat klausul kerahasiaan	Kontrak bertanda tangan	Akun dukungan tetap aktif; 1.240 rekam terbaca selama 8 malam (data latihan)
Cadangan data tersedia	Catatan pekerjaan cadangan	Pemulihan belum pernah diuji

Tabel 1.16: Lembar isian Latihan 2

Keadaan pengandaian	Bukti kepatuhan	Risiko tersisa
…	…	…
…	…	…
…	…	…

Pertanyaan analisis.

1. Bukti tambahan apa yang mengubah kesimpulan risiko? Mengapa keberadaan dokumen belum cukup untuk menerima risiko?
2. Bila 30 akun sampel hanya diambil dari akun tertua, apa yang berubah pada kesimpulan 20 persen? Tuliskan batas kesimpulan yang lebih jujur.

Latihan 3: Siapa Menanggung Akibat

Pilih satu pemicu GRC pada Medikara Health. Sebutkan pemangku kepentingan yang paling dirugikan bila pemicu itu diabaikan, lalu jelaskan alasannya.

Latihan ini membuktikan bahwa pengaruh dalam rapat berbeda dari besarnya kerugian.

1. Pilih salah satu dari empat pemicu dasar Medikara.
2. Daftar sedikitnya tiga pihak terdampak dan jelaskan bentuk kerugiannya.
3. Beri skala 1 sampai 3 untuk dampak dan pengaruh, lalu tulis alasan tiap angka.

4. Bandingkan dampak dan kemampuan memengaruhi keputusan, lalu tentukan pihak yang perlu dilibatkan.

Tabel 1.17 berisi contoh terisi untuk pemicu insiden vendor, dan Tabel 1.18 adalah lembar isian.

Tabel 1.17: Contoh terisi Latihan 3 (penilaian contoh)

Pemangku kepentingan	**Dampak**	**Pengaruh dan respons**
Pasien pada insiden vendor	3: kerahasiaan dan kepercayaan, 1.240 rekam (data latihan)	1: wakili kepentingannya
Direktur pelayanan	3: gangguan layanan lintas 5 rumah sakit	3: tetapkan pemilik tindak lanjut
Vendor Medikara+	2: pemeriksaan dan peninjauan kontrak	2: minta bukti dan batas akses

Tabel 1.18: Lembar isian Latihan 3

Pemangku kepentingan	**Dampak**	**Pengaruh dan respons**
…	…	…
…	…	…
…	…	…

Pertanyaan analisis.

1. Apakah pihak yang paling berpengaruh selalu paling dirugikan? Tunjukkan dengan baris pada tabel.
2. Bukti apa yang diperlukan agar urutan dampak tidak sekadar pendapat?
3. Sel mana pada Gambar 1.5 berubah bila pemicunya diganti menjadi antrean panjang? Sebutkan alasannya.

Bab 2

Prinsip Tata Kelola TI dan Peran Direksi

Tujuan Pembelajaran

- Menerapkan model *Evaluate, Direct, Monitor* dan prinsip ISO/IEC 38500:2024 untuk menilai praktik tata kelola sebuah organisasi.
- Menyusun matriks hak keputusan TI yang memisahkan pihak yang memberi masukan dari pihak yang memutuskan.
- Mengkritisi pilihan struktur tata kelola, misalnya komite pengarah TI, berdasarkan ukuran dan konteks organisasi.

2.1 Pendahuluan

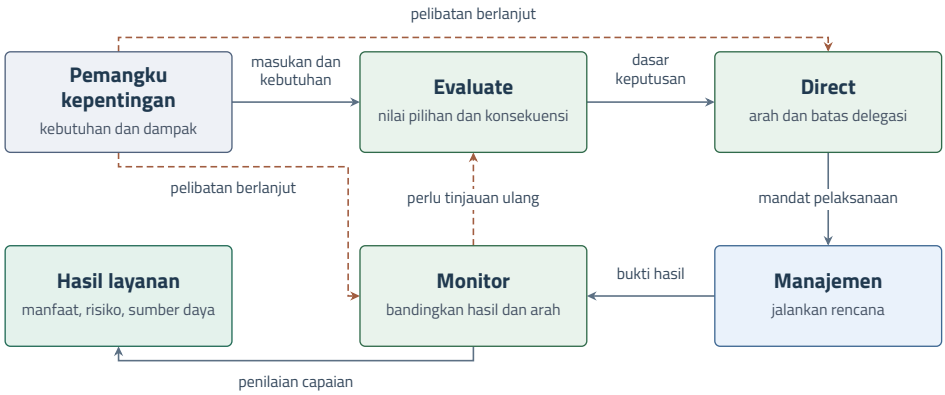
Misalkan Medikara menyetujui Rp8 miliar dari anggaran modernisasi Rp10 miliar untuk memperbarui aplikasi layanan pasien Medikara+. Setelah enam bulan, tim proyek melaporkan pemasangan sesuai jadwal pada 5 rumah sakit dan 90 persen pekerjaan selesai. Waktu tunggu pendaftaran baru turun dari 40 menjadi 38 menit, padahal targetnya 25 menit. Direktur pelayanan belum dapat menjelaskan siapa yang memastikan penurunan itu. Vendor menganggap pekerjaannya selesai setelah aplikasi diterima. Kepala TI menunjuk jadwal yang terpenuhi. Semua pihak bekerja, tetapi tidak ada yang memiliki hasilnya. Masalahnya muncul pada hubungan antara investasi, manfaat, dan kewenangan.

Tata kelola teknologi informasi (TI) memberi tempat bagi pertanyaan yang melampaui pekerjaan proyek. Bab 1 sudah membedakan tata kelola dari manajemen. Bab ini menjawab pertanyaan berikutnya: siapa menilai pilihan, siapa memberi

arah, siapa memutuskan, dan bagaimana pihak yang berwenang memantau hasil. Susunan ini harus sesuai dengan bentuk badan hukum, anggaran dasar, serta delegasi yang berlaku. Hasil kerja bab ini adalah matriks hak keputusan dan rancangan piagam komite pengarah TI untuk tonggak C1 capstone.

Bab ini memakai empat rujukan utama. ISO/IEC 38500:2024 dari International Organization for Standardization (ISO) dan International Electrotechnical Commission (IEC) menjelaskan prinsip dan model *Evaluate, Direct, Monitor* (EDM). Weill dan Ross menyediakan kerangka hak keputusan. De Haes, Van Grembergen, Joshi, dan Huygh membahas mekanisme tata kelola. Wu, Straub, dan Liang menguji hubungan tata kelola dengan kinerja. Standar menjelaskan arah, matriks membantu membagi kewenangan, dan penelitian menguji mekanisme yang menghubungkan tata kelola dengan hasil [79, 164, 29, 170].

Gambar 2.1 merangkum hubungan komponen dan konsep utama bab ini.



Hak keputusan harus mengikuti mandat dan delegasi. Forum komite tidak memindahkan pertanggungjawaban hasil bisnis kepada TI.

Gambar 2.1: Evaluate, Direct, Monitor dengan pelibatan pemangku kepentingan

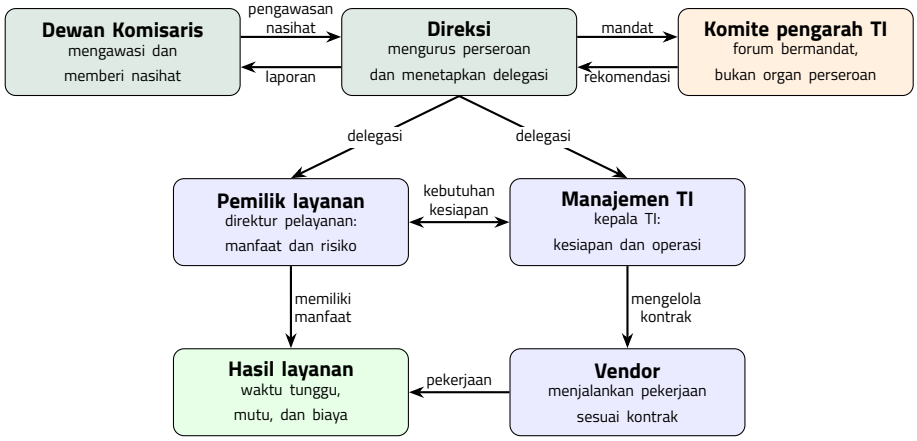
2.2 Tata Kelola Korporat dan Posisi TI

Pertanyaan pertama: di mana letak TI dalam tata kelola perusahaan? Tata kelola TI bukan sistem yang berdiri sendiri. *White paper* di situs komite ISO menyebutnya bagian yang menyatu dengan tata kelola organisasi [147]. Karena itu, penelusuran kewenangan dimulai dari organ perseroan, bukan dari struktur unit TI.

Pada perseroan terbatas Indonesia, direksi menjalankan pengurusan untuk kepentingan perseroan, sesuai kebijakan yang dipandang tepat dalam batas undang-undang dan anggaran dasar. Dewan komisaris mengawasi kebijakan dan jalannya pengurusan, lalu memberi nasihat kepada direksi. Pembagian tugas antaranggota

direksi ditetapkan rapat umum pemegang saham, atau oleh direksi sendiri bila rapat umum tidak menetapkannya. Pembagian ini perlu dibaca bersama anggaran dasar dan perubahan peraturan yang berlaku. Pasal 92 dan Pasal 108 Undang-Undang (UU) 40/2007 menjadi titik awal penelusuran, bukan alasan menyalin struktur perusahaan lain [131].

Organisasi tidak dapat memindahkan seluruh pertanggungjawaban pemanfaatan TI kepada kepala TI atau vendor. Direktur pelayanan memiliki manfaat layanan. Direktur keuangan memiliki pertimbangan pendanaan. Fungsi teknologi menjelaskan kelayakan. Komite memberi forum koordinasi, sedangkan kewenangan hukum tetap mengikuti mandat. Gambar 2.2 memperlihatkan hubungan itu pada Medikara. Rincian di bawah direksi adalah pengandaian, karena fakta dasar kasus tidak menyebut susunan jabatannya.



Gambar 2.2: Organ perseroan, forum komite, dan pemilik hasil pada pengandaian Medikara

Pengelola rumah sakit dapat meminta penasihat menilai mutu bangunan. Penasihat membantu menimbang pilihan, tetapi tanda tangan kontrak dan tanggung jawab pengelolaan tetap mengikuti kewenangan organisasi. Membentuk forum tambahan tidak otomatis memindahkan tanggung jawab.

Dua contoh penerapannya:

1. Misalkan anggaran dasar Medikara mewajibkan persetujuan dewan komisaris untuk pengadaan di atas Rp5 miliar. Pasal 117 memberi ruang bagi pengaturan seperti itu. Investasi Rp8 miliar melewati batas tersebut. Dewan komisaris kemudian meminta laporan risiko modernisasi lima rumah sakit setiap triwulan, atau 4 kali setahun. Direksi tetap mengurus program dan menindaklanjuti temuan yang masuk kewenangannya.
2. Misalkan direktur pelayanan menjadi pemilik manfaat investasi Rp8 miliar. Waktu tunggu dipengaruhi jadwal sekitar 640 dokter dan alur kerja di 5

rumah sakit. Kepala TI memimpin 52 staf TI dan mengelola kesiapan teknis, tetapi tidak berwenang mengubah jadwal dokter. Kepala TI juga tidak sendirian menerima risiko perubahan alur klinis.

Tabel 2.1 merangkum peran korporat dan pemanfaatan TI.

Tabel 2.1: Peran korporat dan pemanfaatan TI

Peran	Tanggung jawab contoh	Bukti yang dicari
Dewan komisaris	Pengawasan dan nasihat	Notulen pengawasan
Direksi	Arah, investasi, dan pengurusan	Keputusan serta delegasi
Pemilik layanan	Hasil dan risiko layanan	Ukuran manfaat
Manajemen TI	Pelaksanaan serta operasi	Rencana dan laporan kontrol
Vendor	Pekerjaan sesuai kontrak	Berita acara dan laporan layanan

Pengurusan dan pengawasan

Dua hal sering tertukar: pengurusan dan pengawasan. Pembagiannya begini. Pengurusan memilih tindakan dan menjalankannya. Pengawasan memeriksa kebijakan dan jalannya pengurusan, lalu memberi nasihat. Komisaris yang memilih vendor Medikara+ sedang masuk ke wilayah pengurusan. Pasal 118 hanya membuka jalan itu berdasarkan anggaran dasar atau keputusan rapat umum pemegang saham, untuk keadaan dan jangka waktu tertentu [131].

Pembagian ini menimbulkan kesulitan istilah. Standar internasional memakai kata badan pengarah (*governing body*) atau *board*. The Institute of Internal Auditors (IIA) memakai *board* untuk berbagai bentuk badan pengarah beserta komitenya [151]. Perseroan Indonesia memisahkan dua organ, sehingga istilah itu tidak dapat diterjemahkan satu lawan satu. Tabel 2.2 memberi pemetaan kerja untuk bab ini. Pemetaan itu penafsiran bab ini, bukan isi standar. Tim tetap perlu mencocokkannya dengan anggaran dasar organisasi.

Akuntabilitas tidak ikut berpindah

Bila pekerjaan didelegasikan atau dialihkan ke vendor, apakah tanggung jawabnya ikut berpindah? Tidak seluruhnya. Direksi bertanggung jawab atas pengurusan, dan dewan komisaris bertanggung jawab atas pengawasan. Anggota kedua organ dapat bertanggung jawab secara pribadi atas kerugian perseroan bila bersalah atau lalai. Pasal 97 ayat (5) menyebut syarat pembebasan bagi anggota direksi, antara lain itikad baik, kehati-hatian, dan tidak adanya benturan kepentingan [131]. IIA menyatakan alih daya tidak mengubah akuntabilitas *board* untuk memastikan kegiatan yang dialihkan berjalan efektif [151]. Pernyataan IIA itu membahas

Tabel 2.2: Pemetaan kerja tugas tata kelola pada dua organ perseroan

Tugas	Direksi	Dewan komisaris
Evaluate	Menilai opsi investasi dan dampaknya	Memberi nasihat; menyetujui bila anggaran dasar menetapkan
Direct	Menetapkan arah, pemilik manfaat, dan batas delegasi	Tidak memberi perintah operasional
Monitor	Memantau hasil dan memerintahkan koreksi	Mengawasi kebijakan dan jalannya pengurusan
Pelibatan	Mengatur saluran masukan pasien, klinisi, dan unit lokal	Menanyakan apakah pihak terdampak sudah didengar

kegiatan asurans dan nasihat. Bab ini memakai logika yang serupa untuk pekerjaan vendor.

Keadaan ini punya dua konsekuensi. Pertama, catatan keputusan bernilai sebagai pertanggungjawaban. Notulen yang memuat opsi, alasan, dan deklarasi kepentingan membantu menunjukkan kehati-hatian, meskipun tidak menjamin pembebasan tanggung jawab. Bagian ini bukan nasihat hukum. Kedua, kontrak menetapkan tugas vendor, tetapi tidak menghapus kewajiban organisasi menetapkan siapa memantau hasil. Data latihan Bab 1 memperlihatkan akibatnya: kontrak selesai, akun dukungan tetap aktif, dan 1.240 rekam kunjungan terbaca selama 8 malam.

Kasus Medikara Health: Pertanyaan Komisaris pada Laporan Triwulan

Misalkan laporan triwulan menyebut pemasangan Medikara+ sudah mencapai 90 persen. Dewan komisaris mengajukan tiga pertanyaan. Siapa pemilik manfaat? Berapa selisih hasil terhadap target? Apa keputusan yang menunggu direksi? Jawaban pertama ternyata berbeda antara direktur pelayanan dan kepala TI. Jawaban kedua baru tersedia setelah data 5 rumah sakit dikumpulkan: 38 menit, dari target 25 menit. Jawaban ketiga belum ada.

Dewan komisaris tidak memilih perbaikan, karena memilih perbaikan termasuk pengurusan. Dewan komisaris menasihati direksi agar menetapkan satu pemilik manfaat dan membawa pilihan koreksi pada triwulan berikutnya. Direksi lalu menunjuk direktur pelayanan sebagai pemilik manfaat, sesuai pembagian tugas yang berlaku.

2.3 ISO/IEC 38500:2024 dan Model Evaluate, Direct, Monitor

Setelah organnya jelas, apa yang seharusnya dikerjakan? ISO/IEC 38500:2024 memberi panduan bagi badan pengarah tentang penggunaan TI dalam organisasi [79]. Teks standar ini berbayar, sehingga rincian berikut mengikuti *white paper* perbedaan edisi yang terbit di situs komite penyusunnya. Halaman itu memuat penafian bahwa isinya dikelola pihak ketiga, sehingga tim yang memakainya untuk penilaian formal tetap perlu memeriksa teks standar [147].

Edisi 2024 selaras dengan ISO 37000 tentang tata kelola organisasi. Prinsipnya berubah dari enam menjadi sebelas. Modelnya menambahkan pelibatan pemangku kepentingan (*engage stakeholders*) di samping tiga tugas EDM. Fokusnya juga bergeser. Tata kelola tidak lagi dibahas terutama sebagai kerja badan pengarah, tetapi sebagai sesuatu yang dijalankan di seluruh organisasi, dengan manajemen bekerja dalam kerangka yang ditetapkan badan pengarah [147]. Tabel 2.3 merangkum perbedaannya.

Tabel 2.3: Perbedaan ISO/IEC 38500 edisi 2015 dan edisi 2024

Aspek	Edisi 2015	Edisi 2024
Prinsip	Enam: tanggung jawab, strategi, akuisisi, kinerja, kesesuaian, perilaku manusia	Sebelas, mengikuti prinsip ISO 37000
Model	*Evaluate*, *Direct*, dan *Monitor* oleh badan pengarah	Ditambah pelibatan pemangku kepentingan, di atas manajemen TI
Letak tata kelola	Terutama pada badan pengarah	Di seluruh organisasi, dalam kerangka dari badan pengarah
Kerangka	Konsepnya pertama muncul pada ISO/IEC 38502	Enam unsur: arah, kapabilitas, kebijakan, delegasi, kinerja, akuntabilitas

Banyak materi daring masih memakai enam prinsip edisi 2015. Daftar itu tidak boleh diberi label edisi 2024. Tabel 2.4 memuat sebelas prinsip edisi 2024, dengan kelompok *primary* (utama), *foundational* (dasar), dan *enabling* (pemungkin). Kolom pertanyaan adalah penerapan bab ini berupa pertanyaan keputusan, bukan kutipan persyaratan standar.

Prinsip tidak berjalan tanpa kerangka. *White paper* yang sama menyebut enam unsur kerangka tata kelola menurut edisi 2024 [147]. Keenam unsur itu menjadi daftar periksa yang berguna saat menilai sebuah organisasi. Tabel 2.5 menerapkannya pada pengandaian Medikara.

Evaluasi memerlukan alternatif nyata, termasuk menunda atau menghentikan.

Tabel 2.4: Sebelas prinsip ISO/IEC 38500:2024 dan pertanyaan penerapannya

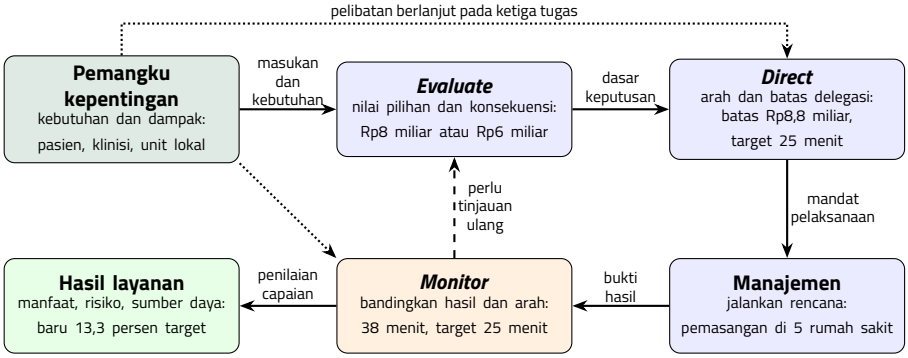
Kelompok	Prinsip	Pertanyaan bagi TI Medikara
Utama	Tujuan	Layanan pasien mana yang dilayani TI?
Dasar	Pembentukan nilai	Nilai apa yang dihasilkan Medikara+?
Dasar	Strategi	Apakah investasi mendukung "Satu Pasien, Satu Rekam Medis"?
Dasar	Pengawasan	Siapa memeriksa jalannya program?
Dasar	Akuntabilitas	Siapa menjawab bila target tidak tercapai?
Pemungkin	Pelibatan pemangku kepentingan	Apakah pasien dan klinisi sudah didengar?
Pemungkin	Kepemimpinan	Siapa memberi contoh dalam memakai data dan aturan?
Pemungkin	Data dan keputusan	Apakah keputusan memakai data yang dapat diperiksa?
Pemungkin	Tata kelola risiko	Risiko mana yang diterima, dan oleh siapa?
Pemungkin	Tanggung jawab sosial	Siapa terdampak di luar organisasi?
Pemungkin	Kelangsungan dan kinerja dari waktu ke waktu	Apakah layanan tetap bertahan setelah proyek selesai?

Tabel 2.5: Enam unsur kerangka tata kelola pada pengandaian Medikara

Unsur	Bentuk pada Medikara
Arah	Strategi "Satu Pasien, Satu Rekam Medis" 2026 sampai 2030
Kapabilitas	52 staf TI dengan tim platform 6 orang, ditambah vendor Medikara+
Kebijakan	Aturan akses vendor dan standar integrasi
Delegasi	Batas biaya dan toleransi 10 persen, dijelaskan pada seksi berikutnya
Kinerja	Waktu tunggu pendaftaran dari 40 menjadi 25 menit
Akuntabilitas	Direktur pelayanan sebagai pemilik manfaat, dengan catatan keputusan

Arahan menyebut batas biaya, pemilik manfaat, risiko yang diterima, dan kondisi penghentian. Pemantauan membandingkan hasil terhadap arahan dan dapat memicu evaluasi ulang. Pertanyaan kemudian muncul: siapa perlu dilibatkan? Pihak yang memakai layanan dan menanggung akibat harus memiliki saluran masukan. Gambar 2.3 memperlihatkan siklus itu dengan angka pengandaian Medikara.

Panitia renovasi sekolah membandingkan pilihan sebelum memilih kontraktor, menetapkan batas anggaran dan keselamatan, lalu memeriksa penggunaan ruangan setelah selesai. Guru serta murid memberi masukan karena mereka mengalami akibat keputusan setiap hari.



Gambar 2.3: Siklus EDM dengan pelibatan pemangku kepentingan pada keputusan Medikara+

Dua contoh penerapannya:

1. Misalkan dua opsi aplikasi pasien berbiaya Rp8 miliar dan Rp6 miliar, dengan masa pakai 5 tahun. Biaya per tahunnya Rp1,6 miliar dan Rp1,2 miliar. Dengan 336.000 janji temu per tahun, biaya per janji temu sekitar Rp4.760 dan Rp3.570. Misalkan opsi pertama menargetkan penurunan 15 menit, dan opsi kedua 10 menit. Penghematannya 84.000 jam dan 56.000 jam per tahun, atau sekitar Rp19.000 dan Rp21.400 per jam. Evaluasi juga menilai keselamatan serta kemampuan adopsi, bukan memilih angka terendah secara otomatis.
2. Misalkan target waktu tunggu turun dari 40 menjadi 25 menit, dengan batas biaya Rp8,8 miliar berdasarkan toleransi 10 persen seperti pada Bab 1. Hasil tiga bulan masih 38 menit, atau baru 2 dari 15 menit yang ditargetkan (13,3 persen). Pemantauan memicu peninjauan proses, alokasi petugas, dan rancangan aplikasi. Bila biaya naik 27 persen, sesuai rata-rata pada Bab 1, nilainya Rp10,16 miliar dan keputusan kembali ke direksi.

Dua pemantauan yang sering tertukar

Dua hal pada EDM sering tertukar: *Monitor* sebagai tugas tata kelola dan pemantauan harian oleh manajemen. Pembagiannya begini. Manajemen memantau jalannya pekerjaan agar rencana terlaksana. Badan pengarah memantau apakah arah masih benar dan hasilnya sesuai. Control Objectives for Information and Related Technologies (COBIT) juga memisahkan keduanya [64], dan Bab 4 membahas rinciannya.

Misalkan tiap rumah sakit mengirim laporan pekanan. Lima rumah sakit menghasilkan 260 laporan setahun. Manajemen membaca semuanya untuk memperbaiki operasi. Direksi cukup menerima 4 laporan triwulan yang memuat hasil, risiko, dan keputusan yang diperlukan. Bila direksi membaca 260 laporan,

direksi masuk ke pekerjaan manajemen dan justru kehilangan pandangan atas arah. Tabel 2.6 merangkum pertanyaan pada tingkat tata kelola.

Tabel 2.6: Pertanyaan EDM untuk keputusan investasi

Tugas	Pertanyaan	Contoh hasil
Evaluate	Apa masalah, opsi, dan dampaknya?	Perbandingan dua opsi
Direct	Siapa berwenang dan apa batasnya?	Mandat dan pemilik manfaat
Monitor	Apakah hasil memenuhi arahan?	Laporan manfaat dan tindakan
Pelibatan pihak	Siapa belum didengar?	Masukan pasien dan klinisi

2.4 Hak Keputusan TI

Pertanyaan berikutnya: siapa tepatnya yang memutuskan? Hak keputusan menyatakan siapa memberi masukan dan siapa menetapkan keputusan akhir pada domain tertentu. Weill memandang tata kelola TI sebagai penetapan hak keputusan dan akuntabilitas untuk mendorong perilaku yang diinginkan dalam penggunaan TI. Kajiannya mencakup lebih dari 250 perusahaan di 23 negara [163]. Weill dan Ross membedakan lima keputusan: prinsip TI, arsitektur, infrastruktur, kebutuhan aplikasi bisnis, serta investasi dan prioritas. Arketipe menggambarkan lokasi kewenangan: monarki bisnis, monarki TI, feodal, federal, duopoli, dan anarki [164, 163].

Monarki bisnis menempatkan keputusan pada pimpinan bisnis, monarki TI pada pimpinan teknologi, dan feodal pada unit bisnis masing-masing. Federal menggabungkan pusat dan unit. Duopoli menggabungkan teknologi dengan satu kelompok bisnis. Anarki berarti keputusan individual. Arketipe adalah lensa analisis. Matriks organisasi tetap harus menyebut jabatan dan batas delegasi yang konkret. Tabel 2.7 memberi contoh dan akibat tiap arketipe.

Lima keputusan dan enam arketipe membentuk sebuah matriks. Gambar 2.4 mengisinya dengan pengandaian Medikara. Misalkan kotak merah menunjukkan pemutus saat ini, sedangkan lingkaran menunjukkan susunan yang diusulkan. Tiga dari lima kotak merah berada pada kolom feodal, sejalan dengan versi SIMRS yang berbeda di tiap rumah sakit. Makin banyak kotak pada kolom itu, makin besar hambatan bagi strategi satu rekam medis.

Memilih menu makan bersama memberi semua peserta kesempatan menyampaikan alergi dan preferensi. Satu koordinator tetap perlu mengonfirmasi pesanan dalam anggaran yang disepakati. Banyak masukan tidak mengharuskan banyak pemesan akhir.

Tabel 2.7: Enam arketipe hak keputusan dengan contoh pengandaian Medikara

Arketipe	Letak keputusan	Misalkan di Medikara	Akibat
Monarki bisnis	Pimpinan bisnis senior	Direksi memutuskan prinsip identitas pasien	Arah kuat; perlu masukan kelayakan
Monarki TI	Pimpinan TI	Kepala TI memutuskan standar integrasi	Standar konsisten; manfaat layanan kurang terwakili
Feodal	Tiap unit bisnis	Tiap rumah sakit memilih sistem sendiri	Cepat di tingkat lokal; 5 versi Sistem Informasi Manajemen Rumah Sakit (SIMRS) sulit disatukan
Federal	Pusat bersama unit	Direktur pelayanan bersama 5 direktur rumah sakit	Pusat dan unit terwakili; kesepakatan lebih lama
Duopoli TI	TI bersama satu kelompok bisnis	Kepala TI bersama direktur pelayanan	Nilai dan kelayakan dinilai bersama; perlu aturan bila tidak sepakat
Anarki	Individu atau kelompok kecil	Unit menyusun laporan dengan *spreadsheet* sendiri	Murah di awal; data tersebar

Keputusan	Monarki bisnis	Monarki TI	Feodal	Federal	Duopoli TI	Anarki
Prinsip TI	●	□		○		
Arsitektur TI		●	□	○		
Infrastruktur TI		●	□		○	
Kebutuhan aplikasi bisnis			○ □	●		
Investasi dan prioritas TI	●	□			○	

● pemutus usulan ○ pemberi masukan usulan □ pemutus saat ini

Gambar 2.4: Matriks hak keputusan pengandaian Medikara: lima keputusan dan enam arketipe menurut Weill dan Ross

Dua contoh penerapannya:

1. Misalkan investasi Medikara+ diputuskan direksi berdasarkan rekomendasi bersama direktur pelayanan dan kepala TI. Polanya menyerupai duopoli pada tahap rekomendasi, dengan persetujuan akhir mengikuti delegasi investasi. Karena Rp8 miliar melewati batas Rp5 miliar pada pengandaian sebelumnya,

dewan komisaris ikut memberi persetujuan.

2. Misalkan lima rumah sakit membeli pengelolaan identitas sendiri seharga Rp700 juta per rumah sakit, atau Rp3,5 miliar seluruhnya. Pola feodal memberi kecepatan lokal, tetapi menyulitkan sasaran identitas pasien tunggal. Platform bersama Rp2 miliar menghemat Rp1,5 miliar, dengan konsekuensi rumah sakit terakhir menunggu lebih lama.

Tidak ada satu susunan terbaik

Weill melaporkan bahwa perusahaan unggul berbeda satu sama lain dan berbeda dari perusahaan rata-rata. Perusahaan yang unggul pada pertumbuhan cenderung memberi lebih banyak hak keputusan kepada unit bisnis. Perusahaan yang unggul pada laba lebih terpusat, dengan pimpinan bisnis senior memutuskan keputusan TI utama [163]. Halaman MIT Center for Information Systems Research menyebut perusahaan dengan tata kelola TI yang unggul memiliki laba lebih dari 25 persen di atas perusahaan dengan tata kelola buruk, pada tujuan strategis yang sama [164].

Angka 25 persen itu menggambarkan perbedaan antarkelompok perusahaan. Angka itu bukan janji bahwa Medikara akan menaikkan laba 25 persen setelah membuat matriks. Pesan yang dapat dipakai adalah kesesuaian: letak keputusan mengikuti tujuan kinerja. Medikara mengejar satu rekam medis lintas fasilitas, sehingga keputusan identitas pasien lebih wajar terpusat. Alur pendaftaran bergantung pada kondisi tiap rumah sakit, sehingga pola federal lebih masuk akal.

Masukan, veto, dan keputusan akhir

Dua hal sering tertukar. Hak memberi masukan tidak sama dengan hak memveto. Masukan wajib didengar, tetapi boleh tidak diikuti dengan alasan tertulis. Veto menghentikan keputusan, sehingga harus ditulis eksplisit dan dibatasi. Bila semua pihak disebut pemutus, tanggung jawab justru kabur. Setiap keputusan perlu satu kewenangan akhir yang jelas, sekalipun keputusan dicapai melalui musyawarah atau badan kolektif.

Hitungan sederhana memperlihatkan alasannya. Misalkan empat pihak masing-masing memegang veto, dan tiap pihak menyetujui 90 persen usulan secara terpisah. Peluang satu usulan lolos adalah 0,9 pangkat 4, atau sekitar 65,6 persen. Sekitar sepertiga usulan berhenti, meskipun tiap pihak terlihat mudah setuju. Veto sebaiknya diberikan untuk alasan yang sempit, misalnya kepala rekam medis menghentikan pembukaan data pasien ke mitra bila dasar pemrosesannya belum ada. Tabel 2.8 memperlihatkan pemisahan masukan dan keputusan pada empat keputusan.

Matriks perlu ditemani batas delegasi, karena tidak semua keputusan investasi

Tabel 2.8: Contoh matriks hak keputusan

Keputusan	Pemberi masukan	Pemutus akhir	Pengawas
Prinsip identitas pasien	Layanan, data, dan TI	Direksi	Dewan komisaris
Standar arsitektur	Pemilik aplikasi dan keamanan	Kepala TI lewat forum berdelegasi jelas	Komite pengarah TI
Investasi Medikara+	Layanan, TI, dan keuangan	Direksi sesuai batas	Dewan komisaris
Akses vendor harian	Keamanan, kepala TI, dan pemilik data	Pemilik Medikara+	Audit internal

layak naik ke direksi. Tabel 2.9 memberi contoh yang sejalan dengan Bab 1, ketika direksi menyetujui integrasi Rp450 juta per tahun dengan toleransi 10 persen. Semua angka adalah pengandaian, bukan batas hukum.

Tabel 2.9: Contoh batas delegasi keputusan TI pada pengandaian Medikara

Nilai keputusan	Pemutus akhir	Laporan
Sampai Rp100 juta	Kepala TI, dengan masukan pemilik layanan	Ringkasan triwulan ke komite
Di atas Rp100 juta sampai Rp400 juta	Komite pengarah TI, sesuai mandat direksi	Notulen ke direksi
Di atas Rp400 juta sampai Rp5 miliar	Direksi	Laporan triwulan ke dewan komisaris
Di atas Rp5 miliar	Direksi dengan persetujuan dewan komisaris, bila anggaran dasar menetapkan	Laporan triwulan ke dewan komisaris
Kenaikan di atas 10 persen	Kembali ke pemutus awal	Alasan dan pilihan koreksi

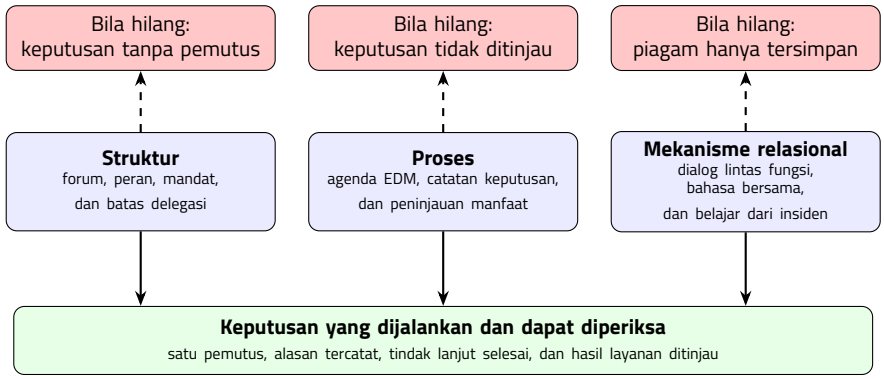
Kasus Medikara Health: Siapa Mencabut Akun Vendor?

Risiko R-01 pada Bab 1 adalah akses vendor yang berlebihan. Audit memeriksa 30 dari 120 akun vendor dan menemukan 6 akun aktif setelah penugasan berakhir. Peninjauan bulan berikutnya mencabut 24 akun. Angka itu menjawab apa yang terjadi, tetapi belum menjawab siapa yang berwenang. Misalkan tim menyusun hak berikut. Pemilik Medikara+ memutuskan pemberian akses, dengan keamanan dan kepala TI sebagai pemberi masukan. Bila kepala TI keberatan, keputusan naik ke direktur pelayanan. Staf TI mencabut akun paling lambat 1 hari kerja setelah penugasan berakhir. Direksi menerima risiko sisa R-01, sedangkan audit internal memeriksa

kontrol AC-01. Pada data latihan Bab 1, akun dukungan memanggil data selama 8 malam dan baru diketahui pada hari ke-11. Dengan aturan 1 hari kerja, akun itu berpeluang sudah dicabut sebelum panggilan data dimulai, asalkan tanggal berakhirnya penugasan tercatat.

2.5 Struktur, Proses, dan Mekanisme Relasional

Matriks sudah ada. Apa yang membuatnya benar-benar berjalan? Mekanisme tata kelola meliputi struktur, proses, dan hubungan kerja. Struktur menentukan forum dan peran. Proses menentukan kapan keputusan diambil serta ditinjau. Mekanisme relasional membangun pemahaman bersama melalui dialog dan pembelajaran lintas fungsi. Peterson memandang kemampuan struktural, proses, dan relasional sebagai bagian yang menyatu dari arsitektur tata kelola TI [124, 29]. Gambar 2.5 memperlihatkan akibatnya bila salah satu hilang.



Gambar 2.5: Tiga mekanisme tata kelola dan akibat bila salah satunya hilang

Jadwal piket, daftar tugas, dan kebiasaan saling memberi kabar diperlukan bersama untuk menjaga kebersihan kantor. Bagan piket tidak cukup bila petugas tidak tahu kapan pekerjaan selesai atau tidak mau melaporkan masalah.

Dua contoh penerapannya:

1. Misalkan komite Medikara bertemu sebulan sekali, tetapi hanya melihat persentase proyek. Dari 96 item agenda setahun, 72 item (75 persen) berupa laporan kemajuan dan hanya 24 item (25 persen) meminta keputusan. Agenda perlu menambah manfaat, risiko, pengecualian, serta keputusan yang benar-benar diperlukan.
2. Misalkan ada 60 permintaan perubahan per bulan, dan 48 di antaranya berisiko rendah. Bila semuanya menunggu rapat bulanan, waktu tunggu

rata-ratanya sekitar 15 hari. Delegasi untuk perubahan berisiko rendah dengan waktu 2 hari menurunkan rata-rata menjadi 4,6 hari, sedangkan 12 perubahan lintas fasilitas tetap ditinjau pusat.

Tabel 2.10 merangkum mekanisme dan ukuran pelaksanaannya.

Tabel 2.10: Mekanisme dan ukuran pelaksanaannya

Mekanisme	Contoh penerapan	Ukuran yang bermakna
Struktur	Komite dengan mandat jelas	Keputusan memiliki pemutus
Proses	Agenda opsi dan evaluasi manfaat	Tindak lanjut selesai
Relasional	Dialog layanan dan teknologi	Asumsi dipahami bersama
Pengendalian konflik	Deklarasi kepentingan vendor	Pihak berkepentingan tidak menilai sendiri

Komite pengarah TI dan piagamnya

Komite pengarah TI adalah struktur yang paling sering dibentuk. Pertanyaannya: apa yang membuat komite berguna? Piagam komite pengarah TI menyebut tujuan, anggota, mandat, batas kewenangan, kuorum, konflik kepentingan, frekuensi rapat, masukan wajib, dan jalur eskalasi. Notulen merekam opsi, alasan, keputusan, penanggung jawab, tenggat, serta hasil peninjauan. Jumlah rapat tidak membuktikan mutu keputusan. Tabel 2.11 memberi contoh isi piagam. Rinciannya pengandaian, dan templat lengkapnya ada di `sources/chapter02/templat-piagam-komite-ti.md`.

Komite bukan organ perseroan. Keputusan komite berlaku karena mandat dari direksi, sehingga mandat itu perlu tertulis. Medikara juga tidak dapat menempatkan wakil dari setiap fasilitas. Lima rumah sakit, 18 klinik, 1 laboratorium, dan 12 apotek berarti 36 fasilitas. Komite beranggota 36 orang akan sulit memutuskan apa pun. Jalan keluarnya adalah wakil bergilir, ditambah saluran masukan dari unit yang tidak hadir.

Struktur mengikuti ukuran dan konteks

Apakah semua organisasi membutuhkan komite yang sama? Tidak. Pilihan struktur memiliki dua konsekuensi. Pertama, sentralisasi memperjelas standar bersama tetapi dapat memperlambat respons lokal. Kedua, desentralisasi mempercepat keputusan dekat layanan tetapi membutuhkan batas yang mencegah risiko berpindah ke unit lain. Organisasi menengah dapat memulai dari forum yang sudah ada dengan mandat yang diperjelas.

Biaya forum juga dapat dihitung. Komite Medikara beranggota 9 orang dengan

Tabel 2.11: Unsur piagam komite pengarah TI pada pengandaian Medikara

Unsur	Contoh isi
Tujuan	Menilai prioritas investasi TI dan hasil pemanfaatannya
Anggota	9 orang: direktur utama sebagai ketua, direktur pelayanan, direktur keuangan, kepala TI, 2 direktur rumah sakit bergilir, kepala rekam medis, kepala risiko, dan hukum
Mandat	Memutuskan sampai Rp400 juta; merekomendasikan di atasnya kepada direksi
Kuorum	6 dari 9 anggota, dan pemilik risiko yang dibahas wajib hadir
Rapat	Bulanan selama 2 jam, serta rapat insiden sesuai jalur eskalasi
Agenda	Tiga bagian EDM, dengan bagian keputusan lebih dahulu
Konflik kepentingan	Anggota menyatakan hubungan dengan vendor; vendor hadir sebagai undangan tanpa hak memutus
Eskalasi	Keputusan di luar mandat naik ke direksi; keputusan darurat dicatat dan ditinjau pada rapat berikutnya
Laporan	Notulen keputusan ke direksi dan ringkasan triwulan untuk pengawasan

rapat bulanan 2 jam memakai 216 jam orang per tahun. Beban itu setara 0,045 jam per karyawan bila dibagi 4.800 karyawan. Misalkan klinik mitra dengan 60 karyawan meniru bentuk yang sama dengan 5 anggota. Biayanya 120 jam orang per tahun, atau 2 jam per karyawan. Beban relatifnya sekitar 44 kali lebih berat. Tabel 2.12 membandingkan pilihan untuk tiga ukuran organisasi.

Tabel 2.12: Pilihan forum menurut ukuran organisasi

Organisasi	Forum yang masuk akal	Risiko yang perlu dijaga
Klinik mitra: 60 karyawan, 2 staf TI	Agenda TI triwulan pada rapat pimpinan yang sudah ada	Satu orang memegang semua keputusan
Jaringan menengah: 800 karyawan, 15 staf TI	Komite kecil dua bulanan dengan mandat tertulis	Forum berubah menjadi laporan kemajuan
Medikara: sekitar 4.800 karyawan, 52 staf TI	Komite bulanan dan forum arsitektur berdelegasi	Antrean keputusan dan jarak dengan unit lokal

Bukti untuk organisasi kecil dan menengah mendukung kehati-hatian ini. Huang, Zmud, dan Price mempelajari tiga organisasi kecil dan menengah yang sama-sama terpusat. Perbedaan komite pengarah dan kebijakan komunikasi menjelaskan perbedaan hasil pemakaian TI [54]. Temuan itu berupa proposisi dari data kualitatif, sehingga belum dapat digeneralisasi. Pelajaran pentingnya adalah bentuk dan cara kerja komite ikut menentukan hasil, bukan sekadar keberadaannya.

Kasus Medikara Health: Komite yang Berani Meninjau Investasi

Misalkan komite Medikara menerima laporan pemasangan aplikasi senilai Rp8 miliar pada lima rumah sakit. Laporan menunjukkan kemajuan pekerjaan 90 persen, tetapi belum memuat ukuran waktu tunggu. Komite meminta pemilik manfaat membandingkan kondisi awal 40 menit dengan target 25 menit, menjelaskan risiko layanan, dan membawa pilihan koreksi. Keputusan melanjutkan, mengubah, atau menunda harus memiliki alasan serta tenggat peninjauan.
Sebulan kemudian, direktur pelayanan membawa tiga pilihan. Pilihan pertama melanjutkan tanpa perubahan, dengan perkiraan waktu tunggu tetap sekitar 38 menit. Pilihan kedua mengubah alur pendaftaran dan jadwal petugas dengan tambahan Rp400 juta, sehingga total Rp8,4 miliar masih di bawah batas Rp8,8 miliar. Pilihan ketiga menunda pemasangan pada 18 klinik. Komite memutuskan pilihan kedua, karena tambahan Rp400 juta masih dalam mandatnya, lalu melaporkannya ke direksi. Keputusan itu memuat satu syarat: bila waktu tunggu belum di bawah 30 menit dalam 90 hari, direksi mengevaluasi ulang investasi. Vendor hadir untuk menjelaskan, tetapi tidak ikut menilai.

2.6 Keselarasan Bisnis dan TI serta Penciptaan Nilai

Pertanyaan terakhir: apakah seluruh mekanisme itu menghasilkan sesuatu? Keselarasan strategis berarti prioritas pemanfaatan TI dan prioritas bisnis saling mendukung serta terus disesuaikan. Henderson dan Venkatraman membangun Strategic Alignment Model dari empat domain pilihan: strategi bisnis, strategi TI, infrastruktur dan proses organisasi, serta infrastruktur dan proses TI [52]. Nilai perlu dilihat dari manfaat, risiko, dan sumber daya. Aplikasi yang tersedia tepat waktu belum tentu menghasilkan nilai bila proses dan perilaku pengguna tidak berubah.

Membeli kendaraan pengiriman baru tidak meningkatkan kepuasan pelanggan bila alamat pengantaran dan jadwal keberangkatan tetap salah. Nilai muncul ketika investasi, proses, dan tujuan layanan bergerak bersama.

Dua contoh penerapannya:

1. Misalkan investasi Rp8 miliar menghasilkan aplikasi yang aktif di lima rumah sakit, tetapi waktu tunggu hanya berubah dari 40 ke 38 menit. Kemajuan pekerjaan 90 persen, sedangkan capaian manfaat 13,3 persen. Tim perlu memeriksa alur kerja dan adopsi sebelum menyatakan manfaat tercapai.
2. Misalkan proyek identitas pasien senilai Rp2 miliar mengurangi pengisian

ulang dari 12 menjadi 4 menit. Bila berlaku pada 1,2 juta kunjungan per tahun, penghematannya 160.000 jam. Pemilik layanan masih perlu memeriksa keamanan pencocokan identitas. Salah cocok 0,5 persen berarti 6.000 kunjungan per tahun berisiko tercatat pada pasien yang keliru.

Tabel 2.13 menghitung contoh pertama. Hitungan memakai biaya Rp1,6 miliar per tahun selama 5 tahun, belum termasuk biaya operasi, dan mengandaikan waktu tunggu berlaku pada seluruh 336.000 janji temu per tahun.

Tabel 2.13: Hitungan manfaat investasi Medikara+ pada pengandaian bab ini

Ukuran	Target	Hasil tiga bulan
Waktu tunggu	25 menit	38 menit
Penurunan dari 40 menit	15 menit	2 menit
Capaian terhadap target	100 persen	13,3 persen
Jam tunggu yang dihemat per tahun	84.000 jam	11.200 jam
Biaya per jam yang dihemat	sekitar Rp19.000	sekitar Rp143.000

Biaya per jam menjadi 7,5 kali lebih mahal bila hasil berhenti pada 38 menit. Laporan kemajuan pekerjaan tidak dapat memperlihatkan selisih itu. Tabel 2.14 merangkum rantai keputusan menuju nilai beserta bukti yang perlu diminta pada tiap tahap.

Tabel 2.14: Rantai keputusan menuju nilai

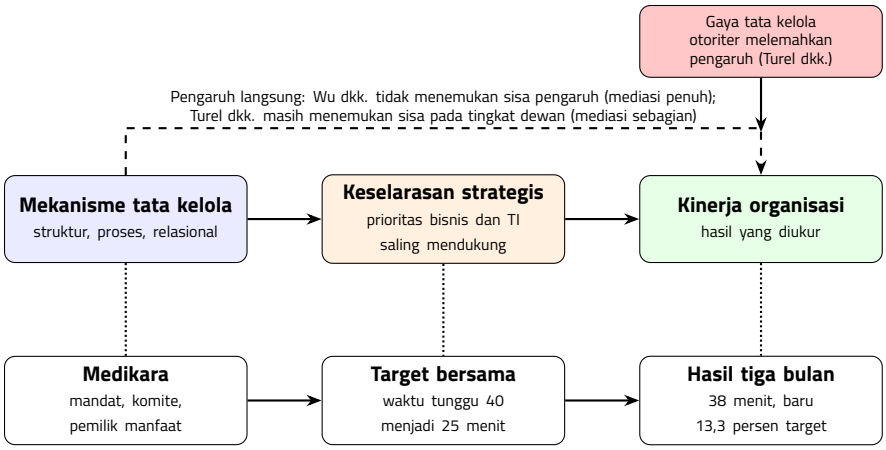
Tahap	Bukti	Pertanyaan kritis
Tata kelola	Mandat dan keputusan	Apakah prioritas jelas?
Keselarasan	Target bersama bisnis dan TI	Apakah proses ikut berubah?
Hasil	Waktu tunggu dan mutu	Apakah data dapat dibandingkan?
Nilai	Manfaat dengan risiko terkendali	Siapa menerima hasilnya?

Bukti empiris: apa yang boleh disimpulkan

Apakah tata kelola TI benar-benar berkaitan dengan kinerja? Wu, Straub, dan Liang meneliti hubungan mekanisme tata kelola, keselarasan strategis, dan kinerja dengan data berpasangan manajer bisnis dan manajer TI dari 131 perusahaan di Taiwan. Validasi silangnya memakai data arsip dari 72 perusahaan. Mekanisme tata kelola berpengaruh positif pada keselarasan, dan keselarasan berpengaruh positif pada kinerja. Pengaruh tata kelola pada kinerja sepenuhnya melewati keselarasan, atau dimediasi penuh [170].

Mediasi berarti ada perantara di antara dua hal. Tata kelola memperbaiki keselarasan, lalu keselarasan memperbaiki kinerja. Turel, Liu, dan Bart memberi

gambaran yang berbeda pada tingkat dewan. Studi pertama mereka menemukan keselarasan memediasi sebagian. Studi kedua menemukan gaya tata kelola otoriter melemahkan pengaruh tata kelola TI tingkat dewan pada kinerja [155]. Gambar 2.6 memperlihatkan letak perbedaan itu.



Gambar 2.6: Rantai tata kelola, keselarasan, dan kinerja beserta contoh pengandaian Medikara

Tabel 2.15 merangkum enam sumber dan batas penerapannya. Ringkasan temuan diambil dari abstrak tiap artikel. Mahasiswa yang memakainya untuk capstone perlu membaca metode pada teks lengkapnya.

Bersama-sama, sumber ini memberi tiga pesan. Pertama, arah hubungannya sama. De Haes dan Van Grembergen menemukan kematangan keselarasan lebih tinggi pada organisasi yang memakai paduan praktik tata kelola yang matang [28]. Meta-analisis Gerow dkk. menemukan seluruh korelasi rata-rata antara dimensi keselarasan dan variabel terikat bernilai positif [44]. Kedua, besar dan jalur pengaruhnya belum seragam, seperti terlihat pada perbedaan mediasi penuh dan sebagian. Ketiga, korelasi tidak membuktikan sebab akibat. Penelitian survei tidak membuktikan bahwa satu komite tertentu otomatis menyebabkan peningkatan kinerja di semua organisasi.

Pembaca perlu menilai konteks, ukuran organisasi, cara mengukur variabel, dan kemungkinan penjelasan lain. Penerapan pada rumah sakit Indonesia memerlukan pemeriksaan tambahan atas tata kelola klinis, kewajiban data, budaya keputusan, serta kapasitas perubahan. Bukti empiris menjadi dasar hipotesis yang diuji, bukan janji hasil. Misalkan waktu tunggu Medikara turun menjadi 30 menit setelah komite bekerja. Tim masih perlu memeriksa apakah penurunan itu berasal dari keputusan komite, dari penambahan petugas, atau dari pola kunjungan yang berubah.

Tabel 2.15: Bukti empiris tata kelola TI dan batas penerapannya

Sumber	Data	Temuan	Batas penerapan
Weill (2004)	Lebih dari 250 perusahaan, 23 negara	Letak hak keputusan mengikuti tujuan kinerja	Tidak khusus rumah sakit
De Haes dan Van Grembergen (2009)	Beberapa strategi penelitian	Kematangan keselarasan lebih tinggi pada paduan praktik yang matang	Kajian eksploratif
Huang dkk. (2010)	3 organisasi kecil dan menengah	Komite dan komunikasi menjelaskan perbedaan hasil pemakaian TI	Berupa proposisi
Gerow dkk. (2014)	Meta-analisis	Korelasi rata-rata keselarasan dengan kinerja positif	Korelasi, bukan sebab akibat
Wu dkk. (2015)	131 perusahaan Taiwan, 72 data arsip	Keselarasan memediasi penuh	Satu negara; survei
Turel dkk. (2017)	Dua studi empiris	Keselarasan memediasi sebagian; gaya otoriter melemahkan	Tingkat dewan; perlu dipetakan ke dua organ

2.7 Aktivitas: Matriks Hak Keputusan dan Piagam Komite Pengarah TI

Tujuan. Merancang pembagian kewenangan yang dapat dijalankan dan diperiksa, lalu menuangkannya ke dalam matriks hak keputusan dan rancangan piagam komite pengarah TI.

Pembagian peran. Tabel 2.16 membagi peran dalam tim. Peran yang sama dengan Bab 1 dapat dipertahankan.

Langkah kerja.

1. Buka profil organisasi dan peta pemangku kepentingan dari Bab 1.
2. Daftar 8 sampai 10 keputusan TI penting dari konteks C1, misalnya pemilihan vendor SIMRS, anggaran keamanan, atau pembukaan data ke mitra. Pastikan kelima keputusan Weill dan Ross terwakili.
3. Isi pihak pemberi masukan, pemutus akhir, pengawas, batas delegasi, dan bukti untuk setiap keputusan.
4. Periksa dasar kewenangannya pada anggaran dasar dan aturan tata kelola

Tabel 2.16: Pembagian peran dalam Aktivitas Bab 2

Peran	Tanggung jawab	Luaran pada bab ini
Pemilik konteks	Memastikan matriks mencerminkan kenyataan, bukan sekadar bagan organisasi	Contoh keputusan yang benar terjadi
Analis regulasi	Memeriksa anggaran dasar, delegasi, dan aturan tata kelola perusahaan	Dasar kewenangan tiap baris
Analis risiko	Menandai batas penerimaan risiko dan jalur eskalasi	Batas delegasi dan skenario uji
Analis teknologi	Menjelaskan dependensi dan bukti pelaksanaan	Daftar bukti tiap keputusan

perusahaan. Bila dokumen tidak dapat diakses, tulis "belum diperiksa", bukan dugaan.

5. Uji matriks dengan dua keputusan yang sudah terjadi. Catat siapa yang memutuskan dalam kenyataan.
6. Bandingkan pola saat ini dengan arketipe hak keputusan dan identifikasi satu konflik kewenangan.
7. Tulis piagam komite yang mencakup tujuan, mandat, anggota, wewenang, kuorum, frekuensi rapat, agenda EDM, konflik kepentingan, eskalasi, dan laporan ke direksi.
8. Uji piagam memakai satu keputusan investasi dan satu insiden mendesak, lalu perbaiki bagian yang tidak menghasilkan pemutus jelas.
9. Simpan versi bertanggal dan daftar bukti yang masih dibutuhkan untuk tinjauan hari Sabtu.

Data organisasi nyata wajib seizin organisasi dan dianonimkan. Matriks memakai jabatan, bukan nama orang. Data pribadi pasien atau karyawan tidak boleh dipakai.

Luaran. Matriks hak keputusan berisi 8 sampai 10 keputusan, serta rancangan piagam komite pengarah TI yang sudah diuji dengan dua skenario.

Kaitan dengan tonggak capstone. Matriks hak keputusan dan piagam komite masuk C1 Konteks dan Strategi. Rancangan ini diselaraskan dengan forum arsitektur pada IT40513 dan dipakai ulang untuk model target pada Bab 8.

Kriteria penilaian. Kejelasan kewenangan 30 persen; kesesuaian konteks serta delegasi 25 persen; cakupan EDM dan eskalasi 25 persen; keterlacakan bukti dan justifikasi pilihan 20 persen.

Berkas pendukung.

- `sources/chapter02/matriks-hak-keputusan.csv`: contoh delapan keputusan dan baris isian.
- `sources/chapter02/templat-piagam-komite-ti.md`: templat piagam, format catatan keputusan, dan skenario uji.
- `sources/chapter02/lembar-telaah-penelitian.md`: panduan membaca penelitian untuk Latihan 3.

Pendalaman Teknis (opsional)

Jejak keputusan dapat ditelusuri pada sistem tiket atau repositori kode. Misalkan persetujuan perubahan memerlukan dua peninjau, tetapi pengaturan memungkinkan pengembang menyetujui perubahannya sendiri. Bandingkan aturan tertulis, konfigurasi aktual, dan contoh perubahan. Misalkan dari 20 perubahan yang diperiksa, 3 perubahan (15 persen) disetujui oleh pembuatnya sendiri. Temuan itu lebih kuat daripada pernyataan bahwa aturan sudah berlaku.
Aturan persetujuan *merge* pada repositori kode memberi bukti serupa. Jejak seperti ini menunjukkan apakah hak keputusan benar-benar dijalankan. Hanya gunakan akses baca yang berizin dan laporkan hasil agregat tanpa nama pengguna.

2.8 Ringkasan

Tata kelola TI merupakan bagian dari tata kelola organisasi. Pada perseroan Indonesia, direksi mengurus dan dewan komisaris mengawasi serta memberi nasihat. Struktur komite harus mengikuti kewenangan hukum, anggaran dasar, dan delegasi yang berlaku. Mendelegasikan pekerjaan atau menyewa vendor tidak memindahkan seluruh pertanggungjawaban. Karena itu, pemilik manfaat perlu ditetapkan pada fungsi bisnis yang mampu mengubah hasil layanan.

Model EDM menghubungkan evaluasi pilihan, arahan, serta pemantauan hasil. Edisi 2024 ISO/IEC 38500 menekankan keselarasan dengan prinsip tata kelola organisasi, memakai sebelas prinsip, dan menambahkan pelibatan pemangku kepentingan. Pemantauan pada tingkat tata kelola berbeda dari pemantauan harian manajemen. Laporan 90 persen pekerjaan selesai belum menjawab pertanyaan tentang manfaat.

Matriks hak keputusan memisahkan masukan dari keputusan akhir. Lima keputusan dan enam arketipe Weill dan Ross membantu membaca letak kewenangan, sedangkan jabatan dan batas delegasi membuatnya dapat dijalankan. Tidak ada satu susunan terbaik, karena letak keputusan perlu mengikuti tujuan

kinerja. Veto perlu dibatasi agar keputusan tidak berhenti tanpa pemilik.

Struktur, proses, dan hubungan kerja memastikan mandat diterjemahkan menjadi tindakan yang dapat diperiksa. Komite pengarah TI berguna bila piagamnya memuat mandat, kuorum, konflik kepentingan, dan eskalasi. Bentuknya perlu mengikuti ukuran organisasi, karena komite yang wajar bagi 4.800 karyawan terasa berat bagi klinik dengan 60 karyawan.

Penelitian mendukung pentingnya keselarasan strategis, tetapi hasilnya perlu dibaca bersama konteks dan keterbatasannya. Medikara dapat memakai temuan itu sebagai hipotesis, lalu mengujinya dengan data waktu tunggu dan keputusan yang tercatat. Pesan utama bab ini adalah bahwa forum tata kelola bernilai ketika memperjelas keputusan dan menguji hasil layanan.

2.9 Latihan

Latihan 1: Menguji Agenda Komite

Sebuah rumah sakit membentuk komite pengarah TI, tetapi rapatnya hanya membahas laporan kemajuan proyek. Bagian mana dari model *Evaluate, Direct, Monitor* yang belum dijalankan? Jelaskan.

Latihan ini membuktikan bahwa cakupan tugas komite dinilai dari bukti agenda dan keputusan, bukan dari keberadaan forum.

1. Kumpulkan agenda atau notulen pengandaian, lalu hitung jumlah item laporan dan item keputusan.
2. Tuliskan informasi yang tersedia dan yang belum tersedia dalam agenda.
3. Petakan informasi itu ke tugas EDM dan pelibatan pemangku kepentingan.
4. Usulkan dua perubahan agenda beserta keputusan yang hendak dihasilkan.

Tabel 2.17 memuat contoh terisi dari pengandaian Medikara, dengan 96 item agenda setahun.

Tabel 2.18 adalah lembar isian Latihan 1.

Pertanyaan analisis.

1. Dari data contoh, 75 persen item agenda berupa laporan. Berapa persen yang menurut analisis layak dipertahankan, dan mengapa?
2. Mengapa laporan kemajuan tidak cukup membuktikan fungsi *Monitor* lengkap?
3. Data apa yang paling dahulu diminta sebelum mengizinkan peluncuran?

Tabel 2.17: Contoh terisi Latihan 1

Agenda pengandaian	Tugas EDM	Kekurangan
72 item laporan kemajuan, misalnya 90 persen pekerjaan	*Monitor* pelaksanaan	Belum menguji manfaat: 38 menit dari target 25 menit
Tidak ada pembandingan opsi	*Evaluate*	Pilihan koreksi belum dinilai
Tidak ada batas peluncuran	*Direct*	Syarat penerimaan belum jelas
Tidak ada masukan unit	Pelibatan	Keluhan klinisi di 5 rumah sakit tidak sampai ke forum

Tabel 2.18: Lembar isian Latihan 1

Agenda pengandaian	Tugas EDM	Kekurangan
…	…	…
…	…	…
…	…	…

Latihan 2: Membandingkan Arketipe

Bandingkan dua arketipe hak keputusan untuk investasi aplikasi pasien Medikara+. Mana yang lebih tepat, dan apa *trade-off*-nya?

Latihan ini membuktikan bahwa desain kewenangan harus menimbang nilai dan konsekuensi, bukan meniru pola yang populer.

1. Pilih dua arketipe dan nyatakan letak keputusan masing-masing dengan jabatan.
2. Bandingkan kecepatan, kompetensi, risiko, dan konsistensi lintas fasilitas.
3. Pilih satu rancangan serta tulis batas delegasi dan aturan bila terjadi perbedaan pendapat.

Tabel 2.19 memuat contoh terisi. Angka waktu keputusan adalah pengandaian.

Tabel 2.20 adalah lembar isian Latihan 2.

Pertanyaan analisis.

1. Pada contoh, duopoli memerlukan 15 hari lebih lama. Target penuh menghemat sekitar 7.000 jam tunggu per bulan. Berapa jam yang tertunda, dan apakah selisih itu sepadan dengan manfaat duopoli?
2. Siapa memberi keputusan akhir ketika dua pihak tidak sepakat?
3. Kondisi apa yang membuat pilihan arketipe perlu berubah?

Tabel 2.19: Contoh terisi Latihan 2

Kriteria	Monarki TI	Duopoli TI
Letak keputusan	Kepala TI	Kepala TI dan direktur pelayanan
Kecepatan	Misalkan 10 hari	Misalkan 25 hari
Kompetensi	Kelayakan teknis kuat; manfaat layanan kurang terwakili	Nilai serta kelayakan dinilai bersama
Risiko	Alur klinis 5 rumah sakit terlambat diperiksa	Perbedaan pendapat dapat berlarut
Konsistensi	Standar teknis seragam	Standar dan alur diselaraskan

Tabel 2.20: Lembar isian Latihan 2

Kriteria	Arketipe pertama: ...	Arketipe kedua: ...
Letak keputusan	...	...
Kecepatan	...	...
Kompetensi	...	...
Risiko	...	...
Konsistensi	...	...

Latihan 3: Menilai Bukti Penelitian

Ringkas temuan Wu, Straub, dan Liang (2015) tentang peran keselarasan strategis. Nilai apakah temuan itu berlaku untuk organisasi tempat bekerja.

Latihan ini membuktikan kemampuan membedakan temuan artikel dari inferensi penerapannya. Baca abstrak dan metode sumber asli [170], memakai `sources/chapter02/lembar-telaah-penelitian.md`. Teks lengkap mungkin memerlukan akses perpustakaan.

1. Catat pertanyaan penelitian, responden, metode, dan hubungan yang diuji.
2. Pisahkan temuan yang dilaporkan dari dugaan sebab akibat.
3. Bandingkan konteks penelitian dengan organisasi pilihan dan rumuskan satu pemeriksaan tambahan.

Tabel 2.21 memuat contoh terisi.

Tabel 2.22 adalah lembar isian Latihan 3.

Pertanyaan analisis.

1. Wu dkk. melaporkan mediasi penuh, sedangkan Turel dkk. melaporkan mediasi sebagian. Apa saja perbedaan data dan tingkat analisis yang dapat menjelaskan selisih itu?

Tabel 2.21: Contoh terisi Latihan 3

Aspek	Temuan atau inferensi	Batas penerapan
Responden	Temuan: pasangan manajer bisnis dan TI, 131 perusahaan di Taiwan	Negara dan masa pengumpulan data berbeda
Keselarasan strategis	Temuan: peran perantara didukung, mediasi penuh	Bukan jaminan semua komite efektif
Penerapan lokal	Inferensi: misalkan layanan 5 rumah sakit perlu target bersama	Perlu bukti perubahan proses dan hasil
Penjelasan lain	Inferensi: penurunan menjadi 30 menit berasal dari tambahan petugas	Perlu data petugas dan pola kunjungan

Tabel 2.22: Lembar isian Latihan 3

Aspek	Temuan atau inferensi	Batas penerapan
...	...	...
...	...	...
...	...	...

2. Penjelasan lain apa yang dapat menghubungkan tata kelola dengan kinerja?
3. Bukti organisasi apa yang dapat memperkuat atau melemahkan penerapan temuan?

Bab 3

Lanskap Regulasi dan Kewajiban Kepatuhan

Tujuan Pembelajaran

- Mengidentifikasi regulasi dan standar yang mengikat sebuah organisasi berdasarkan sektor, jenis data, dan model bisnisnya.
- Menurunkan pasal regulasi menjadi kewajiban yang dapat diperiksa, lengkap dengan pemilik dan buktinya.
- Membedakan kewajiban hukum, kewajiban kontrak, dan standar sukarela beserta akibat pelanggarannya.

3.1 Pendahuluan

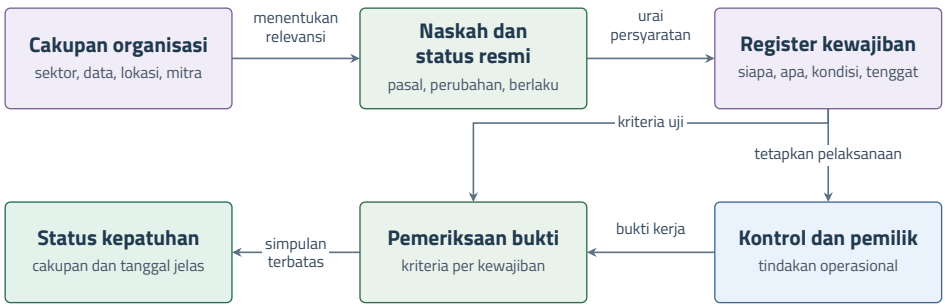
Misalkan pada akhir Juli 2026 sebuah tautan berita tentang aturan pelaksana baru beredar di grup pesan pimpinan Medikara. Direktur pelayanan mengira urusan itu milik teknologi informasi (TI). Kepala TI menunggu penjelasan fungsi hukum. Fungsi hukum menunggu daftar sistem dari TI. Tiga bulan kemudian, belum ada yang membaca naskahnya. Pada saat yang sama, aturan rekam medis yang lebih lama juga belum tuntas. Unit layanan menganggap penyimpanan merupakan tanggung jawab vendor. Vendor menyediakan tempat penyimpanan, sedangkan kontrak tidak menjelaskan bukti pencadangan dan pemulihan. Ketika audit datang, kedua pihak menunjukkan dokumen yang berbeda. Masalah kepatuhan muncul karena kewajiban belum diterjemahkan menjadi pekerjaan dengan pemilik dan bukti.

Analisis dimulai dari bentuk organisasi, sektor, jenis data, lokasi pemrosesan,

dan hubungan mitra. Satu organisasi dapat menghadapi beberapa lapis kewajiban sekaligus. Medikara memiliki 36 fasilitas layanan dengan sekitar 1,2 juta kunjungan pasien per tahun, sehingga satu aturan dapat menyentuh banyak unit. Kelonggaran pada aturan umum juga tidak otomatis menghapus persyaratan yang lebih khusus pada layanan kesehatan. Hasil kerja bab ini adalah register kewajiban untuk tonggak C1 capstone. Bab ini membantu menyusun pertanyaan dan register, bukan memberi nasihat hukum. Penerapan pada organisasi nyata tetap perlu ditinjau penasihat hukum yang berwenang. Bagian yang merupakan tafsir penulis ditandai dengan frasa "penafsiran bab ini".

Bab ini memakai rujukan utama berikut: Undang-Undang (UU) 27/2022 tentang Pelindungan Data Pribadi (PDP), Peraturan Pemerintah (PP) 71/2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik (PSTE), UU 17/2023 tentang Kesehatan beserta PP 28/2024, Peraturan Menteri Kesehatan (Permenkes) 24/2022, Peraturan Presiden (Perpres) 82/2022, serta Peraturan Badan Siber dan Sandi Negara (BSSN) 1/2024. Kerangka register mengikuti ISO 37301:2021 dari International Organization for Standardization (ISO). Naskah asli dan statusnya menjadi dasar register; berita hanya membantu menemukan perkembangan yang perlu diverifikasi [136, 134, 137, 139, 88, 135, 9, 58].

Gambar 3.1 merangkum hubungan komponen dan konsep utama bab ini.



Gambar 3.1: Menurunkan sumber hukum menjadi kewajiban yang dapat diuji

3.2 Membaca Regulasi Indonesia

Mulai dari cakupan organisasi

Pertanyaan pertama bukan "aturan apa yang terbaru", melainkan "organisasi ini siapa". Cakupan organisasi ditentukan oleh sektor, jenis data, lokasi pemrosesan, model bisnis, dan mitra. Setiap jawaban membuka atau menutup satu kelompok

aturan. Daftar aturan yang disusun tanpa langkah ini biasanya menjadi salinan daftar milik organisasi lain.

Cara kerjanya seperti mengurus izin warung makan. Warung di rumah sendiri dan warung dalam kantin sekolah sama-sama menjual makanan, tetapi syaratnya tidak sama. Pemilik warung lebih dulu menjelaskan apa yang dijual, di mana, dan kepada siapa. Barulah jelas kantor mana yang perlu didatangi.

Dua contoh penerapannya:

1. Pasal 3 ayat (2) Permenkes 24/2022 menyebut klinik, rumah sakit, apotek, dan laboratorium kesehatan sebagai fasilitas pelayanan kesehatan [88]. Medikara memiliki 5 rumah sakit, 18 klinik pratama, 1 laboratorium rujukan, dan 12 apotek, atau 36 fasilitas. Register yang hanya mencatat rumah sakit melewatkan 31 fasilitas, atau sekitar 86 persen.
2. Misalkan klinik mitra memiliki 60 karyawan dan 2 staf TI, seperti contoh Bab 2. Ukuran kecil tidak menghapus kewajiban rekam medis elektronik. Ukuran itu memengaruhi cara pemenuhannya. Pasal 22 Permenkes 24/2022 membuka kerja sama penyimpanan ketika sumber daya fasilitas terbatas.

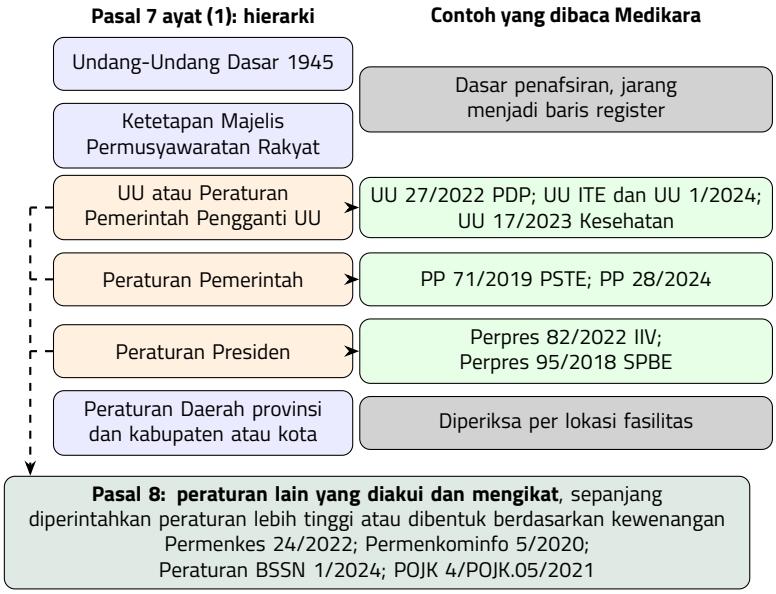
Tabel 3.1 menerapkan lima pertanyaan cakupan pada Medikara. Kolom ketiga adalah titik awal penelusuran. Tim tetap membuktikan keberlakuannya pada tiap baris register. Pada tabel itu, Permenkominfo adalah Peraturan Menteri Komunikasi dan Informatika, dan BPJS adalah Badan Penyelenggara Jaminan Sosial.

Tabel 3.1: Lima pertanyaan cakupan pada Medikara

Pertanyaan	Keadaan Medikara	Titik awal penelusuran
Sektor	Layanan kesehatan swasta dengan 36 fasilitas	UU 17/2023, PP 28/2024, Permenkes 24/2022, Perpres 82/2022
Jenis data	Data kesehatan dari sekitar 1,2 juta kunjungan per tahun; data sekitar 4.800 karyawan	UU PDP, terutama data pribadi spesifik
Lokasi	Sistem di tiap rumah sakit, rencana modernisasi ke *cloud*, dukungan vendor	PP 71/2019, PP 28/2024, Pasal 56 UU PDP
Model bisnis	Medikara+ untuk janji temu dan telekonsultasi, 28.000 janji temu per bulan	PP 71/2019, Permenkominfo 5/2020, Pasal 4 Permenkes 24/2022
Mitra	BPJS Kesehatan, SATUSEHAT, asuransi, klinik mitra, instansi pemerintah	Kontrak, aturan yang mengikat mitra, ketentuan integrasi

Hierarki peraturan

Setelah cakupan jelas, tim perlu tahu kedudukan tiap aturan. UU 12/2011 beserta perubahannya mengatur pembentukan peraturan. Pasal 7 ayat (1) memuat tujuh tingkat hierarki, dan ayat (2) menyatakan kekuatan hukumnya mengikuti hierarki itu. Pasal 8 mengatur jenis lain, termasuk peraturan yang ditetapkan menteri dan badan atau lembaga setingkat. Peraturan tersebut diakui dan mengikat sepanjang diperintahkan peraturan lebih tinggi atau dibentuk berdasarkan kewenangan. Peraturan menteri dan lembaga tidak boleh dianggap tidak mengikat hanya karena tidak tercantum pada daftar Pasal 7 [132]. Gambar 3.2 menempatkan aturan yang dibaca Medikara pada susunan itu. Singkatan ITE, IIV, SPBE, dan POJK pada gambar dijelaskan pada seksi masing-masing.



Gambar 3.2: Kedudukan aturan yang dibaca Medikara menurut Pasal 7 dan Pasal 8 UU 12/2011

Membaca regulasi mirip membaca kontrak sewa. Pembacaan memerlukan naskah yang ditandatangani dan lampiran perubahan. Ringkasan iklan properti membantu mencari tempat, tetapi tidak cukup untuk menyimpulkan kewajiban penyewa.

Memeriksa status di JDIH

Jaringan Dokumentasi dan Informasi Hukum (JDIH) membantu mencari naskah serta metadata. Tim memeriksa nomor, judul, tanggal penetapan, tanggal pengundangan, tanggal berlaku, perubahan, pencabutan, dan putusan yang relevan. Halaman metadata dan naskah lengkap perlu dibaca bersama. Status belum

ditemukan berbeda dari tidak berlaku. Tabel 3.2 merangkum pemeriksaan sumber hukum.

Tabel 3.2: Pemeriksaan sumber hukum

Unsur	Yang diperiksa	Hasil pencatatan
Identitas	Nomor, tahun, dan judul	Rujukan tepat
Waktu	Pengundangan, mulai berlaku, dan ketentuan penutup	Tenggat dengan dasar
Status	Perubahan, pencabutan, putusan	Versi yang dipakai
Cakupan	Subjek dan kondisi penerapan	Alasan berlaku atau bersyarat
Jejak	Sumber resmi dan tanggal akses	Dapat diperiksa ulang orang lain

Dua contoh penerapannya:

1. Bagian menimbang Permenkes 24/2022 menyebut pelaksanaan Pasal 47 ayat (3) UU 29/2004, sedangkan JDIH Badan Pemeriksa Keuangan (BPK) mencatat UU 17/2023 mencabut UU 29/2004. Apakah Permenkes itu gugur? Pasal 453 UU 17/2023 menyatakan peraturan pelaksanaan undang-undang lama tetap berlaku sepanjang tidak bertentangan. Pasal 787 PP 28/2024 menyerahkan rincian rekam medis elektronik kepada peraturan menteri. Pada 31 Oktober 2026, JDIH BPK mencatat Permenkes 24/2022 berstatus berlaku. Satu baris register memerlukan empat pemeriksaan ini [88, 137, 139].
2. Publikasi resmi Badan Pengawas Obat dan Makanan (BPOM) menyebut PP 33/2026 diundangkan pada 16 Juli 2026 [8]. Basis data nonresmi mencatat judulnya sebagai peraturan pelaksanaan UU PDP dengan tanggal mulai berlaku 16 Januari 2027, atau enam bulan sesudah pengundangan [99]. Bila tanggal itu benar, sisa waktu dari 31 Oktober 2026 adalah 77 hari. Penelusuran bab ini belum memperoleh naskah resmi. Tim mencatat angka itu sebagai pemantauan, lalu mencari ketentuan penutup pada naskah resmi sebelum memasukkannya sebagai tenggat.

Surat edaran, panduan teknis, rancangan peraturan, dan undang-undang memiliki fungsi berbeda. Dokumen yang masih berupa rancangan dicatat sebagai pemantauan perubahan. Bila naskah resmi belum tersedia, tim mencatat ketidakpastian beserta penanggung jawab penelusuran, bukan mengarang isi pasal. Dua salinan aturan dengan judul sama juga perlu dibedakan. Tim menyimpan nomor, versi, sumber resmi, dan tanggal akses, sehingga kesimpulan tidak bergantung pada nama berkas.

Kasus Medikara Health: Tautan di Grup Pesan

Misalkan direksi menyelesaikan kebingungan pada awal bab dengan tiga keputusan. Analis regulasi menjadi pemilik pemantauan aturan baru. Setiap temuan masuk daftar pemantauan paling lambat 5 hari kerja, lengkap dengan sumber dan status pembacaannya. Pemilik proses terdampak memutuskan pekerjaan lanjutan, bukan analis yang mengisi tabel.
Keputusan ini punya dua konsekuensi. Pertama, tautan berita tidak lagi berhenti di grup pesan. Tautan itu menjadi satu baris dengan pemilik dan tanggal. Kedua, kekosongan tetap terlihat. Baris PP 33/2026 berstatus "teks belum diperiksa", sehingga tidak ada yang keliru menganggapnya sudah patuh, dan tidak ada yang keliru menganggapnya belum ada.

3.3 Pelindungan Data Pribadi dan Sistem Elektronik

UU PDP: dipetakan di sini, dirinci di Bab 7

UU PDP mengatur pemrosesan data pribadi, termasuk dasar pemrosesan dan pertanggungjawaban pengendali. Pasal 4 ayat (2) menempatkan data dan informasi kesehatan sebagai data pribadi yang bersifat spesifik. Pasal 46 ayat (1) mengatur pemberitahuan tertulis kegagalan pelindungan data pribadi paling lambat 3×24 jam kepada subjek data dan lembaga, dan ayat (2) menetapkan isi minimumnya [136]. Bab 7 mengambil rincian pelaksanaan itu. Bab ini cukup memetakan pasal ke baris register, seperti pada Tabel 3.3.

Tabel 3.3: Pemetaan UU PDP ke register dan bab yang merincinya

Pasal	Isi ringkas	Register	Rincian
Pasal 4	Data kesehatan termasuk data spesifik	Kolom cakupan	Bab 7
Pasal 20	Dasar pemrosesan	K-16	Bab 7
Pasal 39	Mencegah akses tidak sah	K-01	Bab 6, Bab 7
Pasal 46	Pemberitahuan tertulis 3×24 jam	K-04	Bab 7
Pasal 56	Transfer ke luar wilayah hukum	K-13	Bab 7
Pasal 57	Sanksi administratif	Kolom akibat	Bab ini
Pasal 74	Masa penyesuaian 2 tahun	Catatan status	Bab ini

Status juga mencakup putusan pengadilan. Putusan Mahkamah Konstitusi (MK) Nomor 151/PUU-XXII/2024, yang diucapkan 30 Juli 2025, menyatakan kata "dan" pada Pasal 53 ayat (1) huruf b tidak mengikat secara bersyarat sepanjang tidak dimaknai "dan/atau" [95]. Membaca UU PDP tanpa putusan ini menghasilkan kriteria yang keliru. Bab 7 membahas akibatnya pada fungsi pelindungan data.

Pertanyaan kemudian muncul: seberapa berat akibatnya bila kewajiban dilewatkan? UU PDP memberi dua angka yang perlu dicatat.

1. Pasal 57 ayat (3) menetapkan denda administratif paling tinggi 2 persen dari pendapatan atau penerimaan tahunan terhadap variabel pelanggaran [136]. Misalkan pendapatan yang menjadi variabel pelanggaran di Medikara adalah Rp500 miliar. Batas atas dendanya Rp10 miliar, sama dengan anggaran modernisasi pengandaian Bab 1. Cara menetapkan variabel itu perlu dibaca pada aturan pelaksana, sehingga angka ini hanya alat diskusi.
2. Pasal 74 memberi masa penyesuaian paling lama 2 tahun sejak pengundangan pada 17 Oktober 2022. Masa itu berakhir pada 17 Oktober 2024. Insiden vendor Medikara terjadi pada 2025, sehingga alasan "masih masa penyesuaian" tidak tersedia. Pembacaan ini adalah penafsiran bab ini.

PP 71/2019: siapa penyelenggara dan apa kewajibannya

PP 71/2019 membedakan Penyelenggara Sistem Elektronik (PSE) lingkup publik dan privat pada Pasal 2. Lingkup privat antara lain mencakup penyelenggara yang diatur atau diawasi kementerian atau lembaga, serta penyelenggara yang memiliki portal, situs, atau aplikasi untuk penawaran barang dan jasa. Pasal 6 mewajibkan pendaftaran sebelum sistem mulai digunakan pengguna. Pasal 24 mewajibkan prosedur dan sarana pengamanan. Pasal 24 ayat (3) juga mewajibkan laporan dalam kesempatan pertama kepada aparat penegak hukum serta kementerian atau lembaga terkait, bila kegagalan berdampak serius terjadi akibat perbuatan pihak lain. Pasal 100 memuat sanksi administratif [134].

Permenkominfo 5/2020 merinci pendaftaran PSE lingkup privat. Pasal 2 ayat (2) huruf b angka 6 mencakup pemrosesan data pribadi untuk kegiatan operasional melayani masyarakat yang terkait transaksi elektronik. Pasal 5 mewajibkan perubahan informasi pendaftaran dilaporkan. Pasal 7 ayat (2) menetapkan pemutusan akses (*access blocking*) bagi PSE yang tidak mendaftar [90]. Penafsiran bab ini: Medikara+ termasuk lingkup privat, karena Medikara berbadan usaha swasta dan aplikasinya melayani masyarakat secara daring.

UU Informasi dan Transaksi Elektronik (ITE), yaitu UU 11/2008, telah diubah dengan UU 19/2016 dan UU 1/2024. Undang-undang ini perlu dibaca pada persoalan sistem serta transaksi elektronik yang relevan, dalam versi yang sudah memuat perubahan terakhir [138]. Tim juga tidak menyatukan semua tenggat pelaporan insiden ke dalam satu angka. Notifikasi PDP, pelaporan siber, dan pemberitahuan kontrak dapat memiliki penerima serta pemicu yang berbeda.

Satu kejadian kerusakan kendaraan dapat memerlukan laporan kepada pemilik, perusahaan asuransi, dan petugas jalan. Menghubungi salah satu pihak tidak otomatis memenuhi kewajiban kepada pihak lain.

Dua contoh penerapannya:

1. Varian uji kontrak, sama dengan Bab 7: misalkan kontrak mewajibkan vendor melapor dalam 12 jam, dan vendor memberi tahu kebocoran setelah 30 jam. Kontrak terlewati 18 jam. Bila kegagalan dan penemuan terjadi bersamaan, sisa rentang Pasal 46 tinggal 42 jam dari 72 jam. Bab 7 mengingatkan bahwa Pasal 46 ayat (1) tidak secara eksplisit memakai frasa sejak diketahui, sehingga tim mencatat waktu kejadian dan waktu diketahui secara terpisah, lalu fungsi hukum menetapkan batas operasional yang konservatif. Salinan pihak ketiga PP 33/2026 Pasal 114 ayat (2) hanya dipantau, karena naskah resminya belum diperoleh [99].
2. Misalkan aplikasi pasien dengan 28.000 janji temu per bulan, atau 336.000 per tahun, memakai pusat data luar negeri. Tim memeriksa aliran data aktual, salinan cadangan, dukungan jarak jauh, serta aturan sektor. Lokasi server utama saja belum menjelaskan seluruh pemrosesan.

Tabel 3.4 merangkum lapisan penilaian data dan sistem.

Tabel 3.4: Lapisan penilaian data dan sistem

Lapisan	Pertanyaan	Bukti
UU PDP	Data apa, untuk tujuan apa, dengan dasar apa?	Catatan pemrosesan
PSTE dan ITE	Siapa PSE, sudah terdaftar, dan bagaimana sistem dikelola?	Tanda daftar dan dokumen penyelenggaraan
Aturan sektor	Apakah ada syarat khusus penyimpanan?	Naskah aturan dan kontrak
Perkembangan aturan	Apakah teks baru sudah diverifikasi?	Catatan pemantauan regulasi

Kasus Medikara Health: Siapa PSE untuk Medikara+?

Medikara+ dibuat vendor, tetapi janji temu dan telekonsultasi melayani pasien Medikara. Misalkan tanda daftar PSE tercatat atas nama vendor. Misalkan pula pimpinan menyimpulkan seluruh kewajiban sudah pindah ke vendor.

Kesimpulan itu mencampur dua pertanyaan. Pertanyaan pertama: siapa yang wajib mendaftar sebagai PSE? Pertanyaan kedua: siapa pengendali data pribadi? Tanda daftar vendor belum menjawab pertanyaan kedua. Pasal 962 PP 28/2024 menyatakan setiap penyelenggara Sistem Informasi Kesehatan merupakan pengendali data pribadi, dan Pasal 946 menyebut fasilitas pelayanan kesehatan sebagai salah satu penyelenggaranya [139]. Pasal 37 UU PDP juga mewajibkan pengendali mengawasi pihak yang

terlibat dalam pemrosesan di bawah kendalinya [136]. Tim mencatat K-10 untuk pendaftaran dan K-16 untuk dasar pemrosesan, lalu meminta tinjauan fungsi hukum atas peran tiap pihak.

3.4 Regulasi Sektor Kesehatan

Rantai tiga tingkat

Kewajiban rekam medis tersusun dalam tiga tingkat. UU 17/2023 menetapkan pokoknya. PP 28/2024 menjabarkannya. Permenkes 24/2022 memberi rincian operasional. Pasal 296 ayat (2) UU 17/2023 menempatkan penyelenggaraan rekam medis sebagai tanggung jawab fasilitas, kecuali praktik mandiri. Pasal 779 PP 28/2024 mewajibkan rekam medis diselenggarakan secara elektronik. Pasal 781 mewajibkan integrasi dengan Sistem Informasi Kesehatan Nasional. Pasal 45 Permenkes 24/2022 menetapkan batas penyelenggaraan paling lambat 31 Desember 2023, sehingga masa peralihan itu sudah lewat [137, 139, 88]. Tabel 3.5 merangkum rantai tersebut.

Tabel 3.5: Rantai aturan rekam medis dan data kesehatan

Aturan	Pasal	Isi ringkas
UU 17/2023	296	Tanggung jawab fasilitas; penyimpanan dan kerahasiaan
UU 17/2023	297	Dokumen milik fasilitas; pasien berhak mengakses informasinya
PP 28/2024	779, 781	Wajib elektronik; integrasi dengan sistem nasional; berlaku juga untuk telemedisin
PP 28/2024	966	Pusat data di dalam wilayah Indonesia; syarat jasa pihak lain
PP 28/2024	972	Transfer ke luar wilayah hukum: tujuan spesifik, izin Menteri
Permenkes 24/2022	20	Keamanan penyimpanan, media tersertifikasi, cadangan
Permenkes 24/2022	21	Terhubung dengan platform Kementerian Kesehatan
Permenkes 24/2022	22	Kerja sama penyimpanan dengan PSE berfasilitas dalam negeri
Permenkes 24/2022	39	Penyimpanan paling singkat 25 tahun sejak kunjungan terakhir
Permenkes 24/2022	42	Sanksi administratif atas pelanggaran Pasal 3

Empat kewajiban yang sering tertukar

Empat hal pada rekam medis sering tertukar: retensi, cadangan, interoperabilitas, dan pelaporan. Pembagiannya begini. Retensi menjawab berapa lama data dipertahankan. Cadangan membantu memulihkan data ketika salinan utama rusak. Interoperabilitas menjawab apakah data sampai dan terbaca di sistem tujuan. Pelaporan menjawab siapa perlu diberi tahu ketika ada kejadian. Sistem dapat memiliki cadangan harian tetapi gagal mempertahankan rekam medis selama jangka yang diperlukan. Interoperabilitas juga berbeda dari pengiriman yang berhasil. Organisasi perlu memeriksa data yang dikirim, kesesuaian tujuan, hasil pemrosesan, dan penanganan kegagalan.

Pasal 20 ayat (4) dan (5) Permenkes 24/2022 mewajibkan cadangan data di tempat berbeda dari lokasi fasilitas, dilakukan secara periodik, dan dituangkan dalam standar prosedur operasional. Pasal 21 mewajibkan rekam medis elektronik terhubung dengan platform yang dikelola Kementerian Kesehatan. Pasal 39 menetapkan penyimpanan paling singkat 25 tahun sejak kunjungan terakhir pasien [88]. Bab ini memperlakukan SATUSEHAT sebagai platform yang dimaksud Pasal 21. Itu penafsiran bab ini, mengikuti fakta kasus. Dokumentasi teknis SATUSEHAT dipakai pada mata kuliah platform; register tata kelola, risiko, dan kepatuhan menjaga keterkaitan kewajiban dengan pemilik serta buktinya.

Arsip kontrak yang disimpan selama bertahun-tahun memerlukan indeks dan cara membacanya kembali. Menaruh salinan di lemari kedua membantu saat lemari pertama rusak, tetapi tidak menjamin seluruh kontrak tetap terbaca sampai akhir masa simpan.

Dua contoh penerapannya:

1. Misalkan lima rumah sakit memakai versi Sistem Informasi Manajemen Rumah Sakit (SIMRS) berbeda. Satu prosedur retensi korporat perlu diterjemahkan ke bukti konfigurasi dan pemulihan pada tiap sistem. Dengan sekitar 1,2 juta kunjungan per tahun, data 25 tahun mencapai sekitar 30 juta catatan kunjungan bila jumlahnya tetap. Pasien yang terakhir berkunjung pada 2 Maret 2026 memiliki batas simpan paling singkat sampai 2 Maret 2051.
2. Misalkan klinik mengirim 1.000 catatan dan 40 ditolak platform, atau 4 persen. Bukti pengiriman 1.000 catatan belum membuktikan seluruh kewajiban interoperabilitas terlaksana. Bila keadaan yang sama terjadi di 18 klinik, 720 dari 18.000 catatan perlu ditelusuri.

Tabel 3.6 merangkum kewajiban rekam medis dan contoh bukti.

Tabel 3.6: Kewajiban rekam medis dan contoh bukti

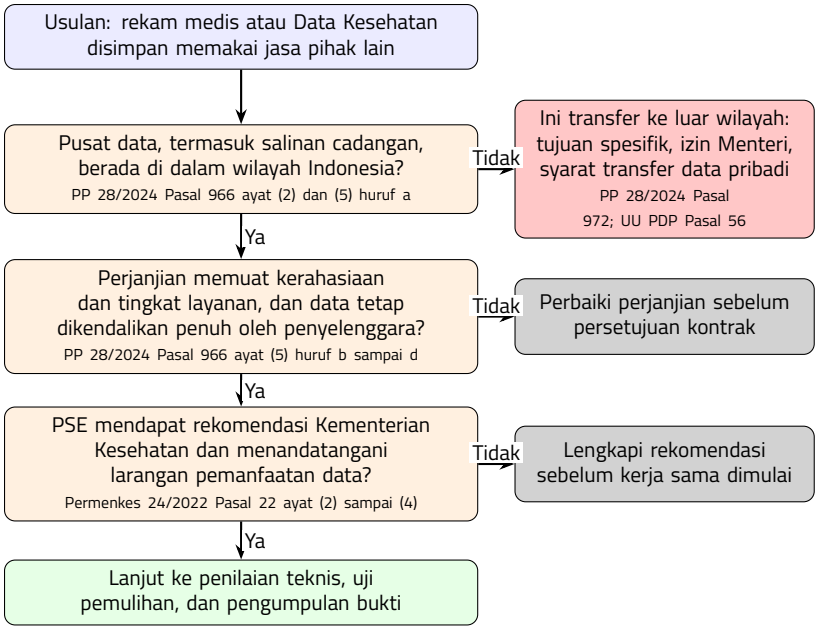
Dasar	Kewajiban ringkas	Bukti contoh
Permenkes Pasal 20	Penyimpanan aman dan cadangan	Prosedur serta hasil uji pemulihan
Permenkes Pasal 21	Interoperabilitas platform kementerian	Rekonsiliasi hasil integrasi
Permenkes Pasal 22	Syarat kerja sama penyimpanan	Kontrak, lokasi, rekomendasi, dan akses data
Permenkes Pasal 30	Hak akses ditetapkan pimpinan fasilitas	Daftar hak akses dan hasil peninjauan
Permenkes Pasal 39	Retensi sedikitnya 25 tahun	Jadwal retensi dan uji akses arsip
PP 28/2024 Pasal 966	Pusat data di dalam wilayah Indonesia	Inventaris lokasi data dan cadangan

Bolehkah disimpan di luar negeri?

Pertanyaan kemudian muncul: bolehkah rekam medis disimpan di luar negeri? Aturan umum dan aturan sektor perlu dibaca bersama. Pasal 21 PP 71/2019 mengizinkan PSE lingkup privat mengelola sistem dan data di dalam atau di luar wilayah Indonesia, dengan kewajiban memastikan efektivitas pengawasan dan penegakan hukum [134]. Ketentuan umum ini tidak otomatis membolehkan seluruh rekam medis disimpan di luar negeri, karena aturan kesehatan lebih khusus.

Pasal 781 PP 28/2024 menempatkan rekam medis elektronik sebagai bagian Sistem Informasi Kesehatan fasilitas. Untuk penyimpanan data kesehatan, Pasal 966 ayat (2) menyatakan pangkalan data berupa pusat data yang berada di dalam wilayah Indonesia. Ayat (5) mengizinkan jasa pihak lain bila dilaksanakan di dalam wilayah Indonesia, berdasarkan perjanjian kerja sama, dengan data yang dimiliki dan dikendalikan penuh oleh penyelenggara. Pasal 972 mengatur transfer ke luar wilayah hukum untuk tujuan spesifik dan terbatas, dengan izin Menteri, serta memenuhi syarat transfer data pribadi [139]. Pasal 22 Permenkes 24/2022 menambahkan kerja sama penyimpanan dengan PSE berfasilitas dalam negeri, dalam hal fasilitas memiliki keterbatasan sumber daya, dengan rekomendasi unit data Kementerian Kesehatan [88].

Gambar 3.3 menyusun bacaan itu sebagai pertanyaan desain. Urutannya adalah penafsiran bab ini, termasuk perlakuan salinan cadangan sebagai bagian dari penyimpanan. Pasal 966 tidak menyebut lokasi cadangan secara tersendiri. Hubungan aturan umum dan aturan khusus pada kasus nyata tetap perlu dinilai penasihat hukum.



Gambar 3.3: Pertanyaan desain untuk penyimpanan rekam medis oleh pihak lain (penafsiran bab)

Kasus Medikara Health: Satu Data, Beberapa Lapis Kewajiban

Medikara memiliki integrasi SATUSEHAT, aplikasi pasien buatan vendor, dan sistem rumah sakit yang berbeda versi. Misalkan vendor menawarkan penyimpanan baru di luar negeri seharga Rp420 juta per tahun. Biaya penyimpanan saat ini Rp600 juta per tahun, sehingga penghematannya Rp180 juta, atau 30 persen. Nilai kontrak Rp420 juta melewati batas Rp400 juta pada Bab 2, sehingga keputusan naik ke direksi.

Tim memeriksa jenis data, dasar pemrosesan dan transfer, ketentuan penyimpanan rekam medis, akses jarak jauh, cadangan, serta syarat kontrak. Pada Gambar 3.3, usulan berhenti pada pertanyaan pertama. Penawaran harga yang lebih rendah tidak cukup menjadi alasan menerima desain sebelum kewajiban sektor dinilai. Direksi menerima dua pilihan: tawar ulang dengan fasilitas dalam negeri, atau pisahkan data bukan rekam medis yang memang boleh dipindahkan setelah dinilai. Keduanya tercatat sebagai keputusan beserta *tradeoff*-nya.

3.5 Keamanan Siber Nasional dan Infrastruktur Informasi Vital

BSSN memiliki peran pada keamanan siber nasional. Perpres 82/2022 mendefinisikan Infrastruktur Informasi Vital (IIV) sebagai sistem elektronik yang menunjang sektor strategis, dan gangguannya berdampak serius terhadap kepentingan umum, pelayanan publik, pertahanan dan keamanan, atau perekonomian nasional. Pasal 4 ayat (1) huruf e memasukkan kesehatan sebagai sektor IIV. Status sektor berbeda dari penetapan sistem tertentu sebagai IIV. Pasal 6 mewajibkan setiap penyelenggara sistem elektronik lingkup sektor IIV melakukan identifikasi paling sedikit 1 kali dalam 1 tahun dan melaporkan hasilnya. Kementerian atau lembaga memverifikasi laporan itu, lalu menetapkan sistem dan penyelenggaranya [135].

Peraturan BSSN 1/2024 mencakup tim tanggap insiden, pelaporan, penanganan, dan kesiapan insiden siber. Pasal 7 dan Pasal 8 meminta penyelenggara IIV dan penyelenggara sistem elektronik lainnya membentuk tim tanggap insiden organisasi. Pasal 15 ayat (3) membatasi insiden yang dilaporkan pada insiden yang paling sedikit berisiko tinggi. Pasal 15 ayat (4) menetapkan isi minimum: kontak pelapor, deskripsi, kronologi, dan dampak serangan. Pasal 15 ayat (5) menetapkan batas 1×24 jam setelah ditemukan bila insiden terjadi pada IIV [9]. Bukti komunikasi, kronologi, klasifikasi, dan tindakan pemulihan perlu dipelihara.

Masuk kawasan rawan banjir tidak berarti setiap bangunan memiliki tingkat risiko yang sama. Pemetaan dan penetapan objek tertentu menentukan tindakan yang lebih khusus, sementara seluruh kawasan tetap memerlukan kesiapsiagaan.

Tim tidak menyimpulkan bahwa semua server rumah sakit otomatis berstatus IIV. Bab ini juga tidak mengasumsikan sistem Medikara sudah ditetapkan, karena fakta kasus tidak menyebutnya. Register memisahkan kewajiban identifikasi pada lingkup sektor dan kewajiban khusus setelah penetapan. Status rancangan undang-undang keamanan siber dicatat dalam daftar pemantauan bila belum tersedia naskah yang telah diundangkan.

Dua contoh penerapannya:

1. Misalkan sistem pendaftaran berhenti selama dua jam di 1 dari 18 klinik. Tim mengklasifikasikan dampak dan memeriksa jalur pelaporan yang sesuai, tanpa menganggap semua gangguan memiliki kewajiban yang identik. Hasil klasifikasi di bawah risiko tinggi tidak masuk Pasal 15 ayat (3), tetapi tetap dicatat sebagai bukti penilaian.
2. Misalkan layanan klinis lintas 5 rumah sakit dan sekitar 640 dokter bergantung pada satu layanan identitas. Ketergantungan itu masuk bahan identifikasi tahunan Pasal 6 dan penilaian status sistem.

Tabel 3.7 merangkum pemisahan status dan respons insiden.

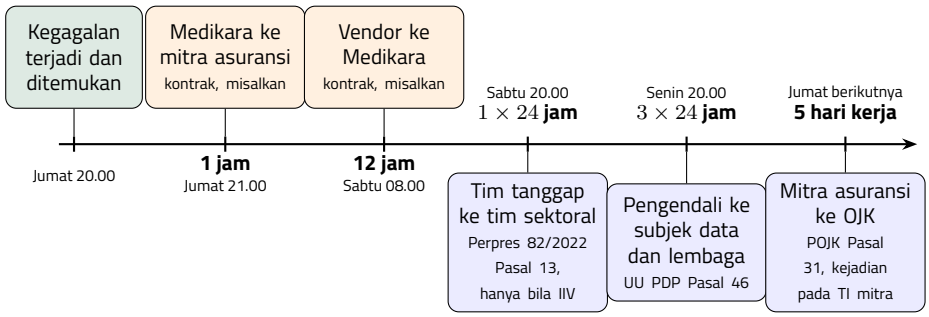
Tabel 3.7: Pemisahan status dan respons insiden

Aspek	Pemeriksaan	Pemilik bukti
Sektor kesehatan	Cakupan Pasal 4 Perpres 82/2022	Analis regulasi
Sistem tertentu	Identifikasi tahunan dan keputusan penetapan	Pemilik sistem
Insiden siber	Risiko, jalur, penerima laporan	Koordinator insiden
Kegagalan PDP	Kewajiban notifikasi tersendiri	Fungsi privasi dan hukum

Satu kejadian, beberapa jam

Dua hal pada insiden sering tertukar: insiden siber dan kegagalan pelindungan data pribadi. Pembagiannya begini. Insiden siber menurut Pasal 1 Perpres 82/2022 mengganggu atau mengancam berjalannya sistem elektronik. Kegagalan pelindungan data pribadi menurut Penjelasan Pasal 46 UU PDP adalah kegagalan melindungi kerahasiaan, integritas, dan ketersediaan data pribadi. Kedua pengertian dapat bertemu pada satu kejadian, tetapi pemicu, penerima, dan batas waktunya berbeda [135, 136].

Gambar 3.4 menyusun batas waktu itu pada satu garis. Skala garis tidak proporsional. Asumsinya sama dengan contoh Bab 7: kegagalan terjadi dan ditemukan bersamaan pada Jumat pukul 20.00 WIB. Tabel 3.8 memuat dasar tiap batas.



Gambar 3.4: Batas waktu pelaporan yang berbeda pada satu kejadian (angka kontrak adalah pengandaian)

Kasus Medikara Health: Satu Insiden Vendor, Beberapa Jam

Kasus ini varian uji kontrak yang juga dipakai Bab 7, bukan kronologi insiden 2025. Misalkan vendor Medikara+ menemukan akun dukungan dipakai di

Tabel 3.8: Dasar, pemicu, dan penerima tiap batas waktu

Dasar	Batas	Pemicu	Dari dan kepada
Kontrak mitra (K-12)	1 jam (misalkan)	Gangguan layanan	Medikara ke mitra asuransi
Kontrak vendor (K-05)	12 jam (misalkan)	Insiden pada vendor	Vendor ke Medikara
Perpres 82/2022 Pasal 13; BSSN 1/2024 Pasal 15	1×24 jam	Insiden pada sistem yang ditetapkan IIV	Tim tanggap organisasi ke tim sektoral, tembusan tim nasional
UU PDP Pasal 46	3×24 jam	Kegagalan pelindungan data pribadi	Pengendali ke subjek data dan lembaga
PP 71/2019 Pasal 24 ayat (3)	Kesempatan pertama	Kegagalan berdampak serius akibat pihak lain	PSE ke aparat penegak hukum dan kementerian atau lembaga
POJK Pasal 31	5 hari kerja	Kejadian kritis pada TI mitra	Mitra asuransi ke OJK

luar penugasan pada Jumat pukul 20.00 WIB, tetapi baru memberi tahu Medikara setelah 30 jam, yaitu Minggu pukul 02.00 WIB. Kontrak 12 jam sudah terlewati 18 jam. Dengan asumsi Bab 7, batas Pasal 46 berakhir Senin pukul 20.00 WIB, sehingga tersisa 42 jam. Koordinator insiden membuka tiga baris: K-04 untuk pemberitahuan, K-05 untuk pelanggaran kontrak, dan K-09 untuk penilaian insiden siber.

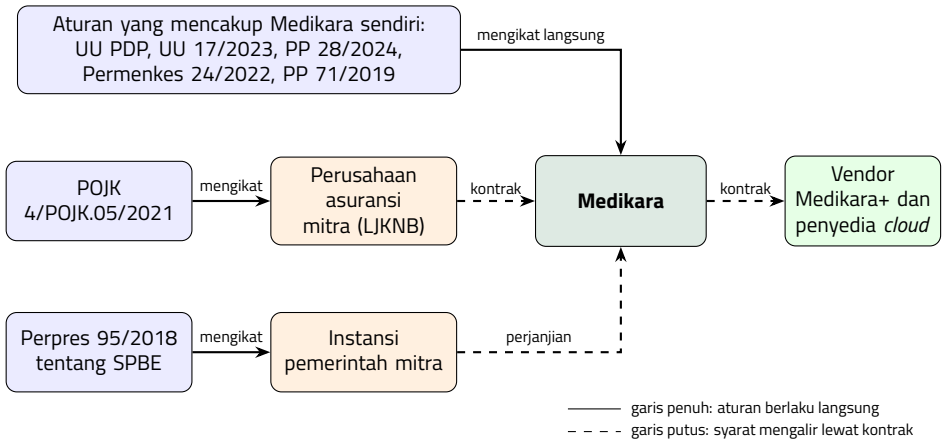
Tim tidak memakai satu laporan untuk semua penerima. Pemberitahuan kepada pasien memuat data yang terungkap, kapan dan bagaimana terungkapnya, serta penanganannya. Laporan insiden siber memuat kontak, deskripsi, kronologi, dan dampak serangan. Data latihan Bab 1 memberi peringatan tambahan: akun dukungan memanggil data selama 8 malam dan baru diketahui pada hari ke-11. Rentang 72 jam setara 3 hari, sehingga tim mencatat waktu kejadian dan waktu diketahui, lalu meminta fungsi hukum menetapkan batas operasional konservatif.

3.6 Regulasi yang Mengikat Mitra: OJK dan SPBE

Otoritas Jasa Keuangan (OJK) mengatur lembaga jasa keuangan sesuai cakupan peraturannya. Peraturan OJK (POJK) 4/POJK.05/2021 membahas manajemen risiko penggunaan TI oleh Lembaga Jasa Keuangan Nonbank (LJKNB). Pasal 2 menyebut perusahaan asuransi sebagai salah satu LJKNB. Pasal 21 mewajibkan

LJKNB tetap bertanggung jawab atas manajemen risiko, mengawasi penyedia jasa TI, dan memberi akses kepada auditor serta OJK. Pasal 31 mewajibkan laporan kejadian kritis paling lambat 5 hari kerja setelah diketahui [120]. Medikara perlu memeriksa ketentuan yang relevan bagi mitra asuransi dan kewajiban yang diteruskan melalui kontrak. Rumah sakit tidak otomatis menjadi lembaga jasa keuangan karena menerima pembayaran klaim.

Sistem Pemerintahan Berbasis Elektronik (SPBE) menjadi konteks bagi mitra instansi pemerintah berdasarkan Perpres 95/2018. Pasal 70 menetapkan pemantauan dan evaluasi SPBE untuk mengukur kemajuan dan meningkatkan kualitas SPBE di instansi pusat dan pemerintah daerah. Sasaran evaluasi itu adalah instansi, bukan rumah sakit swasta [133]. Kerja sama dapat menuntut tata cara integrasi, keamanan, dan bukti tertentu. Arsitektur SPBE dibahas pada IT40513. Bab ini membedakan kewajiban langsung organisasi dari persyaratan kerja sama yang mengalir lewat kontrak. Gambar 3.5 memperlihatkan pembedaan itu.



Gambar 3.5: Aturan yang mengikat langsung dan syarat yang mengalir lewat kontrak

Pemasok makanan kepada sekolah perlu memenuhi aturan usahanya sendiri dan spesifikasi kontrak sekolah. Menjadi pemasok tidak mengubahnya menjadi sekolah, tetapi kontrak dapat mensyaratkan mutu dan jadwal yang lebih ketat.

Dua contoh penerapannya:

1. Misalkan mitra asuransi meminta laporan gangguan dalam satu jam. Tim mencatatnya sebagai kewajiban kontrak dan memeriksa apakah organisasi mampu memenuhinya. Misalkan dari 12 gangguan terakhir, hanya 2 yang dilaporkan dalam satu jam, atau sekitar 17 persen. Status barisnya "tidak memenuhi", dan tim membawa pilihan kepada pemilik mitra: perbaiki deteksi atau tawar ulang klausul.
2. Misalkan rumah sakit pemerintah meminta format bukti integrasi tertentu

sebagai bagian dari 3 dokumen kerja sama. Tim menelusuri dasar permintaan dan memasukkannya pada cakupan kerja sama, bukan menganggap semua aturan internal mitra langsung berlaku.

Hukum, kontrak, dan standar sukarela

Perbedaan tersebut memengaruhi pihak yang berwenang mengubah syarat dan akibat pelanggarannya. Kewajiban hukum tidak dapat dihapus melalui kesepakatan vendor. Syarat kontrak dapat lebih ketat daripada minimum hukum, selama tidak bertentangan dengan ketentuan yang mengikat. Standar sukarela mengikat karena organisasi memilihnya, lalu berubah menjadi kewajiban kontrak bila disebut dalam perjanjian. Tabel 3.9 merangkum jenis kewajiban dalam kerja sama.

Tabel 3.9: Jenis kewajiban dalam kerja sama

Jenis	Sumber	Yang dapat mengubah	Akibat utama
Hukum langsung	Aturan yang mencakup Medikara	Pembentuk aturan atau putusan	Sanksi sesuai aturan
Kontrak	Perjanjian mitra atau vendor	Para pihak	Akibat perjanjian
Standar sukarela	Pilihan organisasi	Organisasi	Komitmen yang ditetapkan; sertifikat dapat hilang
Syarat standar di kontrak	Standar disebut pada perjanjian	Para pihak	Menjadi kewajiban kontrak

Akibat pelanggaran juga berbeda besarnya. Tabel 3.10 memuat akibat yang tertulis pada aturan. Baris kontrak dan standar adalah pengandaian, karena isinya mengikuti perjanjian dan skema sertifikasi masing-masing.

3.7 Register Kewajiban Kepatuhan

Register kewajiban menerjemahkan aturan menjadi siapa melakukan apa, pada kondisi atau tenggat apa, dan bukti apa yang menunjukkan pelaksanaannya. Satu pasal dapat menghasilkan beberapa baris. Satu kontrol juga dapat mendukung beberapa kewajiban, tetapi masing-masing kewajiban tetap perlu dinilai dalam cakupannya. Urutan kerjanya mengikuti Gambar 3.1: cakupan organisasi, naskah dan status resmi, register kewajiban, kontrol dan pemilik, pemeriksaan bukti, lalu status kepatuhan.

ISO 37301:2021 memberi kerangka sistem manajemen kepatuhan untuk

Tabel 3.10: Akibat pelanggaran menurut sumber kewajiban

Sumber	Akibat
UU PDP Pasal 57	Peringatan tertulis, penghentian sementara pemrosesan, penghapusan data, denda paling tinggi 2 persen
UU PDP Pasal 67	Pidana bagi setiap orang yang sengaja dan melawan hukum, misalnya mengungkapkan data bukan miliknya
PP 71/2019 Pasal 100	Teguran tertulis, denda administratif, penghentian sementara, pemutusan akses, dikeluarkan dari daftar
Permenkominfo 5/2020 Pasal 7	Pemutusan akses bagi PSE yang tidak mendaftar
Permenkes 24/2022 Pasal 42	Teguran tertulis, rekomendasi pencabutan atau pencabutan status akreditasi
Kontrak mitra (misalkan)	Denda layanan, kewajiban perbaikan, penghentian kerja sama
Standar sukarela (misalkan)	Temuan audit sertifikasi, pembekuan atau pencabutan sertifikat

mengidentifikasi dan mengelola kewajiban serta memperbaiki pelaksanaan. Istilah *compliance obligations* pada standar itu mencakup yang wajib dan yang dipilih organisasi. Register adalah salah satu alat operasionalnya, bukan pengganti keseluruhan sistem manajemen [58]. Medikara memakainya sebagai acuan cara kerja, bukan sebagai sertifikat yang dikejar pada C1.

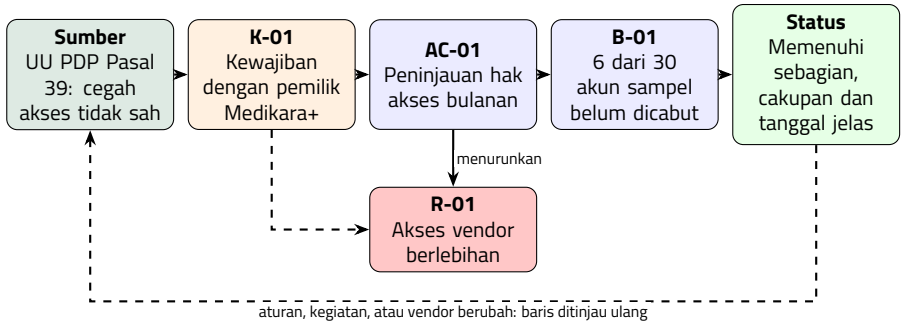
Daftar tugas pindah kantor menjadi berguna ketika setiap tugas memiliki penanggung jawab, tenggat, dan tanda penerimaan. Daftar judul pekerjaan tanpa pemilik hanya memindahkan kebingungan ke dokumen.

Dua contoh penerapannya:

1. K-01 menurunkan Pasal 39 UU PDP tentang pencegahan akses tidak sah. Tim menautkannya ke kontrol AC-01 dan risiko R-01, supaya perubahan bukti diperiksa pada tiga artefak. Bab 1 sudah memberi datanya: 6 dari 30 akun vendor sampel belum dicabut, dan peninjauan berikutnya mencabut 24 dari 120 akun. Gambar 3.6 memperlihatkan jejak baris itu.
2. Misalkan register contoh berisi 16 kewajiban. Sebanyak 7 baris belum memiliki bukti, atau sekitar 44 persen. Tim melaporkan 7 baris belum diverifikasi, bukan menyimpulkan 9 lainnya otomatis patuh hanya karena kolomnya terisi.

Satu pasal, beberapa baris

Bagaimana satu pasal diurai? Tim memisahkan setiap tindakan wajib, lalu menulis pihak, tindakan, kondisi, tenggat, dan bukti. Cara mengujinya sederhana. Pemeriksa yang tidak menulis baris itu harus dapat menyimpulkan status tanpa me-



Gambar 3.6: Jejak satu baris register dari pasal sampai status

nebak maksud penulis. Tabel 3.11 mengurai Pasal 20 ayat (4) dan (5) Permenkes 24/2022. Satu kalimat "wajib memiliki cadangan data" menghasilkan tiga hal yang harus dapat diuji.

Tabel 3.11: Uraian Pasal 20 ayat (4) dan (5) Permenkes 24/2022 menjadi unsur yang dapat diuji

Unsur pasal	Tindakan yang diuji	Bukti
Tempat berbeda	Cadangan berada di luar lokasi tiap fasilitas	Inventaris lokasi cadangan per fasilitas
Periodik	Cadangan berjalan sesuai jadwal	Catatan pekerjaan cadangan dan uji pemulihan
Prosedur tertulis	Prosedur ditetapkan tiap fasilitas	Standar prosedur operasional yang disahkan

Pasal itu menyebut "masing-masing" fasilitas. Misalkan satu prosedur dan satu uji pemulihan per fasilitas per triwulan. Medikara memerlukan 36 prosedur atau satu prosedur korporat dengan lampiran tiap fasilitas, serta 144 uji dalam setahun. Angka 144 menjadi dasar menilai beban kerja 52 staf TI, sehingga kewajiban tidak berhenti sebagai kalimat register.

Status dan pemilik

Status perlu dibedakan: terverifikasi memenuhi, memenuhi sebagian, tidak memenuhi, belum diverifikasi, serta tidak berlaku dengan alasan. Status hijau tanpa bukti dan tanggal penilaian tidak membantu auditor. Kolom pemilik harus menunjuk fungsi yang menerima tanggung jawab, bukan hanya nama analis yang mengisi tabel. Tabel 3.12 memuat arti tiap status dan sebarannya pada register contoh.

Baris "tidak berlaku" pun memerlukan alasan. K-15 mencatat Pasal 31 POJK 4/POJK.05/2021 tidak berlaku langsung, karena Medikara bukan LJKNB. Alasan itu dapat diperiksa dan dapat berubah bila bentuk usaha berubah. Tabel 3.13 merangkum contoh register yang dapat diuji. Berkas lengkapnya ada di `sources/`

Tabel 3.12: Lima status pada register contoh berisi 16 kewajiban

Status	Arti	Jumlah
Terverifikasi memenuhi	Bukti diperiksa, cakupan dan tanggal jelas	2
Memenuhi sebagian	Sebagian cakupan terbukti, sisanya tertulis	4
Tidak memenuhi	Bukti menunjukkan kewajiban tidak terpenuhi	2
Belum diverifikasi	Bukti belum ada atau belum diperiksa	7
Tidak berlaku	Tidak mencakup organisasi, dengan alasan tertulis	1

`chapter03/register-kewajiban.csv`.

Tabel 3.13: Contoh register yang dapat diuji

ID dan dasar	Pemilik dan tindakan	Bukti serta status
K-01, UU PDP Pasal 39	Pemilik Medikara+ mencegah akses tidak sah	Hasil AC-01; memenuhi sebagian
K-02, Permenkes Pasal 20	TI dan rekam medis menguji cadangan	Laporan uji; belum diverifikasi
K-03, Permenkes Pasal 39	Rekam medis menjaga retensi	Jadwal retensi; memenuhi sebagian
K-04, UU PDP Pasal 46	Pengendali menyiapkan pemberitahuan	Kronologi dan salinan; belum diverifikasi
K-05, kontrak vendor	Pengelola vendor menagih laporan 12 jam	Rekam komunikasi; tidak memenuhi
K-15, POJK Pasal 31	Analis regulasi mencatat alasan	Pasal 2 POJK; tidak berlaku

Batas bukti sertifikat

Sertifikat sering dipakai sebagai jalan pintas. ISO/IEC 27001:2022, terbitan ISO dan International Electrotechnical Commission (IEC), menjadi dasar penilaian sistem manajemen keamanan informasi dalam ruang lingkup tertentu [75]. Sertifikat itu tidak menjawab dasar pemrosesan Medikara, pemberitahuan kepada pasien, atau masa simpan 25 tahun. Satu sertifikat tidak menggantikan pemeriksaan cakupan. Bukti sertifikat tetap berguna sebagai masukan untuk baris keamanan, selama lingkup dan masa berlakunya tercatat. Latihan 3 menguji batas ini.

Pendalaman Teknis (opsional)

Register yang baik dapat diturunkan menjadi persyaratan sistem. Contoh tiga kewajiban:

1. Masa simpan (K-03) menjadi kriteria penerimaan: catatan yang berusia 25 tahun dalam data uji masih dapat dibuka, dan penghapusan

otomatis ditolak sebelum batas itu.
2. Cadangan (K-02) menjadi jadwal, pemisahan lokasi, dan uji pemulihan dengan hasil yang disetujui pemilik layanan. Enkripsi cadangan dicatat sebagai keputusan desain untuk mendukung kerahasiaan pada Pasal 29 Permenkes 24/2022.
3. Pencatatan aktivitas (*logging*) untuk K-01 ditautkan ke bukti peninjauan: setiap akses akun vendor tercatat dengan identitas, waktu, dan tujuan.

Cantumkan ID kewajiban pada *backlog* pengembang agar alasan kontrol tetap terlihat. Penelitian rekayasa kebutuhan menempuh jalan serupa. Breaux dan Antón menyajikan metode mengekstrak hak akses dan kewajiban langsung dari teks regulasi, lalu menerapkannya pada seluruh Privacy Rule dalam Health Insurance Portability and Accountability Act (HIPAA) Amerika Serikat [18]. Artikel Massey dan rekan membahas evaluasi kebutuhan keamanan dan privasi yang sudah ada terhadap kepatuhan hukum [96]. Hukumnya berbeda dari hukum Indonesia, sehingga yang dipinjam adalah metodenya, bukan isinya. Berkas `sources/chapter03/periksa_register.py` memeriksa kelengkapan kolom register dan menghitung sebaran status.

3.8 Aktivitas: Register Kewajiban Kepatuhan

Tujuan. Menyusun satu daftar kewajiban yang jelas cakupan, pemilik, dan buktinya, untuk organisasi nyata yang memberi izin atau untuk Medikara.

Pembagian peran. Tim memakai latar belakang anggotanya.

- Analis regulasi memimpin pembacaan pasal. Anggota berlatar hukum membantu pada tahap ini.
- Pemilik konteks menetapkan fungsi pemilik dan memastikan fungsi itu menerima tanggung jawabnya.
- Analis teknologi menilai implikasi sistem, misalnya masa simpan rekam medis atau notifikasi kegagalan pelindungan data pribadi.
- Analis risiko menuliskan konsekuensi dan keterkaitan skenario, termasuk R-01 bila memakai kasus Medikara.

Langkah kerja.

1. Tentukan bentuk organisasi, sektor, kategori PSE, jenis data, lokasi pemrosesan, dan model kerja sama.
2. Periksa sumber resmi serta status tiap aturan; simpan URL, tanggal akses,

dan catatan perubahan.

3. Pilih sedikitnya 10 kewajiban prioritas dan pecah setiap pasal menjadi tindakan yang dapat diuji. Untuk Medikara, register minimal mencakup UU PDP, aturan rekam medis elektronik, PSTE, integrasi SATUSEHAT, dan pelaporan insiden siber.
4. Isi pemilik, kondisi pemicu, tenggat, bukti, status, ID kontrol, dan penanggung jawab verifikasi.
5. Tinjau satu baris bersama anggota lain: buktikan bahwa pemeriksa dapat menyimpulkan status tanpa menebak maksud penulis.
6. Gabungkan register ke C1 dan tandai kewajiban yang perlu diperiksa kembali pada penilaian risiko, privasi, dan audit.

Luaran dan kaitan capstone. Register dan daftar regulasi masuk C1. Kewajiban hukum, kontrak, serta standar sukarela diberi kategori terpisah dan dipakai ulang pada Bab 5, Bab 7, dan Bab 12. Baris kontrak vendor juga berguna pada Bab 9.

Kriteria penilaian. Ketepatan cakupan serta sumber 30 persen; kewajiban yang dapat diuji 30 persen; pemilik dan bukti 25 persen; konsistensi status dan keterkaitan kontrol 15 persen.

Berkas pendukung. `sources/chapter03/register-kewajiban.csv`, `sources/chapter03/daftar-regulasi-medikara.md`, `sources/chapter03/panduan-menurunkan-pasal.md`, `sources/chapter03/periksa-register.py`.

Etika. Data organisasi nyata wajib seizin organisasi dan dianonimkan. Data pribadi pasien atau karyawan tidak boleh masuk register. Register menyimpan rujukan ke bukti, bukan salinan bukti yang memuat data pribadi. Register tim bukan pendapat hukum; simpulan hukum pada organisasi nyata ditinjau pihak yang berwenang.

Pendalaman teknis (opsional). Turunkan tiga kewajiban menjadi persyaratan sistem yang dapat diuji, seperti pada kotak pendalaman, lalu tautkan ke *backlog* tim pengembang.

3.9 Ringkasan

Kepatuhan dimulai dari identifikasi cakupan, bukan dari daftar sertifikat. Jenis organisasi, sektor, data, lokasi, dan hubungan mitra menentukan aturan yang perlu diperiksa. Pada Medikara, pertanyaan cakupan memperluas perhatian dari 5 rumah sakit menjadi 36 fasilitas, dan dari satu undang-undang menjadi beberapa

lapis aturan.

Naskah resmi, metadata status, putusan, serta ketentuan penutup perlu dibaca bersama. Hierarki menjelaskan kedudukan aturan, sedangkan peraturan menteri dan badan tetap mengikat sepanjang memenuhi syarat Pasal 8 UU 12/2011. Perkembangan yang belum memiliki teks terverifikasi, seperti PP 33/2026 pada penelusuran bab ini, dicatat sebagai pekerjaan pemantauan.

Rekam medis, data pribadi, penyelenggaraan sistem elektronik, dan pelaporan siber memiliki persyaratan yang saling melengkapi. Memenuhi satu persyaratan tidak menghilangkan yang lain. Retensi 25 tahun tidak sama dengan cadangan, batas 3×24 jam tidak sama dengan 1×24 jam, dan aturan umum tentang lokasi sistem tidak menghapus ketentuan pusat data pada PP 28/2024.

Sumber kewajiban menentukan akibatnya. Hukum langsung membawa sanksi menurut aturan. Kontrak membawa akibat perjanjian dan dapat lebih ketat daripada minimum hukum. Standar sukarela mengikat karena dipilih, lalu menjadi kewajiban kontrak bila disebut dalam perjanjian. Aturan yang mengikat mitra asuransi atau instansi pemerintah tidak otomatis mengikat Medikara, tetapi syaratnya dapat mengalir lewat kontrak.

Register yang berguna menerjemahkan pasal menjadi tindakan, pemilik, kondisi, dan bukti, lalu memberi status dengan cakupan dan tanggal yang jelas. Pesan utama bab ini adalah bahwa kewajiban baru dapat diperiksa setelah organisasi menjelaskan pekerjaan yang harus dilakukan dan cara membuktikannya.

3.10 Latihan

Latihan 1: Penyimpanan Rekam Medis Lintas Negara

Sebuah klinik mitra menyimpan rekam medis di layanan *cloud* luar negeri. Kewajiban apa saja yang perlu diperiksa, dan pada peraturan mana?

Latihan ini membuktikan kemampuan membaca aturan umum bersama aturan sektor, tanpa menyimpulkan izin hanya dari satu ketentuan.

1. Gambar aliran data, termasuk cadangan dan dukungan jarak jauh.
2. Identifikasi kategori data, pihak pemroses, dan tujuan transfer.
3. Petakan kewajiban UU PDP, PSTE, dan aturan kesehatan, lalu tulis bukti yang masih dibutuhkan.
4. Bandingkan hasilnya dengan Gambar 3.3, lalu tulis keputusan yang diusulkan.

Tabel 3.14 merangkum contoh terisi Latihan 1 pada klinik mitra pengandaian

dengan sekitar 40.000 kunjungan per tahun.

Tabel 3.14: Contoh terisi Latihan 1

Aspek	Dasar penelusuran	Bukti yang diminta
Lokasi pusat data	PP 28/2024 Pasal 966 ayat (2) dan (5)	Daftar lokasi data dan cadangan
Transfer ke luar	PP 28/2024 Pasal 972; UU PDP Pasal 56	Izin Menteri, tujuan, dan penilaian perlindungan
Kerja sama penyimpanan	Permenkes Pasal 22	Lokasi fasilitas PSE, rekomendasi, dan perjanjian
Cadangan dan retensi	Permenkes Pasal 20 dan 39	Prosedur, hasil uji, jadwal retensi
Kategori PSE	PP 71/2019 Pasal 2, Pasal 6, dan Pasal 21	Tanda daftar dan kesiapan akses pengawasan

Tabel 3.15 merangkum lembar isian Latihan 1.

Tabel 3.15: Lembar isian Latihan 1

Aspek	Dasar penelusuran	Bukti yang diminta
…	…	…
…	…	…
…	…	…

Pertanyaan analisis.

1. Mengapa persetujuan pasien saja belum menjawab syarat penyimpanan sektor? Tunjuk baris tabel yang mendukung jawaban.
2. Bagaimana jawaban berubah bila server utama di Indonesia tetapi cadangan di luar negeri?
3. Klinik contoh memiliki sekitar 40.000 kunjungan per tahun. Berapa catatan yang perlu dipindahkan bila data 5 tahun harus kembali ke pusat data dalam negeri, dan siapa yang memutuskan biayanya?

Latihan 2: Dari Pasal ke Pengujian

Tulis ulang satu pasal UU PDP menjadi kewajiban yang dapat diperiksa auditor: siapa melakukan apa, kapan, dan apa buktinya.

Latihan ini membuktikan bahwa rumusan kewajiban harus memberi dasar penilaian yang dapat diulang.

1. Pilih satu pasal dari naskah resmi dan catat cakupannya. Bab 7 sudah memakai Pasal 20, 34, 46, dan 56.

2. Pecah menjadi pihak, tindakan, kondisi pemicu, tenggat, dan bukti.
3. Uji rumusan menggunakan satu skenario pengandaian dan tandai informasi yang belum diketahui.
4. Minta anggota tim lain menyimpulkan status dari rumusan itu, tanpa penjelasan tambahan.

Tabel 3.16 merangkum contoh terisi Latihan 2 dengan varian uji kontrak: vendor melapor setelah 30 jam.

Tabel 3.16: Contoh terisi Latihan 2

Unsur	**Contoh Pasal 46**	**Bukti**
Pihak dan tindakan	Pengendali memberi pemberitahuan tertulis	Salinan serta penerima
Pemicu	Kegagalan pelindungan data pribadi	Kronologi dan analisis kejadian
Waktu	Paling lambat 3×24 jam; sisa 42 jam bila vendor melapor pada jam ke-30	Waktu kejadian, waktu diketahui, waktu pengiriman
Penerima	Subjek data dan lembaga	Daftar penerima dan tanda kirim
Isi	Data terungkap, waktu dan cara, penanganan	Naskah pemberitahuan
Yang belum diketahui	Kanal lembaga yang berwenang	Catatan penelusuran dan pemilik

Tabel 3.17 merangkum lembar isian Latihan 2.

Tabel 3.17: Lembar isian Latihan 2

Unsur	**Pasal yang dipilih**	**Bukti**
…	…	…
…	…	…
…	…	…

Pertanyaan analisis.

1. Informasi apa yang diperlukan untuk menguji tenggat pada insiden nyata? Tunjukkan dengan angka dari skenario.
2. Mengapa kata “sudah ditangani” tidak cukup untuk menyatakan patuh?

Latihan 3: Batas Bukti Sertifikat

Jelaskan mengapa sertifikat ISO/IEC 27001 tidak otomatis membuktikan kepatuhan pada UU PDP.

Latihan ini membuktikan bahwa ruang lingkup penilaian perlu dibandingkan dengan kewajiban yang harus dibuktikan.

1. Catat ruang lingkup, masa berlaku, dan entitas pada sertifikat pengandaian.
2. Pilih dua kewajiban UU PDP dan tentukan apakah bukti sertifikat menilainya secara langsung.
3. Tulis bukti tambahan dan simpulkan batas keyakinan yang wajar.

Tabel 3.18 merangkum contoh terisi Latihan 3 pada sertifikat vendor pengandaian yang mencakup 1 pusat data dan belum mencakup aplikasi Medikara+.

Tabel 3.18: Contoh terisi Latihan 3

Keadaan pengandaian	Sertifikat membuktikan	Yang masih diperiksa
Sertifikat mencakup pusat data vendor	Penilaian sistem manajemen dalam lingkup itu	Dasar pemrosesan Medikara (K-16)
Sertifikat masih berlaku	Status sertifikasi pada tanggal terkait	Notifikasi insiden dan hak subjek data (K-04)
Medikara+ di luar lingkup	Tidak ada kesimpulan untuk aplikasi	Hasil AC-01 pada 120 akun vendor (K-01)

Tabel 3.19 merangkum lembar isian Latihan 3.

Tabel 3.19: Lembar isian Latihan 3

Keadaan pengandaian	Sertifikat membuktikan	Yang masih diperiksa
…	…	…
…	…	…
…	…	…

Pertanyaan analisis.

1. Apa akibatnya bila aplikasi pasien berada di luar ruang lingkup sertifikasi?
2. Kontrol mana dapat dipakai bersama tanpa menyamakan dua jenis kesimpulan? Tunjuk barisnya pada tabel.

Bab 4

COBIT 2019: Sistem Tata Kelola dan Faktor Desain

Tujuan Pembelajaran

- Menjelaskan komponen sistem tata kelola dan 40 objektif tata kelola dan manajemen dalam COBIT 2019.
- Menerapkan faktor desain dan *goals cascade* untuk memilih objektif yang paling penting bagi sebuah organisasi.
- Menilai tingkat kapabilitas saat ini untuk objektif prioritas berdasarkan bukti, bukan pengakuan.

4.1 Pendahuluan

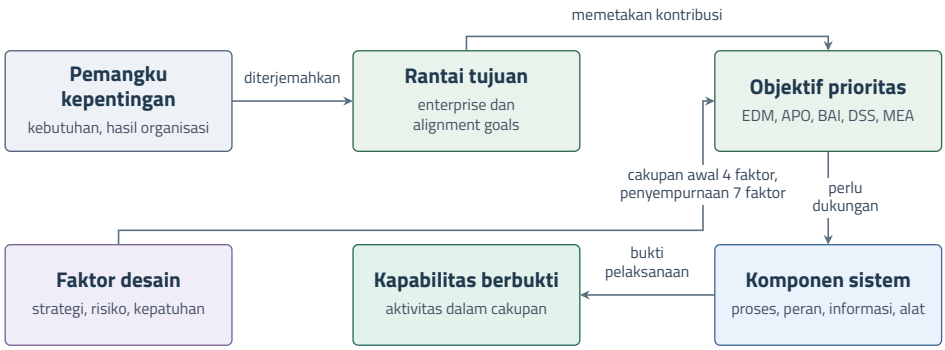
Misalkan rapat komite pengarah teknologi informasi (TI) Medikara membahas temuan audit internal: 6 dari 30 akun vendor yang diperiksa masih aktif setelah penugasan berakhir. Direktur utama menutup rapat dengan satu kalimat: "Terapkan COBIT." Kepala TI membuka daftar 40 objektif dan tidak tahu harus mulai dari mana. Konsultan menawarkan penilaian seluruh objektif dengan hasil satu angka rata-rata. Direktur pelayanan bertanya apakah angka itu akan memperpendek antrean, dan tidak ada yang bisa menjawab. Organisasi sering menyatakan akan menerapkan COBIT tanpa menjelaskan masalah yang hendak diselesaikan. Hasilnya dapat berupa puluhan prosedur baru sementara akses vendor tetap tidak ditinjau. Kesulitan itu muncul karena kerangka diperlakukan sebagai daftar pekerjaan seragam bagi semua organisasi.

COBIT adalah Control Objectives for Information and Related Technologies. Bab

ini menggunakan model inti COBIT 2019 sebagai bahasa untuk memilih objektif, menilai kapabilitas, dan merancang perbaikan. Tujuan awal bukan memperoleh nilai rata-rata tinggi, melainkan mengetahui proses mana yang paling memengaruhi layanan dan bukti apa yang mendukung penilaian. Bab ini juga membuka tonggak C2 Kondisi Saat Ini. Tim capstone menghasilkan lembar faktor desain, rantai tujuan, lima sampai tujuh objektif prioritas, dan potret kapabilitas.

Rujukan utama adalah buku pengantar dan panduan desain COBIT 2019 dari ISACA. Akses ke terbitan resmi itu terbatas, sehingga rincian yang dapat diperiksa mahasiswa diambil dari artikel terbuka di situs ISACA dan dua studi rumah sakit di Indonesia. Bagian yang merupakan tafsir penulis ditandai dengan frasa "penafsiran bab ini". Pembacaan harus membedakan model COBIT 2019 dari COBIT 5 dan dari COBIT 7 yang diumumkan pada Oktober 2026 [64, 63, 49, 143, 144, 68].

Gambar 4.1 merangkum hubungan komponen dan konsep utama bab ini.



Versi model dicatat pada artefak. Prioritas lokal dan hasil pemetaan tidak otomatis menjadi keluaran resmi COBIT Toolkit.

Gambar 4.1: COBIT 2019: tujuan, faktor desain, dan bukti kapabilitas

4.2 COBIT 2019 sebagai Kerangka Tata Kelola

COBIT 2019 adalah kerangka tata kelola dan manajemen informasi serta teknologi dari ISACA. Kerangka ini memuat prinsip, komponen, model inti berisi 40 objektif pada lima domain, serta panduan merancang sistem tata kelola [153, 65]. Cara kerjanya: organisasi memakai konteksnya untuk memilih bagian model yang paling penting, lalu menilai pelaksanaan bagian itu. Isi COBIT bersifat umum dan perlu disesuaikan [130]. Tabel 4.1 memperlihatkan empat publikasi inti dan pertanyaan yang dijawab masing-masing [64, 60, 63, 61]. Dua publikasi desain dan implementasi sudah menyatakan arahnya pada judul: merancang serta menerapkan solusi, bukan menyalin isi model.

Tabel 4.1: Empat publikasi inti COBIT 2019

Publikasi	Pertanyaan yang dijawab	Seksi bab ini
Framework: Introduction and Methodology	Apa konsep dan prinsip kerangka ini?	Prinsip, komponen
Framework: Governance and Management Objectives	Apa isi tiap objektif, praktik, dan aktivitasnya?	Model inti, kapabilitas
Design Guide	Bagaimana merancang sistem sesuai konteks organisasi?	Faktor desain, rantai tujuan
Implementation Guide	Bagaimana menerapkan dan mengoptimalkan rancangan itu?	Dibahas lagi pada C4

Cara berpikirnya mirip bengkel mobil. Katalog bengkel memuat ratusan suku cadang. Pemilik mobil tidak mengganti semuanya. Montir mendengar keluhan, memeriksa mobil, lalu memilih bagian yang perlu diperbaiki. Katalog membantu menyebut nama bagian, tetapi katalog bukan rencana perbaikan.

Dua contoh kasus nyata:

1. Kadam menelusuri satu tujuan organisasi tentang kelangsungan layanan. Empat objektif yang dipilih memuat 25 praktik dan 140 aktivitas [86]. Rata-ratanya 35 aktivitas per objektif. Misalkan rata-rata itu berlaku untuk seluruh model, sehingga 40 objektif memuat sekitar 1.400 aktivitas. Ini perkiraan kasar, bukan hitungan resmi. Bila satu aktivitas diperiksa 30 menit, penilaian menyeluruh menghabiskan 700 jam atau 87,5 hari kerja satu orang. Empat objektif hanya memerlukan 70 jam atau 8,75 hari kerja.
2. Bab 1 sudah menghitung bahwa 52 staf TI Medikara yang dibagi ke 40 objektif hanya menghasilkan 1,3 orang per objektif. Bila dibagi ke 6 objektif prioritas, angkanya sekitar 8,7 orang. Hitungan ini kasar, sebab staf tidak dibagi rata, tetapi cukup untuk menunjukkan bahwa lingkup adalah keputusan, bukan urusan administrasi.

Dua hal pada COBIT sering tertukar: sertifikat seseorang dan kapabilitas organisasi. Pembagiannya begini. Sertifikat pelatihan menunjukkan pengetahuan seseorang. Kapabilitas menunjukkan cara proses organisasi berjalan dan buktinya. Misalkan 4 dari 52 staf TI Medikara lulus ujian COBIT, atau sekitar 7,7 persen. Angka itu tidak menjawab apakah 120 akun vendor sudah ditinjau. Organisasi tidak dapat menyatakan seluruh risikonya terkendali hanya karena beberapa pegawai lulus ujian.

Kasus Medikara Health: Dari Perintah ke Tiga Pertanyaan

Misalkan kepala TI mengembalikan perintah "Terapkan COBIT" kepada komite dengan tiga pertanyaan. Masalah layanan mana yang paling merugikan? Siapa pemilik tiap masalah? Bukti apa yang akan diterima komite? Misalkan pula konsultan mengajukan penawaran Rp600 juta untuk menilai 40 objektif.

Keputusan mempersempit lingkup punya dua konsekuensi. Pertama, penawaran Rp600 juta melewati batas komite Rp400 juta pada Bab 2, sehingga keputusannya naik ke direksi. Direksi akan bertanya apa yang dibeli dengan uang itu. Kedua, bila biaya mengikuti jumlah objektif, 6 objektif setara 15 persen lingkup atau sekitar Rp90 juta. Angka itu berada di bawah batas Rp100 juta untuk kepala TI, dengan masukan pemilik layanan. Asumsi biaya sebanding ini kasar, tetapi cukup untuk membuka diskusi tentang apa yang dikerjakan lebih dahulu.

4.3 Prinsip dan Komponen Sistem Tata Kelola

Enam prinsip sistem dan tiga prinsip kerangka

COBIT 2019 membedakan prinsip sistem tata kelola dan prinsip kerangkanya. Prinsip sistem menjelaskan ciri sistem yang dibangun organisasi. Jumlahnya enam, naik dari lima pada COBIT 5 [49]. Sistem menekankan nilai bagi pemangku kepentingan, pendekatan menyeluruh, sifat dinamis, pemisahan tata kelola dan manajemen, penyesuaian dengan kebutuhan organisasi, serta cakupan seluruh fungsi organisasi [17]. Prinsip kerangka menjelaskan ciri COBIT sebagai alat: model konseptual, keterbukaan dan keluwesan, serta keselarasan dengan standar, kerangka, dan regulasi utama [49]. Tabel 4.2 menerjemahkan enam prinsip sistem ke keadaan Medikara. Kolom terakhir adalah pengandaian untuk pembelajaran.

Tujuh komponen

Tujuh komponen sistem ialah proses; struktur organisasi; prinsip, kebijakan, dan prosedur; informasi; budaya, etika, dan perilaku; orang, keterampilan, dan kompetensi; serta layanan, infrastruktur, dan aplikasi [130]. Istilah komponen menggantikan *enabler* pada COBIT 5 [153]. Perbaikan proses membutuhkan komponen lain agar berjalan. Prosedur peninjauan akses tanpa pemilik, daftar akun, dan keterampilan pemeriksa akan sulit menghasilkan kontrol yang efektif.

Sistem perpustakaan membutuhkan aturan peminjaman, petugas, katalog, perangkat, kebiasaan mengembalikan, dan informasi tunggakan. Menulis prosedur saja tidak membuat buku kembali ke rak.

Tabel 4.2: Enam prinsip sistem tata kelola pada Medikara

Prinsip	Maknanya	Contoh pada Medikara
Nilai bagi pemangku kepentingan	Sistem memenuhi kebutuhan dan menghasilkan nilai dari informasi serta teknologi	Ukuran utama adalah kerahasiaan data dan waktu tunggu, bukan jumlah prosedur
Pendekatan menyeluruh	Beberapa komponen bekerja bersama	AC-01 memerlukan proses, daftar akun, pemilik, dan alat
Sistem yang dinamis	Rancangan ditinjau ketika faktor desain berubah	Akuisisi fasilitas baru memicu penilaian ulang
Tata kelola berbeda dari manajemen	Kegiatan dan strukturnya berbeda	Komite 9 anggota menilai arah; kepala TI menjalankan rencana
Disesuaikan dengan kebutuhan	Kebutuhan organisasi membentuk rancangan	Medikara+ buatan vendor menaikkan perhatian pada vendor
Mencakup seluruh fungsi	Semua fungsi, teknologi, dan informasi yang dipakai organisasi	Cakupan 36 fasilitas, bukan hanya divisi TI pusat

Dua contoh penerapannya:

1. Misalkan kontrol AC-01 harus meninjau 120 akun vendor, tetapi daftar yang diterima peninjau hanya memuat 108 akun. Sebanyak 12 akun, atau 10 persen, luput dari peninjauan. Prosedurnya tertulis dan peninjaunya ada. Yang lemah adalah komponen informasi, sehingga menambah prosedur tidak menutup celah itu.
2. Misalkan satu rumah sakit memiliki prosedur berbeda dari empat rumah sakit lain karena SIMRS hasil akuisisinya berbeda. SIMRS adalah Sistem Informasi Manajemen Rumah Sakit. Penyesuaian lokal perlu dijelaskan agar tetap memenuhi tujuan bersama, bukan dinilai hanya dari kesamaan format.

Tabel 4.3 merangkum komponen dan bukti untuk peninjauan akses. Tabel ini dipakai lagi saat menilai kapabilitas, sebab satu komponen yang kosong dapat menjelaskan mengapa proses gagal.

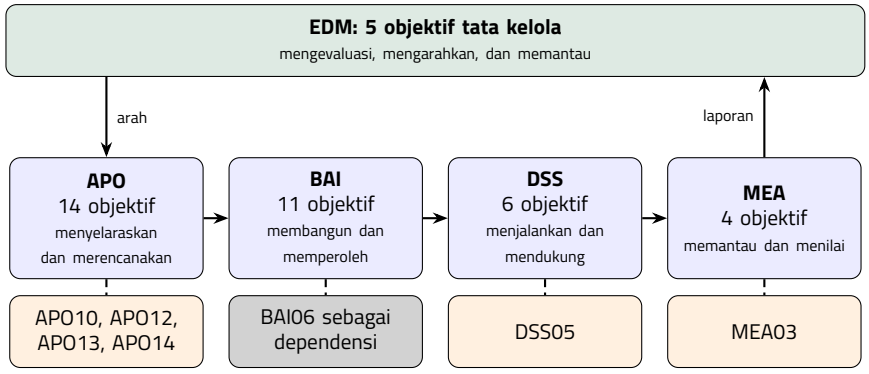
Dua hal pada sistem ini sering tertukar: tata kelola dan manajemen. Pembagiannya begini. Tata kelola menilai pilihan, memberi arah, dan memantau apakah arah masih benar. Manajemen merencanakan, membangun, menjalankan, dan memantau pekerjaan. Bab 2 sudah membahas pembagian ini lewat komite 9 anggota dengan kuorum 6 orang. Komite tidak mencabut 24 akun vendor. Komite memastikan ada pemilik dan melihat hasil peninjauan. Pertanyaan kemudian muncul: bagaimana pembagian itu terlihat pada model COBIT?

Tabel 4.3: Komponen dan bukti untuk peninjauan akses AC-01

Komponen	Penerapan AC-01	Bukti
Proses	Tarik daftar, tandai, cabut, catat	Catatan peninjauan bulanan
Struktur organisasi	Pengelola vendor, pemilik layanan, dan jalur eskalasi	Mandat dan daftar peran
Prinsip, kebijakan, dan prosedur	Akun per orang dan batas waktu pencabutan	Kebijakan akses yang disahkan
Informasi	Populasi akun dan tanggal berakhir penugasan	Daftar 120 akun dan daftar penugasan
Budaya, etika, dan perilaku	Peninjau berani mencabut akses milik vendor penting	Tindak lanjut atas keberatan vendor
Orang, keterampilan, dan kompetensi	Peninjau memahami peran akses	Catatan pelatihan dan hasil uji sampel
Layanan, infrastruktur, dan aplikasi	Alat pencatatan serta pencabutan	Rekam perubahan akses

4.4 Model Inti: 40 Objektif dalam Lima Domain

Model inti berisi 40 objektif pada lima domain [153]. Evaluate, Direct and Monitor (EDM) memuat objektif tata kelola. Align, Plan and Organize (APO), Build, Acquire and Implement (BAI), Deliver, Service and Support (DSS), serta Monitor, Evaluate and Assess (MEA) memuat objektif manajemen. Objektif menjelaskan hasil yang perlu dicapai. Tiap objektif diuraikan menjadi praktik dan aktivitas, dan komponen lain membantu mewujudkannya [86, 130]. Gambar 4.2 memperlihatkan susunannya beserta enam objektif awal pengandaian Medikara yang dibahas pada seksi berikutnya.



5 + 14 + 11 + 6 + 4 = 40 objektif. Baris bawah: enam objektif awal pengandaian Medikara.

Gambar 4.2: Lima domain model inti COBIT 2019 dan enam objektif awal pengandaian Medikara

Jumlah objektif pada masing-masing domain adalah 5, 14, 11, 6, dan 4. Penge-

nal tertinggi pada sumber yang terbaca cocok dengan susunan itu, yaitu EDM05, APO14, BAI11, DSS06, dan MEA04, dan jumlahnya 40 [4, 49, 148]. Katalog pada berkas sumber mencantumkan seluruh pengenal. Nama 31 objektif sudah dicocokkan ke artikel yang terbaca. Sembilan sisanya ditandai "perlu dicocokkan" dan tim memeriksanya ke publikasi resmi sebelum memakainya. Katalog membantu orientasi, sedangkan penilaian rinci tetap memerlukan aktivitas pada publikasi resmi. Tabel 4.4 merangkum lima domain dengan contoh nama objektif yang sudah dicocokkan [148, 4, 49].

Tabel 4.4: Lima domain model inti COBIT 2019

Domain	Fokus	Contoh objektif
EDM, 5	Arah serta pengawasan	EDM03 *Ensured risk optimization*
APO, 14	Perencanaan serta pengorganisasian	APO10 *Managed vendors*; APO12 *Managed risk*; APO13 *Managed security*; APO14 *Managed data*
BAI, 11	Perolehan serta perubahan solusi	BAI06 *Managed IT changes*; BAI11 *Managed projects*
DSS, 6	Operasi serta layanan	DSS04 *Managed continuity*; DSS05 *Managed security services*
MEA, 4	Pemantauan serta penilaian	MEA03 *Managed compliance with external requirements*; MEA04 *Managed assurance*

Struktur di bawah objektif menjelaskan mengapa model ini terasa besar. DSS04, misalnya, memiliki 8 praktik [130]. Tiap aktivitas pada komponen proses dikaitkan dengan satu tingkat kapabilitas [153]. Satu objektif bukan satu baris pemeriksaan, melainkan sekumpulan pekerjaan yang dapat diuji satu per satu.

Risiko vendor melintasi domain. Pengelolaan hubungan vendor, keamanan, data, perubahan, dan asurans saling terkait. Memilih satu objektif prioritas tidak berarti objektif lain tidak diperlukan. Pilihan menunjukkan fokus penilaian dan perbaikan pada tahap tertentu.

Peta layanan rumah sakit membagi pekerjaan ke rawat jalan, laboratorium, farmasi, dan unit lain. Pembagian membantu menemukan penanggung jawab, tetapi perjalanan satu pasien tetap melewati beberapa unit.

Dua contoh penerapannya:

1. Misalkan temuan 6 dari 30 akun vendor mengarah pada APO10 untuk hubungan vendor dan DSS05 untuk layanan keamanan. Tim menilai keduanya bersama bukti perintah akses. Bila hanya DSS05 yang dinilai, 12 akun yang tidak tercatat tetap luput, sebab daftar akun itu bersumber dari pengelolaan vendor.

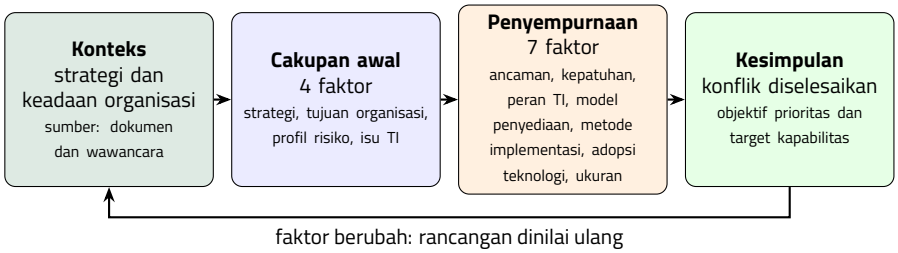
2. Misalkan pembaruan aplikasi di rumah sakit Bogor mengubah format nomor rekam medis, sehingga 2.400 dari 96.000 data pasien, atau 2,5 persen, tidak

cocok dengan data pusat. BAI06 tentang perubahan dan APO14 tentang data membantu menelusuri keputusan serta kontrol yang terkait. Satu kejadian menyentuh dua domain.

4.5 Faktor Desain dan Focus Area

Sebelas faktor desain

Sebelas faktor desain membentuk pilihan objektif dan target kapabilitas. Faktor tersebut mencakup strategi, tujuan organisasi, profil risiko, isu terkait TI, ancaman, kebutuhan kepatuhan, peran TI, model penyediaan, metode implementasi, strategi adopsi teknologi, dan ukuran organisasi [63, 49, 118]. Empat faktor pertama menetapkan cakupan awal, lalu faktor lain memperhalus prioritas [148, 49]. *Toolkit* COBIT menghasilkan skor tiap objektif untuk cakupan awal, cakupan yang disempurnakan, dan cakupan akhir. Cakupan akhir lahir setelah konflik diselesaikan dan rancangan dituntaskan [49]. Gambar 4.3 memperlihatkan urutan itu.



Gambar 4.3: Faktor desain dipakai bertahap untuk menyusun cakupan sistem tata kelola

Rancangan sistem air untuk rumah satu lantai berbeda dari rancangan jaringan air kompleks rumah sakit. Tujuannya sama-sama menyediakan air, tetapi ukuran, kebutuhan layanan, risiko, dan sumber pasokan menentukan bagian yang perlu diperkuat.

Tabel 4.5 merangkum sebelas faktor dengan kategori penilaian. Kategori diambil dari lembar *toolkit* yang dilaporkan studi rumah sakit di Denpasar [143]. Tim memeriksa ulang rumusannya pada versi *toolkit* yang dipakai.

Dua contoh penerapannya:

1. Studi di Denpasar mencatat rumah sakit dengan 170 karyawan sebagai organisasi kecil dan menengah, dengan rentang 50 sampai 250 karyawan, dan model penyediaan 75 persen *outsourcing* [143]. Medikara memiliki sekitar 4.800 karyawan, atau 19,2 kali batas atas itu. Klinik mitra 60 karyawan pada Bab 3 masuk rentang tersebut. Satu jaringan layanan dapat berhadapan dengan dua kategori ukuran pada rancangan yang berbeda.

Tabel 4.5: Sebelas faktor desain, kategori penilaian, dan bukti

Faktor	Kategori penilaian	Bukti contoh
Strategi organisasi	*Growth/acquisition, innovation/differentiation, cost leadership, client service/stability*	Dokumen strategi
Tujuan organisasi	EG01 sampai EG13, nilai 1 sampai 5	Rencana kerja direksi
Profil risiko	Kategori skenario risiko, dampak 1 sampai 5	Register risiko, insiden
Isu terkait TI	Daftar isu, tingkat 1 sampai 3	Temuan audit, tiket berulang
Ancaman	*High, normal*	Analisis ancaman, paparan
Kebutuhan kepatuhan	*High, normal, low*	Register kewajiban C1
Peran TI	*Support, factory, turnaround, strategic*	Peta layanan dan dampak
Model penyediaan	*Outsourcing, cloud, insourced*	Kontrak, daftar layanan
Metode implementasi	*Agile*, DevOps, *traditional*	Rencana kerja, data rilis
Strategi adopsi teknologi	*First mover, follower, slow adopter*	Peta jalan teknologi
Ukuran organisasi	Besar atau kecil dan menengah	Data karyawan

2. Misalkan Medikara mengakuisisi dua fasilitas baru dalam skenario latihan, sehingga 36 fasilitas menjadi 38, atau naik sekitar 5,6 persen. Isu integrasi dan akses lintas unit perlu dinilai kembali, meskipun tujuan layanan tidak berubah. Inilah arti prinsip sistem yang dinamis.

Dua rumah sakit di Indonesia memperlihatkan pengaruh konteks. Studi di Denpasar menghasilkan lima objektif: APO12, APO13, BAI06, DSS04, dan DSS05 [143]. Studi di Kediri, pada Rumah Sakit Wilujeng, menghasilkan tiga: DSS05, APO07, dan APO12 [144]. Keduanya memiliki 2 objektif yang sama, yaitu APO12 dan DSS05, dari 6 objektif berbeda. Studi pertama menyebut 11 faktor, sedangkan studi kedua menyebut 10 faktor. Pembaca perlu mencatat perbedaan metode itu sebelum menyimpulkan bahwa perbedaan hasil hanya berasal dari konteks.

Penilaian faktor harus memiliki dasar. Kategori ketergantungan vendor ditopang daftar layanan dan kontrak. Kategori ancaman ditopang insiden serta paparan. Bila data belum ada, tim mencatat asumsi dan menguji pengaruhnya pada prioritas. Penilaian ulang diperlukan ketika strategi, vendor, atau lingkungan berubah. Tabel 4.6 mengisi faktor untuk Medikara dan membedakan fakta kasus dari pengandaian. Rumusan isu dan risiko berbahasa Inggris mengikuti daftar pada studi Denpasar.

Focus area

Dua hal pada rancangan ini sering tertukar: faktor desain dan *focus area*. Pembagiannya begini. Faktor desain menggambarkan keadaan organisasi. *Focus area* memberi perhatian pada tema tertentu dan memakai objektif serta komponen

Tabel 4.6: Sebelas faktor desain pada Medikara: fakta kasus dan pengandaian

Faktor	Nilai pada Medikara	Status
Strategi organisasi	Layanan terintegrasi lintas fasilitas: *client service/stability* tertinggi	Pengandaian dari strategi kasus
Tujuan organisasi	EG06 kelangsungan layanan, EG03 kepatuhan, EG12 transformasi digital	Pengandaian
Profil risiko	*Third-party/supplier incidents, unauthorized actions*; R-01	Insiden 2025 fakta; rincian pengandaian
Isu terkait TI	Temuan audit berulang, masalah layanan dari vendor, integrasi data, biaya integrasi	Fakta kasus
Ancaman	*High* 75 persen, *normal* 25 persen	Pengandaian
Kebutuhan kepatuhan	*High*: register K-01 sampai K-16 pada 36 fasilitas	Register C1
Peran TI	*Factory* dan *turnaround*: SIMRS menopang layanan, sedang dimodernisasi	Pengandaian
Model penyediaan	Medikara+ dan dukungan vendor; SIMRS *on-premise* di tiap rumah sakit	Fakta kasus
Metode implementasi	*Traditional* 70 persen, *agile* 25 persen, DevOps 5 persen	Pengandaian
Strategi adopsi teknologi	*Follower*: modernisasi *cloud* bertahap sampai 2030	Pengandaian dari strategi kasus
Ukuran organisasi	Sekitar 4.800 karyawan, 52 staf TI, tim platform 6 orang	Fakta kasus

yang relevan. ISACA menerbitkan panduan untuk DevOps, risiko informasi dan teknologi, keamanan informasi, serta organisasi kecil dan menengah [65]. Tema bukan domain keenam dan tidak membenarkan mengabaikan keputusan yang berpengaruh pada tujuan layanan. Kalimat terakhir ini adalah penafsiran bab ini.

Analoginya seperti klinik spesialis di dalam rumah sakit. Klinik jantung memberi perhatian khusus, tetapi tetap memakai laboratorium, farmasi, dan rekam medis yang sama.

Dua contoh penerapannya:

1. Misalkan tim platform 6 orang ingin mempercepat rilis Medikara+. Panduan DevOps relevan bagi 6 orang itu. Panduan yang sama tidak menjawab kewajiban peninjauan 120 akun vendor, sehingga tema ini tidak menggantikan objektif prioritas.
2. Misalkan klinik mitra berkaryawan 60 orang dengan 2 staf TI ingin menerapkan COBIT. Panduan organisasi kecil dan menengah lebih masuk akal sebagai titik awal, sebab 2 staf tidak dapat menjalankan rancangan milik jaringan dengan 52 staf TI.

Pendalaman Teknis (opsional)

Gunakan *toolkit* COBIT resmi bila aksesnya tersedia. Halaman COBIT di situs ISACA menautkan berkasnya [65]. Bobot faktor mengikuti kepentingan relatif tiap objektif, dan nilainya dihitung sebagai selisih persentase antara kondisi dasar dan kondisi organisasi [49]. Ubah satu faktor pada satu waktu dan catat perubahan prioritas. Bandingkan hasil dengan alasan manual, lalu jelaskan perbedaan. Hindari memberi nama skor resmi kepada rumus lokal. Lembar kerja pada folder sumber sengaja memisahkan data konteks, prioritas, dan bukti agar penalarannya dapat ditinjau tanpa alat berbayar. Mahasiswa berlatar rekayasa perangkat lunak dapat membandingkan hasilnya dengan *focus area* DevOps.

4.6 Goals Cascade dan Pemilihan Prioritas

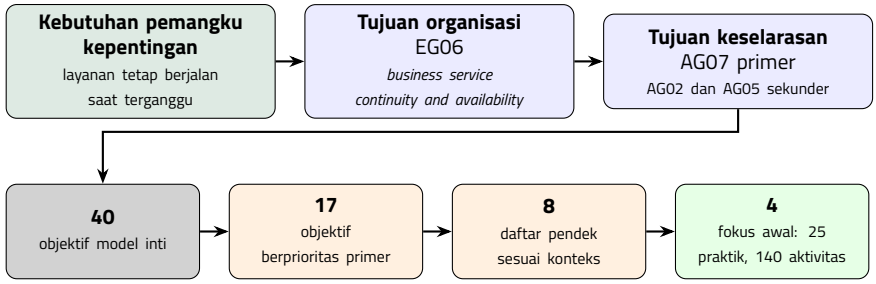
Goals cascade atau rantai tujuan menghubungkan kebutuhan pemangku kepentingan, tujuan organisasi (*enterprise goal*, EG), tujuan keselarasan (*alignment goal*, AG), dan objektif tata kelola serta manajemen [141, 130]. COBIT 2019 memuat 13 EG dan 13 AG [4, 32]. Pemetaan membantu menjelaskan mengapa objektif dipilih. Tiap hubungan diberi tanda primer atau sekunder [86]. Hubungan pada model resmi adalah alat bantu. Konteks organisasi tetap perlu menjelaskan pilihan akhirnya [86, 130].

Rencana perjalanan dimulai dari tujuan dan kebutuhan peserta, lalu memilih rute serta alat transportasi. Menghitung kenyamanan kursi sebelum menentukan tujuan tidak membantu memilih perjalanan yang tepat.

Dua contoh penerapannya:

1. Kadam memulai dari EG06, yaitu *business service continuity and availability*. EG06 terhubung ke AG07 sebagai primer, serta AG02 dan AG05 sebagai sekunder. Objektif berprioritas primer berjumlah 17, sehingga penulisnya menilai jumlah itu kurang praktis. Daftar dipersempit menjadi 8 objektif, lalu 4 objektif untuk fokus awal, yaitu APO09, APO10, DSS04, dan DSS05 [86]. Dari 40 objektif, yang tersisa 10 persen. Gambar 4.4 memperlihatkan penyaringan itu.
2. Rafeq dan Elangovan memakai EG06 yang sama, tetapi memilih jalur lain. Enam objektif primer untuk AG07 adalah EDM03, APO12, APO13, BAI10, DSS04, dan DSS05, lalu contoh mereka memilih DSS04 berdasarkan kekritisan dan relevansi [130]. Titik awal yang sama dapat berakhir pada pilihan berbeda. Karena itu alasan harus tertulis.

Rantai penalaran dimulai dari masalah yang dapat dikenali pemilik layanan.



Gambar 4.4: Rantai tujuan dan penyaringan objektif menurut contoh Kadam

Tim merumuskan hasil organisasi, lalu kemampuan informasi dan teknologi yang mendukungnya. Faktor desain dipakai untuk menguji apakah prioritas tersebut masuk akal terhadap risiko serta batas sumber daya. Tabel 4.7 memperlihatkan rantai untuk Medikara. Nama EG dan AG hanya ditulis bila terbaca pada sumber. Kolom terakhir menyatakan bagian mana yang tercantum pada sumber dan bagian mana yang merupakan penafsiran bab ini.

Tabel 4.7: Contoh rantai prioritas Medikara

Kebutuhan	EG	AG	Objektif	Status pemetaan
Kerahasiaan data pasien	EG06	AG07	APO13; DSS05	Tercantum pada sumber
Vendor dapat dipertanggungjawabkan	EG06	AG05	APO10	Tercantum pada sumber
Risiko layanan terkendali	EG02	AG02	APO12	Penafsiran bab ini; EG dan AG terbaca
Identitas pasien konsisten	EG12	AG08	APO14	Penafsiran bab ini; cocokkan ke tabel resmi
Kewajiban dapat dibuktikan	EG03	Belum ditetapkan	MEA03	Penafsiran bab ini; AG dicari pada tabel resmi

Skor prioritas lokal pada latihan merupakan alat diskusi, bukan keluaran resmi *toolkit* COBIT. Bobot, asumsi, dan perubahan urutan harus ditulis. Dua objektif dengan skor sama dapat memiliki urgensi berbeda bila satu berkaitan dengan kewajiban hukum atau keselamatan pasien. Tabel 4.8 memberi nilai 1 sampai 5 pada tiga pertanyaan: seberapa besar kaitannya dengan risiko R-01 dan insiden, seberapa besar kaitannya dengan register kewajiban, dan seberapa besar kaitannya dengan strategi Satu Pasien, Satu Rekam Medis. Semua nilai adalah pengandaian.

Skor memberi tiga objektif bernilai 10, sedangkan kapasitas hanya menyisakan dua tempat. Di sinilah tahap kesimpulan bekerja. Dua pilihan lalu diambil dengan alasan. APO12 masuk karena R-01 memerlukan pemilik dan pemantauan yang sama pada semua fasilitas. MEA03 masuk karena 16 baris register kewajiban

Tabel 4.8: Skor prioritas lokal Medikara (pengandaian, nilai maksimum 15)

Objektif	Risiko	Kewajiban	Strategi	Total	Keputusan
APO10	5	4	3	12	Masuk
DSS05	5	5	2	12	Masuk
APO13	4	4	3	11	Masuk
APO14	3	3	5	11	Masuk
APO12	4	3	3	10	Masuk
MEA03	2	5	3	10	Masuk
DSS04	3	4	3	10	Ditunda ke Bab 10
BAI06	3	2	4	9	Dependensi
APO09	3	2	2	7	Ditunda

belum memiliki pemantauan bersama. DSS04 ditunda sampai analisis dampak bisnis pada Bab 10, tetapi kewajiban 36 prosedur dan 144 uji pemulihan per tahun dari Bab 3 tetap tercatat sebagai pekerjaan berjalan.

Target kapabilitas juga berasal dari skor. Menurut Souza Neto dan rekan, panduan desain memberi contoh sebuah perusahaan manufaktur: skor 75 atau lebih memerlukan tingkat 4, skor 50 atau lebih tingkat 3, skor 25 atau lebih tingkat 2, dan sisanya tingkat 1. Ambang itu adalah logika contoh tersebut, bukan aturan umum. Mereka juga mengkritik akibatnya: semua proses di bawah objektif berskor sama menerima satu tingkat yang sama [148]. Bab 8 mengambil keputusan target, sedangkan bab ini berhenti pada kondisi saat ini.

Kasus Medikara Health: Memilih Enam Objektif Awal

Misalkan Medikara memilih APO10, APO12, APO13, APO14, DSS05, dan MEA03 sebagai enam objektif awal. Pilihan tersebut ditopang ketergantungan vendor, insiden 2025, temuan kontrol akses, data yang tersebar, dan kewajiban yang perlu dibuktikan. BAI06 tetap dicatat sebagai dependensi perubahan. Daftar ini merupakan hasil pengandaian untuk diskusi. Tim harus mengubahnya bila konteks dan bukti menunjukkan prioritas berbeda.

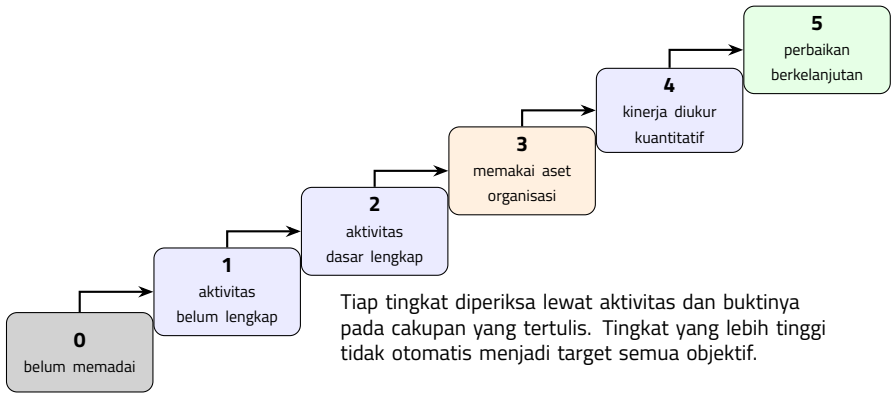
Pilihan ini punya dua konsekuensi yang dapat dihitung. Pertama, bila bobot kewajiban digandakan, DSS05 menjadi 17, APO10 menjadi 16, APO13 dan MEA03 menjadi 15, APO14 dan DSS04 menjadi 14, serta APO12 menjadi 13. APO12 turun ke urutan ketujuh dan DSS04 masuk enam besar. Urutan bergantung pada bobot, sehingga bobot perlu disetujui komite, bukan dipilih analis sendirian. Kedua, dengan rata-rata 35 aktivitas per objektif, enam objektif setara 210 aktivitas atau 105 jam pemeriksaan. Hitungan itu berbeda jauh dari 700 jam untuk 40 objektif.

4.7 Penilaian Kapabilitas Berdasarkan Bukti

Tingkat kapabilitas 0 sampai 5

COBIT 2019 menggunakan pendekatan kapabilitas proses yang mengacu pada Capability Maturity Model Integration (CMMI), dengan tingkat 0 sampai 5 [49]. Aktivitas memiliki hubungan dengan tingkat kapabilitas, sehingga penilaian perlu memeriksa aktivitas yang berlaku pada objektif tersebut [153]. Skala COBIT 5 tidak boleh dipindahkan begitu saja ke COBIT 2019, sebab COBIT 5 memakai skala berbasis ISO/IEC 33000, standar dari International Organization for Standardization (ISO) dan International Electrotechnical Commission (IEC) [49].

Tingkat 0 menunjukkan pendekatan belum memadai. Tingkat 1 masih awal dan belum lengkap. Tingkat 2 mencapai tujuan melalui aktivitas dasar yang lengkap. Tingkat 3 menggunakan cara kerja dan aset organisasi. Tingkat 4 mengukur kinerja secara kuantitatif. Tingkat 5 memakai pengukuran untuk perbaikan berkelanjutan [148]. Gambar 4.5 menyusunnya sebagai tangga. Ini ringkasan orientasi, bukan rubrik penetapan formal.



Gambar 4.5: Tingkat kapabilitas proses COBIT 2019 sebagai tangga

Satu foto dapur yang bersih tidak membuktikan kebersihan terjaga sepanjang bulan. Pemeriksa perlu melihat jadwal, catatan, contoh hari berbeda, serta tindak lanjut penyimpangan.

Dua contoh penerapannya:

1. Misalkan 8 dari 10 perubahan memiliki persetujuan, tetapi tidak ada analisis dampak pada dua perubahan darurat. Tim mencatat celah itu sebelum menerima klaim proses perubahan tingkat 3. Dua tiket yang gagal adalah jenis perubahan yang paling berisiko, sehingga 80 persen tidak mewakili keadaan terburuk.
2. Misalkan AC-01 memiliki prosedur korporat, tetapi bukti peninjauan baru

tersedia pada satu dari lima rumah sakit, atau 20 persen. Lingkup bukti belum mendukung klaim penerapan menyeluruh. Keputusan yang wajar adalah membatasi klaim pada satu lokasi itu.

Peringkat capaian dan aturan penetapan

Pertanyaan kemudian muncul: kapan satu tingkat dinyatakan tercapai? Tabel 4.9 memuat empat peringkat capaian yang lazim dipakai. Souza Neto dan rekan menyebut peringkat itu serupa dengan ISO/IEC 33004 [148], sedangkan studi Denpasar merujuknya ke ISACA [143]. Batas pada kedua sumber sedikit berbeda, yaitu 85 persen dan 84 persen sebagai batas atas *largely*.

Tabel 4.9: Peringkat capaian menurut dua sumber

Peringkat	Souza Neto dan rekan	Studi Denpasar
N, *not achieved*	Kurang dari 15 persen	0 sampai 14 persen
P, *partially achieved*	15 sampai 50 persen	15 sampai 49 persen
L, *largely achieved*	50 sampai 85 persen	50 sampai 84 persen
F, *fully achieved*	Lebih dari 85 persen	85 sampai 100 persen

Aturan penetapan perlu ditulis, sebab hasilnya bergantung pada aturan itu. Dua studi rumah sakit hanya menyatakan satu tingkat tercapai bila capaiannya penuh, dan studi Denpasar menuliskannya sebagai 85 persen atau lebih. Bila belum, penilaian berhenti [143, 144]. Usulan Souza Neto dan rekan untuk menetapkan target menerima peringkat L atau F pada tiap aktivitas [148]. Keduanya menjawab pertanyaan berbeda, tetapi memperlihatkan bahwa angka yang sama dapat dibaca berbeda. Rumusan resmi perlu dicocokkan ke publikasi ISACA sebelum dipakai dalam asesmen formal. Dua contoh di bawah memperlihatkan akibatnya:

1. Di Kediri, APO07 mencapai 100 persen pada tingkat 1 dan 80,55 persen pada tingkat 2. Peringkatnya *largely*, sehingga APO07 dinyatakan tetap tingkat 1 [144]. Tanpa aturan itu, pembaca dapat keliru mengira 80,55 persen sudah dekat dengan tingkat 2 yang terpenuhi.
2. Di Denpasar, lima responden menilai APO12 tingkat 2 dengan nilai 66, 66, 50, 50, dan 83 persen. Jumlahnya 315 dan rata-ratanya 63 persen, sehingga APO12 dinyatakan tingkat 1 [143]. Selisih responden tertinggi dan terendah 33 poin. Rata-rata menyembunyikan perbedaan pandangan itu.

Membaca studi kapabilitas secara kritis

Studi rumah sakit berguna sebagai contoh alur, dan layak dibaca kritis. Tabel 4.10 membandingkan dua studi. Penilaian kedua studi terutama bersandar pada jawaban responden, walaupun studi Denpasar juga menyebut observasi dan wawancara.

Pada Denpasar, kelima responden memberikan nilai yang sama pada dua objektif: 71 persen untuk APO13 dan 60 persen untuk BAI06. Pembaca patut bertanya apakah itu lima pengamatan atau satu pendapat yang disepakati. Naskah yang sama menyebut kelima objektif bernilai 75 dan memerlukan tingkat 4, tetapi tabel target mencantumkan tingkat 3 untuk APO12 dan DSS04. Pembacaan ini adalah penafsiran bab ini.

Tabel 4.10: Dua studi kapabilitas rumah sakit di Indonesia

Aspek	Rumah Sakit Umum Bhakti Rahayu Denpasar [143]	Rumah Sakit Wilujeng [144]
Faktor desain	11 faktor, memilih objektif bernilai 75	10 faktor dengan Design Toolkit
Objektif dan tingkat saat ini	APO12 dan DSS04 tingkat 1; APO13, BAI06, DSS05 tingkat 2	DSS05, APO07, dan APO12 tingkat 1
Capaian yang dilaporkan	APO12 63 persen, DSS04 56 persen pada tingkat 2	61,5; 80,55; dan 58,33 persen pada tingkat 2
Sumber data	Kuesioner lima karyawan, observasi, wawancara	Kuesioner skala Guttman, manajer unit TI, satu responden sumber daya manusia untuk APO07
Target	APO12 dan DSS04 tingkat 3; lainnya tingkat 4	Dibandingkan lewat analisis celah
Pertanyaan pembaca	Bukti apa yang menopang jawaban kuesioner?	Apakah satu manajer dapat menilai pekerjaannya sendiri?

Potret cepat untuk capstone

Potret cepat dalam capstone melaporkan aktivitas yang diamati, bukti yang tersedia, celah, dan tingkat indikatif dengan batas keyakinannya. Wawancara hanya satu jenis bukti. Sampel, periode, lokasi, dan populasi perlu disebutkan. Ketiadaan bukti tidak sama dengan bukti bahwa pekerjaan tidak pernah dilakukan, tetapi klaim kapabilitas belum dapat diterima.

Kapabilitas proses juga berbeda dari satu angka gabungan. COBIT 2019 memakai skala 0 sampai 5 untuk kapabilitas dan kematangan [49]. Bab ini memakai kapabilitas per objektif prioritas. Satu angka rata-rata tidak menjelaskan apakah proses kritis gagal. Tim perlu melaporkan proses dan celahnya secara terpisah agar perbaikan mengikuti risiko layanan. Tabel 4.11 merangkum bukti dan batas klaim kapabilitas.

Kasus Medikara Health: Potret Cepat DSS05 Lewat AC-01

Misalkan kepala TI menyatakan peninjauan akses vendor sudah berjalan baik. Tim C2 mengujinya dengan data Bab 1 dan Bab 2. Audit memeriksa 30 dari 120 akun dan menemukan 6 akun masih aktif setelah penugasan

Tabel 4.11: Bukti dan batas klaim kapabilitas

Klaim	Bukti yang diperlukan	Batas kesimpulan
Pekerjaan dilakukan	Contoh hasil dan pelaksana	Belum membuktikan konsistensi
Cara kerja terdefinisi	Prosedur dan penerapan lintas unit	Perlu sampel beberapa periode
Kinerja diukur	Definisi metrik dan data andal	Angka tanpa tindakan belum cukup
Perbaikan berkelanjutan	Analisis, tindakan, dan hasil ulang	Perlu keterkaitan sebab dan hasil

berakhir. Peninjauan bulan berikutnya mencabut 24 dari 120 akun. Kedua angka itu sama-sama 20 persen, tetapi sampel hanya mewakili satu lokasi, sehingga angka sampel tidak diproyeksikan ke 120 akun. Angka 24 berasal dari peninjauan penuh, bukan dari proyeksi. Pada sampel, 24 dari 30 akun atau 80 persen sudah sesuai. Bukti peninjauan hanya tersedia pada satu dari lima rumah sakit.

Temuan ini punya dua konsekuensi. Pertama, peringkat sampel berada pada rentang *largely*, tetapi sampel hanya mewakili satu lokasi. Tim menulis tingkat indikatif 1 untuk lingkup satu rumah sakit dan menolak sementara klaim lintas 5 rumah sakit. Kedua, AC-01 hanya satu bagian dari DSS05. Kesimpulan ini tidak menjadi tingkat DSS05 secara keseluruhan. Daftar bukti tambahan memuat catatan peninjauan empat rumah sakit lain, daftar penugasan, dan contoh keberatan vendor. Pemilik Medikara+ menjadi penanggung jawab pengumpulan.

4.8 Kaitan dengan ITIL 4 dan Tata Kelola Arsitektur

Tiga hal sering tertukar: COBIT, Information Technology Infrastructure Library (ITIL) 4, dan tata kelola arsitektur. Pembagiannya begini. COBIT menyatakan hasil yang perlu dicapai dan cara menilainya. ITIL 4 membantu menjalankan praktik layanan sehari-hari, dan Bab 8 merinci hubungan keduanya [7]. Tata kelola arsitektur mengatur keputusan tentang susunan aplikasi, data, dan integrasi, dan dibahas rinci pada mata kuliah IT40513. COBIT 2019 dapat dipadukan dengan standar, panduan, dan regulasi lain [49], dan Braga menggambarkannya sebagai kerangka payung [17]. Tabel 4.12 merangkum pembagian itu.

Analoginya seperti rumah sakit yang menghadapi akreditasi. Standar akreditasi menyebut hasil yang harus dibuktikan. Prosedur bangsal menjelaskan cara perawat bekerja tiap giliran jaga. Denah gedung menjelaskan letak ruang dan alur

Tabel 4.12: Kaitan COBIT, ITIL 4, dan tata kelola arsitektur

Aspek	**COBIT 2019**	**ITIL 4**	**Tata kelola arsitektur**
Pertanyaan	Hasil apa yang perlu dicapai dan dibuktikan?	Bagaimana layanan dijalankan sehari-hari?	Susunan mana yang dipilih dan siapa memutuskan?
Contoh	BAI06 perubahan TI	Praktik *change enablement*	Keputusan pola integrasi
Bukti	Tingkat kapabilitas dan celah	Tiket dan jadwal perubahan	Catatan keputusan arsitektur
Dibahas di	Bab ini	Bab 8	IT40513

orang. Ketiganya berbeda jenis dan tidak saling menggantikan.

Dua contoh penerapannya:

1. Misalkan tim memeriksa 10 tiket perubahan SIMRS. ITIL 4 membantu merancang alur penilaian dan otorisasi tiket. BAI06 memakai tiket yang sama sebagai bukti kapabilitas. Sepuluh tiket itu tidak perlu dikumpulkan dua kali, sehingga pekerjaan satu tim terbaca oleh dua kerangka.
2. Bab 1 mengandaikan biaya integrasi Rp450 juta per tahun dengan toleransi 10 persen, sehingga batasnya Rp495 juta. Forum arsitektur memutuskan pola integrasi yang menekan biaya itu. COBIT memeriksa apakah keputusan tersebut memiliki pemilik, bukti, dan pemantauan.

4.9 Pengendalian Versi dan Transisi COBIT 7

Informasi resmi komunitas ISACA menyebut debut COBIT 7 pada 27 Oktober dengan kerangka *digital-first* dan transisi sertifikat. Tahunnya disimpulkan dari daftar tanggal pada halaman yang sama. Halaman produk resmi juga memuat ujian COBIT 7 Foundation. Informasi tersebut membuktikan adanya transisi, tetapi tidak cukup untuk menyimpulkan bahwa semua definisi atau pengenal model berubah [68, 66]. Pada 31 Oktober 2026, halaman sumber daya COBIT yang terbaca masih menampilkan publikasi COBIT 2019 dan belum menyebut COBIT 7 [65]. Bab ini tidak memuat isi COBIT 7 karena teks resminya belum diperoleh. Tabel 4.13 mencatat tanggal yang terbaca.

Bab ini mempertahankan model COBIT 2019 agar referensi aktivitas, lembar kerja, dan penilaian konsisten sepanjang semester. Penggunaan versi tertentu berbeda dari klaim bahwa versi tersebut paling baru. Tim menulis versi pada setiap artefak dan menilai dampak pembaruan sebelum mengganti rujukan. Pergantian versi memerlukan perbandingan ruang lingkup, pemetaan pengenal, pelatihan

Tabel 4.13: Tanggal transisi menurut pengumuman ISACA Sydney Chapter

Tanggal	Peristiwa
26 Oktober 2026	Batas pembelian sertifikat COBIT 2019 Foundation serta Design and Implementation
27 Oktober	Debut COBIT 7 dan sertifikat COBIT 7 Foundation
26 April 2027	Batas ujian kedua sertifikat COBIT 2019, tanpa perpanjangan
2027	Rencana sertifikat COBIT 7 Design and Implementation

penilai, dan uji ulang satu contoh. Riwayat penilaian tetap disimpan. Perubahan nama atau format tidak otomatis menunjukkan peningkatan kapabilitas organisasi.

Mengganti formulir penilaian pegawai tidak berarti kinerja pegawai langsung meningkat. Organisasi perlu memetakan pertanyaan lama dan baru agar hasil antartahun masih dapat dijelaskan.

Dua contoh penerapannya:

1. Pergantian COBIT 5 ke COBIT 2019 memberi preseden. COBIT 5 memiliki 37 proses dan COBIT 2019 memiliki 40. Tiga tambahannya adalah APO14, BAI11, dan MEA04 [49]. Lembar kerja COBIT 5 lama tidak memiliki baris untuk 3 objektif itu, termasuk APO14 yang menjadi prioritas Medikara. Misalkan lembar C2 berlabel COBIT 2019 sedangkan konsultan memakai COBIT 7. Tim meminta pemetaan model dan dasar penilaian sebelum membandingkan angka.
2. Dari 31 Oktober 2026 sampai 26 April 2027 tersisa 177 hari. Staf yang membeli ujian COBIT 2019 paling lambat 26 Oktober 2026 masih dapat mengikutinya dalam rentang itu. Sertifikat yang sudah diperoleh tetap berlaku [68]. Misalkan perubahan format memindahkan letak bukti AC-01. Pemilik kontrol memastikan riwayat bukti tetap terbaca dan keputusan terdahulu tidak hilang.

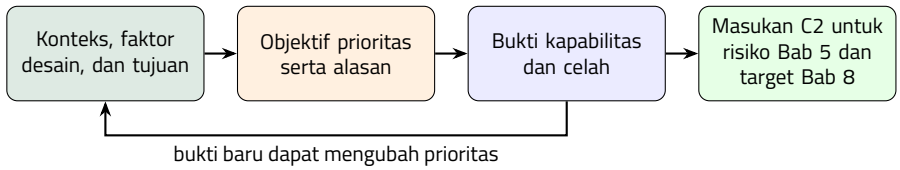
Tabel 4.14 merangkum pemeriksaan saat mengganti versi kerangka.

Tabel 4.14: Pemeriksaan saat mengganti versi kerangka

Langkah	Hasil yang disimpan	Risiko bila dilewati
Tetapkan versi	Identitas model dan tanggal	Definisi bercampur
Petakan perubahan	Hubungan unsur lama dan baru	Angka tidak sebanding
Uji contoh	Penilaian ulang satu proses	Perbedaan penilai tersembunyi
Setujui transisi	Keputusan serta jadwal	Artefak tidak sinkron

4.10 Aktivitas: Faktor Desain, Goals Cascade, dan Potret Kapabilitas

Aktivitas ini adalah kerja tim campuran latar belakang untuk capstone Cetak Biru Transformasi Digital dan menjadi langkah pertama tonggak C2. Tim memakai organisasi nyata dengan izin dan data yang dianonimkan, atau kasus Medikara Health. Gambar 4.6 menghubungkan langkah utamanya.



Gambar 4.6: Desain tata kelola dimulai dari konteks dan diakhiri dengan bukti prioritas

Tujuan. Memilih lima sampai tujuh objektif yang penting dan menggambarkan keadaan proses berdasarkan bukti.

Pembagian peran. Pemilik konteks mengumpulkan notulen, prosedur, dan hasil kerja. Analis risiko mengisi profil risiko serta ancaman. Analis regulasi mengisi kebutuhan kepatuhan. Analis teknologi mengisi peran TI, penyediaan, serta metode implementasi. Analis risiko dan analis teknologi menilai bukti secara berpasangan.

Langkah kerja.

1. Isi sebelas faktor desain pada `sources/chapter04/lembar-faktor-desain.csv`. Tulis sumber bukti serta asumsi pada setiap faktor, dan tandai mana fakta dan mana pengandaian.
2. Turunkan sedikitnya tiga kebutuhan pemangku kepentingan menjadi tujuan organisasi dan tujuan keselarasan pada `sources/chapter04/goals-cascade.csv`. Tulis apakah pemetaannya tercantum pada sumber atau merupakan penafsiran tim.
3. Beri skor kandidat pada `sources/chapter04/skor-prioritas-lokal.csv`. Tulis bobot sebelum melihat hasilnya, lalu ubah satu bobot dan catat perubahan urutan.
4. Pilih lima sampai tujuh objektif prioritas, lalu jelaskan alasan serta dependensinya. Periksa nama objektif pada `sources/chapter04/katalog-40-objektif.csv`.
5. Untuk tiap objektif, tentukan aktivitas yang diamati, periode, populasi, dan sampel bukti pada `sources/chapter04/lembar-bukti-kapabilitas.md`.

6. Nilai bukti secara berpasangan. Catat celah dan tingkat indikatif tanpa mengklaim asesmen formal.
7. Bandingkan hasil penilaian dengan matriks keputusan C1 dan register kewajiban, kemudian susun daftar bukti tambahan untuk C2.

Luaran. Lembar faktor desain, rantai tujuan, skor lokal beserta bobotnya, daftar objektif prioritas, dan potret kapabilitas.

Kaitan dengan capstone. Luaran masuk tonggak C2 Kondisi Saat Ini, yang ditinjau menjelang Ujian Tengah Semester. Celah diteruskan ke penilaian risiko Bab 5 serta rancangan target Bab 8.

Berkas pendukung. Seluruh lembar kerja ada di `sources/chapter04/`, dengan daftar berkas pada `sources/chapter04/README.md`.

Kriteria penilaian. Konteks dan bukti faktor desain 25 persen; keterlacakan tujuan ke prioritas 30 persen; mutu bukti serta batas kesimpulan 30 persen; konsistensi dan kejelasan rekomendasi 15 persen.

Etika. Data organisasi nyata wajib seizin organisasi dan dianonimkan. Data pribadi pasien atau karyawan tidak boleh dipakai. Tim mencatat rujukan bukti dan data agregat, sedangkan bukti asli tetap disimpan di tempat yang diizinkan organisasi.

Pendalaman teknis (opsional). Tim memakai *toolkit* COBIT resmi dan menelusuri bagaimana bobot faktor desain menggeser prioritas, seperti pada kotak pendalaman di seksi faktor desain. Bagian ini tidak dinilai sebagai syarat luaran C2.

4.11 Ringkasan

COBIT 2019 membantu merancang sistem tata kelola yang sesuai kebutuhan organisasi. Enam prinsip sistem dan tujuh komponen menunjukkan bahwa prosedur, manusia, struktur, informasi, dan teknologi perlu bekerja bersama. Perintah "Terapkan COBIT" menjadi berguna setelah diterjemahkan menjadi masalah, pemilik, dan bukti.

Empat puluh objektif pada lima domain memberi bahasa bersama untuk arah dan pelaksanaan. EDM memuat tata kelola, sedangkan APO, BAI, DSS, dan MEA memuat manajemen. Dengan perkiraan kasar 35 aktivitas per objektif, menilai semuanya menghabiskan ratusan jam. Karena itu pilihan lingkup merupakan keputusan yang perlu dipertanggungjawabkan.

Sebelas faktor desain dan rantai tujuan membantu memilih bagian yang paling perlu diperiksa dan diperbaiki. Contoh Kadam menyaring 40 objektif menjadi 17,

8, lalu 4. Medikara memilih enam objektif awal dengan skor lokal, lalu melihat bahwa menggandakan bobot kewajiban mengubah anggota enam besar. Skor lokal berguna selama bobot dan asumsinya tertulis.

Kapabilitas dinilai melalui aktivitas serta bukti dalam lingkup yang jelas. Klaim manajer, sertifikat individu, dan rata-rata angka tidak menggantikan penilaian penerapan proses. Dua studi rumah sakit memperlihatkan alur yang dapat ditiru sekaligus keterbatasan yang perlu dihindari, terutama penilaian yang bersandar pada jawaban sedikit responden. Pada AC-01, 80 persen sampel yang sesuai tetap tidak membuktikan penerapan di lima rumah sakit.

COBIT berjalan bersama ITIL 4 dan tata kelola arsitektur, dan transisi versi memerlukan pemetaan serta pengendalian artefak. Pesan utama bab ini adalah bahwa prioritas yang dapat dijelaskan dan bukti yang dapat diperiksa lebih berguna daripada mengejar penerapan seluruh kerangka sekaligus.

4.12 Latihan

Latihan 1: Pengaruh Model Penyediaan

Dua rumah sakit memiliki strategi yang sama, tetapi satu mengembangkan sistem sendiri dan satu bergantung pada vendor. Bagaimana perbedaan model *sourcing* itu menggeser objektif prioritas?

Latihan ini membuktikan bahwa strategi sama tidak menghasilkan rancangan tata kelola yang identik.

1. Tulis satu tujuan layanan yang sama bagi kedua rumah sakit.
2. Identifikasi tiga perbedaan kewenangan, keterampilan, dan ketergantungan.
3. Pilih dua objektif yang meningkat prioritasnya pada tiap rumah sakit dan jelaskan risikonya.

Tabel 4.15 merangkum contoh terisi latihan 1, dan Tabel 4.16 adalah lembar isiannya. Angka pada contoh adalah pengandaian.

Tabel 4.15: Contoh terisi Latihan 1

Konteks pengandaian	Perhatian utama	Objektif kandidat
A membangun 2 aplikasi sendiri, 8 pengembang, 15 akun pihak ketiga	Kebutuhan, kualitas, dan perubahan	BAI02, BAI03, BAI06
B memakai 2 vendor utama, 1 pengelola kontrak, 120 akun vendor	Hubungan, risiko, dan keamanan	APO10, APO12, DSS05

Tabel 4.16: Lembar isian Latihan 1

Konteks pengandaian	Perhatian utama	Objektif kandidat
…	…	…
…	…	…

Pertanyaan analisis. Objektif mana yang tetap penting pada keduanya? Bila akun pihak ketiga pada A naik dari 15 menjadi 120, apa yang berubah pada pilihan? Bukti apa yang dapat membalik urutan prioritas awal?

Latihan 2: Menguji Klaim Tingkat Tiga

Seorang manajer menyatakan proses manajemen perubahan sudah berada di tingkat kapabilitas 3. Bukti apa yang perlu diminta untuk menguji klaim itu?

Latihan ini menguji kecukupan bukti aktivitas dan penerapan cara kerja organisasi.

1. Tentukan lingkup proses perubahan dan rujukan aktivitas COBIT 2019 yang dipakai.
2. Pilih sampel perubahan normal serta darurat pada lebih dari satu periode.
3. Bandingkan prosedur, persetujuan, analisis dampak, pengujian, dan evaluasi hasil, lalu nyatakan batas kesimpulan.

Tabel 4.17 merangkum contoh terisi latihan 2, dan Tabel 4.18 adalah lembar isiannya.

Tabel 4.17: Contoh terisi Latihan 2

Bukti pengandaian	Temuan	Implikasi
10 tiket perubahan dari 2 periode	8 punya persetujuan lengkap, atau 80 persen	Telaah 2 pengecualian
Prosedur korporat	Tersedia, tetapi 1 dari 5 rumah sakit belum memberi bukti penerapan	Klaim lintas 5 rumah sakit belum terbukti
Hasil pengujian	Tidak lengkap pada 2 perubahan darurat	Minta bukti pengganti dan evaluasi

Tabel 4.18: Lembar isian Latihan 2

Bukti pengandaian	Temuan	Implikasi
…	…	…
…	…	…

Pertanyaan analisis. Mengapa persentase 80 persen tidak langsung menjadi tingkat kapabilitas? Bila aturan menuntut 85 persen, berapa tiket minimum dari 10 yang harus lengkap? Informasi tambahan apa yang perlu diminta sebelum kesimpulan final?

Latihan 3: Menentukan Lingkup yang Masuk Akal

Jelaskan mengapa COBIT tidak dimaksudkan untuk diterapkan seluruhnya sekaligus.

Latihan ini menilai hubungan prioritas, dependensi, dan kapasitas perbaikan.

1. Pilih tiga masalah utama dari konteks Medikara.
2. Hubungkan masalah dengan objektif dan dependensi yang mendukungnya.
3. Susun urutan perbaikan dalam kapasitas pengandaian dua inisiatif per triwulan, lalu jelaskan yang ditunda.

Tabel 4.19 merangkum contoh terisi latihan 3, dan Tabel 4.20 adalah lembar isiannya. Enam objektif dengan dua inisiatif per triwulan memerlukan 3 triwulan.

Tabel 4.19: Contoh terisi Latihan 3

Urutan pengandaian	Fokus	Alasan dan dependensi
Triwulan 1	Akses vendor: APO10, DSS05	Insiden R-01 dan 120 akun vendor
Triwulan 2	Keamanan dan data: APO13, APO14	Kebijakan serta strategi pasien tunggal
Triwulan 3	Pemantauan: APO12, MEA03	Memerlukan pemilik serta data dasar dari dua triwulan awal

Tabel 4.20: Lembar isian Latihan 3

Urutan pengandaian	Fokus	Alasan dan dependensi
…	…	…
…	…	…

Pertanyaan analisis. Apa risiko menunda objektif yang tidak masuk prioritas awal, misalnya DSS04 dengan 144 uji pemulihan per tahun? Bila baris pemantauan Peraturan Pemerintah (PP) 33/2026 pada Bab 3 berubah menjadi tenggat, bagaimana urutan tersebut berubah?

Bab 5

Manajemen Risiko Enterprise dan Risiko TI

Tujuan Pembelajaran

- Menerapkan proses ISO 31000 untuk mengidentifikasi, menganalisis, dan mengevaluasi risiko terkait TI.
- Merumuskan pernyataan *risk appetite* yang dapat dipakai untuk mengambil keputusan.
- Membandingkan penilaian risiko kualitatif dan kuantitatif beserta keterbatasan masing-masing.

5.1 Pendahuluan

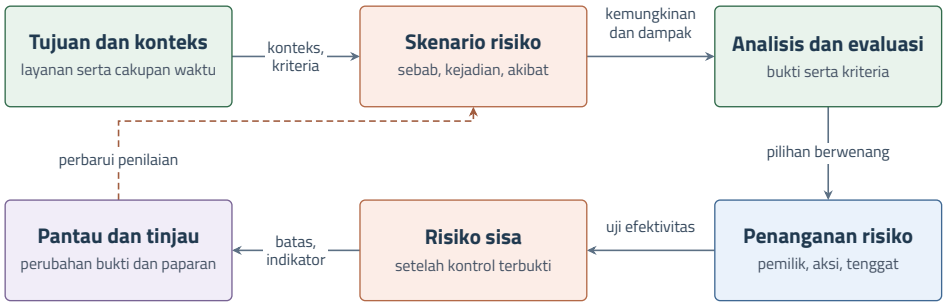
Misalkan pada akhir 2025 register risiko Medikara berisi 86 baris dalam sebuah spreadsheet. Register itu dibuka dua kali setahun, menjelang audit. Setiap baris berwarna merah, kuning, atau hijau, tetapi tidak ada notulen komite yang merujuknya. Ketika kontrak vendor Medikara+ diperpanjang, tidak ada yang membuka baris tentang akun vendor. Masalahnya bukan jumlah baris, melainkan hubungan antara skenario, bukti, dan batas keputusan. Daftar risiko yang tidak pernah mengubah keputusan hanya menjadi arsip.

Medikara mengalami kebocoran data skala kecil lewat vendor pada 2025, dan audit internal menemukan kontrol akses yang lemah. Penilaian risiko perlu menjelaskan tujuan yang terancam, kontrol yang benar-benar berjalan, dan pemilik risiko sisa. Perbaikan teknologi informasi (TI) harus dinilai bersama akibatnya terhadap pasien dan layanan. Hasil kerja bab ini adalah pernyataan *risk appetite*

dan *risk register* kondisi saat ini untuk tonggak C2 capstone.

Bab ini memakai ISO 31000:2018 dari International Organization for Standardization (ISO) untuk proses penilaian. Hubungan risiko dengan strategi dan kinerja mengikuti Enterprise Risk Management (ERM) 2017 dari Committee of Sponsoring Organizations of the Treadway Commission (COSO). Risiko keamanan informasi merujuk ISO/IEC 27005:2022 dari ISO dan International Electrotechnical Commission (IEC). Naskah ketiganya berbayar, sehingga publikasi terbuka National Institute of Standards and Technology (NIST) dipakai untuk rincian yang dapat diperiksa mahasiswa. Seluruh hitungan merupakan contoh pembelajaran, bukan perkiraan kerugian Medikara yang telah diukur [69, 23, 77, 126].

Gambar 5.1 merangkum hubungan komponen dan konsep utama bab ini.



Skor matriks berskala urut, bukan rupiah atau peluang. Pemilik risiko tetap bertanggung jawab meski kontrol dikerjakan vendor.

Gambar 5.1: Skenario risiko dinilai terhadap tujuan dan kriteria

5.2 Risiko Berawal dari Tujuan Organisasi

Risiko dan ERM

Daftar ancaman belum menjadi penilaian risiko. ISO 31000:2018 mendefinisikan risiko sebagai efek ketidakpastian terhadap tujuan [69]. Definisi yang sama sudah dipakai pada Bab 1. Akibatnya, penilaian dimulai dari tujuan, bukan dari daftar hal buruk yang mungkin terjadi. ERM menghubungkan pilihan strategi dengan risiko portofolio, bukan sekadar mengumpulkan masalah departemen. COSO mendefinisikan ERM sebagai budaya, kapabilitas, dan praktik yang diintegrasikan organisasi dengan penetapan strategi dan diterapkan saat strategi dijalankan. Tujuannya mengelola risiko dalam menciptakan, menjaga, dan mewujudkan nilai [23, 126].

Analogi yang dekat ialah perjalanan ambulans. Hujan menjadi risiko bila jalan tergenang sehingga pasien terlambat mendapat pertolongan. Hujan yang sama

tidak berarti apa-apa bagi ambulans yang sedang parkir. Tujuan, rute, waktu tempuh, dan alternatif jalan menentukan keputusan.

Dua contoh memperjelas hubungan tersebut:

1. Medikara melayani sekitar 1,2 juta kunjungan per tahun, atau sekitar 3.288 kunjungan per hari. Misalkan layanan berjalan 12 jam per hari, sehingga ada sekitar 274 kunjungan per jam. Gangguan pendaftaran selama 3 jam menyentuh sekitar 822 kunjungan. Gangguan itu dihitung sebagai kunjungan tertunda dan waktu tunggu, bukan hanya jumlah server yang mati.
2. Misalkan penggabungan laporan 18 klinik memerlukan 3 hari kerja setiap bulan, dari 216 berkas per tahun. Satu klinik yang mengubah format tanpa pemberitahuan berarti 1 dari 18 berkas bulanan, atau sekitar 5,6 persen, salah terbaca. Perubahan itu mengancam ketepatan laporan, meskipun tidak ada sistem yang berhenti.

Tabel 5.1 merangkum hubungan tujuan, risiko, dan keputusan. Kode R-01 dan AC-01 mengikuti Bab 1 dan tetap dipakai sampai Bab 14. BPJS adalah Badan Penyelenggara Jaminan Sosial.

Tabel 5.1: Hubungan tujuan, risiko, dan keputusan

Tujuan	Skenario	Keputusan
Kerahasiaan data	R-01: akses vendor berlebihan menyebabkan pengungkapan data pasien	Batasi akses dan tinjau AC-01
Kelangsungan pendaftaran	R-03: integrasi BPJS Kesehatan terhenti ketika pasien datang	Siapkan antrean pengganti
Laporan konsisten	R-04: versi spreadsheet berbeda	Tetapkan validasi dan pemilik definisi
Keselamatan pasien	R-11: riwayat alergi tidak terbaca lintas rumah sakit	Libatkan pimpinan klinis dan perbaiki pertukaran data

Dua hal pada register sering tertukar: risiko dan temuan. Pembagiannya begini. Risiko masih mengandung ketidakpastian, sedangkan temuan sudah terjadi. Audit menemukan 6 dari 30 akun vendor sampel masih aktif setelah penugasan berakhir. Itu temuan. Kemungkinan salah satu akun itu dipakai mengakses data pasien adalah risiko. Keduanya saling berkaitan, tetapi menuntut hal yang berbeda.

Pembedaan ini punya dua konsekuensi. Pertama, temuan memerlukan penutupan dengan bukti, seperti 24 akun yang dicabut pada peninjauan bulan berikutnya. Risiko memerlukan keputusan: dikurangi, dibagi, dihindari, atau diterima. Kedua, register yang mencampur keduanya tampak panjang, tetapi tidak menunjukkan keputusan yang menunggu.

COSO ERM: lima komponen

Pertanyaan kemudian muncul: bagaimana risiko dihubungkan dengan strategi? COSO ERM 2017 menyusun jawabannya dalam lima komponen yang saling terkait dan 20 prinsip [23, 109]. Kelima komponen itu bukan tahap berurutan. Setiap komponen menjawab pertanyaan pimpinan yang berbeda. Tabel 5.2 menerapkan kelimanya pada Medikara. Nama komponen diterjemahkan bebas oleh bab ini, dan contohnya merupakan pengandaian.

Tabel 5.2: Lima komponen COSO ERM pada pengandaian Medikara

Komponen	Contoh penerapan pada Medikara
Tata kelola dan budaya (*Governance and Culture*)	Komite pengarah TI 9 anggota pada Bab 2, dengan kuorum 6 anggota dan pemilik risiko wajib hadir
Strategi dan penetapan sasaran (*Strategy and Objective-Setting*)	Strategi "Satu Pasien, Satu Rekam Medis" dipakai untuk menurunkan pernyataan *risk appetite*
Kinerja (*Performance*)	Register 12 skenario dinilai, diprioritaskan, dan diberi keputusan penanganan
Tinjauan dan revisi (*Review and Revision*)	Insiden vendor 2025 dan temuan audit memicu penilaian ulang R-01
Informasi, komunikasi, dan pelaporan (*Information, Communication, and Reporting*)	Indikator dan laporan satu halaman untuk direksi pada Bab 13

Risiko TI di dalam risiko enterprise

Dua hal pada risiko TI juga sering tertukar: risiko pada sistem dan risiko pada organisasi. Pembagiannya begini. NIST Special Publication (SP) 800-39 memakai tiga tingkat: organisasi, proses misi dan bisnis, serta sistem informasi [83]. Pertanyaan pada tiap tingkat berbeda, sehingga pemiliknya juga berbeda. NIST Interagency Report (IR) 8286 Revisi 1 menjelaskan bahwa register dari sistem dan unit digabungkan, dinormalkan, dan diprioritaskan menjadi profil risiko pada tingkat lebih tinggi [126]. Tabel 5.3 menerapkan pembagian itu pada Medikara. SIMRS pada tabel adalah Sistem Informasi Manajemen Rumah Sakit.

Polanya mirip laporan keuangan grup usaha. Setiap cabang menyusun buku kas sendiri. Kantor pusat tidak membaca setiap kuitansi, tetapi menerima laporan gabungan dengan definisi akun yang sama.

Dua contoh penerapannya:

1. Misalkan 5 rumah sakit masing-masing mengirim 14 baris, sehingga terkumpul 70 baris. Delapan baris menyebut hak akses SIMRS lokal dengan

Tabel 5.3: Tiga tingkat risiko pada pengandaian Medikara

Tingkat	Pertanyaan	Pemeran	Keluaran
Organisasi	Risiko mana yang menyentuh strategi?	Direksi, komite 9 anggota, kepala risiko	*Risk appetite* dan profil risiko
Proses misi dan bisnis	Layanan mana yang terdampak?	Pemilik Medikara+, kepala pendaftaran	*Risk tolerance* dan register layanan
Sistem informasi	Kontrol mana yang berjalan?	Kepala operasi TI, pengelola SIMRS	Bukti kontrol dan register sistem

kata berbeda. Kantor pusat menggabungkannya menjadi satu skenario R-02, karena pemilik dan penanganannya sama. Direksi membaca satu keputusan, bukan delapan keluhan.

2. Akun vendor di Medikara+ terlihat sebagai urusan teknis pada tingkat sistem. Pada tingkat layanan, akun itu berkaitan dengan 28.000 janji temu per bulan, atau 336.000 per tahun. Pada tingkat organisasi, akun itu berkaitan dengan strategi ekosistem mitra. APO12 masuk enam objektif awal COBIT pada Bab 4 karena R-01 memerlukan pemilik dan pemantauan yang sama pada semua fasilitas.

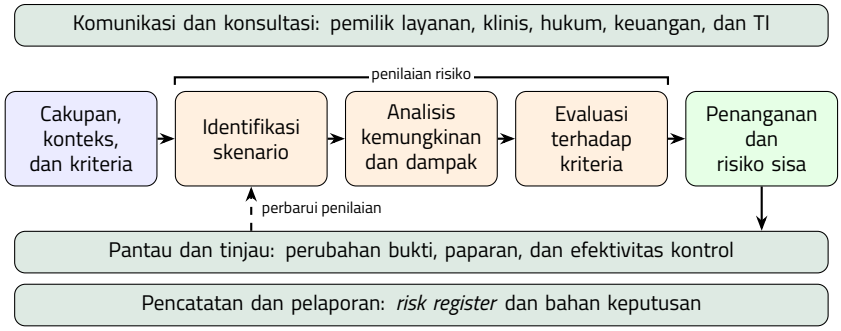
5.3 Proses ISO 31000 dan Konteks Penilaian

Prinsip, kerangka, dan proses

ISO 31000:2018 memberikan panduan, bukan persyaratan sertifikasi organisasi. Standar ini tersusun dari tiga bagian: prinsip, kerangka, dan proses [69, 110]. Delapan prinsipnya meminta manajemen risiko terintegrasi, terstruktur dan menyeluruh, disesuaikan dengan organisasi, inklusif, dinamis, memakai informasi terbaik yang tersedia, memperhitungkan faktor manusia dan budaya, serta terus diperbaiki. Seksi ini berfokus pada prosesnya.

Tim menetapkan cakupan, konteks, dan kriteria sebelum penilaian. Identifikasi mencari skenario, analisis menilai kemungkinan dan dampak, sedangkan evaluasi membandingkannya dengan kriteria keputusan. Penanganan memilih tindakan. Komunikasi dan konsultasi, pantau dan tinjau, serta pencatatan dan pelaporan menyertai seluruh proses. NIST mencatat kerangka dari COSO, Office of Management and Budget (OMB) Amerika Serikat, dan ISO pada umumnya memuat langkah serupa [126]. Gambar 5.2 merupakan ringkasan pembelajaran, bukan reproduksi gambar standar.

Analogi pemeriksaan kendaraan memisahkan tahapnya. Ban tipis adalah temuan awal. Peluang tergelincir pada rute hujan merupakan analisis. Keputusan



Gambar 5.2: Proses dari konteks hingga keputusan risiko

bahwa ban itu melewati batas aman merupakan evaluasi. Mengganti ban sebelum berangkat adalah keputusan penanganan.

Dua penerapan menunjukkan pentingnya batas penilaian:

1. Misalkan cakupannya Medikara+ selama 12 bulan, dengan 336.000 janji temu dan 120 akun vendor. Tim menelusuri kontrak, akun vendor, akses data, dan pemilik layanan. Temuan rumah sakit lain menjadi konteks, bukan bukti otomatis.
2. Misalkan cakupannya pelaporan 18 klinik selama 12 bulan, dengan 216 berkas. Tim menelusuri penggabungan data dan versi berkas. Daftar ancaman internet yang tidak berhubungan dengan proses itu tidak dijadikan titik awal.

Kriteria risiko ditetapkan sebelum skor

Pertanyaan kemudian muncul: skor 3 itu artinya apa? Kriteria menjawabnya. Kriteria menetapkan periode, arti tiap nilai, dan tindakan pada tiap kelompok skor. NIST SP 800-30 Revisi 1 menekankan bahwa nilai perlu didefinisikan jelas atau diberi contoh bermakna. Tanpa itu, ahli yang berbeda dapat memberi hasil yang jauh berbeda. Penilaian juga perlu menyebut periode waktunya [84]. Tabel 5.4 adalah contoh pembelajaran, bukan skala baku.

Keputusan menetapkan kriteria lebih dahulu punya dua konsekuensi. Pertama, tim tidak dapat mengubah skala setelah melihat hasil supaya risiko tampak lebih rendah. Kedua, keselamatan, hak pasien, dan kepatuhan dinilai dalam kolom terpisah. Risiko cedera berat langsung dieskalasikan kepada pimpinan klinis, meskipun skor gabungannya rendah. Batas rupiah tidak dipakai untuk mengizinkan pelanggaran.

Tabel 5.4: Contoh skala penilaian Medikara untuk periode 12 bulan (misalkan)

Nilai	Kemungkinan	Dampak finansial per kejadian	Dampak layanan
1	Kurang dari 5 persen	Di bawah Rp10 juta	Pekerjaan pulih dalam unit
2	5 sampai kurang dari 15 persen	Rp10 juta sampai kurang dari Rp50 juta	Gangguan lokal terkendali
3	15 sampai kurang dari 40 persen	Rp50 juta sampai kurang dari Rp200 juta	Layanan penting tertunda
4	40 sampai kurang dari 70 persen	Rp200 juta sampai kurang dari Rp1 miliar	Gangguan lintas lokasi
5	70 persen atau lebih	Rp1 miliar atau lebih	Layanan utama tidak berjalan

Mulai dari peristiwa atau aset?

Pertanyaan berikutnya: apakah penilaian harus dimulai dari aset? Tidak selalu. ISO/IEC 27005:2022 memandu pengelolaan risiko keamanan informasi [77]. Pendekatan berbasis aset memulai dari data dan ketergantungannya. Pendekatan berbasis peristiwa memulai dari kejadian. Keduanya harus menghasilkan skenario berisi sebab, kejadian, dan akibat. NIST SP 800-30 Revisi 1 memberi peringatan yang berguna. Titik awal yang berbeda dapat membuat sebagian risiko tidak teridentifikasi, sehingga memakai sudut pandang kedua meningkatkan ketelitian analisis [84]. Tabel 5.5 membandingkan keduanya.

Tabel 5.5: Pendekatan berbasis peristiwa dan berbasis aset pada Medikara

Unsur	Berbasis peristiwa	Berbasis aset
Titik awal	Kejadian dan akibatnya pada tujuan	Data, sistem, dan ketergantungan
Contoh Medikara	Insiden vendor 2025 dan gangguan integrasi BPJS Kesehatan	Rekam medis, SIMRS di 5 rumah sakit, Medikara+
Mudah terlewat	Aset yang belum pernah terkena masalah	Kejadian lintas aset, misalnya dua vendor dengan satu subpenyedia

Dua contoh penerapannya:

1. Misalkan jalur peristiwa menghasilkan 9 skenario dan jalur aset menghasilkan 8 skenario. Sebanyak 5 skenario sama, sehingga register memuat 12 skenario unik. Tiga skenario hanya muncul dari jalur aset, dan empat hanya muncul dari jalur peristiwa.
2. R-05 tentang cadangan yang belum diuji muncul dari jalur aset, karena

belum pernah ada kejadian pemulihan gagal. R-08 tentang dua vendor dengan satu subpenyedia muncul dari jalur peristiwa, karena daftar aset menempatkan kedua vendor pada baris terpisah.

5.4 Risk Appetite, Risk Tolerance, dan Kapasitas Risiko

Tiga istilah, tiga fungsi

Risk appetite menyatakan arah risiko yang bersedia diambil organisasi. NIST menggambarkannya sebagai panduan tentang jenis dan jumlah risiko, pada tingkat umum, yang bersedia diterima pimpinan senior untuk mengejar tujuan. Pernyataan ini dapat bersifat kualitatif atau kuantitatif. *Risk tolerance* menerjemahkannya menjadi batas operasional. Definisi OMB yang dikutip NIST menyebutnya tingkat variasi kinerja yang dapat diterima terhadap pencapaian tujuan [127]. Kapasitas risiko, dalam rumusan umum bab ini, adalah batas yang mampu ditanggung organisasi. Mampu membayar kerugian tidak berarti boleh melanggar kewajiban hukum atau mengabaikan keselamatan.

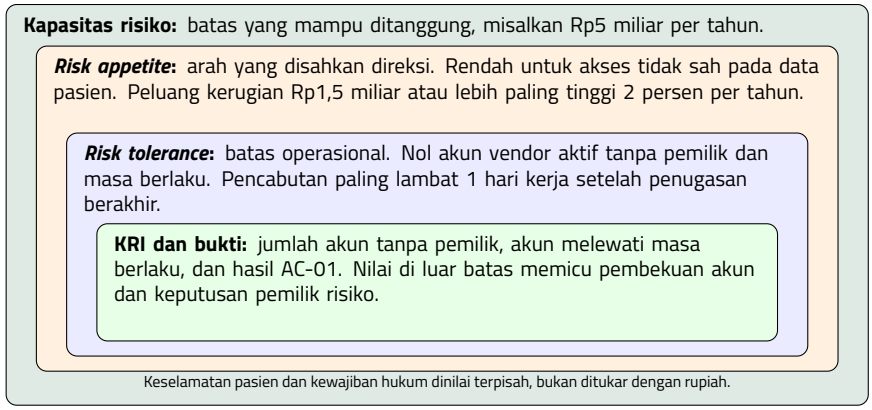
Analogi anggaran keluarga membantu membedakan ketiganya. Keluarga memilih anggaran perjalanan, menetapkan batas penyimpangan, dan menyisakan dana kebutuhan pokok. Mampu menghabiskan tabungan tidak membuat pilihan itu sesuai tujuan keluarga.

Dua usulan berikut adalah skenario pembelajaran:

1. Misalkan semua akun vendor harus memiliki penanggung jawab dan masa berlaku. Satu akun tanpa keduanya diblokir, walaupun hanya 1 dari 120 akun, atau sekitar 0,8 persen. Pengecualian darurat hanya disetujui pemilik layanan dan berakhir paling lambat 24 jam. Batas ini sejalan dengan aturan pencabutan 1 hari kerja pada Bab 2.
2. Misalkan gangguan pendaftaran dibatasi 2 jam per bulan, atau 24 jam per tahun. Dengan 12 jam layanan per hari, batas itu setara sekitar 0,55 persen dari 4.380 jam layanan setahun. Dua jam gangguan menyentuh sekitar 548 kunjungan. Pelanggaran memicu tinjauan mingguan. Risiko cedera berat langsung dieskalasikan tanpa menunggu batas bulanan terlewati.

Gambar 5.3 memperlihatkan hubungan keempat lapis tersebut untuk R-01. KRI pada gambar adalah Key Risk Indicator, yang dibahas pada seksi penanganan. Angka kapasitas Rp5 miliar dipilih sama dengan batas delegasi Bab 2, karena keputusan di atas angka itu sudah melibatkan dewan komisaris bila anggaran dasar menetapkan.

Pertanyaan kemudian muncul: mengapa kapasitas perlu dicatat bila batas lain sudah ada? Pengandaian Bab 3 memberi jawabannya. Denda administratif paling



Gambar 5.3: Kapasitas, *risk appetite*, *risk tolerance*, dan indikator untuk R-01 (misalkan)

tinggi 2 persen dari Rp500 miliar sama dengan Rp10 miliar [136]. Angka itu dua kali kapasitas Rp5 miliar. Skenario dengan peluang kecil tetap perlu dibahas direksi bila akibat terburuknya melewati kapasitas. Angka Rp10 miliar adalah batas atas untuk diskusi, bukan perkiraan denda.

Appetite dan tolerance sering tertukar

Dua hal ini sering tertukar. Pembagiannya begini. Pernyataan *risk appetite* memberi arah umum dan berasal dari pimpinan tertinggi. Pernyataan *risk tolerance* selalu lebih spesifik dan harus berada di dalam batas arah itu. NIST memberi contoh penyedia layanan kesehatan. Direksinya menyatakan *risk appetite* rendah untuk paparan keamanan siber akibat kontrol akses atau autentikasi yang tidak memadai. Pernyataan *risk tolerance*-nya mengakui sebagian perangkat belum mendukung autentikasi lanjutan, tetapi 100 persen aplikasi bisnis kesehatan yang kritis wajib memakai Multi-Factor Authentication (MFA) [127]. Pernyataan pertama memberi arah. Pernyataan kedua dapat diperiksa.

NIST SP 800-39 mengingatkan bahwa tidak ada tingkat toleransi risiko yang benar untuk semua organisasi. Organisasi yang terlalu menghindari risiko dapat gagal mencapai kemampuan yang dibutuhkan. Organisasi yang terlalu berani dapat mengejar efisiensi jangka pendek dan menyiapkan kegagalan di kemudian hari [83]. Tabel 5.6 merangkum usulan batas keputusan Medikara. Seluruh angkanya pengandaian, bukan batas hukum.

Menguji pernyataan risk appetite

Pernyataan “Medikara tidak menoleransi kebocoran data” belum memberi aturan kerja. Organisasi dapat menolak pemrosesan tanpa dasar yang sah, sambil meng-

Tabel 5.6: Usulan batas keputusan Medikara (misalkan)

Kategori	Arah	Ukuran	Pemicu tindakan
Keselamatan pasien	Tidak menukar risiko cedera berat dengan kecepatan atau biaya	Setiap risiko cedera berat ditinjau dalam 1 hari kerja	Libatkan pimpinan klinis segera
Kerahasiaan	Rendah untuk akses tidak sah pada data pasien	Nol akun vendor aktif tanpa pemilik dan masa berlaku	Bekukan akun yang tidak sesuai
Kelangsungan	Menerima gangguan singkat bila prosedur pengganti berjalan	Pendaftaran terganggu paling lama 2 jam per bulan	Pemilik layanan menyiapkan perbaikan
Kepatuhan	Rendah untuk kewajiban hukum yang terlewat	K-01 sampai K-16 memiliki pemilik; nol baris lewat tenggat tanpa keputusan	Catat penyimpangan dan tindakan
Finansial	Menerima kerugian kecil yang sering; membatasi kerugian besar	Peluang kerugian Rp1,5 miliar atau lebih paling tinggi 2 persen per tahun per skenario	Laporkan ke komite pengarah TI

akui ketidakpastian teknis. Indikator, pemilik tindakan, dan jalur pengecualian membuat arah kebijakan dapat dipakai. Tabel 5.7 memuat empat pertanyaan uji. Daftar ini disusun bab ini sebagai alat bantu, bukan kutipan standar.

Tabel 5.7: Empat pertanyaan uji pernyataan *risk appetite*

Pertanyaan	Pernyataan lemah	Pernyataan yang lolos
Apakah menyebut yang diterima dan ditolak?	Tidak menoleransi kebocoran	Vendor boleh mengakses data bila ada dasar tugas tercatat
Apakah ada ukuran?	Akses dijaga dengan baik	Nol akun aktif tanpa pemilik
Apakah memicu tindakan dan menyebut pemilik?	Masalah dilaporkan	Pemilik Medikara+ membekukan akun dalam 1 hari kerja
Apakah sejalan dengan kewajiban hukum?	Biaya kontrol lebih besar daripada kerugian, jadi diabaikan	K-01 tetap dipenuhi walaupun manfaat finansial negatif

Kasus Medikara Health: Batas Risiko yang Disahkan Direksi

Misalkan komite pengarah TI membahas batas kerahasiaan pada rapat bulanan dengan 7 dari 9 anggota hadir, sehingga kuorum 6 anggota terpenuhi. Pemilik Medikara+ hadir sebagai pemilik R-01. Direksi lalu mengesahkan

batas pada Tabel 5.6.
Sebulan kemudian, vendor meminta 4 akun tetap aktif selama 10 hari setelah penugasan berakhir supaya perbaikan lebih cepat. Paparannya 40 akun-hari. Pemilik Medikara+ menolak dan memberi satu pengecualian darurat 24 jam untuk keempat akun. Paparannya turun menjadi 4 akun-hari, atau berkurang 90 persen.
Keputusan ini punya dua konsekuensi. Pertama, perbaikan vendor berjalan lebih lambat, dan tenggat perbaikan digeser 3 hari. Itulah harga yang diterima dalam *tradeoff* ini. Kedua, percakapan berubah. Yang dibahas bukan lagi siapa yang paling hati-hati, melainkan apakah bukti pengecualian tersedia dan siapa yang menyetujuinya. Tanpa batas tertulis, permintaan seperti ini diputuskan lewat pesan singkat dan tidak meninggalkan jejak.

5.5 Skenario, Kontrol, dan Risk Register

Register menyimpan alasan keputusan

Risk register menyimpan alasan keputusan. OMB, seperti dikutip NIST, mendefinisikannya sebagai tempat penyimpanan informasi risiko, termasuk data yang dipahami tentang risiko dari waktu ke waktu [126]. Satu baris memuat pengenal, tujuan, sebab, kejadian, akibat, pemilik risiko, bukti, kontrol berjalan, penilaian, dan rencana tindakan. Pemilik risiko berwenang mengelola akibatnya, sedangkan pelaksana kontrol teknis dapat berbeda. NIST menyebut pemilik risiko sebagai pihak yang bertanggung jawab dan akuntabel, dan pemilik itu dapat bekerja dengan pengelola yang memantau penanganan.

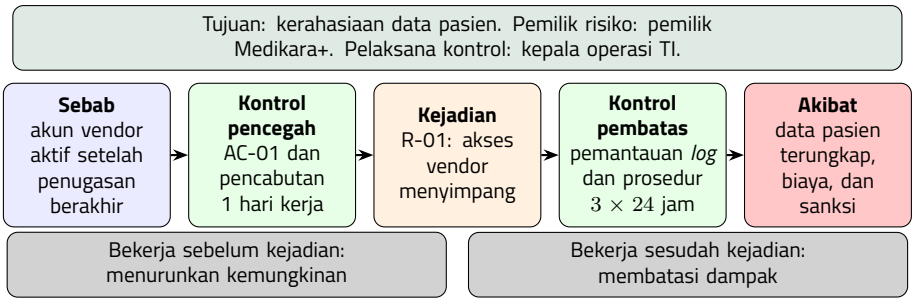
Analogi buku piutang menunjukkan peran rincian. Catatan bahwa pelanggan berisiko tidak menggerakkan pekerjaan apa pun. Jumlah, jatuh tempo, penagih, dan tindakan berikutnya membuat catatan itu berguna.

Dua contoh membedakan bukti dari rencana:

1. R-01 menyebut akses vendor yang berlebihan menyebabkan pengungkapan data pasien. AC-01 adalah peninjauan akses. Daftar persetujuan dan bukti pencabutan menunjukkan apakah kontrol tersebut bekerja. Audit menemukan 6 dari 30 akun sampel bermasalah, atau 20 persen. Peninjauan berikutnya mencabut 24 dari 120 akun, juga 20 persen. Pengandaian Bab 4 menambahkan kelemahan lain: daftar peninjau hanya memuat 108 akun, sehingga 12 akun, atau 10 persen, luput. Rencana membeli alat belum membuktikan apa pun tentang 12 akun itu.
2. Misalkan R-04 menyebut petugas menyalin angka dari berkas lama sehingga laporan 18 klinik berbeda. Rekonsiliasi bulanan menurunkan kesalahan,

tetapi belum menyelesaikan perbedaan definisi data. Bila rekonsiliasi memerlukan 3 hari kerja per bulan, kontrol itu menghabiskan 36 hari kerja per tahun tanpa menghilangkan sebabnya.

Gambar 5.4 menguraikan R-01 menjadi sebab, kejadian, dan akibat. Kontrol di sisi kiri menurunkan kemungkinan, sedangkan kontrol di sisi kanan membatasi dampak. Pasal 46 Undang-Undang (UU) 27/2022 tentang Pelindungan Data Pribadi (PDP) menetapkan pemberitahuan tertulis paling lambat 3×24 jam, seperti dicatat pada Bab 3 [136].



Gambar 5.4: Skenario R-01: sebab, kejadian, akibat, dan letak kontrol

Kasus Medikara Health: Dari 86 Baris ke 12 Skenario

Misalkan analis risiko memeriksa 86 baris register lama bersama pemilik layanan. Sebanyak 38 baris digabung karena menggambarkan skenario yang sama. Sebanyak 21 baris dipindahkan ke daftar temuan karena sudah terjadi. Sebanyak 15 baris dikeluarkan karena berada di luar cakupan 12 bulan. Tersisa 12 skenario, masing-masing dengan satu pemilik.

Fakta dasar menyebut insiden vendor pada 2025 dan kontrol akses yang lemah, tanpa jumlah data dan kerugian. Data latihan Bab 1 memakai 1.240 rekam dan biaya langsung Rp23,7 juta, tetapi register tidak memakainya sebagai hasil investigasi. Tim menulis "belum ada bukti" untuk unsur tersebut. Angka tambahan dalam contoh adalah asumsi pembelajaran.

Keputusan ini punya dua konsekuensi. Pertama, komite dapat membaca seluruh register dalam rapat 2 jam, sehingga register benar-benar masuk agenda. Kedua, rincian tidak hilang. Baris yang digabung tetap terlacak lewat pengenal lama, supaya audit dapat menelusuri asal setiap skenario. Bukti kontrol yang dipakai tetap dipisahkan dari rencana. Baris R-01 menulis "AC-01 sebagian", bukan "AC-01 ada".

Kolom yang diperlukan

Pertanyaan kemudian muncul: kolom apa saja yang diperlukan? NIST IR 8286 Revisi 1 memberi templat register keamanan siber yang dapat dijadikan pembanding [126]. Tabel 5.8 memetakan kolom berkas `sources/chapter05/risk-register.csv` ke elemen templat itu. Bab ini menambahkan kolom bukti, keselamatan, dan kepatuhan, karena ketiganya dibutuhkan pada kasus layanan kesehatan. NIST menggabungkan kemungkinan dan dampak sebagai *exposure*, sedangkan ISO 31000 menyebutnya tingkat risiko.

Tabel 5.8: Kolom register dan pertanyaan yang dijawab

Kolom pada berkas	Pertanyaan	Elemen NIST
`id`, `kategori`, `prioritas`	Risiko yang mana?	ID, Risk Category, Priority
`tujuan`, `sebab`, `peristiwa`, `akibat`	Apa yang dapat terjadi?	Risk Description
`kemungkinan`, `dampak`, `skor`	Seberapa serius?	Likelihood, Impact, Exposure Rating
`kontrol_berjalan`, `bukti`, `keselamatan`, `kepatuhan`	Apa yang terbukti? Apa yang tidak boleh ditukar?	Tambahan bab ini
`jenis_penanganan`, `rencana`, `biaya_rupiah`, `tenggat`	Apa keputusannya?	Risk Response Type, Cost, Description
`pemilik_risiko`, `pemilik_tindakan`, `pemberi_persetujuan`, `risiko_sisa`, `status`	Siapa menanggung? Apa sisanya?	Risk Owner, Status

Tabel 5.9 menampilkan enam dari 12 baris register contoh di `sources/chapter05/contoh-risk-register-medikara.csv`. Keempat skenario wajib Medikara ada di sini: kebocoran lewat vendor (R-01), kontrol akses yang lemah (R-02), gangguan integrasi BPJS Kesehatan (R-03), dan laporan berbasis spreadsheet (R-04). Pemilik R-01 mengikuti register Bab 1.

5.6 Matriks Risiko dan Kelemahannya

Matriks kemungkinan dan dampak membantu diskusi awal. Tim menempatkan skenario pada kisi 5×5 dan mengalikan kedua nilai. Angkanya berskala urut. Perkalian skor tidak menghasilkan rupiah atau peluang. Risiko keselamatan juga tidak boleh tersamarkan oleh satu nilai gabungan. NIST menyebut batas kelompok skor dapat ditetapkan sebagai bagian dari tata kelola organisasi [126]. Gambar 5.5 menempatkan 12 skenario register contoh.

Analogi peringkat lomba menjelaskan batasnya. Peserta peringkat kedua tidak

Tabel 5.9: Bagian register kondisi saat ini (misalkan)

ID dan pemilik	Skenario	Skor	Kontrol dan pemeriksaan
R-01, pemilik Medikara+	Akses vendor berlebihan menyebabkan pengungkapan data pasien	$3 \times 4 = 12$	AC-01 belum lengkap; cocokkan 120 akun dengan penugasan
R-02, pemilik SIMRS	Hak akses lokal berbeda antar-rumah sakit, data berubah tanpa hak	$3 \times 4 = 12$	Persetujuan lokal; periksa persetujuan dan pencabutan
R-03, kepala pendaftaran	Integrasi BPJS Kesehatan terhenti, antrean tertunda	$3 \times 3 = 9$	Antrean manual belum dilatih; uji gangguan integrasi
R-04, kepala pelaporan	Versi spreadsheet berbeda, angka salah digabung	$4 \times 3 = 12$	Rekonsiliasi bulanan; tetapkan pengendalian versi
R-05, pemilik layanan	Cadangan belum diuji, pemulihan gagal	$2 \times 5 = 10$	Cadangan malam; uji pemulihan
R-11, direktur pelayanan	Riwayat alergi tidak terbaca lintas rumah sakit, kesalahan obat	$3 \times 4 = 12$, keselamatan	Pemeriksaan manual; tinjauan klinis



Gambar 5.5: Matriks 5×5 dengan 12 skenario register contoh (misalkan)

berlari dua kali lebih cepat daripada peserta peringkat keempat. Dampak 4 juga tidak otomatis dua kali dampak 2. Menurut Tabel 5.4, dampak 2 mulai dari Rp10 juta, sedangkan dampak 4 mulai dari Rp200 juta. Selisihnya 20 kali, bukan 2 kali.

Dua contoh berikut menggunakan asumsi terbuka:

1. Misalkan kesalahan obat (R-11) mendapat kemungkinan 3 dan dampak 4, sedangkan laporan terlambat (R-04) kemungkinan 4 dan dampak 3. Keduanya berskor 12, tetapi jalur eskalasinya harus berbeda. R-11 masuk ke pimpinan klinis pada hari yang sama. R-04 masuk rencana perbaikan pelaporan.
2. Tabel 5.10 menaksir peluang dan kerugian tiga skenario sesuai skala. R-01 dan R-04 sama-sama berskor 12, tetapi harapan kerugiannya berbeda sekitar 3,3 kali. R-05 berskor lebih rendah daripada keduanya, tetapi harapan kerugiannya paling besar.

Tabel 5.10: Skor urut dan harapan kerugian tiga skenario (misalkan)

Skenario	Peluang per tahun	Kerugian bersyarat	Skor	Harapan per tahun
R-01 akses vendor	0,2	Rp500 juta	$3 \times 4 = 12$	Rp100 juta
R-04 laporan spreadsheet	0,5	Rp60 juta	$4 \times 3 = 12$	Rp30 juta
R-05 pemulihan gagal	0,1	Rp2 miliar	$2 \times 5 = 10$	Rp200 juta

Kelemahan ini sudah dibahas dalam literatur. Cox menunjukkan empat keterbatasan matriks risiko. Resolusinya buruk, sehingga risiko yang jauh berbeda dapat memperoleh peringkat sama. Matriks dapat memberi peringkat lebih tinggi pada risiko yang secara kuantitatif lebih kecil. Kategorinya tidak mendukung alokasi sumber daya yang efektif. Masukan dan keluarannya juga memerlukan tafsir subjektif [24]. Thomas dan rekan meninjau 30 makalah Society of Petroleum Engineers serta beberapa standar pada sektor minyak dan gas. Mereka berargumen bahwa struktur matriks menghasilkan keputusan yang arbitrer, lalu menganjurkan metode analisis risiko dan keputusan [154]. Buku Hubbard dan Seiersen menjadi bacaan lanjutan untuk pengukuran risiko keamanan siber. Naskahnya berbayar, sehingga rinciannya tidak diuraikan di sini [55].

Pertanyaan kemudian muncul: apakah matriks harus ditinggalkan? Penafsiran bab ini: tidak harus. Matriks tetap berguna sebagai alat penyaring dan bahan diskusi lintas peran. Empat aturan membuatnya lebih aman dipakai:

1. Definisi skala ditulis sebelum penilaian, dengan periode yang sama untuk semua baris.
2. Keselamatan pasien dan kepatuhan dinilai pada kolom terpisah, bukan dilebur ke dalam skor.
3. Skor yang sama tidak otomatis berarti anggaran yang sama.
4. Skenario dengan skor tinggi atau kerugian besar dihitung lagi sebelum kon-

trol dibeli.

NIST SP 800-30 Revisi 1 membagi cara menilai menjadi kualitatif, kuantitatif, dan semi-kuantitatif [84]. Matriks 5×5 dengan skala angka termasuk semi-kuantitatif, karena angkanya hanya bermakna dalam konteks penilaian itu. Tabel 5.11 merangkum perbandingannya.

Tabel 5.11: Perbandingan pendekatan penilaian menurut NIST SP 800-30 Revisi 1

Pendekatan	Bentuk nilai	Kekuatan	Keterbatasan
Kualitatif	Kategori bukan angka, seperti rendah, sedang, tinggi	Mudah disampaikan kepada pengambil keputusan	Rentang nilai kecil; hasil antarahli berbeda bila definisi kabur
Semi-kuantitatif	Skala atau kelompok angka yang maknanya hanya berlaku dalam konteks itu	Mudah diterjemahkan menjadi kategori; dapat membandingkan secara relatif	Ketelitian turun bila penilaian subjektif tersembunyi
Kuantitatif	Angka yang makna dan proporsinya terjaga di dalam dan di luar konteks penilaian	Paling mendukung analisis biaya dan manfaat	Asumsi perlu dijelaskan; biaya keahlian dan alat dapat melebihi manfaat

5.7 Gambaran Pengukuran Kuantitatif

Dua pertanyaan: seberapa sering dan seberapa besar

Pengukuran kuantitatif memecah risiko menjadi dua pertanyaan: seberapa sering kerugian terjadi, dan seberapa besar kerugian bila terjadi. NIST menyebut kerugian per kejadian sebagai Single Loss Expectancy (SLE), dan total kerugian setahun sebagai Annualized Loss Expectancy (ALE) [127]. Open Factor Analysis of Information Risk (Open FAIR) dari The Open Group menyediakan taksonomi faktor risiko dan proses analisis, sehingga pernyataan risiko dapat dibandingkan dalam ukuran ekonomi [152]. Versi terbarunya, Risk Taxonomy (O-RT) 3.1 dan Risk Analysis (O-RA) 2.1, terbit Mei 2025 [94].

Analogi prakiraan cuaca membantu. Peluang hujan 30 persen bukan janji bahwa hari ini akan hujan. Angka itu tetap berguna untuk memutuskan apakah payung dibawa. O-RT yang dikutip NIST menyatakan analisis risiko bukan ramalan masa depan. Tidak ada yang tahu hasil lemparan dadu berikutnya, tetapi mengetahui peluangnya 1 banding 36 tetap berguna [127].

Dua contoh berikut menggunakan asumsi terbuka:

1. Misalkan peluang satu insiden vendor setahun 0,2 dan kerugian bersyarat rata-rata Rp500 juta. Kerugian harapan tahunan menjadi $0{,}2\times$ Rp500 juta $=$ Rp100 juta. Model ini hanya mencakup satu kejadian dan kerugian finansial.
2. NIST menjelaskan perkiraan tiga titik: optimistis, paling mungkin, dan pesimistis [127]. Misalkan analis keuangan memberi Rp100 juta, Rp400 juta, dan Rp1,5 miliar. Rata-rata sederhana ketiganya sekitar Rp667 juta. Rumus yang memberi bobot empat pada nilai paling mungkin menghasilkan $(100 + 4 \times 400 + 1.500)/6$, atau sekitar Rp533 juta. Pada peluang 0,2, harapannya masing-masing sekitar Rp133 juta dan Rp107 juta. Pilihan rumus saja menggeser hasil sekitar Rp27 juta.

Angka industri tidak dapat langsung dijadikan kerugian bersyarat. Rata-rata 4,99 juta dolar Amerika Serikat per pelanggaran pada laporan IBM 2026, yang dikutip Bab 1, berasal dari populasi dan cara hitung yang berbeda [56]. Angka itu membantu bertanya, bukan mengisi sel register.

Dari rata-rata ke kurva kerugian

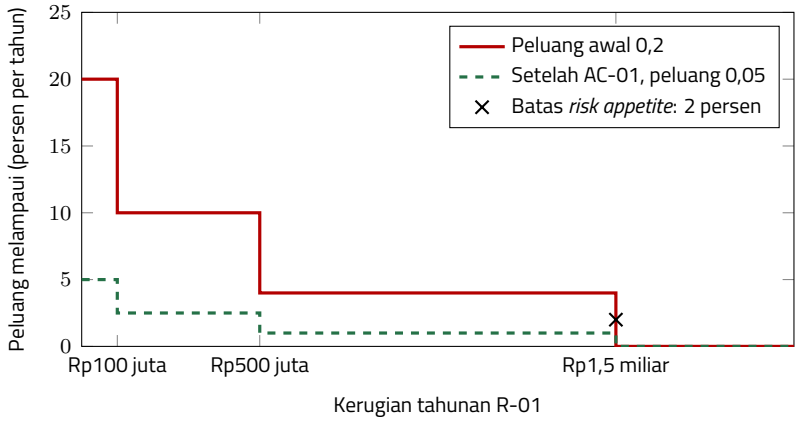
Dua hal pada hitungan ini sering tertukar: harapan kerugian dan kerugian yang akan terjadi. Pembagiannya begini. Harapan Rp100 juta per tahun tidak berarti Medikara rugi Rp100 juta setiap tahun. Pada sebagian besar tahun, kerugiannya nol. Pada tahun terjadinya insiden, kerugiannya jauh lebih besar. Karena itu, rata-rata perlu ditemani sebaran. Tabel 5.12 mengandaikan tiga tingkat kerugian. Rata-ratanya tetap Rp500 juta, yaitu jumlah Rp50, Rp150, dan Rp300 juta.

Tabel 5.12: Sebaran kerugian bersyarat R-01 per kejadian (misalkan)

Tingkat	Kerugian	Peluang bersyarat	Hasil kali	Rincian pengandaian
Terbatas	Rp100 juta	0,5	Rp50 juta	Penelusuran, pemberitahuan, perbaikan akses
Sedang	Rp500 juta	0,3	Rp150 juta	Ditambah pengaduan dan pendampingan hukum
Berat	Rp1,5 miliar	0,2	Rp300 juta	Ditambah sengketa, penghentian vendor, penurunan kunjungan

Sebaran itu menghasilkan *loss exceedance curve*, yaitu kurva peluang kerugian melampaui suatu angka. NIST memberi contoh membaca kurva ini: organisasi fiktif memiliki peluang sekitar 38 persen kehilangan 5 juta dolar atau lebih setiap tahun [126]. Pada R-01, peluang kerugian Rp500 juta atau lebih sama dengan 0,2

dikali 0,5, yaitu 10 persen. Peluang kerugian Rp1,5 miliar atau lebih sama dengan 0,2 dikali 0,2, yaitu 4 persen. Dengan peluang setelah AC-01 sebesar 0,05, ketiga ambang menghasilkan 5, 2,5, dan 1 persen. Gambar 5.6 menunjukkan kedua kurva, dan hitungannya ada di `sources/chapter05/kurva-kerugian.csv`.



Gambar 5.6: *Loss exceedance curve* R-01 sebelum dan sesudah AC-01 (misalkan)

Pembacaan kurva punya dua konsekuensi. Pertama, batas pada Tabel 5.6 dapat diperiksa langsung. Peluang 4 persen melewati batas 2 persen, sedangkan 1 persen berada di dalamnya. Kedua, pembicaraan dengan direksi berubah. Pertanyaannya bukan lagi "risiko ini merah atau kuning", melainkan "apakah peluang 1 persen untuk kerugian Rp1,5 miliar dapat diterima dengan biaya Rp60 juta per tahun".

Asumsi mana yang mengubah keputusan?

Misalkan kontrol Rp60 juta per tahun menurunkan peluang dari 0,2 menjadi 0,05. Kerugian harapan menjadi Rp25 juta. Pengurangan Rp75 juta memberi manfaat harapan bersih Rp15 juta. Jika peluang awal hanya 0,1, manfaat bersih menjadi minus Rp35 juta. Tabel 5.13 memperlihatkan ketiga asumsi peluang. Rumusnya harapan awal dikurangi harapan sisa, lalu dikurangi biaya kontrol.

Tabel 5.13: Sensitivitas manfaat bersih AC-01 terhadap peluang awal (misalkan)

Peluang awal	Harapan awal	Harapan sisa	Pengurangan	Biaya	Manfaat bersih
0,1	Rp50 juta	Rp25 juta	Rp25 juta	Rp60 juta	Minus Rp35 juta
0,2	Rp100 juta	Rp25 juta	Rp75 juta	Rp60 juta	Rp15 juta
0,4	Rp200 juta	Rp25 juta	Rp175 juta	Rp60 juta	Rp115 juta

Tabel itu memberi tiga pembacaan:

1. Titik impasnya berada pada peluang awal 0,17, karena $(0{,}17-0{,}05)\times$ Rp500 juta sama dengan Rp60 juta. Pada peluang 0,2, titik impasnya kerugian bersyarat Rp400 juta.
2. Efektivitas kontrol juga asumsi. Bila kontrol hanya menurunkan peluang menjadi 0,1, manfaat bersihnya minus Rp10 juta.
3. Ekor sebaran dapat menggeser hasil. Pengandaian Bab 3 memuat denda paling tinggi Rp10 miliar. Bila tingkat Rp10 miliar diberi peluang bersyarat 0,01 dan tingkat terbatas menjadi 0,49, rata-rata bersyaratnya naik menjadi Rp599 juta. Harapan tahunan menjadi Rp119,8 juta, dan manfaat bersih menjadi Rp29,85 juta. Peluang melewati kapasitas Rp5 miliar sebesar 0,2 persen per tahun sebelum kontrol dan 0,05 persen sesudahnya.

Kewajiban hukum dan keselamatan tetap berlaku meskipun manfaat finansial harapan negatif. Pasal 39 UU PDP, yang pada register Bab 3 tercatat sebagai K-01, mengatur pencegahan akses tidak sah [136]. Pada peluang 0,1, AC-01 tidak terbayar secara finansial, tetapi kontrol akses tetap harus ada. Hitungan yang demikian berguna untuk memilih cara yang paling hemat, bukan untuk meniadakan kewajiban. NIST SP 800-30 Revisi 1 juga mengingatkan bahwa ketelitian kuantifikasi menurun ketika penilaian subjektif tersembunyi atau ketidakpastiannya besar [84].

Pendalaman Teknis (opsional)

Buka `sources/chapter05/analisis-sensitivitas.csv`. Hitung ulang tiga asumsi peluang. NIST menjelaskan simulasi Monte Carlo sebagai pengambilan nilai acak berulang untuk melihat rentang hasil, dan menyebut bahwa simulasi tidak selalu diperlukan [127]. Simulasi sederhana dapat dibuat di spreadsheet. Kolom A dan B berisi `=RAND()`, lalu kolom C memakai rumus berikut untuk 100, 500, atau 1.500 juta rupiah.

```
=IF(A2<0.2,IF(B2<0.5,100,IF(B2<0.8,500,1500)),0)
```

Berkas `sources/chapter05/simulasi-kerugian.py` menjalankan model yang sama dengan Python. Dengan 200.000 tahun simulasi dan benih 2026, peluang awal menghasilkan rata-rata Rp100,8 juta serta peluang melampaui ambang 20,13, 10,06, dan 4,04 persen. Hitungan tangan memberi Rp100 juta serta 20, 10, dan 4 persen. Setelah AC-01, hasilnya rata-rata Rp24,3 juta serta 4,93, 2,42, dan 0,97 persen.

Skrip juga menggabungkan R-01 dengan R-03, yang diandaikan tidak terkait. R-03 berpeluang 0,3 dengan kerugian bersyarat rata-rata Rp95 juta, sehingga harapannya Rp28,5 juta. Harapan dapat dijumlahkan menjadi Rp128,5 juta. Peluang melampaui tidak dapat dijumlahkan: peluang kerugian gabungan Rp100 juta atau lebih sama dengan 32 persen, bukan 50

persen.
Untuk simulasi Monte Carlo, catat distribusi, alasan rentang, jumlah sampel, dan cara mengulang hasil. Kurva peluang kerugian melampaui batas bukan jaminan bahwa kerugian maksimum diketahui.

5.8 Penanganan, Risiko Sisa, dan Pemantauan

Empat pilihan penanganan

Organisasi dapat menghindari kegiatan, mengurangi kemungkinan atau dampak, membagi sebagian konsekuensi, atau menerima risiko melalui pihak berwenang. NIST IR 8286 Revisi 1 mencatat empat jenis tanggapan yang serupa: terima, alihkan, kurangi, dan hindari [126]. Kontrak dan asuransi tidak memindahkan seluruh akuntabilitas. NIST SP 800-39 menegaskan bahwa pengalihan risiko tidak menurunkan kemungkinan kejadian maupun akibatnya [83]. Sebagian akibat juga tidak dapat dialihkan, misalnya hilangnya kepercayaan pelanggan [126].

Analogi payung menunjukkan pilihan yang berbeda. Menunda perjalanan menghindari paparan. Payung mengurangi dampak hujan. Asuransi membantu biaya tertentu. Tetap berangkat berarti menerima sebagian paparan.

Dua contoh menunjukkan mengapa risiko perlu ditinjau kembali:

1. Misalkan AC-01 dijalankan bulanan dan akses vendor dibatasi. Penyalahgunaan akun sah tetap mungkin. Pemilik layanan memantau akses menyimpang dan menguji sampel hasil peninjauan, misalnya 30 dari 120 akun setiap triwulan. Penanganan juga dapat memunculkan risiko baru. NIST mencontohkan MFA yang dapat menurunkan produktivitas ketika pengguna kesulitan memakainya [126].
2. Misalkan Medikara mengganti vendor aplikasi. Ketergantungan belum hilang bila data tidak bisa diekspor atau vendor baru memakai subpenyedia yang sama. Dalam migrasi darurat 3 bulan, 84.000 janji temu ikut terdampak.

Tabel 5.14 merangkum opsi penanganan R-01 dan bukti keputusannya. Pada opsi bagi, misalkan premi asuransi Rp40 juta per tahun menanggung 60 persen kerugian. Harapan yang ditanggung sama dengan 60 persen dari Rp100 juta, yaitu Rp60 juta, sehingga manfaat bersihnya Rp20 juta.

Opsi bagi tampak lebih untung Rp5 juta daripada opsi kurangi. Inilah *tradeoff* yang perlu dibaca. Asuransi tidak mengubah peluang, sehingga skor tetap 12, dan peluang 4 persen untuk kejadian berat tetap melewati batas. K-01 juga belum terpenuhi. Hitungan rupiah saja akan memilih jawaban yang keliru. Medikara

Tabel 5.14: Opsi penanganan R-01 dan bukti keputusan (misalkan)

Opsi	Contoh keputusan	Hitungan	Bukti dan risiko sisa
Hindari	Tunda pengiriman data berlebih	Tidak dihitung; manfaat layanan ikut hilang	Alur dinonaktifkan; kebutuhan layanan tersisa
Kurangi	Akses terbatas dan AC-01, Rp60 juta per tahun	Peluang 0,2 menjadi 0,05; manfaat bersih Rp15 juta	Bukti pencabutan; akun sah tetap berisiko
Bagi	Klausul tanggung jawab dan asuransi, Rp40 juta per tahun	Peluang tetap 0,2; manfaat bersih Rp20 juta	Cakupan dan pengecualian kontrak; kepercayaan pasien tidak berpindah
Terima	Persetujuan direksi sesuai Bab 2	Harapan Rp100 juta; peluang 4 persen melewati batas 2 persen	Alasan, tenggat, dan kondisi tinjau

memilih opsi kurangi lebih dahulu. Asuransi dapat ditambahkan kemudian untuk kerugian yang tersisa.

Risiko sisa dinilai setelah kontrol terbukti

Risiko sisa dinilai setelah kontrol terbukti berjalan. COSO, seperti dikutip NIST, membedakan risiko inheren, sasaran risiko sisa, dan risiko sisa aktual. Risiko sisa aktual adalah risiko yang tersisa setelah manajemen bertindak, dan semestinya sama dengan atau di bawah sasaran [23, 126]. Tabel 5.15 memakai pengandaian kasar: penurunan peluang sebanding dengan cakupan kontrol. Dari peluang 0,2 menuju 0,05, penurunan penuhnya 0,15.

Tabel 5.15: Risiko sisa R-01 menurut cakupan bukti AC-01 (misalkan)

Keadaan	Peluang	Skor	Harapan	Manfaat bersih
Risiko saat ini, AC-01 sebagian	0,2	$3 \times 4 = 12$	Rp100 juta	Belum dihitung
Bukti pada 1 dari 5 rumah sakit	0,17	$3 \times 4 = 12$	Rp85 juta	Minus Rp45 juta
Daftar peninjau 108 dari 120 akun	0,065	$2 \times 4 = 8$	Rp32,5 juta	Rp7,5 juta
Sasaran, cakupan penuh	0,05	$2 \times 4 = 8$	Rp25 juta	Rp15 juta

Tabel ini memberi dua pelajaran:

1. Biaya Rp60 juta sudah keluar pada baris kedua, tetapi skornya tidak berubah. Pada cakupan 20 persen, peluang 0,17 masih masuk kemungkinan 3. Ke-

mungkinan baru turun bila cakupan di atas sekitar 33 persen. Register yang menulis "AC-01 sudah dibeli" pada keadaan ini menyesatkan pembacanya.

2. Baris ketiga dan keempat sama-sama berskor 8, tetapi harapan kerugiannya berbeda Rp7,5 juta. Risiko sisa aktual masih di atas sasaran. Selisih itu hanya tampak bila 12 akun yang luput dihitung.

Pantau dan tinjau lewat KRI

Pertanyaan kemudian muncul: bagaimana organisasi tahu batas mulai terlewati? Key Risk Indicator (KRI) memberi peringatan dini. NIST menyebut ukuran seperti KRI menunjukkan bagian yang melewati toleransi atau yang masih berada di dalamnya [126]. Misalkan akun vendor melewati masa berlaku naik dari 1 menjadi 5 dalam sebulan. Perubahan itu memicu pemeriksaan sebelum insiden terulang. Bab 13 membedakan KRI, ukuran kinerja, dan ukuran efektivitas kontrol. Tabel 5.16 memberi pengantar yang ambangnya sejalan dengan Bab 13.

Tabel 5.16: Pengantar indikator untuk R-01 (misalkan)

Indikator	Ambang	Tindakan
Akun vendor aktif tanpa pemilik	Nol hijau; lebih dari nol merah	Validasi 1 hari kerja, lalu bekukan
Akun melewati masa berlaku per bulan	Nol hijau; lebih dari nol merah	Pemilik Medikara+ memeriksa penyebab
Cakupan peninjauan AC-01	Minimal 95 persen hijau; 90 sampai kurang dari 95 kuning; kurang dari 90 merah	Periksa kelengkapan daftar akun

Dua indikator pertama termasuk KRI. Indikator ketiga mengukur pelaksanaan kontrol, sehingga Bab 13 menyebutnya Key Control Indicator (KCI). Daftar 108 dari 120 akun menghasilkan cakupan 90 persen dan berstatus kuning. Status itu tidak meniadakan merah pada dua indikator pertama, karena keduanya menjawab pertanyaan yang berbeda.

Kasus Medikara Health: Rp60 Juta untuk AC-01

Misalkan kepala risiko membawa hitungan AC-01 ke komite. Biaya Rp60 juta per tahun berada di bawah batas Rp100 juta pada Bab 2, sehingga kepala TI memutuskan dengan masukan pemilik layanan. Ringkasannya dilaporkan ke komite setiap triwulan. Pemilik R-01 tetap pemilik Medikara+. Kepala operasi TI menjalankan AC-01, staf TI mencabut akun paling lambat 1 hari kerja, dan audit internal memeriksa kontrolnya. Direksi menerima risiko sisa R-01, sesuai pembagian hak pada Bab 2.

Keputusan ini punya dua konsekuensi. Pertama, vendor yang mengerjakan sebagian peninjauan tidak memindahkan akuntabilitas. Bila 12 akun luput lagi, pemilik Medikara+ yang menjawab, bukan vendor. Kedua, anggaran Rp60 juta belum tentu cukup. Bila biaya naik di atas 10 persen, atau di atas Rp66 juta, keputusan kembali ke pemutus awal sesuai Bab 2. Ketika R-01 dibahas pada Bab 9, kerangka risiko pihak ketiga memakai pemilik dan bukti yang sama.

5.9 Aktivitas: Risk Appetite dan Risk Register Kondisi Saat Ini

Tujuan. Tim menghasilkan pernyataan *risk appetite* untuk tiga sampai empat kategori dan *risk register* kondisi saat ini berisi 10 sampai 15 skenario. Bahasanya dipilih supaya dapat langsung dipakai direksi. Tim memakai organisasi nyata dengan izin dan data yang dianonimkan, atau kasus Medikara Health.

Pembagian peran. Analis risiko memimpin perumusan skenario dan menjaga konsistensi skala. Pemilik konteks memeriksa tujuan, layanan, dan keterbacaan bagi direksi. Analis regulasi menandai kewajiban dari register C1. Analis teknologi menilai kemungkinan kejadian dan kontrol yang sudah ada. Anggota berlatar akuntansi atau keuangan menilai dampak finansial dan menguji asumsi kerugian.

Langkah kerja.

1. Baca profil C1, register kewajiban Bab 3, dan celah kapabilitas Bab 4. Pilih periode 12 bulan dan sumber bukti.
2. Isi `sources/chapter05/risk-appetite.md` untuk tiga atau empat kategori, misalnya keselamatan pasien, kerahasiaan data, kelangsungan layanan, dan kepatuhan. Cantumkan arah, ukuran, pemicu, pemilik, dan pemberi persetujuan.
3. Sepakati skala di `sources/chapter05/kriteria-risiko.md` sebelum menilai skenario.
4. Salin `sources/chapter05/risk-register.csv`. Susun 10 sampai 15 skenario dari jalur peristiwa dan jalur aset. Untuk Medikara, skenario wajib mencakup kebocoran data lewat vendor, kontrol akses yang lemah, gangguan integrasi BPJS Kesehatan, dan laporan manajemen yang bergantung pada spreadsheet.
5. Bedakan kontrol berjalan dari rencana perbaikan. Tulis “belum ada bukti” bila bukti memang belum tersedia.

6. Bandingkan dua skenario dengan `sources/chapter05/analisis-sensitivitas.csv`. Catat asumsi yang mengubah keputusan.
7. Pilih tiga prioritas beserta pemilik, jenis penanganan, dan tenggat. Uji satu penyimpangan terhadap pernyataan *risk appetite*.
8. Tulis memo satu halaman tentang keputusan yang berubah karena penilaian.

Luaran. Pernyataan *risk appetite*, *risk register*, dan memo satu halaman. Contoh pembanding tersedia di `sources/chapter05/contoh-risk-register-medikara.csv`. Pada contoh itu, prioritas Medikara adalah R-11 karena keselamatan pasien, R-01 karena insiden 2025 dan K-01, serta R-05 karena harapan kerugiannya paling besar walaupun skornya 10.

Kaitan dengan capstone. Luaran masuk tonggak C2 Kondisi Saat Ini, yang ditinjau menjelang Ujian Tengah Semester. Register dipakai lagi pada Bab 6 untuk menautkan celah kontrol, Bab 8 untuk target kapabilitas, Bab 9 untuk risiko pihak ketiga, Bab 10 untuk kelangsungan layanan, dan Bab 13 untuk ambang KRI.

Kriteria penilaian. Skenario dan bukti 30 persen; batas keputusan 30 persen; penanganan 25 persen; asumsi 15 persen.

Berkas pendukung. Daftar lengkap ada di `sources/chapter05/README.md`. Data organisasi nyata wajib seizin organisasi dan dianonimkan. Data pribadi pasien atau karyawan tidak boleh dipakai.

Pendalaman teknis (opsional). Kuantifikasi dua skenario dengan simulasi Monte Carlo sederhana di spreadsheet atau dengan `sources/chapter05/simulasi-kerugian.py`. Buku Hubbard dan Seiersen dapat dipakai sebagai bacaan lanjutan [55]. Gambar *loss exceedance curve*, lalu bandingkan dengan `sources/chapter05/kurva-kerugian.csv`.

5.10 Ringkasan

Risiko terkait dengan tujuan. Gangguan teknologi memiliki arti organisasi ketika akibatnya terhadap layanan, pasien, kewajiban, dan nilai dijelaskan. ERM menghubungkan penilaian itu dengan strategi. Risiko TI pada sistem naik menjadi bahan keputusan lewat register yang digabungkan pada tingkat layanan dan organisasi. Risiko juga berbeda dari temuan. Temuan memerlukan penutupan, sedangkan risiko memerlukan keputusan.

Konteks dan kriteria mendahului skor. Identifikasi, analisis, evaluasi, dan penanganan memerlukan bukti serta komunikasi. Pernyataan *risk appetite* berguna bila memicu tindakan dengan pemilik yang jelas. Pernyataan *risk tolerance* menerjemahkannya menjadi batas yang dapat diperiksa, seperti nol akun vendor aktif tanpa pemilik. Kapasitas risiko mengingatkan bahwa sebagian akibat tidak

mampu ditanggung, sedangkan keselamatan dan kewajiban hukum tidak ditukar dengan rupiah.

Register menyimpan skenario dan alasan keputusan. Kontrol yang direncanakan berbeda dari kontrol yang telah bekerja. Pemilik risiko tetap bertanggung jawab ketika pelaksana kontrol adalah vendor. Register Medikara yang semula 86 baris menjadi 12 skenario yang dapat dibaca komite dalam satu rapat.

Matriks membantu diskusi, sementara model kuantitatif membantu membandingkan biaya dengan asumsi kerugian. Keduanya memiliki batas. Skor 12 yang sama dapat menyembunyikan harapan kerugian Rp30 juta dan Rp100 juta, atau keselamatan pasien dan laporan terlambat. Hitungan rupiah juga memiliki batas: manfaat bersih AC-01 berubah dari Rp15 juta menjadi minus Rp35 juta hanya karena peluang awal berubah dari 0,2 menjadi 0,1. Karena itu, asumsi ditulis terbuka dan diuji.

Penanganan memilih antara menghindari, mengurangi, membagi, dan menerima. Risiko sisa baru dinilai setelah kontrol terbukti berjalan, lalu dipantau lewat indikator. Pesan utama bab ini sederhana: penilaian risiko harus mengubah pilihan dan ditinjau ketika bukti berubah.

5.11 Latihan

Latihan 1: Pernyataan Appetite

Ubah pernyataan “Medikara tidak menoleransi kebocoran data” menjadi pernyataan *risk appetite* yang realistis dan dapat diukur. Latihan ini membuktikan bahwa batas baru berguna bila terhubung dengan tindakan.

1. Pilih satu alur data vendor pada Medikara+ dan tetapkan cakupannya.
2. Tulis arah: apa yang diterima dan apa yang ditolak.
3. Tetapkan indikator, ambang, pemilik, dan pemberi persetujuan.
4. Uji satu penyimpangan dan catat keputusan yang dihasilkan.

Tabel 5.17 memuat contoh analisis, dan Tabel 5.18 merupakan lembar hasil.

Pertanyaan analisis.

1. Apakah ukuran pada tabel menangkap insiden atau penyebabnya?
2. Bila 1 dari 120 akun hanya sekitar 0,8 persen, mengapa statusnya tetap merah?
3. Bukti apa menunjukkan aturan dipakai ketika layanan sibuk?

Tabel 5.17: Contoh analisis Latihan 1 (skenario pembelajaran)

Pernyataan	Ukuran (misalkan)	Keputusan
Rendah untuk akses tidak sah; vendor boleh mengakses data bila ada dasar tugas tercatat	Nol akun vendor aktif tanpa pemilik; pencabutan paling lambat 1 hari kerja	1 dari 120 akun tanpa pemilik (sekitar 0,8 persen): bekukan akun, pemilik Medikara+ memutuskan dalam 1 hari kerja

Tabel 5.18: Lembar hasil Latihan 1

Pernyataan	Ukuran (misalkan)	Keputusan
…	…	…
…	…	…

Latihan 2: Skor Sama

Dua risiko sama-sama mendapat skor 12 pada matriks 5×5, tetapi hanya satu yang berdampak pada keselamatan pasien. Jelaskan kelemahan matriks risiko dari contoh ini. Latihan ini membuktikan bahwa skor yang sama dapat menuntut keputusan yang berbeda.

1. Definisikan skala kemungkinan dan dampak dengan Tabel 5.4.
2. Bandingkan dampak pada pasien dan pada laporan.
3. Taksir peluang dan kerugian bersyarat dengan asumsi terbuka.
4. Tetapkan jalur eskalasi untuk tiap skenario.

Tabel 5.19 memuat contoh analisis, dan Tabel 5.20 merupakan lembar hasil.

Tabel 5.19: Contoh analisis Latihan 2 (skenario pembelajaran)

Skenario (misalkan)	Skor	Akibat utama	Keputusan
R-11 kesalahan obat	$3 \times 4 = 12$	Cedera pasien; tidak cukup dinyatakan dalam rupiah	Tinjauan klinis pada hari yang sama
R-04 laporan terlambat	$4 \times 3 = 12$	Harapan Rp30 juta per tahun	Perbaikan pelaporan dalam 60 hari

Tabel 5.20: Lembar hasil Latihan 2

Skenario (misalkan)	Skor	Akibat utama	Keputusan
…	…	…	…
…	…	…	…

Pertanyaan analisis.

1. Apakah skor yang sama membenarkan anggaran yang sama?
2. Informasi apa yang membedakan risiko jarang tetapi berakibat berat dari risiko sering tetapi ringan?
3. Pada Tabel 5.10, urutan prioritas mana yang berubah bila memakai harapan kerugian, bukan skor?

Latihan 3: Ketergantungan Vendor

Tentukan opsi penanganan yang paling tepat untuk risiko ketergantungan pada vendor aplikasi Medikara+, beserta alasan dan risiko sisanya. Latihan ini membuktikan bahwa pilihan penanganan bergantung pada bagian risiko yang ingin diubah.

1. Petakan data dan keahlian yang hanya dimiliki vendor.
2. Tulis skenario R-10 dengan sebab, kejadian, dan akibat.
3. Bandingkan dua opsi dengan biaya, perubahan peluang, dan perubahan kerugian.
4. Pilih bukti keberhasilan, pemutus sesuai delegasi Bab 2, dan tanggal tinjau.

Tabel 5.21 memuat contoh analisis, dan Tabel 5.22 merupakan lembar hasil. Misalkan peluang terkunci 0,1 per tahun. Kerugian bersyarat Rp800 juta berasal dari migrasi darurat 3 bulan pada 84.000 janji temu, atau sekitar Rp9.500 per janji temu. Harapan awalnya Rp80 juta per tahun, dan skornya pada register $2 \times 4 = 8$. Biaya pada tabel adalah biaya sekali, bukan biaya per tahun. Bab 9 dan Bab 14 memakai perlakuan yang sama.

Tabel 5.21: Contoh analisis Latihan 3 (skenario pembelajaran)

Opsi (misalkan)	Biaya dan manfaat	Risiko sisa
Uji ekspor dan pendampingan	Rp60 juta sekali, keputusan kepala TI; kerugian bersyarat menjadi Rp300 juta, harapan Rp30 juta	Keahlian dan waktu migrasi
Ganti vendor segera	Rp300 juta sekali, keputusan komite; peluang menjadi 0,05, harapan Rp40 juta	Data tidak lengkap dan subpenyedia yang sama

Tabel 5.22: Lembar hasil Latihan 3

Opsi (misalkan)	Biaya dan manfaat	Risiko sisa
…	…	…
…	…	…

Pertanyaan analisis.

1. Apakah pilihan pada tabel mengurangi kemungkinan atau dampak?
2. Berapa manfaat bersih tiap opsi pada tahun pertama, dan mengapa angka itu belum cukup?
3. Kondisi apa yang membuat pilihan lain layak?

Bab 6

Keamanan Informasi: ISO/IEC 27001 dan NIST CSF 2.0

Tujuan Pembelajaran

- Menjelaskan struktur ISMS (*Information Security Management System*) menurut ISO/IEC 27001:2022 serta peran kontrol Annex A dan ISO/IEC 27002.
- Menyusun profil saat ini NIST CSF 2.0 untuk sebuah organisasi.
- Menganalisis celah kontrol keamanan dan mengaitkannya dengan skenario di *risk register*.

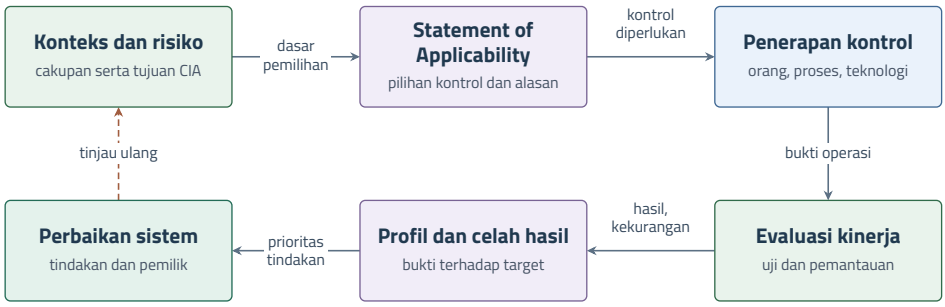
6.1 Pendahuluan

Kebijakan keamanan Medikara sudah ditandatangani, tetapi audit internal masih menemukan akun vendor tanpa batas waktu. Pengandaian pada bab sebelumnya memberi angkanya: 6 dari 30 akun sampel masih aktif setelah penugasan berakhir, dan peninjauan bulan berikutnya mencabut 24 dari 120 akun. Daftar yang diterima peninjau hanya memuat 108 akun, sehingga 12 akun luput. Dokumen kebijakan menunjukkan niat. Organisasi tetap membutuhkan bukti bahwa petugas menyetujui akses, membatasi kewenangan, dan mencabut akun ketika tugas selesai.

Medikara memiliki lima rumah sakit dengan versi Sistem Informasi Manajemen Rumah Sakit (SIMRS) yang berbeda. Satu rumah sakit dapat menerapkan kontrol dengan baik, sementara lokasi lain belum melakukannya. Penilaian karena itu harus menyebut cakupan sistem, lokasi, dan periode bukti. Hasil kerja bab ini adalah profil keamanan saat ini dan daftar celah kontrol untuk tonggak C2 capstone. Setiap celah ditautkan ke register risiko Bab 5 dan register kewajiban Bab 3.

Bab ini memakai ISO/IEC 27001:2022 sebagai persyaratan sistem manajemen, ISO/IEC 27002:2022 sebagai panduan kontrol, dan National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) 2.0 sebagai bahasa hasil keamanan. Penerapan pada organisasi kesehatan merujuk ISO 27799:2025. ISO adalah International Organization for Standardization, dan IEC adalah International Electrotechnical Commission. Naskah ISO berbayar, sehingga rincian klausulnya ditulis ringkas dan perlu dicocokkan ke naskah berlisensi sebelum dipakai untuk audit. Publikasi NIST terbuka dan dapat diperiksa mahasiswa. Seluruh angka tambahan tentang Medikara merupakan contoh pembelajaran [75, 76, 72, 104].

Gambar 6.1 merangkum hubungan komponen dan konsep utama bab ini.



NIST CSF: Govern, Identify, Protect, Detect, Respond, Recover bekerja bersamaan. Pemetaan tidak membuktikan kesetaraan kerangka.

Gambar 6.1: ISMS menghubungkan risiko, kontrol, dan hasil keamanan

6.2 Kerahasiaan, Integritas, dan Ketersediaan

Tiga tujuan pelindungan

Keamanan informasi melindungi kerahasiaan, integritas, dan ketersediaan. Ketiganya sering disingkat CIA, dari *confidentiality*, *integrity*, dan *availability*. Kerahasiaan membatasi siapa yang boleh membaca. Integritas menjaga ketepatan data serta perubahan yang sah. Ketersediaan memastikan informasi dapat dipakai ketika diperlukan. Ketiga tujuan itu dapat saling berbenturan, sehingga konfliknya diselesaikan sesuai konteks layanan.

Analogi lemari obat membantu menjelaskan pilihan. Lemari terkunci mengurangi akses yang tidak sah. Pencatatan keluar masuk menjaga ketepatan stok. Kunci cadangan dan petugas pengganti menjaga layanan ketika pemegang kunci utama tidak hadir.

Dua contoh memperlihatkan mengapa kontrol tidak cukup dinilai dari kerahasiaan:

1. Misalkan satu akun bersama dipakai 12 petugas sebuah bangsal, dan dalam sebulan tercatat 40 perubahan riwayat alergi. Sistem selalu tersedia dan tidak ada pihak luar yang membaca data. Namun, tidak satu pun dari 40 perubahan itu dapat ditelusuri kepada petugas tertentu. Kelemahannya ada pada integritas, dan kaitannya ada pada R-02 di register Bab 5.
2. Misalkan semua akses darurat diblokir ketika pengelola identitas terganggu selama 2 jam. Data terlindung dari akses biasa, tetapi dokter tidak dapat membaca riwayat pengobatan. Bab 5 menghitung gangguan 2 jam menyentuh sekitar 548 kunjungan. Akses darurat yang terbatas, beralasan, dan ditinjau menjadi pilihan yang perlu diuji.

Tabel 6.1 merangkum tujuan pelindungan, pertanyaan layanan, dan bukti contoh. Kode R-01, R-02, dan R-05 mengikuti register Bab 5.

Tabel 6.1: Tujuan pelindungan dan bukti layanan

Tujuan	Pertanyaan	Bukti contoh	Risiko
Kerahasiaan	Apakah vendor hanya melihat data penugasannya?	Persetujuan dan pembatasan akses	R-01
Integritas	Siapa mengubah alergi dan kapan?	Jejak perubahan yang terlindungi	R-02
Ketersediaan	Apakah data dapat dibaca saat gangguan?	Hasil uji pemulihan dan akses darurat	R-05

Ketersediaan di rumah sakit: membaca satu penelitian

Pertanyaan kemudian muncul: apakah gangguan ketersediaan di rumah sakit dapat diukur? Ghafur dan rekan menelaah serangan *ransomware* WannaCry 2017 pada National Health Service (NHS) Inggris dengan data statistik episode rumah sakit [45]. Penelitian itu memberi dua pembacaan:

1. Dampak terukur dalam layanan dan biaya. Pada 34 *trust* rumah sakit yang terinfeksi, sekitar 13.500 janji rawat jalan dibatalkan pada pekan serangan. Pendaftaran gawat darurat turun sekitar 4 persen, dan pendaftaran elektif turun sekitar 9 persen, dihitung per hari per rumah sakit. Kerugian kegiatan diperkirakan £5,9 juta: £4 juta dari rawat inap, £0,6 juta dari gawat darurat, dan £1,3 juta dari rawat jalan.
2. Satu ukuran tidak cukup. Penulis tidak menemukan kenaikan kematian, tetapi menyebut kematian sebagai ukuran kasar bagi bahaya terhadap pasien. Temuan itu tidak membuktikan serangan tanpa akibat klinis.

Angka NHS tidak boleh disalin menjadi perkiraan kerugian Medikara, karena ukuran layanan dan sistem pembiayaannya berbeda. Nilainya ada pada cara

mengukur. Ketersediaan dinyatakan sebagai janji temu, pendaftaran, dan biaya, bukan hanya jam server yang berhenti.

Dua hal juga sering tertukar: keamanan dan privasi. Pembagiannya begini. NIST menggambarkan keduanya sebagai dua lingkaran yang beririsan [104]. Kebocoran lewat akun vendor berada pada irisan itu. Pemakaian data yang sah secara teknis untuk tujuan lain dapat menjadi masalah privasi tanpa insiden keamanan apa pun. Bab 7 merinci sisi pelindungan data pribadi.

6.3 Sistem Manajemen ISO/IEC 27001

Klausul 4 sampai 10

Sistem manajemen keamanan informasi, atau ISMS, menghubungkan kebijakan, risiko, pelaksanaan, evaluasi, dan perbaikan. ISO/IEC 27001 menetapkan persyaratan sistem manajemen itu. Klausul 4 sampai 10 mencakup konteks, kepemimpinan, perencanaan, dukungan, operasi, evaluasi kinerja, dan perbaikan [75]. Daftar alat dan kumpulan dokumen belum membentuk ISMS. Hubungan antarbagian itulah yang diperiksa.

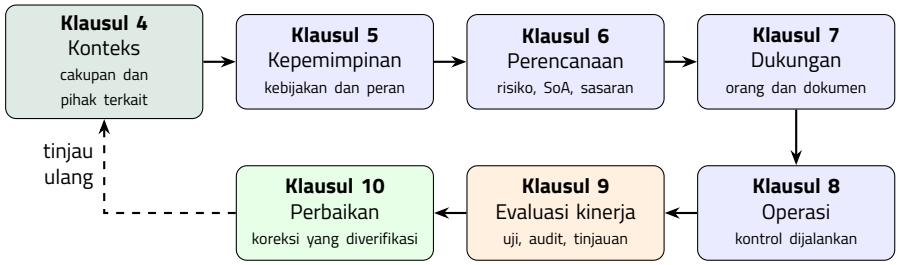
Analogi pengelolaan kebersihan dapur menunjukkan bedanya dengan daftar alat. Memiliki cairan pembersih belum memastikan dapur bersih. Jadwal, pelaksana, pemeriksaan, penanganan kegagalan, dan peninjauan pengelola membentuk sistem kerja.

Dua contoh membedakan kegiatan dan sistem:

1. Misalkan tim membeli alat pemantauan untuk 5 rumah sakit. Tiap rumah sakit menghasilkan 300 alarm per bulan, sehingga totalnya 1.500 alarm. Bila satu alarm ditelaah 10 menit, pekerjaannya 250 jam per bulan, atau lebih dari satu orang penuh waktu dengan 160 jam kerja per bulan. Tanpa petugas, kriteria eskalasi, dan jadwal pemeriksaan, alarm hanya menjadi pesan yang menumpuk. Kekurangannya ada pada klausul dukungan dan operasi, bukan pada alat.
2. Misalkan AC-01 dijalankan setiap bulan. Bulan pertama 24 dari 120 akun dicabut. Pemilik layanan membahas temuan itu dan menemukan sebabnya: tanggal berakhir penugasan tidak masuk daftar. Prosedur keluar vendor diubah, lalu jumlah pencabutan turun menjadi 9, 5, dan 2 akun pada tiga peninjauan berikutnya, atau turun sekitar 92 persen dari angka awal. Hubungan pelaksanaan, evaluasi, dan perbaikan menjadi terlihat.

Gambar 6.2 memperlihatkan urutan klausul tersebut. Gambar ini merupakan ringkasan pembelajaran, bukan reproduksi isi standar. Singkatan SoA pada gambar berarti *Statement of Applicability*, yang dibahas pada seksi berikutnya. Tabel 6.2 me-

nerapkan tiap klausul pada AC-01. Kode AC-01 mengikuti Bab 1, yaitu peninjauan akses berkala.



Gambar 6.2: Klausul 4 sampai 10 sebagai satu sistem kerja

Tabel 6.2: Klausul ISO/IEC 27001 pada kontrol AC-01 (misalkan)

Klausul	Pertanyaan	Bukti pada AC-01
4 Konteks	Sistem, lokasi, dan pihak mana yang masuk cakupan?	5 rumah sakit, Medikara+, 120 akun vendor; kewajiban K-01
5 Kepemimpinan	Siapa menetapkan kebijakan dan peran?	Kebijakan akses vendor; direksi menerima risiko sisa R-01
6 Perencanaan	Risiko dan kontrol apa yang dipilih?	R-01 dengan skor $3 \times 4 = 12$; baris SoA; sasaran nol akun tanpa pemilik
7 Dukungan	Apakah orang dan dokumen cukup?	Peninjau yang ditunjuk; prosedur tertulis
8 Operasi	Apakah kontrol dijalankan?	Daftar akun, penandaan pemilik layanan, tiket pencabutan
9 Evaluasi kinerja	Apakah kontrol bekerja?	108 dari 120 akun tercakup; audit 6 dari 30 akun; tinjauan pimpinan
10 Perbaikan	Apa yang berubah karena temuan?	Prosedur keluar vendor diubah; hasil diuji ulang

Keputusan membaca ISMS sebagai sistem punya dua konsekuensi. Pertama, temuan 12 akun yang luput tidak ditutup hanya dengan mencabut 12 akun. Tim juga memeriksa mengapa daftar peninjau hanya memuat 108 akun. Kedua, kebijakan yang bagus tidak menaikkan penilaian bila catatan operasinya tidak ada.

Diagram konsep pada awal bab meringkas alur yang sama. Konteks dan risiko memberi dasar pemilihan kontrol. SoA mencatat kontrol yang diperlukan. Penerapan kontrol menghasilkan bukti operasi. Evaluasi kinerja menguji bukti itu, lalu hasil dan kekurangannya masuk ke profil dan celah hasil. Prioritas tindakan menggerakkan perbaikan sistem, dan hasilnya ditinjau ulang.

Amandemen 1:2024 hanya mengubah dua subklausul. Rancangan adopsi Bad-

an Standardisasi Nasional (BSN) memuat teksnya. Subklausul 4.1 menambahkan kewajiban menentukan apakah perubahan iklim adalah isu yang relevan. Subklausul 4.2 menambahkan catatan bahwa pihak berkepentingan dapat mempunyai persyaratan terkait perubahan iklim [11]. Misalkan banjir musiman mengancam ruang server satu rumah sakit. Tim mencatat hasil penentuan itu pada konteks ISMS, lalu menilai akibatnya bersama R-05.

Sertifikat dan ruang lingkup

Sertifikasi menilai sistem dalam ruang lingkup tertentu. Pertanyaan kemudian muncul: apa yang dibuktikan sertifikat bagi Medikara? Bab 3 sudah menunjukkan sertifikat tidak menjawab kewajiban hukum seperti dasar pemrosesan data. Dua contoh berikut menunjukkan batas lainnya:

1. Misalkan Medikara memegang sertifikat untuk pusat data. Ke-36 fasilitas layanan, yaitu 5 rumah sakit, 18 klinik, 1 laboratorium, dan 12 apotek, berada di luar ruang lingkup itu. Aplikasi vendor juga tidak otomatis tercakup.
2. Misalkan vendor Medikara+ memiliki sertifikat yang masih berlaku 14 bulan, tetapi ruang lingkupnya hanya pengembangan aplikasi. Akun dukungan vendor yang masuk ke data pasien tidak termasuk. Masa berlaku yang panjang tidak menutup celah cakupan tersebut.

Tanggal, penerbit, ruang lingkup, dan temuan karena itu tetap harus diperiksa sebelum sertifikat dipakai sebagai bukti. Bab 9 memakai pemeriksaan yang sama untuk penyedia cloud.

Literatur ilmiah membantu membaca klaim manfaat sertifikasi. Tinjauan literatur Culot dan rekan mengelompokkan penelitian ISO/IEC 27001 ke lima fokus: hubungan dengan standar lain, motivasi penerapan, masalah saat penerapan, hasil yang mungkin, dan faktor konteks [26]. Pada pembacaan bab ini, susunan itu berguna sebagai daftar pertanyaan. Tim yang mendengar klaim “sudah bersertifikat” dapat bertanya: mengapa sertifikat diambil, masalah apa yang muncul, dan hasil apa yang benar-benar teramati.

6.4 Annex A, SoA, dan Panduan Kontrol

Annex A sebagai rujukan pemeriksa

Annex A merupakan rujukan kontrol. Isinya 93 kontrol dalam empat tema: organisasi, manusia, fisik, dan teknologi [75, 82]. Berkas Informative References dari NIST mencantumkan nomor yang sama: 5.1 sampai 5.37, 6.1 sampai 6.8, 7.1 sampai 7.14, dan 8.1 sampai 8.34 [105]. *Statement of Applicability* (SoA) menjelaskan kontrol yang diperlukan, alasan pemilihan, status penerapan, dan

alasan pengecualian kontrol Annex A yang tidak dipilih. Annex A dipakai untuk memeriksa bahwa tidak ada kontrol perlu yang terlewat, bukan sebagai daftar yang otomatis wajib seluruhnya.

Analogi daftar perlengkapan perjalanan menjelaskan pemilihan. Perjalanan pegunungan dan perjalanan kota membutuhkan perlengkapan berbeda. Barang yang tidak dibawa harus dinilai terhadap tujuan dan kondisi, bukan dihapus agar daftar terlihat lengkap.

Tabel 6.3 merangkum keempat tema. Uraian topik ditulis ringkas oleh bab ini dan bukan terjemahan resmi. Nomor kontrol mengikuti berkas NIST tersebut.

Tabel 6.3: Empat tema Annex A dan contoh topik pada Medikara

Nomor	Tema	Jumlah	Contoh topik pada Medikara
5	Organisasi	37	5.18 hak akses; 5.19 dan 5.20 hubungan serta perjanjian pemasok; 5.26 tanggapan insiden
6	Manusia	8	Pelatihan petugas dan tanggung jawab setelah penugasan berakhir
7	Fisik	14	Ruang server dan perangkat di 36 fasilitas
8	Teknologi	34	8.5 autentikasi; 8.13 cadangan; 8.15 pencatatan; 8.16 pemantauan
Total		93	

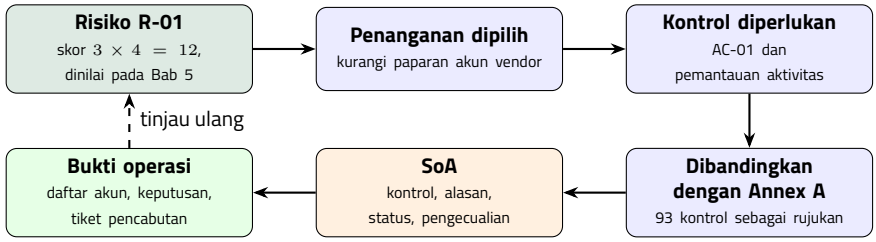
Dua hal pada keluarga standar ini sering tertukar: persyaratan dan panduan. Pembagiannya begini. ISO/IEC 27001 berjudul *Requirements* dan menjadi dasar penilaian sistem manajemen. ISO/IEC 27002 memberi panduan penerapan kontrol, sehingga tidak menjadi target sertifikasi sistem manajemen tersendiri [75, 76]. ISO 27799:2025 memberi kontrol keamanan informasi beserta panduan penerapan untuk organisasi kesehatan, dengan dasar ISO/IEC 27002 [72]. Tabel 6.4 membandingkan ketiganya.

Tabel 6.4: Tiga standar dan pemakaiannya pada Medikara

Standar	Sifat	Pemakaian pada Medikara
ISO/IEC 27001:2022	Persyaratan sistem manajemen	Menilai ruang lingkup ISMS, SoA, evaluasi, dan perbaikan
ISO/IEC 27002:2022	Panduan penerapan kontrol	Menjelaskan cara merancang peninjauan hak akses pada AC-01
ISO 27799:2025	Panduan kontrol untuk organisasi kesehatan	Membaca kontrol untuk rekam medis elektronik, perangkat digital fasilitas, dan telekonsultasi Medikara+

Dari risiko ke SoA

Pertanyaan berikutnya: dari mana kontrol dalam SoA berasal? Dari penanganan risiko. Tim memilih penanganan, menetapkan kontrol yang diperlukan, lalu membandingkannya dengan Annex A. Gambar 6.3 memperlihatkan rantai itu untuk R-01. Hasilnya berupa bukti operasi yang dapat diuji.



Gambar 6.3: Rantai dari risiko ke SoA dan bukti operasi

Dua contoh menguji alasan pemilihan:

1. Misalkan akses vendor diperlukan untuk perbaikan. AC-01 dipilih karena R-01 dan K-01. Bukti mencakup daftar hak akses, peninjau yang sah, hasil keputusan, dan pencabutan. Status pada SoA ditulis "diterapkan sebagian", karena 12 dari 120 akun luput dan bukti peninjauan baru ada pada 1 dari 5 rumah sakit.
2. Misalkan Medikara tidak mengembangkan satu aplikasi sendiri, lalu mengusulkan pengecualian kontrol pengembangan. Sekitar 28.000 janji temu per bulan berjalan pada Medikara+ buatan vendor, dan R-07 menyebut perubahan yang tidak diuji. Pengadaan dan perubahan oleh vendor tetap menimbulkan kebutuhan kontrol, misalnya 8.30 tentang pengembangan alih daya dan 8.32 tentang manajemen perubahan. Usulan itu belum dapat diterima.

Tabel 6.5 merangkum penalaran SoA tersebut sebagai ringkasan pembelajaran. Berkas `sources/chapter06/catatan-soa.md` menyediakan lembar isiannya.

Keputusan mengecualikan kontrol punya dua konsekuensi. Pertama, alasannya harus dapat diuji peninjau, sehingga kalimat "tidak relevan" saja tidak cukup. Kedua, pengecualian perlu ditinjau ulang ketika cakupan berubah. Skenario Bab 4 menambah dua fasilitas, dari 36 menjadi 38, sehingga baris yang menyangkut lokasi harus dibaca ulang.

Kode juga sering tertukar. AC-01 pada bab ini adalah kode lokal Medikara. Angka 5.18 adalah nomor kontrol Annex A. Berkas NIST juga memuat label AC-01 milik NIST Special Publication (SP) 800-53 pada subkategori PR.AA-05 [105], dan label itu bukan kontrol Medikara. Register sebaiknya selalu menulis sumber

Tabel 6.5: Contoh penalaran SoA (ringkasan pembelajaran)

Kontrol	Alasan	Status dan bukti
Peninjauan hak akses, AC-01 (Annex A 5.18)	Mengurangi akses vendor berlebih pada R-01; mendukung K-01	Diterapkan sebagian; bukti baru 1 dari 5 rumah sakit
Pencatatan aktivitas (Annex A 8.15)	Menelusuri perubahan data pada R-01 dan R-02	Catatan ada; perlindungan dan tinjauan belum terbukti
Cadangan dan pemulihan (Annex A 8.13)	Menjaga data saat gangguan pada R-05; mendukung K-02	Cadangan tersedia; hasil uji pemulihan diminta
Pengembangan alih daya (Annex A 8.30)	Vendor mengubah Medikara+; R-07	Usulan pengecualian ditolak; kontrol dinilai pada kontrak vendor

kode, supaya pembaca tidak menganggap ketiganya satu kontrol yang sama.

Konteks kesehatan

Cakupan ISO 27799:2025 meliputi perangkat lunak kesehatan seperti sistem rekam medis elektronik, dan perangkat medis yang mengandung perangkat lunak. Standar itu berlaku pada organisasi kesehatan dari segala jenis dan ukuran, termasuk layanan jarak jauh [72]. Medikara dengan 36 fasilitas dan telekonsultasi berada dalam gambaran itu. Penilaian karena itu melibatkan pimpinan klinis. Pembatasan akses tidak boleh merusak kebutuhan pelayanan darurat. NIST juga mencontohkan akses darurat pada PR.AA-03: petugas yang berwenang tetap dapat mengakses akun yang penting bagi keselamatan [105]. Persetujuan pengecualian dan peninjauan setelah kejadian tetap diperlukan.

Bab 5 sudah membatasi pengecualian darurat pada akun vendor paling lama 24 jam. Misalkan dalam sebulan terjadi 6 pengecualian seperti itu pada 120 akun. Keenamnya ditinjau pemilik layanan pada hari kerja berikutnya. Bila hanya 4 yang punya catatan alasan, kontrol bukan berjalan 67 persen, melainkan ada 2 pengecualian yang tidak dapat dipertanggungjawabkan.

Kasus Medikara Health: Menyusun SoA untuk Cakupan Terbatas

Misalkan tim menilai 93 kontrol untuk cakupan 5 rumah sakit dan Medikara+. Hasil awalnya 84 kontrol diperlukan dan 9 kontrol diusulkan dikecualikan, atau sekitar 9,7 persen. Peninjau menguji kesembilan usulan dengan register Bab 5. Tiga usulan ditolak karena R-07 menunjukkan vendor tetap mengubah Medikara+. Hasil akhirnya 87 kontrol diperlukan dan 6 dikecualikan.

Keputusan ini punya dua konsekuensi. Pertama, pekerjaan bertambah 3 baris yang harus punya pemilik dan bukti. Kedua, keenam pengecualian tersisa ditulis dengan alasan, pihak yang menyetujui, dan tanggal tinjau ulang. Jumlah kontrol yang diperlukan bukan ukuran keamanan. Kualitas alasannya yang dinilai.

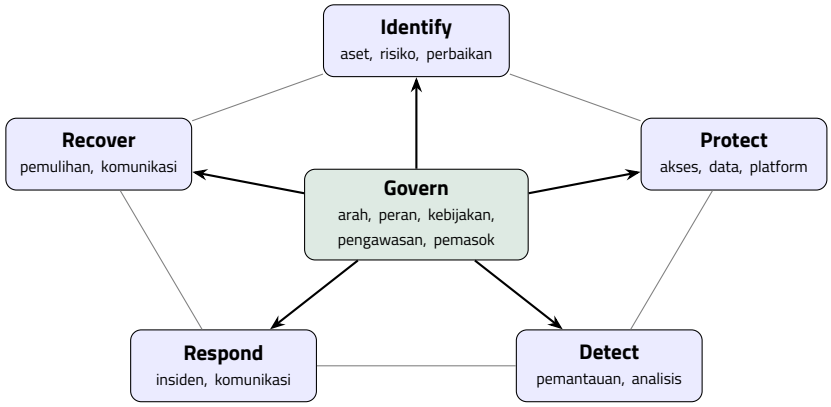
6.5 Enam Fungsi NIST CSF 2.0

Struktur inti

NIST CSF 2.0 menyusun hasil keamanan dalam hierarki fungsi, kategori, dan subkategori. Hitungan bab ini pada lampiran naskahnya menghasilkan 6 fungsi, 22 kategori, dan 106 subkategori. Enam fungsinya adalah Govern, Identify, Protect, Detect, Respond, dan Recover. Hasil itu bukan daftar periksa tindakan. Urutannya juga tidak menyatakan urutan kerja atau tingkat kepentingan. Fungsi perlu ditangani bersamaan. Kerangka ini menjelaskan hasil yang diinginkan tanpa menetapkan cara mencapainya [104].

Analogi pengamanan gedung menunjukkan hubungan antarfungsi. Pengelola menetapkan aturan, mendata ruangan, memasang pengamanan, mendeteksi gangguan, menanganinya, lalu memulihkan penggunaan. Pintu yang kuat tidak menggantikan petugas dan rencana penanganan.

Gambar 6.4 menempatkan Govern di tengah, karena fungsi itu menjadi dasar cara lima fungsi lain dijalankan. Gambar ini digambar ulang untuk bab ini. Tabel 6.6 merangkum hasil tiap fungsi dan pertanyaan bagi Medikara.



Gambar 6.4: Govern mengarahkan lima fungsi lain yang saling berhubungan

Dua contoh menunjukkan fungsi yang saling melengkapi:

Tabel 6.6: Hasil dan pertanyaan penilaian pada enam fungsi

Fungsi	Hasil (ringkasan)	Pertanyaan Medikara	Bukti contoh
Govern	Strategi, harapan, dan kebijakan risiko ditetapkan serta dipantau	Siapa menerima risiko akses vendor?	Keputusan dan wewenang
Identify	Risiko keamanan saat ini dipahami	Sistem dan data apa yang terlibat?	Inventaris serta alur data
Protect	Pengaman dipakai untuk mengelola risiko	Bagaimana akses dibatasi?	Daftar hak dan bukti AC-01
Detect	Kemungkinan serangan ditemukan dan dianalisis	Bagaimana akses menyimpang diketahui?	Catatan alarm dan tinjauan
Respond	Tindakan atas insiden yang terdeteksi diambil	Siapa membekukan akses?	Prosedur dan hasil latihan
Recover	Aset dan operasi yang terdampak dipulihkan	Bagaimana data dipulihkan?	Hasil uji pemulihan

1. Misalkan seluruh 108 akun pada daftar peninjau memakai Multi-Factor Authentication (MFA). Cakupannya tampak 100 persen. Terhadap populasi 120 akun, cakupannya hanya 90 persen, karena 12 akun tidak tercatat. Protect yang kuat tidak menolong bila Identify belum lengkap.
2. Misalkan alarm akses diterima dalam 5 menit. Tanpa petugas yang berwenang membekukan akun, kecepatan deteksi belum menghasilkan penanganan. Data latihan Bab 1 memberi pembandingnya: akun dukungan memanggil data selama 8 malam dan baru diketahui pada hari ke-11.

Inventaris pada ID.AM-02 juga mencakup layanan *Application Programming Interface* (API) dan layanan cloud [105]. Bab ini cukup memastikan keduanya masuk cakupan profil. Cara mengamankan API dibahas pada mata kuliah IT40613, dan keamanan cloud pada IT40713.

Mengapa Govern ditambahkan

Versi 1.1 memiliki lima fungsi: Identify, Protect, Detect, Respond, dan Recover [102]. Versi 2.0 menambahkan Govern dan menonjolkan tata kelola serta rantai pasok [104]. Masalah organisasi apa yang ingin diselesaikan? NIST menulis bahwa kegiatan tata kelola penting untuk memasukkan keamanan ke strategi risiko enterprise, dan bahwa pimpinan mengomunikasikan harapan tentang *risk appetite*, akuntabilitas, dan sumber daya. Tanpa fungsi ini, penilaian keamanan mudah berhenti sebagai urusan tim teknis. Kalimat terakhir merupakan penafsiran

bab ini.

Tabel 6.7 menautkan kategori Govern dengan hasil kerja bab sebelumnya. Enam kategori pada Govern adalah konteks organisasi (GV.OC), strategi pengelolaan risiko (GV.RM), peran dan wewenang (GV.RR), kebijakan (GV.PO), pengawasan (GV.OV), dan pengelolaan risiko rantai pasok (GV.SC).

Tabel 6.7: Subkategori Govern dan hasil kerja bab sebelumnya

Subkategori	Hasil (ringkasan)	Hasil kerja Medikara
GV.OC-03	Persyaratan hukum, regulasi, dan kontrak dipahami serta dikelola	Register K-01 sampai K-16 pada Bab 3
GV.RM-02	Pernyataan *risk appetite* dan *risk tolerance* ditetapkan	Batas nol akun vendor aktif tanpa pemilik pada Bab 5
GV.RR-02	Peran, tanggung jawab, dan wewenang ditetapkan serta ditegakkan	Hak keputusan akses vendor pada Bab 2
GV.SC-07	Risiko pemasok dipahami dan dipantau sepanjang hubungan	Vendor Medikara+, R-01, dan insiden 2025

ISO/IEC 27001 dan NIST CSF

Dua kerangka ini juga sering tertukar. Pembagiannya begini. ISO/IEC 27001 menetapkan persyaratan yang dapat dinilai dalam ruang lingkup tertentu. NIST CSF menyediakan bahasa hasil yang dapat dipakai secara sukarela atau lewat kebijakan pemerintah, dan naskah 2.0 tidak memuat skema sertifikasi [104]. Tabel 6.8 menunjukkan bahwa keduanya melengkapi, bukan menggantikan.

Tabel 6.8: Perbedaan ISO/IEC 27001 dan NIST CSF 2.0

Pembeda	ISO/IEC 27001:2022	NIST CSF 2.0
Sifat	Persyaratan sistem manajemen	Taksonomi hasil, tanpa menetapkan cara
Unsur	Klausul 4 sampai 10, 93 kontrol Annex A, SoA	6 fungsi, 22 kategori, 106 subkategori, profil, *tier*
Pemeriksaan	Dapat disertifikasi dalam ruang lingkup	Tidak ada skema sertifikasi pada naskah 2.0
Akses naskah	Berbayar	Terbuka
Luaran Medikara	Ruang lingkup ISMS, SoA, hasil evaluasi	Profil saat ini, celah, profil target Bab 8

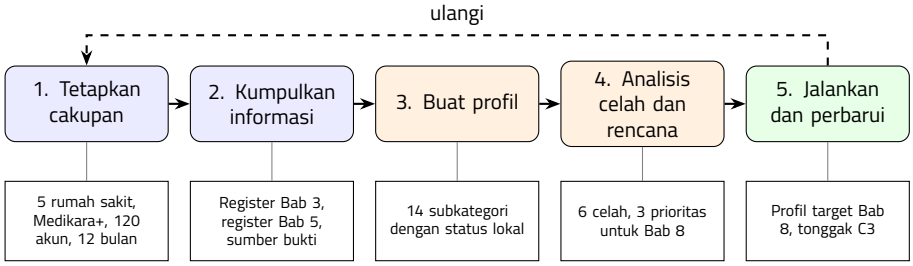
6.6 Profil Saat Ini dan Tier

Profil organisasi

Profil organisasi menggambarkan keadaan keamanan saat ini atau target dalam bahasa hasil pada CSF. Profil saat ini (*Current Profile*) menyebut hasil yang sedang dicapai dan seberapa jauh hasil itu tercapai. Profil target (*Target Profile*) menyebut hasil yang dipilih dan diprioritaskan [104]. Satu organisasi dapat memiliki beberapa profil, masing-masing dengan cakupan berbeda. Setiap kesimpulan memerlukan bukti dan catatan batasnya.

Analogi potret cabang toko menunjukkan pentingnya cakupan. Foto satu rak yang rapi tidak menunjukkan seluruh toko. Potret harus menjelaskan rak, tanggal, dan bagian yang tidak terlihat.

NIST menyarankan lima langkah: menetapkan cakupan, mengumpulkan informasi, membuat profil, menganalisis celah serta menyusun rencana tindakan, lalu menjalankan rencana dan memperbarui profil [104, 103]. Gambar 6.5 menerapkannya pada Medikara. Templat NIST memuat kolom praktik, status, peringkat, prioritas, dan sasaran, dan kolom itu boleh disesuaikan [103]. Bab ini mengerjakan langkah 1 sampai 4 untuk profil saat ini. Profil target dirancang pada Bab 8.



Gambar 6.5: Lima langkah membuat dan memakai profil, dengan keluaran Medikara (misalkan)

Dua contoh menguji kualitas klaim:

1. Audit Bab 4 memeriksa 30 akun, dan 24 di antaranya sesuai, atau 80 persen. Tim menyimpulkan ada 6 pengecualian dalam sampel. Tim tidak menyatakan seluruh organisasi 80 persen aman. Angka 24 dari 120 akun berasal dari peninjauan penuh, bukan dari proyeksi sampel. Daftarnya pun hanya memuat 108 akun dan buktinya hanya ada pada 1 dari 5 rumah sakit.
2. Misalkan cadangan berhasil dibuat setiap malam selama 30 hari pada 5 rumah sakit, sehingga ada 150 pekerjaan cadangan yang berhasil. Tim belum menyatakan pemulihan tercapai sebelum data dipulihkan dan pemilik layanan menguji kelengkapannya. PR.DS-11 meminta cadangan juga diuji, dan RC.RP-03 meminta integritas cadangan diverifikasi sebelum dipakai

[104].

Tabel 6.9 merangkum status lokal yang dipakai tim. Daftar ini merupakan alat kerja bab ini, bukan skala resmi NIST. NIST memberi contoh skala seperti tinggi, sedang, dan rendah, atau 1 sampai 5 [103]. Status lokal dipilih karena memisahkan "belum terbukti" dari "gagal".

Tabel 6.9: Status lokal yang dipakai tim

Status lokal	Arti	Tindakan
Terbukti	Bukti sesuai cakupan dan periode	Simpan sumber dan peninjau
Sebagian	Sebagian hasil atau lokasi belum tercakup	Jelaskan celah spesifik
Belum ada bukti	Klaim belum dapat diuji	Minta bukti; jangan beri status lulus
Tidak relevan	Ada alasan terhadap cakupan	Catat persetujuan dan tinjau ulang

Contoh profil saat ini

Misalkan tim Medikara memilih cakupan akses vendor dan SIMRS pada 5 rumah sakit serta Medikara+, untuk periode 12 bulan. Tim memilih 14 dari 106 subkategori, atau sekitar 13,2 persen. Pemilihan mengikuti konteks risiko, bukan keinginan memperindah hasil. Tabel 6.10 dan Tabel 6.11 menyajikan hasilnya. Teks hasil diringkas dari NIST [104].

Tabel 6.10: Profil saat ini: Govern dan Identify (misalkan)

Subkategori	Status	Bukti dan batasnya	Tautan
GV.OC-03	Sebagian	Register 16 baris ada; 7 baris belum diverifikasi	K-01 sampai K-16
GV.RM-02	Sebagian	Batas nol akun tanpa pemilik sudah dirumuskan; pemantauannya belum teruji	R-01
GV.RR-02	Sebagian	Hak keputusan tertulis; 12 akun belum punya pemilik	R-01
GV.SC-07	Sebagian	Vendor utama dikenal; tinjauan berkala belum ada; laporan insiden telat	R-01, R-08, K-05
ID.AM-02	Sebagian	Daftar lokal 5 rumah sakit berbeda dan belum direkonsiliasi	R-02

Rekap status itu adalah 1 terbukti, 10 sebagian, 2 belum ada bukti, dan 1 tidak relevan. Rekap ini punya dua konsekuensi. Pertama, angka itu tidak boleh dirata-rata menjadi satu nilai. Satu baris "terbukti" dari 14 baris tidak berarti keamanan

Tabel 6.11: Profil saat ini: Protect sampai Recover (misalkan)

Subkategori	Status	Bukti dan batasnya	Tautan
PR.AA-01	Sebagian	Akun per orang belum berlaku; akun bersama ditemukan	R-02, K-01
PR.AA-03	Sebagian	MFA tercatat pada 108 akun; 12 akun tidak diketahui	R-01, K-01
PR.AA-05	Sebagian	AC-01 berjalan; bukti pada 1 dari 5 rumah sakit	R-01, R-02, K-01
PR.AA-06	Tidak relevan	Vendor bekerja jarak jauh pada cakupan ini; tinjau bila vendor hadir di lokasi	Tidak ada
PR.PS-04	Terbukti	Catatan aktivitas tersedia pada 5 SIMRS selama 12 bulan	R-01
PR.DS-11	Sebagian	Cadangan malam berjalan; uji pemulihan belum ada	R-05, K-02
DE.CM-03	Sebagian	Catatan tersedia; bukti tinjauan dan tindak lanjut belum ada	R-01, K-01
RS.MA-01	Belum ada bukti	Prosedur tertulis; belum dilatih bersama vendor	R-01, R-12, K-04, K-05
RC.RP-03	Belum ada bukti	Hasil verifikasi cadangan belum tersedia	R-05, K-02

Medikara sekitar 7 persen. Kedua, status "tidak relevan" hanya berlaku pada cakupan ini. NIST menyebut cakupan profil menentukan apakah suatu hasil berlaku [103], sehingga PR.AA-06 kembali dinilai bila cakupan berubah.

Tier

Tier menggambarkan ketelitian tata kelola dan pengelolaan risiko keamanan organisasi. Ada empat *tier*: Partial, Risk Informed, Repeatable, dan Adaptive. *Tier* melengkapi metode pengelolaan risiko, bukan menggantikannya. Naskah NIST menyebut tabelnya sebagai ilustrasi [104]. Pemilihan *tier* umumnya dilakukan pimpinan organisasi. Memilih pada tingkat keseluruhan, fungsi, atau kategori memberi gambaran yang lebih baik daripada pada tingkat subkategori [125].

Analoginya seperti cara keluarga mengatur keuangan. Ada yang mencatat seadanya, ada yang punya anggaran tetapi hanya di kepala satu orang, ada yang menulis aturan bersama, dan ada yang terus menyesuaikan anggaran dengan keadaan. Tingkat itu menjelaskan cara mengelola uang, bukan jumlah saldo hari ini.

Tabel 6.12 meringkas keempatnya, lalu membacanya dari sisi risiko pemasok.

Dua contoh memperlihatkan pemakaiannya:

Tabel 6.12: Empat *tier* dan pembacaan risiko pemasok

Tier	Tata kelola risiko (ringkasan)	Risiko pemasok (ringkasan)
Tier 1, Partial	Strategi risiko diterapkan seadanya	Umumnya tidak menyadari risiko pemasok
Tier 2, Risk Informed	Praktik disetujui manajemen, tetapi mungkin belum menjadi kebijakan organisasi	Sadar risiko pemasok, tetapi belum bertindak konsisten atau formal
Tier 3, Repeatable	Praktik disetujui resmi sebagai kebijakan dan diperbarui berkala	Strategi risiko mempertimbangkan pemasok; ada perjanjian tertulis dan pemantauan
Tier 4, Adaptive	Risiko dipantau pimpinan bersama risiko keuangan dan risiko lain	Informasi hampir waktu nyata dipakai untuk bertindak atas risiko pemasok

1. Misalkan pimpinan membaca kolom pemasok untuk fungsi Protect. Insiden 2025 membuat risiko vendor dikenal, tetapi AC-01 baru terbukti pada 1 dari 5 rumah sakit. Deskripsi itu paling dekat dengan Tier 2. Pembacaan ini merupakan penilaian pimpinan, bukan hasil hitungan dari 14 baris profil.
2. Misalkan konsultan menawarkan rumus: status terbukti diberi nilai 4, sebagian nilai 2, dan belum ada bukti nilai 1. Tiga belas baris yang dinilai menghasilkan rata-rata 2,0, lalu ditulis "Tier 2". Rumus itu tidak punya dasar pada NIST. Angkanya tampak cocok dengan contoh pertama hanya karena kebetulan.

Tiga hal pada penilaian ini sering tertukar: status lokal, *tier*, dan tingkat kapabilitas Control Objectives for Information and Related Technologies (COBIT). Pembagiannya begini. Ketiganya menjawab pertanyaan yang berbeda, seperti pada Tabel 6.13, dan tidak saling dikonversi. Bab 8 memakai batas yang sama ketika menetapkan profil target dan target kapabilitas.

Tabel 6.13: Tiga ukuran yang tidak saling dikonversi

Ukuran	Yang dinilai	Contoh Medikara
Status lokal	Bukti satu hasil dalam cakupan profil	PR.AA-05 sebagian, karena bukti baru 1 dari 5 rumah sakit
Tier	Ketelitian pengelolaan risiko pada organisasi, fungsi, atau kategori	Tier 2 untuk Protect pada pembacaan pimpinan
Tingkat kapabilitas COBIT	Kapabilitas proses pada objektif COBIT	Tingkat indikatif 1 untuk DSS05 lewat AC-01 pada satu rumah sakit, seperti Bab 4

Pendalaman Teknis (opsional)

Sampel 30 dari 120 akun memberi perkiraan, bukan kepastian. Bila sampel diambil acak, proporsi 6 dari 30 sama dengan 0,2. Galat baku dengan koreksi populasi terbatas adalah $\sqrt{0{,}2 \times 0{,}8/30} \times \sqrt{90/119}$, atau sekitar 0,0635. Rentang kepercayaan 95 persen dengan pendekatan normal sekitar 0,2 ditambah atau dikurangi 0,124. Hasilnya 7,6 sampai 32,4 persen, atau sekitar 9 sampai 39 akun dari 120. Peninjauan penuh yang menemukan 24 akun berada di dalam rentang itu. Hitungan ini tidak berlaku bila sampel dipilih karena mudah diperoleh, dan tidak mencakup 12 akun yang tidak masuk daftar.

6.7 Dari Bukti ke Celah Kontrol

Pemetaan menunjukkan kontribusi

Pemetaan menghubungkan hasil yang belum tercapai, kontrol, risiko, dan kewajiban. Hubungannya dapat banyak ke banyak. NIST menyebut *Informative References* sebagai pemetaan antara inti CSF dan standar atau regulasi lain, dan sebagian rujukan lebih sempit dari subkategorinya [104]. Pemetaan tidak membuktikan kesetaraan antarkerangka. Bukti yang cukup untuk satu tujuan audit belum tentu cukup untuk tujuan lain.

Analogi peta angkutan memperlihatkan batasnya. Dua jalur melewati stasiun yang sama, tetapi memiliki tujuan dan jam operasi berbeda. Kesamaan satu titik bukan kesamaan seluruh perjalanan.

Pertanyaan kemudian muncul: seberapa jauh pemetaan dapat dipercaya? Panduan NIST SP 1347 memberi tiga peringatan. Rujukan pada katalog Online Informative References (OLIR) disusun NIST dan pihak lain. NIST tidak menguji kebenaran pemetaan dari pihak lain, dan pencantuman tidak berarti dukungan NIST. Hubungan turunan antardokumen pun tidak bersifat otoritatif [106]. Panduan yang sama mencontohkan organisasi pemakai CSF 2.0 yang ingin mengadopsi ISO/IEC 27001. Organisasi itu menyaring hasil pemetaan, lalu bertanya hasil mana yang sudah tercapai, mana yang belum, mana yang bertentangan, dan sumber daya apa yang diperlukan. Tim karena itu memperlakukan pemetaan sebagai titik awal.

Dua contoh menghasilkan keputusan yang berbeda:

1. Misalkan AC-01 baru punya bukti pada 1 dari 5 rumah sakit. Dengan peninjauan bulanan selama 12 bulan, seharusnya ada 60 catatan, dan yang tersedia 12, atau 20 persen. Celahnya adalah cakupan peninjauan. Membeli

alat baru belum menjamin pemilik layanan menyetujui seluruh hak akses.

2. Misalkan seluruh lokasi mempunyai catatan akses dan aturan organisasi meminta tinjauan mingguan. Selama 52 minggu pada 5 rumah sakit, seharusnya ada 260 catatan tinjauan, dan yang tersedia nol. Celahnya adalah proses deteksi dan tindak lanjut, bukan sekadar penyimpanan catatan.

Tabel 6.14 menautkan sebagian subkategori dengan nomor Annex A dari berkas NIST, kontrol Medikara, risiko, dan kewajiban [105, 136, 88]. Kolom kewajiban mengikuti register Bab 3. K-01 berasal dari Pasal 39 Undang-Undang (UU) 27/2022 tentang Pelindungan Data Pribadi (PDP), dan K-02 dari Permenkes 24/2022 Pasal 20. Tautan ke kontrol, risiko, dan kewajiban merupakan penganda-ian bab ini.

Tabel 6.14: Pemetaan subkategori ke Annex A, kontrol, risiko, dan kewajiban

Subkategori	Annex A	Kontrol Medikara	Risiko, kewajiban
PR.AA-05	5.15, 5.18, 8.2, 8.3, 8.18	AC-01 peninjauan akses	R-01, R-02, K-01
PR.AA-01	5.15, 5.16, 5.18, 8.2, 8.5	Akun per orang	R-02, K-01
PR.AA-03	5.15, 5.16, 5.17, 5.18, 8.5	MFA akun vendor	R-01, K-01
ID.AM-02	5.9	Inventaris sistem lintas rumah sakit	R-02
PR.PS-04	8.15, 8.17	Pencatatan aktivitas	R-01, K-01
DE.CM-03	7.4, 8.16	Tinjauan catatan aktivitas	R-01, K-01
PR.DS-11	8.13	Cadangan di lokasi terpisah	R-05, K-02
RC.RP-03	8.13	Uji pemulihan	R-05, K-02
RS.MA-01	5.26, 5.27, 5.28	Prosedur insiden bersama vendor	R-01, R-12, K-04, K-05
GV.SC-07	5.19, 5.20, 5.22, 5.31	Tinjauan vendor	R-01, R-08, K-05

Dua hal perlu dibaca dari tabel itu. Berkas NIST memuat dua daftar untuk PR.AA-05. Daftar pertama berisi 11 kontrol, daftar kedua berisi 6 kontrol, dan keduanya hanya bertemu pada 5 kontrol. Tabel di atas memakai irisan itu, lalu daftar lengkapnya tersedia di `sources/chapter06/pemetaan-csf-annex-a.csv`. Selain itu, tujuan pemetaan tidak selalu kontrol Annex A. DE.CM-03 juga dipetakan ke klausul 9.1, dan GV.RR-02 ke klausul 7.2 [105]. Sebagian celah karena itu berujung pada perbaikan sistem manajemen.

Menyusun daftar celah

Pertanyaan berikutnya: celah dibandingkan dengan apa? Analisis celah pada CSF membandingkan profil saat ini dan profil target [104]. Profil target baru dirancang pada Bab 8. Bab ini karena itu memakai pembanding sementara: batas *risk appetite* Bab 5, kewajiban pada register Bab 3, dan kontrol yang diperlukan pada SoA. Rencana tindakan yang baik memuat tindakan, prioritas, pemilik, tenggat, dan sumber daya [103].

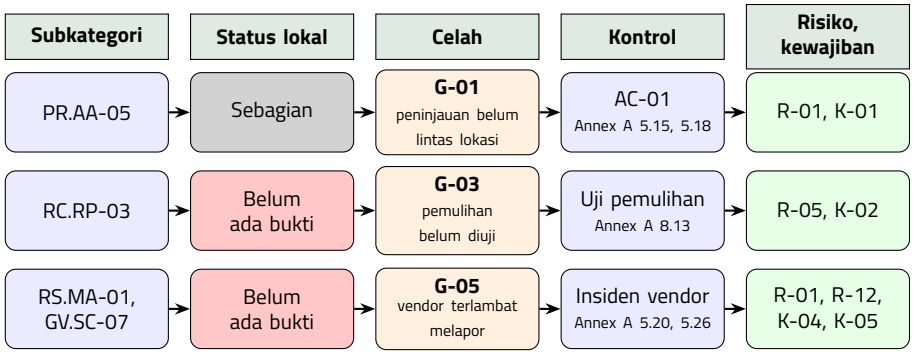
Tabel 6.15 merangkum enam celah. Kolom pemilik memisahkan pemilik risiko dan pemilik tindakan. Pemilik R-02 tetap pemilik SIMRS sesuai Bab 5, sedangkan kepala teknologi informasi (TI) memimpin tindakan inventaris. Gambar 6.6 menelusuri tiga celah prioritas dari subkategori sampai kewajiban.

Tabel 6.15: Hubungan celah dan risiko (misalkan)

ID	Hasil belum tercapai	Risiko	Pemilik risiko; pemilik tindakan	Bukti penerimaan
G-01	Peninjauan belum lintas lokasi; 12 dari 120 akun luput	R-01, K-01	Pemilik Medikara+; kepala operasi TI	120 dari 120 akun cocok; peninjauan 5 rumah sakit
G-02	Catatan aktivitas tidak ditinjau	R-01, K-01	Pemilik Medikara+; fungsi keamanan	Alarm uji ditangani dalam latihan
G-03	Pemulihan belum diuji	R-05, K-02	Pemilik layanan; kepala operasi TI	Data contoh pulih; hasil disahkan pemilik layanan
G-04	Hak lokal berbeda; akun bersama masih ada	R-02, K-01	Pemilik SIMRS; pemilik layanan	Peran baku pada 5 rumah sakit; nol akun bersama pada sampel
G-05	Vendor terlambat melapor; prosedur belum dilatih	R-01, R-12, K-04, K-05	Pemilik Medikara+; pengelola vendor	Latihan bersama: laporan dalam 12 jam
G-06	Inventaris lokal belum direkonsiliasi	R-02	Pemilik SIMRS; kepala TI	Satu inventaris disetujui untuk 5 rumah sakit

Kasus Medikara Health: Tiga Prioritas untuk Bab 8

Bab 5 menetapkan tiga prioritas risiko: R-11 karena keselamatan pasien, R-01 karena insiden 2025 dan K-01, serta R-05 karena harapan kerugiannya paling besar. R-11 berakar pada pertukaran data, sehingga tetap berada pada jalur pimpinan klinis. Misalkan tim memilih G-01 untuk R-01 dan



Gambar 6.6: Keterlacakan tiga celah prioritas (misalkan)

G-03 untuk R-05. Tim menambah G-05, karena K-05 berstatus tidak memenuhi: pada varian uji kontrak Bab 3, vendor baru melapor setelah 30 jam, sedangkan kontrak meminta 12 jam.

Keputusan ini punya dua konsekuensi yang dapat dihitung. Pertama, bila mencocokkan satu akun memerlukan 6 menit, G-01 memakan 12 jam per bulan untuk 120 akun, atau 144 jam per tahun. Bab 5 menganggarkan Rp60 juta untuk perluasan AC-01. Kedua, Bab 3 mengandaikan 144 uji pemulihan per tahun, yaitu satu uji per fasilitas per triwulan pada 36 fasilitas. Bila satu uji memerlukan 3 jam, G-03 memakan 432 jam per tahun. Keduanya berjumlah 576 jam, atau sekitar 3,6 bulan kerja dari 52 staf TI. Beban itu terjangkau, tetapi harus dijadwalkan dan tidak bisa bergantung pada tim platform 6 orang. Rincian kelangsungan layanan menunggu Bab 10, karena DSS04 ditunda ke sana.

Pendalaman Teknis (opsional)

Bagian ini opsional dan hanya untuk sistem milik tim atau sistem dengan izin tertulis. Jangan menjalankan pemindaian atau uji apa pun pada sistem pihak lain tanpa izin itu. Pilih satu kontrol teknis, misalnya cakupan MFA. Ambil populasi dari sumber yang tidak bergantung pada sistem yang diperiksa, misalnya daftar penugasan. Hitung akun yang memenuhi dibagi populasi: 108 dari 120 akun berarti 90 persen, bukan 100 persen. Catat pengecualian dan tanggal pengambilan bukti.

Pilihan lain adalah konfigurasi pencatatan terhadap CIS Benchmarks dari Center for Internet Security (CIS), yaitu rekomendasi konfigurasi preskriptif untuk lebih dari 25 keluarga produk [19]. Misalkan tim memeriksa 20 rekomendasi pencatatan pada 5 SIMRS, sehingga ada 100 baris, dan 72 baris sesuai. Laporkan juga 28 baris yang tersisa beserta alasannya. Pemetaan

antarkerangka dapat memakai katalog OLIR atau CSF 2.0 Reference Tool [106]. Kesimpulan tetap memerlukan pengujian.

6.8 Aktivitas: Profil Keamanan Saat Ini dan Daftar Celah

Tujuan. Tim menyusun profil saat ini NIST CSF 2.0 dan daftar celah kontrol yang dapat dipertanggungjawabkan. Tim memakai organisasi nyata dengan izin dan data yang dianonimkan, atau kasus Medikara Health.

Pembagian peran. Analis teknologi memimpin penilaian dan memilih subkategori. Pemilik konteks memastikan buktinya benar ada dan mengesahkan sumbernya. Analis regulasi menandai kontrol yang juga diwajibkan regulasi, dengan register Bab 3. Analis risiko menjaga hubungan dengan register Bab 5.

Langkah kerja.

1. Tetapkan sistem, lokasi, periode, dan pembatasan akses bukti. Untuk Medikara, fokusnya kontrol akses SIMRS lintas rumah sakit, pengelolaan akun vendor, pencatatan *log*, dan cadangan data.
2. Salin `sources/chapter06/profil-csf-saat-ini.csv`. Mulai dari 14 subkategori yang tersedia, lalu tambah atau kurangi sesuai cakupan. Keenam fungsi harus terwakili, dan alasan pemilihan dicatat.
3. Kumpulkan bukti dengan `sources/chapter06/panduan-bukti.md`. Jangan menyalin data pasien.
4. Beri status terbukti, sebagian, belum ada bukti, atau tidak relevan. Bandingkan dengan `sources/chapter06/contoh-profil-medikara.csv` sebagai pembanding skenario, bukan bukti organisasi.
5. Isi `sources/chapter06/celah-kontrol.csv`. Cari nomor Annex A dengan `sources/chapter06/pemetaan-csf-annex-a.csv`, lalu cocokkan ke naskah berlisensi bila tersedia.
6. Hubungkan setiap celah dengan risiko, kontrol, kewajiban, pemilik risiko, pemilik tindakan, dan bukti penerimaan. Tulis “perlu analisis” bila hubungan itu belum dapat dipastikan.
7. Tinjau alasan pemilihan dan pengecualian dengan `sources/chapter06/catatan-soa.md`.
8. Pilih tiga prioritas beserta alasannya, lalu serahkan kepada tim perancang profil target Bab 8.

Luaran. Profil saat ini, daftar celah terhadap kontrol Annex A, catatan SoA, dan

tiga prioritas.

Kaitan dengan capstone. Luaran masuk tonggak C2 Kondisi Saat Ini, yang ditinjau menjelang Ujian Tengah Semester. Daftar celah dipakai lagi pada Bab 8 untuk profil target, Bab 9 untuk risiko pihak ketiga, Bab 10 untuk kelangsungan layanan, dan Bab 12 untuk pengujian kontrol.

Kriteria penilaian. Cakupan dan bukti 35 persen; penalaran status 25 persen; keterlacakan risiko 25 persen; batas kesimpulan 15 persen. Nilai tinggi diberikan pada kejujuran celah dan kualitas bukti, bukan banyaknya status terbukti.

Berkas pendukung. Daftar lengkap ada di `sources/chapter06/README.md`. Data organisasi nyata wajib berizin dan dianonimkan. Data pribadi pasien atau karyawan, kata sandi, dan token tidak boleh disalin. Pendalaman teknis pada kotak di atas bersifat opsional dan terpisah dari penilaian utama.

6.9 Ringkasan

Keamanan informasi menjaga kerahasiaan, integritas, dan ketersediaan sesuai tujuan layanan. Dalam kesehatan, kontrol harus dinilai bersama dampaknya pada pasien dan akses darurat. Akun bersama dapat merusak jejak perubahan alergi tanpa kebocoran apa pun, dan pemblokiran total dapat menyentuh ratusan kunjungan. Penelitian tentang WannaCry menunjukkan ketersediaan dapat diukur sebagai janji temu, pendaftaran, dan biaya.

ISMS menghubungkan risiko, kontrol, evaluasi, dan perbaikan melalui klausul 4 sampai 10. Kebijakan serta pembelian alat belum membuktikan sistem berjalan. Temuan 12 dari 120 akun yang luput baru selesai ketika sebab pada daftar peninjau diperbaiki dan hasilnya diuji. Ruang lingkup sertifikat harus diperiksa, karena sertifikat pusat data tidak menjawab 36 fasilitas layanan.

Annex A memberi 93 kontrol rujukan dalam empat tema, dan SoA mencatat alasan pemilihan serta pengecualian. ISO/IEC 27002 memberi panduan penerapan, sedangkan ISO 27799 menempatkannya dalam konteks kesehatan. Pengecualian yang baik dapat diuji peninjau dan ditinjau ulang ketika cakupan berubah.

NIST CSF 2.0 memberi bahasa hasil dalam 6 fungsi, dengan Govern sebagai dasar lima fungsi lainnya. Profil saat ini menyampaikan hasil yang tercapai dan bukti yang belum ada. *Tier* menggambarkan ketelitian pengelolaan risiko, bukan rata-rata status kontrol. Status lokal, *tier*, dan tingkat kapabilitas COBIT tidak saling dikonversi.

Pemetaan menunjukkan kontribusi, bukan kesetaraan, sehingga tim memperlakukannya sebagai titik awal. Daftar celah menautkan subkategori, kontrol, risiko, kewajiban, pemilik, dan bukti penerimaan. Tiga prioritas Medikara menjadi ma-

sukan profil target Bab 8. Pesan utama bab ini sederhana: kesimpulan keamanan harus sepadan dengan cakupan buktinya.

6.10 Latihan

Latihan 1: Persyaratan dan Panduan

Jelaskan mengapa organisasi dapat disertifikasi terhadap ISO/IEC 27001, tetapi tidak terhadap ISO/IEC 27002. Latihan ini membuktikan bahwa kedua standar menilai objek yang berbeda.

1. Baca deskripsi resmi kedua standar dan catat kata pada judulnya.
2. Pilih AC-01 sebagai contoh kontrol.
3. Pisahkan hal yang diperiksa pada sistem manajemen dari panduan cara menerapkan kontrol.
4. Uji pemisahan itu dengan temuan 6 dari 30 akun dan 12 dari 120 akun.

Tabel 6.16 merangkum contoh analisis Latihan 1 dari skenario pembelajaran, dan Tabel 6.17 menyediakan lembar isiannya.

Tabel 6.16: Contoh analisis Latihan 1 (skenario pembelajaran)

Rujukan	Objek	Bukti contoh
ISO/IEC 27001	Sistem manajemen dalam cakupan	Evaluasi risiko R-01, baris SoA, dan perbaikan daftar 108 menjadi 120 akun
ISO/IEC 27002	Panduan kontrol	Cara meninjau hak akses dan mencabut akun

Tabel 6.17: Lembar hasil Latihan 1

Rujukan	Objek	Bukti contoh
…	…	…
…	…	…

Pertanyaan analisis. Audit menemukan 6 dari 30 akun bermasalah, dan bukti peninjauan hanya ada pada 1 dari 5 rumah sakit: bagian mana menyentuh sistem manajemen, dan bagian mana menyentuh cara menerapkan kontrol? Bila sertifikat hanya mencakup pusat data, bukti apa yang masih diminta untuk 36 fasilitas layanan?

Latihan 2: Peran Govern

Fungsi Govern ditambahkan pada NIST CSF 2.0. Masalah organisasi apa yang ingin diselesaikan dengan penambahan itu? Latihan ini membuktikan bahwa sebagian celah keamanan berakar pada keputusan, bukan pada alat.

1. Telusuri satu keputusan keamanan vendor dari permintaan sampai pencabutan akses.
2. Identifikasi pemilik risiko dan batas keputusannya pada register Bab 5.
3. Tentukan subkategori Govern yang belum tercapai.
4. Hubungkan keputusan dengan pelaksanaan kontrol pada fungsi lain.

Tabel 6.18 merangkum contoh analisis Latihan 2 dari skenario pembelajaran, dan Tabel 6.19 menyediakan lembar isiannya.

Tabel 6.18: Contoh analisis Latihan 2 (skenario pembelajaran)

Keadaan (misalkan)	Celah organisasi	Perbaikan
MFA pada 108 akun; 12 akun tidak punya pemilik	Akuntabilitas tidak jelas (GV.RR-02)	Tetapkan pemilik dan tinjau AC-01
Alarm tiba dalam 5 menit; tidak ada yang berwenang membekukan akun	Wewenang belum ditetapkan (GV.RR-02)	Beri wewenang kepada petugas jaga; uji eskalasi
Vendor melapor setelah 30 jam; kontrak 12 jam	Risiko pemasok tidak dipantau (GV.SC-07)	Tinjau kontrak dan latih insiden bersama

Tabel 6.19: Lembar hasil Latihan 2

Keadaan (misalkan)	Celah organisasi	Perbaikan
…	…	…
…	…	…

Pertanyaan analisis. Pada baris pertama, berapa persen cakupan MFA terhadap populasi 120 akun, dan mengapa menambah alat belum memperbaikinya? Pada baris ketiga, berapa jam kontrak terlewati? Bukti apa menunjukkan direksi benar menindaklanjuti risiko itu?

Latihan 3: Pengecualian Kontrol

Sebuah rumah sakit memutuskan tidak menerapkan satu kontrol Annex A. Apa yang harus ditulis di SoA agar keputusan itu dapat dipertanggungjawabkan? Latihan ini membuktikan bahwa pengecualian adalah keputusan yang punya alasan, pemilik, dan batas waktu.

1. Tentukan cakupan dan risiko terkait.

2. Uji kewajiban pada register Bab 3 serta alternatif kontrol.
3. Catat alasan, pihak yang menyetujui, dan tanggal tinjau ulang.
4. Tulis bukti yang akan membatalkan alasan tersebut.

Tabel 6.20 merangkum contoh analisis Latihan 3 dari skenario pembelajaran, dan Tabel 6.21 menyediakan lembar isiannya.

Tabel 6.20: Contoh analisis Latihan 3 (skenario pembelajaran)

Usulan (misalkan)	**Analisis**	**Keputusan dan isi SoA**
Tidak ada pengembangan internal	Vendor tetap mengubah aplikasi; R-07	Jangan mengecualikan tanpa menilai pengadaan dan perubahan
Satu rumah sakit tanpa akses vendor selama 12 bulan	Daftar menunjukkan 0 akun; penugasan baru dapat muncul	Pengecualian lokal; alasan, penyetuju, tinjau tiap triwulan

Tabel 6.21: Lembar hasil Latihan 3

Usulan (misalkan)	**Analisis**	**Keputusan dan isi SoA**
…	…	…
…	…	…

Pertanyaan analisis. Pada baris kedua, angka berapa pada daftar akun akan membatalkan alasan pengecualian? Bila Medikara bertambah dua fasilitas sehingga menjadi 38, baris SoA mana yang harus ditinjau kembali, dan siapa yang menyetujuinya?

Bab 7

Pelindungan Data Pribadi dalam Praktik

Tujuan Pembelajaran

- Menjelaskan kewajiban pengendali dan prosesor data pribadi menurut UU 27/2022 dan ketentuan pelaksana yang terverifikasi.
- Menyusun catatan kegiatan pemrosesan data pribadi untuk satu proses layanan.
- Menganalisis insiden kebocoran data dan menilai apakah penanganannya memenuhi kewajiban notifikasi.

7.1 Pendahuluan

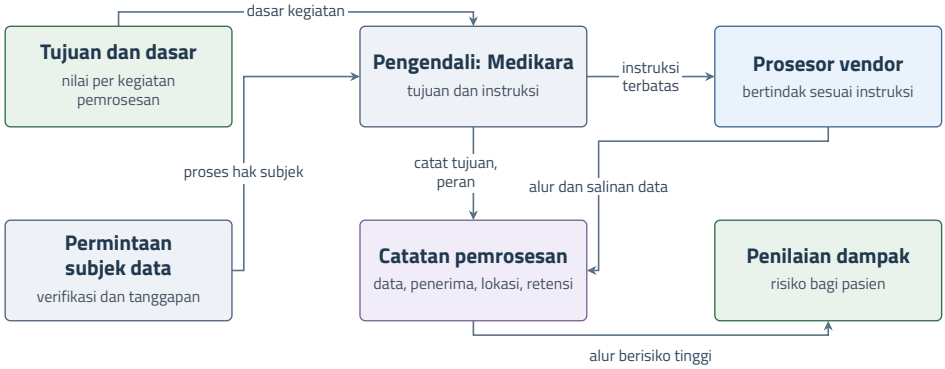
Ketika kebocoran terjadi pada vendor, pertanyaan pertama sering diarahkan kepada pemilik server. Pelindungan data memerlukan pertanyaan lain: siapa menentukan tujuan pemrosesan, siapa memberi instruksi, siapa menerima data, dan siapa memberi tahu pasien. Data latihan yang dipakai sejak Bab 1 memberi gambarannya. Akun dukungan vendor tetap aktif setelah kontrak pekerjaan selesai. Selama 8 malam akun itu memanggil data kunjungan pada dua rumah sakit, 155 panggilan per malam, sehingga 1.240 rekam kunjungan terbaca. Medikara baru mengetahuinya pada hari ke-11, lewat keluhan pasien.

Bab ini menutup tonggak C2. Bab 3 memberi register kewajiban K-01 sampai K-16, Bab 5 memberi skenario R-01 dan R-12, dan Bab 6 memberi daftar celah G-01 sampai G-06. Bab ini menambahkan catatan kegiatan pemrosesan dan analisis celah pelindungan data. Fakta dasar kasus hanya menyebut kebocoran skala

kecil lewat vendor pada 2025. Angka insiden mengikuti data latihan mata kuliah IT40613, sedangkan rincian jam merupakan pengandaian bab ini. Bab ini bukan nasihat hukum. Pembacaan pasal yang memerlukan penilaian ditandai "penafsiran bab", dan keputusan pada kasus nyata tetap memerlukan penasihat hukum.

Acuan hukum bab ini adalah Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi (UU PDP), Putusan Mahkamah Konstitusi (MK) Nomor 151/PUU-XXII/2024, Peraturan Pemerintah (PP) Nomor 28 Tahun 2024, dan Peraturan Menteri Kesehatan (Permenkes) Nomor 24 Tahun 2022 tentang Rekam Medis. Sistem manajemen privasi dibahas melalui ISO/IEC 27701:2025. Panduan Eropa dipakai sebagai pembanding, bukan sumber kewajiban di Indonesia. Aturan pelaksana yang naskah resminya belum diperoleh tidak dijadikan kewajiban [136, 95, 139, 88, 80].

Gambar 7.1 merangkum hubungan komponen dan konsep utama bab ini.



Persetujuan bukan satu-satunya dasar pemrosesan. Retensi serta transfer dinilai bersama aturan sektor dan tujuan masing-masing.

Gambar 7.1: Tujuan dan dasar pemrosesan mengendalikan alur data pribadi

7.2 Data, Tujuan, dan Dasar Pemrosesan

Data umum dan data spesifik

UU PDP mendefinisikan data pribadi sebagai data tentang orang perseorangan yang teridentifikasi atau dapat diidentifikasi, secara tersendiri atau dikombinasi dengan informasi lain. Pasal 4 membaginya menjadi data yang bersifat umum dan data yang bersifat spesifik. Data dan informasi kesehatan, data biometrik, data genetika, catatan kejahatan, data anak, dan data keuangan pribadi termasuk data spesifik. Nama lengkap, jenis kelamin, agama, dan status perkawinan termasuk data umum [136]. Pembagian ini punya akibat. Pasal 34 menempatkan pem-

rosesan data spesifik sebagai pemrosesan berpotensi risiko tinggi, dan Pasal 53 memakainya untuk menilai kebutuhan petugas pelindungan data.

Analogi buku tamu membantu menjelaskan pembagian ini. Nama di buku tamu gedung perkantoran tidak banyak bercerita. Nama yang sama di buku tamu poli jantung sudah bercerita tentang kesehatan seseorang. Datanya tampak sama, tetapi konteksnya mengubah risikonya.

Dua contoh pada Medikara:

1. Medikara+ melayani sekitar 28.000 janji temu per bulan, atau 336.000 per tahun. Tiap baris memuat nama dan poli tujuan. Nama termasuk data umum, tetapi poli tujuan memperlihatkan keadaan kesehatan. Bab ini memperlakukan seluruh baris sebagai data spesifik. Itu penafsiran bab, karena Pasal 4 tidak membahas gabungan seperti ini.
2. Mata kuliah IT40613 menghitung akibat pembatasan data. Kontrak Application Programming Interface (API) janji temu memuat 4 bidang. Misalkan vendor meminta 10 bidang, dengan tambahan nama lengkap, tanggal lahir, telepon, nomor identitas, diagnosis, dan alergi. Bila 1.240 rekam terpapar, butir data yang terpapar naik dari 4.960 menjadi 12.400, atau 2,5 kali. Bidang yang tidak pernah dikirim tidak dapat bocor lewat jalur itu.

Tabel 7.1 menerapkan pembagian itu pada data Medikara.

Tabel 7.1: Jenis data pada Medikara dan akibatnya (misalkan)

Data	Jenis menurut Pasal 4	Akibat pada pengelolaan
Nama lengkap dan jenis kelamin pada pendaftaran	Umum	Tetap memerlukan dasar, tujuan, dan pengamanan
Diagnosis, hasil laboratorium, dan resep	Spesifik: data dan informasi kesehatan	Potensi risiko tinggi menurut Pasal 34 ayat (2) huruf b
Nama dan poli tujuan pada janji temu	Gabungan; diperlakukan spesifik (penafsiran bab)	Akses dibatasi seperti data klinis
Data pasien anak	Spesifik: data anak	Persetujuan orang tua atau wali menurut Pasal 25
Rekening untuk pembayaran	Spesifik: data keuangan pribadi	Dipisahkan dari catatan klinis

Kepemilikan dokumen juga berbeda dari hak subjek data. Pasal 297 UU 17/2023 menyatakan dokumen rekam medis milik fasilitas pelayanan kesehatan, dan pasien berhak mengakses informasi di dalamnya [137].

Tujuan membatasi pemrosesan

Pasal 16 ayat (2) UU PDP memuat prinsip pemrosesan. Pengumpulan dilakukan terbatas dan spesifik, sah secara hukum, dan transparan. Pemrosesan sesuai tujuan, menjamin hak subjek data, akurat, aman, dan diberitahukan. Data dimusnahkan atau dihapus setelah masa retensi berakhir, kecuali ditentukan lain. Seluruh pemrosesan dapat dibuktikan [136]. Pasal 27 dan Pasal 28 mengulang dua prinsip pertama sebagai kewajiban pengendali.

Analogi kunci rumah membantu menjelaskan batas tujuan. Izin tukang memperbaiki keran tidak memberi izin membuka seluruh lemari. Begitu pula data yang diperlukan untuk pengobatan tidak otomatis boleh dipakai untuk promosi layanan lain. Pembatasan data diterjemahkan menjadi kolom formulir, hak akses, penerima, dan masa simpan yang dapat diperiksa.

Enam dasar, bukan satu kotak persetujuan

Pasal 20 ayat (1) mewajibkan pengendali memiliki dasar pemrosesan. Ayat (2) menyebut enam dasar: persetujuan eksplisit, perjanjian, kewajiban hukum, kepentingan vital, tugas kepentingan umum atau pelayanan publik berdasarkan peraturan, dan kepentingan sah lainnya dengan memperhatikan keseimbangan. Penjelasan huruf d mencontohkan kepentingan vital pada perawatan medis serius [136]. Pasal 963 ayat (1) PP 28/2024 memakai pola serupa: pemrosesan data kesehatan individu memerlukan persetujuan pemilik data dan/atau ketentuan lain yang menjadi dasar pemrosesan [139]. Tim menilai dasar untuk setiap kegiatan, bukan memakai satu kotak persetujuan untuk semua kegiatan.

Dua contoh menunjukkan perlunya pemisahan tujuan:

1. Misalkan Medikara memproses diagnosis untuk pelayanan dan pencatatan yang diwajibkan aturan kesehatan, pada sekitar 1,2 juta kunjungan per tahun. Tim mencatat dasar yang sesuai dengan unsur kewajibannya, bukan menganggap persetujuan satu-satunya dasar. Dengan dasar itu, satu baris K-16 menjelaskan seluruh kunjungan, tanpa 1,2 juta kotak centang yang harus dibuktikan satu per satu.
2. Misalkan data kontak 2.000 pasien akan dipakai untuk promosi, dan 150 pasien kemudian menarik persetujuan. Pasal 40 ayat (2) meminta penghentian paling lambat 3×24 jam sejak permintaan diterima. Daftar promosi turun menjadi 1.850 pasien. Penarikan itu tidak otomatis menghilangkan rekam medis ke-150 pasien yang wajib disimpan.

Tabel 7.2 merangkum analisis tujuan pemrosesan. Kolom dasar adalah penafsiran bab dan perlu ditinjau fungsi hukum.

Dua hal pada persetujuan sering tertukar: persetujuan tindakan dan persetu-

Tabel 7.2: Analisis tujuan pemrosesan (misalkan; dasar adalah penafsiran bab)

Tujuan	Data	Dasar kandidat	Bila pasien menolak atau menarik
Pendaftaran janji temu	Identitas, poli, jadwal	Perjanjian atau permintaan subjek data, Pasal 20 ayat (2) huruf b	Layanan daring tidak berjalan; pasien memakai loket
Pelayanan dan rekam medis	Catatan klinis relevan	Kewajiban hukum, huruf c; UU 17/2023 Pasal 296, PP 28/2024 Pasal 779	Pencatatan tetap berjalan; retensi 25 tahun tetap berlaku
Gawat darurat, pasien tidak sadar	Alergi dan obat	Kepentingan vital, huruf d	Persetujuan tidak dapat diminta saat itu
Pembukaan rekam medis untuk asuransi	Data klaim	Persetujuan, huruf a; Permenkes 24/2022 Pasal 34 ayat (1) huruf c	Klaim lewat jalur itu berhenti; perlu jalur lain
Promosi layanan lain	Kontak	Persetujuan terpisah, huruf a	Keluar dari daftar paling lambat 3×24 jam

juan pemrosesan data. Pembagiannya begini. Pasal 293 UU 17/2023 meminta persetujuan untuk setiap tindakan pelayanan kesehatan perseorangan [137]. Persetujuan itu menjawab boleh tidaknya tindakan pada pasien. Persetujuan pemrosesan menjawab boleh tidaknya data dipakai untuk tujuan tertentu. Tanda tangan pada formulir tindakan bedah tidak membuktikan persetujuan promosi.

Pilihan dasar punya dua konsekuensi. Pertama, bila rekam medis didasarkan pada persetujuan, penarikan persetujuan memicu Pasal 40 dan Pasal 43 ayat (1) huruf b UU PDP, padahal Pasal 39 Permenkes 24/2022 meminta penyimpanan paling singkat 25 tahun. Rentang 72 jam berbenturan dengan rentang 25 tahun. Kedua, persetujuan menuntut bukti. Pasal 24 UU PDP mewajibkan pengendali menunjukkan bukti persetujuan, dan Pasal 22 ayat (5) menyatakan persetujuan yang tidak memenuhi syarat batal demi hukum [136, 88].

Kasus Medikara Health: Satu Kotak untuk Tiga Tujuan

Misalkan formulir Medikara+ memakai satu kotak centang untuk pendaftaran, pengobatan, dan promosi. Dalam setahun, 336.000 janji temu melewati formulir itu. Pasal 22 ayat (4) UU PDP meminta persetujuan yang memuat tujuan lain dapat dibedakan secara jelas, dengan format yang mudah dipahami dan bahasa yang sederhana [136]. Tim menandai K-16

belum memenuhi untuk baris promosi.
Keputusan perbaikannya punya dua konsekuensi. Pertama, daftar promosi 2.000 pasien dibekukan sampai persetujuan terpisah terkumpul. Misalkan 40 persen pasien setuju kembali, sehingga daftar turun menjadi 800 pasien. Kedua, pendaftaran dan pengobatan tidak lagi bergantung pada kotak itu, karena dasarnya sudah dipisahkan. Tim kehilangan 1.200 kontak promosi dan memperoleh dasar yang dapat dibuktikan.

7.3 Pengendali, Prosesor, dan Pengendali Bersama

Peran ditentukan oleh kegiatan nyata

Pasal 1 UU PDP menyebut pengendali sebagai pihak yang menentukan tujuan dan melakukan kendali pemrosesan, sedangkan prosesor memproses atas nama pengendali. Pasal 51 mengatur akibatnya. Prosesor wajib memproses berdasarkan perintah pengendali, dan pemrosesan itu termasuk tanggung jawab pengendali. Prosesor memerlukan persetujuan tertulis sebelum melibatkan prosesor lain. Pemrosesan di luar perintah dan tujuan yang ditetapkan pengendali menjadi tanggung jawab prosesor. Pasal 52 memberlakukan sejumlah kewajiban pengendali kepada prosesor, termasuk Pasal 35 sampai Pasal 39 [136]. Nama jabatan dalam kontrak karena itu perlu diuji terhadap alur keputusan.

Pada sektor kesehatan, Pasal 962 PP 28/2024 menyatakan setiap penyelenggara Sistem Informasi Kesehatan merupakan pengendali data pribadi [139]. Panduan Eropa memberi pembanding yang berguna. European Data Protection Board (EDPB) menyebut pengendali dan prosesor sebagai konsep fungsional: statusnya ditentukan kegiatan nyata pada situasi tertentu, bukan sebutan formal dalam kontrak [34]. Panduan itu tidak mengikat di Indonesia.

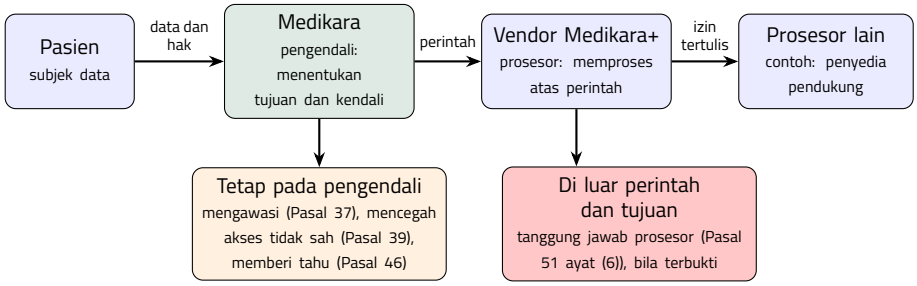
Analogi jasa penitipan dokumen menunjukkan perbedaan peran. Pemilik menentukan mengapa dokumen disimpan dan siapa boleh menerima salinan. Penyedia penyimpanan menjalankan instruksinya. Bila penyedia memakai isi dokumen untuk tujuannya sendiri, analisis perannya berubah.

Dua contoh menjaga analisis tetap spesifik:

1. Misalkan Medikara menentukan tujuan janji temu dan vendor hanya mengoperasikan Medikara+. Medikara dianalisis sebagai pengendali dan vendor sebagai prosesor untuk 28.000 janji temu per bulan itu. Bila vendor memakai 3 penyedia pendukung, Medikara perlu dapat menunjukkan 3 persetujuan tertulis.
2. Misalkan vendor memakai data 336.000 janji temu per tahun untuk melatih

produk komersialnya sendiri. Tim menilai kembali tujuan, dasar, instruksi, dan peran untuk penggunaan itu. Label prosesor dalam kontrak tidak menyelesaikan analisis.

Gambar 7.2 memperlihatkan hubungan itu, dan Tabel 7.3 merangkum pertanyaan untuk menentukan tanggung jawab. Istilah "instruksi" pada bab ini sama dengan "perintah" pada Pasal 51.



Gambar 7.2: Pengendali, prosesor, dan letak tanggung jawab (penafsiran bab)

Tabel 7.3: Pertanyaan untuk menentukan tanggung jawab

Pertanyaan	Bukti	Akibat keputusan
Siapa menentukan tujuan?	Kebijakan layanan dan keputusan bisnis	Tentukan pengendali per kegiatan
Siapa memberi instruksi?	Kontrak serta perubahan instruksi	Batasi tindakan prosesor
Siapa melibatkan pihak lain?	Persetujuan tertulis dan daftar prosesor lain	Pasal 51 ayat (5) dapat diuji
Siapa menangani permintaan pasien?	Alur permintaan dan catatan tanggapan	Cegah pasien dipingpong antarorganisasi
Siapa memberi tahu saat kegagalan?	Prosedur insiden dan bukti pengiriman	Pengendali memiliki data yang diperlukan tepat waktu

Pertanyaan kemudian muncul: apakah kebocoran di vendor memindahkan seluruh tanggung jawab kepada vendor? Kasus berikut memisahkan dua pertanyaan yang sering dicampur.

Kasus Medikara Health: Akun Dukungan di Luar Penugasan

Pada data latihan, kontrak pekerjaan sudah selesai dan akun dukungan tetap aktif. Pertanyaan pertama: siapa bertanggung jawab atas pembacaan 1.240 rekam yang tidak punya hubungan layanan dengan pekerjaan vendor? Bila bukti menunjukkan vendor bertindak di luar perintah, Pasal 51 ayat (6) mengarah kepada vendor. Bukti itu belum lengkap, karena catatan

hanya memuat ID aplikasi, bukan ID orang.
Pertanyaan kedua: siapa wajib memberi tahu pasien? Pasal 46 menyebut pengendali, sehingga kewajiban itu tetap berada pada Medikara. Pasal 37 dan Pasal 39 juga menuntut Medikara mengawasi pihak yang terlibat dan mencegah akses tidak sah [136]. Temuan 12 dari 120 akun yang luput dari peninjauan menunjukkan kewajiban itu belum terpenuhi sepenuhnya. Pembacaan ini penafsiran bab dan perlu ditinjau fungsi hukum.
Keputusan ini punya dua konsekuensi. Pertama, perjanjian vendor harus memuat instruksi, daftar akun, dan pencabutan saat kontrak selesai, karena G-01 dan K-01 bergantung padanya. Kedua, klausul laporan 12 jam pada K-05 tidak menggantikan Pasal 46. Klausul itu hanya memberi Medikara waktu untuk memenuhi kewajibannya sendiri.

Perjanjian prosesor akan menjadi lebih rinci. Salinan pihak ketiga PP 33/2026 Pasal 14 memuat 11 butir minimum perjanjian, antara lain cakupan, jenis data, jangka waktu, serta mekanisme pengawasan dan audit [99]. Ringkasan RSM Indonesia menyebut pasal yang sama [142]. Naskah resmi belum diperoleh, sehingga bab ini memakainya sebagai daftar periksa awal, bukan kewajiban. Misalkan perjanjian vendor hanya memuat 6 dari 11 butir. Tim mencatat 5 butir kosong sebagai bahan tawar ulang pada Bab 9.

Pasal 18 UU PDP mengatur pemrosesan oleh 2 atau lebih pengendali. Syarat minimalnya adalah perjanjian yang memuat peran dan tanggung jawab, tujuan yang saling berkaitan dengan cara pemrosesan yang ditentukan bersama, dan narahubung yang ditunjuk bersama [136]. Misalkan Medikara dan perusahaan klien merancang program kesehatan untuk 3.000 karyawan. Keduanya menentukan tujuan skrining dan cara pelaporannya. Tim memeriksa ketiga syarat, lalu menetapkan bahwa perusahaan hanya menerima hasil agregat. Mitra asuransi yang menentukan tujuan klaimnya sendiri dinilai sebagai pengendali terpisah. Pembedaan ini penafsiran bab.

Pejabat atau petugas fungsi pelindungan data

Pasal 53 ayat (1) mewajibkan pengendali dan prosesor menunjuk pejabat atau petugas yang melaksanakan fungsi pelindungan data dalam tiga keadaan. Keadaan pertama adalah pemrosesan untuk kepentingan pelayanan publik. Keadaan kedua adalah kegiatan inti yang memerlukan pemantauan teratur dan sistematis atas data berskala besar. Keadaan ketiga adalah kegiatan inti berupa pemrosesan data spesifik atau data tindak pidana dalam skala besar [136]. Putusan MK Nomor 151/PUU-XXII/2024, yang diucapkan 30 Juli 2025, menyatakan kata “dan” pada huruf b tidak mempunyai kekuatan hukum mengikat secara bersyarat sepanjang tidak dimaknai “dan/atau” [95]. Karena itu bab ini tidak membaca kriteria tersebut

sebagai keharusan memenuhi semua keadaan sekaligus. Pembacaan ini penafsiran bab. Pasal 54 menetapkan tugas paling sedikit: memberi saran, memantau kepatuhan, memberi saran penilaian dampak, dan menjadi narahubung.

Analogi petugas keselamatan kerja membantu menjelaskan posisi fungsi ini. Petugas itu memeriksa dan melapor, tetapi tidak mengoperasikan mesin yang diperiksanya. Bila operator mesin merangkap pemeriksa, temuan mudah hilang.

Dua contoh penerapannya:

1. Medikara memproses data kesehatan dari sekitar 1,2 juta kunjungan per tahun sebagai kegiatan inti. Keadaan ini dibaca memenuhi keadaan ketiga. Sebelum putusan, pembacaan kumulatif membuka perdebatan apakah jaringan swasta juga memenuhi keadaan pertama. Sesudah putusan, perdebatan itu tidak lagi menentukan kewajiban menunjuk.
2. Misalkan Medikara menunjuk 1 petugas penuh waktu dan 5 koordinator rumah sakit dengan 20 persen waktu. Kapasitasnya setara 2 orang penuh waktu, atau 320 jam per bulan pada 160 jam kerja. Kepala Teknologi Informasi (TI) yang memimpin 52 staf tidak dipilih, karena ia ikut menentukan cara pemrosesan. Pengawasan tidak boleh berbenturan dengan kepentingan pelaksana pemrosesan.

7.4 Hak Subjek Data dan Batas Tanggapan

UU PDP memberi subjek data hak atas informasi (Pasal 5), perbaikan (Pasal 6), akses dan salinan (Pasal 7), pengakhiran dan penghapusan (Pasal 8), penarikan persetujuan (Pasal 9), keberatan atas keputusan otomatis (Pasal 10), penundaan atau pembatasan (Pasal 11), gugatan ganti rugi (Pasal 12), serta pemakaian dan pengiriman data (Pasal 13). Pasal 14 meminta hak pada Pasal 6 sampai Pasal 11 diajukan lewat permohonan tercatat kepada pengendali. Hak juga punya batas. Pasal 15 memuat pengecualian tertentu, dan Pasal 33 mewajibkan pengendali menolak akses perubahan yang membahayakan kesehatan atau mengungkap data orang lain [136]. Hak karena itu diterjemahkan menjadi proses: penerimaan, verifikasi identitas, penilaian, dan pencatatan tanggapan.

Analogi loket berkas di kantor kelurahan membantu. Warga mengambil nomor, petugas memeriksa identitas, berkas dinilai, dan tanda terima disimpan. Tanpa nomor antrean, warga dipingpong ke loket lain, dan tidak ada yang tahu berapa lama permintaan sudah menunggu.

Dua contoh menguji proses itu:

1. Misalkan 0,1 persen dari 28.000 janji temu per bulan berujung permintaan hak, yaitu 28 permintaan per bulan. Bila satu permintaan memerlukan 45

menit, bebannya 21 jam per bulan, atau 252 jam per tahun. Angka itu sekitar 1,6 bulan kerja. Permintaan akses yang masuk Jumat pukul 16.00 WIB harus selesai Senin pukul 16.00 WIB. Bila loket hanya buka Senin sampai Jumat pukul 08.00 sampai 17.00 WIB, jam kerja yang tersedia hanya 9 jam. Pasal menulis jam, bukan hari kerja. Pembacaan jam kalender ini penafsiran bab.

2. Misalkan pasien yang terakhir berkunjung pada 2 Maret 2026 meminta seluruh datanya dihapus. Pasal 39 Permenkes 24/2022 mengharuskan rekam medis elektroniknya disimpan paling singkat sampai 2 Maret 2051 [88]. Tim menghapus data dari daftar promosi, menjelaskan alasan rekam medis tidak dihapus, lalu mencatat keduanya. Permintaan dinilai terhadap kewajiban penyimpanan, bukan langsung dijalankan atau langsung ditolak tanpa alasan.

Tabel 7.4 menerjemahkan hak menjadi batas, pemilik, dan bukti.

Tabel 7.4: Hak subjek data, batas tanggapan, dan bukti (pemilik misalkan)

Hak	Pasal	Batas	Pemilik	Bukti
Akses dan salinan	7, 32; UU 17/2023 Pasal 297	3×24 jam sejak permintaan diterima	Rekam medis	Tiket dan bukti pengiriman
Perbaikan	6, 30	3×24 jam sejak permintaan diterima	Rekam medis	Jejak perubahan
Menarik persetujuan	9, 40	Penghentian 3×24 jam sejak permintaan diterima	Pemasaran	Daftar sebelum dan sesudah
Menunda atau membatasi	11, 41	3×24 jam sejak permintaan diterima	Fungsi privasi	Pengaturan sistem
Mengakhiri dan menghapus	8, 42, 43, 44	Tidak ada rentang jam pada pasal; mengikuti peraturan	Fungsi privasi	Keputusan beserta alasan
Keberatan keputusan otomatis	10	Rincian diatur peraturan pemerintah	Pemilik layanan	Catatan keberatan

7.5 Catatan Pemrosesan dan Retensi

Satu baris per kegiatan pemrosesan

Catatan kegiatan pemrosesan menghubungkan tujuan, data, dasar, penerima, lokasi, retensi, dan kontrol. Pasal 31 UU PDP mewajibkan pengendali merekam seluruh kegiatan pemrosesan, dan Pasal 52 memberlakukannya pula pada prosesor [136]. *Records of Processing Activities* (RoPA) dipakai di bab ini sebagai nama lembar kerja. Pengisian kolom membantu menemukan salinan data yang tidak mempunyai tujuan atau pemilik jelas. Salinan pihak ketiga PP 33/2026 Pasal 74 merinci 13 butir minimum, antara lain sumber dan tujuan pengiriman, dasar, jenis data, pihak yang dapat mengakses, peta aliran data, masa retensi, dan rincian transfer [99]. Templat bab ini memuat butir tersebut, dengan status pemantauan sampai naskah resmi diperoleh.

Analogi kartu persediaan gudang membantu penelusuran. Barang masuk dicatat asal, tujuan, lokasi, dan masa simpannya. Salinan yang berpindah tanpa catatan membuat pengendalian menjadi sulit.

Dua contoh menilai alur data, bukan hanya aplikasi:

1. Misalkan data janji temu disalin ke sistem pesan dan catatan dukungan vendor. Tim membuat baris penerima dan masa simpan masing-masing. Bila catatan dukungan disimpan 90 hari, isinya sekitar 84.000 baris pada satu waktu. Bila retensi rekam medis 25 tahun disalin otomatis ke catatan itu, isinya menjadi 8,4 juta baris, atau 100 kali lipat. Retensi rekam medis tidak otomatis berlaku untuk seluruh catatan pemasaran atau dukungan.
2. Misalkan tim mendaftar 6 proses inti pada 36 fasilitas. Satu baris per fasilitas menghasilkan 216 baris, dan pada 40 menit per baris bebannya 144 jam. Tim mengelompokkan fasilitas menjadi 4 jenis: rumah sakit, klinik, laboratorium, dan apotek, sehingga ada 24 baris. Karena 5 rumah sakit memakai versi Sistem Informasi Manajemen Rumah Sakit (SIMRS) berbeda, proses rekam medis rumah sakit dipecah lagi menjadi 5 baris, sehingga totalnya 28 baris, atau sekitar 19 jam. *Tradeoff*-nya, perbedaan antarklinik harus dicatat sebagai pengecualian.

Tabel 7.5 memuat contoh tiga baris. Baris dukungan vendor sering luput karena tidak tampak pada alur layanan pasien.

Diagram konsep pada awal bab meringkas alur yang sama. Tujuan dan dasar dinilai per kegiatan pemrosesan, lalu menjadi pegangan pengendali. Medikara sebagai pengendali memberi instruksi terbatas kepada prosesor vendor. Tujuan, peran, alur, dan salinan data masuk catatan pemrosesan. Alur berisiko tinggi diteruskan ke penilaian dampak. Permintaan subjek data masuk ke pengendali untuk diverifikasi dan ditanggapi. Diagram itu menampilkan pembagian umum,

Tabel 7.5: Contoh catatan pemrosesan (misalkan; dasar adalah penafsiran bab)

Butir	**P-01 Pendaftaran**	**P-02 Telekonsultasi**	**P-05 Dukungan vendor**
Tujuan dan pemilik	Janji temu; pemilik Medikara+	Pelayanan jarak jauh; pemilik rekam medis	Perbaikan gangguan; pengelola vendor
Data	Identitas, poli, jadwal	Keluhan dan catatan klinis	Data pada tiket; akses baca terbatas
Dasar	Perjanjian, huruf b	Kewajiban hukum, huruf c	Perjanjian; instruksi tertulis
Penerima	Vendor sesuai instruksi	Tenaga kesehatan berwenang	Staf vendor yang ditugaskan
Lokasi	Harus dikonfirmasi	Pusat data dalam negeri	Harus dikonfirmasi, termasuk dukungan jarak jauh
Retensi	Ditetapkan per tujuan	Mengikuti rekam medis	90 hari
Bukti	Dasar, instruksi, akses	Dasar, akses, jejak perubahan	AC-01 dan daftar 120 akun

sedangkan peran pada kasus nyata tetap dinilai per kegiatan.

Dua masa simpan yang sering tertukar

Dua hal pada retensi sering tertukar: masa simpan rekam medis dan masa simpan catatan akses. Pembagiannya begini. Pasal 39 Permenkes 24/2022 menetapkan penyimpanan rekam medis elektronik di fasilitas pelayanan kesehatan paling singkat 25 tahun sejak tanggal kunjungan terakhir pasien. Setelah itu data dapat dikecualikan dari pemusnahan bila masih dipergunakan, dan pemusnahan mengikuti ketentuan yang berlaku [88]. Catatan akses punya pertanyaan lain: berapa lama organisasi perlu dapat membuktikan siapa membaca apa.

Analogi rekaman kamera toko menjelaskan bedanya. Faktur penjualan disimpan bertahun-tahun untuk pembukuan. Rekaman kamera hanya disimpan beberapa hari. Bila pencurian baru diketahui sesudah rekaman tertimpa, faktur tidak dapat menjawab siapa pelakunya.

Dua contoh berangka:

1. Pada data latihan, catatan rinci hanya disimpan 7 hari. Ketika kejadian diketahui pada hari ke-11, yang tersisa hanya hari ke-5 sampai ke-11. Rekam malam ke-5 sampai ke-8 masih terlacak, yaitu 620 rekam. Rekam malam ke-1 sampai ke-4, juga 620 rekam, tinggal terlihat sebagai jumlah pada rekap harian. Pasal 46 ayat (2) huruf a meminta pemberitahuan memuat data yang terungkap. Separuh rekam tidak dapat dijawab.

2. Misalkan masa simpan catatan rinci dinaikkan dari 7 menjadi 90 hari. Ruang simpan naik sekitar 12,9 kali. Catatan akses juga memuat data pribadi, sehingga masa simpan yang lebih panjang memerlukan tujuan, pembatasan akses, dan baris sendiri pada RoPA. Keputusan ini *tradeoff*, bukan sekadar tambahan ruang.

7.6 Pusat Data dan Transfer ke Luar Wilayah Hukum

Pertanyaan berikutnya: di mana data pasien boleh berada? Dua lapis aturan dibaca bersama. Lapis umum ada pada Pasal 56 UU PDP. Pengendali wajib memastikan negara penerima memiliki tingkat pelindungan yang setara atau lebih tinggi. Bila tidak terpenuhi, harus ada pelindungan yang memadai dan bersifat mengikat. Bila keduanya tidak terpenuhi, pengendali wajib mendapatkan persetujuan subjek data [136].

Lapis sektor ada pada PP 28/2024. Pasal 966 ayat (2) menyatakan pangkalan data kesehatan berupa pusat data yang berada di dalam wilayah Indonesia. Ayat (5) mengizinkan jasa dan fasilitas pihak lain bila dilaksanakan di dalam wilayah Indonesia, berdasarkan perjanjian kerja sama, dengan data yang dimiliki dan dikendalikan penuh oleh penyelenggara, serta memenuhi kewajiban prosesor. Pasal 972 mengatur transfer ke luar wilayah hukum untuk tujuan spesifik dan terbatas, dengan izin Menteri, serta memenuhi persyaratan transfer data pribadi [139]. Pasal 22 Permenkes 24/2022 menambahkan rekomendasi unit data Kementerian Kesehatan dan larangan pemanfaatan data bagi penyedia penyimpanan [88]. Bab 3 sudah membaca ketentuan ini bersama Pasal 21 PP 71/2019, yang lebih umum [134]. Hubungan aturan umum dan aturan khusus pada kasus nyata tetap perlu dinilai penasihat hukum.

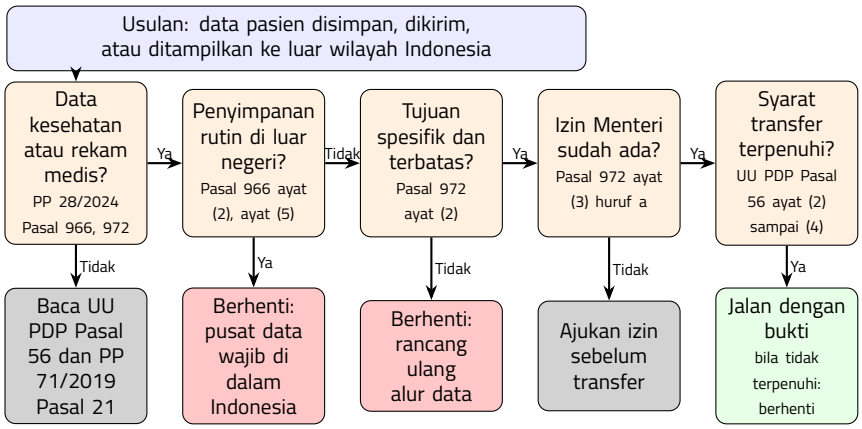
Analogi brankas bank membantu. Bank boleh menyewa jasa penjaga dari luar, tetapi brankasnya tetap di gedung itu dan kuncinya tetap dipegang bank. Mengirim isi brankas ke kantor luar negeri memerlukan alasan khusus dan izin, bukan sekadar persetujuan pemilik rekening.

Dua contoh berangka:

1. Bab 3 memisalkan vendor menawarkan penyimpanan di luar negeri seharga Rp420 juta per tahun. Penghematannya Rp180 juta, atau 30 persen dari Rp600 juta. Bila hanya membaca Pasal 56, tim dapat tergoda mengejar persetujuan pasien dari sekitar 1,2 juta kunjungan per tahun. Persetujuan itu tidak menjawab Pasal 966 ayat (2), sehingga usulan berhenti lebih awal.
2. Misalkan 4 staf dukungan vendor di luar negeri membuka layar Medikara+ dari jarak jauh untuk sekitar 300 tiket per bulan. Data tidak berpindah penyimpanan. Namun Pasal 971 ayat (2) PP 28/2024 menyebut penampilan

sebagai salah satu bentuk transfer [139]. Tim memperlakukan akses itu sebagai transfer, dan ini penafsiran bab. Pilihan lainnya adalah dukungan dalam negeri atau data sintetis. Misalkan tarif dukungan dalam negeri lebih mahal Rp25 juta per bulan, atau Rp300 juta per tahun. Selisih itu menjadi bahan keputusan.

Gambar 7.3 menyusun bacaan itu sebagai pertanyaan, dan urutannya adalah penafsiran bab. Baris register terkait adalah K-07 dan K-13. Salinan pihak ketiga PP 33/2026 Pasal 163 sampai Pasal 165 mengulang urutan Pasal 56 dan menambah penilaian risiko transfer [99], sehingga tim memantaunya.



Gambar 7.3: Pertanyaan berurutan untuk lokasi dan transfer data pasien (penafsiran bab)

7.7 Penilaian Dampak Pelindungan Data Pribadi

Penilaian dampak pelindungan data pribadi, atau *Data Protection Impact Assessment* (DPIA), mengevaluasi potensi risiko dari suatu pemrosesan serta langkah mitigasinya, termasuk terhadap hak subjek data. Pasal 34 ayat (1) UU PDP mewajibkannya bila pemrosesan berpotensi risiko tinggi terhadap subjek data. Ayat (2) menyebut tujuh keadaan: keputusan otomatis dengan akibat hukum atau dampak signifikan, data spesifik, skala besar, evaluasi atau pemantauan sistematis, pencocokan atau penggabungan data, teknologi baru, dan pemrosesan yang membatasi hak subjek data [136]. Salinan pihak ketiga PP 33/2026 Pasal 121 menambahkan waktu dan isi: dilakukan sebelum pemrosesan, memuat deskripsi, kebutuhan dan proporsionalitas, risiko terhadap hak, serta langkah pelindungan, lalu ditinjau ulang bila risiko berubah [99].

Analogi pemeriksaan ruang baru menjelaskan waktunya. Sebelum ruang operasi baru dibuka, tim memeriksa jalur evakuasi dan pasokan listrik. Pemeriksaan dilakukan sebelum pasien masuk. Hasilnya tidak selalu melarang ruang dibuka,

tetapi menentukan syarat pembukaannya.

Dua contoh menuntut keputusan berbeda:

1. Misalkan integrasi asuransi mengirim data kesehatan 6.000 klaim per bulan, atau 72.000 per tahun. Tim menilai kebutuhan, penerima, dampak diskriminasi, pembatasan data, dan bukti pengujian sebelum alur diaktifkan. Alur itu menyentuh tiga keadaan Pasal 34: data spesifik, skala besar, dan penggabungan data.
2. Misalkan 5 dari 6 proses inti Medikara memuat data kesehatan. Satu DPIA memerlukan 3 orang selama 3 hari kerja, atau 72 jam. Lima DPIA memerlukan 360 jam, sekitar 2,25 bulan kerja, atau Rp21,6 juta pada tarif Rp60.000 per jam. Angka itu kecil dibanding harapan kerugian R-01 sebesar Rp100 juta per tahun, tetapi perbandingan rupiah bukan alasan utamanya. Alasan utamanya adalah hak pasien.

Tabel 7.6 menyaring tiga usulan terhadap ketujuh keadaan.

Tabel 7.6: Penyaringan tiga usulan terhadap Pasal 34 ayat (2) (misalkan)

Keadaan	**Klaim asuransi**	**Triase otomatis pada telekonsultasi**	**Tampilan baru Medikara+**
a. Keputusan otomatis	Tidak	Ya	Tidak
b. Data spesifik	Ya	Ya	Sudah ada, tidak berubah
c. Skala besar	Ya: 72.000 per tahun	Perlu dihitung	Sudah ada, tidak berubah
d. Evaluasi atau pemantauan	Tidak	Ya: penskoran gejala	Tidak
e. Penggabungan data	Ya	Tidak	Tidak
f. Teknologi baru	Tidak	Ya	Tidak
g. Membatasi hak	Perlu diperiksa	Perlu diperiksa	Tidak
Keputusan	DPIA sebelum aktif	DPIA sebelum uji coba	Tinjau DPIA lama bila alur berubah

Panduan Eropa memberi pembanding. Article 29 Working Party memakai sembilan kriteria, dan pemrosesan yang memenuhi dua kriteria pada umumnya memerlukan DPIA. Pada kasus tertentu, satu kriteria dapat cukup. Panduan itu mencontohkan rumah sakit yang memproses data genetik dan kesehatan pasien pada sistem informasi rumah sakit [5]. Pasal 34 tidak memuat aturan dua kriteria. Bab ini membaca satu keadaan sudah cukup, karena ayat (2) memakai “dan/atau”. Pembacaan ini penafsiran bab. Akibatnya, hampir seluruh proses klinis Medikara masuk, sehingga DPIA disusun per alur proses, bukan per fasilitas.

Dua hal pada risiko juga sering tertukar: risiko bagi organisasi dan risiko bagi subjek data. Pembagiannya begini. R-01 pada Bab 5 berskor $3 \times 4 = 12$ pada skala 5 tingkat, dengan harapan kerugian Rp100 juta per tahun. Skala dampak Bab 5 memakai rupiah dan gangguan layanan. DPIA bertanya hal lain: apa akibatnya pada pasien? Misalkan satu rekam kunjungan ke poli kejiwaan terungkap kepada atasan pasien. Kerugian Medikara mungkin di bawah Rp10 juta, atau dampak 1. Akibat pada pasien dapat berupa stigma dan kehilangan pekerjaan. Bab 5 sudah menilai hak pasien dalam kolom terpisah, dan DPIA menjadi tempat penalaran kolom itu.

7.8 Kegagalan Pelindungan dan Pemberitahuan

Isi kewajiban

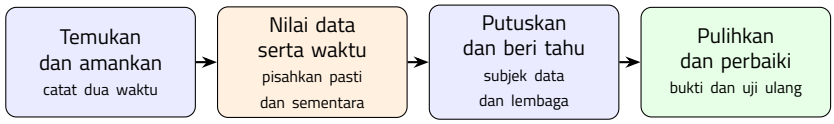
Penjelasan Pasal 46 ayat (1) UU PDP mengartikan kegagalan pelindungan sebagai kegagalan melindungi kerahasiaan, integritas, dan ketersediaan data pribadi. Kegagalan itu mencakup pelanggaran keamanan, disengaja maupun tidak, yang mengarah pada perusakan, kehilangan, perubahan, pengungkapan, atau akses yang tidak sah. Ayat (1) mewajibkan pengendali menyampaikan pemberitahuan tertulis paling lambat 3×24 jam kepada subjek data dan lembaga. Ayat (2) menetapkan isi minimum: data yang terungkap, kapan dan bagaimana data terungkap, serta upaya penanganan dan pemulihan. Ayat (3) mewajibkan pemberitahuan kepada masyarakat dalam hal tertentu, antara lain bila kegagalan mengganggu pelayanan publik dan/atau berdampak serius terhadap kepentingan masyarakat [136]. Bab 3 sudah membedakan pengertian ini dari insiden siber, sehingga K-04 dan K-09 tetap dua baris.

Analogi peringatan kerusakan produk menunjukkan pentingnya waktu. Menunggu seluruh penyebab diketahui dapat membuat pengguna terus terpapar. Organisasi menyampaikan fakta yang telah dipastikan dan mencatat pembaruan, sambil melanjutkan penanganan.

Dua contoh tenggat:

1. Misalkan kegagalan terjadi dan ditemukan bersamaan pada Jumat pukul 20.00 WIB. Untuk latihan, akhir rentang 72 jam adalah Senin pukul 20.00 WIB, bukan akhir jam kerja hari Senin. Contoh ini menjadi asumsi dasar pada Bab 3.
2. Bab 3 memakai varian untuk menguji kontrak. Misalkan vendor menemukan akun dukungan dipakai di luar penugasan pada Jumat pukul 20.00 WIB, dan baru memberi tahu Medikara setelah 30 jam, yaitu Minggu pukul 02.00 WIB. Kontrak 12 jam terlewati 18 jam. Bila batas tetap dihitung dari Jumat, sisa rentang Pasal 46 tinggal 42 jam dari 72 jam.

Gambar 7.4 memperlihatkan alur keputusan ketika kegagalan pelindungan terdeteksi.



Gambar 7.4: Alur keputusan ketika kegagalan pelindungan terdeteksi

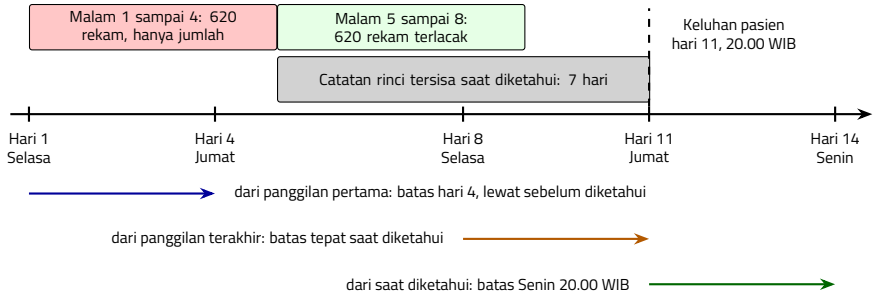
Kapan rentang 72 jam mulai dihitung?

Pertanyaan kemudian muncul: kapan rentang 72 jam mulai dihitung? Pasal 46 ayat (1) tidak menjawabnya secara eksplisit. Empat pasal lain pada undang-undang yang sama menulis titik mulai dengan jelas. Pasal 30, Pasal 32, Pasal 40, dan Pasal 41 memakai frasa "terhitung sejak" pengendali menerima permintaan. Pasal 46 tidak memakai frasa itu [136]. Dua sumber lain membantu, tetapi tidak menyelesaikan persoalan.

1. Salinan pihak ketiga PP 33/2026 Pasal 114 ayat (2) menulis rentang itu terhitung sejak kegagalan "diketahui secara pasti, patut, dan wajar". Penjelasannya mengaitkan pengetahuan itu dengan kesimpulan dokumentasi pengendali [99]. Naskah resminya belum diperoleh, dan peraturan itu baru berlaku 16 Januari 2027, sehingga ketentuan ini hanya dipantau. Bab ini tidak memakainya untuk menilai insiden 2025.
2. *General Data Protection Regulation* (GDPR) di Eropa menghitung 72 jam setelah pengendali mengetahui pelanggaran. EDPB menganggap pengendali mengetahui ketika memiliki tingkat kepastian yang wajar bahwa insiden keamanan telah membuat data pribadi terganggu. Investigasi singkat diperbolehkan, tetapi harus segera dimulai [35]. GDPR tidak menjadi dasar kewajiban Medikara dalam kasus ini.

Bab ini mengambil sikap kerja berikut, sebagai penafsiran bab. Waktu kejadian dan waktu diketahui dicatat terpisah. Fungsi hukum menetapkan batas operasional konservatif. Selama belum ada kepastian, batas terluar dihitung dari saat pertama Medikara mengetahui kegagalan, bukan dari saat dokumentasi selesai. Contoh Jumat hanya berlaku dengan asumsi waktu kegagalan dan penemuan sama. Jika kejadian lebih awal, tim tidak boleh otomatis menganggap penemuan sebagai awal tenggat baru. Alasan keterlambatan terhadap titik yang lebih awal harus tertulis.

Data latihan insiden 2025 menguji sikap itu. Misalkan hari ke-1 jatuh pada Selasa, panggilan pertama terjadi pukul 20.00 WIB, dan hari ke-11 jatuh pada Jumat. Gambar 7.5 dan Tabel 7.7 memperlihatkan akibat tiap titik mulai.



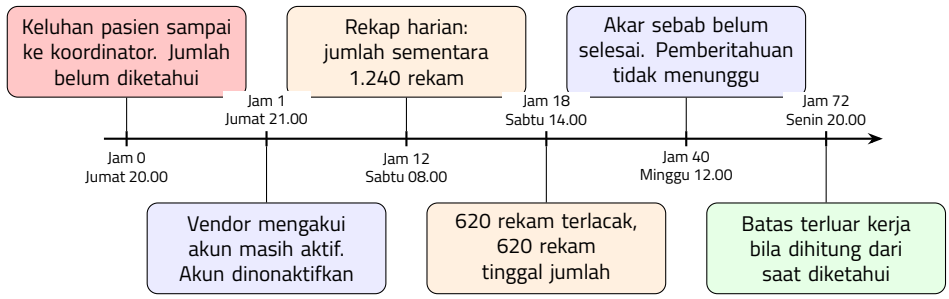
Gambar 7.5: Fakta latihan insiden 2025 dan tiga pembacaan rentang 72 jam (jam adalah pengandaian)

Tabel 7.7: Akibat pilihan titik mulai pada insiden 2025 (misalkan)

Titik mulai	Waktu	Batas 72 jam	Terhadap saat diketahui
Panggilan pertama	Hari 1, Selasa 20.00	Hari 4, Jumat 20.00	Lewat 168 jam sebelum Medikara tahu; dijelaskan pada kronologi
Panggilan terakhir	Hari 8, Selasa 20.00	Hari 11, Jumat 20.00	Habis tepat saat Medikara tahu
Saat diketahui	Hari 11, Jumat 20.00	Hari 14, Senin 20.00	Sisa 72 jam; batas terluar kerja bab ini
Kesimpulan dokumentasi (salinan PP 33/2026)	Hari 12, Sabtu 14.00	Hari 15, Selasa 14.00	Sisa 90 jam; tidak dipakai karena belum berlaku pada 2025

Jam-jam pertama: angka belum pasti

Pertanyaan berikutnya: apa yang dilakukan ketika jumlah data belum diketahui? Gambar 7.6 menyusun pengandaian jam-jam pertama. Urutan harinya mengikuti data latihan IT40613, sedangkan jamnya pengandaian bab ini.



Gambar 7.6: Jam-jam pertama sesudah Medikara mengetahui kejadian (misalkan; skala tidak proporsional)

Kasus Medikara Health: Jam-Jam Pertama Insiden 2025

Misalkan keluhan pasien sampai kepada koordinator insiden pada hari ke-11, Jumat pukul 20.00 WIB. Pada jam itu jumlah data belum diketahui. Pukul 20.30 WIB vendor mengakui akun dukungan masih aktif. Pukul 21.00 WIB akun dinonaktifkan.

Sabtu pukul 08.00 WIB, rekap harian menunjukkan 155 panggilan per malam selama 8 malam. Jumlah sementara menjadi 1.240 rekam, sesudah 12 jam dari 72 jam. Sabtu pukul 14.00 WIB, pemeriksaan catatan rinci menunjukkan 620 rekam terlacak dan 620 rekam tinggal jumlah. Pada titik itu 18 jam, atau 25 persen rentang, sudah terpakai. Minggu pukul 12.00 WIB, jam ke-40, akar sebab belum selesai. Catatan hanya memuat ID aplikasi, sehingga orang yang memakai akun belum diketahui. Apakah data disalin keluar juga belum diketahui.

Tim tidak menunggu angka final. Pemberitahuan menyatakan yang sudah pasti, yang masih sementara, dan kapan pembaruan dikirim. Pasal 33 ayat (4) GDPR mengizinkan informasi diberikan bertahap [35]. UU PDP tidak menyebut tahapan itu, dan salinan PP 33/2026 Pasal 119 menyerahkan rincian pemberitahuan kepada peraturan lembaga [99]. Tim memakai cara bertahap sebagai praktik kerja dan mencatat keputusan itu bersama fungsi hukum. Ini penafsiran bab.

Tabel 7.8 menerapkan isi minimum Pasal 46 ayat (2) pada Senin pagi. Rincian pemberitahuan tersedia di `sources/chapter07/templat-notifikasi.md`.

Tabel 7.8: Isi minimum pemberitahuan pada Senin pagi (misalkan)

Unsur Pasal 46 ayat (2)	Sudah pasti	Masih sementara atau belum diketahui
Data yang terungkap	Rekam kunjungan pada dua rumah sakit	Jumlah 1.240 berasal dari rekap; 620 rekam belum terhubung ke nama pasien
Kapan dan bagaimana	8 malam, lewat akun dukungan vendor yang aktif setelah kontrak selesai	Orang yang memakai akun; apakah data disalin keluar
Penanganan dan pemulihan	Akun dinonaktifkan; 120 akun diperiksa	Akar sebab; hasil pemeriksaan di sisi vendor

Pertanyaan kemudian muncul: bagaimana memberi tahu pemilik 620 rekam yang tidak terlacak? Mata kuliah IT40613 menghitung pemberitahuan kepada 620 pasien: 15 menit per pasien dengan tarif Rp60.000 per jam, atau Rp9,3 juta. Hitungan itu menganggap satu rekam mewakili satu pasien. Tabel 7.9 membandingkan tiga pilihan. Bila dua rumah sakit itu menerima 30 persen dari sekitar 1,2 juta kunjungan, pilihan C menjangkau sekitar 360.000 kunjungan per

tahun. Angka itu batas atas, karena satu pasien dapat berkunjung beberapa kali. Angka itu juga berbeda dari 336.000 janji temu Medikara+, yang hanya menghitung pemesanan lewat aplikasi pada kelima rumah sakit.

Tabel 7.9: Tiga pilihan untuk rekam yang tidak terlacak (misalkan)

Pilihan	Biaya langsung	Kelemahan
A. Hanya 620 pasien yang terlacak	Rp9,3 juta	620 rekam lain tanpa pemberitahuan
B. A ditambah pengumuman di Medikara+ dan situs, serta kanal tanya jawab	Rp9,3 juta ditambah 2 orang, 5 hari, 8 jam, atau Rp4,8 juta; jumlah Rp14,1 juta	Pesan umum tidak menjamin terbaca
C. Pesan ke seluruh kunjungan dua rumah sakit	360.000 pesan dikali Rp500, atau Rp180 juta	Sebagian besar penerima tidak terdampak; menimbulkan kecemasan

Misalkan tim mengusulkan pilihan B. Biaya langsung naik dari Rp23,7 juta pada hitungan IT40613 menjadi Rp28,5 juta. Keputusan ini punya dua konsekuensi. Pertama, fungsi hukum perlu menilai apakah keadaan ini masuk "dalam hal tertentu" pada Pasal 46 ayat (3). Bab ini tidak menyimpulkannya, dan memakai pengumuman sebagai cara menjangkau pasien. Kedua, kanal tanya jawab dapat menerima permintaan akses yang berjalan pada rentang 3×24 jam tersendiri, sehingga petugasnya perlu disiapkan.

Membaca dua penelitian

Literatur membantu membaca besar kecilnya kejadian dan akibat perbaikannya. Dua penelitian dari Amerika Serikat berikut tidak boleh disalin menjadi angka Medikara, karena aturan dan sistem layanannya berbeda.

1. McCoy dan Perlis menelaah pelanggaran data kesehatan yang dilaporkan pada 2010 sampai 2017. Jumlahnya 2.149 pelanggaran dengan 176,4 juta rekam. Penyedia layanan kesehatan menyumbang 70 persen pelanggaran, tetapi 21 persen rekam. *Health plan* menyumbang 13 persen pelanggaran, tetapi 63 persen rekam [97]. Jumlah kejadian dan jumlah rekam memberi gambaran yang berbeda. Register Medikara karena itu mencatat keduanya, dan 1.240 rekam tetap satu kejadian yang perlu dinilai.

2. Choi dan rekan menggabungkan data pelanggaran dengan data mutu pada 3.025 rumah sakit, atau 14.297 observasi rumah sakit per tahun, untuk 2012 sampai 2016. Dalam 3 tahun sesudah pelanggaran, waktu sampai elektrokardiogram naik hingga 2,7 menit. Mortalitas 30 hari infark miokard akut naik hingga 0,36 poin persentase. Penulis mengaitkannya dengan upaya perbaikan dan menyarankan inisiatif keamanan dievaluasi cermat

[21]. Hubungan itu asosiasi, bukan bukti sebab tunggal. Pembacaan bagi Medikara: kontrol baru sesudah insiden diuji dampaknya pada pelayanan klinis bersama pimpinan klinis.

7.9 Status Aturan, Sanksi, dan Sistem Manajemen Privasi

Mencatat status sumber hukum

Status hukum diperiksa melalui naskah resmi, perubahan, putusan pengadilan yang relevan, dan ruang lingkup. Berita penerbitan aturan berguna sebagai petunjuk pencarian, tetapi belum cukup untuk mengisi nomor pasal, tenggat, atau kewajiban baru.

Analogi jadwal perjalanan membantu menjelaskan kehati-hatian ini. Pengumuman bahwa rute baru akan dibuka belum menunjukkan jadwal keberangkatan yang dapat dipesan. Petugas perlu memeriksa dokumen resmi dan tanggal berlakunya sebelum mengubah prosedur.

Dua contoh memisahkan pengetahuan dan asumsi:

1. Publikasi Badan Pengawas Obat dan Makanan (BPOM) menyebut PP 33/2026 diundangkan 16 Juli 2026 [8]. Basis data nonresmi dan ringkasan RSM Indonesia mencatat mulai berlaku 16 Januari 2027, yaitu 76 hari dari 1 November 2026 [99, 142]. Penelusuran bab ini pada 1 November 2026 belum memperoleh naskah resmi. Tim menandai status belum terverifikasi dan tidak menurunkan kewajiban tambahan darinya. Salinan pihak ketiga dipakai untuk menyiapkan daftar periksa.
2. Portal resmi MK memuat putusan yang mengubah makna Pasal 53 ayat (1) huruf b [95]. Tim membaca amar dan konteksnya, memperbarui register kewajiban, serta menautkan bukti perubahan. Satu kata pada amar putusan mengubah pembacaan tiga keadaan.

Tabel 7.10 merangkum cara mencatat kepastian sumber hukum per 1 November 2026.

Pasal 58 UU PDP menyatakan lembaga ditetapkan oleh Presiden, dan ketentuan lebih lanjut diatur dengan Perpres [136]. Statusnya belum pasti pada tanggal pemeriksaan bab ini. Pada 23 Juli 2026, Wakil Menteri Komunikasi dan Digital menyebut pembahasan Perpres sedang difinalisasi [51]. Pada 13 September 2026, Bisnis.com mengutip Kementerian Komunikasi dan Digital bahwa rancangan Perpres sudah diajukan kepada Presiden. Berita yang sama mengutip pengamat yang mendengar Perpres sudah ditandatangani, tetapi lembaganya masih memerlukan proses pembentukan [156]. Penelusuran pada 1 November 2026 belum menemukan naskah Perpres. Ketiadaan rincian kanal tidak menghapus kewajiban

Tabel 7.10: Status sumber hukum per 1 November 2026

Sumber	Status kerja	Tindakan
UU 27/2022	Naskah resmi terbaca; masa penyesuaian Pasal 74 berakhir 17 Oktober 2024	Turunkan kewajiban serta bukti
Putusan MK 151/PUU-XXII/2024	Amar resmi terbaca	Baca bersama Pasal 53
PP 28/2024; Permenkes 24/2022	Naskah resmi terbaca	Turunkan kewajiban sektor
PP 33/2026	Salinan pihak ketiga dan ringkasan; naskah resmi belum diperoleh	Pantau; jangan menetapkan pasal sebagai kewajiban
Peraturan Presiden (Perpres) dan lembaga	Berita; naskah belum ditemukan	Tetapkan penanggung jawab kanal
Peraturan lembaga	Belum ditemukan	Pantau; catat pasal yang menunggunya

UU PDP. Pemilik kepatuhan harus memastikan kanal yang berwenang, menyimpan bukti upaya, dan mengaktifkan jalur eskalasi. Bab ini tidak menganggap rancangan lembaga atau mekanisme masa depan sudah berlaku.

Sanksi dan masa penyesuaian

Pasal 57 ayat (1) UU PDP mengenakan sanksi administratif atas pelanggaran sejumlah pasal, termasuk Pasal 20 ayat (1), Pasal 31, Pasal 34 ayat (1), Pasal 37, Pasal 39 ayat (1), Pasal 46 ayat (1) dan ayat (3), serta Pasal 53 ayat (1). Ayat (2) menyebut peringatan tertulis, penghentian sementara pemrosesan, penghapusan atau pemusnahan data, dan denda administratif. Ayat (3) membatasi denda paling tinggi 2 persen dari pendapatan atau penerimaan tahunan terhadap variabel pelanggaran. Ayat (4) menyatakan sanksi diberikan oleh lembaga. Di luar sanksi administratif, Pasal 12 memberi subjek data hak menggugat ganti rugi, dan Pasal 67 mengancam pidana bagi orang yang dengan sengaja dan melawan hukum memperoleh, mengungkapkan, atau menggunakan data pribadi yang bukan miliknya [136].

Analogi rambu lalu lintas menjelaskan peran angka maksimum. Rambu menulis denda paling tinggi, bukan tagihan yang pasti diterima. Pengemudi tetap perlu tahu besarnya sebelum memutuskan menerobos.

Dua contoh berangka:

1. Bab 3 memisalkan variabel pelanggaran Rp500 miliar, sehingga denda paling tinggi Rp10 miliar. Angka itu sekitar 422 kali biaya langsung Rp23,7 juta, dan dua kali kapasitas risiko Rp5 miliar pada Bab 5. Salinan PP 33/2026 Pasal 185 menyebut variabel seperti dampak, durasi, jenis data, jumlah subjek data, dan tingkat kerja sama [99]. Angka Rp10 miliar tetap alat diskusi, bukan perkiraan denda.
2. Pasal 67 ayat (1) mengancam pidana penjara paling lama 5 tahun dan/atau denda paling banyak Rp5 miliar. Ayat (2) mengancam 4 tahun dan/atau Rp4 miliar. Pasal 70 ayat (3) menetapkan denda korporasi paling banyak 10 kali maksimum, atau sampai Rp50 miliar pada ancaman Rp5 miliar [136]. Ancaman ini menuntut unsur sengaja dan melawan hukum, sehingga berbeda dari kelalaian administratif. Penerapannya pada kasus nyata adalah urusan penasihat hukum.

Pasal 74 memberi masa penyesuaian paling lama 2 tahun sejak pengundangan pada 17 Oktober 2022, sehingga berakhir 17 Oktober 2024. Insiden 2025 terjadi sesudah itu, sehingga alasan "masih masa penyesuaian" tidak tersedia. Sebaliknya, PP 33/2026 baru berlaku 2027, sehingga rinciannya tidak dipakai menilai kejadian 2025. Kedua pembacaan ini penafsiran bab.

Sistem manajemen privasi

ISO/IEC 27701:2025 menetapkan persyaratan dan panduan *Privacy Information Management System* (PIMS) [80]. Halaman lembaga sertifikasi DNV menyebut edisi yang terbit 14 Oktober 2025 ini sebagai standar mandiri, yang juga dapat menambahkan kontrol privasi pada ISO/IEC 27001 [31]. Naskah standarnya berbayar, sehingga rincian klausul perlu dicocokkan ke naskah berlisensi. Sertifikasi tidak menggantikan analisis dasar pemrosesan dan kewajiban hukum.

Analogi pengelolaan arsip menunjukkan manfaat sistem. Satu lembar persetujuan bukan sistem privasi. Pembagian peran, daftar pemrosesan, penanganan permintaan, pemeriksaan, dan perbaikan harus saling terkait.

Dua contoh memperlihatkan peran pengujian:

1. Misalkan tim mengganti nama pasien dengan kode pada salinan untuk analitik berisi 1.240 rekam. Bila tabel penghubung masih tersedia, data belum otomatis anonim. Penilaian harus mencakup akses dan kemungkinan pengenalan ulang.
2. Misalkan persetujuan tercatat pada aplikasi, tetapi salinan vendor tidak mengikuti pencabutan. Dari 150 pasien yang menarik persetujuan, uji sampel menemukan 12 pasien masih menerima promosi, atau 8 persen. Keberadaan kolom persetujuan belum membuktikan pelaksanaan di seluruh

alur.

Tabel 7.11 merangkum hubungan kegiatan privasi dan bukti.

Tabel 7.11: Hubungan kegiatan privasi dan bukti

Kegiatan	Bukti	Pertanyaan peninjau
Pemetaan pemrosesan	RoPA yang diperbarui	Apakah prosesor lain tercakup?
Permintaan subjek	Catatan permintaan anonim	Apakah alasan tanggapan dapat diuji?
Penilaian dampak	DPIA dan saran petugas	Apakah dilakukan sebelum alur aktif?
Penanganan insiden	Kronologi dan bukti pengiriman	Apakah waktu dan penerima tercatat?
Perbaikan	Tindakan dan uji ulang	Apakah celah yang sama berulang?

Pendalaman Teknis (opsional)

Gunakan data sintetis untuk membandingkan penghapusan pengenal langsung, pseudonimisasi, dan anonimisasi. Daftar kembali siapa memegang kunci penghubung. Rocher dan rekan memodelkan bahwa 99,98 persen orang Amerika akan teridentifikasi kembali dengan benar pada himpunan data apa pun yang memakai 15 atribut demografis [140]. Angka itu berasal dari model statistik dan populasi Amerika Serikat, tetapi cukup untuk meragukan klaim "sudah anonim" yang hanya menghapus nama.
Sumber daya Consent pada Health Level Seven Fast Healthcare Interoperability Resources (HL7 FHIR) membantu representasi teknis. Spesifikasinya menyebut sumber daya itu sebagai catatan pilihan konsumen layanan kesehatan [53]. Catatan itu tidak membuktikan sendiri bahwa persetujuan atau dasar hukumnya sah. Skrip `sources/chapter07/hitung-tenggat-notifikasi.py` menghitung ulang Tabel 7.7, sehingga tim dapat menguji titik mulai lain.

Merangkum celah untuk C2

Seluruh pembacaan bab ini bermuara pada daftar celah. Tabel 7.12 melanjutkan G-01 sampai G-06 dari Bab 6, dengan kode CP untuk celah pelindungan data. Tabel ini pengandaian dan tersedia di `sources/chapter07/analisis-celah-pdp.md`.

Tabel 7.12: Celah pelindungan data Medikara untuk C2 (misalkan)

ID	Celah	Kaitan	Pemilik	Bukti selesai
CP-01	Perjanjian vendor tanpa instruksi, daftar akun, dan pencabutan	R-01, K-01, K-05, G-01	Pengelola vendor	Perjanjian baru; 120 dari 120 akun cocok
CP-02	RoPA belum mencakup 36 fasilitas	K-16, K-13	Fungsi privasi	28 baris disahkan pemilik proses
CP-03	DPIA alur asuransi belum ada	Pasal 34, R-01	Fungsi privasi	DPIA disetujui sebelum aktif
CP-04	Prosedur pemberitahuan belum dilatih	R-12, K-04, G-05	Fungsi hukum	Latihan: naskah siap sebelum jam ke-60
CP-05	Catatan rinci 7 hari tidak menjawab isi pemberitahuan	R-12, G-02	Fungsi keamanan	Masa simpan baru; uji telusur satu rekam
CP-06	Fungsi pelindungan data belum ditunjuk	Pasal 53, R-12	Direksi	Keputusan penunjukan dan jalur laporan
CP-07	Lokasi cadangan dan dukungan jarak jauh belum diperiksa	K-13, K-07	Kepala TI dan rekam medis	Inventaris lokasi

Kasus Medikara Health: Tiga Celah untuk C3

Misalkan tim memilih CP-04, CP-01, dan CP-05. CP-04 dipilih karena R-12 berpemilik fungsi hukum dan K-04 masih belum terverifikasi. CP-01 dipilih karena R-01 menjadi prioritas Bab 5, dan K-05 berstatus tidak memenuhi. CP-05 dipilih karena 620 rekam tidak dapat dijawab pada pemberitahuan. Keputusan ini punya dua konsekuensi yang dapat dihitung. Pertama, latihan pemberitahuan dua kali setahun dengan 12 orang selama 4 jam memakan 96 jam per tahun, atau Rp5,76 juta. Kedua, masa simpan 90 hari menaikkan ruang simpan sekitar 12,9 kali. Keduanya kecil dibanding denda paling tinggi Rp10 miliar, tetapi tetap harus masuk anggaran dan jadwal. Sisanya tidak dihapus. CP-02, CP-03, CP-06, dan CP-07 tetap tercatat dengan pemilik pada C2.

7.10 Aktivitas: Catatan Pemrosesan dan Analisis Insiden Vendor

Tujuan. Tim menyusun catatan kegiatan pemrosesan untuk satu proses layanan, lalu menilai penanganan insiden vendor terhadap UU PDP dan ketentuan pelaksana yang terverifikasi. Tim memakai organisasi nyata dengan izin dan data yang dianonimkan, atau kasus Medikara Health.

Pembagian peran. Analis regulasi memimpin dasar pemrosesan dan tenggat. Pemilik konteks memetakan alur data yang sebenarnya. Analis teknologi menelusuri sistem, penerima, serta salinan data. Analis risiko memperbarui R-01 dan R-12.

Langkah kerja.

1. Pilih pendaftaran atau telekonsultasi. Isi `sources/chapter07/catatan-pemrosesan.csv`, lalu bandingkan dengan `sources/chapter07/contoh-pemrosesan-medikara.csv`.
2. Periksa dasar, penerima, lokasi, retensi, kontrol, dan sumber bukti. Pisahkan promosi dari tujuan pengobatan. Uji lokasi dengan Gambar 7.3.
3. Saring proses itu dengan `sources/chapter07/penyaringan-penilaian-dampak.csv`. Tandai bila DPIA diperlukan.
4. Baca kronologi pengandaian di `sources/chapter07/kronologi-insiden-vendor-2025.md`. Pisahkan waktu kejadian, penemuan, eskalasi, dan pemberitahuan.
5. Isi `sources/chapter07/analisis-celah-pdp.md`. Cocokkan kewajiban dengan fakta yang tersedia, dan tandai yang belum diketahui.
6. Siapkan rancangan pemberitahuan dengan `sources/chapter07/templat-notifikasi.md`. Dokumen ini hanya latihan dan tidak dikirim kepada pihak nyata.
7. Perbarui baris R-01, R-12, K-01, K-04, K-05, K-13, K-16, dan G-05 bila temuan mengubahnya.
8. Rangkum luaran Bab 4 sampai 7 menjadi C2 menurut Tabel 7.13. Bawa tiga celah utama ke desain target C3.

Luaran. RoPA, hasil penyaringan DPIA, analisis insiden, rancangan pemberitahuan, celah PDP, dan tiga prioritas.

Kaitan dengan capstone. Luaran menutup tonggak C2 Kondisi Saat Ini, yang ditinjau menjelang Ujian Tengah Semester (UTS). Tiga prioritas menjadi masukan C3 pada Bab 8 dan Bab 9. Penulisan temuan pada Bab 12 memakai kronologi yang

Tabel 7.13: Isi tonggak C2 Kondisi Saat Ini

Bab	Luaran	Pertanyaan peninjau
4	Hasil faktor desain, objektif prioritas COBIT, dan potret kapabilitas	Apakah objektif berasal dari faktor desain?
5	Pernyataan *risk appetite* dan *risk register*	Apakah skenario punya pemilik dan batas?
6	Profil saat ini National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) dan daftar celah kontrol	Apakah status didukung bukti?
7	Catatan pemrosesan dan analisis celah PDP	Apakah celah tertaut ke kewajiban dan risiko?

sama.

Kriteria penilaian. Ketepatan dasar dan peran 30 persen; kelengkapan alur 25 persen; kronologi serta tenggat 30 persen; keterlacakan bukti 15 persen. Nilai tinggi diberikan pada ketepatan batas kesimpulan, termasuk penandaan fakta yang belum diketahui.

Berkas pendukung. Daftar lengkap ada di `sources/chapter07/README.md`. Data organisasi nyata wajib berizin dan dianonimkan. Data pribadi pasien atau karyawan tidak boleh dipakai.

7.11 Ringkasan

Pelindungan data dimulai dari tujuan dan dasar pemrosesan. Data kesehatan termasuk data spesifik, dan Pasal 20 UU PDP menyediakan enam dasar. Persetujuan hanya salah satunya. Rekam medis yang disandarkan pada persetujuan berbenturan dengan retensi 25 tahun, sedangkan daftar promosi memang pantas memakai persetujuan terpisah. Satu kotak centang tidak membenarkan seluruh penggunaan dan salinan data.

Pengendali dan prosesor dinilai per kegiatan. Instruksi, penggunaan mandiri, serta prosesor lain memengaruhi tanggung jawab. Pasal 51 ayat (6) dapat mengarahkan pemrosesan di luar perintah kepada vendor, tetapi kewajiban memberi tahu tetap pada pengendali. Fungsi pelindungan data membutuhkan wewenang dan ruang pengawasan yang sesuai, dan Putusan MK Nomor 151/PUU-XXII/2024 mengubah pembacaan kriteria penunjukannya.

RoPA memperlihatkan ke mana data berpindah dan mengapa disimpan. Retensi, permintaan subjek, dan transfer dinilai bersama aturan sektor. Pasal 56 UU PDP tidak dibaca sendiri, karena Pasal 966 dan Pasal 972 PP 28/2024 lebih dahulu

menentukan lokasi dan transfer data kesehatan. DPIA menilai akibat bagi pasien sebelum alur berjalan, sehingga melengkapi skor risiko organisasi pada Bab 5.

Penanganan insiden memerlukan kronologi dan keputusan cepat. Tenggat tidak berhenti pada akhir pekan. Pasal 46 tidak menulis titik mulai, sehingga waktu kejadian dan waktu diketahui dicatat terpisah. Pada insiden 2025, jumlah 1.240 rekam baru tersedia pada jam ke-12, dan 620 rekam tidak dapat dilacak karena catatan hanya disimpan 7 hari. Status PP 33/2026 dan lembaga pelindungan data masih harus dipantau, dengan tanggal pemeriksaan yang tertulis.

Seluruh temuan bermuara pada daftar celah dan tonggak C2. Tiga celah prioritas membawa kondisi saat ini ke perancangan kondisi target. Sebagai kerangka, ISO/IEC 27701:2025 membantu menjaga agar kegiatan tersebut tetap menjadi sistem. Pesan utama bab ini ialah bahwa organisasi harus dapat menunjukkan alasan pemrosesan, kendali alur data, dan bukti pertanggungjawabannya.

7.12 Latihan

Latihan 1: Peran Vendor

Medikara memakai vendor untuk aplikasi Medikara+. Dalam hubungan ini, siapa pengendali dan siapa prosesor? Apa akibatnya terhadap tanggung jawab saat terjadi kebocoran? Latihan ini membuktikan bahwa peran dinilai per kegiatan, bukan per nama perusahaan.

1. Daftar kegiatan vendor pada Medikara+: operasi, dukungan, dan penggunaan untuk produk vendor.
2. Catat pihak yang menentukan tujuan dan pihak yang memberi instruksi untuk tiap kegiatan.
3. Pisahkan operasi sesuai instruksi dan penggunaan mandiri.
4. Tetapkan alur eskalasi serta pemilik pemberitahuan.

Tabel 7.14 merangkum contoh analisis Latihan 1 dari skenario pembelajaran, dan Tabel 7.15 menyediakan lembar isiannya.

Pertanyaan analisis. Apakah label kontrak cukup bila kegiatan nyata berbeda? Informasi apa harus diterima Medikara agar dapat memberi pemberitahuan tepat waktu? Bila 12 dari 120 akun vendor luput dari peninjauan, apakah Pasal 51 ayat (6) cukup untuk melepaskan Medikara?

Tabel 7.14: Contoh analisis Latihan 1 (skenario pembelajaran)

Kegiatan (misalkan)	Analisis peran	Akibat saat bocor	Bukti
Vendor mengoperasikan 28.000 janji temu per bulan	Medikara pengendali; vendor prosesor untuk kegiatan ini	Pasal 51 ayat (3): termasuk tanggung jawab pengendali	Instruksi dan kontrak
Akun dukungan membaca 1.240 rekam setelah kontrak selesai	Di luar perintah bila terbukti	Pasal 51 ayat (6) mengarah ke vendor; pemberitahuan tetap pada Medikara	Daftar akun dan catatan akses
Vendor melatih produk sendiri	Peran dan dasar perlu dinilai kembali	Vendor dapat dinilai sebagai pengendali untuk kegiatan itu	Keputusan tujuan penggunaan

Tabel 7.15: Lembar hasil Latihan 1

Kegiatan (misalkan)	Analisis peran	Akibat saat bocor	Bukti
…	…	…	…
…	…	…	…

Latihan 2: Dasar Pengobatan

Tentukan dasar pemrosesan yang paling tepat untuk data rekam medis dalam layanan pengobatan. Jelaskan mengapa persetujuan belum tentu menjadi dasar yang terbaik. Latihan ini membuktikan bahwa pilihan dasar punya akibat pada hak dan retensi.

1. Pisahkan tujuan pelayanan, pencatatan, keadaan darurat, dan promosi.
2. Baca kewajiban rekam medis dan Pasal 20 ayat (2) UU PDP.
3. Tuliskan pilihan dasar untuk tiap tujuan.
4. Hitung akibat penarikan persetujuan terhadap retensi dan daftar promosi.

Tabel 7.16 merangkum contoh analisis Latihan 2 dari skenario pembelajaran, dan Tabel 7.17 menyediakan lembar isiannya. Jawaban dasar adalah penafsiran yang harus dipertahankan dengan alasan.

Pertanyaan analisis. Apakah pencabutan persetujuan promosi menghapus rekam medis? Data mana yang tidak diperlukan untuk tujuan pelayanan? Bila formulir lama memakai satu kotak untuk 336.000 janji temu per tahun, baris mana yang diperbaiki lebih dulu?

Tabel 7.16: Contoh analisis Latihan 2 (skenario pembelajaran)

Tujuan	Dasar kandidat	Pertimbangan	Keputusan yang harus dibuktikan
Rekam medis layanan pengobatan	Kewajiban hukum, huruf c	Penarikan persetujuan memicu rentang 72 jam, padahal retensi paling singkat 25 tahun	Dokumentasikan dasar sesuai kewajiban
Pasien gawat darurat tidak sadar	Kepentingan vital, huruf d	Persetujuan tidak dapat diperoleh saat itu	Catat keadaan dan akses darurat
Promosi layanan lain	Persetujuan terpisah, huruf a	Tujuan berbeda; 2.000 pasien turun menjadi 1.850 sesudah 150 penarikan	Nilai dasar tersendiri

Tabel 7.17: Lembar hasil Latihan 2

Tujuan	Dasar kandidat	Pertimbangan	Keputusan yang harus dibuktikan
…	…	…	…
…	…	…	…

Latihan 3: Notifikasi Jumat Malam

Susun garis waktu notifikasi yang memenuhi UU PDP untuk insiden yang ditemukan pada Jumat malam. Latihan ini menguji waktu kalender dan kecukupan informasi.

1. Mulai dari asumsi kegagalan dan penemuan bersamaan Jumat 20.00 WIB, sehingga batasnya Senin 20.00 WIB.
2. Tetapkan eskalasi, penyiapan informasi, dan pengiriman sebelum batas. Sisakan cadangan 12 jam.
3. Tandai informasi yang masih sementara pada setiap langkah.
4. Uji ulang dengan data latihan insiden 2025, ketika bukti menunjukkan kejadian lebih awal.

Tabel 7.18 merangkum contoh analisis Latihan 3 dari skenario pembelajaran, dan Tabel 7.19 menyediakan lembar isiannya.

Pertanyaan analisis. Bagaimana batas berubah bila kejadian ternyata Kamis? Fakta minimum apa yang belum tersedia dan bagaimana pembaruannya dicatat?

Tabel 7.18: Contoh analisis Latihan 3 (skenario pembelajaran)

Waktu (misalkan)	Jam	Tindakan	Bukti
Jumat 20.00	0	Keluhan dieskalasi; waktu diketahui dicatat; jumlah belum diketahui	Tiket layanan pasien
Jumat 21.00	1	Akun dinonaktifkan; fungsi hukum dihubungi	Daftar akun
Sabtu 08.00	12	Jumlah sementara 1.240 rekam	Rekap harian
Sabtu 14.00	18	620 rekam terlacak, 620 rekam tinggal jumlah	Catatan rinci
Minggu 12.00	40	Rancangan disetujui fungsi hukum	Versi rancangan
Senin 08.00	60	Pemberitahuan tertulis dikirim kepada pasien dan lembaga	Bukti pengiriman
Senin 20.00	72	Batas terluar kerja; cadangan 12 jam	Catatan keputusan
Rabu 20.00	120	Pembaruan pertama	Salinan pembaruan

Tabel 7.19: Lembar hasil Latihan 3

Waktu (misalkan)	Jam	Tindakan	Bukti
…	…	…	…
…	…	…	…

Bila jam ke-60 terlewati, siapa memutuskan pengiriman dengan informasi yang belum lengkap?

Bab 8

Merancang Sistem Tata Kelola Target

Tujuan Pembelajaran

- Merancang struktur tata kelola target, termasuk forum keputusan, peran kunci, dan matriks RACI.
- Menetapkan target kapabilitas COBIT dan profil target NIST CSF yang selaras dengan *risk appetite*.
- Mengaitkan praktik ITIL 4 dengan objektif manajemen COBIT untuk menjalankan layanan TI sehari-hari.

8.1 Pendahuluan

Semua pimpinan Medikara menyetujui strategi Satu Pasien, Satu Rekam Medis. Perselisihan baru muncul ketika keputusan nyata datang. Misalkan mitra asuransi meminta integrasi untuk 6.000 klaim per bulan. Tim platform teknologi informasi (TI) ingin segera membuka data, pemilik layanan khawatir terhadap gangguan, dan fungsi hukum meminta pembatasan tujuan. Usulan itu berpindah antarforum selama 4 bulan. Selama itu 24.000 klaim tetap diproses manual, dan belum ada yang dapat menyebut siapa pemutusnya.

Medikara membutuhkan tata kelola yang menjawab dua pertanyaan: siapa menyetujui pembukaan data kepada mitra, dan siapa memegang akuntabilitas atas rekam medis terpadu. Bab 4 sampai Bab 7 sudah memberi bahannya, yaitu enam objektif awal, 12 skenario risiko, 14 baris profil keamanan, dan 13 celah. Bab ini mengubah bahan itu menjadi model tata kelola target untuk tonggak C3

capstone. Model tersebut harus menutup celah C2, sepadan dengan kemampuan organisasi, dan terhubung dengan rancangan tiga mata kuliah lain.

Bab ini memakai panduan desain Control Objectives for Information and Related Technologies (COBIT) 2019 untuk menetapkan target, National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) 2.0 untuk profil target keamanan, dan Information Technology Infrastructure Library (ITIL) 4 untuk praktik layanan. ISO/IEC 38500:2024 dan Three Lines Model dari The Institute of Internal Auditors (IIA) menjadi pegangan pembagian peran. ISO adalah International Organization for Standardization, dan IEC adalah International Electrotechnical Commission. Naskah COBIT, ITIL, dan ISO berbayar, sehingga rinciannya ditulis ringkas dan perlu dicocokkan ke naskah berlisensi sebelum dipakai untuk penilaian formal. Publikasi NIST terbuka. Pilihan target dan angka biaya merupakan skenario pembelajaran [63, 104, 7, 79, 151].

Gambar 8.1 merangkum hubungan komponen dan konsep utama bab ini.



Target kapabilitas dipilih sesuai kebutuhan. Kebijakan, standar, prosedur, dan pedoman memiliki fungsi serta pemilik berbeda.

Gambar 8.1: Rancangan tata kelola target berawal dari celah yang terbukti

8.2 Dari Temuan C2 ke Keputusan Target

Empat tahap panduan desain

Desain target menjelaskan hasil yang ingin dicapai dan cara mempertanggungjawabkannya. Panduan desain COBIT 2019 memuat empat tahap: memahami konteks dan strategi, menetapkan cakupan awal, menyempurnakan cakupan, lalu menyelesaikan konflik dan menyimpulkan rancangan [62]. Tahap akhir memberi tiap objektif terpilih tingkat kapabilitas target [148]. Rancangan ini berulang. Bila konteks, strategi, atau faktor desain berubah, rancangan ditinjau lagi [48].

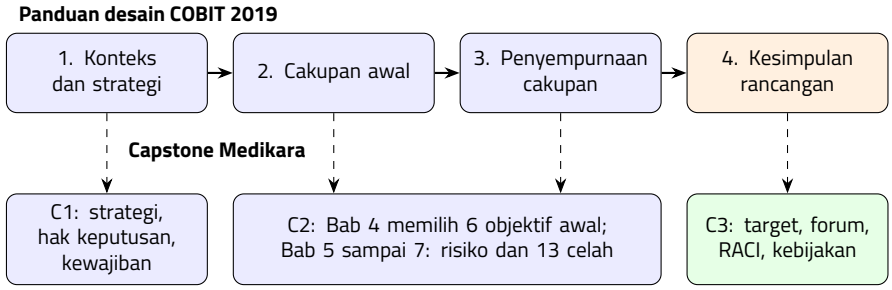
Analogi renovasi rumah memperjelas urutannya. Penghuni menetapkan kebutuhan, memeriksa kondisi, memilih perubahan, lalu menyepakati rancangan serta

biaya. Mengganti seluruh bagian dengan bahan termahal tidak selalu menyelesaikan masalah utama.

Dua contoh menghubungkan target dengan bukti:

1. Misalkan AC-01 baru punya bukti pada 1 dari 5 rumah sakit, atau 12 dari 60 catatan peninjauan per tahun. Target awal adalah peninjauan bulanan dengan bukti pencabutan pada seluruh lokasi, yaitu 60 dari 60 catatan, bukan langsung otomatisasi penuh. Perluasan itu berbiaya Rp60 juta per tahun pada hitungan Bab 5.
2. Misalkan laporan 18 klinik tidak konsisten karena definisi indikator berbeda. Bila tiap klinik memerlukan 2 jam rekonsiliasi per bulan, pekerjaannya 432 jam per tahun, atau Rp25,92 juta pada tarif Rp60.000 per jam dari Bab 7. Target menetapkan pemilik definisi dan aturan rekonsiliasi. Mengganti aplikasi lembar kerja tanpa definisi yang sama hanya menghasilkan angka berbeda lebih cepat.

Gambar 8.2 menempatkan keempat tahap pada urutan capstone. Bab 4 memakai faktor desain untuk memilih enam objektif awal, tetapi berhenti pada kondisi saat ini. Bab ini mengerjakan tahap keempat.



Gambar 8.2: Empat tahap panduan desain dan penerapannya pada capstone

Diagram konsep pada awal bab meringkas urutan kerja yang sama. Temuan kondisi saat ini memberi prioritas perubahan. Prioritas menjadi hasil target beserta cakupan dan syarat penerimaannya. Hasil target menentukan kewenangan yang diperlukan, sehingga forum dan mandat dirancang sesudahnya. Forum membagi tanggung jawab ke dalam matriks *Responsible, Accountable, Consulted, Informed* (RACI) per kegiatan. RACI menetapkan pelaksanaan lewat standar dan prosedur. Standar dan prosedur menghasilkan bukti operasi, lalu bukti penerimaan memverifikasi hasil target. Seksi berikut mengikuti urutan itu.

Dari 13 celah menjadi empat paket

Pertanyaan kemudian muncul: bagaimana memilih target ketika anggaran terbatas? Tim membandingkan dampak celah terhadap batas risiko Bab 5, kewajiban hukum, ketergantungan, dan bukti hasil. Tim juga mencatat inisiatif yang ditunda serta akibat penundaannya.

Bab 6 menghasilkan G-01 sampai G-06, dan Bab 7 menghasilkan CP-01 sampai CP-07, sehingga ada 13 celah. Masing-masing bab memilih tiga prioritas, yaitu G-01, G-03, dan G-05, serta CP-04, CP-01, dan CP-05. Enam prioritas itu saling bertaut. CP-01 dan G-01 sama-sama menyentuh akun vendor. CP-04 dan G-05 sama-sama menyentuh insiden bersama vendor. Tabel 8.1 menyatukannya menjadi empat paket target. Seluruh target merupakan pengandaian.

Tabel 8.1: Empat paket target dari celah prioritas C2 (misalkan)

Paket	Celah	Risiko, kewajiban	Hasil target	Bukti penerimaan
A. Akses vendor	G-01, CP-01	R-01, K-01, K-05	Peninjauan bulanan pada 5 rumah sakit; perjanjian vendor lengkap	120 dari 120 akun cocok; 60 dari 60 catatan AC-01; 11 dari 11 butir perjanjian
B. Pemulihan	G-03	R-05, K-02	Uji pemulihan terjadwal pada 36 fasilitas	144 uji per tahun; hasil disahkan pemilik layanan
C. Insiden dan pemberitahuan	G-05, CP-04	R-01, R-12, K-04, K-05	Prosedur bersama vendor dilatih	2 latihan per tahun; laporan vendor dalam 12 jam; naskah siap sebelum jam ke-60
D. Jejak aktivitas	CP-05, G-02	R-01, R-12, K-01	Catatan rinci disimpan 90 hari dan ditinjau	Uji telusur satu rekam; 247 dari 260 tinjauan mingguan

Tujuh celah sisanya tidak dihapus. G-02 ikut Paket D. CP-06 selesai lewat rancangan peran pada bab ini. CP-03 menjadi syarat alur berbagi data asuransi. G-04, G-06, CP-02, dan CP-07 tetap tercatat dengan pemiliknya dan masuk gelombang kedua. R-11 tetap berada pada jalur pimpinan klinis dengan direktur pelayanan sebagai pemilik risiko, seperti Bab 5.

Keputusan ini punya dua konsekuensi yang dapat dihitung. Pertama, beban kerjanya terukur. Bab 6 menghitung 576 jam per tahun untuk G-01 dan G-03. Bab 7 menghitung 96 jam per tahun untuk latihan pemberitahuan. Misalkan satu tinjauan catatan aktivitas memerlukan 2 jam, sehingga 260 tinjauan memakan 520 jam. Totalnya 1.192 jam per tahun, atau sekitar 0,62 orang penuh waktu pada 1.920 jam kerja per tahun. Dengan tarif Rp60.000 per jam, nilainya Rp71,52

juta. Angka itu hanya waktu staf, dan sebagian sudah termasuk dalam Rp60 juta untuk AC-01 pada Bab 5, sehingga kedua angka tidak dijumlahkan begitu saja. Kedua, penundaan punya akibat. G-04 dan G-06 berkaitan dengan R-02 berskor 12, sehingga R-02 tetap terbuka selama gelombang pertama. Pemilik Sistem Informasi Manajemen Rumah Sakit (SIMRS) perlu mengetahui penundaan itu dan menyetujuinya secara tertulis.

8.3 Menetapkan Target Kapabilitas COBIT

Target tidak sama dengan tingkat tertinggi

Target kapabilitas menyatakan tingkat yang dituju untuk proses pada objektif terpilih. Bab 4 sudah menjelaskan maknanya. Tingkat 2 mencapai tujuan lewat aktivitas dasar yang lengkap. Tingkat 3 memakai cara kerja dan aset organisasi. Tingkat 4 mengukur kinerja secara kuantitatif. Tingkat 5 memakai pengukuran untuk perbaikan berkelanjutan [148]. Tingkat lebih tinggi menuntut lebih banyak aset, pengukuran, dan orang, sehingga tingkat tertinggi bukan tujuan yang berlaku untuk seluruh proses.

Menurut Souza Neto dan rekan, contoh pada panduan desain memberi tingkat 4 untuk skor 75 atau lebih, tingkat 3 untuk skor 50 atau lebih, tingkat 2 untuk skor 25 atau lebih, dan tingkat 1 untuk sisanya. Skor 75 pada contoh itu berarti kepentingan objektif sedikitnya 75 persen lebih tinggi daripada situasi pembanding. Mereka mengkritik satu akibatnya: semua proses pada objektif berskor sama menerima satu tingkat yang sama [148].

Analogi kendaraan rumah sakit menjelaskan pilihan itu. Ambulans diperiksa setiap hari dengan catatan terukur. Mobil pengantar berkas cukup diservis berkala. Menyamakan keduanya menghabiskan biaya tanpa menaikkan keselamatan.

Dua contoh memperlihatkan kesalahan yang sering muncul:

1. Misalkan analis mengubah skor lokal DSS05 pada Bab 4, yaitu 12 dari 15, menjadi 80 persen, lalu memakai ambang 75 sehingga DSS05 mendapat tingkat 4. Hitungan itu salah skala. Skor lokal Bab 4 adalah pengandaian dengan nilai maksimum 15. Ambang 75 berasal dari skor kepentingan relatif pada contoh panduan, dan hanya berlaku pada logika contoh tersebut.

2. Bab 4 membaca studi di rumah sakit Denpasar. Naskah itu menyebut 5 objektif bernilai 75 dan memerlukan tingkat 4, tetapi tabel targetnya mencantumkan tingkat 3 untuk APO12 dan DSS04 [143]. Selisih pada 2 dari 5 objektif mungkin beralasan. Alasan itu perlu tertulis, karena target tanpa alasan tidak dapat diuji ulang.

Target Medikara

Tabel 8.2 menetapkan target 12 bulan untuk enam objektif awal dan BAI06 sebagai dependensi. Kolom bukti C2 bukan tingkat kapabilitas. Selain AC-01 pada DSS05, Bab 4 belum memberi penilaian kapabilitas, sehingga semua target ditandai sementara sampai penilaian lengkap tersedia. SoA pada tabel berarti *Statement of Applicability* dari Bab 6. Gambar 8.3 memperlihatkan bentuknya. Tiga objektif yang berkaitan langsung dengan insiden 2025 dituju pada tingkat 3. Empat objektif lain cukup tingkat 2 pada tahun pertama.

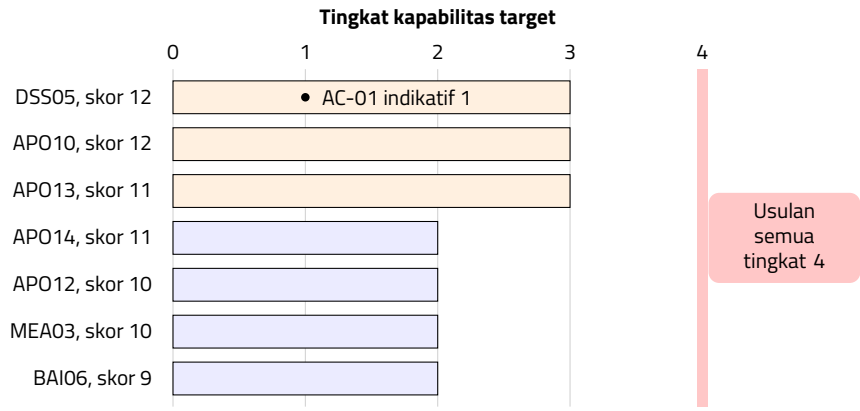
Tabel 8.2: Target kapabilitas Medikara untuk 12 bulan (misalkan)

Objektif	Skor	Bukti C2	Target	Alasan dan bukti penerimaan
DSS05	12	AC-01 indikatif 1, hanya satu rumah sakit	3	Insiden 2025 dan K-01; satu prosedur berjalan di 5 rumah sakit
APO10	12	Perjanjian vendor memuat 6 dari 11 butir	3	K-05 tidak memenuhi; 11 dari 11 butir dan latihan laporan 12 jam
APO13	11	SoA: 87 kontrol diperlukan, 6 dikecualikan	3	Kebijakan dan SoA ditinjau berkala; bukti pada 5 rumah sakit
APO14	11	2.400 dari 96.000 data tidak cocok di Bogor	2	Data tunggal menunggu rancangan IT40613; definisi punya pemilik
APO12	10	12 skenario sudah berpemilik	2	Perlu data dua triwulan lebih dahulu; 12 skenario ditinjau tiap triwulan
MEA03	10	7 dari 16 kewajiban belum diverifikasi	2	16 dari 16 baris register terverifikasi
BAI06	9	8 dari 10 tiket contoh lengkap	2	Dependensi perubahan; 10 dari 10 tiket contoh lengkap, termasuk darurat

Dua objektif sengaja tidak mendapat target pada tabel itu. DSS04 menunggu analisis dampak bisnis pada Bab 10, tetapi 144 uji pemulihan pada Paket B tetap berjalan. APO09 berskor 7 tetap ditunda, walaupun praktik tingkat layanan tetap dipakai pada seksi ITIL. Penundaan target tidak menghentikan pekerjaan yang sudah diwajibkan.

Kasus Medikara Health: Usulan Tingkat 4 untuk Semua Objektif

Misalkan konsultan mengusulkan tingkat 4 untuk ketujuh objektif, dengan alasan angka terukur mudah dilaporkan. Misalkan pula biaya per objektif per



Bulatan: AC-01 pada satu rumah sakit, bukan tingkat DSS05. Biaya per objektif per tahun (pengandaian): tingkat 2 Rp60 juta, tingkat 3 Rp120 juta, tingkat 4 Rp300 juta. Target ditandai sementara sampai penilaian kapabilitas lengkap tersedia.

Gambar 8.3: Target kapabilitas bertingkat dibanding usulan tingkat 4 (misalkan)

tahun Rp60 juta untuk tingkat 2, Rp120 juta untuk tingkat 3, dan Rp300 juta untuk tingkat 4. Pada DSS05, angka Rp120 juta sudah mencakup AC-01 sebesar Rp60 juta. Usulan konsultan menelan 7 kali Rp300 juta, atau Rp2,1 miliar per tahun. Rancangan bertingkat menelan 3 kali Rp120 juta ditambah 4 kali Rp60 juta, atau Rp600 juta. Selisihnya Rp1,5 miliar per tahun.

Keputusan ini punya tiga konsekuensi. Pertama, pada DSS05 saja, kenaikan dari tingkat 3 ke tingkat 4 menambah Rp180 juta. Setelah AC-01, peluang R-01 menjadi 0,05 dengan kerugian rata-rata Rp500 juta, sehingga harapan kerugiannya Rp25 juta per tahun. Sekalipun tingkat 4 menghapus seluruh sisa risiko itu, manfaatnya hanya Rp25 juta. Kedua, peluang kerugian Rp1,5 miliar atau lebih pada R-01 sudah 1 persen, di dalam batas 2 persen pada Bab 5. Ketiga, Rp600 juta melewati batas Rp400 juta, sehingga keputusan tetap naik ke direksi, bukan berhenti di komite pengarah TI.

Hitungan rupiah bukan satu-satunya pertimbangan. Keselamatan pasien dan hak pasien tidak diukur dengan harapan kerugian saja. Target ditinjau lagi bila AC-01 gagal pada tiga peninjauan berturut-turut, bila ada kewajiban baru, atau bila arsitektur target berubah.

Rp600 juta adalah rancangan awal untuk tujuh objektif. Setelah analisis dampak bisnis selesai, Bab 10 menambahkan DSS04 pada tingkat 3 dengan kode T-24. Rancangannya menjadi 4 kali Rp120 juta ditambah 4 kali Rp60 juta, atau Rp720 juta per tahun, dan keputusan tetap berada di direksi. Bab 14 memakai angka Rp720 juta.

Hitungan batas risiko dapat dipakai dengan arah sebaliknya. Misalkan kerugian Rp2 miliar pada R-05 terjadi setiap kali pemulihan gagal. Dengan peluang 0,1, peluang kerugian Rp1,5 miliar atau lebih adalah 10 persen, jauh di atas batas 2 persen. Peluangnya harus turun menjadi seperlima. Karena itu, Paket B tidak dapat dipangkas walaupun skor R-05 lebih rendah daripada R-01.

Pendalaman Teknis (opsional)

Souza Neto dan rekan mengusulkan penyempurnaan. Target ditetapkan satu tingkat demi satu tingkat, dari tingkat 2 sampai tingkat 5. Tiap aktivitas diberi peringkat N, P, L, atau F, dengan *Not* di bawah 15 persen, *Partially* 15 sampai 50 persen, *Largely* 50 sampai 85 persen, dan *Fully* lebih dari 85 persen. Proses naik hanya bila aktivitas pada tingkat itu berperingkat L atau F. Mereka juga memetakan keluaran proses berskor rendah ke proses berskor tinggi. MEA02 mendapat tingkat 2 pada contoh panduan, tetapi mengirim keluaran ke enam objektif berskor tertinggi, sehingga tingkat rendah tidak patut diberikan otomatis [148].

Metode ini usulan penulis, bukan aturan asesmen ISACA. Biaya penilaiannya dapat dihitung dari asumsi Bab 4. Tujuh objektif dengan rata-rata 35 aktivitas berarti 245 aktivitas, atau 122,5 jam pada 30 menit per aktivitas. Pada Medikara, BAI06 berskor paling rendah, tetapi Bab 4 menunjukkan perubahan di rumah sakit Bogor ikut merusak data pada APO14. Keterkaitan seperti itu dapat menjadi alasan menaikkan target BAI06 pada tahun kedua.

8.4 Profil Target NIST CSF

Profil target menyebut hasil yang dipilih

Bab 6 menyerahkan profil target kepada bab ini. Profil target menyebut hasil yang dipilih dan diprioritaskan organisasi untuk mencapai sasaran pengelolaan risiko keamanannya. Profil itu juga memperhitungkan perubahan yang diperkirakan, seperti persyaratan baru, adopsi teknologi baru, dan tren ancaman. Selisih dengan profil saat ini dianalisis, lalu menjadi rencana tindakan berprioritas [104]. Bab 6 mengerjakan langkah 1 sampai 4 untuk profil saat ini dengan pembanding sementara. Bab ini mengisi kolom target pada langkah 3, menyelesaikan analisis celah pada langkah 4, dan menyiapkan langkah 5.

Analogi pemeriksaan kesehatan berkala membantu. Hasil laboratorium menunjukkan keadaan saat ini. Dokter menetapkan sasaran berbeda untuk gula darah, kolesterol, dan tekanan darah sesuai risiko pasien. Tidak semua angka harus sempurna pada bulan yang sama.

Dua contoh menuntut ukuran hasil yang nyata:

1. Misalkan target PR.AA-05 mencakup 5 rumah sakit dalam 6 bulan. Penerimaan memerlukan 30 dari 30 catatan peninjauan selama 6 bulan itu, atau 60 dari 60 per tahun. Pelatihan administrator saja tidak cukup.
2. Misalkan pembukaan data asuransi untuk 72.000 klaim per tahun membutuhkan inventaris alur, penilaian dampak, serta batas akses. Forum arsitektur memeriksa kesesuaiannya dengan rancangan platform IT40613 dan layanan cloud IT40713. NIST juga menyebut profil target dapat menyatakan persyaratan kepada pemasok dan mitra [104]. Karena itu, laporan 12 jam dan 11 butir perjanjian dapat masuk kontrak vendor pada Bab 9.

Tabel 8.3 menyusun profil target Medikara. Empat belas baris pertama berasal dari profil saat ini Bab 6, dengan cakupan 5 rumah sakit dan Medikara+. Dua baris terakhir, GV.PO-01 dan GV.PO-02, ditambahkan karena bab ini menata kebijakan. NIST merumuskan keduanya sebagai kebijakan pengelolaan risiko keamanan yang ditetapkan, dikomunikasikan, ditegakkan, dan ditinjau [104]. Keduanya belum pernah dinilai, sehingga profil menjadi 16 dari 106 subkategori dan kolom saat ini harus diisi lebih dahulu. Pada tabel, Multi-Factor Authentication (MFA) mengikuti Bab 6, dan Gel. 2 berarti gelombang kedua.

Pembacaan tabel memberi dua hal. Pada 14 baris Bab 6, status terbukti naik dari 1 menjadi 11, sebagian turun dari 10 menjadi 2, dan belum ada bukti turun dari 2 menjadi 0. Satu baris tetap tidak relevan. Selain itu, ID.AM-02 dan PR.AA-01 sengaja tetap sebagian, karena G-06 dan G-04 masuk gelombang kedua. Profil target yang semua barisnya terbukti pada tahun pertama sering menandakan pilihan belum dibuat.

Perubahan yang diperkirakan juga masuk rancangan. Bab 7 mencatat Peraturan Pemerintah (PP) 33/2026 berlaku 16 Januari 2027, tetapi naskah resminya belum diperoleh, sehingga aturan itu tetap menjadi butir pemantauan [8]. Rencana modernisasi ke cloud pada IT40713 dapat mengubah cakupan PR.DS-11 dan RC.RP-03. Bila arsitektur berubah, baris yang terkena ditinjau ulang.

Tier tidak dihitung dari profil

Dua hal pada profil target sering tertukar: target hasil dan *tier*. Pembagiannya begini. Target hasil menyebut apa yang harus tercapai. *Tier* menggambarkan ketelitian pengelolaan risiko. NIST mendorong kenaikan *tier* bila risiko atau mandat lebih besar, atau bila analisis biaya dan manfaat menunjukkan penurunan risiko yang layak [104].

Tabel 8.4 melanjutkan batas pada Bab 6. Ketiga ukuran tidak saling dikonversi. Medikara menuju Tier 3 untuk Protect karena R-01 dan K-01 merupakan risiko

Tabel 8.3: Profil target NIST CSF Medikara untuk 12 bulan (misalkan)

Subkategori	Saat ini	Target	Bukti penerimaan	Paket
GV.OC-03	Sebagian	Terbukti	16 dari 16 baris register terverifikasi	Umum
GV.RM-02	Sebagian	Terbukti	Batas diuji dengan satu penyimpangan	Umum
GV.RR-02	Sebagian	Terbukti	Mandat dan RACI disahkan; 120 akun berpemilik	A
GV.SC-07	Sebagian	Terbukti	Tinjauan vendor berkala; 11 dari 11 butir	A, C
ID.AM-02	Sebagian	Sebagian	Rekonsiliasi berjalan pada 2 dari 5 rumah sakit	Gel. 2
PR.AA-01	Sebagian	Sebagian	Nol akun bersama pada sampel 2 rumah sakit	Gel. 2
PR.AA-03	Sebagian	Terbukti	MFA pada 120 dari 120 akun	A
PR.AA-05	Sebagian	Terbukti	120 dari 120 akun cocok; 60 dari 60 catatan	A
PR.AA-06	Tidak relevan	Tidak relevan	Ditinjau bila vendor hadir di lokasi	Umum
PR.PS-04	Terbukti	Terbukti	Cakupan ditambah Medikara+; catatan rinci 90 hari	D
PR.DS-11	Sebagian	Terbukti	Cadangan disertai hasil uji pemulihan	B
DE.CM-03	Sebagian	Terbukti	247 dari 260 tinjauan mingguan	D
RS.MA-01	Belum ada bukti	Terbukti	2 latihan bersama; laporan vendor dalam 12 jam	C
RC.RP-03	Belum ada bukti	Terbukti	144 uji per tahun; hasil disahkan	B
GV.PO-01	Belum dinilai	Terbukti	KB-01 dan KB-05 disahkan serta disosialisasikan	Umum
GV.PO-02	Belum dinilai	Terbukti	8 dari 8 dokumen ditinjau sesuai jadwal	Umum

dan mandat yang besar. Pada Bab 6, Tier 3 berarti praktik disetujui resmi sebagai kebijakan dan diperbarui berkala, sehingga arsitektur kebijakan pada bab ini menjadi syaratnya. Tier 4 memerlukan informasi pemasok yang hampir waktu nyata. Medikara belum menjadikannya target, karena biayanya belum dapat dibenarkan pada tahun pertama.

Tabel 8.4: Tiga target yang tidak saling dikonversi (misalkan)

Ukuran	Saat ini	Target
Status lokal PR.AA-05	Sebagian, bukti 1 dari 5 rumah sakit	Terbukti pada 5 rumah sakit
Tier Protect	Tier 2 pada pembacaan pimpinan	Tier 3 pada pembacaan pimpinan
Tingkat kapabilitas DSS05	Indikatif 1 lewat AC-01 pada satu rumah sakit	Tingkat 3 setelah penilaian lengkap

8.5 Struktur, Forum Keputusan, dan Pemisahan Tugas

Forum dan peran kunci

Hasil target menentukan kewenangan yang diperlukan. Struktur tata kelola membagi hak keputusan dan pengawasan. Forum harus memiliki mandat, anggota, kuorum, jenis keputusan, jalur eskalasi, serta catatan hasil. ISO/IEC 38500:2024 memakai tugas evaluasi, pengarahan, dan pemantauan, lalu menambahkan pelibatan pemangku kepentingan [147]. Peterson memandang struktur, proses, dan hubungan kerja sebagai satu kesatuan [124]. Forum tanpa proses hanya menambah rapat.

Beberapa peran kunci perlu dibedakan. Chief Information Security Officer (CISO), yang pada mata kuliah lain disebut kepala keamanan informasi, mengoordinasikan keamanan. Petugas pelindungan data memberi penilaian sesuai tugas dan independensinya. Pemilik data menetapkan aturan pemakaian data. Pemilik layanan bertanggung jawab atas hasil layanan. Forum arsitektur (*architecture board*) memeriksa kesesuaian rancangan dengan prinsip arsitektur. Rincian forum arsitektur dibahas pada mata kuliah IT40513.

Analogi rapat pengelola gedung menunjukkan perlunya mandat. Petugas perawatan dapat memperbaiki lampu. Ia tidak otomatis berwenang mengubah jalur evakuasi atau menerima risiko keselamatan penghuni.

Dua contoh menghindari persetujuan yang berputar:

1. Misalkan usulan data asuransi berjalan berurutan melewati 4 forum bulanan. Waktu tunggunya paling lama 4 bulan. Dengan 5 menit per klaim, 6.000 klaim manual memakan 500 jam per bulan, atau Rp30 juta per bulan. Empat bulan berarti Rp120 juta. Alur pada Gambar 8.5 selesai dalam 10 hari kerja, sekitar setengah bulan atau Rp15 juta. Selisihnya Rp105 juta, dan tinjauan hukum, privasi, keamanan, serta arsitektur tetap ada.
2. Misalkan Medikara mencatat 40 perubahan per bulan: 30 kecil, 8 biasa, dan 2 darurat. Bila semuanya dibawa ke komite pengarah TI selama 5 menit per usulan, diperlukan 200 menit. Bab 2 menyediakan rapat 120 menit per bulan. Perubahan kecil tampilan janji temu yang tidak mengubah data atau kendali keamanan memakai persetujuan terdelegasi bila kriteria dan bukti pengujiannya terpenuhi.

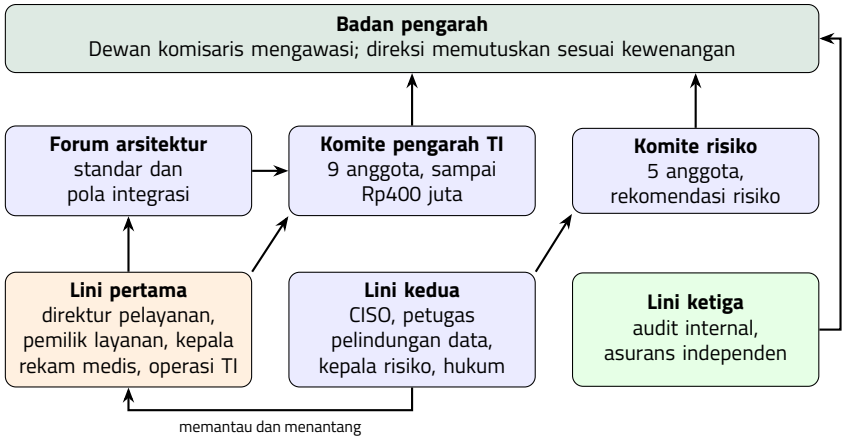
Tabel 8.5 merangkum rancangan forum dan peran. Komite pengarah TI dan batas delegasi mengikuti Bab 2. Keanggotaan komite risiko dan forum arsitektur merupakan pengandaian bab ini. Komite risiko beranggotakan direktur keuangan sebagai ketua, direktur pelayanan, kepala risiko, hukum, dan CISO. Pada tabel, Data Protection Impact Assessment (DPIA) mengikuti Bab 7. Gambar 8.4 menempatkan semuanya pada Three Lines Model dari Bab 1.

Tabel 8.5: Rancangan forum dan peran Medikara (misalkan)

Forum atau peran	Mandat	Aturan kerja	Bukti hasil
Direksi	Risiko di atas batas; keputusan di atas Rp400 juta sampai Rp5 miliar	Laporan triwulan ke dewan komisaris	Keputusan, alasan, batas waktu
Komite pengarah TI	Prioritas dan anggaran lintas fasilitas sampai Rp400 juta	9 anggota, kuorum 6; bulanan 2 jam	Notulen dan pemilik manfaat
Komite risiko	Menelaah risiko di atas batas; memberi rekomendasi ke direksi	5 anggota, kuorum 4; triwulanan 2 jam	Rekomendasi dan pemantauan batas
Forum arsitektur	Kesesuaian rancangan dan pengecualian standar	6 anggota; dua kali sebulan 1 jam; kepala TI memutuskan	Catatan keputusan arsitektur
Direktur pelayanan	Akuntabilitas rekam medis terpadu dan tujuan berbagi data	Naik ke direksi bila melewati batas	Keputusan tujuan dan mutu layanan
Kepala rekam medis	Pemilik data; aturan data rekam medis	Hak henti bila dasar pemrosesan belum ada	Catatan henti dan alasan
Pemilik layanan	Hasil layanan, akses teknis, uji pemulihan	Pengecualian darurat paling lama 24 jam	Catatan AC-01, hasil uji
CISO	Koordinasi keamanan dan tinjauan standar	Lini kedua; tidak menyetujui akses	Pendapat dan temuan tertulis
Petugas pelindungan data	Pendapat DPIA dan pemantauan pemrosesan	1 penuh waktu, 5 koordinator 20 persen	Pendapat DPIA

Penunjukan petugas pelindungan data menutup CP-06. Bab 7 mengandaikan kapasitasnya setara 2 orang penuh waktu, dan kepala TI tidak merangkap peran itu. CISO berada pada lini kedua. Three Lines Model membedakan peran, bukan departemen [151], sehingga bila fungsi keamanan juga menjalankan tinjauan catatan aktivitas pada G-02, peran pelaksana dan peran penantang perlu dipegang orang berbeda.

Pertanyaan berikutnya: apakah Medikara perlu komite risiko terpisah? Biaya forum dapat dihitung. Komite pengarah TI memakan $9 \times 2 \times 12 = 216$ jam orang per tahun. Komite risiko memakan $5 \times 2 \times 4 = 40$ jam. Forum arsitektur



Gambar 8.4: Forum dan peran pada Three Lines Model (misalkan)

memakan $6 \times 1 \times 24 = 144$ jam. Jumlahnya 400 jam, atau sekitar Rp24 juta pada tarif Rp60.000 per jam. Biaya sesungguhnya lebih tinggi karena tarif pimpinan lebih mahal. Pilihan lain adalah agenda risiko triwulanan pada komite pengarah TI, yang menghemat 40 jam tetapi menambah agenda pada rapat 2 jam yang sudah padat. Misalkan Medikara memilih komite terpisah karena R-11 dan K-04 memerlukan pembahasan yang tidak bercampur dengan anggaran. Organisasi kecil dapat memilih sebaliknya. Yang dinilai adalah kemampuan forum mengambil keputusan, bukan banyaknya forum.

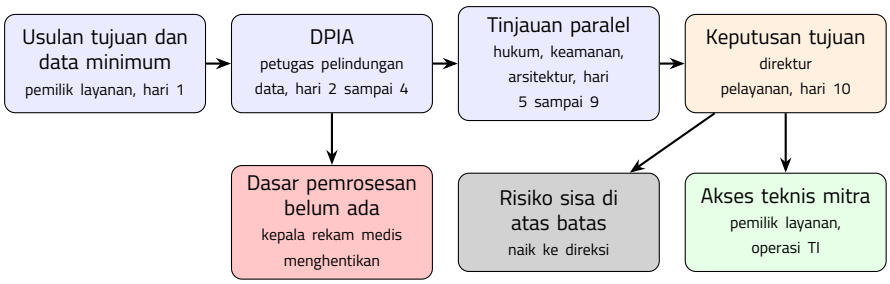
Kasus Medikara Health: Dua Pertanyaan C3

Pertanyaan pertama: siapa menyetujui pembukaan data kepada mitra? Misalkan direktur pelayanan memutuskan tujuan berbagi data. Pemilik layanan mengusulkan tujuan dan data minimum. Petugas pelindungan data menyusun pendapat atas DPIA, yang pada Bab 7 memerlukan 72 jam dalam 3 hari kerja. Hukum, keamanan, dan forum arsitektur meninjau secara paralel selama 5 hari kerja. Kepala rekam medis memegang hak henti sempit bila dasar pemrosesan belum ada. Risiko sisa di atas batas naik ke direksi. Gambar 8.5 merangkum alurnya.

Pertanyaan kedua: siapa memegang akuntabilitas atas rekam medis terpadu? Misalkan direktur pelayanan memegangnya. Peran itu sejalan dengan Bab 2, yang menempatkannya sebagai pemilik manfaat layanan, dan Bab 5, yang menempatkannya sebagai pemilik R-11. Kepala rekam medis menjalankan aturan data. Kepala TI menjalankan platform, tetapi tidak memegang akuntabilitas hasil klinis.

Rancangan ini punya tiga konsekuensi. Pertama, jalur tinjauan menjadi

lebih pendek. Tinjauan berurutan oleh hukum, keamanan, dan arsitektur memakan 15 hari kerja, sehingga seluruh alur menjadi 20 hari kerja. Tinjauan paralel membuatnya 10 hari kerja. Kedua, peluang lolos naik. Bab 2 menghitung empat veto dengan persetujuan 90 persen menghasilkan 65,6 persen. Dengan satu hak henti sempit, angka itu menjadi 90 persen, dan masukan pihak lain wajib didengar serta dijawab tertulis. Ketiga, mandat internal tidak menghapus aturan. Bab 3 mencatat Permenkes 24/2022 Pasal 30: hak akses ditetapkan pimpinan fasilitas [88]. Model menyediakan aturan yang sama, tetapi penetapan pada 36 fasilitas tetap harus ada. Tafsir hukum atas susunan ini perlu dikonfirmasi kepada fungsi hukum.



Gambar 8.5: Alur persetujuan pembukaan data kepada mitra dalam 10 hari kerja (misalkan)

Pemisahan tugas

Pemisahan tugas membatasi pihak yang mengusulkan, menyetujui, menjalankan, dan menguji. NIST menyebut pemisahan tugas sebagai salah satu kontrol akses [112]. Tujuannya sederhana: tidak ada satu orang yang dapat membuat masalah sekaligus menutupinya.

Analogi kas kecil kantor menjelaskan alasannya. Orang yang mengeluarkan uang tidak mencocokkan buku kasnya sendiri. Pencocokan oleh orang lain membuat selisih lebih cepat terlihat.

Dua contoh memperlihatkan penerapannya:

1. Tabel 8.6 menerapkan empat tugas pada AC-01. Administrator tidak menyetujui aksesnya sendiri. Audit internal menguji secara independen, dan contoh pada Bab 6 memakai 30 akun sampel, dengan 24 akun sesuai.
2. Misalkan satu klinik hanya memiliki 1 administrator. Pemisahan penuh tidak mungkin, sehingga Medikara memakai pemeriksaan kompensasi oleh peninjau pusat. Pada 18 klinik, peninjauan bulanan 15 menit per klinik memakan 54 jam per tahun. Potensi konflik dan bukti tinjauannya tetap dicatat.

Tabel 8.6: Pemisahan tugas pada AC-01 (misalkan)

Tugas	Pemegang	Bukti
Mengusulkan	Pengelola vendor	Daftar penugasan dan tanggal berakhir
Menyetujui	Pemilik Medikara+	Persetujuan per akun
Menjalankan	Operasi TI	Tiket pemberian dan pencabutan
Menguji	Audit internal	Hasil uji sampel dan temuan

8.6 Matriks RACI yang Dapat Dipakai

RACI membedakan pelaksana, pemegang akuntabilitas, pihak yang dimintai pertimbangan, dan pihak yang diberi informasi. Dalam rancangan kelas ini setiap baris memiliki satu *Accountable* agar keputusan akhir jelas. Satu orang boleh menjalankan beberapa peran bila kewenangan dan pemisahan tugas tetap dapat dipertanggungjawabkan.

Analogi pengelolaan acara memperjelas pembagian. Banyak panitia menjalankan kegiatan, tetapi satu penanggung jawab menetapkan keputusan akhir untuk satu kegiatan. Bila dua pihak sama-sama menganggap yang lain memutuskan, pekerjaan berhenti.

Dua contoh menunjukkan perlunya unit keputusan yang tepat:

1. Misalkan baris berjudul “mengelola seluruh data” diberi dua *Accountable*, yaitu TI dan pimpinan klinis. Tim memecahnya menjadi aturan rekam medis, tujuan berbagi data, akses teknis, dan uji pemulihan. Satu baris kabur menjadi 4 baris dengan pemegang akuntabilitas yang jelas.
2. Bab 2 menempatkan pemberian akses vendor pada D-06, dengan pemilik Medikara+ sebagai pemutus dan eskalasi ke direktur pelayanan bila kepala TI keberatan. Eskalasi itu tidak menambah pemutus kedua. Model target tetap menulisnya sebagai satu *Accountable*, yaitu pemilik layanan, dan operasi TI sebagai *Responsible*. Keamanan memberi pertimbangan. Administrator tidak menyetujui aksesnya sendiri.

Dua hal sering tertukar: *Accountable* dan *Responsible*. Pembagiannya begini. *Responsible* mengerjakan. *Accountable* menanggung keputusan akhir dan menjawab bila hasilnya gagal. Kepala operasi TI dapat menjalankan 144 uji pemulihan, sedangkan pemilik layanan yang mengesahkan apakah layanannya benar-benar pulih.

Tabel 8.7 merangkum 10 keputusan dengan 9 peran. Salinannya tersedia di `sources/chapter08/contoh-raci-medikara.csv`. Audit internal sengaja tidak masuk matriks, karena peran lini ketiga menguji hasil kerja dan tidak ikut memutuskan.

Tabel 8.7: Contoh RACI keputusan target Medikara (misalkan)

Keputusan	Dir	DP	PL	RM	TI	KA	PD	HK	FA
1. Aturan rekam medis terpadu	I	A	C	R	C	C	C	C	C
2. Tujuan berbagi data mitra	I	A	R	C	I	C	C	C	C
3. Akses teknis mitra	-	I	A	C	R	C	I	I	C
4. Peninjauan akses AC-01	I	I	A	-	R	C	I	-	-
5. Pencabutan akun vendor	-	-	A	-	R	C	I	-	-
6. Perubahan darurat SIMRS	I	C	A	C	R	C	I	-	I
7. Penerimaan risiko di atas batas	A	C	R	C	C	C	C	C	I
8. Uji pemulihan	I	I	A	C	R	C	-	-	I
9. Pemberitahuan insiden data	I	C	C	C	C	R	R	A	-
10. Subprosesor dan penghentian vendor	I	C	A	C	R	C	C	C	C

Dir direksi; DP direktur pelayanan; PL pemilik layanan; RM kepala rekam medis; TI operasi TI; KA keamanan (CISO); PD petugas pelindungan data; HK hukum; FA forum arsitektur.

Matriks itu dapat dibaca seperti data. Huruf A berjumlah 10, dan tiap baris mempunyai tepat satu A. Pemilik layanan memegang 6 dari 10 A. Angka itu aman hanya bila peran tersebut dipegang beberapa orang, misalnya pemilik Medikara+ dan pemilik SIMRS, dengan pengganti yang ditunjuk. Keamanan muncul sebagai C pada 9 dari 10 baris. Misalkan tiap baris terjadi 4 kali per bulan dan satu pertimbangan memerlukan 2 jam. Bebannya $9 \times 4 \times 2 = 72$ jam per bulan, atau 45 persen dari 160 jam kerja. Kolom C terbanyak menjadi antrean. Bila baris 4 dan 5 memakai kriteria tetap sehingga keamanan cukup menjadi I, bebannya turun menjadi 56 jam, atau 35 persen.

RACI tidak menggantikan wewenang dalam piagam atau aturan hukum. Kolom C juga bukan hak veto universal. Jika dua fungsi mempunyai persetujuan terpisah yang wajib, tim membuat baris keputusan masing-masing dan menjelaskan ketergantungannya. Baris 2 dan baris 3 pada tabel adalah contohnya: tujuan disetujui lebih dahulu, baru akses teknis diberikan.

Tiga bacaan memberi gambaran pemakaiannya. Feltus dan rekan mengajukan model tanggung jawab karyawan yang dibangun atas kewajiban, hak, dan komitmen, membandingkannya dengan konsep pada COBIT, lalu mengilustrasikan usulan perubahannya pada bagan RACI [39]. Michałek merancang matriks RACI untuk organisasi proyek matriks dengan pendekatan *design science research*,

menerapkannya pada tiga portofolio proyek pada 2023, lalu memvalidasi serta menyempurnakannya pada 2024 [100]. Hartono dan rekan memakai RACI untuk membagi kegiatan mitigasi setelah analisis risiko pada satu usaha [50]. Abstrak ketiga sumber itu tidak melaporkan angka hasil. Karena itu, bab ini memperlakukan aturan satu *Accountable* sebagai aturan rancangan yang perlu diuji lewat simulasi, bukan temuan yang berlaku umum.

8.7 Arsitektur dan Siklus Hidup Kebijakan

Empat jenis dokumen

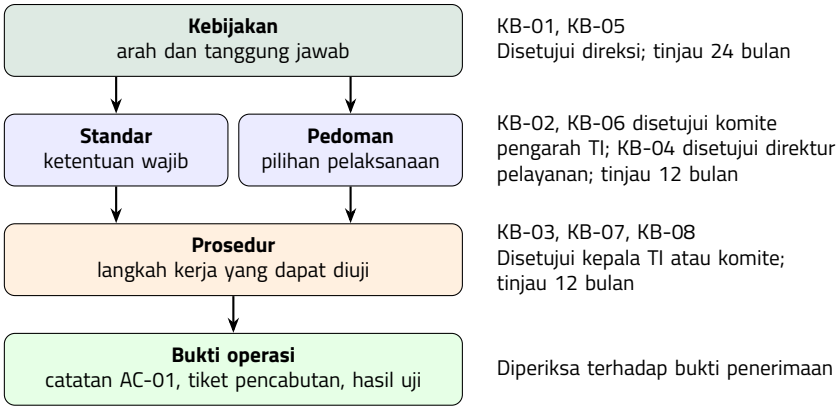
Kebijakan menyatakan arah dan tanggung jawab pada tingkat yang luas. NIST menjelaskan bahwa organisasi karena itu menyusun standar, pedoman, dan prosedur agar pelaksanaannya lebih jelas. Standar biasanya wajib di dalam organisasi. Pedoman membantu pelaksana dan dapat dijalankan dengan lebih dari satu cara. Prosedur merinci langkah untuk menjalankan kebijakan, standar, dan pedoman [112]. Setiap dokumen memiliki pemilik, versi, persetujuan, tanggal berlaku, pelatihan, dan jadwal tinjau.

Analogi aturan perpustakaan memisahkan tingkatnya. Kebijakan menetapkan pelindungan koleksi. Standar menetapkan lama peminjaman. Pedoman membantu petugas menghadapi kasus khusus. Prosedur menjelaskan pencatatan dan pengembalian.

Dua contoh menunjukkan akibat dokumen yang tidak terhubung:

1. Misalkan kebijakan mewajibkan akses sesuai tugas, tetapi prosedur keluar vendor tidak meminta pencabutan akun. Bab 6 menghitung pencabutan turun dari 24 menjadi 9, 5, dan 2 akun setelah prosedur itu diubah. Kalimat kebijakan tidak berubah sama sekali. Yang berubah adalah tautannya dengan langkah kerja.
2. Misalkan standar masa simpan catatan rinci diusulkan menjadi 180 hari. Bab 7 sudah menghitung kenaikan dari 7 menjadi 90 hari menaikkan ruang simpan 12,9 kali. Angka 180 hari menaikkannya 25,7 kali dari 7 hari, dan menggandakan paparan data pribadi dibanding 90 hari. Tim menilai dasar serta tujuan sebelum menyetujui angka. Retensi rekam medis 25 tahun pada K-03 tidak disalin ke semua jenis catatan.

Gambar 8.6 memperlihatkan hubungannya. Standar dan pedoman ditempatkan sejajar, karena keduanya menurunkan kebijakan dengan sifat yang berbeda. Tabel 8.8 menerapkan keempatnya pada akses vendor. NIST juga menyarankan pemisahan yang jelas antara kebijakan dan pelaksanaannya, karena pemisahan itu memberi keleluasaan cara pelaksanaan [112].



Gambar 8.6: Arsitektur kebijakan dan penyetujunya (misalkan)

Tabel 8.8: Hubungan jenis dokumen dan bukti pada akses vendor (misalkan)

Jenis	Isi akses vendor	Bukti
Kebijakan	Akses sesuai kebutuhan dan dapat ditelusuri	Persetujuan serta pemilik
Standar	Akun pribadi, MFA, dan masa berlaku wajib	Daftar syarat pemeriksaan
Pedoman	Contoh akses darurat terbatas	Contoh skenario dan pelatihan
Prosedur	Beri, tinjau, dan cabut akun paling lambat 1 hari kerja	Catatan AC-01 dan tiket pencabutan

Daftar kebijakan dan bebannya

Pertanyaan kemudian muncul: dokumen mana yang benar-benar perlu ditulis? Medikara tidak mulai dari daftar dokumen ideal. Medikara mulai dari celah. Tabel 8.9 menurunkan delapan dokumen dari paket target. Kodenya KB, karena awalan K sudah dipakai register kewajiban Bab 3.

Keputusan ini punya dua konsekuensi. Pertama, bebannya terukur. Misalkan kebijakan ditinjau tiap 24 bulan dan dokumen lain tiap 12 bulan, sehingga ada 7 tinjauan per tahun. Dengan 8 jam per tinjauan, bebannya 56 jam. Pelatihan 2 jam untuk 52 staf TI menambah 104 jam. Jumlahnya 160 jam, atau satu bulan kerja, senilai Rp9,6 juta. Kedua, perubahan menjadi lebih ringan. Direksi hanya menyetujui 2 dari 8 dokumen. Enam dokumen lain dapat berubah tanpa rapat direksi, selama arahnya tetap sama.

Pengecualian

Pengecualian harus menyebut ruang lingkup, risiko sisa, kontrol kompensasi, pemberi persetujuan, dan kedaluwarsa. Tanpa masa berlaku, pengecualian sementara

Tabel 8.9: Daftar kebijakan yang dibuat atau direvisi (misalkan)

ID	Jenis	Nama	Celah	Pemilik	Penyetuju
KB-01	Kebijakan	Akses dan penggunaan data	G-01, G-04	Kepala rekam medis	Direksi
KB-02	Standar	Akun vendor	G-01, CP-01	CISO	Komite pengarah TI
KB-03	Prosedur	AC-01 dan pencabutan	G-01	Pemilik layanan	Kepala TI
KB-04	Pedoman	Akses darurat klinis	R-05, R-11	Pimpinan klinis	Direktur pelayanan
KB-05	Kebijakan	Berbagi data dengan mitra	CP-03	Direktur pelayanan	Direksi
KB-06	Standar	Masa simpan catatan aktivitas	CP-05, G-02	CISO	Komite pengarah TI
KB-07	Prosedur	Pemberitahuan insiden	CP-04, G-05	Fungsi hukum	Komite pengarah TI
KB-08	Prosedur	Uji pemulihan	G-03	Pemilik layanan	Kepala TI

dapat menjadi kebijakan tanpa disadari. Bab 5 sudah memberi contohnya. Vendor meminta 4 akun tetap aktif selama 10 hari, sehingga paparannya 40 akun-hari. Pemilik Medikara+ memberi pengecualian darurat 24 jam, sehingga paparannya 4 akun-hari, atau turun 90 persen. Misalkan pengecualian yang berulang lebih dari tiga kali dibawa ke pemilik standar, karena standarnya mungkin perlu diubah.

8.8 COBIT dan ITIL 4 dalam Operasi Layanan

COBIT membantu memilih hasil tata kelola dan manajemen serta menilai kapabilitas. ITIL 4 membantu organisasi mengelola layanan lewat sistem nilai layanan (*service value system*) dan praktik kerja [64, 7]. Praktik pada ITIL 4 adalah sekumpulan sumber daya organisasi untuk melakukan pekerjaan atau mencapai sasaran. ITIL 4 terbit pada 2019 dengan panduan terpisah untuk 34 praktik [47]. Modul PeopleCert menempatkan *change enablement*, *incident management*, dan *service level management* pada tiga kelompok berbeda [123]. Hubungan COBIT dan ITIL pada bab ini merupakan pemetaan pembelajaran, bukan pernyataan kesetaraan resmi.

Analogi sekolah memisahkan pertanyaan arah dan pelaksanaan. Pengelola menetapkan hasil belajar serta pertanggungjawaban. Guru menyusun cara mengajar dan mengelola kelas. Keduanya perlu terhubung tanpa mengambil alih seluruh tugas pihak lain.

Dua contoh rumah sakit memperlihatkan perannya:

1. Misalkan perubahan SIMRS harus mempertahankan keselamatan dan jejak persetujuan. Bab 4 mengandaikan 8 dari 10 tiket lengkap, dan 2 tiket darurat tanpa analisis dampak. BAI06 memberi arah hasil dan pengawasan, sedangkan *change enablement* membantu penilaian risiko, otorisasi, dan penjadwalan. Sepuluh tiket yang sama menjadi bukti bagi keduanya.
2. Misalkan gangguan integrasi berlangsung 30 menit. Dengan 274 kunjungan per jam pada hitungan Bab 5, gangguan itu menyentuh 137 kunjungan dan memakai 25 persen batas 2 jam per bulan. *Incident management* mengembalikan layanan. PeopleCert menganjurkan insiden dilihat dari sisi pemakai layanan [47]. Analisis masalah berulang dan peninjauan risiko kemudian mengubah cara pengendaliannya.

Tabel 8.10 merangkum pemetaan pembelajaran objektif dan praktik. Nama objektif mengikuti katalog Bab 4. Tingkat layanan pada baris APO09 memakai batas Bab 5: 2 jam gangguan dari 360 jam layanan per bulan, yaitu 12 jam per hari selama 30 hari, setara ketersediaan sekitar 99,44 persen.

Tabel 8.10: Pemetaan pembelajaran objektif COBIT dan praktik ITIL 4 (misalkan)

Objektif COBIT	Praktik ITIL 4	Bukti layanan
BAI06 *Managed IT changes*	*Change enablement*	Penilaian, otorisasi, uji, dan rencana pemulihan
DSS02 *Managed service requests and incidents*	*Incident management*	Kronologi, pemulihan, komunikasi
DSS03 *Managed problems*	*Problem management*	Akar masalah dan perbaikan permanen
APO09 *Managed service agreements*	*Service level management*	Target 2 jam per bulan dan tinjauan hasil
APO10 *Managed vendors*	*Supplier management*	Perjanjian, tinjauan, laporan 12 jam
APO13 *Managed security*	*Information security management*	Kebijakan, SoA, hasil tinjauan

Jenis perubahan perlu dibedakan agar komite tidak tenggelam. Pada 40 perubahan per bulan di atas, 30 perubahan kecil memakai kriteria standar dan disetujui lebih dahulu. Delapan perubahan biasa dinilai oleh pemegang wewenang perubahan. Dua perubahan darurat memakai pengecualian 24 jam dan ditinjau pada rapat berikutnya, sesuai Bab 2. Dalam setahun, 24 perubahan darurat itu layak diperiksa sebagai pola. Bila jumlahnya naik, mungkin yang bermasalah adalah perencanaan rilis.

Tingkat layanan mitra juga dapat dibaca dengan cara yang sama. Bab 3 mengandaikan kontrak mitra asuransi meminta pemberitahuan gangguan dalam 1 jam, dan hanya 2 dari 12 gangguan yang tepat waktu, atau 16,7 persen. *Service level management* menetapkan sasaran yang jelas dan berbasis bisnis [123], sedangkan

APO09 memeriksa apakah sasaran itu dipantau dan dibahas.

PeopleCert juga menyediakan ITIL (Version 5). Halaman resminya menyebut versi ini hasil evolusi yang dibangun di atas konsep kunci ITIL 4: prinsip panduan, sistem nilai layanan, rantai nilai, praktik, dan perbaikan berkelanjutan. Perubahan utamanya mencakup model siklus hidup produk dan layanan, rantai nilai yang disederhanakan, serta istilah dan definisi praktik yang baru [85]. Modul ini menyebut ITIL 4 secara eksplisit agar istilah dan bahan capstone konsisten. Perubahan versi perlu dicatat ketika sumber organisasi memakai versi lain, dan praktik dari beberapa versi tidak dicampur tanpa penjelasan.

8.9 Bukti Penerimaan dan Simulasi Keputusan

Bukti penerimaan menyatakan kapan sebuah target dianggap tercapai. Bukti itu ditetapkan sebelum pekerjaan dimulai, dan diperiksa oleh pihak yang bukan pelaksananya. Diagram konsep menggambarkannya sebagai verifikasi hasil yang kembali ke hasil target. Bila bukti tidak memenuhi, yang ditinjau adalah pelaksanaan, cakupan, atau targetnya.

Analogi serah terima renovasi menjelaskan bedanya. Penghuni tidak cukup menerima nota pembelian keran. Penghuni memutar keran itu dan memeriksa airnya mengalir.

Dua contoh memisahkan kegiatan dari hasil:

1. Misalkan 52 staf TI selesai dilatih tentang AC-01. Pelatihan itu kegiatan. Bukti penerimaannya adalah 120 dari 120 akun cocok, 60 dari 60 catatan, dan audit internal menemukan 30 dari 30 akun sampel sesuai, dibanding 24 dari 30 pada kondisi saat ini.
2. Bab 6 mencatat 150 pekerjaan cadangan berhasil dalam 30 hari. Angka itu bukan bukti pemulihan. Bukti penerimaan Paket B adalah 144 uji per tahun, data contoh pulih, dan hasilnya disahkan pemilik layanan.

Tabel 8.11 menetapkan pemeriksa dan akibat bila bukti gagal untuk keempat paket.

Kasus Medikara Health: Menguji Model dengan Dua Keputusan

Misalkan tim menguji model di atas meja dengan dua keputusan. Keputusan pertama adalah pembukaan data asuransi. Alur selesai pada hari ke-10, tetapi simulasi menemukan bahwa pendapat DPIA tidak punya tempat pada catatan keputusan. Tim menambah kolom itu pada `sources/chapter08/model-tata-kelola-target.md`.

Tabel 8.11: Pemeriksaan bukti penerimaan empat paket (misalkan)

Paket	Bukti operasi	Pemeriksa	Bila gagal
A	Catatan AC-01 dan tiket pencabutan	Audit internal	Pemilik Medikara+ menyusun perbaikan; laporan ke komite risiko
B	Hasil 144 uji pemulihan	Pemilik layanan, lalu audit internal	Uji ulang; R-05 dilaporkan ke direksi
C	Catatan 2 latihan bersama	Petugas pelindungan data	Prosedur KB-07 diubah; latihan diulang
D	Uji telusur satu rekam dan 247 dari 260 tinjauan	CISO	KB-06 ditinjau; tugas peninjau diperjelas

Keputusan kedua adalah perubahan darurat SIMRS yang menghentikan pendaftaran pada jam layanan, ketika pemilik layanan sedang cuti dan tidak ada pengganti. Operasi TI menunggu persetujuan selama 3 jam. Batas Bab 5 adalah 2 jam per bulan, sehingga gangguan itu melampauinya. Dengan 274 kunjungan per jam, gangguan 3 jam setara 822 kunjungan.

Simulasi ini punya dua konsekuensi. Pertama, RACI yang rapi belum menjamin keputusan dapat dibuat. Tim menambah aturan pengganti yang ditunjuk pada baris 6. Kedua, kebuntuan ditemukan tanpa pasien yang terkena. Biaya simulasi 8 orang selama 2 jam hanya 16 jam kerja, atau Rp960.000 pada tarif Rp60.000 per jam.

Pendalaman Teknis (opsional)

Policy as code menerjemahkan sebagian aturan menjadi pemeriksaan otomatis. Open Policy Agent adalah mesin kebijakan sumber terbuka yang memisahkan pengambilan keputusan kebijakan dari penegakannya. Perangkat lunak mengirim masukan terstruktur, lalu menerima keputusan. Aturannya ditulis dalam bahasa Rego, dan dokumentasinya menyebut pemakaian pada Kubernetes serta *pipeline* Continuous Integration / Continuous Delivery (CI/CD) [119].

Misalkan perubahan tanpa pengenal persetujuan ditolak *pipeline*. Pemeriksaan dapat menilai keberadaan pengenal, tetapi tidak membuktikan pertimbangan klinis yang mendasarinya. Titik pemeriksaan dirancang bersama IT40713 tanpa menghilangkan keputusan manusia untuk pengecualian berisiko. Bagian ini opsional, dan hanya dijalankan pada sistem milik tim atau sistem dengan izin tertulis.

8.10 Aktivitas: Model Tata Kelola Target

Tujuan. Tim merancang model tata kelola target berdasarkan kondisi target yang dirancang di tiga mata kuliah lain. Isinya forum keputusan dan perannya, RACI untuk 8 sampai 10 keputusan, target kapabilitas untuk objektif prioritas, profil target NIST CSF, dan daftar kebijakan. Tim memakai organisasi nyata dengan izin dan data yang dianonimkan, atau kasus Medikara Health. Untuk Medikara, model harus menjawab dua pertanyaan: siapa menyetujui pembukaan data ke mitra, dan siapa memegang akuntabilitas atas rekam medis terpadu.

Pembagian peran. Pemilik konteks dan analis regulasi merancang struktur serta mandat. Analis risiko menyelaraskan target dengan *risk appetite*. Analis teknologi memetakan praktik ITIL dan profil keamanan. Satu anggota berlatar nonteknis membaca seluruh rancangan sebagai peninjau.

Langkah kerja.

1. Baca celah C2, register risiko, serta rancangan target IT40513, IT40613, dan IT40713. Satukan celah prioritas menjadi tiga sampai lima paket.
2. Isi `sources/chapter08/target-kapabilitas-csf.csv`. Tulis alasan tiap target, dan bedakan target kapabilitas dari hasil profil CSF.
3. Isi `sources/chapter08/model-tata-kelola-target.md` untuk forum, delegasi, kuorum, eskalasi, dan catatan keputusan.
4. Susun 8 sampai 10 baris dalam `sources/chapter08/raci.csv`. Uji satu *Accountable* per baris, lalu bandingkan dengan `sources/chapter08/contoh-raci-medikara.csv`.
5. Gunakan `sources/chapter08/daftar-kebijakan.csv` untuk dokumen yang dibuat atau direvisi beserta pengecualiannya.
6. Petakan objektif prioritas dengan praktik ITIL 4, dan tandai sebagai pemetaan pembelajaran.
7. Simulasikan persetujuan satu alur data mitra dan satu perubahan darurat. Catat waktu, lalu perbaiki baris yang menimbulkan kebuntuan.

Luaran. Model tata kelola target yang memuat struktur, RACI, target kapabilitas, profil target, daftar kebijakan, dan catatan dua simulasi.

Kaitan dengan capstone. Luaran masuk tonggak C3 Kondisi Target. Forum arsitektur diselaraskan dengan IT40513. Alur data mitra diselaraskan dengan IT40613. Titik persetujuan perubahan diselaraskan dengan IT40713. Target dipakai lagi pada Bab 9, Bab 10, dan Bab 11, lalu diuji pada Bab 12 dan diukur pada Bab 13.

Kriteria penilaian. Keterlacakan celah 30 persen; kejelasan wewenang 30

persen; kelayakan target 25 persen; bukti simulasi 15 persen. Struktur tidak dinilai dari banyaknya komite. Yang dinilai adalah apakah keputusan dapat dibuat dan diuji.

Berkas pendukung. Seluruh lembar kerja ada di `sources/chapter08/`, dengan daftar berkas pada `sources/chapter08/README.md`.

Pendalaman teknis (opsional). Tim dengan anggota berlatar teknis dapat mengenal *policy as code* memakai Open Policy Agent, lalu merancang alur persetujuan perubahan yang menyatu dengan *pipeline* CI/CD bersama IT40713.

8.11 Ringkasan

Desain target berangkat dari celah yang terbukti dan batas risiko. Panduan COBIT menyusunnya dalam empat tahap, dan bab ini mengerjakan tahap terakhir. Tiga belas celah C2 disatukan menjadi empat paket target, sementara celah sisanya tetap tercatat dengan pemilik. Target harus menyebut hasil, cakupan, sumber daya, serta bukti penerimaan.

Tingkat kapabilitas tertinggi tidak otomatis paling tepat. Medikara menuju tingkat 3 pada tiga objektif dan tingkat 2 pada empat objektif, dengan biaya pengandaian awal Rp600 juta per tahun, bukan Rp2,1 miliar, dan Bab 10 menaikkannya menjadi Rp720 juta setelah DSS04 masuk sebagai T-24. Profil target NIST CSF menaikkan status terbukti dari 1 menjadi 11 pada 14 baris Bab 6, dan menyisakan dua baris gelombang kedua secara sengaja. Status lokal, *tier*, dan tingkat kapabilitas tetap tidak saling dikonversi.

Struktur membagi mandat, keputusan, dan eskalasi. Direktur pelayanan memegang akuntabilitas rekam medis terpadu dan memutuskan tujuan berbagi data, dengan hak henti sempit pada kepala rekam medis. Pemisahan tugas mencegah persetujuan atas pekerjaan sendiri. RACI menerjemahkan pembagian itu menjadi 10 keputusan dengan tepat satu pemegang akuntabilitas per baris, dan pembacaan kolomnya menunjukkan antrean seperti beban keamanan 45 persen.

Kebijakan, standar, pedoman, dan prosedur membuat keputusan dapat dijalankan. Delapan dokumen KB diturunkan dari celah, dan pengecualian memiliki batas waktu. COBIT, ITIL 4, dan NIST CSF membantu pertanyaan yang berbeda, dan hubungannya dibuktikan lewat tiket serta hasil layanan yang sama.

Bukti penerimaan menutup lingkaran. Simulasi menemukan kebuntuan sebelum pasien terkena, dan biayanya kecil. Pesan utama bab ini sederhana: tata kelola target berhasil ketika organisasi dapat memutuskan, menjalankan, dan meninjau hasil secara konsisten, bukan ketika struktur dan dokumennya terlihat lengkap.

8.12 Latihan

Latihan 1: Akuntabilitas RACI

Mengapa dalam matriks RACI satu aktivitas hanya boleh memiliki satu pihak *Accountable*? Berikan contoh masalah bila aturan ini dilanggar. Latihan ini membuktikan bahwa dua pemegang akuntabilitas pada satu baris dapat menghentikan keputusan.

1. Pilih satu baris dengan dua *Accountable* dari organisasi tim atau dari contoh.
2. Catat keputusan yang berpotensi tertunda, lalu hitung akibatnya dalam waktu atau biaya.
3. Pecah atau perbaiki baris sesuai wewenang.
4. Uji baris baru dengan satu kejadian nyata atau simulasi.

Tabel 8.12 merangkum contoh analisis Latihan 1 dari skenario pembelajaran, dan Tabel 8.13 menyediakan lembar isiannya.

Tabel 8.12: Contoh analisis Latihan 1 (skenario pembelajaran)

Baris (misalkan)	Masalah	Perbaikan
Setujui semua data: TI dan pimpinan klinis sama-sama A	Masing-masing menunggu; 3 bulan tertunda berarti 18.000 klaim manual, atau Rp90 juta	Pisah tujuan berbagi data (A direktur pelayanan) dari akses teknis (A pemilik layanan)

Tabel 8.13: Lembar isian Latihan 1

Baris	Masalah	Perbaikan
…	…	…
…	…	…

Pertanyaan analisis. Siapa menanggung akibat jika keputusan terlambat? Apakah pemecahan baris tetap memenuhi persetujuan wajib? Pada Tabel 8.7, pemilik layanan memegang 6 dari 10 A. Kapan angka itu menjadi masalah?

Latihan 2: COBIT dan ITIL

Jelaskan perbedaan peran COBIT dan ITIL 4 dengan contoh proses manajemen perubahan di rumah sakit. Latihan ini membuktikan bahwa satu tumpukan bukti dapat melayani dua kerangka tanpa membuat keduanya setara.

1. Pilih satu perubahan SIMRS beserta jenisnya: kecil, biasa, atau darurat.

2. Tentukan hasil dan pengawasan yang dibutuhkan.
3. Hubungkan praktik layanan dengan bukti pelaksanaan.
4. Hitung bukti yang lengkap dari 10 tiket contoh.

Tabel 8.14 merangkum contoh analisis Latihan 2 dari skenario pembelajaran, dan Tabel 8.15 menyediakan lembar isiannya.

Tabel 8.14: Contoh analisis Latihan 2 (skenario pembelajaran)

Kebutuhan	Peran kerangka	Bukti
Perubahan terkendali	COBIT BAI06 memberi arah hasil dan penilaian	8 dari 10 tiket lengkap; angka itu kelengkapan sampel, bukan tingkat kapabilitas
Perubahan dijalankan aman	ITIL 4 *change enablement* membantu praktik	Otorisasi, uji, dan rencana pemulihan pada tiap tiket

Tabel 8.15: Lembar isian Latihan 2

Kebutuhan	Peran kerangka	Bukti
…	…	…
…	…	…

Pertanyaan analisis. Mengapa pemetaan tidak membuktikan kesetaraan? Celah apa tersisa bila tiket lengkap tetapi pemulihan tidak diuji? Mengapa 2 tiket darurat yang gagal lebih berat daripada 2 tiket biasa?

Latihan 3: Target Tingkat 4

Sebuah tim menetapkan target kapabilitas tingkat 4 untuk semua objektif. Kritisi keputusan ini dari sisi biaya dan *risk appetite*. Latihan ini membuktikan bahwa target harus dibenarkan oleh risiko dan bukti, bukan oleh angkanya.

1. Pilih tiga objektif dengan dampak berbeda.
2. Bandingkan biaya tiap tingkat dengan harapan kerugian dan batas risiko terkait.
3. Tetapkan target serta prioritas bertahap.
4. Tulis pemicu yang akan membuat target dinaikkan.

Tabel 8.16 merangkum contoh analisis Latihan 3 dengan biaya pengandaian pada seksi target kapabilitas, dan Tabel 8.17 menyediakan lembar isiannya.

Pertanyaan analisis. Apakah target tinggi menunda kontrol yang mendesak? Bukti apa membenarkan biaya peningkatan berikutnya? Dengan biaya penganda-

Tabel 8.16: Contoh analisis Latihan 3 (skenario pembelajaran)

Objektif	Usulan tingkat 4	Target	Analisis
DSS05	Tambah Rp180 juta dari tingkat 3	3	Sisa harapan kerugian R-01 hanya Rp25 juta; peluang 1 persen di dalam batas 2 persen
APO12	Tambah Rp240 juta dari tingkat 2	2	Data dasar dua triwulan belum ada, sehingga ukuran kuantitatif belum bermakna
BAI06	Tambah Rp240 juta dari tingkat 2	2	8 dari 10 tiket lengkap; lengkapi dahulu 10 dari 10 tiket

Tabel 8.17: Lembar isian Latihan 3

Objektif	Usulan tingkat 4	Target	Analisis
…	…	…	…
…	…	…	…

ian bab ini, berapa selisih biaya bila satu objektif lagi dinaikkan ke tingkat 3?

Bab 9

Risiko Pihak Ketiga dan Cloud

Tujuan Pembelajaran

- Menyusun siklus hidup manajemen risiko pihak ketiga, mulai dari uji tuntas sampai pemutusan kontrak.
- Memetakan pembagian tanggung jawab keamanan antara organisasi dan penyedia cloud.
- Menyusun penilaian dampak pelindungan data pribadi untuk alur berbagi data dengan mitra.

9.1 Pendahuluan

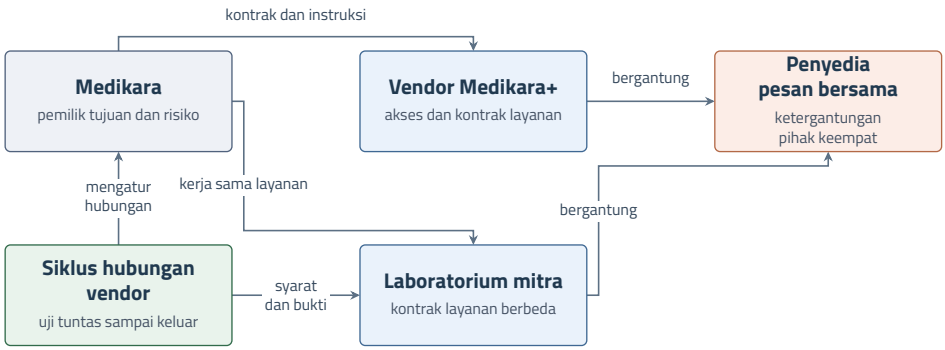
Kebocoran dapat terjadi di vendor, tetapi pasien tetap meminta pertanggungjawaban organisasi yang melayaninya. Insiden Medikara pada 2025 memperlihatkan pola itu. Pada data latihan Bab 7, kontrak pekerjaan vendor sudah selesai, tetapi akun dukungan tetap aktif. Selama 8 malam, akun itu melakukan 155 panggilan per malam dan membaca 1.240 rekam kunjungan pada dua rumah sakit. Medikara baru mengetahuinya pada hari ke-11 lewat keluhan pasien. Risiko pihak ketiga karena itu tidak selesai ketika kontrak ditandatangani atau sertifikat penyedia diterima.

Strategi Medikara membuka kerja sama dengan klinik, asuransi, laboratorium, apotek daring, dan penyedia cloud. Setiap hubungan mempunyai data, ketergantungan, serta hak keputusan berbeda. Pemilihan mitra harus diikuti kendali selama hubungan berlangsung dan cara keluar yang dapat diuji. Bab 8 sudah menetapkan targetnya: Paket A menuntut 11 dari 11 butir perjanjian vendor, dan Paket C menuntut laporan vendor dalam 12 jam. Bab ini menjelaskan cara mencapainya.

Hasil kerjanya adalah kerangka pihak ketiga, matriks tanggung jawab cloud, dan penilaian dampak pelindungan data pribadi, atau *Data Protection Impact Assessment* (DPIA), untuk tonggak C3 capstone.

Bab ini memakai ISO/IEC 27036-2:2022 dari International Organization for Standardization (ISO) dan International Electrotechnical Commission (IEC) untuk hubungan pemasok. Panduan National Institute of Standards and Technology (NIST) SP 800-161 Rev. 1 dipakai untuk risiko rantai pasok, NIST SP 800-145 untuk definisi cloud, serta Cloud Controls Matrix (CCM) dan Consensus Assessments Initiative Questionnaire (CAIQ) dari Cloud Security Alliance (CSA) untuk penilaian cloud. Penilaian dampak merujuk Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi (UU PDP). Naskah ISO berbayar, sehingga isinya ditulis secara umum. Pemetaan tanggung jawab dan klausul contoh adalah rancangan pembelajaran yang harus disesuaikan dengan layanan nyata, bukan nasihat hukum [74, 16, 98, 22, 136].

Gambar 9.1 merangkum hubungan komponen dan konsep utama bab ini.



Dua vendor dapat memiliki satu titik kegagalan bersama. Kontrak dan sertifikat penyedia tidak menghapus tanggung jawab pelanggan.

Gambar 9.1: Risiko konsentrasi tersembunyi di balik beberapa vendor

9.2 Rantai Pasok Digital dan Konsentrasi Risiko

Pihak ketiga dan pihak keempat

Pihak ketiga mencakup vendor aplikasi, penyedia cloud, mitra data, dan layanan pendukung. Pihak keempat adalah pemasok yang dipakai pihak ketiga. NIST CSF 2.0 (Cybersecurity Framework) menyebut teknologi bergantung pada ekosistem pasok yang saling terhubung, dengan beberapa lapis alih daya [104]. Ketergantungan karena itu perlu ditelusuri melampaui nama vendor. Dua kontrak berbeda dapat bergantung pada pusat data atau layanan identitas yang sama.

Analogi pemasok kantin menunjukkan konsentrasi. Dua pedagang yang membeli bahan dari gudang yang sama tidak memberi keragaman pasokan ketika gudangnya tutup. Jumlah kontrak tidak sama dengan jumlah sumber daya yang independen.

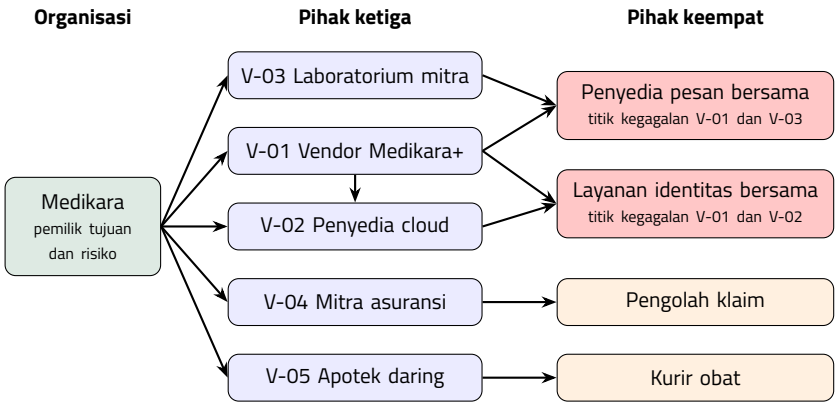
Dua contoh menuntut penelusuran lebih jauh:

1. Misalkan vendor Medikara+ dan laboratorium mitra memakai penyedia pesan yang sama. Layanan pesan itu tersedia 99,5 persen dari 8.760 jam per tahun, sehingga gangguannya 43,8 jam per tahun. Bila kedua jalur benar-benar terpisah dan gangguannya tidak saling terkait, gangguan bersamaan hanya 0,5 persen dikali 0,5 persen, atau 0,0025 persen dari waktu. Angka itu setara sekitar 13 menit per tahun. Bila penyedianya sama, gangguan bersamaan menjadi 43,8 jam, atau 200 kali lipat. Pengingat 336.000 janji temu per tahun ikut terganggu sekitar 0,5 persen, atau 1.680 janji temu. Register Bab 5 mencatat skenario ini sebagai R-08 dengan skor $2 \times 4 = 8$.
2. Misalkan cadangan ditempatkan di akun cloud yang sama dengan produksi. Akun yang diretas dapat membuat kedua salinan tidak dapat digunakan, meskipun medianya berbeda. Bab 3 mencatat 144 uji pemulihan per tahun, yaitu 36 fasilitas dikali 4 uji. Seluruh uji itu dapat lulus tanpa menjawab skenario ini, bila setiap uji memakai akun pengelola yang sama. Bab 10 memakai temuan ini untuk R-05.

Gambar 9.2 memperlihatkan peta ketergantungan pengandaian untuk lima hubungan Medikara. Tabel 9.1 merangkum pertanyaan yang perlu dijawab pada tiap hubungan. Dari lima hubungan itu, penyedia pesan dan layanan identitas masing-masing dipakai dua hubungan. V-01 menyentuh keduanya dan juga memakai V-02, sehingga vendor Medikara+ memiliki 3 penyedia pendukung. Bab 7 memisalkan angka yang sama: Medikara perlu menunjukkan 3 persetujuan tertulis.

Dua hal sering tertukar: jumlah kontrak dan jumlah sumber daya yang independen. Pembagiannya begini. Lima kontrak terlihat seperti lima pilihan. Bila dua di antaranya berhenti karena satu penyedia yang sama, pilihannya tinggal tiga pada saat gangguan. Temuan ini punya dua konsekuensi. Pertama, Medikara memerlukan inventaris layanan pemasok, yang pada NIST CSF tercantum sebagai ID.AM-04 [104]. Kedua, kontrak harus mewajibkan vendor menyebut subprosesornya. Istilah subprosesor pada bab ini sama dengan “prosesor lain” pada Pasal 51 ayat (5) UU PDP [136].

Diagram konsep pada awal bab meringkas pola itu. Medikara memegang tujuan dan risiko. Vendor Medikara+ dan laboratorium mitra terikat kontrak layanan yang berbeda, tetapi keduanya bergantung pada penyedia pesan bersama. Siklus hubungan vendor, dari uji tuntas sampai keluar, mengatur hubungan itu lewat



Gambar 9.2: Peta ketergantungan pihak ketiga dan pihak keempat (misalkan)

Tabel 9.1: Ketergantungan yang perlu ditelusuri (misalkan)

Hubungan	Pihak lanjutan	Pertanyaan
Vendor Medikara+	Penyedia cloud, identitas, pesan, dan staf dukungan	Siapa dapat mengakses data, dan dari mana?
Laboratorium mitra	Penyedia pesan bersama	Apakah ada titik kegagalan bersama?
Cadangan data	Identitas dan akun pengelola	Apakah pemulihan tetap mungkin saat akun utama gagal?
Mitra asuransi	Pengolah klaim	Siapa lagi menerima data klaim, dan untuk tujuan apa?
Apotek daring	Kurir obat	Data apa yang sampai ke kurir?

syarat dan bukti.

Membaca kejadian dan laporan industri

Pertanyaan kemudian muncul: seberapa besar akibat pihak ketiga pada layanan kesehatan? Dua kejadian dan satu laporan memberi pembacaan yang berbeda:

1. Change Healthcare, Amerika Serikat. American Hospital Association (AHA) menyebut perusahaan ini memproses 15 miliar transaksi kesehatan per tahun, termasuk pemeriksaan kepesertaan, farmasi, klaim, dan pembayaran. Serangan terjadi pada 21 Februari 2024. Survei AHA pada 9 sampai 12 Maret 2024 terhadap hampir 1.000 rumah sakit mencatat 94 persen mengalami dampak keuangan, 83 persen dampak pada arus kas, dan 74 persen dampak pada pelayanan langsung pasien [3]. Satu pihak ketiga yang berhenti dapat

menyentuh banyak rumah sakit sekaligus.

2. Synnovis, Inggris. NHS England London melaporkan serangan *ransomware* pada 3 Juni 2024 terhadap laboratorium patologi yang memproses tes darah bagi organisasi National Health Service (NHS), terutama di London bagian tenggara. Laporan mingguannya mencatat janji rawat jalan dan tindakan elektif yang ditunda pada dua *trust* rumah sakit, dengan data manajemen yang belum diverifikasi [111]. Angka rincinya tidak dikutip di sini, karena halaman laporan tidak dapat dibaca utuh saat pemeriksaan. Medikara memiliki laboratorium rujukan dan membuka kerja sama laboratorium mitra, sehingga polanya relevan.

Laporan industri memberi gambaran lebih luas. Ringkasan WaterISAC atas Verizon Data Breach Investigations Report (DBIR) 2026 menyebut keterlibatan pihak ketiga mencapai 48 persen pelanggaran, naik 60 persen dari tahun sebelumnya [160, 162]. Data laporan industri dapat memberi konteks, tetapi persentase global tidak langsung menjadi peluang insiden Medikara. Angka 48 persen adalah bagian dari seluruh pelanggaran yang dilaporkan, bukan peluang satu rumah sakit mengalami insiden. Bab 5 tetap memakai peluang R-01 sebesar 0,2 per tahun, karena angka itu dinilai dari bukti Medikara.

Tabel 9.2 merangkum cara membaca ketiga sumber. Tim memisahkan hasil survei, definisi kejadian, dan bukti organisasi sebelum memakainya untuk keputusan risiko.

Tabel 9.2: Membaca tiga sumber tentang risiko pihak ketiga

Sumber	Jenis data	Yang berguna	Batas pembacaan
Survei AHA	Laporan mandiri, beberapa pekan setelah serangan	Bentuk dampak pada kas dan pelayanan	Dibuat asosiasi rumah sakit; sistem pembiayaannya berbeda
NHS England London	Data manajemen mingguan yang belum diverifikasi	Dampak dinyatakan dalam janji dan tindakan	Angka sementara; ukuran layanan berbeda
DBIR 2026 lewat WaterISAC	Ringkasan laporan industri global	Tren keterlibatan pihak ketiga	Bagian dari pelanggaran, bukan peluang; definisi perlu dibaca pada laporan asli

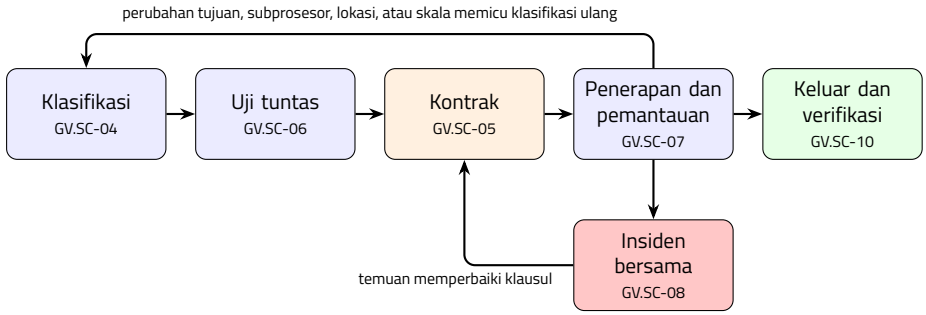
9.3 Siklus Hidup Risiko Pihak Ketiga

Dari klasifikasi sampai keluar

Manajemen pemasok dimulai sebelum pemilihan, dilanjutkan dengan kontrak, penerapan, pemantauan, perubahan, dan penghentian. ISO/IEC 27036-2:2022 membahas persyaratan hubungan pengadaan dan pemasok [74]. NIST SP 800-161 Rev. 1 membahas identifikasi, penilaian, dan pengurangan risiko rantai pasok siber pada semua tingkat organisasi [16]. NIST CSF 2.0 merumuskan hasil yang dituju pada kategori GV.SC, dan menyebut SP 800-161 sebagai bacaan mendalam [104]. Bab 8 menargetkan objektif COBIT APO10 *Managed vendors* pada tingkat 3 [64].

Analogi menyewa kendaraan memperjelas siklusnya. Penyewa memeriksa kondisi sebelum menerima, mencatat aturan penggunaan, memantau gangguan, lalu memeriksa keadaan saat mengembalikan. Tanda tangan awal tidak menyelesaikan seluruh tanggung jawab.

Gambar 9.3 memperlihatkan siklus kendali pihak ketiga dari klasifikasi sampai keluar. Tabel 9.3 memasangkan tiap tahap dengan hasil NIST CSF dan bukti pada Medikara. Rumusan hasil pada tabel adalah ringkasan bab. Dari enam baris itu, hanya GV.SC-07 yang masuk profil target Bab 8. Lima baris lain dipakai sebagai pertanyaan kerja, tanpa mengubah profil 16 dari 106 subkategori.



Gambar 9.3: Siklus kendali pihak ketiga dari klasifikasi sampai keluar

Klasifikasi: seberapa dalam pemeriksaannya?

Klasifikasi menentukan kedalaman pemeriksaan. Tiga pertanyaan cukup untuk memulai: data apa yang disentuh, layanan apa yang berhenti bila pihak itu gagal, dan seberapa sulit menggantinya. Pemeriksaan yang sama untuk semua pemasok memboroskan tenaga pada pemasok kecil dan mengurangi perhatian pada pemasok kritis.

Tabel 9.3: Tahap siklus, hasil NIST CSF, dan bukti Medikara (misalkan)

Tahap	Hasil	Ringkasan hasil	Bukti pada Medikara
Klasifikasi	GV.SC-04	Pemasok dikenal dan diprioritaskan menurut kekritisan	Register pemasok dengan skor
Uji tuntas	GV.SC-06	Perencanaan dan uji tuntas sebelum hubungan resmi	Kuesioner beserta bukti dan cakupan
Kontrak	GV.SC-05	Persyaratan masuk kontrak dan perjanjian	11 dari 11 butir; klausul K-05
Penerapan dan pemantauan	GV.SC-07	Risiko dinilai dan dipantau sepanjang hubungan	60 dari 60 catatan AC-01; tinjauan triwulanan
Insiden bersama	GV.SC-08	Pemasok dilibatkan dalam rencana insiden dan pemulihan	2 latihan per tahun; laporan 12 jam
Keluar	GV.SC-10	Rencana mencakup kegiatan setelah hubungan berakhir	Hasil uji ekspor dan bukti penghapusan

Analogi tamu rumah sakit membantu. Pengantar bunga cukup mendaftar di lobi. Teknisi yang masuk ruang obat perlu surat tugas, pendamping, dan catatan keluar. Keduanya tamu, tetapi risikonya berbeda.

Dua contoh menentukan tingkat pemeriksaan:

1. Misalkan penyedia cetak materi umum tidak menerima data pribadi dan mudah diganti. Skornya 1 dari 9, sehingga pemeriksaan dasar memadai. Vendor Medikara+ mengolah data kesehatan untuk 28.000 janji temu per bulan dan mendukung layanan lintas fasilitas. Skornya 9 dari 9. Uji akses, insiden, pemulihan, subprosesor, serta strategi keluar menjadi prioritas.
2. Misalkan register pemasok memuat 40 hubungan: 5 tingkat terperinci, 12 menengah, dan 23 dasar. Pemeriksaan memakan 40, 16, dan 4 jam per hubungan. Totalnya 200 tambah 192 tambah 92, atau 484 jam, yaitu Rp29,04 juta pada tarif Rp60.000 per jam dari Bab 7. Bila seluruh 40 hubungan diperiksa terperinci, diperlukan 1.600 jam atau Rp96 juta. Pembagian tingkat menghemat 1.116 jam, sekitar 70 persen, dan pemeriksaan terperinci tetap jatuh pada hubungan penting.

Tabel 9.4 menerapkan skala pengandaian pada enam hubungan. Kolom Data, Kritis, dan Ganti menilai akses data, kekritisan layanan, dan kesulitan mengganti, masing-masing 0 sampai 3. Skor 7 sampai 9 berarti terperinci, 4 sampai 6 menengah, dan 0 sampai 3 dasar. Salinannya tersedia di `sources/chapter09/klasifikasi-vendor.csv`. Skala ini rancangan pembelajaran, bukan rumus

standar.

Tabel 9.4: Klasifikasi enam hubungan Medikara (misalkan)

ID	Hubungan	Data	Kritis	Ganti	Skor	Tingkat
V-01	Vendor Medikara+	3	3	3	9	Terperinci
V-02	Penyedia cloud	3	3	2	8	Terperinci
V-03	Laboratorium mitra	3	3	2	8	Terperinci
V-04	Mitra asuransi	3	2	2	7	Terperinci
V-05	Apotek daring	2	2	1	5	Menengah
V-06	Penyedia cetak materi	0	0	1	1	Dasar

Klasifikasi tidak sekadar menghasilkan warna. Vendor kritis harus memiliki pemilik hubungan, jadwal tinjau, indikator, pemicu eskalasi, dan rencana bila gagal. Misalkan 5 hubungan terperinci ditinjau tiap triwulan selama 8 jam. Bebannya 5 dikali 4 dikali 8, atau 160 jam per tahun, atau Rp9,6 juta. Perubahan subprosesor, lokasi, atau tujuan data memicu pemeriksaan ulang sebelum persetujuan perubahan.

Uji tuntas: dari jawaban ke bukti

Uji tuntas meminta bukti, bukan janji. Tim menanyakan siapa mengakses data, di mana data berada, siapa subprosesornya, dan kapan pemulihan terakhir diuji. Tiap jawaban lalu dinilai dari jenis buktinya. Daftar sepuluh pertanyaan tersedia di `sources/chapter09/kuesioner-uji-tuntas.md`.

Analogi membeli rumah bekas menjelaskan bedanya. Penjual berkata atapnya tidak bocor. Pembeli melihat langit-langit saat hujan dan meminta catatan perbaikan. Jawaban penjual tetap berguna, tetapi hanya sebagai titik awal pemeriksaan.

Dua contoh menunjukkan batas jawaban:

1. Misalkan vendor menjawab ya pada 10 dari 10 pertanyaan. Saat bukti diminta, 7 jawaban memiliki bukti dalam cakupan layanan, 2 memiliki bukti di luar cakupan, dan 1 tanpa bukti. Yang dapat diandalkan 7 dari 10, atau 70 persen, bukan 100 persen. Tiga baris sisanya menjadi syarat kontrak atau risiko sisa yang diputuskan.
2. Skor keamanan eksternal disusun dari informasi publik, tanpa masuk ke sistem pemasok. Keskin dan rekan membandingkan metode semacam itu dan menyimpulkan skornya memiliki kemiripan, tetapi tidak sepenuhnya menyatu untuk organisasi yang sama [91]. Misalkan dua layanan memberi vendor yang sama nilai 85 dan 62 dari 100. Selisih 23 poin itu bukan keputusan. Tim memakainya untuk memilih pertanyaan lanjutan.

Tabel 9.5 menyusun empat jenis bukti, dari yang paling lemah sampai yang paling kuat. Urutan ini penafsiran bab. Bukti yang kuat juga lebih mahal, sehingga uji bersama dipilih untuk hubungan terperinci.

Tabel 9.5: Empat jenis bukti uji tuntas (penafsiran bab)

Jenis	Contoh	Yang perlu diperiksa
1. Jawaban vendor	Kuesioner, CAIQ	Tanggal dan siapa yang menjawab
2. Dokumen vendor	Kebijakan, prosedur	Apakah dijalankan pada layanan yang dibeli
3. Laporan independen	Sertifikat, laporan SOC 2	Cakupan, periode, dan pengecualian
4. Uji bersama	Uji ekspor, latihan insiden, uji pemulihan	Hasil, kekurangan, dan uji ulang

Pemantauan dan perubahan

Kontrak yang baik dapat melemah selama masa berlakunya. GV.SC-07 meminta risiko pemasok dipantau sepanjang hubungan [104]. Pemantauan memakai indikator yang punya ambang, pemilik, dan tindakan. Laporan tahunan vendor saja tidak memenuhi kebutuhan itu.

Analogi katering kantor menunjukkan alasannya. Dapur yang baik pada Januari belum tentu baik pada Juni. Pengurus kantor mencicipi contoh, mencatat keterlambatan, dan menanyakan pergantian pemasok bahan.

Dua contoh memperlihatkan pemantauan yang berguna:

1. Bab 6 memisalkan pencabutan AC-01 turun dari 24 akun menjadi 9, 5, dan 2 akun. Penurunan itu hanya berarti bila seluruh 120 akun tercakup, karena sebelumnya 12 akun luput. Peninjauan bulanan pada 5 rumah sakit menghasilkan 60 catatan per tahun. Bab 8 menetapkan 60 dari 60 catatan dan 120 dari 120 akun cocok sebagai bukti penerimaan.
2. Misalkan kontrak meminta pemberitahuan 30 hari sebelum subprosesor berganti. Alur tinjauan paralel Bab 8 memakan 10 hari kerja, sekitar 14 hari kalender. Sisa 16 hari dipakai untuk menguji layanan pengganti. Bila vendor hanya memberi tahu 7 hari sebelumnya, tinjauan tidak selesai, dan keputusan menjadi menerima risiko atau menunda perubahan.

Tabel 9.6 merangkum indikator awal untuk hubungan terperinci. Bab 13 mengolahnya menjadi indikator risiko dengan batas dari Bab 5.

Tabel 9.6: Indikator pemantauan hubungan terperinci (misalkan)

Indikator	Ambang	Tindakan bila terlewati	Pemilik
Akun vendor tanpa pemilik	0 akun (Bab 5)	Bekukan akun dan catat penyimpangan	Pemilik Medikara+
Catatan peninjauan AC-01	60 dari 60 per tahun	Eskalasi ke kepala TI	Pemilik layanan
Laporan dugaan insiden	12 jam (K-05)	Catat pelanggaran kontrak dan tagih perbaikan	Pengelola vendor
Latihan insiden bersama	2 per tahun	Masuk temuan Paket C	Petugas pelindungan data
Pemberitahuan subprosesor	30 hari sebelumnya	Tunda perubahan atau putuskan risiko sisa	Pemilik layanan
Uji ekspor	1 per tahun	Tinjau ulang skor R-10	Pengelola vendor

Strategi keluar

Strategi keluar menjawab cara mengakhiri hubungan tanpa menghentikan layanan dan tanpa meninggalkan data. GV.SC-10 meminta rencana mencakup kegiatan setelah hubungan berakhir [104]. Rencana itu mencakup ekspor, pemindahan, pencabutan akses, dan penghapusan yang terverifikasi. Kata "keluar" juga berlaku bagi vendor yang gagal mendadak.

Analogi pindah kontrakan membantu. Penyewa yang baik tahu barang apa yang miliknya, berapa lama mengangkutnya, dan siapa memegang kunci terakhir. Kontrak sewa yang menyebut "boleh pindah kapan saja" tidak menjawab ketiga hal itu.

Dua contoh menunjukkan mengapa keluar perlu diuji:

1. Misalkan vendor menjanjikan ekspor data, tetapi hanya menyediakan gambar dokumen tanpa metadata. Tim menguji format, kelengkapan, waktu, dan biaya ekspor sebelum menerima layanan. Pada uji dengan 10.000 rekam sintetis, 9.600 rekam terbaca mesin, atau 96 persen. Sisa 4 persen dari 336.000 rekam janji temu per tahun adalah 13.440 rekam. Dengan 5 menit per rekam, pekerjaan manualnya 1.120 jam, atau Rp67,2 juta.
2. Bab 5 memisalkan R-10 berpeluang 0,1 per tahun dengan kerugian Rp800 juta, yang berasal dari migrasi darurat 3 bulan pada 84.000 janji temu. Harapan kerugiannya Rp80 juta per tahun. Tabel 9.7 membandingkan dua opsi pada latihan bab itu.

Tabel 9.7: Dua opsi penanganan R-10 (misalkan, mengikuti Bab 5)

Opsi	Biaya sekali	Harapan setelahnya	Turun per tahun	Balik modal	Pemutus
Uji ekspor dan pendampingan	Rp60 juta	0,1 kali Rp300 juta, atau Rp30 juta	Rp50 juta	1,2 tahun	Kepala TI
Ganti vendor segera	Rp300 juta	0,05 kali Rp800 juta, atau Rp40 juta	Rp40 juta	7,5 tahun	Komite

Perbandingan ini punya dua konsekuensi. Pertama, mengganti vendor bukan otomatis pilihan yang paling aman. Vendor baru dapat memakai subpenyedia yang sama, sehingga R-08 tidak berubah. Kedua, uji ekspor memberi manfaat lebih cepat, tetapi tidak menghapus keahlian yang hanya dimiliki vendor. Risiko sisanya tetap dicatat.

Kasus Medikara Health: Lima Hubungan, Dua Prioritas

Tim mengisi register pemasok dan mendapat empat hubungan terperinci dari lima hubungan target. Aktivitas bab ini meminta dua hubungan paling kritis. V-01 jelas terpilih dengan skor 9. V-02 dan V-03 sama-sama 8. Tim memakai satu pemutus tambahan, yaitu jumlah layanan yang berhenti. V-02 menampung seluruh platform target, sehingga V-02 dipilih.

Keputusan ini punya dua konsekuensi. Pertama, V-03 tetap diperiksa terperinci, tetapi klausul lengkapnya disusun pada gelombang berikutnya, dan risikonya tetap tercatat pada R-08. Kedua, biaya perlu diakui terus terang. Bab 8 menganggarkan Rp120 juta per tahun untuk APO10 tingkat 3. Harapan kerugian R-10 turun Rp50 juta per tahun bila uji ekspor dilakukan. Selisihnya dibenarkan oleh K-05 yang berstatus tidak memenuhi dan oleh hak pasien, bukan oleh hitungan rupiah semata. Pemilik layanan memegang akuntabilitas atas subprosesor dan penghentian vendor, sesuai baris 10 RACI Bab 8.

9.4 Klausul Kontrak dan Kewajiban Prosesor

Dari janji menjadi ukuran

Kontrak menerjemahkan kebutuhan kendali menjadi kewajiban yang dapat ditagih. Unsur penting meliputi instruksi pemrosesan, pembatasan tujuan, akses, subprosesor, bukti kontrol, insiden, pemulihan, dan pengembalian atau penghapusan

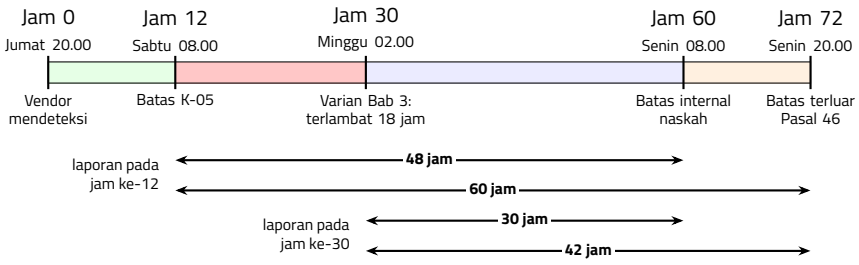
data. Ketentuan prosesor harus diperiksa terhadap UU PDP, bukan hanya janji kerahasiaan umum. Pasal 51 mewajibkan prosesor bekerja berdasarkan perintah pengendali. Pasal 52 memberlakukan sejumlah kewajiban pengendali kepada prosesor [136]. Bab 7 sudah membaca pasal-pasal itu, dan bab ini mengubahnya menjadi klausul.

Analogi jasa pengiriman membantu membedakan janji dan bukti. Pernyataan barang dijaga belum menjelaskan siapa menerima, kapan keterlambatan diberitahukan, dan bagaimana kehilangan ditangani. Kontrak membutuhkan ukuran serta jalur pelaksanaan.

Dua contoh menunjukkan akibat klausul yang kabur:

1. Misalkan kontrak hanya meminta pemberitahuan insiden secepatnya. Medikara tidak dapat menagih apa pun karena tidak ada batasnya. Register Bab 3 menetapkan batas kontraktual 12 jam sejak vendor mendeteksi dugaan insiden (K-05), beserta pembaruan berkala. Angka ini pilihan kontrak, bukan tenggat undang-undang. Bila vendor mendeteksi pada Jumat 20.00, batasnya Sabtu 08.00.
2. Misalkan kontrak berbunyi vendor menjaga kerahasiaan data. Kalimat itu tidak berkata apa pun tentang akun yang tetap aktif setelah pekerjaan selesai, padahal itulah sebab insiden 2025. Klausul pengganti menuntut tiap akun punya pemilik dan tanggal berakhir, dan akun dicabut paling lambat 1 hari kerja setelah penugasan selesai. Buktinya 120 dari 120 akun cocok dengan daftar penugasan.

Gambar 9.4 menempatkan klausul 12 jam pada garis waktu Bab 7. Laporan tepat waktu menyisakan 48 jam sampai batas internal jam ke-60 dan 60 jam sampai batas terluar. Varian Bab 3, yaitu laporan setelah 30 jam, melanggar kontrak 18 jam dan menyisakan 30 jam serta 42 jam. Hitungan ini mengandaikan kegagalan dan penemuan bersamaan, seperti asumsi Bab 3 dan Bab 7. Pasal 46 ayat (1) tidak memakai frasa sejak diketahui secara eksplisit, sehingga fungsi hukum menetapkan titik mulainya.



Gambar 9.4: Klausul laporan 12 jam pada garis waktu pemberitahuan (misalkan)

Dua hal pada kontrak sering tertukar: ganti rugi dan tanggung jawab. Pembagiannya begini. Ganti rugi dapat memindahkan biaya. Biaya langsung insiden pada hitungan IT40613 adalah Rp14,4 juta untuk penanganan dan Rp9,3 juta untuk pemberitahuan kepada 620 pasien, atau Rp23,7 juta. Vendor dapat diminta mengganti angka itu. Kewajiban memberi tahu menurut Pasal 46 tetap berada pada Medikara sebagai pengendali [136]. Kepercayaan pasien juga tidak berpindah lewat kontrak.

Tabel 9.8 merangkum sembilan pokok klausul beserta ukuran penerimaan dan bukti. Lembar kerjanya ada di `sources/chapter09/klausul-kontrak.md`. Ukuran internalnya mengikuti dokumen Bab 8: KB-02 untuk akun vendor, KB-03 untuk pencabutan, dan KB-07 untuk pemberitahuan insiden. Isinya rancangan pembelajaran, bukan naskah siap tanda tangan.

Tabel 9.8: Klausul contoh dan bukti penerimaan (misalkan)

Pokok	Ukuran penerimaan	Bukti
Instruksi dan batas tujuan	Tujuan tertulis; perubahan lewat persetujuan	Daftar instruksi berversi
Pengguna dan peninjauan akses	Pemilik dan tanggal berakhir; cabut dalam 1 hari kerja	120 dari 120 akun cocok; AC-01
Subprosesor	Persetujuan tertulis; pemberitahuan 30 hari	Daftar penerima dan persetujuan
Lokasi dan akses dukungan	Di dalam wilayah Indonesia, kecuali izin sesuai Pasal 972	Inventaris lokasi data, cadangan, dan akses
Laporan dugaan insiden	Laporan awal 12 jam; 2 latihan per tahun	Kronologi dan hasil latihan
Catatan aktivitas	Per orang; disimpan 90 hari	Uji telusur satu rekam
Pemeriksaan dan asurans	Bukti dapat ditinjau sesuai cakupan	Laporan, pengecualian, dan tindak lanjut
Ekspor dan biaya keluar	Format dan tenggat disepakati; ekspor lengkap	Hasil uji ekspor tahunan
Penghapusan dan cadangan	Terverifikasi, termasuk salinan cadangan	Berita acara penghapusan

Enam dari sebelas butir

Pertanyaan berikutnya: butir apa yang perlu ditawar ulang? Salinan pihak ketiga PP 33/2026 Pasal 14 memuat 11 butir minimum perjanjian, antara lain cakupan, jenis data, jangka waktu, serta mekanisme pengawasan dan audit [99, 142]. Peraturan itu baru berlaku 16 Januari 2027 dan naskah resminya belum diperoleh, sehingga bab ini memakainya sebagai daftar periksa, bukan kewajiban.

Bab 7 memisalkan perjanjian vendor Medikara+ hanya memuat 6 dari 11 butir, dan Bab 8 menargetkan 11 dari 11. Rincian kelima butir kosong belum dapat

dicocokkan ke naskah resmi. Tim karena itu memetakannya ke lima pokok kontrol berikut, dan pemetaan ini penafsiran bab:

1. instruksi pemrosesan yang tertulis,
2. daftar akun dan subprosesor,
3. pencabutan akses saat penugasan selesai,
4. mekanisme pengawasan dan audit,
5. pengembalian dan penghapusan data saat kontrak berakhir.

Tiga pokok pertama menjawab CP-01 pada Bab 7. Laporan 12 jam tidak masuk daftar ini, karena klausulnya sudah ada pada K-05. Masalah K-05 adalah pelaksanaan, sehingga jawabannya latihan bersama, bukan kalimat baru. Waktu pulih kontrak juga berada di luar kelima pokok ini. Bab 10 memisalkan kontrak V-01 menjanjikan pemulihan 24 jam dan layanan identitas 8 jam, lalu membawa selisihnya terhadap RTO ke tawar ulang tersendiri. Bila naskah resmi tersedia, tim mencocokkan ulang kelima pokok itu.

Peran menentukan klausul

Tidak semua hubungan memakai kontrak yang sama. Tabel 9.9 memperlihatkan peran awal tiap hubungan. Bab 7 sudah menempatkan vendor sebagai prosesor untuk janji temu dan mitra asuransi sebagai pengendali terpisah, dan keduanya penafsiran yang perlu ditinjau fungsi hukum. Panduan European Data Protection Board menyebut peran ditentukan kegiatan nyata, bukan sebutan dalam kontrak [34]. Panduan itu tidak mengikat di Indonesia.

Tabel 9.9: Peran awal tiap hubungan dan akibatnya pada kontrak (penafsiran bab)

Hubungan	Peran awal	Akibat pada kontrak
Vendor Medikara+	Prosesor	Perintah tertulis; persetujuan subprosesor; Pasal 51 dan Pasal 52
Penyedia cloud	Prosesor atau subprosesor	Syarat Pasal 966 ayat (5) PP 28/2024; data dikendalikan penuh Medikara
Laboratorium mitra	Perlu analisis per kegiatan	Hasil kepada dokter berbeda dari layanan laboratorium untuk tujuan sendiri
Mitra asuransi	Pengendali terpisah	Tujuan, dasar, dan data minimum; DPIA sebelum aktif
Program kesehatan karyawan	Pengendali bersama bila tujuan ditentukan bersama	Syarat Pasal 18; perusahaan hanya menerima hasil agregat

Perjanjian dengan mitra sektor keuangan dapat membawa persyaratan tambahan melalui kontrak. Tim memeriksa pihak yang langsung diatur, dasar ke-

tentuan, dan bagian yang mengalir kepada Medikara. Aturan untuk lembaga jasa keuangan tidak otomatis berlaku langsung kepada semua penyedia layanan kesehatan. Bab 3 mencatat dua baris yang berbeda: K-15 tidak berlaku karena Medikara bukan lembaga jasa keuangan nonbank, sedangkan K-12 mengikat lewat kontrak. K-12 meminta Medikara melapor gangguan kepada mitra asuransi dalam 1 jam, dan contoh Bab 3 mencatat hanya 2 dari 12 gangguan tepat waktu. Kewajiban kontrak karena itu berjalan dua arah. Medikara menagih vendor, dan mitra menagih Medikara.

Kasus Medikara Health: Tiga Klausul yang Menjawab Insiden 2025

Tim menguji klausul terhadap kronologi Bab 7. Akun dukungan tetap aktif setelah kontrak pekerjaan selesai, panggilan berlangsung 8 malam, dan catatan rinci hanya disimpan 7 hari. Catatan itu juga hanya memuat ID aplikasi, bukan ID orang.

Klausul pertama mencabut akun paling lambat 1 hari kerja setelah penugasan selesai. Bila dijalankan, akun itu tidak aktif pada malam pertama, sehingga peristiwanya tidak terjadi. Klausul kedua mewajibkan pemantauan akses dan laporan dugaan insiden dalam 12 jam. Bila akses di luar penugasan terdeteksi pada malam pertama, rekam yang terbaca paling banyak 155, bukan 1.240, atau turun 87,5 persen. Bila deteksi terjadi setelah dua malam, jumlahnya 310, atau turun 75 persen. Klausul ketiga mewajibkan catatan per orang yang disimpan 90 hari. Pada kronologi itu, 620 rekam malam 1 sampai 4 tinggal jumlah karena catatannya terhapus. Dengan masa simpan 90 hari, seluruh 8 malam masih dapat ditelusuri pada hari ke-11.

Keputusan ini punya dua konsekuensi. Pertama, ketiga klausul membutuhkan pekerjaan di sisi Medikara. Daftar penugasan harus tersedia, dan AC-01 tetap dijalankan, karena Pasal 37 dan Pasal 39 UU PDP tetap menuntut pengawasan oleh pengendali [136]. Kedua, klausul tidak menjawab bahwa Medikara mengetahui kejadian lewat keluhan pasien. Hal itu memerlukan tinjauan catatan aktivitas di sisi Medikara, yang masuk Paket D pada Bab 8.

9.5 Cloud dan Tanggung Jawab Bersama

Tiga model layanan

NIST SP 800-145 mendefinisikan cloud sebagai model akses jaringan ke kumpulan sumber daya komputasi yang dapat disediakan dan dilepas dengan cepat. Definisi itu menyebut lima karakteristik, tiga model layanan, dan empat model penyebaran

[98]. Ketiga model layanan adalah *Infrastructure as a Service* (IaaS), *Platform as a Service* (PaaS), dan *Software as a Service* (SaaS). Model tanggung jawab bersama, atau *shared responsibility model*, membagi pekerjaan penyedia dan pelanggan pada tiap model. Amazon Web Services (AWS) merumuskan tanggung jawabnya sebagai *security of the cloud*. Tanggung jawab pelanggan disebut *security in the cloud*, dan besarnya ditentukan layanan yang dipilih [2].

Analogi sewa tempat usaha menjelaskan batasnya. Pengelola gedung menjaga struktur bangunan, tetapi penyewa tetap mengatur kunci ruang, pegawai, dan dokumennya. Membayar sewa tidak otomatis menjaga seluruh kegiatan di dalam ruangan.

Dua contoh membantah asumsi pemindahan penuh:

1. Misalkan Medikara memakai IaaS untuk 40 server virtual. Penyedia mengelola fasilitas dan virtualisasi, sementara tim Medikara masih mengelola sistem operasi serta aplikasi. Bila pembaruan memakan 1 jam per server per bulan, bebannya 40 jam per bulan, atau 480 jam per tahun, atau Rp28,8 juta. Tim platform 6 orang memiliki 960 jam kerja per bulan, sehingga pembaruan saja memakan sekitar 4,2 persen kapasitasnya.
2. Misalkan Medikara memakai SaaS. Penyedia mengoperasikan aplikasi, tetapi pelanggan tetap mengatur pengguna, hak akses, tujuan penggunaan, dan prosedur keluar. Peninjauan 120 akun tetap milik Medikara, yaitu 12 peninjauan pada 5 rumah sakit, atau 60 catatan per tahun. Penyedia hanya menyediakan fungsinya.

Gambar 9.5 memperlihatkan pembagian umum menurut panduan Microsoft [101]. Panduan itu menyatakan pembagiannya ilustratif dan tidak mengubah perjanjian layanan, sehingga pembagian harus dikonfirmasi pada kontrak. Pelanggan memegang penuh 7 dari 10 lapisan pada IaaS, 4 dari 10 pada PaaS, dan 3 dari 10 pada SaaS. Dua lapisan lain pada PaaS dan SaaS dibagi bersama. Pada SaaS sekalipun, 5 dari 10 lapisan masih memerlukan kerja pelanggan.

Dua hal sering tertukar: tanggung jawab kerja dan tanggung jawab hukum. Pembagiannya begini. Matriks tanggung jawab menjawab siapa mengatur, menjalankan, dan memantau tiap kendali. Pasal 51 ayat (3) UU PDP menjawab hal lain: pemrosesan oleh prosesor termasuk tanggung jawab pengendali [136]. Penyedia dapat mengerjakan seluruh lapisan fisik, tetapi Medikara tetap pengendali data pasien.

Tabel 9.10 menerapkan pembagian itu sebagai matriks kendali. Salinannya ada di `sources/chapter09/matriks-cloud.csv`. Tim mengisi model layanan berdasarkan rancangan IT40713, bukan asumsi dari nama model saja. Banyak solusi memakai campuran model layanan [101].

Lapisan	IaaS	PaaS	SaaS
Data pelanggan	Pelanggan	Pelanggan	Pelanggan
Konfigurasi dan pengaturan	Pelanggan	Pelanggan	Pelanggan
Identitas dan pengguna	Pelanggan	Pelanggan	Pelanggan
Perangkat klien	Pelanggan	Pelanggan	Bersama
Aplikasi	Pelanggan	Bersama	Bersama
Kendali jaringan	Pelanggan	Bersama	Penyedia
Sistem operasi	Pelanggan	Penyedia	Penyedia
Host fisik	Penyedia	Penyedia	Penyedia
Jaringan fisik	Penyedia	Penyedia	Penyedia
Pusat data fisik	Penyedia	Penyedia	Penyedia

Gambar 9.5: Pembagian lapisan menurut panduan Microsoft; kontrak layanan tetap menentukan

Tabel 9.10: Matriks kendali cloud yang harus dikonfirmasi kontrak (misalkan)

Kendali	Penyedia	Medikara	Bukti
Fasilitas fisik	Operasikan dan lindungi	Tinjau asurans dan cakupan	Ruang lingkup laporan
Sistem operasi pada IaaS	Konfirmasi batas layanan	Konfigurasi dan pembaruan	Hasil pembaruan
Hak pengguna pada SaaS	Sediakan fungsi akses	Setujui dan tinjau lewat AC-01	Daftar hak dan pencabutan
Tujuan dan klasifikasi data	Dukung kewajiban layanan	Tetapkan tujuan dan dasar	Catatan pemrosesan
Pemulihan	Penuhi bagian kontrak	Uji hasil layanan	Hasil uji terpadu
Keluar dan penghapusan	Ekspor serta hapus sesuai peran	Verifikasi kelengkapan	Hasil uji keluar

Sertifikat, laporan SOC 2, dan CCM

Asurans adalah keyakinan dari pihak lain atas kendali penyedia. Bentuknya beragam, dan tiap bentuk menjawab pertanyaan berbeda. Sertifikat ISO/IEC 27001 menilai sistem manajemen dalam ruang lingkup tertentu [75]. Annex A memuat kontrol A.5.23 tentang keamanan pemakaian layanan cloud [82]. ISO/IEC 27036-4:2016 memberi panduan bagi pelanggan dan penyedia untuk memahami serta mengelola risiko layanan cloud, tetapi tidak mencakup kelangsungan bisnis [73]. Laporan System and Organization Controls (SOC) membantu pengguna menilai risiko alih daya [1].

Analogi sertifikat laik sehat restoran menjelaskan batasnya. Sertifikat menilai dapur pada waktu dan cakupan tertentu. Sertifikat itu tidak menjawab apakah pesanan sampai ke meja yang benar. Bagian itu diatur pelanggan dan pelayan pada hari itu.

Dua contoh menunjukkan cara membaca bukti:

1. Bab 6 memisalkan vendor Medikara+ memiliki sertifikat yang masih berlaku 14 bulan, tetapi ruang lingkupnya hanya pengembangan aplikasi. Akun dukungan yang masuk ke data pasien tidak termasuk. Masa berlaku yang panjang tidak menutup celah cakupan itu.
2. Misalkan laporan SOC 2 Type 2 penyedia mencakup 1 Januari sampai 30 Juni 2026, dan tim membacanya pada 1 November 2026. Empat bulan terakhir belum tercakup. Bagian pengujian mencatat 3 pengecualian dari 25 sampel pencabutan akses, atau 12 persen. Laporan juga memuat 14 kontrol pelengkap pengguna (*complementary user entity controls*), dan Medikara baru menjalankan 9. Lima sisanya adalah pekerjaan Medikara, bukan pekerjaan penyedia.

Tabel 9.11 merangkum empat bentuk bukti. SOC 2 memeriksa kendali pada kategori keamanan, ketersediaan, integritas pemrosesan, kerahasiaan, atau privasi. Type 1 menilai rancangan dan penerapan kendali pada satu tanggal. Type 2 menambahkan pengujian efektivitas operasi selama periode tertentu, umumnya 6 sampai 12 bulan [30]. CCM versi 4.1 memuat 197 objektif kontrol dalam 17 domain, dan CAIQ mengubahnya menjadi pertanyaan ya atau tidak [22]. Catat versi unduhan, karena jawaban kuesioner tetap merupakan klaim yang perlu dibuktikan. Bab 12 membahas laporan asurans lebih rinci.

Tabel 9.11: Empat bentuk bukti penyedia dan cara membacanya

Bentuk	Yang dijawab	Yang harus dibaca
CAIQ	Apa yang dinyatakan penyedia	Versi, tanggal, layanan, dan bukti tiap jawaban ya
Sertifikat ISO/IEC 27001	Apakah sistem manajemen memenuhi persyaratan pada ruang lingkup itu	Ruang lingkup, lokasi, masa berlaku, dan penerbit
SOC 2 Type 1	Apakah kendali dirancang dan diterapkan pada satu tanggal	Tanggal, kategori, dan uraian sistem
SOC 2 Type 2	Apakah kendali bekerja selama satu periode	Periode, pengecualian, kontrol pelengkap pengguna dan subpenyedia

Lokasi data dan akses dukungan

Pertanyaan kemudian muncul: bolehkah data pasien berada pada layanan cloud di luar negeri? Bab 3 dan Bab 7 sudah membaca aturannya. Pasal 21 PP 71/2019 mengizinkan Penyelenggara Sistem Elektronik (PSE) lingkup privat mengelola sistem dan data di dalam atau di luar wilayah Indonesia [134]. Ketentuan umum ini tidak otomatis berlaku bagi rekam medis, karena aturan kesehatan lebih khusus.

Pasal 966 ayat (2) PP 28/2024 menyatakan pangkalan data kesehatan berupa pusat data di dalam wilayah Indonesia. Ayat (5) mengizinkan jasa pihak lain bila dilaksanakan di dalam wilayah Indonesia, berdasarkan perjanjian kerja sama, dengan data yang dimiliki dan dikendalikan penuh oleh penyelenggara. Pasal 972 mengatur transfer ke luar wilayah hukum untuk tujuan spesifik dan terbatas, dengan izin Menteri, serta memenuhi syarat transfer data pribadi [139]. Hubungan aturan umum dan aturan khusus pada kasus nyata tetap perlu dinilai penasihat hukum.

Analogi gudang arsip menjelaskan mengapa lokasi saja belum cukup. Gudang boleh berada di kota yang benar, tetapi kuncinya dapat dipegang petugas di kota lain. Pemilik arsip menanyakan letak gudang dan juga siapa yang dapat membuka pintunya.

Dua contoh berangka:

1. Bab 3 memisalkan vendor menawarkan penyimpanan di luar negeri seharga Rp420 juta per tahun, dibanding Rp600 juta saat ini. Penghematannya Rp180 juta, atau 30 persen. Nilai kontrak melewati batas Rp400 juta, sehingga keputusan naik ke direksi. Usulan berhenti pada Pasal 966 ayat (2), karena harga tidak menjawab lokasi pusat data. Pilihan yang tersisa adalah menawar ulang dengan fasilitas dalam negeri, atau memisahkan data bukan rekam medis setelah dinilai.
2. Bab 7 memisalkan 4 staf dukungan vendor di luar negeri membuka layar Medikara+ untuk sekitar 300 tiket per bulan. Pasal 971 ayat (2) PP 28/2024 menyebut penampilan sebagai salah satu bentuk transfer [139], sehingga akses itu diperlakukan sebagai transfer, dan ini penafsiran Bab 7. Dukungan dalam negeri lebih mahal Rp25 juta per bulan, atau Rp300 juta per tahun, atau sekitar Rp83.000 per tiket. Selisih itu dibandingkan dengan beban izin Pasal 972 atau pemakaian data sintetis.

Tabel 9.12 menyusun pertanyaan yang diajukan kepada penyedia cloud. Baris register terkait adalah K-07 dan K-13, dan celah terkait adalah CP-07. Bab 3 memperlakukan salinan cadangan sebagai bagian dari penyimpanan, dan perlakuan itu penafsiran bab, karena Pasal 966 tidak menyebut cadangan secara tersendiri.

9.6 Berbagi Data dan Penilaian Dampak

Pemicu dan tujuan DPIA

DPIA menilai dampak pemrosesan terhadap subjek data. Pasal 34 ayat (1) UU PDP mewajibkannya bila pemrosesan berpotensi risiko tinggi. Ayat (2) menyebut tujuh keadaan, antara lain data spesifik, skala besar, serta pencocokan atau pengga-

Tabel 9.12: Pertanyaan lokasi dan akses kepada penyedia cloud (penafsiran bab)

Aspek	Pertanyaan	Dasar penelusuran	Bukti
Pusat data	Di mana data aktif disimpan?	PP 28/2024 Pasal 966 ayat (2)	Inventaris lokasi
Cadangan	Di mana salinan cadangan berada?	Pasal 966; Permenkes 24/2022 Pasal 20	Prosedur dan hasil uji
Jasa pihak lain	Apakah data tetap dikendalikan penuh?	Pasal 966 ayat (5); Permenkes Pasal 22	Perjanjian dan rekomendasi
Akses dukungan	Dari negara mana staf dapat melihat data?	Pasal 971 ayat (2) dan Pasal 972	Daftar staf dan catatan akses
Transfer	Apakah ada tujuan spesifik dan izin?	Pasal 972; UU PDP Pasal 56	Izin Menteri dan penilaian

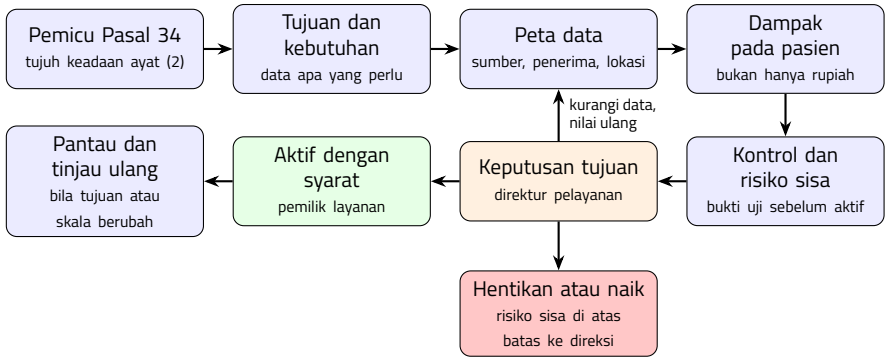
bungan data [136]. Bab 7 membaca satu keadaan sudah cukup, dan pembacaan itu penafsiran bab. Tim menjelaskan tujuan, kebutuhan, proporsionalitas, alur, risiko, kontrol, risiko sisa, dan keputusan sebelum alur berisiko diaktifkan.

Analogi membuka akses jalan di kawasan perumahan menunjukkan tujuan penilaian. Jalan baru mempercepat perjalanan, tetapi mengubah lalu lintas dan keselamatan penghuni. Penilaian tidak hanya menghitung pendapatan pengelola, karena akibat pada warga juga perlu dipertimbangkan.

Dua contoh menunjukkan mengapa nama mitra belum cukup:

1. Misalkan mitra asuransi meminta seluruh riwayat medis 10.000 pasien untuk verifikasi kepesertaan. Tim menguji apakah status kepesertaan dan data minimum sudah memenuhi tujuan. Pengiriman riwayat lengkap tidak diterima hanya karena mitra memiliki sistem yang aman. Bab 7 menghitung alur klaim 6.000 per bulan, atau 72.000 per tahun. Bagi 10.000 pasien itu, rata-ratanya 7,2 klaim per pasien per tahun.
2. Misalkan hasil laboratorium dikirim kepada dokter yang merawat. Tim membatasi penerima, tujuan, data, dan waktu akses. Kebutuhan layanan tidak menghapus risiko salah penerima. Misalkan 1 dari 2.000 pengiriman salah alamat pada uji coba. Bila ada 300 pengiriman per hari, kesalahannya sekitar 55 per tahun, sehingga uji negatif dilakukan sebelum produksi.

Gambar 9.6 memperlihatkan alurnya. Urutan ini mengikuti alur 10 hari kerja pada Bab 8 dan kebijakan KB-05 tentang berbagi data dengan mitra. Petugas pelindungan data memimpin DPIA, direktur pelayanan memutuskan tujuan, dan risiko sisa di atas batas naik ke direksi. Kepala rekam medis memegang hak henti sempit bila dasar pemrosesan belum ada.



Gambar 9.6: Alur DPIA untuk berbagi data dengan mitra (penafsiran bab)

Mengurangi data lebih dahulu

Dua hal sering tertukar: kontrol keamanan dan kebutuhan data. Pembagiannya begini. Enkripsi melindungi data dalam perjalanan, tetapi penerima yang sah tetap dapat memakai seluruh isinya. Pertanyaan pertama karena itu adalah data apa yang perlu dikirim. Kontrol baru dipasang pada data yang lolos pertanyaan itu.

Tabel 9.13 menghitung akibatnya. Misalkan riwayat lengkap memuat rata-rata 30 rekam per pasien dan 42 kolom per rekam. Data minimum untuk klaim memerlukan 9 kolom. Hitungan memakai jumlah nilai data sebagai ukuran paparan, bukan ukuran risiko. Riwayat lengkap menghasilkan 12,6 juta nilai data, sedangkan data minimum 648.000, atau turun sekitar 94,9 persen. Dibanding klaim lengkap, data minimum tetap turun sekitar 78,6 persen.

Tabel 9.13: Tiga pilihan data alur asuransi (misalkan)

Pilihan	Rekam	Kolom	Nilai data
Riwayat lengkap	$10.000 \times 30 = 300.000$	42	12.600.000
Klaim lengkap	72.000 per tahun	42	3.024.000
Data minimum	72.000 per tahun	9	648.000

Tabel 9.14 merangkum penilaian dampak alur ini. Kolom risiko membicarakan pasien, bukan Medikara. Templatnya ada di `sources/chapter09/templat-dpia.md`, dan contoh terisinya ada di `sources/chapter09/contoh-dpia-medikara.md`.

Kasus Medikara Health: DPIA Alur Asuransi

CP-03 pada Bab 7 mencatat DPIA alur asuransi belum ada, dan Bab 8 menjadikannya syarat alur berbagi data. Alur klaim menyentuh tiga keadaan Pasal 34 ayat (2): data spesifik, skala besar, dan penggabungan data.

Tabel 9.14: Contoh penilaian dampak alur asuransi (misalkan)

Risiko terhadap pasien	Pengurangan yang diusulkan	Risiko sisa dan keputusan
Riwayat berlebih memengaruhi perlakuan	Kirim status dan 9 kolom minimum sesuai tujuan	Nilai kemungkinan penggabungan ulang
Salah penerima	Verifikasi mitra dan pembatasan akses	Uji negatif sebelum produksi
Penggunaan tujuan lain	Instruksi, kontrak, dan pemantauan	Hentikan alur bila penggunaan menyimpang

DPIA dikerjakan 3 orang selama 3 hari kerja, atau 72 jam, atau Rp4,32 juta. Pekerjaan itu mengisi hari ke-2 sampai ke-4 pada alur 10 hari kerja.
Misalkan mitra tetap meminta riwayat lengkap. Tim menolak permintaan itu dan mengusulkan data minimum 9 kolom. Mitra meminta waktu 1 bulan untuk mengubah sistemnya. Selama itu klaim diproses manual: 6.000 klaim kali 5 menit, atau 500 jam, atau Rp30 juta. Petugas pelindungan data memberi saran tertulis, dan direktur pelayanan memutuskan menunggu.
Keputusan ini punya dua konsekuensi. Pertama, Rp30 juta adalah biaya yang diterima secara sadar demi mengurangi paparan pasien sekitar 94,9 persen. Keputusan itu tercatat bersama alasannya. Kedua, DPIA tidak selesai saat alur aktif. Perubahan tujuan, kolom, penerima, lokasi, atau skala memicu penilaian ulang. Bila mitra kemudian memakai data klaim untuk menilai premi perorangan, alur dihentikan sampai tujuan baru dinilai. Peran dan kebutuhan datanya perlu ditinjau fungsi hukum.

Pendalaman Teknis (opsional)

Software Bill of Materials (SBOM) membantu mengidentifikasi komponen perangkat lunak. Daftar komponen bukan bukti bebas kerentanan. Misalkan SBOM vendor memuat 180 komponen, dan 6 di antaranya memiliki kerentanan yang diketahui. Tim bertanya komponen mana yang benar-benar dipakai pada jalur data pasien, dan kapan perbaikannya.
Saat membaca uji penetrasi vendor, periksa tanggal, cakupan, pembatasan, temuan, perbaikan, dan uji ulang. Pengujian langsung hanya dilakukan pada sistem sendiri atau dengan izin tertulis. Tim teknis juga dapat menilai kontrol vendor dengan CCM seri 4, lalu mencatat versi berkas yang dipakai [22]. Strategi migrasi cloud dibahas pada IT40713, dan keamanan teknis Application Programming Interface (API) dibahas pada IT40613.

9.7 Aktivitas: Kerangka Pihak Ketiga, Matriks Cloud, dan DPIA

Tujuan. Tim menyusun kerangka pihak ketiga untuk rancangan target, mengisi matriks tanggung jawab bersama, dan menyusun DPIA satu alur berbagi data. Tim memakai organisasi nyata dengan izin dan data yang dianonimkan, atau kasus Medikara Health.

Pembagian peran. Anggota berlatar bisnis menilai kekritisan vendor. Analis regulasi memimpin penyusunan klausul kontrak dan DPIA. Analis teknologi mengisi matriks cloud. Analis risiko menghubungkan hasil dengan R-01, R-08, dan R-10.

Langkah kerja.

1. Isi `sources/chapter09/klasifikasi-vendor.csv` untuk penyedia cloud, vendor Medikara+, laboratorium mitra, asuransi, dan apotek daring. Hitung skor, lalu tetapkan tingkat pemeriksaan.
2. Isi `sources/chapter09/peta-ketergantungan.csv`. Tandai pihak keempat yang dipakai lebih dari satu hubungan.
3. Pilih dua hubungan paling kritis. Gunakan `sources/chapter09/kuesioner-uji-tuntas.md` dan `sources/chapter09/klausul-kontrak.md`.
4. Tentukan indikator pemantauan, perubahan yang memicu tinjau ulang, serta strategi keluar dan uji ekspor.
5. Isi `sources/chapter09/matriks-cloud.csv` berdasarkan layanan yang dirancang IT40713, bukan asumsi nama model saja.
6. Isi `sources/chapter09/templat-dpia.md` untuk satu alur asuransi. Bandingkan dengan `sources/chapter09/contoh-dpia-medikara.md`.
7. Simulasikan dugaan insiden vendor pada Jumat 20.00. Pastikan kontrak dan matriks menunjukkan siapa menyelidiki, menghentikan alur, dan memberi informasi sebelum Sabtu 08.00.

Luaran. Kerangka pihak ketiga, matriks tanggung jawab cloud, DPIA satu alur, dan catatan simulasi.

Kaitan dengan capstone. Luaran masuk tonggak C3 Kondisi Target. Matriks diselaraskan dengan layanan IT40713, dan alur data mitra diselaraskan dengan rancangan platform IT40613. Bab 10 memakai hubungan kritis dan strategi keluar, sedangkan Bab 12 menguji klausul sebagai bukti audit.

Kriteria penilaian. Klasifikasi dan bukti 25 persen; kontrak serta pemantauan 25 persen; kejelasan tanggung jawab 25 persen; analisis dampak dan risiko sisa 25

persen. Dokumen contoh bukan nasihat kontrak untuk ditandatangani. Penilaian berfokus pada penalaran dan keterlacakan.

Berkas pendukung. Seluruh lembar kerja ada di `sources/chapter09/`, dengan daftar berkas pada `sources/chapter09/README.md`. Data pasien, rahasia akses, dan dokumen asli organisasi tidak boleh disalin ke folder tugas.

Pendalaman teknis (opsional). Tim dengan anggota berlatar teknis dapat menilai kontrol vendor dengan CSA CCM seri 4, mempelajari SBOM untuk risiko rantai pasok perangkat lunak, dan membaca bukti teknis seperti laporan uji penetrasi. Pengujian langsung hanya dilakukan pada sistem sendiri atau dengan izin tertulis.

9.8 Ringkasan

Rantai pasok harus ditelusuri hingga ketergantungan yang bermakna. Banyak vendor dapat memiliki satu titik kegagalan bersama, sehingga risiko konsentrasi tidak terlihat dari jumlah kontrak saja. Dua layanan yang terlihat terpisah dapat berhenti bersama 43,8 jam per tahun, bukan 13 menit, bila memakai satu penyedia pesan. Kejadian Change Healthcare dan Synnovis memperlihatkan bentuk dampaknya, tetapi angkanya tidak disalin menjadi peluang Medikara.

Uji tuntas merupakan awal dari siklus hubungan. Klasifikasi menentukan kedalaman pemeriksaan, sehingga 40 hubungan memerlukan 484 jam, bukan 1.600 jam. Kontrak, penerapan, pemantauan, perubahan, dan keluar membutuhkan pemilik serta bukti. Uji ekspor Rp60 juta menurunkan harapan kerugian R-10 lebih cepat daripada mengganti vendor seharga Rp300 juta.

Ketentuan yang kabur sulit dipakai ketika insiden terjadi. Klausul 12 jam memberi Medikara 48 jam sampai batas internal dan 60 jam sampai batas terluar, tetapi tidak memindahkan kewajiban Pasal 46. Pencabutan akun, laporan insiden, dan catatan 90 hari menjawab langsung kronologi 2025. Lima butir kosong pada perjanjian vendor menjadi bahan tawar ulang menuju 11 dari 11.

Cloud membagi pekerjaan, tetapi tidak menghapus peran pelanggan. Pada SaaS sekalipun, 5 dari 10 lapisan masih memerlukan kerja pelanggan. Model layanan, kontrak, konfigurasi, dan cakupan asurans harus diperiksa bersama, dan sertifikat penyedia tidak membuktikan keamanan konfigurasi pelanggan. Harga Rp420 juta tidak menjawab Pasal 966 ayat (2), dan lokasi pusat data tidak menjawab siapa yang dapat melihat data dari luar negeri.

DPIA menilai akibat pada pasien dan kebutuhan data sebelum berbagi. Pengurangan data dapat lebih efektif daripada menambah kontrol pada alur yang berlebihan, seperti penurunan paparan 94,9 persen pada alur asuransi. Pesan utama bab ini sederhana: hubungan mitra yang baik memungkinkan organisasi membuktikan siapa bertanggung jawab, bukti apa yang tersedia, cara keluar yang

teruji, dan bagaimana risiko sisa diputuskan.

9.9 Latihan

Latihan 1: Batas Sertifikat Cloud

Jelaskan mengapa sertifikat ISO/IEC 27001 milik penyedia cloud tidak memindahkan seluruh tanggung jawab keamanan kepada penyedia. Latihan ini membuktikan bahwa sertifikat menjawab cakupan tertentu, sementara sebagian lapisan tetap menjadi kerja pelanggan.

1. Baca ruang lingkup, lokasi, dan masa berlaku sertifikat.
2. Pilih satu layanan dan modelnya, misalnya dari rancangan IT40713.
3. Tandai lapisan yang tercakup dan yang tidak tercakup.
4. Tentukan kewajiban pelanggan beserta buktinya.

Tabel 9.15 memuat contoh analisis, dan Tabel 9.16 merupakan lembar hasil.

Tabel 9.15: Contoh analisis Latihan 1 (skenario pembelajaran)

Lapisan (misalkan)	Penanggung jawab	Bukti
Fasilitas cloud	Penyedia	Asurans sesuai cakupan
Sistem operasi 40 server pada IaaS	Pelanggan	Hasil pembaruan 480 jam per tahun
Hak pengguna SaaS	Pelanggan dan dukungan penyedia	Persetujuan, 60 catatan AC-01
Lokasi cadangan	Pelanggan menagih, penyedia menyediakan	Inventaris lokasi, K-13

Tabel 9.16: Lembar hasil Latihan 1

Lapisan	Penanggung jawab	Bukti
…	…	…
…	…	…
…	…	…

Pertanyaan analisis. Apa akibatnya bila sertifikat tidak mencakup layanan yang dibeli? Siapa menangani akun pelanggan yang berlebihan? Berapa lapisan pada tabel tim yang masih memerlukan kerja pelanggan?

Latihan 2: Klausul Vendor

Susun tiga klausul kontrak yang dapat mencegah atau membatasi dampak insiden seperti kebocoran data lewat vendor yang dialami Medikara pada 2025. Latihan ini

membuktikan bahwa klausul berguna bila ukuran dan buktinya dapat diuji terhadap kronologi.

1. Baca kronologi di `sources/chapter07/kronologi-insiden-vendor-2025.md`.
2. Pilih kelemahan yang hendak dikendalikan.
3. Tulis kewajiban dan ukuran penerimaan.
4. Hitung perubahan akibat dengan pengandaian insiden.

Tabel 9.17 memuat contoh analisis, dan Tabel 9.18 merupakan lembar hasil.

Tabel 9.17: Contoh analisis Latihan 2 (skenario pembelajaran)

Klausul (misalkan)	Ukuran	Bukti	Akibat pada 2025
Pencabutan akun	Pemilik dan tanggal berakhir; 1 hari kerja	120 dari 120 akun cocok	Akun tidak aktif pada malam 1
Laporan dugaan insiden	12 jam sebagai batas kontrak	Kronologi latihan	Deteksi malam 1: 155 rekam, bukan 1.240
Catatan aktivitas	Per orang; 90 hari	Uji telusur satu rekam	1.240 rekam terlacak, bukan 620

Tabel 9.18: Lembar hasil Latihan 2

Klausul	Ukuran	Bukti	Akibat pada kronologi
…	…	…	…
…	…	…	…
…	…	…	…

Pertanyaan analisis. Berapa jam tersisa bagi Medikara bila vendor melapor tepat pada jam ke-12? Bukti apa yang menunjukkan vendor benar-benar dapat memenuhi klausul? Bagian mana dari insiden yang tetap tidak terjawab oleh kontrak?

Latihan 3: Pemicu DPIA

Kapan alur berbagi data dengan mitra wajib didahului DPIA? Jelaskan dengan contoh. Latihan ini membuktikan bahwa keputusan bergantung pada keadaan pemrosesan, bukan pada nama mitra.

1. Tentukan tujuan dan kelompok data tiap alur.

2. Uji alur terhadap tujuh keadaan Pasal 34 ayat (2) dengan `sources/chapter07/penyaringan-penilaian-dampak.csv`.
3. Nilai kebutuhan, dampak pada pasien, dan pengurangan data.
4. Tulis keputusan beserta pemberi keputusan.

Tabel 9.19 memuat contoh analisis, dan Tabel 9.20 merupakan lembar hasil.

Tabel 9.19: Contoh analisis Latihan 3 (skenario pembelajaran)

Alur (misalkan)	Pemicu dan dampak	Keputusan
Riwayat kesehatan 10.000 pasien ke asuransi	Data spesifik, skala besar, penggabungan; risiko perlakuan merugikan	DPIA sebelum aktif; kirim data minimum 9 kolom
Hasil laboratorium ke dokter yang merawat	Data spesifik; risiko salah penerima	DPIA per alur; uji negatif sebelum produksi
Laporan kesehatan 3.000 karyawan ke perusahaan klien	Data spesifik bila rinci; risiko pada pekerjaan	Hanya hasil agregat; syarat Pasal 18 bila tujuan ditentukan bersama

Tabel 9.20: Lembar hasil Latihan 3

Alur	Pemicu dan dampak	Keputusan
…	…	…
…	…	…
…	…	…

Pertanyaan analisis. Apakah enkripsi menghilangkan risiko penggunaan berlebih? Siapa berwenang memutuskan risiko sisa, dan apa buktinya? Apa yang berubah bila alur yang sama diperluas dari 6.000 menjadi 12.000 klaim per bulan?

Bab 10

Kelangsungan Bisnis dan Ketahanan Operasional

Tujuan Pembelajaran

- Melakukan BIA (*Business Impact Analysis*) untuk menentukan layanan kritis beserta RTO dan RPO-nya.
- Memilih strategi kelangsungan yang sepadan dengan dampak dan biaya.
- Merancang skenario latihan krisis yang menguji keputusan, bukan hanya teknologi.

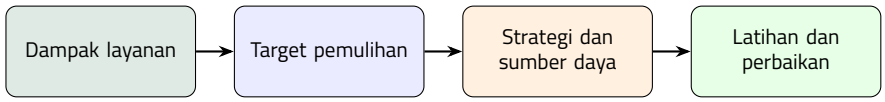
10.1 Pendahuluan

Misalkan Sistem Informasi Manajemen Rumah Sakit (SIMRS) di rumah sakit Bekasi berhenti enam jam, dari pukul 08.00 sampai 14.00. Antrean pendaftaran mengular. Petugas masih dapat menerima pasien dengan formulir kertas, tetapi tidak dapat membaca obat yang sudah diberikan di unit lain. Pukul 14.00 server kembali hidup. Pasien yang menunggu belum hilang, dan catatan kertas belum masuk ke sistem. Menghidupkan server saja belum memulihkan layanan. Organisasi juga perlu memastikan keselamatan pasien, rekonsiliasi catatan manual, dan komunikasi antarfasilitas.

Kelangsungan bisnis mempertahankan layanan pada kapasitas yang dapat diterima selama gangguan. Pemulihan teknologi mendukung tujuan tersebut. Analisis dampak bisnis atau Business Impact Analysis (BIA) menentukan prioritas berdasarkan konsekuensi gangguan, bukan berdasarkan sistem yang paling mudah dipulihkan. Target waktu dan kehilangan data disepakati pemilik layanan

sebelum teknologi dipilih. Bab ini menuntaskan pekerjaan yang ditunda bab sebelumnya. Bab 4 menunda objektif DSS04 *Managed continuity* dari Control Objectives for Information and Related Technologies (COBIT) sampai BIA tersedia. Bab 3 mencatat 144 uji pemulihan per tahun, dan Bab 5 mencatat R-05, pemulihan yang belum diuji, sebagai skenario dengan harapan kerugian terbesar. Hasil kerja bab ini adalah BIA, strategi kelangsungan, dan skenario latihan untuk tonggak C3 capstone. Gambar 10.1 memperlihatkan urutan keputusannya.

Bab ini memakai ISO 22301:2019 beserta Amandemen 1:2024 sebagai kerangka sistem manajemen kelangsungan bisnis. Naskah International Organization for Standardization (ISO) berbayar, sehingga rinciannya ditulis ringkas dan perlu dicocokkan ke naskah berlisensi sebelum dipakai untuk audit. Panduan National Institute of Standards and Technology (NIST) SP 800-34 Rev. 1 terbuka dan memberi langkah BIA yang dapat diperiksa mahasiswa. Peraturan Badan Siber dan Sandi Negara (BSSN) 1/2024 dan 2/2024 melengkapi pembahasan tanggung jawab dan koordinasi, tanpa menyamakan setiap insiden rumah sakit dengan krisis siber nasional. Digital Operational Resilience Act (DORA) dari Uni Eropa dipakai sebagai pembanding, karena berlaku bagi sektor keuangan, bukan bagi Medikara. Seluruh angka tambahan tentang Medikara merupakan contoh pembelajaran [70, 71, 149, 9, 10, 37].



Gambar 10.1: Alur keputusan kelangsungan bisnis dan ketahanan operasional

Gambar 10.2 merangkum hubungan komponen dan konsep utama bab ini.



Server hidup belum menjamin layanan pasien pulih. Tabletop menguji keputusan; restore teknis membuktikan kemampuan pemulihan.

Gambar 10.2: Kelangsungan layanan memerlukan jalur bisnis dan teknologi

10.2 Ketahanan Operasional sebagai Tanggung Jawab Direksi

Tiga disiplin pada satu kejadian

Ketahanan operasional adalah kemampuan mempertahankan hasil layanan penting ketika terjadi gangguan. Tiga disiplin menopangnya. Manajemen insiden membatasi kejadian dan memulihkan operasi yang terganggu. Kelangsungan bisnis menyiapkan cara melayani selama pemulihan. Pemulihan bencana atau *disaster recovery*, yang dijalankan fungsi Teknologi Informasi (TI), mengembalikan teknologi dan data. NIST memisahkan rencana kelangsungan bisnis, yang berfokus pada proses bisnis selama dan sesudah gangguan, dari rencana pemulihan bencana, yang berfokus pada sistem [149]. Ketiganya berhubungan, tetapi keputusan dan buktinya berbeda.

Analogi sederhana terdapat pada toko yang kehilangan listrik. Teknisi memperbaiki instalasi. Pengelola toko mengatur transaksi manual dan batas jumlah pembeli. Pemilik toko memutuskan kapan operasi perlu dihentikan karena risikonya terlalu tinggi.

Dua contoh memperlihatkan pembagian itu:

1. Misalkan pukul 08.15 tim memutus jaringan tiga unit di Bekasi. Pukul 08.35 direktur rumah sakit mengaktifkan formulir kertas. Pemulihan SIMRS kemudian berjalan 90 menit. Satu kejadian menghasilkan tiga keputusan, tiga pemilik, dan tiga bukti. Laporan yang hanya menulis “SIMRS pulih dalam 90 menit” menjawab satu dari tiga pertanyaan pada Tabel 10.1.
2. Misalkan gangguan 30 menit pada laporan manajemen masih dapat diterima, sedangkan gangguan 30 menit pada identifikasi pasien menuntut prosedur darurat. Kedua fungsi berjalan pada SIMRS yang sama, tetapi prioritasnya mengikuti dampak layanan, bukan nama sistem.

Tabel 10.1: Tiga disiplin pada satu gangguan SIMRS

Disiplin	Pertanyaan	Pemimpin	Bukti selesai
Manajemen insiden	Apa yang terjadi dan bagaimana dibatasi?	Kepala operasi TI	Kronologi, alasan isolasi, hasil pembatasan
Kelangsungan bisnis	Bagaimana pasien tetap dilayani dengan aman?	Direktur rumah sakit dan pemilik layanan	Kapasitas minimum tercapai, batas aman dipatuhi
Pemulihan bencana	Kapan sistem dan data kembali?	Kepala operasi TI	Waktu *restore*, titik data, hasil verifikasi

Siapa memutuskan

Pertanyaan kemudian muncul: siapa menetapkan toleransi gangguan? Direksi mengesahkan batas dan sumber daya berdasarkan usulan pemilik layanan. Unit klinis menentukan layanan minimum yang aman. Tim teknologi menyediakan bukti kemampuan pemulihan. Peraturan BSSN 1/2024 Pasal 18 ayat (3) meminta rencana tanggap insiden dan rencana keberlangsungan kegiatan disetujui pimpinan organisasi, baik pada penyelenggara Infrastruktur Informasi Vital (IIV) maupun Penyelenggara Sistem Elektronik (PSE) lainnya [9]. Wewenang bisnis tidak berpindah kepada teknisi hanya karena penyebab gangguan bersifat teknis. Tabel 10.2 merangkum pembagian keputusannya.

Tabel 10.2: Pembagian keputusan kelangsungan layanan

Peran	Keputusan	Bukti
Direksi	Toleransi gangguan dan biaya	Persetujuan batas gangguan dan anggaran
Direktur pelayanan	Layanan minimum lintas fasilitas dan pengalihan pasien	Catatan keputusan pengalihan
Direktur rumah sakit	Aktivasi operasi manual di lokasi	Waktu aktivasi dan alasannya
Pemilik layanan	Kapasitas minimum yang aman	Prosedur manual tervalidasi
Kepala operasi TI	Urutan pemulihan sistem	Hasil uji pemulihan

Pembagian ini punya dua konsekuensi. Pertama, biaya kesiapan menjadi keputusan organisasi. Menurut batas delegasi Bab 2, opsi Rp120 juta per tahun cukup diputus komite pengarah TI, sedangkan opsi Rp480 juta melewati batas Rp400 juta dan naik ke direksi. Kedua, kegagalan mencapai target dieskalasikan sebagai risiko, bukan disimpan sebagai catatan teknis.

Dua contoh memperlihatkan keputusan yang tidak dapat diserahkan kepada teknisi:

1. Misalkan farmasi memiliki stok fisik, tetapi riwayat pemberian obat tidak dapat dibuka. Penanggung jawab klinis membatasi transaksi manual pada resep yang dapat diverifikasi, bukan membebaskan seluruh transaksi. Batas ini berkaitan langsung dengan R-11, kesalahan obat, yang dimiliki direktur pelayanan.
2. Bab 5 membatasi gangguan pendaftaran 2 jam per bulan, atau 24 jam per tahun. Gangguan enam jam di Bekasi memakai 3 kali batas bulanan itu dalam satu kejadian, sehingga memicu tinjauan mingguan. Keputusan menerima kejadian berikutnya tidak berada pada tim teknologi.

Membandingkan dua aturan

Aturan mana yang mengikat Medikara? Peraturan BSSN 1/2024 berlaku bagi PSE, dan Pasal 8 ayat (1) meminta PSE selain penyelenggara IIV membentuk tim tanggap insiden organisasi. Bab 3 sudah menjelaskan bahwa sektor kesehatan tidak otomatis menjadikan setiap sistem sebagai IIV. DORA tidak berlaku bagi Medikara. Pasal 2 ayat (1) mencakup entitas keuangan dan penyedia layanan teknologi pihak ketiganya, tanpa fasilitas kesehatan [37]. Nilainya sebagai pembanding terletak pada ketegasan rumusannya. Pasal 5 ayat (2) menempatkan tanggung jawab akhir pada badan pengelola. Tabel 10.3 memperlihatkan pilihan Medikara terhadap keduanya.

Tabel 10.3: Peraturan BSSN 1/2024, DORA sebagai pembanding, dan pilihan Medikara

Pokok	BSSN 1/2024	DORA (pembanding)	Pilihan Medikara (misalkan)
Pimpinan	Pasal 18 ayat (3): rencana disetujui pimpinan	Pasal 5 ayat (2): badan pengelola memikul tanggung jawab akhir dan menyetujui kebijakan	Direksi mengesahkan BIA dan rencana
Target pulih	Lampiran A: capaian dinilai dari waktu, jumlah data, dan fungsi	Pasal 12 ayat (6): target waktu dan titik pulih per fungsi	MTPD, RTO, RPO, dan kapasitas minimum per layanan
Cadangan	Pasal 18 ayat (3) huruf e: personel memahami penggunaan rekam cadang	Pasal 12 ayat (3): pemulihan memakai sistem terpisah secara fisik dan logis	Cadangan dan akun pengelola terpisah; K-02 tempat berbeda
Frekuensi uji	Pasal 26: simulasi berkala; paling sedikit 1 kali dalam 2 tahun bagi penyelenggara IIV	Pasal 11 ayat (6): paling sedikit setahun sekali	144 uji pemulihan dan 5 latihan *tabletop* per tahun

10.3 Sistem Manajemen: ISO 22301 dan DSS04

ISO 22301:2019

ISO 22301 menetapkan persyaratan sistem manajemen, bukan resep perangkat pemulihan. Organisasi menetapkan ruang lingkup, memahami konteks, membagi tanggung jawab, melakukan analisis, memilih strategi, menyiapkan rencana, menguji, dan memperbaikinya [70]. Susunannya mengikuti pola sistem manaje-

men yang sudah dibaca pada ISO/IEC 27001 di Bab 6. Karena naskahnya berbayar, rincian klausul pada bab ini ditulis umum.

Analogi sistem manajemen adalah pengelolaan latihan kebakaran gedung. Peta evakuasi perlu pemilik, jadwal pemeriksaan, latihan, dan tindak lanjut. Peta yang dicetak rapi tidak membuktikan bahwa pintu darurat dapat dibuka ketika diperlukan.

Dua contoh memperlihatkan pentingnya cakupan:

1. Misalkan lima rumah sakit masuk strategi, tetapi latihan baru mencakup satu rumah sakit. Cakupan latihan dilaporkan 1 dari 5, atau 20 persen, bukan seluruh jaringan. Bila seluruh 36 fasilitas dihitung, cakupannya 1 dari 36, atau sekitar 2,8 persen.
2. Misalkan pusat pemulihan berada di kawasan banjir yang sama dengan pusat utama. Pasal 20 ayat (4) dan (5) Peraturan Menteri Kesehatan (Permenkes) 24/2022 meminta cadangan di tempat berbeda [88], dan Bab 3 mencatatnya sebagai K-02. Alamatnya berbeda, tetapi ancaman bersamanya belum berkurang.

Sertifikat dengan ruang lingkup pusat data tidak otomatis membuktikan seluruh rumah sakit siap beroperasi manual. Tim perlu membaca lokasi, layanan, dan pengecualian dalam ruang lingkup, seperti pemeriksaan sertifikat pada Bab 6 dan Bab 9. Amandemen 1:2024 berjudul *Climate action changes*, dan perubahannya menyentuh konteks organisasi serta kebutuhan pihak berkepentingan [71]. Risiko banjir, panas, listrik, dan pasokan dinilai bila relevan. Amandemen ini tidak berarti organisasi wajib menganggap semua ancaman memiliki tingkat yang sama. Revisi standar ini juga sedang dikembangkan, sehingga status edisinya perlu diperiksa ulang pada halaman resmi ISO sebelum audit. Tabel 10.4 merangkum siklusnya.

Tabel 10.4: Siklus pengelolaan kelangsungan pada Medikara (misalkan)

Tahap	Pertanyaan	Bukti minimum	Contoh Medikara
Rencana	Layanan apa yang dipertahankan?	Ruang lingkup dan BIA	36 baris BIA, disahkan direksi
Pelaksanaan	Siapa menjalankan alternatif?	Rencana dan daftar kontak	Prosedur korporat dengan 36 lampiran
Evaluasi	Target tercapai atau belum?	Catatan latihan	144 uji dan 5 *tabletop* per tahun
Perbaikan	Celah mana yang ditutup?	Tindakan, pemilik, tenggat	Uji ulang masuk register R-05

DSS04, objektif yang ditunda

Bab 4 memberi DSS04 skor 10, sama dengan APO12 dan MEA03, tetapi kapasitas hanya menyisakan dua tempat. DSS04 ditunda sampai BIA tersedia, dan Bab 8 sengaja belum memberinya target. Bab ini menutup penundaan itu. COBIT 2019 merumuskan DSS04 dengan 8 praktik manajemen [130]. Delapan praktik itu mengubah kelangsungan dari satu dokumen menjadi satu proses yang berulang.

Analogi perawatan genset di sebuah pertokoan membantu. Membeli genset hanya satu bagian. Pengelola juga menetapkan toko mana yang dilayani, menyimpan solar, melatih petugas, menyalakannya berkala, dan meninjau hasil setelah listrik padam. Tabel 10.5 memetakan kedelapan praktik ke bukti Medikara. Kode KB mengikuti daftar kebijakan Bab 8.

Tabel 10.5: Delapan praktik DSS04 dan bukti pada Medikara (misalkan)

Praktik	Inti praktik (diringkas)	Bukti Medikara
DSS04.01	Kebijakan, tujuan, dan ruang lingkup	Ruang lingkup 36 fasilitas disahkan direksi
DSS04.02	Menjaga ketahanan bisnis	BIA 36 baris dan pilihan strategi
DSS04.03	Mengembangkan dan menerapkan respons	Prosedur korporat dengan 36 lampiran
DSS04.04	Melatih, menguji, dan meninjau rencana	144 uji pemulihan dan 5 *tabletop*
DSS04.05	Meninjau, memelihara, dan memperbaiki rencana	Tindakan, pemilik, tenggat, dan uji ulang
DSS04.06	Pelatihan rencana	Petugas manual tiap rumah sakit dilatih dan dicatat
DSS04.07	Mengelola pengaturan cadangan	KB-08, K-02, cadangan dan akun terpisah
DSS04.08	Tinjauan sesudah pemulihan	Rekonsiliasi disahkan kepala rekam medis

Pertanyaan berikutnya: tingkat kapabilitas berapa yang sepadan? Dua contoh menunjukkan pilihannya:

1. Bab 8 menjelaskan tingkat 2 sebagai aktivitas dasar yang lengkap dan tingkat 3 sebagai cara kerja dan aset organisasi. Bab 3 menawarkan 36 prosedur terpisah atau satu prosedur korporat dengan lampiran. Misalkan satu prosedur penuh dipelihara 8 jam per tahun, sehingga 36 prosedur memakan 288 jam. Satu prosedur korporat 40 jam ditambah 36 lampiran 2 jam memakan 112 jam. Selisihnya 176 jam, atau Rp10,56 juta dengan tarif Rp60.000 per jam seperti Bab 7 dan Bab 9. Cara kerja bersama pada tingkat 3 sekaligus lebih murah untuk dipelihara.
2. Misalkan konsultan mengusulkan tingkat 4 seharga Rp300 juta per tahun,

atau Rp180 juta di atas tingkat 3. Seksi strategi menghitung harapan kerugian R-05 tersisa Rp40 juta per tahun setelah opsi terpilih. Sekalipun tingkat 4 menghapus seluruh sisa itu, manfaatnya hanya Rp40 juta. Tingkat 3 lebih sepadan.

Keputusan DSS04 pada tingkat 3 punya dua konsekuensi. Pertama, rancangan Bab 8 berubah dari 3 kali Rp120 juta ditambah 4 kali Rp60 juta menjadi 4 kali Rp120 juta ditambah 4 kali Rp60 juta. Biayanya naik dari Rp600 juta menjadi Rp720 juta per tahun, dan keputusannya tetap berada di direksi. Target ini diberi kode T-24, melanjutkan T-01 sampai T-23. Misalkan pemiliknya direktur pelayanan, tenggatnya 12 bulan, dan pekerjaannya masuk Paket B. Kedua, angka Rp120 juta hanya menutup kerja proses: BIA, rencana, pelatihan, dan latihan. Biaya solusi pada seksi strategi terpisah.

10.4 Analisis Dampak Bisnis

Empat ukuran

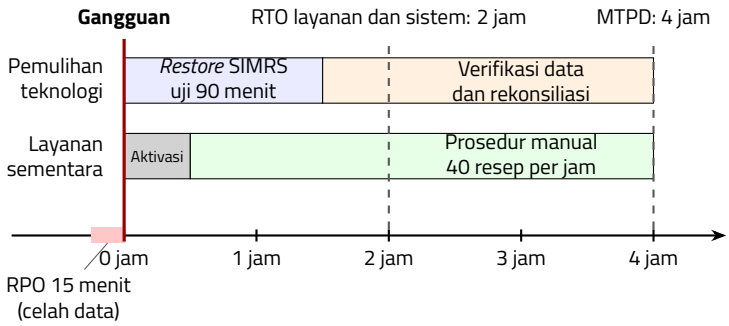
BIA menilai bagaimana dampak gangguan bertambah menurut waktu. Maximum Tolerable Period of Disruption (MTPD) adalah batas setelah dampak menjadi tidak dapat diterima. Recovery Time Objective (RTO) adalah target waktu pemulihan aktivitas pada kapasitas yang disepakati. Recovery Point Objective (RPO) menyatakan titik data yang harus dapat dipulihkan, sehingga biasanya diungkap sebagai kehilangan data maksimum menurut waktu. Minimum Business Continuity Objective (MBCO) menetapkan kapasitas minimum layanan. Bab ini menulis MBCO sebagai kapasitas minimum.

Analogi pencatatan kas menjelaskan perbedaannya. Toko menargetkan kasir berjalan kembali dalam dua jam. Salinan buku transaksi terakhir berasal dari 15 menit sebelum gangguan. Dua jam merupakan target waktu pemulihan, sedangkan 15 menit menunjukkan celah data. Memulihkan sistem cepat tidak mengganti transaksi yang hilang.

NIST memakai istilah Maximum Tolerable Downtime (MTD) untuk gagasan yang dekat dengan MTPD. Menurut panduan itu, RTO harus menjaga agar MTD tidak terlewati, sehingga RTO biasanya lebih pendek daripada MTD. Waktu memproses ulang data ikut dihitung. RPO tidak termasuk bagian MTD, karena RPO menyatakan kehilangan data yang dapat ditoleransi [149]. Tidak ada rasio baku antara RTO dan MTPD. Gambar 10.3 memperlihatkan letak keempat ukuran pada layanan farmasi.

Dua contoh penerapan:

1. Misalkan farmasi memiliki MTPD 4 jam, RTO 2 jam, RPO 15 menit, dan



Gambar 10.3: Letak RPO, RTO, MTPD, dan kapasitas minimum pada satu gangguan farmasi

kapasitas minimum 40 resep per jam. Layanan belum pulih bila server hidup tetapi hanya mampu memproses 5 resep per jam. Target terpenuhi bila keempat ukuran terpenuhi bersama.

2. Misalkan klaim Badan Penyelenggara Jaminan Sosial (BPJS) Kesehatan dapat menunggu satu hari. Ketergantungannya pada identitas pasien tetap perlu dipetakan agar pemulihan tidak terhambat.

Dua hal juga sering tertukar: MTPD dan batas *risk appetite* pada Bab 5. Pembagiannya begini. Batas Bab 5 bersifat kumulatif, yaitu gangguan pendaftaran 2 jam per bulan. Pelanggarannya memicu tinjauan mingguan. MTPD berlaku per kejadian, yaitu 6 jam pada pendaftaran. Pelanggarannya berarti dampak sudah tidak dapat diterima, dan pasien harus dialihkan. RTO pendaftaran karena itu ditetapkan 90 menit, sehingga satu kejadian yang memenuhi target masih menyisakan 30 menit dari batas bulanan.

Tiga langkah BIA

NIST menguraikan BIA menjadi tiga langkah: menentukan proses dan tingkat kekritisannya, mengidentifikasi sumber daya yang diperlukan, dan menetapkan prioritas pemulihan [149]. Medikara menjalankannya pada enam layanan: Instalasi Gawat Darurat (IGD), farmasi, laboratorium, pendaftaran, telekonsultasi, dan klaim BPJS. Pekerjaannya sendiri perlu dihitung. Misalkan BIA disusun untuk 6 layanan pada 5 rumah sakit, atau 30 baris, ditambah 2 layanan bagi 3 kelompok fasilitas lain, yaitu klinik, laboratorium, dan apotek, atau 6 baris. Totalnya 36 baris. Bila satu baris memerlukan 2 jam kerja 3 orang, BIA memakan 216 jam, atau Rp12,96 juta dengan tarif Rp60.000 per jam.

Langkah pertama menilai dampak menurut waktu. Tabel 10.6 memakai skala dampak 1 sampai 5 pada Bab 5 untuk rumah sakit Bekasi. Aturan bacanya

sederhana: MTPD adalah titik waktu pertama dengan nilai 4 atau lebih. Bab 5 juga meminta keselamatan dibaca terpisah dari skor gabungan, sehingga tabel menambahkan kolom cedera berat.

Tabel 10.6: Dampak gangguan menurut waktu pada rumah sakit Bekasi (misalkan)

Layanan	1 jam	4 jam	6 jam	12 jam	24 jam	48 jam	Cedera berat mungkin sejak
IGD	3	**4**	5	5	5	5	1 jam
Farmasi	2	**4**	4	5	5	5	4 jam
Laboratorium	2	**4**	4	5	5	5	4 jam
Pendaftaran	2	3	**4**	4	5	5	Tidak langsung
Telekonsultasi	1	2	2	**4**	4	5	Tidak langsung
Klaim BPJS	1	1	1	2	3	**4**	Tidak ada

Tabel 10.7 menurunkan hasil itu menjadi target. IGD melayani 24 jam, sedangkan layanan lain memakai pengandaian 12 jam per hari dari Bab 5. Gangguan dihitung sejak SIMRS berhenti. Prosedur manual memperpanjang daya tahan layanan, tetapi tidak menghentikan hitungan MTPD, karena data lintas unit tetap tidak terbaca. RTO layanan dapat dicapai lewat jalur apa pun, termasuk manual, selama kapasitas minimum terpenuhi.

Tabel 10.7: Contoh hasil BIA rumah sakit Bekasi (misalkan, perlu validasi pemilik layanan)

Layanan	Kapasitas normal	Kapasitas minimum	MTPD	RTO	RPO
IGD	6 pasien per jam	6 pasien per jam	4 jam	15 menit	5 menit
Farmasi	100 resep per jam	40 resep per jam	4 jam	2 jam	15 menit
Laboratorium	60 hasil per jam	20 hasil per jam	4 jam	2 jam	15 menit
Pendaftaran	40 pasien per jam	20 pasien per jam	6 jam	90 menit	30 menit
Telekonsultasi	40 konsultasi per jam	10 konsultasi per jam	12 jam	6 jam	60 menit
Klaim BPJS	300 klaim per hari	100 klaim per hari	48 jam	24 jam	4 jam

Angka kapasitas perlu cocok dengan bab lain. Bab 5 menghitung sekitar 274 kunjungan per jam untuk seluruh Medikara. Bila 5 rumah sakit masing-masing melayani 40 pendaftaran per jam, totalnya 200 dari 274, atau sekitar 73 persen,

dan sisanya berada di klinik. IGD tidak diberi kapasitas minimum yang lebih rendah, karena pasien gawat darurat tidak dapat menunggu. Angka klinis pada tabel bukan standar pelayanan dan harus divalidasi pihak yang berwenang.

MTPD IGD 4 jam perlu dibaca hati-hati. Angka itu bukan batas lama IGD boleh berhenti melayani, karena cedera berat pada Tabel 10.6 sudah mungkin terjadi sejak 1 jam. Angka itu menyatakan batas lama SIMRS boleh berhenti selama jalur manual berjalan penuh sejak menit ke-15. Bila jalur manual gagal, pasien dialihkan saat itu juga tanpa menunggu jam ke-4. Angka 4 jam adalah pengandaian untuk latihan hitungan, bukan nilai dari sumber klinis.

RTO layanan dan RTO sistem

Dua hal pada RTO sering tertukar. Pembagiannya begini. RTO layanan menyatakan kapan pasien kembali dilayani pada kapasitas minimum, lewat jalur apa pun. RTO sistem menyatakan kapan SIMRS dan datanya kembali. Rumusan NIST mengarah pada sumber daya sistem, sehingga target layanan pada BIA perlu diturunkan lebih dulu menjadi target sistem [149].

Analogi jembatan yang ditutup membantu. Warga masih dapat menyeberang dengan perahu pada kapasitas terbatas. Itu target layanan. Target perbaikan jembatan adalah urusan lain, tetapi perahu tidak dapat dipakai selamanya.

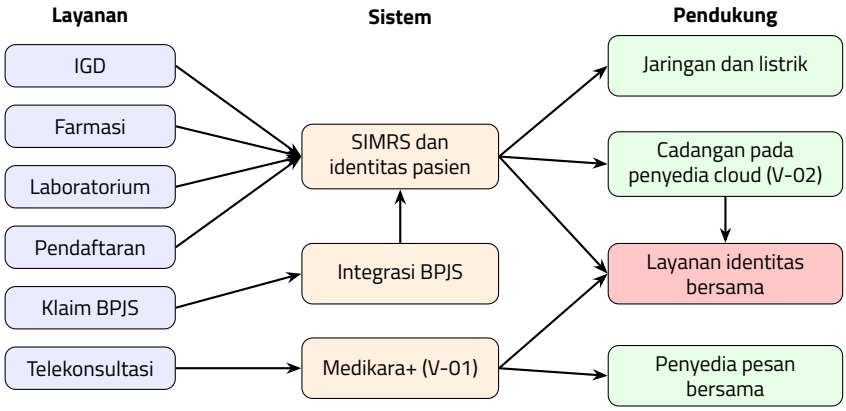
Dua contoh penurunan target:

1. MTPD terpendek pada Tabel 10.7 adalah 4 jam, atau 240 menit. Misalkan stabilisasi, verifikasi data, dan rekonsiliasi awal memerlukan 120 menit. RTO sistem SIMRS menjadi $240 - 120 = 120$ menit. Uji pemulihan yang mencatat 150 menit gagal 30 menit, walaupun formulir kertas sudah berjalan sejak menit ke-30.
2. Register Bab 5 mencatat cadangan malam sebagai kontrol R-05. Celah terburuknya mencakup 12 jam layanan sehari. Pada 100 resep per jam, data yang hilang mencapai 1.200 resep. Dengan 3 menit pengisian ulang per resep, pekerjaannya 60 jam. RPO 15 menit membatasi kehilangan menjadi 25 resep, atau 75 menit kerja. RPO juga tidak selalu sama dengan interval cadangan, karena kegagalan pencadangan, keterlambatan penyalinan, dan validasi dapat memperbesar celah.

Ketergantungan dan prioritas

Langkah kedua mengidentifikasi sumber daya dan ketergantungan. Target layanan tidak dapat lebih pendek daripada waktu pulih ketergantungannya, kecuali tersedia jalur lain. Analogi dapur katering menunjukkan hal ini. Dapur cadangan tidak membantu jika bahan dan juru masak berada di lokasi yang tidak dapat diakses.

Gambar 10.4 memperlihatkan ketergantungan enam layanan. Kode V-01 dan V-02 serta titik kegagalan bersamanya mengikuti peta Bab 9.



Panah berarti bergantung pada. Merah: titik kegagalan bersama menurut peta Bab 9. Rancangan target, seluruhnya pengandaian dan perlu dibuktikan lewat kontrak serta uji.

Gambar 10.4: Ketergantungan enam layanan pada sistem dan pihak pendukung (rancangan target)

Dua hitungan memperlihatkan akibatnya:

1. Bab 9 memperlihatkan 144 uji dapat lulus tanpa menjawab skenario akun pengelola yang diretas. Misalkan layanan identitas bersama berhenti, dan kontraknya menjanjikan pemulihan 8 jam. *Restore* SIMRS 90 menit baru dapat dimulai setelah pengelola dapat masuk. Waktu efektifnya 9,5 jam, atau 5,5 jam di atas MTPD 4 jam. Uji yang selalu memakai akun yang sama tidak akan menemukan selisih ini.
2. Misalkan kontrak V-01 menjanjikan pemulihan Medikara+ dalam 24 jam, sedangkan RTO telekonsultasi 6 jam dan MTPD-nya 12 jam. Selisih 18 jam terhadap RTO ditutup dengan jalur telepon 10 konsultasi per jam, atau dibawa ke tawar ulang kontrak. Dalam 24 jam itu, sekitar 933 janji temu ikut terganggu, karena 28.000 janji temu per bulan setara sekitar 933 per hari.

Langkah ketiga menetapkan prioritas. Urutan pada Medikara adalah identitas pasien lebih dulu, lalu IGD, farmasi, dan laboratorium, disusul pendaftaran, telekonsultasi, dan klaim BPJS. Identitas pasien didahulukan karena empat layanan pertama bergantung padanya. Larsen dan rekan juga menemukan identifikasi pasien sebagai masalah yang sering muncul ketika rekam medis elektronik berhenti [92]. Seksi strategi membaca penelitian itu lebih lengkap.

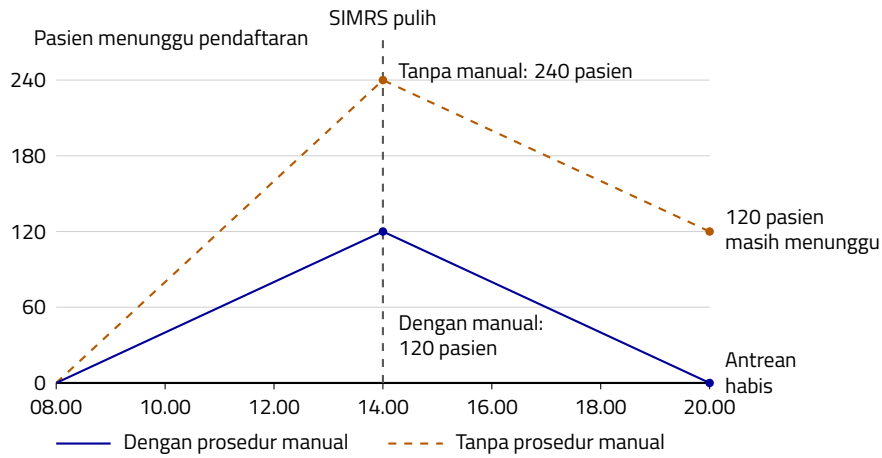
Kasus Medikara Health: Enam Jam di Bekasi

Misalkan SIMRS Bekasi berhenti pukul 08.00 dan pulih pukul 14.00. Pasien datang 40 per jam. Prosedur manual melayani 20 per jam, dan sesudah SIMRS pulih kapasitasnya naik menjadi 60 per jam dengan tambahan petugas. Gambar 10.5 memperlihatkan hasilnya.

Dalam enam jam, 240 pasien datang dan 120 terlayani, sehingga 120 pasien menunggu. Sesudah pukul 14.00, antrean turun 20 pasien per jam dan baru habis pukul 20.00, tepat saat layanan tutup. Tanpa prosedur manual, antrean mencapai 240 pasien, dan pukul 20.00 masih tersisa 120 pasien. Server yang pulih pada jam yang sama memberi hasil layanan yang berbeda.

Pekerjaan belum selesai. Sebanyak 120 pendaftaran manual pada 5 menit per data memerlukan 10 jam. Farmasi melayani 240 resep manual, dan pada 3 menit per resep memerlukan 12 jam. Totalnya 22 jam kerja, atau dua petugas selama 11 jam. Kepala rekam medis mengesahkan hasil rekonsiliasi itu.

Kejadian ini juga melewati dua batas. Enam jam melewati MTPD farmasi, IGD, dan laboratorium sebesar 2 jam, sehingga tim semestinya mengalihkan sebagian layanan sejak jam ke-4. Pendaftaran memakai 3 kali batas bulanan Bab 5. Kedua temuan dicatat sebagai bukti pada register risiko.



Pengandaian rumah sakit Bekasi: 40 pasien datang per jam, manual 20 per jam, tanpa manual 0 per jam, sesudah SIMRS pulih 60 per jam.

Gambar 10.5: Antrean pendaftaran selama dan sesudah gangguan enam jam di Bekasi (misalkan)

10.5 Strategi Kelangsungan

Empat sumber daya dan dua jalur

Strategi kelangsungan memilih kombinasi orang, data, tempat, dan vendor untuk memenuhi target layanan. Kombinasi itu menghasilkan dua jalur. Rencana operasional menjalankan layanan sementara pada kapasitas minimum yang aman. Rencana pemulihan menjalankan pemulihan teknologi, yaitu *restore* dan verifikasi data. Kedua jalur bertemu pada uji dan rekonsiliasi, yang membuktikan layanan aman pulih.

Analogi rumah makan yang kehilangan aliran gas membantu. Pemilik memakai kompor cadangan dengan menu terbatas sambil menunggu teknisi. Menu terbatas adalah layanan sementara. Perbaikan saluran adalah pemulihan teknologi. Buku pesanan dicocokkan sesudahnya. Tabel 10.8 menerapkan dua jalur itu pada enam layanan.

Tabel 10.8: Dua jalur strategi pada enam layanan (misalkan)

Layanan	Rencana operasional	Rencana pemulihan	Risiko sisa
IGD	Triase kertas, gelang identitas, pengalihan terkoordinasi	Salinan baca saja riwayat alergi lewat KB-04	Data lintas unit lambat; R-11
Farmasi	Resep kertas yang dapat diverifikasi	Cadangan terpisah dan pemulihan prioritas	Resep tanpa riwayat tertahan
Laboratorium	Hasil kritis lewat telepon dengan pembacaan ulang	Pemulihan antarmuka alat	Salah identitas
Pendaftaran	Formulir kertas dan daftar jadwal harian	Pemulihan identitas pasien lebih dulu	Antrean dan rekonsiliasi
Telekonsultasi	Alih ke telepon, 10 konsultasi per jam	Kontrak V-01 dan uji ekspor tahunan	Janji temu tertunda
Klaim BPJS	Tunda, lalu 100 klaim per hari	Pulih sesudah layanan klinis	Penumpukan administrasi

Satu penelitian menunjukkan prosedur manual tidak aman dengan sendirinya. Larsen dan rekan menelaah 80.381 laporan insiden keselamatan pasien dan menemukan 76 laporan yang secara eksplisit menyebut rekam medis elektronik yang berhenti [92]. Dari 76 laporan itu:

1. Sebanyak 37 laporan, atau 48,7 persen, menyangkut pemesanan dan hasil laboratorium. Sebanyak 11 laporan, atau 14,5 persen, menyangkut pemesanan dan pemberian obat.
2. Sebanyak 35 laporan, atau 46 persen, memperlihatkan prosedur saat sistem

berhenti tidak diikuti atau tidak tersedia. Hanya 21 laporan, atau 27,6 persen, memperlihatkan prosedur berjalan.

Laporan insiden tidak menunjukkan seberapa sering gangguan terjadi, sehingga persentase itu tidak boleh disalin menjadi peluang Medikara. Pada pembacaan bab ini, nilainya terletak pada arah perhatian. Laboratorium, obat, dan identitas pasien menjadi fokus pertama prosedur manual, dan pelatihannya perlu dibuktikan.

Replikasi dan cadangan

Dua hal pada data sering tertukar: replikasi dan cadangan. Pembagiannya begini. Replikasi menyalin perubahan dengan cepat ke lokasi lain, sehingga mengurangi kehilangan data dan mempercepat peralihan. Replikasi juga dapat menyalin kerusakan atau perubahan berbahaya. Cadangan terpisah menyimpan salinan pada titik waktu tertentu, sehingga data sebelum kerusakan masih tersedia, tetapi pemulihannya dapat lebih lambat. Lokasi alternatif mengurangi dampak lokasi, tetapi tetap bergantung pada jaringan dan orang. Kebutuhan ketiganya berbeda, dan uji pemulihan tetap diperlukan.

Analogi fotokopi dokumen menjelaskan bedanya. Mesin yang menyalin setiap halaman baru ke kantor cabang ikut menyalin halaman yang salah. Arsip mingguan di lemari terkunci tidak mengikuti kesalahan itu, tetapi isinya tertinggal.

Dua contoh penerapan:

1. Misalkan replikasi berjalan setiap 5 menit. Pada kegagalan perangkat, kehilangan data paling lama 5 menit. Pada serangan *ransomware*, berkas terenkripsi ikut tersalin 5 menit kemudian. RPO 5 menit hanya berlaku pada skenario yang pertama.
2. Bab 9 mengandaikan cadangan pada akun cloud yang sama dengan produksi. Akun yang diretas dapat merusak kedua salinan. DORA Pasal 12 ayat (3) meminta pemulihan memakai sistem yang terpisah secara fisik dan logis [37]. Aturan itu tidak mengikat Medikara, tetapi memberi rumusan yang tepat untuk K-02: tempat berbeda belum cukup bila aksesnya sama.

Tiga opsi pada lingkup yang sama

Biaya dibandingkan pada ruang lingkup dan periode yang sama. Tabel 10.9 membandingkan tiga opsi untuk lima rumah sakit selama setahun. Opsi A hanya memakai prosedur manual dan cadangan malam yang ada. Opsi B menambahkan cadangan terpisah dan pemulihan prioritas. Opsi C memakai replikasi aktif pada dua lokasi, dengan biaya misalkan Rp1,2 miliar per rumah sakit. Selisih A dan B sebesar Rp360 juta perlu dijelaskan oleh pengurangan dampak dan kebutuhan

layanan.

Tabel 10.9: Tiga opsi strategi untuk lima rumah sakit per tahun (misalkan)

Ukuran	**Target**	**A. Manual terkontrol**	**B. Manual dan pemulihan prioritas**	**C. Replikasi aktif**
Biaya per tahun		Rp120 juta	Rp480 juta	Rp6 miliar
Manual farmasi aktif	2 jam	30 menit	30 menit	30 menit
Kapasitas manual farmasi	40 resep per jam	20 resep per jam	40 resep per jam	40 resep per jam
SIMRS pulih	120 menit	480 menit	90 menit	Mendekati nol; 90 menit bila data rusak
Titik data	15 menit	Sampai 24 jam	10 menit	Mendekati nol; 10 menit bila data rusak
Harapan kerugian R-05		Rp200 juta	Rp40 juta	Rp40 juta
Biaya ditambah harapan kerugian		Rp320 juta	Rp520 juta	Rp6,04 miliar
Hasil		Ditolak	Layak bersyarat	Ditolak

Harapan kerugian mengikuti Bab 5 dan Bab 8. R-05 memiliki peluang 0,1 dan kerugian Rp2 miliar, atau Rp200 juta per tahun. Bab 8 menghitung peluang kerugian Rp1,5 miliar atau lebih sebesar 10 persen, sedangkan batasnya 2 persen, sehingga peluang harus turun menjadi 0,02. Harapan kerugiannya menjadi Rp40 juta. Tabel menganggap opsi B dan C mencapai 0,02, dan anggapan itu harus dibuktikan lewat uji. Opsi C tetap memerlukan cadangan terpisah, sehingga tidak lebih baik daripada B pada skenario data rusak.

Dua contoh memperlihatkan alasan penolakan:

1. Opsi A pulih dalam 8 jam dengan biaya Rp120 juta per tahun. Opsi ini gagal memenuhi RTO sistem 120 menit dan melewati MTPD 4 jam. Pendaftaran masih lolos RTO 90 menit lewat formulir kertas, tetapi SIMRS kembali sesudah melewati MTPD 6 jam. Murah saja tidak cukup.
2. Opsi C menelan Rp6 miliar per tahun, atau 12,5 kali opsi B. Angka itu melewati batas keputusan direksi Rp5 miliar pada Bab 2, dan setara 60 persen anggaran modernisasi Rp10 miliar setiap tahun. Opsi ini juga belum menjawab data yang rusak.

Pilihan antara A dan B memperlihatkan *tradeoff* yang nyata, dan punya tiga

konsekuensi. Pertama, dalam rupiah saja, A lebih murah Rp200 juta per tahun. Tambahan biaya Rp360 juta hanya menurunkan harapan kerugian Rp160 juta. Kedua, A melanggar batas 2 persen dan kapasitas minimum farmasi, sehingga selisih Rp200 juta adalah harga untuk memenuhi batas yang sudah ditetapkan, bukan investasi yang kembali modal. Ketiga, penghematan tidak boleh mengabaikan batas keselamatan yang ditetapkan pemilik layanan. Harapan kerugian tidak mengukur cedera pasien.

Kasus Medikara Health: Persetujuan Bersyarat atas Opsi B

Misalkan direksi menerima usulan opsi B karena Rp480 juta melewati batas Rp400 juta. Kepala operasi TI melaporkan uji 90 menit baru dilakukan pada lingkungan uji, sehingga hasilnya belum mewakili lima rumah sakit. Direksi menyetujui opsi B dengan dua syarat.

Syarat pertama: tambahan Rp360 juta dicairkan dua tahap, masing-masing Rp180 juta. Tahap kedua cair bila 5 dari 5 rumah sakit lulus uji SIMRS di bawah 120 menit. Syarat kedua: 9 uji akun terpisah pada satu triwulan berhasil memulihkan data, sehingga temuan Bab 9 terjawab.

Pilihan ini punya biaya. Selama syarat belum terpenuhi, peluang R-05 masih dicatat 0,1, bukan 0,02, dan risiko sisa dilaporkan ke komite risiko setiap triwulan. Latihan terpadu dua layanan pada peta jalan Bab 14 seharga Rp180 juta sekali dijadwalkan sesudah tahap kedua.

Pendalaman Teknis (opsional)

Target bisnis perlu diuji terhadap rancangan teknis pada IT40713. Misalkan data SIMRS satu rumah sakit berukuran 4 terabyte. Pada kecepatan pemulihan 200 megabyte per detik, pemulihan penuh memerlukan 20.000 detik, atau sekitar 5,6 jam. Angka ini gagal terhadap RTO sistem 120 menit. Pada 800 megabyte per detik, waktunya 5.000 detik, atau sekitar 83 menit, masih di bawah uji 90 menit. Tim juga dapat memulihkan data identitas dan obat lebih dulu. Selisih yang tersisa dicatat sebagai risiko yang harus diterima atau ditangani, bukan disembunyikan pada target yang dilonggarkan.

10.6 Insiden Siber dan Manajemen Krisis

Insiden, krisis organisasi, dan Krisis Siber

Insiden siber memerlukan pencatatan, penilaian dampak, pembatasan penyebaran, pemulihan, dan pembelajaran. Peraturan BSSN 1/2024 mendefinisikannya

sebagai satu atau serangkaian kejadian yang mengganggu atau mengancam berjalannya sistem elektronik. Pasal 15 meminta tim organisasi melaporkan insiden yang paling sedikit berisiko tinggi kepada tim sektoral, dengan tembusan kepada tim nasional. Laporannya paling sedikit memuat kontak pelapor, deskripsi, kronologi, dan dampak serangan [9]. Batas 1×24 jam pada Pasal 15 ayat (5) berlaku bila insiden terjadi pada IIV, seperti sudah dicatat pada Bab 3.

Dua hal pada istilah krisis sering tertukar. Pembagiannya begini. Peraturan BSSN 2/2024 mendefinisikan Krisis Siber sebagai situasi kedaruratan akibat insiden siber pada tingkat nasional, yang berdampak terhadap keselamatan, keutuhan, dan kedaulatan negara. Statusnya ditetapkan Presiden berdasarkan usulan Kepala BSSN [10]. Rumah sakit tidak dapat menyatakan Krisis Siber. Krisis organisasi adalah istilah internal, yaitu keadaan ketika kapasitas penanganan biasa tidak cukup atau konsekuensinya meluas, sehingga pimpinan mengambil alih koordinasi. Gambar 10.6 memperlihatkan ketiga tingkatnya.



Gambar 10.6: Tiga tingkat eskalasi: insiden, krisis organisasi, dan Krisis Siber

Analogi kecelakaan di jalan membantu membagi peran. Petugas menolong dan menjaga lokasi. Pimpinan mengatur pengalihan layanan dan informasi publik. Juru bicara menyampaikan informasi yang telah diverifikasi. Ketiganya perlu memakai catatan kejadian yang sama.

Dua contoh penerapan:

1. Misalkan pukul 08.00 ditemukan berkas terenkripsi dan pukul 08.15 jaringan terdampak diisolasi. Keputusan isolasi dicatat beserta dampaknya pada pasien. Bila IGD ikut terdampak dan RTO 15 menit terlewat, pemicu krisis organisasi terpenuhi. Direksi mengambil alih koordinasi tanpa menunggu penyebabnya pasti.
2. Misalkan BSSN menyampaikan peringatan dini eskalasi nasional. Pasal 11 Peraturan BSSN 2/2024 mewajibkan PSE menindaklanjutinya dan melaporkan hasilnya setiap 2 jam. Dalam 12 jam layanan, Medikara menyiapkan 6 laporan. Jalur laporan itu perlu pemilik sebelum peringatan datang.

Komunikasi dan pemberitahuan

Komunikasi menyebut apa yang diketahui, dampak layanan, tindakan sementara, dan waktu pembaruan. Rencana komunikasi krisis biasanya menunjuk orang tertentu sebagai satu-satunya pihak yang menjawab pertanyaan publik [149]. Dugaan kebocoran diperiksa melalui jalur pelindungan data pribadi pada Bab 7. Pemulihan teknologi tidak menghentikan penilaian kewajiban pemberitahuan menurut Undang-Undang (UU) 27/2022 [136]. Tim tidak menunggu investigasi selesai untuk menyiapkan keputusan pemberitahuan.

Dua contoh penerapan:

1. Misalkan pukul 09.00 media meminta penjelasan. Juru bicara menyatakan cakupan layanan yang terdampak dan jadwal pembaruan, tanpa mengumumkan penyebab yang belum terverifikasi. Pernyataan "tidak ada data yang keluar" tidak dipakai sebelum ada buktinya.
2. Misalkan Selasa pukul 09.15 muncul indikasi data keluar. Dengan cara hitung Bab 7, batas internal jam ke-60 jatuh pada Kamis 21.15, dan batas terluar 3×24 jam jatuh pada Jumat 09.15. Bila vendor terlibat, laporan 12 jam pada K-05 jatuh pada Selasa 21.15. Pemulihan SIMRS selesai pukul 14.00 tidak menggeser ketiga batas itu.

Tabel 10.10 merangkum catatan keputusan krisis. Kolom target mengikuti skenario latihan pada seksi berikutnya, dan bukan kewajiban hukum, kecuali baris pemberitahuan.

Tabel 10.10: Catatan keputusan krisis (misalkan)

Keputusan	Pemilik	Target waktu	Bukti
Isolasi sistem	Kepala operasi TI sebagai pemimpin tanggap insiden	15 menit	Alasan dan waktu isolasi
Operasi manual	Direktur rumah sakit	20 menit	Kapasitas dan batas aman
Pengalihan pasien	Direktur pelayanan	30 menit	Fasilitas penerima dan kapasitasnya
Pernyataan publik	Direktur utama	60 menit	Fakta terverifikasi dan jadwal pembaruan
Pemberitahuan	Fungsi hukum dan petugas pelindungan data	Jam ke-60, batas terluar 3×24 jam	Dasar, penerima, waktu kirim

Pengalihan pasien: membaca satu penelitian

Pertanyaan kemudian muncul: apakah pengalihan menyelesaikan masalah? Dameff dan rekan menelaah serangan *ransomware* pada Mei 2021 terhadap satu organisasi dengan 4 rumah sakit di Amerika Serikat. Mereka membandingkan 2 instalasi gawat darurat di organisasi lain yang tidak terserang, pada 4 minggu sebelum dan 4 minggu selama serangan [27]. Dua pembacaan penting:

1. Beban pindah ke tetangga. Rata-rata jumlah pasien harian naik dari 218,4 menjadi 251,4, atau 15,1 persen. Kedatangan ambulans naik dari 1.741 menjadi 2.354, atau 35,2 persen. Median waktu sampai masuk ruang periksa naik dari 21 menjadi 31 menit. Pasien yang pulang sebelum dilayani naik dari 158 menjadi 360.
2. Penulis menyarankan serangan seperti ini diperlakukan sebagai bencana regional dengan perencanaan terkoordinasi. Desainnya observasional pada satu wilayah, sehingga angkanya tidak dapat digeneralisasi begitu saja.

Angka itu tidak disalin ke Medikara. Medikara dapat memakai cara berpikirnya. Misalkan IGD Bekasi mengalihkan 3 dari 6 pasien per jam ke IGD Jakarta dan IGD Depok. Bila masing-masing penerima normalnya melayani 6 pasien per jam, keduanya bertambah 1,5 pasien per jam, atau 25 persen. Rencana pengalihan karena itu memuat kapasitas penerima dan persetujuannya, bukan hanya nama fasilitas.

10.7 Latihan dan Pengujian

Setiap metode menjawab pertanyaan berbeda

Latihan *tabletop* menguji pembahasan keputusan melalui skenario di meja rapat. NIST menjelaskan latihan ini sebagai diskusi peran dan keputusan yang tidak mengerahkan peralatan. Latihan fungsional meminta petugas menjalankan perannya dalam lingkungan simulasi [149]. Uji pemulihan teknis membuktikan kemampuan sistem. Diskusi yang lancar belum membuktikan RTO tercapai. Peraturan BSSN 2/2024 Pasal 6 memisahkan latihan teknis dari pemeranan pengambilan keputusan manajerial, termasuk *tabletop exercise*, walaupun pasal itu mengatur simulasi nasional oleh BSSN [10].

Analogi latihan olahraga menunjukkan perlunya ukuran keberhasilan. Menjelaskan strategi pertandingan berbeda dari menjalankannya dalam waktu yang ditentukan. Pengamat perlu mencatat keputusan, waktu, dan kesenjangan terhadap target. Tabel 10.11 merangkum batas bukti tiap metode.

Dua contoh penerapan:

Tabel 10.11: Jenis pengujian dan batas buktinya

Metode	Yang diuji	Yang belum dibuktikan
Tabletop	Wewenang dan keputusan	Kecepatan pemulihan server
Latihan fungsional	Peran dan prosedur satu fungsi, misalnya farmasi manual	Fungsi lain dan data lintas unit
Uji teknis	Waktu dan integritas data	Kesiapan seluruh petugas
Latihan terpadu	Layanan minimum lintas unit	Semua skenario masa depan

1. Misalkan latihan menetapkan keputusan layanan manual paling lama 20 menit. Tim memerlukan 35 menit karena daftar kewenangan tidak tersedia. Selisih 15 menit merupakan temuan yang dapat ditindaklanjuti.
2. Misalkan uji pemulihan mencatat 150 menit terhadap RTO 120 menit. Selisih 30 menit diteruskan ke register risiko dan rancangan teknis mata kuliah IT40713.

Mengisi 144 uji pemulihan

Bab 3 menghitung 144 uji, yaitu 36 fasilitas dikali 4 uji per tahun, dan Bab 6 menghitung 3 jam per uji, atau 432 jam. Bab ini tidak mengubah jumlah itu. Bab ini mengubah isinya. Pertanyaan yang muncul: apa yang dibuktikan 144 uji bila semuanya serupa? Analogi pemeriksaan alat pemadam menjawabnya. Memeriksa tekanan tabung 144 kali tidak membuktikan penghuni tahu jalur keluar.

Keputusan mengisi ulang 144 uji punya dua konsekuensi yang dapat dihitung:

1. Dari 36 fasilitas, hanya 5 yang menjalankan SIMRS rumah sakit. Uji SIMRS berjumlah 5 kali 4, atau 20 dari 144. Sisanya, 124 uji, menyentuh 31 fasilitas lain. Laporan yang menggabungkan keduanya menyamarkan hasil pada layanan dengan MTPD terpendek.
2. Setiap fasilitas menjalankan 3 uji biasa dan 1 uji memakai akun terpisah. Totalnya 108 uji biasa dan 36 uji akun terpisah, atau 25 persen. Uji akun terpisah menjawab temuan Bab 9 tanpa menambah 432 jam.

Tabel 10.12 memperlihatkan contoh hasil triwulan pertama, yaitu 36 uji. Angka gabungan 80,6 persen terlihat baik. Pada rumah sakit, angkanya hanya 60 persen. Dua kegagalan data seluruhnya berasal dari 9 uji akun terpisah, sedangkan 27 uji biasa tidak menemukan kegagalan data. Tingkat lulus uji bukan peluang R-05, sehingga angka ini tidak disamakan dengan 0,02.

Tabel 10.12: Contoh hasil 36 uji pemulihan triwulan pertama (misalkan)

Kelompok	Jumlah uji	Lulus	Lewat RTO	Data gagal	Persen lulus
5 rumah sakit	5	3	1	1	60,0
31 fasilitas lain	31	26	4	1	83,9
Total	36	29	5	2	80,6

Merancang skenario tabletop

Skenario yang baik menambahkan informasi bertahap. Setiap informasi memaksa satu pilihan, bukan laporan keadaan. Tabel 10.13 memuat skenario SIMRS terenkripsi di Bekasi dengan tujuh keputusan. Diskusi berlangsung 45 menit dan evaluasi 15 menit. Waktu skenario dapat berbeda dari waktu diskusi, sehingga pengamat mencatat keduanya. Latihan ini tidak menyentuh sistem nyata, tidak memakai data pasien, dan memakai target BIA, bukan angka baru yang dipilih saat latihan.

Tabel 10.13: Skenario *tabletop* dan contoh hasil (misalkan, menit sejak informasi diterima)

Waktu	Informasi dan keputusan	Pemilik	Target	Aktual
08.00	SIMRS tidak dapat dibuka. Siapa memimpin?	Kepala operasi TI	10	8
08.15	Berkas terenkripsi di tiga unit. Apa yang diisolasi?	Kepala operasi TI	15	15
08.15	Layanan terganggu. Kapan manual aktif?	Direktur rumah sakit	20	35
08.30	Cadangan terakhir belum tervalidasi. Strategi apa dipilih?	Direktur pelayanan	30	25
08.45	Vendor tidak dapat dihubungi. Kapan jalur lain aktif?	Kepala operasi TI	15	40
09.00	Media menanyakan kebocoran. Apa yang diumumkan?	Direktur utama	60	50
09.15	Indikasi data keluar. Kapan proses pemberitahuan dimulai?	Fungsi hukum	30	45

Kasus Medikara Health: Membaca Hasil Tabletop Bekasi

Empat dari tujuh keputusan tepat waktu, atau sekitar 57 persen. Tiga keputusan terlambat, masing-masing 15, 25, dan 15 menit, atau total 55 menit. Pengamat memisahkan penyebabnya menjadi kewenangan, teknis, komunikasi, dan kapasitas layanan.

Aktivasi manual terlambat karena daftar kewenangan tidak tersedia pada malam dan akhir pekan. Direktur rumah sakit menerbitkan daftar pengganti dalam 14 hari. Jalur vendor terlambat karena hanya ada satu nomor kontak. Kepala operasi TI memasukkan kontak cadangan ke kontrak dalam 30 hari.

Pemberitahuan terlambat karena fungsi hukum baru diundang pukul 09.15. Fungsi hukum masuk daftar panggilan awal dalam 14 hari. Ketiganya diuji ulang dalam 60 hari.
Keputusan yang cepat belum tentu benar. Pada pukul 08.30, direktur pelayanan memilih dalam 25 menit, tetapi memakai cadangan yang belum tervalidasi sebagai dasar. Pengamat mencatat dasar bukti tiap keputusan, sehingga keputusan tepat waktu itu tetap menjadi temuan.
Bila latihan diulang pada 5 rumah sakit dengan 6 peran dan 1 pengamat selama 1 jam, bebannya 35 jam per tahun, atau Rp2,1 juta. Ditambah BIA 216 jam, beban Bab 8 naik dari 1.192 jam menjadi 1.443 jam pada tahun pertama, atau sekitar 0,75 orang penuh waktu.

10.8 Aktivitas: BIA dan Strategi Kelangsungan Layanan

Tujuan. Tim menetapkan urutan pemulihan yang dapat dipertanggungjawabkan untuk lima sampai tujuh layanan, memilih strategi untuk dua layanan paling kritis, dan menguji keputusan lewat latihan *tabletop*. Tim memakai organisasi nyata dengan izin dan data yang dianonimkan, atau kasus Medikara Health.

Pembagian peran. Anggota berlatar kesehatan atau operasional memimpin penilaian dampak. Analis teknologi menilai apakah RTO dan RPO dapat dicapai arsitektur target. Analis risiko menautkan keputusan ke *risk register*. Pemilik konteks memvalidasi prosedur manual dan kewenangan.

Langkah kerja.

1. Pilih lima sampai tujuh layanan dan catat kapasitas normalnya. Periksa kecocokan angka dengan jumlah kunjungan keseluruhan. Gunakan asumsi berlabel bila data tidak tersedia.
2. Nilai dampak keselamatan, layanan, hukum, dan keuangan pada beberapa waktu gangguan. Isi `sources/chapter10/templat-bia.csv` dan bandingkan dengan `sources/chapter10/contoh-bia-medikara.csv`.
3. Sepakati MTPD, RTO, RPO, kapasitas minimum, dan ketergantungan. Periksa apakah target teknologi sama dengan target layanan, lalu turunkan RTO sistem.
4. Bandingkan dua strategi untuk dua layanan paling kritis dengan `sources/chapter10/perbandingan-strategi.csv`. Nyatakan biaya tahunan, asumsi, dan risiko sisa pada lingkup yang sama.
5. Isi `sources/chapter10/praktik-dss04.csv` dan `sources/chapter10/rencana-uji-pemulihan.csv`. Tandai bukti yang belum tersedia.

6. Jalankan skenario di `sources/chapter10/skenario-tabletop-ransomware.md`. Tunjuk pengamat yang mencatat waktu keputusan dan dasar buktinya.
7. Catat tindakan perbaikan, pemilik, tenggat, dan tanggal pengujian ulang. Selaraskan target dengan rancangan pemulihan di IT40713.

Luaran. BIA, perbandingan strategi dua layanan, target DSS04, rencana uji, dan catatan latihan.

Kaitan dengan capstone. Luaran masuk tonggak C3 Kondisi Target. Target pemulihan diselaraskan dengan IT40713. Bab 12 memakai hasil uji sebagai bukti audit, Bab 13 memakai RTO untuk bahan indikator, dan Bab 14 memakai latihan terpadu pada peta jalan.

Kriteria penilaian. Keterlacakan dampak ke target 35 persen; strategi dan biaya layak 30 persen; mutu keputusan latihan 20 persen; tindak lanjut yang terukur 15 persen. Penilaian berfokus pada penalaran, bukan pada kesamaan angka dengan contoh.

Berkas pendukung. Seluruh lembar kerja ada di `sources/chapter10/`, dengan daftar berkas pada `sources/chapter10/README.md`. Data pasien dan dokumen asli tidak boleh disalin ke folder tugas. Latihan *tabletop* tidak menyentuh sistem nyata.

Pendalaman Teknis (opsional)

Bandingkan waktu pulih dan titik data terakhir dari uji cadangan di lingkungan sendiri dengan RTO dan RPO. Gunakan data sintetis. Uji hanya dilakukan pada sistem sendiri atau yang sudah berizin tertulis. Pemulihan baru dinyatakan selesai setelah data diverifikasi dan layanan minimum diuji, bukan saat proses server mulai berjalan. Selisih terhadap rancangan IT40713 dicatat sebagai risiko.

10.9 Ringkasan

Kelangsungan bisnis mempertahankan hasil layanan ketika kondisi normal tidak tersedia. Manajemen insiden, kelangsungan bisnis, dan pemulihan bencana memiliki pertanyaan dan bukti yang berbeda, walaupun bermula dari satu kejadian. Direksi menetapkan toleransi, pemilik layanan menetapkan kapasitas minimum, dan tim teknologi membuktikan kemampuan pemulihan. DSS04 yang ditunda Bab 4 kini mendapat target tingkat 3, sehingga rancangan Bab 8 menjadi Rp720 juta per tahun.

BIA menghubungkan dampak menurut waktu dengan MTPD, RTO, RPO, dan

kapasitas minimum. Keempatnya tidak saling menggantikan. MTPD 4 jam menurunkan RTO sistem 120 menit, dan ketergantungan dapat mengalahkan target. Layanan identitas dengan janji 8 jam mengubah *restore* 90 menit menjadi 9,5 jam. Pada kasus Bekasi, server pulih pukul 14.00, tetapi antrean baru habis pukul 20.00.

Strategi menggabungkan orang, data, tempat, dan vendor pada dua jalur: layanan sementara dan pemulihan teknologi. Replikasi dan cadangan memiliki fungsi berbeda. Prosedur manual tetap memerlukan batas aman, pelatihan, dan rekonsiliasi. Opsi B seharga Rp480 juta lebih mahal Rp200 juta per tahun daripada opsi A setelah harapan kerugian dihitung. Selisih itu adalah harga untuk memenuhi batas 2 persen pada R-05.

Insiden siber, krisis organisasi, dan Krisis Siber berada pada tingkat yang berbeda. Status Krisis Siber ditetapkan Presiden, sedangkan krisis organisasi diputuskan pimpinan Medikara. Pemulihan sistem tidak menggeser batas pemberitahuan 3×24 jam. Pengalihan pasien memindahkan beban ke fasilitas penerima, sehingga kapasitasnya harus masuk rencana.

Latihan menguji keputusan, sedangkan uji teknis memeriksa kemampuan sistem. Jumlah 144 uji tidak berubah, tetapi 20 di antaranya menyentuh SIMRS dan 36 memakai akun terpisah. Hasil keduanya masuk ke tindakan perbaikan. Pesan utama bab ini adalah bahwa layanan pulih ketika pasien dapat dilayani secara aman pada kapasitas yang disepakati.

10.10 Latihan

Latihan 1: Waktu dan Data Farmasi

Jelaskan perbedaan RTO dan RPO dengan contoh layanan farmasi rumah sakit. Latihan ini membuktikan kemampuan membedakan waktu pemulihan layanan dan celah data.

1. Tetapkan saat gangguan dan target pemulihan farmasi.
2. Catat titik data terakhir yang dapat dipulihkan, lalu hitung celahnya.
3. Catat waktu pulih dan kapasitas yang tercapai.
4. Bandingkan hasil dengan target dan jelaskan konsekuensi rekonsiliasinya.

Tabel 10.14 memuat contoh dengan gangguan pukul 10.00, data terakhir pukul 09.50, dan pulih pukul 12.30. Tabel 10.15 merupakan lembar hasil.

Hasil dapat berbeda; penilaian bertumpu pada alasan dan perbandingan bukti.

1. Target mana yang gagal dan berapa selisihnya?
2. Mengapa keberhasilan RPO tidak menutup kegagalan RTO?

Tabel 10.14: Contoh Latihan 1 (skenario pembelajaran)

Ukuran	Target	Hasil contoh	Selisih
RTO	120 menit	Pulih dalam 150 menit	Gagal 30 menit
RPO	15 menit	Data terakhir 10 menit sebelum gangguan	Lulus, sisa 5 menit
Kapasitas minimum	40 resep per jam	40 resep per jam lewat manual	Lulus
Resep diisi ulang	Paling banyak 25	Sekitar 17, yaitu 100 per jam kali 10 menit	Lulus

Tabel 10.15: Lembar hasil Latihan 1

Ukuran	Target	Hasil	Selisih
...	...	...	...
...	...	...	...
...	...	...	...

3. Selama 150 menit, berapa resep yang harus dicocokkan kembali bila manual melayani 40 resep per jam?

Latihan 2: Biaya Target Pemulihan

Mengapa RTO untuk semua layanan tidak boleh ditetapkan nol? Kaitkan dengan biaya dan *risk appetite*. Latihan ini membuktikan ketepatan pemilihan strategi menurut dampak. NIST menggambarkan dua kurva: biaya gangguan naik seiring lamanya gangguan, dan biaya pemulihan naik seiring pendeknya RTO. Titik seimbangnya berbeda pada setiap organisasi [149].

1. Pilih dua layanan dengan dampak berbeda.
2. Bandingkan tiga opsi biaya dan kemampuan pemulihan pada lingkup dan periode yang sama.
3. Hitung biaya ditambah harapan kerugian, lalu periksa batas *risk appetite*.
4. Pilih opsi yang memenuhi toleransi dan jelaskan risiko sisanya.

Tabel 10.16 memuat contoh dari seksi strategi, dan Tabel 10.17 merupakan lembar hasil.

Hasil dapat berbeda; penilaian bertumpu pada alasan dan perbandingan bukti.

1. Apa yang harus dibuktikan sebelum biaya lebih besar disetujui?

Tabel 10.16: Contoh Latihan 2 (skenario pembelajaran)

Opsi	RTO sistem	Biaya	Harapan rugi	Jumlah	Batas 2 persen
A. Manual	480 menit	Rp120 juta	Rp200 juta	Rp320 juta	Terlewati, 10 persen
B. Manual dan pemulihan	90 menit	Rp480 juta	Rp40 juta	Rp520 juta	Terpenuhi bila teruji
C. Replikasi aktif	Mendekati nol	Rp6 miliar	Rp40 juta	Rp6,04 miliar	Terpenuhi bila teruji

Tabel 10.17: Lembar hasil Latihan 2

Opsi	RTO sistem	Biaya	Harapan rugi	Jumlah	Batas
...	...	...	...	...	...
...	...	...	...	...	...
...	...	...	...	...	...

2. Dampak apa yang membuat pilihan murah tidak dapat diterima, walaupun jumlahnya paling kecil?
3. Mengapa RTO mendekati nol tidak menurunkan harapan kerugian pada skenario data rusak?

Latihan 3: Keputusan dalam Krisis

Rancang tiga pertanyaan keputusan yang harus dijawab direksi dalam latihan *tabletop* serangan *ransomware*. Latihan ini membuktikan kejelasan wewenang dan batas waktu keputusan.

1. Baca `sources/chapter10/skenario-tabletop-ransomware.md`.
2. Tulis tiga pertanyaan yang menuntut pilihan, bukan laporan keadaan.
3. Tetapkan pengambil keputusan, batas waktu, dan bukti keputusan.

Tabel 10.18 memuat contoh. Pertanyaan pertama menyangkut lima rumah sakit. Bila keempat rumah sakit lain ikut beralih ke manual sebagai pencegahan, kapasitas pendaftaran seluruh rumah sakit turun dari 200 menjadi 100 pasien per jam. Tabel 10.19 merupakan lembar hasil.

Hasil dapat berbeda; penilaian bertumpu pada alasan dan perbandingan bukti.

1. Keputusan mana yang bergantung pada informasi klinis?
2. Bagaimana menilai keputusan yang cepat tetapi memakai data yang salah?

Tabel 10.18: Contoh Latihan 3 (skenario pembelajaran)

Pertanyaan keputusan	Pemilik	Target waktu	Bukti
Apakah empat rumah sakit lain ikut beralih ke manual sebagai pencegahan?	Direktur utama	30 menit	Cakupan serangan dan dampak 100 pasien per jam
Fasilitas mana menerima pengalihan dan sampai kapan?	Direktur pelayanan	30 menit	Kapasitas dan persetujuan penerima
Kapan pembaruan publik berikutnya dan apa isinya?	Direktur utama	60 menit	Fakta terverifikasi dan pendapat fungsi hukum

Tabel 10.19: Lembar hasil Latihan 3

Pertanyaan keputusan	Pemilik	Target waktu	Bukti
…	…	…	…
…	…	…	…
…	…	…	…

Bab 11

Tata Kelola Kecerdasan Artifisial

Tujuan Pembelajaran

- Mengidentifikasi kasus pemakaian AI (*Artificial Intelligence*) di organisasi dan mengklasifikasi risikonya.
- Menjelaskan persyaratan sistem manajemen AI menurut ISO/IEC 42001:2023 dan pendekatan berbasis risiko dalam EU AI Act.
- Merumuskan kebijakan pemakaian AI yang dapat dijalankan dan diawasi.

11.1 Pendahuluan

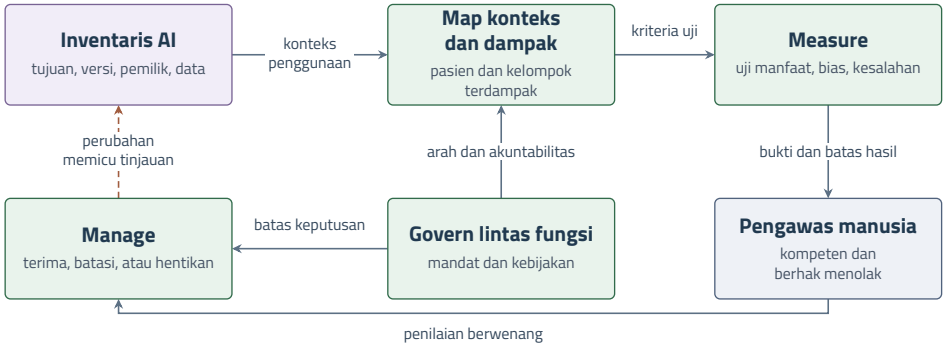
Misalkan seorang petugas di rumah sakit Medikara memakai *chatbot* AI umum untuk merangkum catatan pasien, tanpa izin siapa pun. Pekerjaan yang biasanya 12 menit selesai jauh lebih cepat. Organisasi tidak mengetahui lokasi penyimpanan teks itu, apakah penyedia memakainya ulang, dan apakah alergi pasien masih tercantum pada ringkasan. Medikara belum punya proyek AI resmi. Namun, pemakaian *Artificial Intelligence* (AI) sudah menjadi keputusan organisasi sejak data pertama dimasukkan.

Tata kelola AI menetapkan tujuan, batas pemakaian, pemilik keputusan, dan bukti bahwa risiko dikelola sepanjang siklus hidup. Manfaat administratif dan dampak klinis perlu dibedakan. Kesalahan pada pengelompokan surat tidak berakibat sama dengan kesalahan triase. Pengawasan manusia juga memerlukan kewenangan, waktu, dan informasi untuk menolak keluaran. Hasil kerja bab ini adalah inventaris AI dan kebijakan pemakaian AI untuk tonggak C3 capstone. Keduanya memakai kode yang sudah ada: R-11 pada register Bab 5, peran direktur pelayanan pada Bab 8, kontrak vendor pada Bab 9, dan penilaian dampak

pelindungan data pada Bab 7.

Bab ini memakai ISO/IEC 42001:2023 dan panduan penilaian dampak ISO/IEC 42005:2025. ISO adalah International Organization for Standardization, dan IEC adalah International Electrotechnical Commission. Kerangka risiko memakai AI Risk Management Framework (RMF) dari National Institute of Standards and Technology (NIST). Pembanding hukum memakai European Union (EU) AI Act, yaitu Regulation (EU) 2024/1689, beserta perubahan melalui Regulation (EU) 2026/1744. Konteks Indonesia merujuk Surat Edaran Menteri Komunikasi dan Informatika 9/2023 dan Undang-Undang (UU) 27/2022 tentang Pelindungan Data Pribadi (PDP). Panduan sektor memakai World Health Organization (WHO). Naskah ISO berbayar, sehingga rinciannya ditulis umum dan perlu dicocokkan ke naskah berlisensi. Seluruh angka tambahan tentang Medikara merupakan contoh pembelajaran [78, 81, 113, 38, 36, 89, 136, 166].

Gambar 11.1 merangkum hubungan komponen dan konsep utama bab ini.



Fungsi AI RMF saling berulang. Kategori hukum bergantung tujuan dan cakupan; pengawasan memerlukan waktu serta wewenang nyata.

Gambar 11.1: AI dikelola menurut tujuan, dampak, dan kemampuan pengawasan

11.2 Peluang dan Risiko AI di Layanan Kesehatan

Asisten cepat yang belum berwenang

AI membantu merangkum, mengelompokkan, memprediksi, dan memberi rekomendasi. EU AI Act menyebut sistem AI sebagai sistem berbasis mesin yang bekerja dengan tingkat otonomi beragam, lalu menghasilkan keluaran seperti prediksi atau keputusan dari masukan yang diterimanya [38, 43]. Risikonya mencakup informasi yang keliru, bias antarkelompok, kebocoran data, serangan terhadap sistem, dan ketergantungan berlebihan pada keluaran. Besar risikonya bergantung pada tujuan pemakaian, bukan pada nama teknologinya.

Analogi asisten baru berguna untuk menilai batas delegasi. Asisten mungkin menyusun draf dengan cepat, tetapi belum berwenang memutuskan pengobatan. Organisasi tetap bertanggung jawab atas keputusan yang diambil dari draf tersebut.

Dua contoh memperlihatkan jarak antara klaim dan hasil:

1. Misalkan ringkasan manual memerlukan 12 menit. Draf AI memerlukan 2 menit, ditambah pemeriksaan 8 menit. Penghematan bersih hanya 2 menit, bukan 10 menit.
2. Misalkan dari 100 ringkasan sintetis terdapat 4 penghilangan alergi. Rerata kemiripan teks yang tinggi tidak cukup untuk menyetujui pemakaian klinis, karena satu alergi yang hilang dapat berujung pada kesalahan obat.

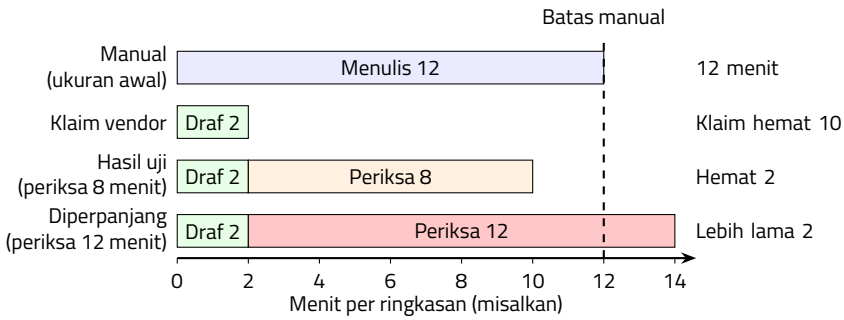
Tabel 11.1 memuat enam kasus yang dipakai sepanjang bab ini. Kode AI-01 sampai AI-06 merupakan pengandaian. Empat kasus pertama berasal dari rencana kondisi target. AI-05 memisahkan informasi gejala dari triase darurat, karena tujuan keduanya berbeda. AI-06 mewakili pemakaian yang sudah terjadi tanpa izin.

Tabel 11.1: Manfaat dan risiko enam kasus pemakaian AI (misalkan)

Kode	Kasus	Manfaat yang diuji	Risiko utama
AI-01	Ringkasan rekam medis	Waktu dokumentasi	Alergi atau obat terlewat
AI-02	Prioritas triase darurat	Waktu sampai ditangani	Kasus gawat diberi prioritas rendah
AI-03	Prediksi tempat tidur	Ketepatan perencanaan	Kinerja berubah antarperiode dan antarlokasi
AI-04	Deteksi kecurangan klaim	Prioritas pemeriksaan	Tuduhan salah dan bias
AI-05	Informasi gejala umum di Medikara+	Pertanyaan terjawab tanpa antre	Jawaban keliru dibaca sebagai nasihat medis
AI-06	*Chatbot* umum tanpa izin	Tidak diukur	Data pasien keluar tanpa kendali

Manfaat harus dihitung

Pertanyaan kemudian muncul: manfaat apa yang akan dibuktikan? Tim menetapkan ukuran awal (*baseline*), sasaran, dan biaya pengawasan sebelum alat dibeli. Waktu mengetik yang berkurang belum tentu mengurangi waktu total, jika pemeriksaan kesalahan memerlukan waktu lebih panjang. Gambar 11.2 membandingkan empat keadaan pada AI-01.



Gambar 11.2: Waktu per ringkasan: klaim, hasil uji, dan pemeriksaan yang diperpanjang (misalkan)

Misalkan AI-01 dipakai untuk 60.000 ringkasan per tahun, atau 5 persen dari sekitar 1,2 juta kunjungan. Tarifnya Rp60.000 per jam seperti Bab 7, atau Rp1.000 per menit. Tiga hitungan berikut dapat dicek ulang:

1. Klaim hemat 10 menit berarti 600.000 menit, atau 10.000 jam, senilai Rp600 juta per tahun.
2. Hasil uji hemat 2 menit berarti 120.000 menit, atau 2.000 jam, senilai Rp120 juta per tahun. Nilainya seperlima dari klaim.
3. Misalkan lisensi Rp150 juta per tahun. Manfaat bersihnya minus Rp30 juta. Titik impasnya Rp150 juta dibagi 60.000 ringkasan, yaitu Rp2.500 atau 2,5 menit per ringkasan.

Keputusan membaca manfaat bersih punya dua konsekuensi. Pertama, hasilnya bergantung pada tarif. Pemeriksa ringkasan umumnya dokter, dan tarif dokter lebih mahal daripada Rp60.000. Misalkan tarif dokter Rp150.000 per jam. Penghematan 2.000 jam bernilai Rp300 juta, sehingga manfaat bersihnya Rp150 juta. Titik impas tarif ada pada Rp75.000 per jam. Tim perlu menulis asumsi tarif secara terbuka. Kedua, jalan termudah menuju impas adalah memotong waktu pemeriksaan. Pemotongan 0,5 menit memenuhi hitungan, tetapi melemahkan pengawasan yang menjadi syarat keselamatan. Seksi terakhir bab ini menghitung akibatnya.

Shadow AI

Shadow AI adalah pemakaian AI yang tidak tercatat atau berada di luar pengawasan organisasi. Pemicunya biasanya kebutuhan kerja yang nyata, bukan niat melanggar. Karena tidak tercatat, pemakaian itu tidak muncul pada daftar vendor, tidak masuk penilaian, dan baru diketahui setelah ada masalah.

Analogi jalan setapak di taman menjelaskan perilakunya. Bila jalur resmi memutar, orang membuat jalan pintas di atas rumput. Papan larangan tidak

menghapus kebutuhan untuk sampai lebih cepat. Pengelola yang paham kebutuhan itu membuka jalur aman, lalu menutup jalan pintas yang berbahaya.

Dua contoh menunjukkan cara mengukur dan menanganinya:

1. Misalkan survei anonim dijawab 600 dari 4.800 karyawan. Sebanyak 96 orang, atau 16 persen, mengaku memakai AI umum untuk pekerjaan. Sebanyak 24 orang, atau 4 persen, pernah memasukkan teks yang memuat data pasien. Bila disamaratakan ke 4.800 karyawan, angkanya sekitar 768 dan 192 orang. Perkiraan itu kasar, karena responden tidak dipilih secara acak.
2. Misalkan seorang kepala ruang mengetahui pada Selasa 10.00 bahwa 40 catatan pasien telah diunggah ke *chatbot* umum. Fungsi hukum dan petugas pelindungan data menilai apakah peristiwa itu kegagalan pelindungan data. Bila ya, pola Bab 7 berlaku: batas internal jam ke-60 jatuh pada Kamis 22.00, dan batas terluar 3×24 jam jatuh pada Jumat 10.00. Peristiwa ini berkaitan dengan R-12 dan K-04 tentang pemberitahuan.

Kasus Medikara Health: Catatan Pasien di Chatbot Umum

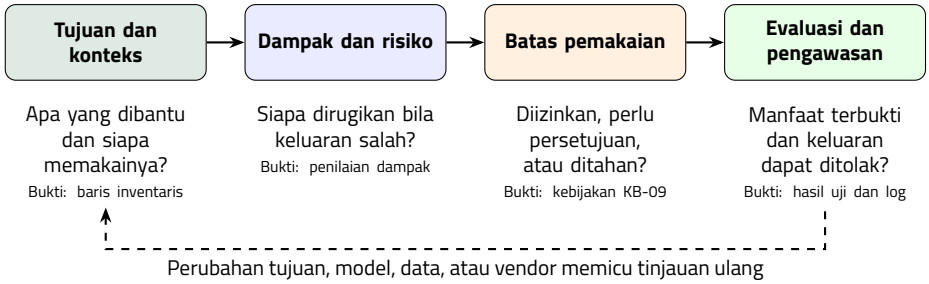
Misalkan staf mengunggah catatan pasien ke *chatbot* umum. Kemudahan kerja telah memunculkan keputusan data dan keselamatan. Tiga pertanyaan muncul sekaligus. Pertanyaan data: ke mana teks itu pergi, dan apakah Pasal 966 serta Pasal 972 Peraturan Pemerintah (PP) 28/2024 terpenuhi? Pertanyaan keselamatan: apakah ringkasan itu kembali masuk ke rekam medis? Pertanyaan perilaku: mengapa staf memilih jalan ini?
Sanksi kepada satu orang hanya menjawab sebagian. Bila antrean ringkasan tetap panjang, orang lain akan memakai cara yang sama dan lebih enggan melapor. Medikara menangani peristiwa ini sebagai insiden, sekaligus sebagai bukti kebutuhan kerja yang belum terpenuhi.

Kaitan dengan R-11 dan urutan keputusan

Register Bab 5 tidak memerlukan kode baru untuk AI-01. R-11 berisi riwayat alergi yang tidak terbaca lintas rumah sakit dan berujung pada kesalahan obat. Skornya $3 \times 4 = 12$, dengan direktur pelayanan sebagai pemilik. Ringkasan yang menghilangkan alergi menambah satu jalur penyebab: alergi tercatat di sumber, tetapi hilang pada ringkasan yang dibaca dokter. Bab ini tidak mengubah skor R-11. Penyebab, kontrol, dan pemilik tindakan ditambahkan pada baris yang sama. Kesalahan kritis AI-01 karena itu masuk ke pimpinan klinis pada hari yang sama, seperti jalur R-11 pada Bab 5, dan tidak berhenti di tim teknologi.

Gambar 11.3 merangkum urutan keputusan yang dipakai pada setiap kasus.

Tiap langkah menghasilkan satu bukti, dan perubahan apa pun mengembalikan kasus ke langkah pertama.



Gambar 11.3: Alur keputusan tata kelola kecerdasan artifisial

Membaca tiga penelitian

Pertanyaan berikutnya: apakah kegagalan AI kesehatan benar-benar terukur? Tabel 11.2 merangkum tiga penelitian, dengan angka dari abstrak artikel. Kolom terakhir adalah pembacaan bab ini. Large Language Model (LLM) pada baris ketiga adalah model bahasa yang menjadi dasar banyak *chatbot*.

Tabel 11.2: Tiga penelitian dan pelajarannya bagi tata kelola

Penelitian	Temuan	Pertanyaan bagi Medikara
Obermeyer dan rekan (2019)	Algoritma memprediksi biaya layanan, bukan keparahan penyakit. Pada skor yang sama, pasien kulit hitam lebih sakit. Perbaikan bias menaikkan porsi pasien kulit hitam yang mendapat bantuan tambahan dari 17,7 menjadi 46,5 persen.	Apa yang diprediksi model?
Wong dan rekan (2021)	Validasi luar model sepsis pada 38.455 rawat inap. Kemampuan membedakan 0,63 pada skala 0,5 sampai 1. Peringatan muncul pada 6.971 rawat inap (18 persen), tetapi 1.709 dari 2.552 pasien sepsis (67 persen) tidak teridentifikasi.	Apakah kinerja bertahan di rumah sakit sendiri?
Asgari dan rekan (2025)	Ringkasan klinis dari 18 konfigurasi LLM, dengan 12.999 kalimat beranotasi klinisi. Halusinasi 1,47 persen dan penghilangan 3,45 persen. Perbaikan *prompt* dan alur kerja menurunkan kesalahan besar.	Kesalahan jenis apa yang dihitung, dan apa pembandingnya?

Ketiga penelitian itu memberi dua pelajaran [116, 165, 6]. Pertama, beban kerja dapat dihitung dari angka yang dilaporkan. Pada penelitian Wong, 2.552 dikurangi 1.709 berarti 843 pasien sepsis teridentifikasi. Dengan 6.971 peringatan, petugas membaca sekitar 8 peringatan untuk menemukan satu kasus. Hitungan ini milik bab ini, bukan pernyataan abstrak. Kedua, satuan ukur menentukan arti angka. Asgari menghitung per kalimat, sedangkan contoh AI-01 menghitung per ringkasan, sehingga 3,45 persen dan 4 persen tidak dapat dibandingkan langsung. Angka penelitian juga tidak disalin menjadi perkiraan Medikara, karena pasien, model, dan alurnya berbeda.

11.3 ISO/IEC 42001:2023 dan Standar Pendukung

Sistem manajemen AI

ISO/IEC 42001 menetapkan persyaratan sistem manajemen AI. Organisasi menetapkan konteks, kepemimpinan, perencanaan, dukungan, operasi, evaluasi, dan perbaikan [78]. Susunan klausul 4 sampai 10 itu mirip dengan ISO/IEC 27001 pada Bab 6. Yang khas adalah penilaian risiko AI dan penilaian dampak sistem AI. Naskah standar berbayar, sehingga nomor klausul pada bab ini diambil dari *crosswalk* NIST, yaitu pemetaan AI RMF ke rancangan akhir standar tersebut [114]. Nomor dan isinya perlu dicocokkan ke naskah berlisensi sebelum dipakai untuk audit.

Analogi pengelolaan alat laboratorium menunjukkan perbedaan sistem dan hasil. Sistem manajemen memastikan alat memiliki pemilik, prosedur, pengujian, dan tindakan koreksi. Keberadaan sistem itu tidak membuktikan setiap hasil pemeriksaan selalu benar.

Dua contoh menunjukkan batas klaim sistem manajemen:

1. Misalkan model aman dari akses tidak sah, tetapi lebih sering salah pada pasien lanjut usia: 3 dari 40 kasus, dibanding 1 dari 60 kasus pada kelompok lain. Kontrol keamanan tidak menyelesaikan kesenjangan mutu kelompok tersebut.
2. Misalkan ada 10 model, tetapi hanya 2 yang masuk ruang lingkup sistem manajemen AI. Bukti dari 20 persen portofolio itu tidak diperluas menjadi klaim seluruh portofolio.

Tabel 11.3 menerapkan klausul pada AI-01, dengan pola yang sama seperti AC-01 pada Bab 6. KB-09 adalah kebijakan pemakaian AI yang menambah daftar KB-01 sampai KB-08 pada Bab 8.

Tabel 11.3: Klausul ISO/IEC 42001 pada AI-01 (misalkan)

Klausul	Pertanyaan	Bukti pada AI-01
4.1 Konteks	Layanan, data, dan kewajiban apa yang tercakup?	Satu rumah sakit tahap uji; UU PDP dan PP 28/2024
5.1 sampai 5.3 Kepemimpinan	Siapa menetapkan kebijakan dan peran?	KB-09 disetujui direksi; direktur pelayanan sebagai pemilik
6.1.2 dan 6.1.3 Risiko AI	Risiko apa yang dinilai dan diperlakukan?	R-11 skor 12; alergi ditarik dari data terstruktur
6.1.4 Dampak sistem AI	Siapa terdampak bila keluaran salah?	Penilaian 72 jam; pasien lanjut usia diperiksa terpisah
7.2 Kompetensi	Apakah pemeriksa mampu menilai?	120 dokter dilatih 2 jam
8.2 sampai 8.4 Operasi	Apakah penilaian dijalankan saat sistem berubah?	Baris inventaris diperbarui; uji diulang
9.1 dan 9.3 Evaluasi	Apakah hasilnya dipantau dan ditinjau pimpinan?	4 dari 100 kesalahan kritis; agenda komite risiko
10.1 Perbaikan	Apa yang berubah karena temuan?	Rancangan diubah; uji ulang 1 dari 100

Penilaian dampak dan penilaian risiko

Dua hal pada penilaian AI sering tertukar. Pembagiannya begini. Penilaian risiko menanyakan peluang dan akibat terhadap tujuan organisasi. Penilaian dampak menanyakan akibat bagi individu, kelompok, dan masyarakat. ISO/IEC 42005:2025 memberi panduan menilai dampak sistem AI, dan keduanya saling melengkapi [81]. Keduanya juga memerlukan konteks penggunaan yang sama.

Analogi pembangunan jalan di depan pasar menjelaskan bedanya. Kontraktor menilai keterlambatan dan biaya. Pedagang menanggung sepinya pembeli selama pekerjaan berjalan. Proyek dapat berjalan aman bagi kontraktor, tetapi tetap merugikan pedagang.

Dua contoh menunjukkan akibatnya pada Medikara:

1. Misalkan AI-04 menandai 300 klaim per bulan dari 6.000 klaim. Bagi organisasi, pemeriksaan 20 menit per klaim berarti 100 jam per bulan, atau Rp6 juta. Risikonya terlihat kecil. Bagi klinik, 93 dari 120 tanda ternyata keliru, dan namanya tercatat sebagai pihak yang dicurigai.
2. Misalkan penilaian dampak memakan 72 jam untuk AI-01 dan AI-02, 24 jam untuk AI-03 dan AI-04, serta 8 jam untuk AI-05. Jumlahnya 200 jam, atau Rp12 juta. Angka 72 jam mengikuti Bab 7, yaitu 360 jam untuk 5 Data Protection Impact Assessment (DPIA). AI-01 dan AI-02 memakai data spesifik, sehingga penilaian dampak AI dapat digabung dengan DPIA agar

tidak ada dua dokumen untuk data yang sama.

AI dan keamanan informasi

Sistem manajemen keamanan informasi menurut ISO/IEC 27001 menekankan kerahasiaan, integritas, dan ketersediaan informasi [75]. Sistem manajemen AI juga menilai konsekuensi penggunaan AI, seperti mutu keputusan dan dampak terhadap manusia. Sertifikasi salah satunya tidak otomatis memenuhi yang lain, dan tidak membuktikan kepatuhan hukum. Tabel 11.4 merangkum perbedaan fokusnya.

Tabel 11.4: Perbedaan fokus kerangka AI dan keamanan

Acuan	Fokus	Bukti contoh
ISO/IEC 42001	Pengelolaan AI bertanggung jawab	Kebijakan, evaluasi, tindak lanjut
ISO/IEC 42005	Dampak penggunaan AI	Pihak terdampak dan mitigasi
ISO/IEC 27001	Risiko keamanan informasi	Kontrol akses dan insiden

11.4 NIST AI RMF

Empat fungsi yang berulang

NIST AI RMF 1.0 mengorganisasi pengelolaan risiko melalui Govern, Map, Measure, dan Manage. Govern membentuk budaya, tanggung jawab, dan kebijakan. Map mengenali konteks dan risiko yang terkait dengan konteks itu. Measure menilai, menganalisis, atau melacak risiko yang sudah dikenali. Manage memberi prioritas dan bertindak menurut dampak yang diperkirakan. NIST menggambarkan Govern sebagai fungsi lintas yang mengisi tiga fungsi lain. Kerangka ini sukarela, dan tindakannya bukan daftar periksa atau urutan tetap. Setelah Govern, sebagian besar pemakai mulai dari Map, lalu ke Measure atau Manage, dan prosesnya berulang [113].

Analogi pemeriksaan mutu makanan menjelaskan pengulangan tersebut. Pemilik usaha menetapkan standar, mengenali kebutuhan pembeli, menguji hasil, dan memperbaiki proses. Perubahan bahan menuntut pemeriksaan baru, meskipun resep lama pernah lulus.

Dua contoh penerapan:

1. Misalkan *chatbot* hanya menjawab pertanyaan jadwal. Map membatasi tujuan, Measure menguji 100 pertanyaan sintetis, dan Manage menetapkan

jalur ke petugas bila jawaban tidak tersedia.

2. Misalkan model pada Medikara+ diganti vendor tanpa pemberitahuan. Govern menetapkan kewajiban perubahan, lalu pengujian diulang sebelum versi baru dipakai. Bab 9 sudah memberi pegangan kontraknya: pemberitahuan subprosesor 30 hari. Penyedia model menjadi penyedia pendukung keempat bagi V-01, yaitu vendor Medikara+, setelah V-02, penyedia pesan, dan layanan identitas.

Tabel 11.5 menerapkan empat fungsi itu pada AI-01.

Tabel 11.5: Penerapan empat fungsi NIST AI RMF pada AI-01 (misalkan)

Fungsi	Pertanyaan	Bukti	Pada AI-01
Govern	Siapa bertanggung jawab?	Pemilik dan batas keputusan	Direktur pelayanan; KB-09
Map	Siapa dapat dirugikan?	Konteks dan pihak terdampak	Pasien dengan alergi; pasien lanjut usia
Measure	Risikonya terbukti bagaimana?	Hasil uji per kelompok	100 kasus sintetis, dua penilai
Manage	Kapan dihentikan atau diperbaiki?	Keputusan dan pemicu tinjauan	Ditahan; alergi ditarik dari data terstruktur

Diagram konsep pada awal bab menerapkan fungsi itu pada inventaris. Inventaris AI mencatat tujuan, versi, pemilik (*owner*), dan data. Konteks penggunaan mengalir ke Map konteks dan dampak, yang menyebut pasien dan kelompok terdampak. Map memberi kriteria uji kepada Measure, yang menguji manfaat, bias, dan kesalahan. Bukti dan batas hasil sampai ke pengawas manusia, yang kompeten dan berhak menolak. Penilaian berwenang itu masuk ke Manage: terima, batasi, atau hentikan. Perubahan memicu tinjauan, sehingga siklus kembali ke inventaris. Govern lintas fungsi memberi mandat dan kebijakan, yaitu arah dan akuntabilitas bagi Map, serta batas keputusan bagi Manage. Kotak pengawas manusia merupakan tambahan bab ini, bukan bagian dari empat fungsi NIST.

Kerangka itu juga menyebut tujuh karakteristik AI yang dapat dipercaya: valid dan andal, aman, terlindung dan tangguh, akuntabel dan transparan, dapat dijelaskan dan ditafsirkan, menjaga privasi, serta adil dengan bias berbahaya yang dikelola. Karakteristik itu sering menuntut *tradeoff* [113].

Measure: satu angka sering menyesatkan

Pertanyaan kemudian muncul: ukuran apa yang pantas dipakai Measure? Ukuran tunggal sering menutupi kesalahan yang paling penting. Karena itu, tim menetapkan kriteria uji sebelum melihat hasil, memisahkan kesalahan penting secara klinis dari kesalahan gaya bahasa, dan membaca hasil per kelompok.

Analogi alarm kebakaran membantu. Alarm yang rusak dan tidak pernah berbunyi tampak benar pada 364 hari dalam setahun. Kegagalannya baru terlihat pada satu hari kebakaran. Persentase hari yang benar tidak mengukur tugas utama alarm itu.

Dua contoh menghitung kesalahan yang tertutup:

1. Misalkan fitur gejala dipakai 1.500 sesi per bulan, sekitar 5 persen dari 28.000 janji temu Medikara+. Sebanyak 30 sesi (2 persen) benar-benar darurat. Model yang selalu menjawab "bukan darurat" benar pada 1.470 sesi, atau 98 persen, tetapi melewatkan seluruh 30 kasus. Model lain menangkap 27 dari 30 kasus dan salah menandai sekitar 74 sesi. Ketepatan totalnya hanya 94,9 persen, padahal jauh lebih berguna. Sisa 3 kasus per bulan, atau 36 per tahun, tetap harus dijawab jalur lain.
2. Misalkan AI-01 diuji pada 100 ringkasan sintetis dengan dua penilai. Tabel 11.6 memperlihatkan 4 kesalahan kritis pada putaran 1, yaitu alergi atau obat penting yang terlewat. Pada usia 60 tahun ke atas, angkanya 7,5 persen, atau sekitar 4,5 kali kelompok lain. Rerata 4 persen menutupi kesenjangan itu.

Kriteria uji AI-01 ditetapkan lebih dahulu. Kesalahan kritis keseluruhan tidak melebihi ukuran awal manual, dan tidak ada kelompok yang melampaui 3 persen. Misalkan pembanding manual pada kasus yang sama menghasilkan 1 kesalahan dari 100, atau 1 persen. Putaran 1 gagal pada kedua kriteria. Tim lalu mengubah rancangan: alergi dan obat ditarik langsung dari data terstruktur, bukan ditulis oleh model. Putaran 2 memenuhi kedua kriteria, tetapi sampel kecil itu hanya membuka tahap uji berikutnya. Direktur pelayanan karena itu memilih batasi, bukan terima: uji lanjutan pada satu rumah sakit, dengan pemeriksa yang tetap membaca sumber asli.

Tabel 11.6: Kesalahan kritis AI-01 pada 100 ringkasan sintetis (misalkan)

Kelompok	Kasus	Putaran 1	Persen	Putaran 2	Persen
Di bawah 60 tahun	60	1	1,7	0	0
60 tahun ke atas	40	3	7,5	1	2,5
Seluruh kasus	100	4	4,0	1	1,0

Bias tidak hanya muncul pada model bahasa. Tabel 11.7 memecah AI-04 menurut sumber klaim, memakai 6.000 klaim per bulan dari Bab 7. Klinik ditandai dua kali lebih sering daripada rumah sakit, tetapi tanda pada klinik lebih sering keliru. Bila tim hanya membaca presisi total 30 persen, kesenjangan itu tidak terlihat. Hitungan seperti ini menjawab pelajaran Obermeyer: tim memeriksa

apakah tanda model mengukur kecurangan, atau hanya pola penagihan klinik yang berbeda.

Tabel 11.7: Tanda klaim AI-04 menurut sumber per bulan (misalkan)

Sumber	Klaim	Ditandai	Terbukti	Tanda keliru
Rumah sakit	4.500	180 (4 persen)	63 (35 persen)	117 (65 persen)
Klinik	1.500	120 (8 persen)	27 (22,5 persen)	93 (77,5 persen)
Jumlah	6.000	300 (5 persen)	90 (30 persen)	210 (70 persen)

Profil AI generatif

Profil AI generatif NIST AI 600-1 menguraikan 12 risiko. Tim dapat memulai dari risiko prioritas, tanpa menganggap pengisian daftar sebagai bukti semua risiko terkendali [115]. Lima risiko paling dekat dengan kasus Medikara. Nama risiko mengikuti profil, sedangkan contohnya ditulis bab ini:

- Confabulation, isi keliru yang ditulis dengan yakin: AI-01 menulis obat yang tidak diresepkan.
- Data Privacy, data sensitif bocor atau dipakai tanpa izin: AI-06 pada *chatbot* umum.
- Harmful Bias or Homogenization, kinerja berbeda antarkelompok: AI-01 pada pasien lansia.
- Human-AI Configuration, ketergantungan berlebihan: pemeriksa setuju tanpa membaca sumber.
- Value Chain and Component Integration, komponen pihak ketiga sulit ditelusuri: vendor mengganti model tanpa pemberitahuan.

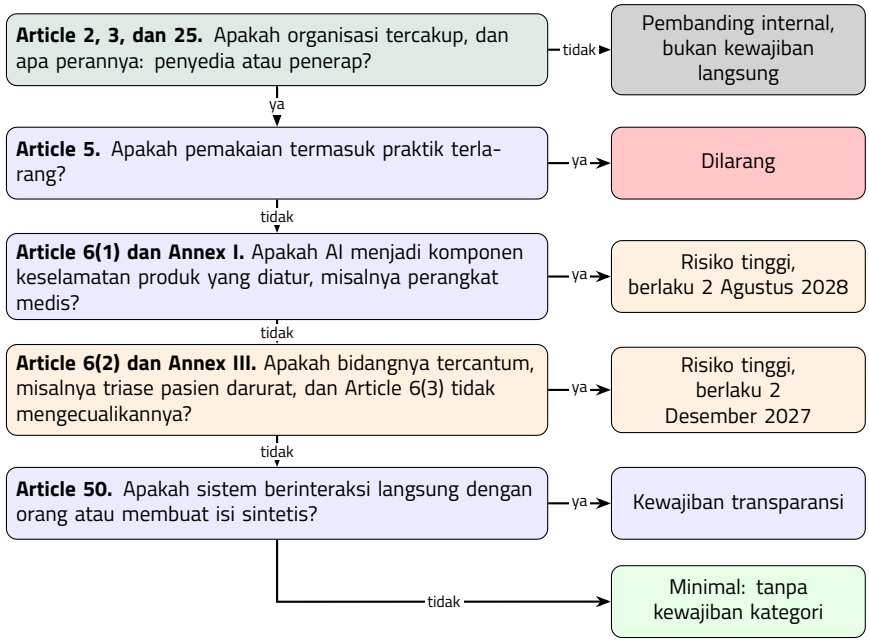
11.5 EU AI Act dan Pendekatan Berbasis Risiko

Empat kategori

EU AI Act membedakan praktik yang dilarang (Article 5), sistem risiko tinggi (Article 6), kewajiban transparansi tertentu (Article 50), serta penggunaan lain yang tidak termasuk kategori tersebut. Penggunaan lain itu lazim disebut minimal, walaupun istilah itu bukan judul pasal. Kategori bergantung pada tujuan penggunaan, peran organisasi, dan rincian hukum. Sistem AI kesehatan tidak otomatis seluruhnya berisiko tinggi, tetapi perangkat medis tertentu dan sistem triase pasien darurat termasuk jalur yang perlu diperiksa secara khusus [38, 43].

Analogi perizinan kendaraan membantu memahami klasifikasi. Bentuk kendaraan saja tidak menentukan izin; fungsi, muatan, dan tempat operasinya ikut berpengaruh. Nama produk seperti asisten kesehatan belum menjelaskan apakah sistem hanya memberi informasi umum atau menentukan prioritas layanan darurat.

Gambar 11.4 menyusun pertanyaannya sebagai urutan. Annex III butir 5 huruf d menyebut sistem untuk mengevaluasi panggilan darurat dan menentukan prioritas pengiriman layanan tanggap darurat, termasuk sistem triase pasien darurat. Annex I bagian A memuat Regulation (EU) 2017/745 tentang perangkat medis pada nomor 11, dan Regulation (EU) 2017/746 tentang diagnostik in vitro pada nomor 12. Article 6(3) mengecualikan sistem Annex III yang tidak menimbulkan risiko bahaya signifikan, tetapi sistem yang melakukan pemrofilan orang perseorangan selalu berisiko tinggi [43].



Ringkasan pembelajaran, bukan alur resmi. Kewajiban transparansi dapat berlaku bersama kewajiban risiko tinggi menurut Article 50(6).

Gambar 11.4: Urutan pertanyaan klasifikasi menurut EU AI Act

Dua contoh penerapan:

1. Misalkan AI-05 hanya menampilkan informasi edukasi, tanpa menentukan prioritas pasien. Tim memeriksa tujuan nyata dan transparansi: Article 50(1) meminta orang diberi tahu bahwa ia berinteraksi dengan AI, kecuali hal itu sudah jelas. Label kesehatan saja belum menentukan risiko tinggi.

2. Misalkan AI-02 menetapkan prioritas pasien gawat darurat. Annex III butir 5 perlu dianalisis. Persetujuan internal tetap memerlukan penilaian klinis, pengawasan, dan uji dampak. Model ini juga menilai kondisi kesehatan orang perseorangan, sehingga pengecualian Article 6(3) perlu diuji dengan hati-hati.

Tabel 11.8 menerapkan urutan itu pada enam kasus. Kolom terakhir sengaja ditulis bersyarat, karena Medikara belum tentu tercakup.

Tabel 11.8: Klasifikasi pembanding enam kasus Medikara (misalkan)

Kasus	Jalur yang diperiksa	Keputusan sementara
AI-01 Ringkasan rekam medis	Article 6(1) dan Annex I bila berfungsi sebagai perangkat medis	Belum disimpulkan; perlu analisis tujuan
AI-02 Prioritas triase darurat	Annex III butir 5 huruf d; Article 6(3)	Risiko tinggi bila cakupan terpenuhi
AI-03 Prediksi tempat tidur	Tidak tampak pada Annex III bila hanya memakai data agregat	Kemungkinan minimal; tetap diuji
AI-04 Deteksi kecurangan klaim	Annex III butir 5: huruf a bila menyentuh kelayakan layanan publik, huruf c bila menyentuh harga asuransi	Perlu analisis tujuan dan dampak
AI-05 Informasi gejala umum	Article 50(1); berpindah ke jalur AI-02 bila menentukan prioritas	Transparansi; batas tujuan dipantau
AI-06 *Chatbot* umum tanpa izin	Pertanyaan peran: apakah dipakai di bawah kewenangan organisasi?	Bukan soal kategori; ditahan oleh kebijakan

Cakupan dan peran

Pertanyaan kemudian muncul: apakah aturan EU berlaku bagi rumah sakit di Indonesia? Article 2(1) mencakup penyedia yang memasarkan sistem di EU, penerap (*deployer*) yang berada di EU, serta penyedia dan penerap di negara ketiga bila keluaran sistem dipakai di EU. Article 3 membedakan penyedia (*provider*), yang mengembangkan dan memasarkan sistem atas nama sendiri, dari penerap, yang memakai sistem di bawah kewenangannya [43]. Seluruh fasilitas Medikara berada di Indonesia, sehingga EU AI Act menjadi pembanding, bukan kewajiban langsung. Kesimpulan itu perlu diperiksa ulang bila keluaran sistem dipakai di EU.

Peran juga dapat berubah. Article 25(1) menempatkan pihak lain sebagai penyedia bila ia memasang nama atau mereknya pada sistem risiko tinggi, melakukan modifikasi substansial, atau mengubah tujuan sistem sehingga menjadi

risiko tinggi [43]. Hal ini berkaitan langsung dengan Medikara+, aplikasi buatan vendor yang tampil dengan nama Medikara.

Dua contoh perubahan peran:

1. Misalkan V-01 menanam model triase pada Medikara+ dengan merek Medikara. Pada jalur EU, huruf a dapat menjadikan Medikara penyedia, walaupun kontrak dapat membagi kewajibannya lain.
2. Misalkan AI-05 semula hanya menjawab informasi umum, lalu tim menambah aturan "bila nyeri dada, naikkan antrean". Tujuannya berubah menjadi penentuan prioritas. Huruf c dapat berlaku, dan baris inventaris pindah dari AI-05 ke jalur AI-02.

Tiga pertanyaan karena itu dijawab sebelum menulis kategori. Apakah masuk cakupan EU? Buktinya lokasi, pasar, dan penggunaan keluaran. Apa tujuan penggunaan? Buktinya spesifikasi dan alur klinis. Apa peran Medikara? Buktinya kontrak dan riwayat perubahan sistem.

Jadwal setelah perubahan 2026

Regulation (EU) 2026/1744 mengubah penerapan ketentuan risiko tinggi tertentu pada Article 113: jalur Article 6(2) dan Annex III menjadi 2 Desember 2027, sedangkan jalur Article 6(1) dan Annex I menjadi 2 Agustus 2028. Jadwal itu tidak menunda seluruh kewajiban AI Act. Regulation ini terbit di Official Journal pada 24 Juli 2026 [36, 25, 43]. Tabel 11.9 memuat jadwalnya. Bab ini membaca tanggal itu dari salinan pasal dan ringkasan firma hukum, sehingga mahasiswa perlu mencocokkannya ke EUR-Lex sebelum menyatakan kewajiban.

Tabel 11.9: Jadwal penerapan EU AI Act setelah perubahan 2026

Tanggal	Yang berlaku
2 Februari 2025	Bab I dan Bab II, termasuk literasi AI (Article 4) dan praktik terlarang
2 Agustus 2025	Antara lain ketentuan model AI serbaguna (Bab V) dan sanksi (Bab XII)
2 Agustus 2026	Penerapan umum
2 Desember 2026	Larangan baru tentang materi intim tanpa persetujuan dan materi pelecehan seksual anak; akhir masa peralihan Article 50(2) bagi sistem lama
2 Desember 2027	Risiko tinggi jalur Article 6(2) dan Annex III
2 Agustus 2028	Risiko tinggi jalur Article 6(1) dan Annex I

Kewajiban penerap sebagai daftar pembanding

Walaupun tidak wajib bagi Medikara, Article 26 berguna sebagai daftar periksa. Tabel 11.10 membandingkannya dengan rancangan untuk AI-02. Article 27 juga meminta penilaian dampak hak dasar dari penerap tertentu, termasuk entitas swasta yang memberi layanan publik. Recital 96 menyebut layanan kesehatan sebagai salah satu contoh bidangnya [43].

Tabel 11.10: Article 26 sebagai pembanding rancangan AI-02 (misalkan)

Ayat	Kewajiban penerap, diringkas	Rancangan Medikara
26(2)	Pengawas kompeten, terlatih, berwenang, dan didukung	Dokter jaga gawat darurat; pelatihan 2 jam
26(4)	Data masukan relevan dan cukup representatif	Uji per kelompok usia
26(5)	Memantau, memberi tahu penyedia, dan menangguhkan bila berisiko	Hak henti direktur pelayanan; jalur ke V-01
26(6)	Menyimpan log paling singkat 6 bulan	KB-06 ditambah log AI 6 bulan; Bab 8 memakai 90 hari
26(11)	Memberi tahu orang yang terkena keputusan	Naskah penjelasan pada Medikara+

Keputusan ini punya dua konsekuensi. Pertama, log AI 6 bulan lebih panjang sekitar 90 hari daripada catatan rinci pada Bab 7 dan Bab 8, sehingga KB-06 mendapat satu baris baru. Kedua, baris itu adalah pilihan internal, bukan kewajiban hukum, sehingga alasan dan biayanya perlu ditulis.

Kasus Medikara Health: Triase Gejala di Medikara+

Misalkan tim produk mengusulkan satu fitur bernama “Cek Gejala”. Spesifikasi awal menyebut dua tujuan: memberi informasi umum dan menaikkan antrean bila gejala gawat. Tim lalu memecahnya menjadi AI-05 dan AI-02. AI-05 boleh berjalan dengan penjelasan yang jelas, ambang rujukan ke petugas, dan uji jawaban. AI-02 ditahan sampai evaluasi lulus, karena satu kasus gawat yang dilewatkan berakibat cedera berat. Risiko cedera berat ditinjau dalam 1 hari kerja, sesuai Bab 5. Pemecahan ini tidak mengubah kode program. Yang berubah adalah pemilik keputusan: pemilik Medikara+ pada AI-05, dan direktur pelayanan pada AI-02.

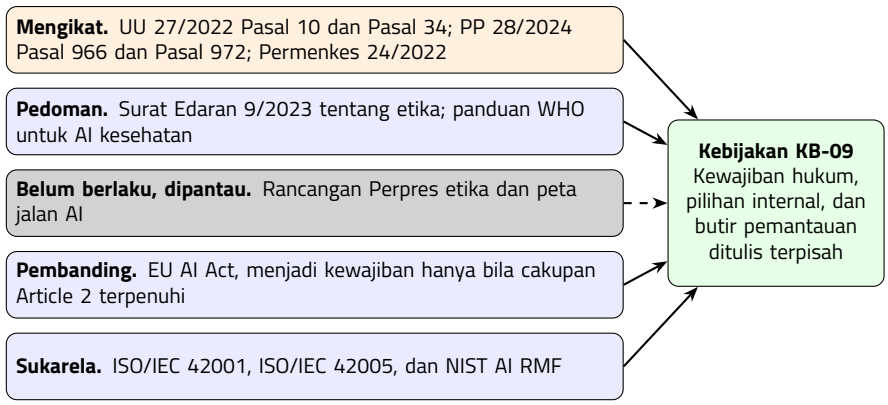
11.6 Posisi Regulasi AI di Indonesia

Lapis aturan

Surat Edaran 9/2023 memberi acuan etika AI. Isinya sembilan nilai: inklusivitas, kemanusiaan, keamanan, aksesibilitas, transparansi, kredibilitas dan akuntabilitas, pelindungan data pribadi, pembangunan dan lingkungan berkelanjutan, serta kekayaan intelektual [89]. Surat edaran tidak menggantikan kewajiban dalam UU atau aturan sektor. Pemrosesan data kesehatan, hubungan vendor, dan layanan klinis tetap dinilai dengan kerangka hukum yang relevan.

Analogi tata tertib kantor menjelaskan lapis aturan. Pedoman perilaku membantu pegawai mengambil keputusan, tetapi tidak dapat membatalkan kewajiban hukum. Begitu pula prinsip etika AI perlu diterjemahkan menjadi batas operasional yang dapat diperiksa.

Gambar 11.5 menyusun seluruh acuan bab ini menurut kekuatannya. Permenkes pada gambar adalah Peraturan Menteri Kesehatan, dan Perpres adalah Peraturan Presiden. Kebijakan Medikara menulis kewajiban hukum, pilihan internal, dan butir pemantauan secara terpisah.



Gambar 11.5: Lapis acuan yang masuk ke kebijakan pemakaian AI

UU 27/2022 Pasal 10 memberi hak mengajukan keberatan atas tindakan pengambilan keputusan yang hanya didasarkan pada pemrosesan otomatis, termasuk pemrofilan, yang menimbulkan akibat hukum atau dampak signifikan. Hal ini tidak sama dengan larangan seluruh otomatisasi [136]. Bab 7 sudah membaca Pasal 34 ayat (2): keputusan otomatis, data spesifik, skala besar, dan teknologi baru termasuk keadaan yang mewajibkan DPIA. AI-01 dan AI-02 menyentuh beberapa keadaan itu sekaligus. Lapis sektor tetap berlaku: Pasal 966 ayat (2) dan Pasal 972 PP 28/2024 mengatur lokasi serta transfer data kesehatan, dan Permenkes 24/2022 mengatur rekam medis [139, 88].

Status rancangan kebijakan baru perlu diperiksa pada sumber resmi saat dipakai. Pada Juli 2026, Kementerian Komunikasi dan Digital (Komdigi) menyatakan peta jalan dan etika AI masih diproses menuju Perpres. Pemberitaan 4 September 2026 menyebut dua Perpres, yaitu Buku Putih Peta Jalan dan Etika Kecerdasan Artifisial, tinggal menunggu tanda tangan Presiden. Perpres etika disebut akan mengatur penggunaan yang dilarang, yang perlu pengawasan ketat, dan yang berisiko lebih ringan [157, 161]. Sampai awal November 2026, bab ini tidak menemukan naskah yang telah ditetapkan. Rancangan tidak dicatat sebagai kewajiban yang telah berlaku. PP 33/2026 juga baru menjadi butir pemantauan pada Bab 7.

Dua contoh penerapan:

1. Misalkan AI-04 menolak klaim secara otomatis. Tim harus memeriksa dampaknya, dasar pemrosesan, dan mekanisme keberatan yang efektif. Bila 300 tanda per bulan diperiksa manusia selama 20 menit, biayanya 100 jam per bulan, atau Rp72 juta per tahun. Menurut pembacaan bab ini, persetujuan 5 detik tanpa membaca berkas sulit disebut keterlibatan manusia. Pembacaan itu bukan tafsir resmi Pasal 10.
2. Misalkan staf memasukkan identitas 40 pasien ke *chatbot* umum. Kebijakan internal menahan pemakaian tersebut sampai ada dasar, kontrol, dan pengaturan penerima data yang memadai. Bila server penyedia berada di luar negeri, Pasal 972 PP 28/2024 ikut diperiksa penasihat hukum.

Panduan sektor kesehatan

WHO merumuskan enam prinsip AI kesehatan: melindungi otonomi manusia; memajukan kesejahteraan, keselamatan, dan kepentingan publik; menjamin transparansi, keterjelasan, dan keterpahaman; membina tanggung jawab dan akuntabilitas; menjamin inklusi dan kesetaraan; serta mendorong AI yang responsif dan berkelanjutan [166, 167]. Panduan WHO untuk *large multi-modal models* menambahkan lima jenis pemakaian. Dua yang paling dekat dengan Medikara adalah pemakaian oleh pasien untuk mencari tahu gejala, dan tugas administrasi seperti ringkasan kunjungan. Panduan itu juga menyebut bias otomatisasi dan memuat lebih dari 40 rekomendasi [169, 168]. Panduan WHO bukan peraturan, tetapi memberi bahasa yang sama bagi pimpinan klinis dan tim teknologi.

Tabel 11.11 menerjemahkan prinsip menjadi aturan yang dapat diperiksa.

Tabel 11.11: Penerjemahan prinsip menjadi aturan operasional

Prinsip	Aturan internal contoh	Bukti
Transparansi	Informasi ketika AI digunakan	Tampilan dan naskah penjelasan
Akuntabilitas	Pemilik setiap kasus AI	Inventaris dan persetujuan
Pelindungan data	Batasi data dan penerima	Penilaian serta konfigurasi
Otonomi manusia	Pemeriksa berhak menolak keluaran	Log penolakan dan hasil uji sisipan
Inklusi dan kesetaraan	Hasil uji dipecah per kelompok	Tabel hasil per usia dan per sumber klaim

11.7 Inventaris AI, Pengawasan Manusia, dan Kebijakan

Inventaris

Inventaris mencatat tujuan penggunaan, pemilik, vendor, versi, data, penerima keluaran, kelompok terdampak, kategori risiko, pengawasan, dan tanggal tinjauan. Kebijakan mengatur penggunaan yang diizinkan, memerlukan persetujuan, atau dilarang. Perubahan tujuan, model, atau data memicu penilaian ulang.

Analogi daftar kendaraan dinas menunjukkan pentingnya inventaris. Organisasi sulit memeriksa kelaikan dan pertanggungjawaban jika kendaraan yang dipakai tidak tercatat. Larangan umum tanpa alternatif kerja dapat mendorong pemakaian yang tidak dilaporkan.

Tabel 11.12 memuat bentuk ringkas inventaris Medikara. Berkas lengkapnya ada di `sources/chapter11/contoh-inventaris-ai.csv`.

Dua contoh memperlihatkan mengapa inventaris harus hidup:

1. Misalkan AI-03 diuji di 5 rumah sakit dengan ambang selisih 5 tempat tidur. Selisih rata-ratanya 3 di Jakarta, 4 di Bekasi, 3 di Depok, 4 di Bogor, dan 8 di Bandung. Lulus pada 4 dari 5 lokasi tidak membuktikan kelayakan seluruh jaringan. Baris inventaris menulis cakupan 4 rumah sakit.
2. Misalkan tiap dari 6 baris inventaris ditinjau tiap triwulan selama 1 jam, sehingga bebannya 24 jam per tahun. Tinjauan berjalan sebagai agenda komite risiko dan forum arsitektur, karena Bab 8 sudah menghitung 400 jam rapat per tahun.

Pengawasan manusia

Pengawasan manusia perlu kompetensi, akses pada sumber asli, waktu pemeriksaan, kewenangan menolak, dan jalur eskalasi. Tombol setuju yang selalu ditekan bukan pengawasan yang memadai. Goddard dan rekan menelaah 74 makalah

Tabel 11.12: Inventaris AI Medikara, bentuk ringkas (misalkan)

Kode	Tujuan	Pemilik	Pengawasan	Keputusan
AI-01	Ringkasan rekam medis	Direktur pelayanan	Pemeriksa klinis dapat menolak	Dibatasi; uji lanjutan satu rumah sakit
AI-02	Prioritas triase darurat	Direktur pelayanan	Keputusan klinis oleh petugas berwenang	Ditahan sampai evaluasi
AI-03	Prediksi tempat tidur	Kepala operasi rumah sakit	Validasi per fasilitas	Uji perencanaan
AI-04	Deteksi kecurangan klaim	Kepala klaim	Pemeriksaan manusia dan keberatan	Uji terbatas
AI-05	Informasi gejala umum	Pemilik Medikara+	Rujukan ke petugas; penjelasan AI	Uji terbatas
AI-06	*Chatbot* umum tanpa izin	Tidak ada, temuan	Kebijakan dan pelaporan	Ditahan; alat alternatif

tentang kecenderungan terlalu mengikuti saran otomatis, atau *automation bias*. Faktor yang memengaruhinya antara lain karakteristik pengguna, kepercayaan, beban kerja, kerumitan tugas, dan tekanan waktu. Cara menguranginya antara lain pelatihan, penekanan tanggung jawab pengguna, dan rancangan tampilan [46].

Analogi apoteker yang memeriksa resep menjelaskan syaratnya. Apoteker berguna karena membaca resep, mengenal obat, punya waktu, dan berani menelepon dokter. Bila antrean memaksanya hanya memberi paraf, namanya tetap tercatat, tetapi pemeriksaannya sudah hilang.

Tabel 11.13 menurunkan syarat itu dari Article 14(4) EU AI Act sebagai pembanding [43]. Kolom buktinya merupakan rancangan Medikara.

Tabel 11.13: Syarat pengawasan manusia dan buktinya (misalkan)

Acuan	Syarat, diringkas	Bukti pada Medikara
14(4)(a)	Memahami kemampuan dan batas sistem	Pelatihan 2 jam; catatan batas uji
14(4)(b)	Waspada terhadap *automation bias*	Uji sisipan kesalahan
14(4)(c)	Menafsirkan keluaran dengan benar	Sumber asli tampil di samping draf
14(4)(d)	Boleh tidak memakai atau membatalkan keluaran	Tombol tolak; log alasan penolakan
14(4)(e)	Dapat menghentikan sistem dengan aman	Hak henti dan prosedur manual

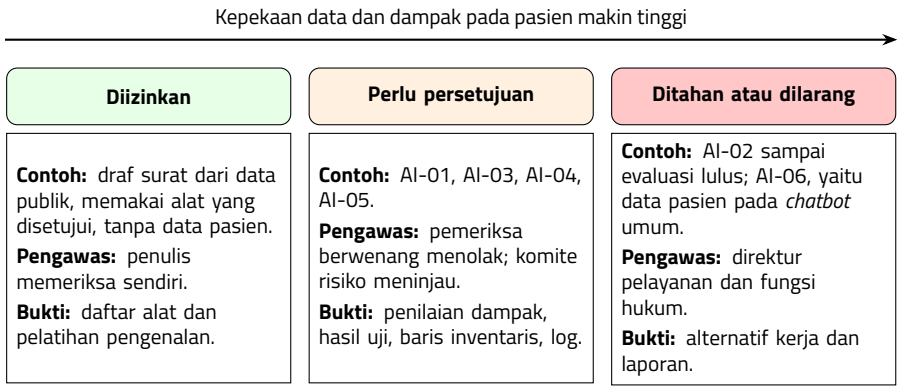
Dua contoh mengukur pengawasan yang tidak berjalan:

1. Misalkan log satu bulan memuat 1.000 draf. Tidak satu pun ditolak, dan median waktu pemeriksaan 40 detik, padahal rancangan menyediakan 8 menit. Dengan tingkat kesalahan 4 persen, sekitar 40 draf seharusnya bermasalah. Nol penolakan karena itu adalah tanda bahaya, bukan tanda mutu.
2. Misalkan 150 ringkasan uji memuat 20 kesalahan sisipan. Dengan waktu 8 menit, pemeriksa menemukan 14 kesalahan, atau 70 persen. Dengan waktu 12 menit, pemeriksa menemukan 18 kesalahan, atau 90 persen.

Hasil itu menutup hitungan pada awal bab. Pada 60.000 ringkasan, tingkat 4 persen menghasilkan 2.400 ringkasan bermasalah. Ukuran awal manual 1 persen setara 600 ringkasan. Pemeriksa dengan temuan 70 persen menyisakan 720 ringkasan, lebih banyak daripada manual. Pemeriksa dengan temuan 90 persen menyisakan 240 ringkasan, tetapi waktunya 14 menit, atau lebih lama 2 menit daripada manual, seperti Gambar 11.2. Rancangan lama karena itu gagal pada salah satu sisi: mutu atau waktu. Rancangan baru dengan tingkat 1 persen menghasilkan 600 ringkasan bermasalah sebelum pemeriksaan. Pemeriksaan 8 menit menyisakan 180 ringkasan, dan waktu tetap hemat 2 menit. Semua angka ini perkiraan kasar dari sampel kecil, tetapi arah keputusannya jelas.

Kebijakan tiga jalur

Pertanyaan berikutnya: bagaimana hasil itu menjadi aturan yang dapat dijalankan? Kebijakan memakai tiga jalur pada Gambar 11.6. Susunan ini sejalan dengan arah rancangan Perpres etika yang diberitakan, tetapi tidak bergantung padanya. Larangan total tanpa alternatif kerja justru memperbanyak *shadow AI*, seperti contoh jalan setapak pada awal bab.



Gambar 11.6: Tiga jalur kebijakan pemakaian AI (misalkan)

Dua contoh penerapan:

1. Misalkan kebijakan mengizinkan draf surat dengan data publik, tetapi memerlukan persetujuan untuk ringkasan rekam medis. Alternatif yang aman diberikan agar pekerjaan tetap berjalan: 100 akun alat yang disetujui, tanpa data pasien, dengan biaya Rp200.000 per akun per bulan, atau Rp240 juta per tahun. Jumlah itu mendekati 96 responden yang mengaku memakai AI umum.
2. Misalkan dari 100 keluaran terdapat 4 kesalahan kritis. Pemakaian klinis ditahan, meskipun 96 keluaran lain tampak baik. Lisensi AI-01 Rp150 juta berada pada mandat komite pengarah TI, sesuai batas Bab 2. Besar biaya itu tidak menjawab risikonya. AI-01 menyentuh R-11, sehingga direktur pelayanan tetap memutuskan pemakaian klinis, dan risiko sisa di atas batas naik ke direksi.

KB-09 menambah daftar kebijakan Bab 8. Jenisnya kebijakan, pemiliknya direktur pelayanan, dan penyetujunya direksi, sehingga direksi kini menyetujui 3 dari 9 dokumen. Hak henti dibagi tiga tingkat. Pemeriksa menolak satu keluaran. Kepala rekam medis menghentikan aliran data bila data dipakai di luar tujuan, sesuai hak henti sempit pada Bab 8. Direktur pelayanan menghentikan pemakaian klinis. Insiden AI memakai dua jalur yang sudah ada: kesalahan yang menyentuh keselamatan masuk ke pimpinan klinis pada hari yang sama, dan kebocoran data masuk ke jalur pemberitahuan KB-07.

Hubungan AI dengan arsitektur cukup disinggung di sini. Enterprise Architecture (EA) untuk AI dibahas pada IT40513, dan Application Programming Interface (API) untuk agen AI dibahas pada IT40613. Mata kuliah ini hanya menetapkan syaratnya: setiap model dan agen yang tersambung ke data pasien harus punya baris inventaris, pemilik, dan hak henti.

Beban tahun pertama

Keputusan membuat kebijakan AI juga punya biaya. Tabel 11.14 menghitung beban tahun pertama dengan tarif Rp60.000 per jam. Waktu pemeriksaan AI-01 pada pemakaian penuh tidak masuk, karena AI-01 masih dibatasi.

Hitungan ini punya dua konsekuensi. Pertama, pengenalan AI mengambil sekitar 79 persen jam. Tanpa kegiatan itu, bebannya turun menjadi 646 jam, atau Rp38,76 juta. Namun, survei menunjukkan pemakaian AI umum tidak terbatas pada dokter, sehingga modul 30 menit dipertahankan. Article 4 EU AI Act juga meminta langkah literasi AI bagi staf [43], walaupun pasal itu hanya menjadi pembanding bagi Medikara. Kedua, bila alat alternatif Rp240 juta ditambahkan, jumlahnya Rp422,76 juta, atau sekitar 4,2 persen dari anggaran modernisasi Rp10 miliar. Bab 14 memasukkan angka ini pada peta jalan. Bila AI-01 kelak dipakai penuh, waktu pemeriksaannya 8.000 jam per tahun, atau sekitar 4,2 orang penuh

Tabel 11.14: Beban tata kelola AI tahun pertama (misalkan)

Kegiatan	Hitungan	Jam
Inventaris awal	6 baris kali 4 jam	24
Penilaian dampak	72, 72, 24, 24, dan 8 jam	200
Uji AI-01	2 putaran, 100 kasus, 15 menit, 2 penilai	100
Uji sisipan pemeriksa	150 ringkasan, 8 menit dan 12 menit	50
Pengenalan AI seluruh karyawan	4.800 orang kali 30 menit	2.400
Pelatihan pemeriksa	120 dokter kali 2 jam	240
Tinjauan inventaris	6 baris, 4 kali, 1 jam	24
Tinjauan KB-09	1 kali 8 jam	8
Jumlah	Senilai Rp182,76 juta	**3.046**

waktu pada 1.920 jam kerja. Angka itu dihitung terpisah sebelum perluasan disetujui.

Kasus Medikara Health: Keputusan Komite atas Enam Baris

Misalkan komite risiko membahas inventaris dalam agenda triwulan. AI-01 dibatasi pada uji lanjutan satu rumah sakit. AI-02 ditahan sampai evaluasi lulus. AI-03 berjalan di 4 rumah sakit, sedangkan Bandung menunggu uji ulang. AI-04 hanya menandai klaim untuk diperiksa manusia, tidak menolak otomatis. AI-05 berjalan terbatas dengan penjelasan dan rujukan ke petugas. AI-06 ditutup dengan alat alternatif dan jalur pelaporan tanpa hukuman bagi staf yang melapor sendiri. Komite tidak menilai model. Komite memeriksa apakah bukti, pemilik, batas keputusan, dan tanggal tinjauan sudah tertulis.

11.8 Aktivitas: Inventaris AI dan Kebijakan Pemakaian AI

Tujuan. Tim membatasi penggunaan AI berdasarkan dampak dan bukti. Tim menyusun inventaris kasus pemakaian AI yang sudah ada dan yang mungkin muncul dalam kondisi target, mengklasifikasi tingkat risikonya dengan EU AI Act sebagai pembanding, lalu merumuskan kebijakan pemakaian AI.

Pembagian peran. Anggota berlatar kesehatan atau hukum menilai dampak pada pasien. Analis teknologi memeriksa data, model, dan vendor. Analis regulasi menautkan kebijakan ke UU PDP, dan memisahkan kewajiban hukum dari pilihan internal. Pemilik konteks menguji apakah aturan dapat dipakai dalam pekerjaan sehari-hari.

Langkah kerja.

1. Daftar paling sedikit empat penggunaan yang ada atau direncanakan, misalnya triase gejala di Medikara+, ringkasan rekam medis, prediksi ketersediaan tempat tidur, dan deteksi kecurangan klaim. Pisahkan fakta, dugaan, dan usulan.
2. Isi `sources/chapter11/inventaris-ai.csv` berdasarkan `sources/chapter11/contoh-inventaris-ai.csv`. Catat tujuan, pemilik, data, dampak, dan pengawasan.
3. Nilai risiko serta klasifikasi EU sebagai pembanding. Nyatakan asumsi cakupan dan peran, bukan hanya nama kategori. Tautkan tiap kasus ke register risiko tim.
4. Susun kebijakan melalui `sources/chapter11/templat-kebijakan-ai.md`. Tetapkan pemakaian yang dilarang, pemakaian yang perlu persetujuan, bentuk pengawasan, alternatif kerja, dan pelaporan insiden AI.
5. Rancang uji dari `sources/chapter11/rencana-evaluasi-ai.md`. Tetapkan kriteria penghentian dan penilaian kelompok terdampak sebelum melihat hasil. Pakai `sources/chapter11/contoh-hasil-uji-ai.csv` sebagai contoh bentuk laporan.
6. Hitung beban tahun pertama. Lakukan tinjauan silang, lalu perbarui inventaris dengan keputusan, pemilik, serta waktu evaluasi berikutnya.

Luaran. Inventaris AI dan kebijakan pemakaian AI, dilengkapi alasan klasifikasi, rencana evaluasi, dan hitungan beban.

Kaitan dengan capstone. Luaran masuk tonggak C3 Kondisi Target. Bab 12 memakai kebijakan ini sebagai bahan rencana asurans, Bab 13 memakai hasil uji sebagai bahan indikator, dan Bab 14 memasukkan bebannya ke peta jalan.

Kriteria penilaian. Konteks dan dampak 30 persen; argumentasi kategori 25 persen; aturan yang dapat diawasi 30 persen; kualitas bukti dan batas klaim 15 persen.

Berkas pendukung. Seluruh lembar kerja ada di `sources/chapter11/`, dengan daftar berkas pada `sources/chapter11/README.md`. Organisasi nyata dipakai dengan izin dan data yang dianonimkan. Data pasien dan karyawan tidak boleh dimasukkan ke layanan AI mana pun selama aktivitas ini.

Pendalaman Teknis (opsional)

Pendalaman ini opsional. Tim menilai satu kasus berbasis LLM dengan OWASP Top 10 for LLM Applications 2025. OWASP adalah Open Worldwide

Application Security Project. Empat butir paling dekat dengan AI-01 adalah LLM01 Prompt Injection, LLM02 Sensitive Information Disclosure, LLM06 Excessive Agency, dan LLM09 Misinformation [121]. Berkas `sources/chapter11/daftar-cek-owasp-llm.csv` memuat kesepuluh butir sebagai lembar kerja.

Uji LLM memakai kasus sintetis tanpa data pasien. Sisipkan instruksi menyesatkan di dokumen tiruan untuk memeriksa apakah sistem mengikuti isi dokumen sebagai perintah. Untuk kebocoran data, sisipkan penanda palsu pada dokumen tiruan lalu periksa apakah penanda itu muncul pada jawaban pengguna lain. Catat versi model, pertanyaan, keluaran, penilaian, dan pengulangan. Uji hanya pada sistem sendiri atau yang sudah berizin tertulis.

Keberhasilan pada kumpulan kecil belum membuktikan keselamatan produksi. Hasil 4 dari 100 memiliki rentang keyakinan 95 persen metode Wilson sekitar 1,6 sampai 9,8 persen. Hasil 1 dari 100 memiliki rentang sekitar 0,2 sampai 5,4 persen. Kedua rentang itu bertumpang tindih, sehingga perbaikan pada putaran 2 belum terbukti secara statistik. Hasil nol kesalahan dari 100 kasus masih menyisakan batas atas sekitar 3 persen menurut aturan tiga. Untuk menekan batas atas ke sekitar 1 persen, tim memerlukan sekitar 300 kasus tanpa kesalahan.

11.9 Ringkasan

AI memberikan manfaat ketika tujuan dan ukurannya jelas. Penghematan waktu perlu menghitung pemeriksaan ulang dan akibat kesalahan. Klaim hemat 10 menit per ringkasan menyusut menjadi 2 menit setelah pemeriksaan dihitung, atau dari Rp600 juta menjadi Rp120 juta per tahun. *Shadow AI* menunjukkan bahwa keputusan AI sudah terjadi, walaupun belum ada proyek resmi. Kasus seperti ini ditangani sebagai insiden dan sebagai bukti kebutuhan kerja. R-11 tetap menjadi jalur risiko keselamatan, dengan direktur pelayanan sebagai pemilik.

Sistem manajemen AI mengatur tanggung jawab dan pengendalian sepanjang siklus hidup. Keamanan informasi mendukungnya, tetapi tidak mencakup seluruh dampak keputusan AI. Penilaian risiko dan penilaian dampak menjawab pertanyaan berbeda, sehingga masalah yang kecil bagi organisasi dapat besar bagi klinik atau pasien. NIST AI RMF memberi empat fungsi yang berulang. Hasil uji perlu dipecah per kelompok, karena rerata 4 persen dapat menutupi 7,5 persen pada pasien lanjut usia.

Klasifikasi hukum bergantung pada tujuan, peran, dan cakupan. Kata triase saja belum menentukan kategori, dan merek Medikara pada produk vendor dapat

mengubah peran pada jalur EU. Perubahan jadwal EU perlu dibaca dari naskah resmi: Annex III pada 2 Desember 2027 dan Annex I pada 2 Agustus 2028. Di Indonesia, prinsip etika Surat Edaran 9/2023 diterapkan bersama UU PDP dan aturan sektor. Rancangan Perpres dipantau, bukan dicatat sebagai kewajiban.

Inventaris, alternatif kerja, persetujuan, dan pengawasan membentuk kebijakan yang dapat dijalankan. Pengawasan manusia diukur, bukan diasumsikan. Pemeriksa yang menemukan 70 persen kesalahan menyisakan 720 ringkasan bermasalah pada rancangan lama, lebih banyak daripada 600 pada cara manual. Perubahan rancangan menurunkan sisanya menjadi 180. Bebannya juga terukur: 3.046 jam pada tahun pertama, ditambah alat alternatif Rp240 juta.

Bab berikutnya menguji apakah kontrol seperti ini benar-benar berjalan. Pesan utama bab ini adalah bahwa organisasi tetap bertanggung jawab atas keputusan yang memakai AI.

11.10 Latihan

Latihan 1: Klasifikasi Triase

Klasifikasikan fitur triase gejala Medikara+ menurut kategori risiko EU AI Act. Jelaskan alasannya dan kewajiban yang muncul. Latihan ini membuktikan bahwa tujuan penggunaan menentukan klasifikasi.

1. Tulis dua kemungkinan tujuan fitur triase.
2. Periksa cakupan dan peran lewat Article 2, Article 3, dan Article 25.
3. Periksa jalur Article 5, Article 6, Annex I, Annex III, dan Article 50.
4. Tulis keputusan bersyarat berikut kewajiban yang perlu dikaji, lalu nyatakan bukti yang masih kurang.

Tabel 11.15 memuat contoh dari kasus Medikara, dan Tabel 11.16 merupakan lembar isian. Angka merupakan skenario pembelajaran, bukan hasil pengukuran organisasi.

Hasil dapat berbeda; penilaian bertumpu pada alasan dan perbandingan bukti.

1. Mengapa kata triase saja belum cukup menentukan kategori?
2. Kontrol apa yang tetap diperlukan bila AI Act hanya dipakai sebagai pembanding?
3. Model pada contoh melewatkan 3 dari 30 kasus darurat per bulan. Bukti apa yang diperlukan agar angka itu dapat diterima atau ditolak?

Tabel 11.15: Contoh terisi Latihan 1 (skenario pembelajaran)

Tujuan fitur	Penilaian awal	Kewajiban yang dikaji	Bukti lanjutan
Informasi gejala umum, 1.500 sesi per bulan	Kategori belum dapat dipastikan; periksa Article 50(1)	Memberi tahu bahwa pengguna berinteraksi dengan AI	Spesifikasi dan pengguna
Prioritas triase darurat, 30 kasus darurat per bulan	Periksa Annex III butir 5 huruf d	Pembanding Article 14 dan Article 26; log 6 bulan	Peran dan cakupan EU; 27 dari 30 tertangkap

Tabel 11.16: Lembar isian Latihan 1

Tujuan fitur	Penilaian awal	Kewajiban yang dikaji	Bukti lanjutan
…	…	…	…
…	…	…	…

Latihan 2: Shadow AI dan Alternatif Kerja

Jelaskan mengapa larangan total memakai AI generatif sering justru memperbanyak *shadow AI*. Latihan ini membuktikan keterkaitan kebutuhan kerja dengan perilaku pelaporan.

1. Tentukan pekerjaan yang mendorong staf memakai AI.
2. Hitung waktu dan volume pekerjaan itu.
3. Bandingkan larangan umum dengan akses terkendali dan bantuan.
4. Tetapkan ukuran pelaporan dan mutu, lalu jelaskan batas kesimpulan.

Tabel 11.17 memuat contoh dari kasus Medikara, dan Tabel 11.18 merupakan lembar isian. Angka merupakan skenario pembelajaran, bukan hasil pengukuran organisasi.

Tabel 11.17: Contoh terisi Latihan 2 (skenario pembelajaran)

Kebijakan contoh	Laporan pemakaian	Kebutuhan yang belum terpenuhi
Larangan tanpa alternatif	2 laporan per bulan	Ringkasan 12 menit per kasus
Akses terkendali dan bantuan	15 laporan per bulan	Perlu pemeriksaan klinis

Hasil dapat berbeda; penilaian bertumpu pada alasan dan perbandingan bukti.

Tabel 11.18: Lembar isian Latihan 2

Kebijakan contoh	Laporan pemakaian	Kebutuhan yang belum terpenuhi
…	…	…
…	…	…

1. Laporan naik 7,5 kali, dari 2 menjadi 15. Apakah peningkatan laporan membuktikan peningkatan pelanggaran?
2. Data tambahan apa yang membedakan adopsi sehat dan pelanggaran tersembunyi?

Latihan 3: AI dan Keamanan Informasi

Bandingkan ISO/IEC 42001 dan ISO/IEC 27001 dari sisi tujuan dan jenis risiko yang dikelola. Latihan ini membuktikan batas penggantian bukti antarkerangka.

1. Tentukan satu sistem AI dan dua risiko berbeda.
2. Hubungkan risiko ke tujuan tiap sistem manajemen.
3. Pilih bukti yang harus dikumpulkan, lalu jelaskan tumpang tindihnya.

Tabel 11.19 memuat contoh pada AI-01, dan Tabel 11.20 merupakan lembar isian. Angka merupakan skenario pembelajaran, bukan hasil pengukuran organisasi.

Tabel 11.19: Contoh terisi Latihan 3 (skenario pembelajaran)

Risiko	Fokus utama	Bukti contoh
Akses data tanpa izin	Keamanan informasi	Uji otorisasi; 120 dari 120 akun lulus
Ringkasan melewatkan alergi	Dampak dan mutu AI	Uji klinis terarah; 4 dari 100 kesalahan kritis

Tabel 11.20: Lembar isian Latihan 3

Risiko	Fokus utama	Bukti contoh
…	…	…
…	…	…

Hasil dapat berbeda; penilaian bertumpu pada alasan dan perbandingan bukti.

1. Apa yang belum dibuktikan oleh uji akses yang lulus pada 120 dari 120 akun?
2. Bagaimana menggabungkan kedua sistem tanpa menggandakan bukti?

Bab 12

Audit TI dan Asurans

Tujuan Pembelajaran

- Menjelaskan pembagian peran dalam Three Lines Model dan posisi audit internal yang independen.
- Menyusun rencana asurans berbasis risiko untuk program transformasi digital.
- Menguji rancangan dan efektivitas satu kontrol dengan bukti yang memadai.

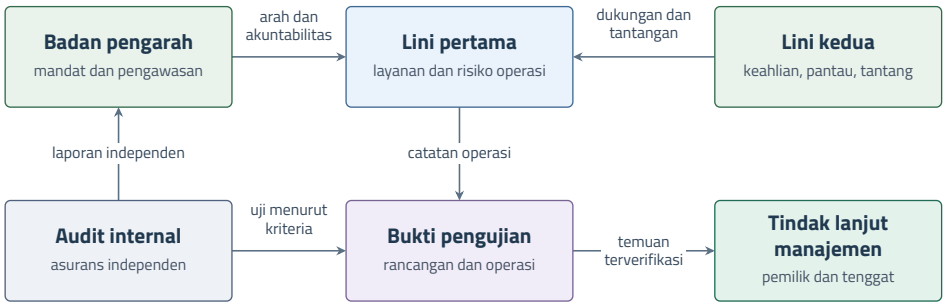
12.1 Pendahuluan

Misalkan direksi Medikara menerima laporan dari unit Teknologi Informasi (TI): peninjauan akses vendor berjalan, dan 108 dari 108 akun sudah ditinjau. Audit internal memeriksa 30 dari 120 akun vendor dan menemukan 6 akun masih aktif setelah penugasan berakhir. Kedua pernyataan dapat benar bersamaan. Unit TI menghitung akun pada daftar yang diterimanya. Auditor memulai dari daftar penugasan. Daftar unit TI hanya memuat 108 akun, sehingga 12 akun tidak pernah masuk hitungan. Dengan penyebut yang benar, cakupannya 90 persen, bukan 100 persen.

Direksi karena itu membutuhkan keyakinan yang tidak berasal dari pihak yang menjalankan pekerjaan. Bab ini menjawab tiga pertanyaan: siapa yang boleh memberi keyakinan, area mana yang diperiksa lebih dahulu, dan bukti apa yang cukup untuk menutup temuan. Bab 8 sampai Bab 11 sudah merancang kontrol beserta bukti penerimaannya. Bab ini memastikan rancangan itu dapat diperiksa, sekaligus membuka tonggak C4 Peta Jalan dan Tata Kelola. Hasil kerjanya adalah rencana asurans dua tahun dan contoh pengujian satu kontrol.

Bab ini merujuk Global Internal Audit Standards dari The Institute of Internal Auditors (IIA), yang berlaku sejak 9 Januari 2025, serta Three Lines Model dalam *Statement of Position* IIA tahun 2026. IT Audit Framework (ITAF) dari ISACA melengkapi metode audit TI. Naskah ITAF berbayar, sehingga perannya ditulis secara umum. Cara menguji kontrol mengambil contoh dari Federal Information System Controls Audit Manual (FISCAM) revisi 2026, yang terbuka untuk dibaca. FISCAM ditulis untuk audit instansi federal Amerika Serikat, sehingga dipakai sebagai contoh metode dan tidak mengikat Medikara. Seluruh angka tambahan tentang Medikara merupakan contoh pembelajaran [150, 151, 67, 159].

Gambar 12.1 merangkum hubungan komponen dan konsep utama bab ini.



Gambar 12.1: Pengelolaan risiko dan asurans independen mempunyai peran berbeda

12.2 Konsep Asurans

Keyakinan yang punya batas

Asurans adalah pernyataan yang dimaksudkan untuk menaikkan keyakinan pemangku kepentingan atas tata kelola, manajemen risiko, kepatuhan, dan kontrol organisasi [151]. Cara kerjanya melibatkan tiga pihak. Pihak yang bertanggung jawab menjalankan kegiatan, penilai memeriksanya terhadap kriteria, dan pengguna hasil mengambil keputusan. Keyakinan selalu memiliki batas ruang lingkup, periode, populasi, dan metode.

Analogi pemeriksaan kendaraan menunjukkan batas itu. Pemeriksaan rem pada tanggal tertentu memberi bukti tentang kondisi yang diperiksa, bukan jaminan bahwa kendaraan tidak akan pernah mengalami kecelakaan. Laporan yang baik menyebut hal yang diperiksa dan hal yang belum dapat disimpulkan.

Pertanyaan kemudian muncul: apakah laporan “semua aman” dapat diterima? Laporan itu perlu menjawab lima pertanyaan pada Tabel 12.1. Keyakinan tanpa

batas klaim tidak membantu direksi menimbang risiko sisa.

Tabel 12.1: Lima pertanyaan atas laporan "semua aman" pada AC-01 (misalkan)

Pertanyaan	Laporan unit TI	Pengujian audit internal
Kriteria	Akun pada daftar sudah ditinjau	Akun dicabut paling lambat 1 hari kerja setelah penugasan berakhir
Populasi	108 akun pada daftar peninjau	120 akun pada daftar penugasan
Periode	Satu bulan terakhir, tanpa tanggal	Tanggal acuan 31 Maret 2026
Metode	Pernyataan pelaksana	Pencocokan dokumen dan 30 akun sampel
Pengecualian	Tidak disebut	Sampel satu lokasi; 4 rumah sakit lain belum punya bukti

Dua contoh menunjukkan akibat batas klaim:

1. Klaim 108 dari 108 benar untuk daftar, tetapi salah untuk Medikara. Bila penyebutnya 120 akun, cakupannya $108/120 = 90$ persen. Selisih 12 akun atau 10 persen tidak pernah ditinjau. Bab 5 menghitung cakupan ini masih menyisakan harapan kerugian Rp32,5 juta, bukan Rp25 juta.
2. Misalkan audit mencakup 7 akun aktif pada 30 Oktober 2026 di satu rumah sakit. Hasilnya tidak otomatis berlaku bagi akun di empat rumah sakit lain, dan tidak menjelaskan 11 bulan sebelumnya.

Asurans dan konsultasi

Dua hal pada audit internal sering tertukar: asurans dan konsultasi. Pembagiannya begini. Asurans menghasilkan kesimpulan objektif tentang efektivitas proses atau kontrol. Konsultasi memberi saran tanpa memberi asurans dan tanpa mengambil tanggung jawab manajemen [150]. IIA menegaskan asurans tidak kredibel bila penilai merancang atau menjalankan prosesnya, menilai keputusannya sendiri, atau terpengaruh preferensi manajemen. Masa paling sedikit 12 bulan antara tanggung jawab atas suatu proses dan pemberian asurans atas proses itu biasanya memadai untuk menjaga objektivitas [151].

Analogi guru les dan penguji membantu membedakan keduanya. Guru les membantu murid belajar. Penguji menilai jawaban murid. Satu orang boleh memegang keduanya pada waktu yang berbeda, tetapi tidak menilai jawaban yang ia diktekan sendiri.

Tabel 12.2 merangkum perbedaannya. Baris pengaman mengikuti pernyataan IIA: peran konsultasi didefinisikan jelas, penasihat tidak mengambil keputusan ma-

najemen, dan badan pengarah mengetahui sifat serta ruang lingkup pekerjaannya [151].

Tabel 12.2: Asurans dan konsultasi

Aspek	Asurans	Konsultasi
Tujuan	Menilai terhadap kriteria	Membantu perbaikan
Kriteria	Wajib ditetapkan	Dapat tidak diperlukan, sesuai kesepakatan
Keluaran	Kesimpulan dan temuan	Saran dan pilihan
Tanggung jawab kontrol	Tetap pada manajemen	Tetap pada manajemen
Pengaman	Penilai tidak menjalankan proses yang dinilai	Peran jelas; keputusan pada manajemen; badan pengarah diberi tahu

Dua contoh penerapan:

1. Misalkan pada Tahun 1 audit internal memberi saran selama 40 jam untuk kebijakan pemakaian AI (KB-09, Bab 11). Pemilik KB-09 tetap direktur pelayanan, dan penyetujunya tetap direksi. Audit AI pada Tahun 2 dipimpin auditor yang tidak memberi saran itu, dan dewan komisaris mengetahui pemisahannya.
2. Misalkan seorang petugas operasi TI menjalankan AC-01 sampai 31 Maret 2026, lalu pindah ke audit internal. Dengan acuan 12 bulan, ia sebaiknya tidak menguji AC-01 sebelum 1 April 2027. Bila auditor lain tersedia, penugasan dialihkan sejak awal.

12.3 Three Lines Model

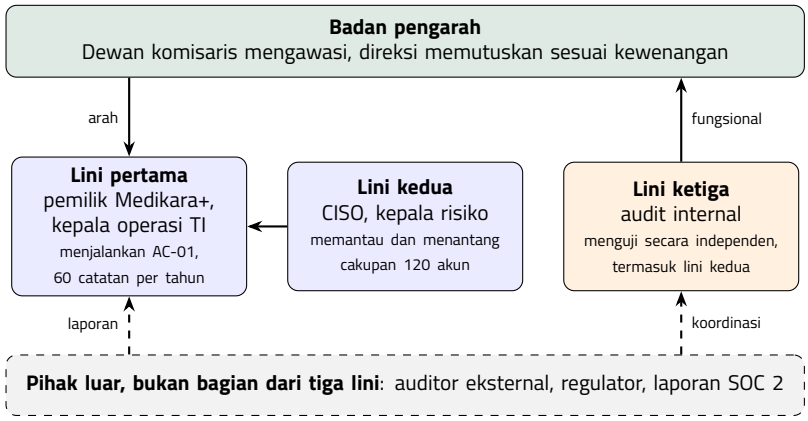
Empat peran pada satu kontrol

Three Lines Model membedakan badan pengarah, manajemen sebagai lini pertama, peran pendukung dan spesialis sebagai lini kedua, serta audit internal sebagai lini ketiga. Lini pertama memiliki risiko sehari-hari, merancang, dan menjalankan kontrol. Lini kedua memberi keahlian, dukungan, pemantauan, dan tantangan. Lini ketiga memberi asurans independen, termasuk atas lini kedua, serta saran tanpa mengambil tanggung jawab manajemen. Pembagiannya merupakan peran, bukan kewajiban memiliki tiga departemen [151].

Analogi pengelolaan pertandingan membantu membedakan fungsi. Pemain menjalankan strategi, pelatih memantau dan memberi koreksi, sedangkan penilai independen memeriksa apakah aturan diterapkan. Pihak yang membuat keputusan operasi tidak sekaligus memberi penilaian independen atas keputusannya

sendiri.

Gambar 12.2 menerapkan model itu pada AC-01. Bab 1 sudah memperkenalkan empat peran ini, dan Bab 8 menempatkan Chief Information Security Officer (CISO) pada lini kedua. Auditor eksternal dan regulator bukan bagian dari tiga lini. Mereka melayani pihak di luar organisasi, tetapi hasilnya dapat dipakai untuk memahami kecukupan kontrol [151].



Gambar 12.2: Three Lines Model pada kontrol AC-01 (misalkan)

Diagram konsep pada awal bab meringkas hubungan yang sama. Badan pengarah memberi arah dan akuntabilitas kepada lini pertama. Lini kedua memberi dukungan dan tantangan. Audit internal menguji menurut kriteria dan menyampaikan laporan independen kepada badan pengarah. Catatan operasi lini pertama menjadi bukti pengujian, atas rancangan dan atas operasi. Temuan yang terverifikasi lalu masuk ke tindak lanjut manajemen, lengkap dengan pemilik dan tenggat.

Tiap peran punya kekuatan dan batasnya sendiri. Dokumen IIA menyebut tidak ada satu lini yang dapat memaksimalkan semua sifat sekaligus [151]. Tabel 12.3 memperlihatkan akibatnya pada Medikara.

Dua contoh penerapan:

1. Bab 8 membagi AC-01 menjadi empat tugas: pengelola vendor mengusulkan, pemilik Medikara+ menyetujui, operasi TI menjalankan, dan audit internal menguji. Bila CISO ikut menjalankan tinjauan catatan aktivitas pada G-02, ia tidak dapat sekaligus menantang hasil tinjauan yang sama. Pada 260 tinjauan per tahun, kedua tugas itu dipegang orang berbeda.
2. Misalkan kepala audit internal diminta menyetujui akses vendor selama 3 bulan karena petugas kosong. IIA menyebut keadaan audit internal menjalankan tugas lini kedua sebagai ancaman menilai diri sendiri. Pengamannya adalah alasan tertulis, pengungkapan kepada badan pengarah, dan asurans

Tabel 12.3: Pemetaan peran AC-01 pada Medikara dan batas tiap peran

Peran	Contoh pemilik	Tanggung jawab	Batas yang perlu dibaca
Badan pengarah	Dewan komisaris dan direksi sesuai kewenangan	Menetapkan arah, mengawasi mandat dan hasil	Bergantung pada informasi yang andal dan berimbang
Lini pertama	Pemilik Medikara+, kepala operasi TI, pemilik SIMRS	Menjalankan AC-01	Dekat dengan risiko, tetapi dapat meremehkan kelemahan kontrolnya
Lini kedua	CISO, kepala risiko, petugas pelindungan data	Memantau dan menantang	Kadang terganggu karena melapor lewat manajemen; dapat berhenti pada kepatuhan prosedur
Lini ketiga	Audit internal	Menguji secara independen	Berkala dan berbasis risiko, sehingga area berisiko rendah jarang diperiksa

dari pihak independen lain selama tumpang tindih itu berlangsung [151]. Area AC-01 pada 3 bulan tersebut diuji oleh pihak lain.

Independensi dan jalur pelaporan

Independensi organisasi ditentukan posisi peran dalam struktur tata kelola dan sejauh mana peran itu bekerja tanpa campur tangan. IIA menyebut lima unsur: jalur pelaporan dan wewenang, otonomi atas ruang lingkup, akses tanpa batas, kendali atas sumber daya, serta perlindungan dari tekanan. Posisi itu umumnya berarti pelaporan fungsional kepada badan pengarah dan pelaporan administratif kepada pimpinan eksekutif. Independensi juga tidak berarti terisolasi [151].

Medikara memiliki dua organ, yaitu dewan komisaris yang mengawasi dan direksi yang memutuskan. Bila ada lebih dari satu organ, istilah badan pengarah merujuk organ yang berwenang memberi mandat [151]. Misalkan audit internal melapor secara fungsional kepada dewan komisaris lewat komite audit, dan secara administratif kepada direktur utama. Tabel 12.4 menguji kelima unsur tersebut.

Pertanyaan kemudian muncul: bolehkah unit risiko melapor kepada direktur TI? IIA menulis lini kedua melapor kepada anggota manajemen senior atau komite setingkat badan pengarah. IIA juga mencatat objektivitas lini kedua kadang terganggu karena melapor lewat manajemen [151]. Jabatan atasan saja belum membuktikan pelanggaran. Masalah muncul bila mandatnya seluruh organisasi,

Tabel 12.4: Lima unsur independensi pada audit internal Medikara (misalkan)

Unsur	Bukti yang diperiksa	Tanda masalah
Jalur pelaporan dan wewenang	Piagam audit; laporan ke komite audit	Laporan harus melewati kepala TI
Otonomi ruang lingkup	Rencana disetujui dewan komisaris	Area AC-01 dicoret oleh pihak yang diperiksa
Akses tanpa batas	Hak meminta daftar penugasan langsung	Daftar hanya datang dari operasi TI
Kendali sumber daya	Jam dan keahlian tercatat pada rencana	Jam dipotong tanpa dilaporkan
Perlindungan dari tekanan	Catatan perubahan laporan audit	Temuan diubah atas permintaan pemilik proses

sementara ruang lingkup, pelaporan, dan tantangannya dibatasi unit yang diawasi. Latihan 1 menguji hal ini.

Dua contoh penerapan:

1. Misalkan auditor hanya menerima daftar akun dari operasi TI, yaitu 108 akun. IIA menyebut independensi terganggu bila akses ke bukti disaring atau dikendalikan [151]. Auditor meminta daftar penugasan dari pengelola vendor dan menemukan 120 akun. Hak akses itu menambah 12 akun ke populasi.
2. Misalkan unit risiko hanya mengelola risiko operasi TI. Pelaporan kepada direktur TI dapat sesuai, tetapi hasilnya bukan penilaian independen. Bila mandatnya mencakup 12 skenario register, pelaporan itu perlu akses langsung ke komite risiko pada 4 rapat per tahun.

12.4 Standar Profesi: GIAS dan ITAF

Global Internal Audit Standards (GIAS) mengatur tujuan audit internal, etika dan profesionalisme, tata kelola fungsi audit, pengelolaan fungsi audit, serta pelaksanaan layanan. Standar yang diterbitkan 2024 ini berlaku sejak 9 Januari 2025, dan memuat 5 domain, 15 prinsip, serta 52 standar [150]. Ukuran tim tidak menghilangkan kebutuhan mandat, kompetensi, dokumentasi, dan komunikasi.

Analogi klinik kecil menunjukkan perlunya mutu yang proporsional. Ukuran organisasi dapat mengubah cara dokumentasi dan pembagian tugas, tetapi tidak membenarkan pemeriksaan tanpa catatan atau pelaporan yang menyembunyikan hasil.

Tabel 12.5 memilih enam standar yang paling dekat dengan pekerjaan bab ini. Uraiannya merupakan ringkasan bab ini, bukan terjemahan resmi.

Tabel 12.5: Enam standar GIAS dan buktinya pada Medikara

Standar	Ketentuan ringkas	Bukti contoh
7.1	Independensi dikonfirmasi kepada badan pengarah paling sedikit setahun sekali	Pernyataan tahunan dan catatan gangguan
8.4	Penilaian mutu eksternal paling sedikit sekali dalam lima tahun	Rencana penilaian yang dibahas dengan badan pengarah
9.4	Rencana audit berdasar penilaian terdokumentasi atas strategi, tujuan, dan risiko, paling sedikit setahun sekali	Tabel 12.6
9.5	Koordinasi dengan penyedia asurans lain; dasar kepercayaan didokumentasikan	Tabel 12.8
14.1	Informasi relevan, andal, dan cukup untuk diulang orang lain dengan kesimpulan sama	Kertas kerja 30 akun
15.2	Pelaksanaan rekomendasi dikonfirmasi dan statusnya dilacak	Status penutupan TA-01

Dua contoh penerapan:

1. Misalkan area vendor dan cloud memerlukan 320 jam, dan 60 jam di antaranya memerlukan keahlian konfigurasi. Tim memakai spesialis independen untuk 60 jam itu, dan tetap menyetujui ruang lingkup serta kesimpulan. Standar 9.5 menempatkan tanggung jawab kesimpulan tetap pada kepala audit internal [150].
2. Misalkan seorang auditor memimpin proyek SIMRS Bekasi sampai 6 bulan lalu, dan audit akses SIMRS dijadwalkan bulan depan. Selisih itu masih di bawah acuan 12 bulan. Konflik dinilai sebelum penugasan, bukan setelah hasil diperdebatkan. Standar 7.1 meminta gangguan independensi beserta pengamannya dilaporkan kepada badan pengarah [150].

Pertanyaan berikutnya: di mana posisi ITAF? ITAF adalah kerangka ISACA untuk audit dan asurans TI. Edisi kelimanya dijual ISACA [67], sehingga bab ini tidak menguraikan isinya. Fungsi audit yang memakainya perlu mencocokkan butir ketentuan ke naskah berlisensi. Mahasiswa tanpa akses naskah itu tetap dapat berlatih memakai FISCAM untuk pengujian kontrol dan Government Auditing Standards untuk unsur temuan [159, 158]. Keduanya terbuka, tetapi ditulis untuk audit pemerintah Amerika Serikat. Sertifikasi profesi menunjukkan kompetensi tertentu, sedangkan mutu tiap penugasan tetap dinilai dari kertas kerjanya.

12.5 Perencanaan Audit Berbasis Risiko

Dari semesta audit ke prioritas

Semesta audit adalah daftar area yang dapat diperiksa. Rencana berbasis risiko memilih prioritas dengan mempertimbangkan dampak, perubahan, kewajiban, insiden, dan cakupan asurans yang sudah ada. Standar 9.4 meminta rencana itu berdasar penilaian terdokumentasi yang diperbarui paling sedikit setahun sekali, dengan masukan badan pengarah dan manajemen senior [150]. Gambar 12.3 memperlihatkan posisi rencana dalam siklus asurans.



Gambar 12.3: Siklus asurans dari mandat sampai tindak lanjut terverifikasi

Analogi pemeriksaan rumah menunjukkan prioritas. Retakan pada struktur dan lampu hias yang mati tidak diperiksa dengan prioritas sama. Riwayat perbaikan dan rencana renovasi ikut menentukan lokasi yang diperiksa lebih dahulu.

Bab ini memakai rumus pembelajaran yang sederhana. Prioritas sama dengan skor risiko Bab 5, ditambah nilai perubahan, ditambah nilai kewajiban, lalu dikurangi nilai asurans lain yang dapat diandalkan. Ketiga nilai tambahan memakai skala 0 sampai 5 dan bersifat pengandaian. Rumus ini bukan ketentuan standar. Tabel 12.6 menerapkannya pada sepuluh area, diurutkan dari prioritas tertinggi.

Kapasitas membatasi pilihan. Misalkan Medikara menyediakan 1 auditor TI selama 1.200 jam dan 1 auditor umum selama 600 jam per tahun, atau 1.800 jam. Dua tahun berarti 3.600 jam. Cadangan 20 persen untuk tindak lanjut dan audit mendadak mengambil 720 jam, sehingga jam terencana hanya 2.880. Kebutuhan 3.240 jam melebihinya sebesar 360 jam. Dua area berprioritas terendah, yaitu laporan spreadsheet dan rilis Medikara+, senilai 480 jam, ditunda. Jam terencana terpakai 2.760 dan tersisa 120 jam.

Keputusan ini punya dua konsekuensi. Pertama, risiko pada area yang ditunda tetap ada. R-04 berskor 12 dengan harapan kerugian Rp30 juta per tahun, dan area itu hanya dipantau lini pertama dan lini kedua. Kepala audit internal melaporkan celah cakupan ini kepada dewan komisaris. Membuka kembali kedua area memerlukan 360 jam tambahan, atau Rp21,6 juta dalam dua tahun dengan tarif Rp60.000 per jam. Kedua, kapasitas 1.800 jam senilai Rp108 juta per tahun

Tabel 12.6: Semesta audit Medikara dan skor prioritas (misalkan)

Area	Risiko	Skor	Ubah	Wajib	Lain	Prioritas	Jam
Akses vendor AC-01	R-01	12	3	5	1	19	600
AI klinis AI-01, AI-02	R-11	12	5	3	1	19	480
Pemulihan DSS04	R-05	10	5	2	1	16	480
Jejak aktivitas KB-06	R-02	12	3	3	2	16	240
Privasi dan retensi	R-09	9	3	5	2	15	200
Insiden dan pemberitahuan	R-12	8	3	5	2	14	240
Vendor inti dan cloud	R-08	8	5	3	3	13	320
Integrasi BPJS Kesehatan	R-03	9	3	2	1	13	200
Laporan spreadsheet	R-04	12	1	1	4	10	240
Rilis Medikara+	R-07	9	2	1	2	10	240
Jumlah							**3.240**

adalah sumber daya yang sudah ada. Angka ini bukan anggaran baru dan tidak menambah beban 3.046 jam pada peta jalan Bab 14.

Dua contoh menunjukkan skor tidak boleh diikuti secara mekanis:

1. Akses vendor dan AI klinis sama-sama berprioritas 19. AC-01 diuji lebih dahulu karena sudah berjalan, sedangkan AI-01 dan AI-02 belum berjalan pada Tahun 1. Skor juga tidak boleh menutupi keselamatan pasien. Misalkan muncul satu kejadian cedera berat terkait ringkasan AI pada masa uji. Bab 5 meminta peninjauan dalam 1 hari kerja, dan audit khusus 120 jam memakai cadangan 360 jam tahun itu tanpa menunggu urutan skor.
2. Pemulihan berprioritas 16, tetapi dijadwalkan pada akhir Tahun 1 karena mendahului perpindahan ke *cloud*. Menempatkannya setelah migrasi mengurangi kesempatan mencegah kegagalan. R-05 juga berharapan kerugian Rp200 juta, terbesar pada Bab 5, walaupun skornya lebih rendah dari R-01. Biaya audit 480 jam hanya Rp28,8 juta.

Kasus Medikara Health: Rencana Asurans Dua Tahun

Misalkan kepala audit internal menyusun rencana pada Tabel 12.7. Tahun 1 memakai 1.440 jam terencana, termasuk sisa 120 jam untuk saran KB-09 selama 40 jam dan pembacaan laporan pihak luar selama 80 jam. Tahun 2 juga memakai 1.440 jam.

Misalkan direktur keuangan memangkas kapasitas menjadi 1.200 jam per tahun. Jam terencana turun menjadi $1.200 \times 0{,}8 = 960$ jam. Akses vendor 600 jam dan pemulihan 480 jam berjumlah 1.080 jam, sehingga

audit pemulihan tidak muat sebelum migrasi. IIA meminta keterbatasan sumber daya yang memengaruhi asurans dilaporkan kepada pihak yang tepat [151]. Pemangkasan itu karena itu masuk laporan ke komite audit, bukan diselesaikan diam-diam dengan mengurangi area.

Tabel 12.7: Contoh rencana asurans dua tahun (misalkan)

Waktu	Area dan pemicu	Jam	Keputusan yang didukung
Tahun 1 awal	Akses vendor AC-01, R-01, insiden 2025	600	Kesiapan perluasan mitra
Tahun 1 akhir	Pemulihan DSS04, sebelum migrasi	480	Kesiapan kelangsungan
Tahun 1 akhir	Insiden dan pemberitahuan, K-04	240	Kesiapan pemberitahuan
Sepanjang Tahun 1	Saran KB-09 dan pembacaan laporan pihak luar	120	Rancangan kebijakan AI; dasar kepercayaan
Tahun 2	AI klinis AI-01, AI-02, KB-09	480	Batas perluasan AI
Tahun 2	Jejak aktivitas KB-06	240	Keandalan penelusuran
Tahun 2	Privasi dan retensi	200	Batas pemakaian data
Tahun 2	Vendor inti dan cloud, V-01 dan V-02	320	Perpanjangan kontrak
Tahun 2	Integrasi BPJS Kesehatan	200	Kelangsungan pendaftaran

Peta asurans

Pertanyaan berikutnya: siapa saja yang sudah memeriksa area yang sama? Peta asurans adalah dokumen tingkat tinggi yang memperlihatkan cakupan risiko oleh berbagai penyedia asurans, sehingga celah dan pengulangan terlihat [151]. Standar 9.5 meminta kepala audit internal berkoordinasi dan mempertimbangkan pekerjaan penyedia lain. Bila audit internal mengandalkan pekerjaan itu, dasarnya didokumentasikan dan tanggung jawab atas kesimpulan tetap pada audit internal [150]. Tabel 12.8 menerapkannya pada Medikara.

Dua contoh penerapan:

1. Bab 1 menghitung tiga fungsi yang masing-masing meminta daftar akun kepada 23 fasilitas setiap triwulan menghasilkan 276 permintaan per tahun. Satu jadwal bersama menurunkannya menjadi 92 permintaan. Dengan 2 jam per permintaan, fasilitas menghemat 368 jam, atau Rp22,08 juta per tahun. Audit internal tetap menilai mutu daftar itu sendiri.
2. Bab 8 menetapkan petugas pelindungan data memeriksa Paket C dan CISO memeriksa Paket D. Audit internal menilai mutu pemeriksaan keduanya, se-

Tabel 12.8: Peta asurans Medikara (misalkan)

Area	Lini pertama	Lini kedua	Audit internal	Pihak luar
Akses vendor AC-01	60 catatan per tahun	CISO memantau 120 akun	Tahun 1	SOC 2, sisi penyedia saja
Pemulihan DSS04	144 uji per tahun	Kepala risiko meninjau hasil	Tahun 1	Tidak ada
Insiden	Prosedur KB-07	Petugas pelindungan data memeriksa 2 latihan	Tahun 1	Tidak ada
Jejak aktivitas	Tinjauan catatan aktivitas	CISO memeriksa 247 dari 260 tinjauan	Tahun 2	Tidak ada
AI klinis	Uji AI-01, AI-02	Kepala risiko, petugas pelindungan data	Tahun 2	Tidak ada
Vendor dan cloud	Pengelola vendor	Kepala risiko meninjau register pemasok	Tahun 2	SOC 2 Type 2, sertifikat
Laporan spreadsheet	Rekonsiliasi manual	Kepala risiko	Ditunda	Audit keuangan, angka keuangan saja

hingga nilai asurans lain pada kedua area itu 2. Bila mutunya tidak memenuhi harapan, audit internal dapat memilih tidak mengandalkannya [151]. Nilai itu turun menjadi 0, dan prioritas jejak aktivitas naik dari 16 menjadi 18.

12.6 Program Audit dan Pengujian Kontrol

Uji rancangan dan uji efektivitas

Program audit menyatakan tujuan, kriteria, populasi, prosedur, bukti, dan cara menyimpulkan hasil. Uji rancangan menilai apakah kontrol, bila dijalankan sesuai rencana, dapat menangani risiko. Uji efektivitas operasi memeriksa apakah kontrol benar-benar dijalankan selama periode yang dipilih. FISCAM menegaskan dokumen proses, diagram alur, dan prosedur memberi bukti tentang rancangan, tetapi tidak membuktikan kontrol sudah diterapkan dan bekerja [159].

Analogi pemeriksaan pintu menunjukkan perbedaannya. Rancangan kunci dapat memadai, tetapi bukti bahwa pintu dikunci setiap malam memerlukan catatan

dan pengamatan pelaksanaan. Membaca prosedur tidak membuktikan kepatuhan setiap hari.

Kedua uji menghasilkan empat keadaan pada Gambar 12.4. Keadaan kiri bawah paling sering menipu. Kontrol dijalankan rajin, laporannya rapi, tetapi tujuannya meleset.



Gambar 12.4: Empat keadaan kontrol menurut hasil uji rancangan dan uji operasi

Dua contoh pada AC-01:

1. Bab 6 menemukan tanggal berakhir penugasan tidak masuk daftar peninjau, dan daftar itu hanya memuat 108 dari 120 akun. Walaupun peninjau bekerja sempurna, cakupan paling tinggi 90 persen. Ini kelemahan rancangan. Menambah frekuensi peninjauan tidak menyelesaikannya.
2. AC-01 berjalan bulanan pada 5 rumah sakit, sehingga seharusnya ada $5 \times 12 = 60$ catatan per tahun. Catatan yang tersedia hanya 12, seluruhnya dari 1 rumah sakit. Rancangan yang baik pada rumah sakit itu tidak membuktikan operasi pada 4 rumah sakit lain. Ini kelemahan operasi.

Tabel 12.9 menyusun keduanya menjadi program audit singkat. Rincian prosedurnya ada di `sources/chapter12/program-audit-hak-akses.md`.

Kriteria ditetapkan sebelum data dibuka

Standar 13.4 meminta auditor memakai kriteria yang paling relevan. Bila kriteria dari manajemen tidak memadai, kriteria yang tepat dibahas dengan badan pengarah atau manajemen senior [150]. Urutannya penting. Kriteria yang ditetapkan sesudah melihat data dapat digeser mengikuti hasil yang diinginkan.

Tabel 12.9: Program audit AC-01 dan hasil contoh (misalkan)

Pertanyaan	Jenis uji	Bukti	Hasil contoh
Siapa boleh menyetujui dan menjalankan?	Rancangan	Prosedur KB-03 dan pemisahan tugas Bab 8	Ada pemisahan tugas
Apakah daftar peninjau lengkap?	Rancangan	Daftar peninjau dan daftar penugasan	108 dari 120 akun
Apakah peninjauan berjalan bulanan di 5 rumah sakit?	Operasi	Catatan bulanan per lokasi	12 dari 60 catatan
Apakah akun dicabut paling lambat 1 hari kerja?	Operasi	Sampel 30 akun dan tiket pencabutan	24 sesuai, 6 menyimpang
Apakah pengecualian ditutup?	Tindak lanjut	Tiket dan verifikasi ulang	24 akun dicabut, lalu 9, 5, dan 2

Kasus Medikara Health: Potret Delapan Baris

Berkas `sources/chapter12/data-contoh-hak-akses.csv` memuat 8 akun sintetis pada satu rumah sakit, dengan tanggal acuan 30 Oktober 2026. Aturan skenarionya: setiap akun aktif punya pemilik, akun bersama manusia tidak dipakai, dan tinjauan paling lama 90 hari. Batas 90 hari bukan kewajiban standar. Satu akun tidak aktif dikeluarkan, sehingga populasinya 7 akun aktif. USR002 tidak punya pemilik. USR003 akun bersama dengan umur tinjauan 122 hari, dan umur tinjauan USR005 107 hari. Jumlahnya 3 akun berindikasi dan 4 indikasi. Tinjauan tepat waktu $5/7 = 71{,}43$ persen. Angka ini punya dua konsekuensi. Pertama, 3 akun dan 4 indikasi berbeda penyebutnya, sehingga USR003 tidak dihitung dua kali sebagai akun. Kedua, hasil bergantung pada kriteria. AC-01 berjalan bulanan. Bila batasnya 31 hari sesuai siklus itu, USR004 dengan 35 hari dan USR008 dengan 59 hari ikut terlambat, dan hasilnya turun menjadi $3/7 = 42{,}86$ persen. Keputusan batas ditulis lebih dahulu. Indikasi ini memicu pemeriksaan lanjutan, bukan vonis penyalahgunaan.

12.7 Bukti dan Sampel

Mutu bukti

Standar 14.1 meminta informasi yang relevan, andal, dan cukup. Relevan berarti sejalan dengan tujuan dan ruang lingkup penugasan. Andal berarti faktual dan terkini, dan keandalannya naik bila informasi diperoleh langsung atau dari sumber

independen, serta dikuatkan sumber lain. Cukup berarti orang lain yang cermat dapat mengulang pekerjaan itu dan sampai pada kesimpulan yang sama [150].

Analogi kas warung menunjukkan empat cara memperoleh bukti. Pemilik dapat bertanya kepada kasir, mengamati kasir pada satu sore, membaca buku kas, atau menghitung ulang uang dan nota. Keempatnya berbeda kekuatan. Hanya cara terakhir yang tidak bergantung pada ucapan kasir. FISCAM memakai pembagian serupa [159], dan Tabel 12.10 menerapkannya pada AC-01.

Tabel 12.10: Empat jenis uji pada AC-01

Jenis	Cara pada AC-01	Batasnya
Bertanya	Kepala operasi TI menjelaskan cara peninjauan	Tidak cukup bila berdiri sendiri
Mengamati	Auditor mendampingi peninjauan satu rumah sakit pada satu bulan	Tidak membuktikan kontrol berjalan pada waktu lain
Memeriksa dokumen	Membaca catatan bulanan dan tiket pencabutan	Dokumen prosedur hanya membuktikan rancangan
Mengulang	Auditor sendiri mencocokkan akun dengan daftar penugasan	Memerlukan akses data dan pemeriksaan kelengkapan data

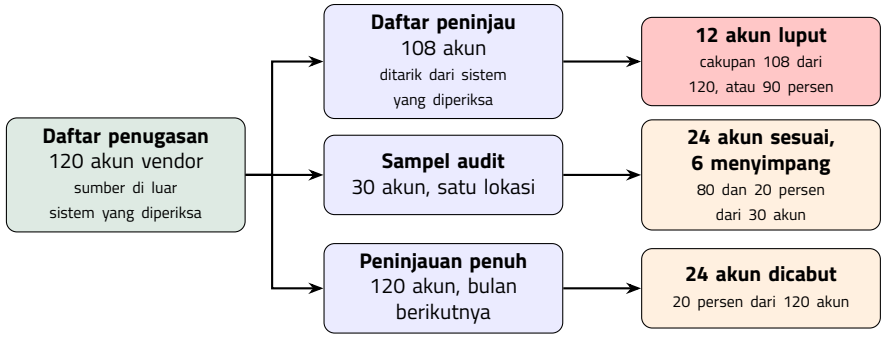
Dua contoh penerapan:

1. Bab 4 memisalkan kepala TI menyatakan peninjauan akses vendor sudah berjalan baik. Pernyataan itu bukti dari orang yang bertanggung jawab atas kontrol. Bukti tertulis hanya ada pada 1 dari 5 rumah sakit, sehingga kesimpulan untuk 4 rumah sakit lain belum dapat ditarik.
2. Bab 10 mencatat 29 dari 36 uji pemulihan lulus, atau 80,6 persen. Pada 5 rumah sakit, hanya 3 yang lulus, atau 60 persen. Pada 31 fasilitas lain, 26 lulus, atau 83,9 persen. FISCAM meminta auditor menimbang pemisahan populasi ketika beberapa lokasi menjalankan kontrol yang sama [159]. Hasil uji juga dibuat pelaksana, sehingga auditor mengulang sebagian uji SIMRS sendiri.

Populasi lebih dahulu

Pertanyaan kemudian muncul: sampel diambil dari mana? FISCAM meminta auditor menjelaskan populasi dan sumbernya, serta menguji apakah data dari manajemen lengkap, akurat, dan sah [159]. Sampel sebaik apa pun tidak dapat memuat akun yang tidak ada pada daftar. Sampel 30 akun dari daftar 108 tidak mungkin menyentuh 12 akun yang luput. Gambar 12.5 memperlihatkan tiga jalur dari satu populasi.

Dua angka 24 pada AC-01 sering tertukar. Pembagiannya begini. Angka pertama adalah 24 dari 30 akun sampel yang sesuai, atau 80 persen, seperti pada Bab



Gambar 12.5: Tiga pemeriksaan dari populasi 120 akun vendor

4 dan Bab 6. Angka kedua adalah 24 dari 120 akun yang dicabut pada peninjauan penuh bulan berikutnya, atau 20 persen. Keduanya sama-sama 24 karena 6 dari 30 dan 24 dari 120 sama-sama 20 persen. Yang pertama menghitung akun sesuai, dan yang kedua menghitung akun bermasalah.

Sampel statistik dan sampel terarah

Sampel memakai dua pendekatan. Sampel statistik dimaksudkan mewakili populasi dan dapat diproyeksikan kepadanya. Pemilihannya acak sederhana atau sistematis, dengan awal yang acak. Sampel terarah dipilih berdasarkan pertimbangan auditor dan tidak dimaksudkan untuk diproyeksikan [159]. Sampel terarah tidak salah, selama kesimpulannya tidak melampaui itemnya.

Analogi mencicipi sayur menjelaskan bedanya. Satu sendok dari panci yang sudah diaduk dapat mewakili isi panci. Satu sendok dari permukaan panci yang belum diaduk hanya menjelaskan permukaannya.

Sampel 30 akun pada Bab 4 hanya mewakili satu lokasi. Medikara karena itu tidak memproyeksikan angka 20 persen ke 120 akun. Angka 24 dari 120 berasal dari peninjauan penuh, bukan dari proyeksi. Misalkan audit ulang memakai sampel acak bertingkat per rumah sakit. Populasi Jakarta 40, Bekasi 24, Depok 20, Bogor 20, dan Bandung 16 akun menghasilkan alokasi 10, 6, 5, 5, dan 4 akun, atau seperempat tiap lokasi. Pemisahan ini layak karena tiap lokasi menjalankan versi SIMRS berbeda.

Pertanyaan berikutnya: apa yang dapat dikatakan sampel acak? Tabel 12.11 dan Tabel 12.12 memberi jawabannya. Hitungan memakai sebaran hipergeometrik karena akun tidak dikembalikan setelah terpilih. Batas bawah dan batas atas masing-masing memakai keyakinan 95 persen satu sisi. Berkas `sources/chapter12/hasil-sampel-ac01.json` memuat seluruh hasilnya.

Dua contoh cara membacanya:

Tabel 12.11: Membaca hasil sampel 30 dari 120 akun, bila sampel acak

Hasil pada sampel	Perkiraan titik	Batas bawah	Batas atas
6 dari 30 menyimpang	24 akun	13 akun	40 akun
2 dari 30 menyimpang	8 akun	2 akun	21 akun
0 dari 30 menyimpang	0 akun	0 akun	9 akun

Tabel 12.12: Daya deteksi sampel pada populasi 120 akun

Akun bermasalah pada populasi	Peluang tertangkap sampel 30	Sampel minimal 95 persen
24 akun	99,96 persen	13 akun
12 akun	97,40 persen	26 akun
6 akun	82,95 persen	47 akun
2 akun	43,91 persen	93 akun
1 akun	25,00 persen	114 akun

1. Bila 6 dari 30 berasal dari sampel acak, perkiraannya 24 akun, dengan rentang 13 sampai 40 akun. Lebar rentang itu 27 akun, atau hampir seperempat populasi. Sampel cukup untuk menyimpulkan ada masalah, tetapi tidak cukup untuk menyatakan jumlah pastinya.
2. Bab 8 menargetkan 30 dari 30 akun sampel sesuai. Hasil sempurna itu pun masih menyisakan kemungkinan sampai 9 akun bermasalah. Bila hanya 1 akun bermasalah, sampel 30 hanya menangkapnya dengan peluang 25 persen. *Risk appetite* Bab 5 adalah nol akun vendor tanpa pemilik, sehingga sampel saja tidak dapat membuktikannya. Karena itu Bab 8 juga menuntut 120 dari 120 akun cocok.

Keputusan ini punya dua konsekuensi. Pertama, untuk toleransi nol, seluruh populasi diuji. FISCAM menyebut alat otomatis memungkinkan pengujian tiap item pada populasi [159]. Bila satu akun diuji manual 20 menit, 120 akun memakan 40 jam atau Rp2,4 juta. Misalkan skrip dengan persiapan data 8 jam menandai 12 akun untuk ditelusuri manual selama 4 jam. Totalnya 12 jam, atau Rp720 ribu. Biaya itu kecil dibanding harapan kerugian R-01 sebesar Rp100 juta per tahun.

Kedua, sampel tetap berguna untuk hal yang tidak dapat dibaca mesin, misalnya keaslian persetujuan. Catatan bulanan juga populasi kecil. FISCAM memberi panduan 2 sampai 4 item untuk 12 pelaksanaan kontrol bulanan [159], atau 10 sampai 20 item bila kelima rumah sakit dipisahkan. Bab 8 menuntut 60 dari 60 catatan, dan membaca seluruhnya dengan 15 menit per catatan hanya memakan 15 jam. Medikara memilih membaca semuanya.

Pendalaman Teknis (opsional)

Rumus peluang. Peluang sampel berukuran n dari populasi N tidak memuat satu pun dari K akun bermasalah adalah $\binom{N-K}{n}/\binom{N}{n}$. Pada $N = 120$, $n = 30$, dan $K = 1$, hasilnya $90/120 = 0{,}75$, sehingga peluang tertangkap 25 persen. Batas atas pada Tabel 12.11 adalah K terbesar yang masih memberi peluang paling sedikit 5 persen untuk menghasilkan temuan sebanyak itu atau lebih sedikit.

Listing 12.1: Peluang sampel tanpa temuan, tersedia di `sources/chapter12/uji_sampel_ac01.py`

```
def peluang_nol_temuan(akun_bermasalah, ukuran_sampel, populasi):
  """Hitung peluang sampel acak tidak memuat satu pun akun bermasalah."""
  cara_tanpa_masalah = comb(populasi - akun_bermasalah, ukuran_sampel)
  return cara_tanpa_masalah / comb(populasi, ukuran_sampel)
```

Skrip pada folder sumber hanya membaca berkas sintetis. FISCAM meminta pemeriksaan teknis bahwa alat dipakai dengan tepat dan hasilnya lengkap serta akurat [159]. Skrip memberi bahan pemeriksaan. Auditor tetap memvalidasi pemilik, pengecualian layanan, dan bukti persetujuan.

12.8 Pelaporan Temuan dan Tindak Lanjut

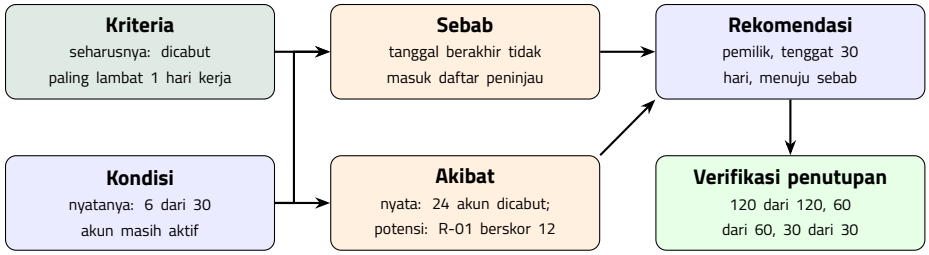
Unsur temuan

Temuan menghubungkan kondisi, kriteria, sebab, akibat, dan rekomendasi. Government Auditing Standards menjelaskan kriteria sebagai keadaan yang disyaratkan atau diharapkan, kondisi sebagai keadaan yang ada, sebab sebagai faktor di balik selisih keduanya, dan akibat sebagai konsekuensi nyata atau potensial [158]. Standar 14.3 meminta auditor menilai signifikansi dari peluang dan dampak, mencari akar sebab bersama manajemen, lalu memberi prioritas tiap temuan [150]. Sebab yang belum terbukti ditulis sebagai dugaan yang perlu dikonfirmasi.

Analogi laporan kebocoran atap menunjukkan kelengkapan temuan. Pernyataan lantai basah belum menjelaskan kriteria bangunan, asal air, akibat, dan perbaikan yang diperlukan. Menambah ember mungkin mengurangi dampak sementara, tetapi belum mengatasi penyebab.

Gambar 12.6 memperlihatkan hubungan keenam unsur, dan Tabel 12.13 menuliskannya untuk temuan TA-01. Kolom terakhir memisahkan yang sudah terbukti dari yang belum. Contoh lengkapnya ada di `sources/chapter12/contoh-temuan-ta01.md`.

Dua contoh menunjukkan batas temuan:



Gambar 12.6: Hubungan unsur temuan pada TA-01 (misalkan)

Tabel 12.13: Temuan TA-01 pada AC-01, tanggal acuan 31 Maret 2026 (misalkan)

Unsur	Isi	Status
Kondisi	6 dari 30 akun sampel masih aktif setelah penugasan berakhir. Daftar peninjau memuat 108 dari 120 akun. Catatan AC-01 tersedia 12 dari 60.	Terbukti pada sampel satu lokasi
Kriteria	Akun dicabut paling lambat 1 hari kerja (Bab 2). Nol akun vendor aktif tanpa pemilik (Bab 5). Peninjauan bulanan pada 5 rumah sakit (Bab 6).	Disetujui
Sebab	Tanggal berakhir tidak masuk daftar. Daftar diambil dari sistem yang diperiksa. Belum ada peninjau lintas lokasi.	Dua terkonfirmasi, satu dugaan
Akibat	Nyata: 24 akun dicabut bulan berikutnya. Potensi: R-01 berskor 12, peringkat Tinggi.	Nyata dipisahkan dari potensi
Rekomendasi	Masukkan tanggal berakhir, tarik populasi dari daftar penugasan, dan terapkan pada 5 rumah sakit.	Menuju sebab
Pemilik dan tenggat	Pemilik risiko pemilik Medikara+; pemilik tindakan kepala operasi TI; 30 hari.	Disepakati
Verifikasi penutupan	120 dari 120 akun cocok, 60 dari 60 catatan, 30 dari 30 akun sampel sesuai.	Belum diuji

1. Temuan TA-01 tidak menyatakan 6 akun itu dipakai membocorkan data. Audit menuliskan bukti, membatasi kesimpulan pada populasi yang diperiksa, lalu menilai dampaknya pada R-01. Bab 5 memberi harganya. Pada bukti 1 dari 5 rumah sakit, peluang R-01 masih 0,17 dan harapan kerugian Rp85 juta. Register yang menulis cakupan penuh akan mencatat Rp25 juta. Selisih Rp60 juta itu lebih besar dari biaya audit area ini, yaitu 600 jam atau Rp36 juta.
2. Misalkan pemilik akun vendor kosong pada 1 dari 120 akun. Persentasenya sekitar 0,8 persen, tetapi statusnya tetap merah menurut Bab 5. Signifikansi temuan dinilai dari peluang dan dampak terhadap batas risiko, bukan dari besar persentasenya.

Tindak lanjut sampai terverifikasi

Penutupan berdasarkan janji atau unggahan dokumen belum membuktikan perbaikan berjalan. Standar 15.2 meminta auditor mengonfirmasi pelaksanaan rekomendasi: menanyakan kemajuan, melakukan penilaian lanjutan berbasis risiko, dan memperbarui status pada sistem pelacakan. Bila manajemen terlambat, auditor meminta penjelasan, dan kepala audit internal menilai apakah manajemen senior sudah menerima risiko di atas toleransinya karena penundaan atau tidak bertindak [150]. Keterlambatan tanpa keputusan berarti risiko diterima tanpa disebut.

Analogi resep dokter menjelaskan bedanya. Resep yang sudah ditulis bukan bukti pasien sembuh. Dokter meminta pasien kembali dan memeriksa ulang, karena yang dinilai adalah hasil, bukan selembar kertas. Pada TA-01, temuan melewati empat status: terbuka, selesai menurut manajemen, diuji ulang, dan ditutup. Status kedua dan keempat sering dianggap sama.

Dua contoh penerapan:

1. Misalkan manajemen menyatakan perbaikan selesai setelah prosedur KB-03 terbit. Audit meminta bukti peninjauan periode berikutnya pada 5 rumah sakit sebelum menyimpulkan efektivitas operasi. Statusnya berhenti pada selesai menurut manajemen, dan belum ditutup.
2. Bab 6 mencatat pencabutan turun dari 24 menjadi 9, 5, dan 2 akun, atau turun sekitar 92 persen. Penurunan itu baik, tetapi bukan bukti penutupan. Bila daftarnya masih 108 akun, angka 2 hanya berlaku untuk akun yang terlihat. Auditor memeriksa penyebutnya lebih dahulu.

Membaca laporan audit nyata

Laporan audit publik melatih cara membaca angka. Office for Civil Rights (OCR) pada Department of Health and Human Services Amerika Serikat mengaudit kepatuhan Health Insurance Portability and Accountability Act (HIPAA) pada 2016 sampai 2017. Menurut ringkasan Lazzarotti dan Atrakchi, audit itu mencakup 166 penyedia layanan kesehatan dan 41 mitra usaha. Hanya 14 persen penyedia layanan yang dinilai memenuhi secara substansial tanggung jawab analisis risiko, dan hanya 6 persen pada manajemen risiko [93].

Bacaan ini memberi dua pelajaran bagi Medikara, tanpa menyalin angkanya:

1. Laporan yang baik menyebut populasi dan skala. Angka 14 persen hanya bermakna bila pembaca tahu penyebutnya 166 penyedia dan penilaiannya memakai peringkat 1 sampai 5.
2. Menganalisis berbeda dari mengelola. Angka manajemen risiko lebih rendah

dari analisis risiko. Pola ini mirip jarak antara register risiko Bab 5 dan bukti operasi pada bab ini.

12.9 Audit Eksternal, Sertifikasi, dan Laporan Pihak Ketiga

Bentuk asurans dari luar

Asurans dari luar berbeda tujuan dan pembacanya. Auditor eksternal memberi pendapat bagi pemangku kepentingan di luar organisasi, umumnya atas laporan keuangan, dan tujuannya bukan menggantikan penyedia asurans internal. Regulator dan lembaga akreditasi menegakkan kepatuhan pada ketentuan tertentu [151]. Laporan System and Organization Controls 2 (SOC 2) membantu pengguna menilai risiko alih daya pada kategori keamanan, ketersediaan, integritas pemrosesan, kerahasiaan, atau privasi [1]. Bab 6 dan Bab 9 sudah membaca sertifikat dan laporan SOC 2. Bab ini membahas keputusan berikutnya: seberapa jauh audit internal boleh mengandalkannya.

Analogi hasil pemeriksaan kesehatan calon karyawan membantu menjelaskannya. Perusahaan membaca tanggal pemeriksaan, jenis pemeriksaan, dan klinik penerbitnya. Hasil pemeriksaan mata tidak menjawab pertanyaan tentang jantung, dan hasil tahun lalu tidak menjawab kondisi hari ini.

International Standard on Assurance Engagements (ISAE) 3402 dari International Auditing and Assurance Standards Board (IAASB) mengatur laporan asurans atas kontrol pada organisasi jasa. Laporan Type 1 menilai uraian sistem dan kecukupan rancangan kontrol. Laporan Type 2 menambahkan apakah kontrol bekerja efektif selama periode tertentu. Ruang lingkupnya kontrol yang relevan dengan pengendalian internal pengguna atas pelaporan keuangan [57]. Ringkasan staf IAASB itu tidak mengikat, sehingga rincian ketentuan perlu dicocokkan ke naskah standarnya. Tabel 12.14 membandingkan bentuk-bentuk tersebut. Baris SOC 2 mengikuti pembacaan Bab 9 [30].

Keputusan mengandalkan laporan

Dua contoh memperlihatkan keputusannya:

1. Bab 9 memisalkan laporan SOC 2 Type 2 mencakup 1 Januari sampai 30 Juni 2026 dan dibaca pada 1 November 2026, sehingga sekitar 4 bulan belum tercakup. Pengujiannya memuat 3 pengecualian dari 25 sampel pencabutan akses, atau 12 persen. Medikara baru menjalankan 9 dari 14 kontrol pelengkap. Audit internal tidak mengurangi uji pencabutan, dan menguji sendiri 5 kontrol pelengkap yang belum berjalan. Bila laporan itu tidak dapat diandalkan sama sekali, nilai asurans lain pada area vendor turun

Tabel 12.14: Bentuk asurans dari luar dan cara memakainya

Bentuk	Yang dijawab	Yang belum dijawab
Audit laporan keuangan	Keandalan laporan keuangan	Apakah akun vendor Medikara+ sudah dicabut
Inspeksi regulator, akreditasi	Kepatuhan pada ketentuan tertentu	Efektivitas seluruh kontrol TI
Sertifikat ISO/IEC 27001	Sistem manajemen pada ruang lingkup itu	Kontrol di luar ruang lingkup
SOC 2 Type 1	Rancangan dan penerapan pada satu tanggal	Operasi sepanjang periode
SOC 2 Type 2	Operasi kontrol penyedia selama periode	Sisa waktu setelah periode; kontrol pelengkap pengguna
ISAE 3402 Type 2	Kontrol terkait pelaporan keuangan pengguna	Kerahasiaan data pasien, bila di luar ruang lingkup

dari 3 menjadi 0, dan prioritasnya naik dari 13 menjadi 16.

2. Misalkan laboratorium mitra V-03 mengirim laporan ISAE 3402 Type 2 untuk layanan penagihan. Laporan itu dapat membantu pemeriksaan angka tagihan. Laporan itu tidak otomatis menjawab kerahasiaan hasil laboratorium, atau salah alamat 1 dari 2.000 pengiriman pada Bab 9.

Bab 9 juga menyerahkan klausul kontrak untuk diuji sebagai bukti audit. Klausul pencabutan 1 hari kerja diuji dengan 120 dari 120 akun cocok, bukan dengan membaca kontraknya saja. Perjanjian vendor yang memuat 6 dari 11 butir menunjukkan rancangan yang belum lengkap. Laporan pihak ketiga tidak menggantikan evaluasi risiko vendor oleh Medikara, karena pengalihan pekerjaan tidak mengubah akuntabilitas badan pengarah [151].

12.10 Aktivitas: Rencana Asurans dan Pengujian Satu Kontrol

Tujuan. Tim menilai apakah program transformasi memiliki pemeriksaan independen yang memadai, lalu membuktikannya pada satu kontrol. Tim memakai organisasi nyata dengan izin dan data yang dianonimkan, atau kasus Medikara Health.

Pembagian peran. Anggota berlatar akuntansi atau audit memimpin. Analis teknologi menyiapkan dan menganalisis data. Analis risiko mengaitkan area audit dengan register risiko. Pemilik konteks menilai apakah rekomendasi dapat dijalankan, tanpa menentukan kesimpulan auditor.

Langkah kerja.

1. Petakan peran lini pertama, kedua, ketiga, dan badan pengarah. Catat konflik beserta pengamannya. Isi `sources/chapter12/peta-asurans.csv`.
2. Susun semesta audit dari register risiko dan kewajiban. Isi `sources/chapter12/rencana-asurans.csv` untuk dua tahun pertama peta jalan, hitung prioritas, lalu cocokkan jam dengan kapasitas.
3. Pilih satu kontrol penting, misalnya peninjauan hak akses SIMRS. Baca `sources/chapter12/program-audit-hak-akses.md`. Tetapkan kriteria, populasi, dan tanggal acuan sebelum membuka data.
4. Uji rancangan kontrol: kewenangan, pemisahan tugas, dan kelengkapan daftar.
5. Uji operasi dengan `sources/chapter12/sampel-ac01-30-akun.csv` dan `sources/chapter12/data-contoh-hak-akses.csv`. Pisahkan akun tidak aktif dari populasi, dan hitung akun bermasalah tanpa menggandakan akun dengan dua indikasi.
6. Konfirmasikan bukti tambahan yang diperlukan. Tulis satu temuan dengan `sources/chapter12/templat-temuan-audit.md`, lalu bandingkan dengan `sources/chapter12/contoh-temuan-ta01.md`.
7. Tetapkan tindakan, pemilik, tenggat, dan pengujian ulang. Presentasikan batas kesimpulan beserta risiko sisanya.

Luaran. Peta peran dan peta asurans, rencana asurans dua tahun, program uji satu kontrol, hasil pemeriksaan, dan satu temuan lengkap.

Kaitan dengan capstone. Luaran masuk tonggak C4 Peta Jalan dan Tata Kelola. Bab 13 memakai kriteria dan hasil uji sebagai bahan indikator. Bab 14 memasukkan rencana asurans ke peta jalan.

Kriteria penilaian. Ketepatan kriteria 25 persen; kecukupan bukti dan perhitungan 35 persen; kualitas temuan 25 persen; batas klaim dan tindak lanjut 15 persen. Hasil tiap tim boleh berbeda dari contoh. Penilaian berfokus pada penalaran.

Berkas pendukung. Daftar lengkap ada di `sources/chapter12/README.md`. Data organisasi nyata wajib berizin dan dianonimkan. Data pribadi pasien atau karyawan tidak boleh dipakai.

Pendalaman Teknis (Opsional): Teknik Audit Berbantuan Komputer

Jalankan `python uji_sampel_ac01.py` dan `python audit_hak_akses.py` dari folder sumber Bab 12. Tim berlatar teknis

dapat menerapkan cara yang sama pada *log* akses sintetis, misalnya mencari akun tanpa pemilik, akun bersama, dan akses di luar jam kerja. Berkas contoh tidak memuat jam akses, sehingga kesimpulan tentang jam kerja memerlukan *log* tambahan. Pada organisasi nyata, pekerjaan ini hanya memakai data berizin tertulis yang sudah dianonimkan, dan tidak boleh berupa pemindaian sistem milik pihak lain.
Langkah berikutnya adalah *continuous control monitoring*, yaitu pemeriksaan kontrol yang berjalan otomatis dan terus-menerus. Chiu, Liu, dan Vasarhelyi menelaah perkembangan penelitian audit otomatis yang berjalan mendekati waktu nyata [20]. Satu keputusan perlu diambil lebih dahulu: siapa pemilik pemantauan. Bila audit internal memiliki pemantauan harian atas AC-01, ia menjalankan tugas lini kedua dan menilai pekerjaannya sendiri [151]. Pada Medikara, lini pertama atau lini kedua memiliki pemantauan, sedangkan audit internal menguji mutu datanya.

12.11 Ringkasan

Asurans memberikan keyakinan berdasarkan kriteria dan bukti, dengan batas ruang lingkup, periode, populasi, dan metode yang jelas. Laporan 108 dari 108 akun dan cakupan 108 dari 120 akun dapat benar bersamaan, karena penyebutnya berbeda. Konsultasi dapat membantu perbaikan tanpa memindahkan tanggung jawab manajemen kepada auditor.

Three Lines Model membagi peran pengelolaan, dukungan dan tantangan, serta penilaian independen. Struktur pelaporan dinilai menurut mandat dan pengamannya, bukan dari jabatan atasan saja. Audit internal melapor secara fungsional kepada badan pengarah. Global Internal Audit Standards memberi kerangka mutu bagi fungsi audit dengan ukuran apa pun.

Rencana audit berangkat dari risiko, kewajiban, perubahan, dan asurans yang sudah ada. Pada contoh Medikara, kebutuhan 3.240 jam melebihi 2.880 jam terencana, sehingga dua area ditunda dan celah cakupannya dilaporkan kepada dewan komisaris. Skor membantu mengurutkan, tetapi waktu migrasi dan keselamatan pasien dapat mengubah urutannya.

Uji rancangan berbeda dari uji efektivitas operasi. Daftar yang hanya memuat 108 akun adalah kelemahan rancangan, sedangkan 12 dari 60 catatan adalah kelemahan operasi. Populasi ditetapkan sebelum sampel. Hasil 30 dari 30 akun sesuai masih menyisakan kemungkinan sampai 9 akun bermasalah, sehingga toleransi nol diuji pada seluruh 120 akun. Laporan pihak luar dipakai setelah tanggal, ruang lingkup, pengecualian, dan kontrol pelengkapnya dibaca.

Temuan yang lengkap menghubungkan kondisi dengan kriteria, sebab, akibat, dan rekomendasi, serta memisahkan fakta dari dugaan. Pesan utama bab ini adalah bahwa keyakinan lahir dari bukti yang dapat diulang orang lain, dan penutupan temuan memerlukan bukti perbaikan, bukan hanya pernyataan selesai.

12.12 Latihan

Latihan 1: Mandat dan Jalur Pelaporan

Unit manajemen risiko di sebuah rumah sakit melapor kepada direktur TI. Apa masalahnya menurut Three Lines Model, dan bagaimana memperbaikinya? Latihan ini membuktikan bahwa konflik dinilai dari mandat, akses, dan pengaman, bukan dari bagan organisasi saja.

1. Tentukan apakah mandat unit risiko hanya TI atau seluruh rumah sakit.
2. Hitung skenario risiko yang menyangkut sistem di bawah atasan unit itu.
3. Petakan siapa dapat membatasi laporan, ruang lingkup, dan eskalasi.
4. Usulkan pengaman tanpa menyamakan lini kedua dengan audit independen.

Misalkan rumah sakit memakai 12 skenario register Bab 5, dan 8 skenario menyangkut sistem di bawah direktur TI. Pada $8/12 = 66{,}7$ persen skenario, unit risiko menantang atasannya sendiri. Empat skenario lain, termasuk R-11, berada di luar kewenangan direktur TI. Medikara memakai sebutan kepala TI untuk jabatan serupa. Tabel 12.15 memberi contoh terisi, dan Tabel 12.16 adalah lembar isiannya.

Tabel 12.15: Contoh terisi Latihan 1 (misalkan)

Mandat	Masalah yang diperiksa	Bukti	Perbaikan
Hanya risiko TI	Tantangan terhadap keputusan direktur TI pada 8 skenario	Notulen tantangan yang ditolak	Akses eskalasi ke komite risiko, 4 rapat per tahun
Seluruh rumah sakit	4 skenario, termasuk R-11, di luar kewenangan atasan	Jalur laporan R-11 dan waktu tinjauannya	Pindahkan pelaporan ke direktur utama atau kepala risiko
Diminta menggantikan audit	Lini kedua dianggap independen	Piagam dan laporan ke komite audit	Audit internal tetap menguji lini kedua

Pertanyaan analisis.

Tabel 12.16: Lembar isian Latihan 1

Mandat	Masalah yang diperiksa	Bukti	Perbaikan
…	…	…	…
…	…	…	…
…	…	…	…

1. Pada contoh, 8 dari 12 skenario menyangkut sistem atasan unit. Berapa jumlah yang membuat pemindahan pelaporan lebih tepat daripada menambah akses eskalasi, dan mengapa?
2. Mengapa jabatan atasan saja belum cukup membuktikan pelanggaran model?
3. Data apa yang membuktikan pengaman benar-benar berjalan selama setahun?

Latihan 2: Rancangan dan Operasi AC-01

Jelaskan perbedaan uji rancangan dan uji efektivitas dengan contoh kontrol peninjauan hak akses. Latihan ini membuktikan bahwa kesimpulan harus cocok dengan jenis uji dan buktinya.

1. Tuliskan rancangan AC-01 dan penanggung jawabnya.
2. Tetapkan kriteria, populasi, dan tanggal acuan sebelum membuka data.
3. Periksa data `sources/chapter12/sampel-ac01-30-akun.csv` dan `sources/chapter12/data-contoh-hak-akses.csv`.
4. Bedakan kesimpulan tentang rancangan dan pelaksanaan, lalu tulis bukti tambahannya.

Tabel 12.17 memberi contoh terisi, dan Tabel 12.18 adalah lembar isiannya.

Pertanyaan analisis.

1. Mengapa kebijakan tidak membuktikan seluruh akun telah ditinjau?
2. Hasil turun dari 5 dari 7 menjadi 3 dari 7 bila batas 90 hari diganti 31 hari. Batas mana yang tepat bagi AC-01, dan siapa yang berwenang menetapkannya?
3. Bila 12 dari 60 catatan seluruhnya dari satu rumah sakit, apa yang dapat dan tidak dapat disimpulkan?

Tabel 12.17: Contoh terisi Latihan 2 (misalkan)

Uji	Bukti contoh	Hasil	Kesimpulan terbatas
Rancangan	Daftar peninjau dan daftar penugasan	108 dari 120 akun	Rancangan belum memastikan kelengkapan
Rancangan	Prosedur KB-03 dan pemisahan tugas	Empat tugas terpisah	Memadai di atas kertas; pelaksanaan diperiksa
Operasi	Catatan bulanan	12 dari 60 catatan	Terbukti pada 1 dari 5 rumah sakit
Operasi	Sampel 30 akun, 31 Maret 2026	24 sesuai, 6 menyimpang	Berlaku untuk satu lokasi, tidak diproyeksikan
Operasi	7 akun aktif, 30 Oktober 2026	5 dari 7 tepat waktu	2 akun terlambat pada satu tanggal

Tabel 12.18: Lembar isian Latihan 2

Uji	Bukti contoh	Hasil	Kesimpulan terbatas
…	…	…	…
…	…	…	…
…	…	…	…

Latihan 3: Temuan Vendor

Tulis satu temuan audit lengkap untuk kasus kebocoran data lewat vendor Medikara pada 2025. Latihan ini membuktikan bahwa temuan dapat ditelusuri ke bukti, dan bahwa fakta terpisah dari dugaan.

1. Pisahkan fakta dasar kasus dari data latihan dan dari dugaan. Fakta dasar hanya menyebut kebocoran skala kecil lewat vendor pada 2025. Angka kronologi mengikuti data latihan Bab 7.
2. Tulis kondisi, kriteria, sebab, akibat, dan rekomendasi.
3. Tetapkan bukti konfirmasi, pemilik tindakan, dan verifikasi penutupan.

Tabel 12.19 memberi contoh terisi, dan Tabel 12.20 adalah lembar isiannya.

Pertanyaan analisis.

1. Unsur mana yang belum boleh dinyatakan sebagai fakta, dan mengapa?
2. Sebanyak 620 rekam tinggal berupa jumlah. Apa akibatnya bagi pernyataan dampak pada temuan?
3. Bagaimana menilai perbaikan tanpa mengakses data pasien asli?

Tabel 12.19: Contoh terisi Latihan 3 (data latihan Bab 7)

Unsur	Contoh isian	Status	Bukti yang diperlukan
Kondisi	Akun dukungan aktif setelah kontrak selesai; selama 8 malam memanggil data dua rumah sakit, 155 panggilan per malam, 1.240 rekam	Data latihan	Catatan insiden tersanitasi dan rekap harian
Kriteria	K-01 pencegahan akses tidak sah; pencabutan 1 hari kerja; K-05 vendor melapor dalam 12 jam	Register	Register kewajiban, kontrak, AC-01
Sebab	Tanggal berakhir tidak masuk daftar; catatan aktivitas tidak ditinjau, 0 dari 260	Dugaan untuk insiden ini	Riwayat persetujuan dan tinjauan
Akibat	Diketahui hari ke-11 lewat keluhan pasien; 620 rekam terlacak, 620 tinggal jumlah	Data latihan	Kronologi dan hasil pelacakan
Rekomendasi	Cocokkan akun dengan daftar penugasan; tinjau catatan aktivitas; lengkapi 11 butir perjanjian	Usulan	Tiket, pemilik, tenggat
Verifikasi	120 dari 120 akun cocok; 247 dari 260 tinjauan; latihan laporan 12 jam	Belum diuji	Hasil uji ulang, tanpa data pasien asli

Tabel 12.20: Lembar isian Latihan 3

Unsur	Contoh isian	Status	Bukti yang diperlukan
Kondisi	...	...	...
Kriteria	...	...	...
Sebab	...	...	...
Akibat	...	...	...
Rekomendasi	...	...	...
Verifikasi	...	...	...

Bab 13

KPI, KRI, dan Pelaporan ke Direksi

Tujuan Pembelajaran

- Membedakan KPI, KRI, dan KCI, lalu memilih indikator yang memicu tindakan.
- Menetapkan ambang batas KRI yang selaras dengan *risk appetite*.
- Menyusun laporan GRC satu halaman yang dapat dipakai direksi untuk mengambil keputusan.

13.1 Pendahuluan

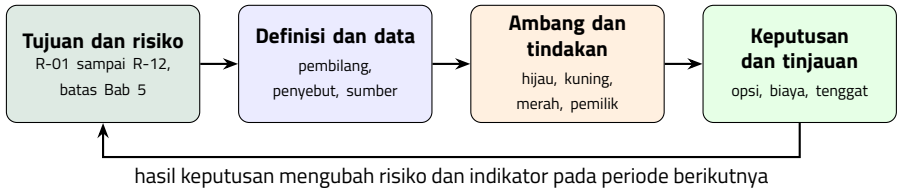
Misalkan direksi Medikara menerima laporan bulanan Teknologi Informasi (TI) setebal 40 halaman. Bila satu halaman dibaca 2 menit, satu pembaca memerlukan 80 menit. Laporan itu mencatat banyak kegiatan, tetapi tidak menjawab dua pertanyaan direksi: apakah risiko akses vendor membaik, dan keputusan apa yang diminta? Panjang laporan tidak menggantikan hubungan antara ukuran, tujuan, dan tindakan.

Bab 5 sudah menetapkan batas risiko Medikara. Bab 8 sampai Bab 12 sudah merancang target, kontrol, dan cara mengujinya. Bab ini mengubah semuanya menjadi sinyal yang dibaca secara berkala. Key Performance Indicator (KPI) mengukur pencapaian hasil. Key Risk Indicator (KRI) memberi sinyal perubahan paparan risiko. Key Control Indicator (KCI) mengukur pelaksanaan kontrol. Hasil kerja bab ini adalah katalog indikator, *dashboard*, dan laporan Governance, Risk, and Compliance (GRC) satu halaman untuk tonggak C4 capstone.

Bab ini memakai panduan pengukuran NIST SP 800-55 Volume 1 dari National Institute of Standards and Technology (NIST), makalah Committee of Sponsoring Organizations of the Treadway Commission (COSO) tentang KRI, dan Cybersecurity

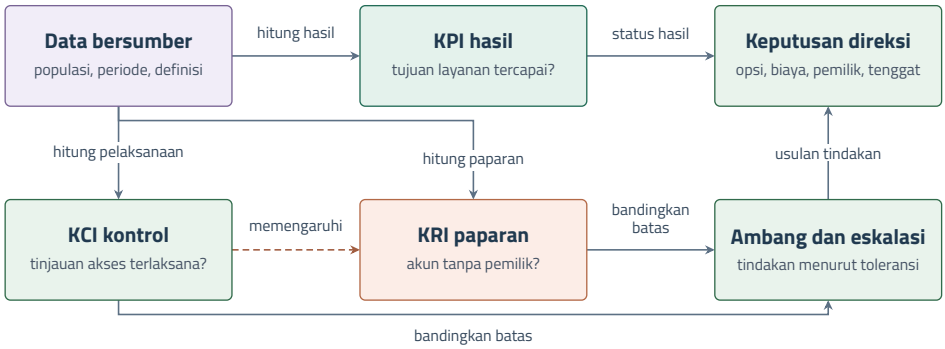
Framework (CSF) 2.0. Objektif Control Objectives for Information and Related Technologies (COBIT) 2019 hanya disinggung secara umum, karena naskah rinci-nya tidak dibaca langsung oleh bab ini. Ambang dan angka Medikara merupakan keputusan skenario, bukan angka wajib standar [145, 13, 104, 60].

Gambar 13.1 menunjukkan urutan kerja bab ini.



Gambar 13.1: Alur dari tujuan dan risiko sampai keputusan

Gambar 13.2 merangkum hubungan komponen dan konsep utama bab ini.



KCI tinjauan 95% dapat hijau sementara satu akun tanpa pemilik membuat KRI merah. Kedua status tidak dirata-ratakan.

Gambar 13.2: Indikator yang berbeda memicu keputusan yang berbeda

13.2 KPI, KRI, dan KCI

Tiga pertanyaan yang berbeda

KPI menjawab apakah tujuan tercapai. KRI menjawab apakah paparan mendekati atau melewati batas. KCI menjawab apakah kontrol dijalankan. COSO mengingatk-an bahwa laporan kinerja sering berfokus pada hasil yang sudah terjadi, sehingga belum tentu memberi peringatan dini. KRI dipakai untuk memberi sinyal awal ketika paparan risiko meningkat [13]. Bab 5 mencatat fungsi yang sama: ukuran seperti KRI menunjukkan bagian yang melewati toleransi atau yang masih berada di dalamnya [126].

Analogi kendaraan pengantar obat menunjukkan perbedaannya. Waktu tiba di apotek menunjukkan hasil. Suhu mesin menunjukkan potensi gangguan. Buku servis rutin menunjukkan pelaksanaan kontrol. Ketiganya membantu keputusan berbeda, dan tidak satu pun menggantikan yang lain.

Dua contoh pada Medikara:

1. Misalkan 12 acara pelatihan keamanan hanya menjangkau 30 dari 100 pegawai prioritas, atau 30 persen. Jumlah acara mengukur kegiatan. Cakupannya menunjukkan 70 pegawai belum terjangkau, dan itu pun belum membuktikan perilaku berubah.
2. Misalkan 114 dari 120 akun vendor ditinjau tepat waktu pada Oktober 2026. KCI-nya 95 persen dan berstatus hijau. Pada bulan yang sama, 1 akun aktif belum memiliki pemilik. KRI-nya merah menurut batas nol pada Bab 5.

Tabel 13.1 merangkum ketiga jenis indikator beserta keputusan yang dipicu.

Tabel 13.1: Jenis indikator Medikara, Oktober 2026 (misalkan)

Jenis	Pertanyaan	Ukuran contoh	Keputusan yang dipicu
KPI	Apakah hasil tercapai?	Waktu tunggu pendaftaran 28 menit, target 25 menit	Alur dan jadwal petugas diubah atau dipertahankan?
KRI	Apakah paparan mendekati batas?	1 akun vendor tanpa pemilik, batas 0 akun	Akun dibekukan atau diberi pengecualian darurat?
KCI	Apakah kontrol dijalankan?	114 dari 120 akun ditinjau tepat waktu	Daftar akun diperbaiki atau peninjau ditambah?

Dua hal pada indikator sering tertukar: KRI dan KCI. Pembagiannya begini. KCI mengukur pekerjaan organisasi. KRI mengukur keadaan yang dihadapi organisasi. Cakupan peninjauan dapat mencapai 100 persen, sementara peninjau tetap menemukan akun tanpa pemilik. Klasifikasi mengikuti pertanyaan, bukan nama datanya. Jumlah menit gangguan menjadi KRI bila dibandingkan dengan batas 2 jam per bulan pada Bab 5. Data yang sama menjadi KPI bila kepala operasi TI memakainya untuk menilai target waktu pulih.

Diagram konsep pada awal bab merangkum alurnya. Data bersumber memuat populasi, periode, dan definisi. Dari data itu lahir KPI hasil, KCI kontrol, dan KRI paparan. Nilai dibandingkan dengan batas pada ambang dan eskalasi, yaitu tindakan menurut toleransi. Status hasil dan usulan tindakan lalu masuk ke keputusan direksi, yang memuat opsi, biaya, pemilik, dan tenggat.

Pertanyaan kemudian muncul: mengapa diagram itu memuat panah dari KCI ke KRI? Bab 5 memberi angkanya. Pengandaian kasarnya: penurunan peluang R-01 sebanding dengan cakupan AC-01, dari 0,2 menuju 0,05. Hasilnya sebagai berikut:

1. Cakupan 85 persen menghasilkan peluang $0{,}2 - 0{,}15 \times 0{,}85 = 0{,}0725$, dengan harapan kerugian Rp36,25 juta dari kerugian rata-rata Rp500 juta.
2. Cakupan 90 persen menghasilkan peluang 0,065 dan harapan kerugian Rp32,5 juta, sama dengan Bab 5. Cakupan 95 persen menghasilkan 0,0575 dan Rp28,75 juta. Sasaran Rp25 juta baru tercapai pada cakupan penuh.

Hubungan itu pengandaian, bukan hukum sebab akibat. Selisih 5 persen cakupan terakhir, yaitu 6 akun, bernilai Rp3,75 juta per tahun. Angka kecil itu tidak meniadakan kewajiban nol akun tanpa pemilik, karena batas Bab 5 tidak ditetapkan dari harapan kerugian saja.

Kasus Medikara Health: Indikator Hijau, Risiko Merah

Misalkan kepala operasi TI melaporkan cakupan AC-01 naik dari 85 persen menjadi 95 persen dalam tiga bulan. Angka itu benar. Pemilik Medikara+ lalu membaca KRI pada halaman yang sama: 1 akun vendor aktif belum memiliki pemilik. Angka ini juga benar, dan statusnya merah.
Keputusan membaca dua status secara terpisah punya dua konsekuensi. Pertama, perbaikan cakupan tetap terlihat, sehingga kerja tim operasi tidak hilang dari laporan. Kedua, akun itu tetap divalidasi dalam 1 hari kerja lalu dibekukan, walaupun hanya 1 dari 120 akun, atau sekitar 0,8 persen. Warna hijau pada satu baris tidak membayar warna merah pada baris lain.

Indikator yang mendahului dan yang tertinggal

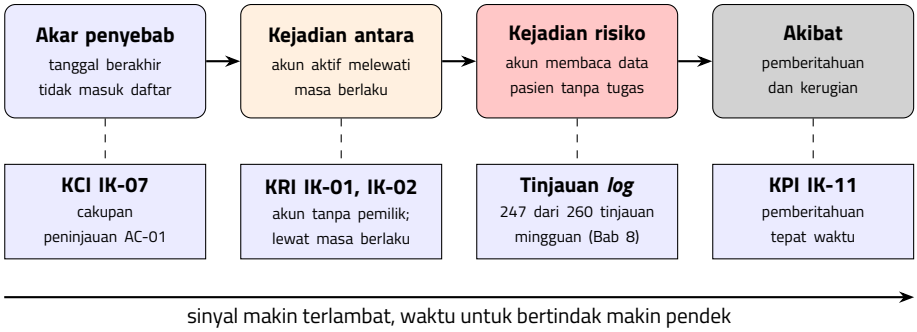
Indikator yang mendahului memberi peringatan sebelum kejadian. Indikator yang tertinggal menggambarkan hasil sesudah kejadian. COSO menyarankan penelusuran mundur: dari kejadian risiko ke kejadian antara, lalu ke akar penyebab. Data pada titik yang lebih awal berpotensi menjadi KRI yang mendahului [13]. Makin dini sinyalnya, makin panjang waktu untuk bertindak.

Analogi prakiraan banjir membantu. Tinggi air di bendungan hulu memberi waktu mengungsi. Jumlah rumah terendam hanya menghitung akibat. Keduanya berguna, tetapi hanya yang pertama dapat mencegah kerugian pada hari itu.

Gambar 13.3 menerapkan penelusuran itu pada R-01. Kode IK-01 sampai IK-12 adalah indikator bab ini, yang dirinci pada seksi metrik.

Dua contoh membedakan keduanya:

1. Bab 5 memberi contoh akun melewati masa berlaku naik dari 1 menjadi 5 dalam sebulan. Kenaikan itu memicu pemeriksaan sebelum insiden terulang. Indikator ini mendahului kejadian.
2. Ketepatan pemberitahuan hanya memiliki nilai bila ada insiden wajib. Mi-



Gambar 13.3: Rantai kejadian R-01 dan indikator pada tiap titik (misalkan)

salkan Agustus memuat 1 pemberitahuan yang tepat waktu, dan dua bulan berikutnya tidak ada. Indikator ini tertinggal. Ia tidak memberi peringatan, tetapi tetap perlu karena K-04 merupakan kewajiban.

Hubungan waktu tidak otomatis membuktikan sebab akibat. Misalkan akun lewat masa berlaku turun 2, 1, 0 dan akun tanpa pemilik turun 3, 2, 1. Tiga titik data belum membuktikan yang satu menyebabkan yang lain. COSO juga mengingatkan bahwa KRI tidak mengelola risiko, dan rancangan yang buruk dapat memberi rasa aman palsu. Kemampuan prediksi tiap KRI karena itu dinilai terus-menerus [13].

Balanced Scorecard dan keseimbangan ukuran

Kaplan dan Norton memperkenalkan Balanced Scorecard pada 1992. Alasannya, ukuran keuangan tradisional dapat memberi sinyal yang menyesatkan bagi perbaikan berkelanjutan dan inovasi [87]. Rumusan umumnya menyandingkan empat perspektif: keuangan, pelanggan, proses internal, serta inovasi dan pembelajaran. Teks utuh artikel tidak terbuka, sehingga daftar ini tidak dikutip dari artikel. Bab ini tidak memakainya sebagai sistem manajemen, melainkan sebagai pemeriksaan keseimbangan. Portofolio yang hanya berisi kontrol keamanan tidak menjawab apakah pasien terlayani.

Analogi rapor sekolah menjelaskan gunanya. Nilai ujian, kehadiran, dan catatan perilaku dibaca bersama. Nilai ujian tinggi dengan kehadiran 50 persen memberi pesan yang berbeda dari nilai yang sama dengan kehadiran penuh.

Dua contoh ketidakseimbangan:

1. Bab 2 mengandaikan investasi Rp8 miliar dengan kemajuan pekerjaan 90 persen, tetapi waktu tunggu hanya berubah dari 40 ke 38 menit. Capaian manfaatnya 2 dari 15 menit, atau 13,3 persen. Laporan proyek saja akan terlihat hijau.

2. Misalkan waktu tunggu Oktober 28 menit. Capaian manfaatnya naik menjadi $12 \div 15 = 80$ persen. Pada bulan yang sama, baru 1 dari 2 uji rumah sakit lulus. Layanan membaik, tetapi kesiapan pulihnya belum.

Tabel 13.2 memeriksa keseimbangan portofolio Medikara. Kata "pasien" menggantikan "pelanggan" karena sesuai dengan konteks layanan.

Tabel 13.2: Pemeriksaan keseimbangan portofolio Medikara, Oktober 2026 (misalkan)

Perspektif	Pertanyaan	Indikator	Nilai
Keuangan	Apakah peluang kerugian besar berada di dalam batas?	IK-04	1 skenario di atas batas 2 persen
Pasien	Apakah layanan lebih cepat dan tersedia?	IK-03, IK-12	100 menit gangguan; tunggu 28 menit
Proses internal	Apakah kontrol berjalan dan bekerja?	IK-07, IK-08	Cakupan 95 persen; 10 dari 12 uji lulus
Pembelajaran	Apakah temuan menghasilkan perbaikan yang teruji?	IK-10	9 dari 10 temuan tertutup

13.3 Merancang Indikator yang Baik

Kartu definisi

NIST membedakan penilaian dari pengukuran. Penilaian mengevaluasi atau menimbang terhadap kriteria. Pengukuran menghasilkan nilai kuantitatif. Metrik memakai hasil pengukuran untuk melacak kemajuan, membantu keputusan, dan memperbaiki kinerja terhadap sasaran. Metrik yang bermakna bersifat objektif, akurat, presisi, terikat pada titik waktu, dapat diulang, dan sebanding dengan pengukuran sebelumnya. Dokumentasinya mencatat pihak yang bertanggung jawab, sumber data, dan bentuk laporan [145]. Volume 2 melanjutkannya menjadi program pengukuran [146].

Analogi nilai kelas menunjukkan bahaya penyebut yang kabur. Nilai rata-rata 90 berbeda maknanya bila hanya menghitung siswa yang hadir, bukan seluruh peserta. Perubahan cara menghitung dapat memperbaiki angka tanpa mengubah kemampuan kelas.

Dua contoh tentang penyebut:

1. Bab 12 mencatat laporan unit TI berbunyi 108 dari 108 akun. Penyebut yang benar adalah 120 akun pada daftar penugasan, sehingga cakupannya $108/120 = 90$ persen. Selisih 12 akun tidak pernah ditinjau. Kedua angka benar, tetapi hanya satu yang menjawab pertanyaan direksi.

2. Misalkan sesudah perbaikan, pembilang diperketat menjadi akun yang ditinjau tepat waktu dalam bulan itu. Agustus menghasilkan $102/120 = 85$ persen, lebih rendah daripada 90 persen. Angka turun karena definisi menjadi lebih ketat, bukan karena kontrol memburuk. Perubahan definisi itu dicatat, dan tren lama tidak disambung tanpa catatan.

Tabel 13.3 memperlihatkan kartu definisi lengkap untuk satu indikator. Katalog contoh seluruh indikator ada di `sources/chapter13/katalog-indikator.csv`.

Tabel 13.3: Kartu definisi IK-07 Cakupan peninjauan AC-01 (misalkan)

Unsur	Isi
Pertanyaan	Apakah peninjauan akses vendor dijalankan tepat waktu pada seluruh akun?
Pembilang	Akun aktif yang ditinjau dalam bulan berjalan, dengan tanggal bukti
Penyebut	Semua akun aktif pada daftar penugasan: 120 akun pada 5 rumah sakit
Sumber	Daftar penugasan dan catatan peninjauan, bukan daftar dari sistem yang diperiksa
Frekuensi dan tanggal data	Bulanan; ekstrak pada hari kerja terakhir, versi disimpan
Pemilik informasi	Kepala operasi TI sebagai pemilik tindakan
Pengumpul dan penerima	Staf TI mengumpulkan; pemilik Medikara+ sebagai pemilik R-01 menerima
Ambang	Minimal 95 persen hijau; 90 sampai kurang dari 95 kuning; kurang dari 90 merah
Tindakan	Periksa kelengkapan daftar akun; koreksi kuning dalam 5 hari kerja; merah dieskalasi
Pemeriksa mutu	Audit internal mencocokkan sampel 30 akun (Bab 12)

Nol, kosong, dan tidak berlaku

Tiga keadaan pada data sering tertukar. Pembagiannya begini. Nol yang sah berarti data lengkap dan hasilnya nol. Tidak berlaku berarti penyebutnya nol karena kewajiban tidak muncul. Data tidak tersedia berarti data kosong atau ekstrak tidak lengkap. Tabel 13.4 memberi contohnya.

Pembagian ini punya dua konsekuensi yang dapat dihitung. Pertama, ketepatan pemberitahuan tiga bulan adalah 1 dari 1, bukan 3 dari 3. Menuliskan 100 persen untuk tiap bulan membuat dua bulan tanpa kejadian terlihat seperti dua bukti keberhasilan. Kedua, bila ekstrak Bogor gagal, laporan "nol akun tanpa pemilik" hanya mencakup 100 dari 120 akun, atau 83,3 persen. Sebaran 120 akun mengikuti Bab 12. Nol itu tidak dapat dibaca hijau.

Tabel 13.4: Tiga keadaan data pada *dashboard* (misalkan)

Keadaan	Contoh	Status
Nol yang sah	0 baris kewajiban lewat tenggat pada Oktober, register lengkap	Dinilai menurut ambang: hijau
Tidak berlaku	0 pemberitahuan wajib pada September, sehingga penyebut nol	Tidak berlaku; bukan 100 persen
Data tidak tersedia	Ekstrak akun Bogor gagal, sehingga 20 dari 120 akun tidak terbaca	Belum dapat dinilai; bukan hijau

Empat jenis ukuran menurut NIST

NIST memakai pembagian lain: ukuran implementasi, efektivitas, efisiensi, dan dampak [145]. Ukuran implementasi memperlihatkan kemajuan kontrol, biasanya dalam persentase, misalnya Multi-Factor Authentication (MFA) pada 108 dari 120 akun. Kontrol yang ada belum tentu bekerja. Ukuran efektivitas menilai seberapa baik kontrol bekerja, misalnya 29 dari 36 uji pemulihan lulus. Ukuran efisiensi melihat ketepatan waktu kontrol, misalnya akun dicabut paling lambat 1 hari kerja. Ukuran dampak menyatakan akibat bagi misi, misalnya harapan kerugian R-01 Rp28,75 juta, yang masih bergantung pada pengandaian Bab 5.

Dua pembagian itu menjawab hal berbeda. KPI, KRI, dan KCI menjelaskan pertanyaan yang dijawab. Jenis NIST menjelaskan apa yang diukur. NIST menyarankan urutan: sesudah ukuran implementasi tersedia, organisasi memprioritaskan ukuran lain berdasarkan strategi risiko, tujuan, ketersediaan data, nilai aset, biaya kontrol, dan kewajiban [145].

13.4 Ambang Batas dan Eskalasi

Menurunkan ambang dari batas Bab 5

Ambang menerjemahkan *risk appetite* menjadi tindakan. COSO menyebutnya titik pemicu: tingkat yang ditetapkan sebelumnya beserta rencana tindakan [13]. CSF mencatat hal yang berkaitan pada GV.RM-02: pernyataan *risk appetite* dan *risk tolerance* ditetapkan, dikomunikasikan, dan dipelihara [104]. Batas tidak tumpang tindih dan mencakup seluruh nilai yang valid. Pemilik, waktu tindakan, dan jalur eskalasi ditetapkan sebelum pengukuran. Merah tidak selalu berarti penghentian, karena respons mengikuti risiko dan kewenangan.

Analogi alarm tangki air menunjukkan perlunya waktu merespons. Peringatan muncul sebelum air habis. Alarm yang berbunyi setelah keran kering sudah terlambat memberi kesempatan bertindak.

Tabel 13.5 menurunkan KRI dari lima batas pada Bab 5. Ambang kuning

ditambahkan hanya bila ada ruang di dalam batas. Pada IK-03, ruang itu berasal dari Recovery Time Objective (RTO) Bab 10.

Tabel 13.5: Lima batas Bab 5 menjadi ambang KRI (misalkan)

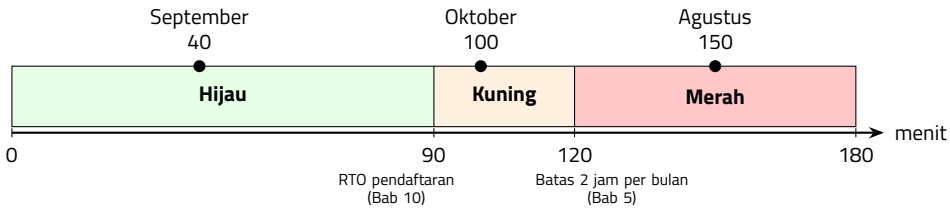
Batas Bab 5	KRI	Ambang	Tindakan
Kerahasiaan: nol akun vendor aktif tanpa pemilik dan masa berlaku	IK-01, IK-02	0 hijau; lebih dari 0 merah	Validasi 1 hari kerja, lalu bekukan
Kelangsungan: pendaftaran terganggu paling lama 2 jam per bulan	IK-03	Paling lama 90 menit hijau; lebih dari 90 sampai 120 kuning; lebih dari 120 merah	Pemilik layanan menyiapkan perbaikan; merah memicu tinjauan mingguan
Finansial: peluang kerugian Rp1,5 miliar atau lebih paling tinggi 2 persen per tahun per skenario	IK-04	0 skenario hijau; lebih dari 0 merah	Laporkan ke komite pengarah TI dan komite risiko
Kepatuhan: K-01 sampai K-16 berpemilik; nol baris lewat tenggat tanpa keputusan	IK-05	0 hijau; lebih dari 0 merah	Catat penyimpangan dan tindakan
Keselamatan: risiko cedera berat ditinjau dalam 1 hari kerja	IK-06	0 laporan terlambat hijau; lebih dari 0 merah	Libatkan pimpinan klinis segera

Dua contoh memperlihatkan penurunannya:

1. IK-03 memakai dua angka lama. Batas Bab 5 adalah 120 menit per bulan. RTO pendaftaran Bab 10 adalah 90 menit, sehingga satu kejadian yang memenuhi target masih menyisakan 30 menit. Misalkan Agustus 150 menit, September 40 menit, dan Oktober 100 menit. Bab 5 menghitung 2 jam gangguan menyentuh sekitar 548 kunjungan, sehingga 150 menit menyentuh sekitar 685 kunjungan dan 100 menit sekitar 457 kunjungan.
2. IK-04 memakai perkalian pada Bab 5 dan Bab 8. Peluang R-01 dikali 0,2 menghasilkan 1,45, 1,3, dan 1,15 persen pada tiga bulan, semuanya di dalam batas 2 persen. R-05 tetap dicatat 0,1 selama syarat opsi B pada Bab 10 belum terpenuhi, sehingga peluang kerugian Rp1,5 miliar atau lebih 10 persen. Nilai IK-04 karena itu 1 skenario pada ketiga bulan.

Gambar 13.4 memperlihatkan ketiga bulan IK-03 pada zona ambangnya.

Toleransi nol punya dua konsekuensi. Pertama, tren membaik tidak mengubah warna. Akun tanpa pemilik 3, 2, 1 tetap merah sampai nol. Zona kuning buatan



Gambar 13.4: Zona ambang IK-03 dari RTO Bab 10 dan batas Bab 5 (misalkan)

akan melunakkan batas yang sudah disahkan direksi. Kedua, peringatan dini berpindah ke indikator lain. IK-02 dan IK-07 memberi waktu sebelum akun kehilangan pemilik. Pengecualian darurat Bab 5 ditulis tegas dalam definisi: akun dengan pengecualian yang sah dicatat terpisah selama belum 24 jam. Sesudah itu, akun masuk hitungan IK-01.

Periode waktu juga memengaruhi tafsir. Rata-rata tiga bulan IK-03 adalah $290 \div 3 \approx 96{,}7$ menit, dan berada pada zona kuning. Rata-rata itu menyembunyikan pelanggaran 150 menit pada Agustus. Karena batas Bab 5 berbunyi per bulan, status dibaca per bulan. Jumlah tahunan dibandingkan dengan 24 jam, atau 1.440 menit, sebagai pembacaan tambahan.

Aturan tepi dan populasi kecil

Pertanyaan berikutnya: bagaimana bila nilai tepat berada pada batas? Aturan tepi ditulis sejak awal. Nilai 95 persen termasuk hijau, 90 persen termasuk kuning, dan 120 menit termasuk kuning. Status memakai nilai sebelum pembulatan, karena pembulatan dapat memindahkan warna. Pada IK-07, satu akun bernilai sekitar 0,83 persen.

Dua contoh menunjukkan akibatnya:

1. Misalkan cakupan turun dari 115 menjadi 113 akun. Nilainya turun dari 95,83 menjadi 94,17 persen, sehingga status berubah menjadi kuning. Koreksi 5 hari kerja berjalan ketika jarak ke merah masih 6 akun, karena merah dimulai pada 107 akun.
2. Pada populasi kecil, satu butir mengubah banyak persen. Medikara memiliki 5 penilaian dampak pelindungan data, atau Data Protection Impact Assessment (DPIA), pada Bab 7, sehingga satu butir bernilai 20 persen. Ambang kuning 90 persen tidak dapat dicapai tanpa menjadi hijau. Ambang kuning karena itu ditulis 80 persen.

Ambang juga diuji pada data lalu sebelum dipakai. Misalkan kuning IK-03 dimulai pada 30 menit. Ketiga bulan tidak ada yang hijau, sehingga sinyal berbunyi setiap bulan dan cepat diabaikan. Dengan ambang 90 menit, tiga bulan itu

menghasilkan satu hijau, satu kuning, dan satu merah. Tiga titik belum cukup untuk menyimpulkan ambang tepat, tetapi cukup untuk menolak ambang yang selalu berbunyi.

Jalur eskalasi

Eskalasi menjawab siapa yang harus bertindak ketika ambang terlewati, dan kapan. COSO mencatat bahwa direksi tidak perlu mengetahui seluruh KRI, tetapi perlu mengikuti KRI untuk paparan risiko teratas. Laporan pengecualian dapat dibuat berkala, dengan waktu yang berbeda menurut tingkat penerimanya [13]. Tabel 13.6 memakai batas delegasi Bab 2, sehingga jalur indikator tidak membuat wewenang baru.

Tabel 13.6: Jalur eskalasi indikator Medikara (misalkan)

Tingkat	Pemicu	Waktu
Pemilik tindakan	Nilai kuning atau merah	Merah 1 hari kerja; kuning 5 hari kerja
Pemilik risiko	Merah belum tertutup; butuh pengecualian	Hari kerja berikutnya; pengecualian paling lama 24 jam
Kepala TI	Perbaikan butuh biaya sampai Rp100 juta	Ringkasan triwulan ke komite
Komite pengarah TI	Biaya di atas Rp100 juta sampai Rp400 juta; merah dua bulan berturut-turut	Rapat bulanan
Direksi	Biaya di atas Rp400 juta sampai Rp5 miliar; penerimaan risiko di atas batas	Laporan triwulan, atau segera bila pemicu krisis organisasi terpenuhi
Dewan komisaris	Di atas Rp5 miliar, bila anggaran dasar menetapkan	Laporan triwulan

Dua jalur memerlukan pengecualian dari urutan itu. IK-06 langsung melibatkan pimpinan klinis, tanpa menunggu tingkat di bawahnya. Pemberitahuan pada K-04 mengikuti jam insiden pada Bab 7, bukan jadwal rapat. Jalur umum tidak boleh memperlambat kewajiban yang punya tenggat sendiri.

Kasus Medikara Health: Satu Akun pada Oktober

Misalkan ekstrak Oktober menemukan 1 akun vendor tanpa pemilik. Kepala operasi TI memvalidasinya dalam 1 hari kerja. Akun itu milik teknisi pada penugasan yang sudah dipindahkan ke unit lain. Pemilik Medikara+ memilih membekukan akun, dan menolak pengecualian 24 jam karena tidak ada pekerjaan darurat.

Keputusan ini punya dua konsekuensi. Pertama, teknisi yang masih bertugas perlu meminta akun baru melalui penugasan yang benar, sehingga pekerjaannya tertunda 1 hari kerja. Kedua, IK-01 tetap merah pada laporan Oktober, walaupun akun sudah dibekukan. Nilai yang dilaporkan adalah keadaan pada tanggal data. Status dapat menjadi hijau pada periode berikutnya bila ekstrak lengkap dan hasilnya nol. Rekonsiliasi lanjutan sampai Rp60 juta berada di bawah batas Rp100 juta, sehingga kepala TI yang memutuskan.

13.5 Metrik Tata Kelola, Keamanan, dan Privasi

Portofolio dua belas indikator

Portofolio indikator mencakup tata kelola, risiko, keamanan, privasi, dan kelangsungan layanan. Ukuran dipilih dari pertanyaan direksi, bukan dari data yang mudah dikumpulkan. NIST mengingatkan kecenderungan memakai semua data yang tersedia. Metrik yang salah pilih merusak mutu laporan dan kepercayaan pada hasil kerja. Ujinya: apakah data itu langsung menggambarkan kinerja kontrol yang sah, atau melacak risiko yang material? Bila tidak, data itu sebaiknya dikeluarkan. Pada tahap awal, lebih sedikit sering lebih baik [145].

Analogi pemeriksaan kesehatan rutin menjelaskan pilihan itu. Dokter membaca tekanan darah, gula darah, dan kolesterol, bukan seluruh angka yang dapat dihasilkan laboratorium. Tiap angka memiliki batas dan tindak lanjut. Angka tanpa tindak lanjut hanya menambah kecemasan.

Dua contoh tentang angka yang perlu dilengkapi:

1. Bab 10 mencatat 29 dari 36 uji pemulihan lulus, atau 80,6 persen. Pada 5 rumah sakit yang menjalankan Sistem Informasi Manajemen Rumah Sakit (SIMRS), hanya 3 yang lulus, atau 60 persen. Dua kegagalan data seluruhnya berasal dari 9 uji akun terpisah. Angka gabungan perlu dilengkapi identitas layanan yang gagal, karena dampaknya tidak setara.
2. Bab 9 mencatat 5 hubungan vendor tingkat terperinci. Misalkan 4 dari 5 sudah dinilai ulang, atau 80 persen. Hubungan yang belum dinilai dilaporkan beserta akses datanya. Bila hubungan itu V-01 dengan skor 9, angka 80 persen menyembunyikan vendor yang paling berisiko.

Tabel 13.7 memuat portofolio contoh. Kolom pemilik menyebut pemilik tindakan. Pemilik risiko tetap mengikuti register Bab 5, sehingga keduanya dipisahkan seperti pada Bab 6. Ambang keenam KRI mengikuti Tabel 13.5, dan rincian lainnya ada di katalog.

Tabel 13.7: Portofolio dua belas indikator Medikara (misalkan)

Kode	Indikator	Jenis	Pemilik tindakan	Kaitan
IK-01	Akun vendor aktif tanpa pemilik atau masa berlaku	KRI	Kepala operasi TI	R-01, AC-01
IK-02	Akun melewati masa berlaku	KRI	Kepala operasi TI	R-01, AC-01
IK-03	Menit gangguan pendaftaran	KRI	Kepala operasi TI	R-03, R-05
IK-04	Skenario melewati batas peluang kerugian	KRI	Kepala risiko	R-01, R-05
IK-05	Baris kewajiban lewat tenggat tanpa keputusan	KRI	Fungsi kepatuhan	K-01 sampai K-16
IK-06	Risiko cedera berat lewat tinjauan 1 hari kerja	KRI	Pimpinan klinis	R-11
IK-07	Cakupan peninjauan AC-01	KCI	Kepala operasi TI	R-01, AC-01
IK-08	Uji pemulihan lulus, gabungan dan rumah sakit	KCI	Kepala operasi TI	R-05, K-02
IK-09	DPIA selesai	KCI	Petugas pelindungan data	5 DPIA Bab 7
IK-10	Temuan tertutup tepat waktu sesudah uji ulang	KPI	Pemilik tiap temuan	TA-01 dan lainnya
IK-11	Pemberitahuan tepat waktu	KPI	Petugas pelindungan data	R-12, K-04
IK-12	Waktu tunggu pendaftaran 18 klinik	KPI	Kepala pendaftaran	Target Bab 1 dan Bab 2

COBIT dan CSF memberi bahasa pengawasan untuk portofolio itu. Dalam susunan COBIT 2019, MEA01 menangani pemantauan kinerja dan kesesuaian oleh manajemen, sedangkan EDM05 menangani keterlibatan pemangku kepentingan [60]. Uraian ini umum, dan perlu dicocokkan ke naskah ISACA sebelum dipakai untuk audit. CSF memiliki GV.OV-03: kinerja pengelolaan risiko keamanan siber dievaluasi dan ditinjau untuk penyesuaian yang diperlukan [104]. Bab 8 menargetkan GV.RM-02 terbukti lewat batas yang diuji dengan satu penyimpangan. Akun Oktober dapat menjadi bukti ujinya. Skor buatan organisasi tidak menjadi sertifikasi NIST.

Portofolio juga berarti ada yang dikeluarkan. Keputusan ini punya dua konsekuensi. Pertama, "perubahan disetujui" dan "hubungan vendor dinilai" tetap dipantau, tetapi pada tingkat forum. Kedua, privasi di tingkat direksi hanya terwakili IK-09 dan IK-11. Sesudah 5 DPIA selesai, IK-09 kehilangan daya beda, dan penggantinya dibahas pada tinjauan tahunan. COSO juga mengingatkan bahwa

KRI kehilangan nilai ketika tujuan dan strategi berubah [13].

Mengolah bahan dari Bab 8 sampai Bab 12

Bab-bab sebelumnya sudah menghasilkan banyak angka. Pertanyaan kemudian muncul: angka mana yang naik ke direksi? Tabel 13.8 memilahnya menurut tingkat pembaca. Bab 9 menyerahkan enam indikator hubungan terperinci, dan seluruhnya tercatat di sini. Hanya satu yang langsung masuk portofolio.

Tabel 13.8: Bahan indikator dari Bab 8 sampai Bab 12 (misalkan)

Asal	Bahan	Diolah menjadi	Pembaca
Bab 8	T-19: 247 dari 260 tinjauan *log* mingguan, atau 95 persen	KCI jejak aktivitas	Komite pengarah TI
Bab 9	Akun vendor tanpa pemilik, 0 akun	IK-01	Direksi bila merah
Bab 9	Catatan AC-01, 60 dari 60 per tahun atau 5 per bulan	Rincian IK-07	Pemilik risiko
Bab 9	Laporan dugaan insiden vendor 12 jam, K-05	Masuk IK-05 bila lewat tenggat tanpa keputusan	Komite risiko
Bab 9	Latihan bersama 2 per tahun; subprosesor 30 hari; uji ekspor 1 per tahun	Kalender kontrol: selesai atau belum	Pengelola vendor
Bab 10	RTO 90 menit; 29 dari 36 uji; 3 dari 5 rumah sakit	IK-03, IK-08	Direksi
Bab 11	27 dari 30 kasus darurat tertangkap; 93 dari 120 tanda klinik keliru; AI-03 selisih 8, ambang 5	KCI mutu kecerdasan artifisial (AI); jalur penyebab R-11 pada IK-06, tanpa kode baru	Komite risiko
Bab 12	TA-01; 24 dari 30 akun sesuai; kriteria 30 dari 30	IK-10; pemeriksa mutu IK-07	Direksi bila lewat tenggat

Kasus Medikara Health: Dari 46 Usulan menjadi 12 Indikator

Misalkan tiap unit mengusulkan ukuran kesayangannya, dan terkumpul 46 usulan. Kepala risiko memakai tiga pertanyaan: keputusan apa yang dipicu, batas mana yang dipakai, dan siapa pemiliknya. Sebanyak 19 usulan gugur karena tidak memicu keputusan, misalnya jumlah tiket yang dibuka. Sebanyak 15 usulan tetap dipantau di tingkat operasional. Sisanya 12 indikator.

Pilihan ini punya biaya. Unit yang ukurannya keluar merasa pekerjaannya tidak terlihat. COSO mencatat bahwa pakar di unit dapat cenderung memilih metrik yang sudah biasa dipakai [13]. Kepala risiko karena itu mencatat

alasan setiap penolakan, dan membuka tinjauan ulang setiap tahun.

Metrik platform dan SLO

Ukuran layanan dari IT40713 dan nilai platform dari IT40613 menjadi masukan risiko. Service Level Objective (SLO) adalah sasaran tingkat layanan. SLO berbeda dari batas hukum dan *risk appetite*, dan rinciannya dibahas pada kedua mata kuliah itu. Bab 9 memberi contoh: layanan pesan tersedia 99,5 persen dari 8.760 jam, atau terganggu 43,8 jam per tahun. Batas pendaftaran Bab 5 adalah 24 jam dari 4.380 jam layanan. Dasar hitungnya berbeda, sehingga kedua angka tidak digabung menjadi satu persentase ketersediaan.

13.6 Mutu Data dan Risiko Manipulasi

Sumber data dan mutu data

Indikator hanya sebaik datanya. NIST meminta cara pengumpulan dan tempat penyimpanan data didefinisikan dengan jelas. Validitas data patut diragukan bila sumber utamanya hanya menyimpan laporan dari sebagian unit, atau proses pelaporan antarunit tidak konsisten. Pemeriksaan integritas, akurasi, dan struktur dijalankan sebelum analisis [145]. COSO menambahkan bahwa tanpa keseragaman cara ukur, data gabungan kehilangan kekuatan dan menambah gangguan pada keputusan [13].

Analogi timbangan pasar membantu. Harga per kilogram antarkios tidak dapat dibandingkan bila timbangannya berbeda. Tera ulang menjadi syarat perbandingan, sebelum ada yang berdebat soal harga.

Sektor lain sudah merasakan akibatnya. Basel Committee on Banking Supervision mencatat bahwa krisis keuangan sejak 2007 memperlihatkan banyak bank tidak mampu menggabungkan paparan risiko secara penuh, cepat, dan akurat, lalu menerbitkan prinsip agregasi data dan pelaporan risiko [12]. Prinsip itu tidak mengikat Medikara, tetapi pelajarannya tetap berlaku.

Dua contoh pada Medikara:

1. Bab 8 mengandaikan laporan 18 klinik tidak konsisten karena definisi indikator berbeda. Dengan 2 jam rekonsiliasi per klinik per bulan, pekerjaannya 432 jam per tahun, atau Rp25,92 juta. IK-12 menuntut satu definisi: kapan tunggu dimulai dan kapan selesai.
2. Register Bab 5 memuat R-04, versi spreadsheet yang berbeda menghasilkan angka salah. Peluangnya 0,5 dan kerugiannya Rp60 juta, sehingga

harapan kerugiannya Rp30 juta per tahun. Spreadsheet boleh dipakai untuk *dashboard* awal, asalkan versi dan sumbernya tercatat.

Tabel 13.9 menempatkan pemeriksaan mutu pada lima sumber data. Pemeriksa tidak berasal dari pihak yang menghasilkan angka, mengikuti temuan Bab 12 bahwa daftar tidak boleh diambil dari sistem yang diperiksa.

Tabel 13.9: Sumber data dan pemeriksaan mutu (misalkan)

Indikator	Sumber	Pemeriksaan	Pemeriksa
IK-01, IK-07	Daftar penugasan dan inventaris identitas	Jumlah 120 cocok; 5 rumah sakit terbaca	Audit internal, sampel
IK-03	Catatan gangguan	Dicocokkan dengan laporan loket pendaftaran	Kepala pendaftaran
IK-08	Catatan uji pemulihan	Rumah sakit dan fasilitas lain dipisah; hasil disahkan	Pemilik layanan
IK-10	Sistem pelacakan temuan	Hanya status sesudah uji ulang yang dihitung	Audit internal
IK-12	Catatan antrean 18 klinik	Definisi mulai dan selesai sama; klinik kosong ditandai	Fungsi data klinik

Indikator yang dimanipulasi

Indikator dengan target mengubah perilaku orang yang diukur. Bevan dan Hood menelaah tata kelola lewat target pada layanan kesehatan publik Inggris. Mereka berpendapat bahwa cara itu mengandaikan bagian dapat mewakili keseluruhan, serta mengandaikan masalah pengukuran dan *gaming* tidak penting. Bukti dari layanan kesehatan dipakai untuk menguji kedua pengandaian itu [15]. *Gaming* di sini berarti pengubahan perilaku atau catatan supaya angka terlihat baik, tanpa perbaikan yang setara.

Analogi kasir warung menjelaskan mekanismenya. Bila kasir dinilai dari jumlah struk, satu belanjaan dapat dipecah menjadi tiga struk. Angkanya naik, dan penjualan tidak berubah. Kasir itu tidak perlu berniat jahat, karena ukuran sudah mendorongnya ke sana.

Dua contoh dengan angka:

1. Misalkan gangguan pendaftaran 125 menit memuat 40 menit yang dicatat sebagai pemeliharaan. Nilainya turun menjadi 85 menit, dan status merah berubah menjadi hijau. Pasien tetap mengantre 125 menit. Definisi IK-03 karena itu mengukur akibat pada pendaftaran, bukan sebab gangguan.

2. Misalkan 10 temuan dilaporkan selesai menurut manajemen, tetapi hanya 9 yang lolos uji ulang. Bila status pertama dihitung, IK-10 menjadi 100 persen. Bila status kedua dihitung, nilainya 90 persen. Bab 12 sudah memisahkan keduanya, dan TA-01 berada pada baris yang belum tertutup.

Tabel 13.10 merangkum bentuk yang sering muncul. Daftar ini disusun bab ini sebagai alat bantu, bukan rangkuman artikel Bevan dan Hood.

Tabel 13.10: Bentuk manipulasi indikator dan pengamannya

Bentuk	Contoh	Pengaman
Mengecilkan penyebut	12 akun keluar dari daftar, 90 menjadi 100 persen	Populasi dari daftar penugasan; jumlah dicocokkan
Memindahkan kategori	Insiden wajib dicatat tidak wajib, IK-11 menjadi tidak berlaku	Alasan klasifikasi ditinjau fungsi hukum
Menutup di atas kertas	Temuan selesai menurut manajemen dihitung tertutup	Hitung sesudah uji ulang
Mengejar batas	Peninjauan tergesa pada akhir bulan supaya tepat 95 persen	Sampel mutu; catatan per akun
Mengubah definisi	Tepat waktu digeser dari 30 menjadi 45 hari	Riwayat definisi; tren tidak disambung

Pilihan pengaman punya *tradeoff*. Pemeriksaan sampel menambah kerja, tetapi Bab 12 sudah menyediakan kapasitas audit 1.800 jam per tahun, sehingga pemeriksaan mutu masuk rencana itu. Mengaitkan indikator dengan bonus memperkuat perhatian, tetapi juga memperkuat dorongan untuk memanipulasi. Pada Medikara, KRI dengan toleransi nol tidak dikaitkan dengan bonus. Unit yang jujur melaporkan 1 akun tanpa pemilik tidak boleh dirugikan dibanding unit yang tidak memeriksanya.

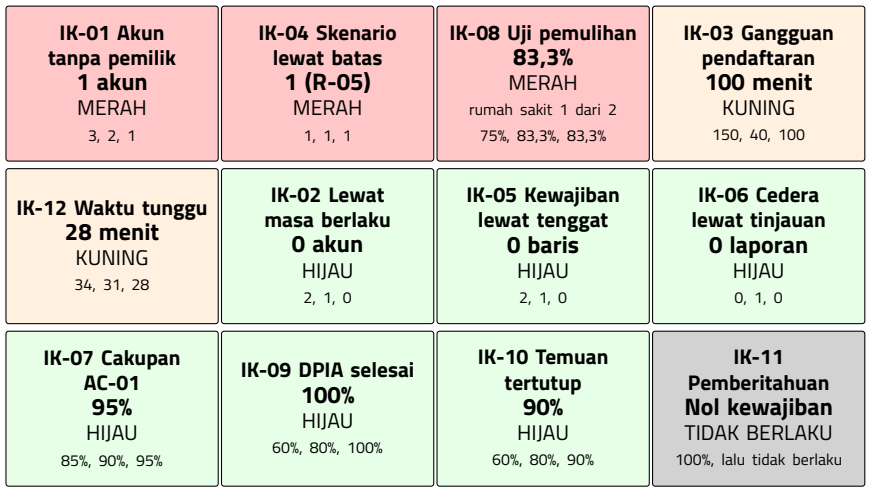
13.7 Dashboard dan Prinsip Visualisasi

Few mendefinisikan *dashboard* sebagai tampilan visual dari informasi terpenting untuk mencapai tujuan tertentu, disatukan dalam satu layar sehingga dapat dipantau sekilas. Isinya terutama ringkasan tingkat tinggi beserta pengecualian. *Dashboard* memberi tahu apa yang terjadi, bukan mengapa [40]. COSO mencatat warna hijau, kuning, dan merah lazim dipakai untuk menandai status KRI pada laporan direksi [13]. Warna disertai angka dan label, supaya status tetap terbaca pada cetakan hitam putih.

Analogi papan keberangkatan stasiun menjelaskan perannya. Papan itu menyebut kereta, jam, dan status terlambat. Penumpang dapat segera memutuskan. Alasan keterlambatan dicari di tempat lain, dan papan tidak mencoba memuatnya.

Bab ini memakai prinsip sederhana yang disusun dari rujukan di atas, bukan daftar resmi. Satu halaman cukup, dan rincian disimpan di katalog. Pengecualian ditaruh lebih dahulu. Warna selalu disertai angka dan kata status. Tiga nilai terakhir terlihat. Tanggal data ditulis, dan perubahan definisi diberi catatan. Tidak ada hiasan, jarum, atau rata-rata warna.

Gambar 13.5 memperlihatkan *dashboard* Oktober. Baris terkecil pada tiap petak adalah nilai Agustus, September, dan Oktober. Tabel 13.11 menyajikan angka yang sama secara lengkap, dan hasilnya dapat dicek ulang di `sources/chapter13/dashboard-contoh.csv`.



Gambar 13.5: *Dashboard* GRC Medikara, Oktober 2026 (misalkan)

IK-08 memakai status terburuk dari dua rasio, dengan ambang yang sama: 100 persen hijau, 75 sampai kurang dari 100 persen kuning, dan kurang dari 75 persen merah. Pada Oktober, 83,33 persen berstatus kuning, tetapi rumah sakit 1 dari 2 atau 50 persen berstatus merah. Pembacaan ini mengikuti peringatan Bab 10: gabungan menyamarkan layanan dengan batas gangguan terpendek. Dua belas uji per bulan membentuk 36 uji triwulan, dengan 29 lulus, sama dengan Bab 10.

Pertanyaan kemudian muncul: bolehkah semua warna dirangkum menjadi satu skor? Dua contoh menjawabnya:

1. Misalkan hijau bernilai 100, kuning 50, merah 0, dan tidak berlaku dikeluarkan. Skor gabungannya 16,7 pada Agustus, 27,3 pada September, dan $700 \div 11 \approx 63{,}6$ pada Oktober. Skor naik hampir empat kali lipat, sementara IK-01 dan IK-04 merah pada ketiga bulan. Oktober bahkan memuat kegagalan uji rumah sakit.
2. Cakupan AC-01 hijau dan akun tanpa pemilik merah tidak dirata-ratakan menjadi kuning. Rata-rata itu tidak berarti apa-apa bagi pemilik Medikara+,

Tabel 13.11: Tren dua belas indikator, Agustus sampai Oktober 2026 (misalkan)

Indikator	Agustus	September	Oktober
IK-01 Akun tanpa pemilik	3, merah	2, merah	1, merah
IK-02 Lewat masa berlaku	2, merah	1, merah	0, hijau
IK-03 Gangguan pendaftaran	150 menit, merah	40 menit, hijau	100 menit, kuning
IK-04 Skenario lewat batas	1, merah	1, merah	1, merah
IK-05 Kewajiban lewat tenggat	2, merah	1, merah	0, hijau
IK-06 Cedera lewat tinjauan	0, hijau	1, merah	0, hijau
IK-07 Cakupan AC-01	102/120 = 85%, merah	108/120 = 90%, kuning	114/120 = 95%, hijau
IK-08 Uji pemulihan	9/12 = 75%; rumah sakit 1/2, merah	10/12 = 83,33%; rumah sakit 1/1, kuning	10/12 = 83,33%; rumah sakit 1/2, merah
IK-09 DPIA selesai	3/5 = 60%, merah	4/5 = 80%, kuning	5/5 = 100%, hijau
IK-10 Temuan tertutup	6/10 = 60%, merah	8/10 = 80%, kuning	9/10 = 90%, hijau
IK-11 Pemberitahuan	1/1 = 100%, hijau	Tidak berlaku	Tidak berlaku
IK-12 Waktu tunggu	34 menit, merah	31 menit, merah	28 menit, kuning

karena tidak menunjukkan akun mana yang dibekukan.

Bab 5 sudah membahas keterbatasan kategori pada matriks risiko, termasuk resolusi yang buruk [24]. Skor gabungan warna mewarisi masalah yang sama. Keputusan menolak skor gabungan punya konsekuensi: laporan bertambah satu baris untuk tiap pengecualian, dan pimpinan tidak mendapat satu angka yang mudah diingat. Harga itu diterima, karena pesan yang hilang justru pesan yang dibutuhkan.

13.8 Laporan Satu Halaman ke Direksi

Struktur laporan

Laporan menghubungkan tiga pesan utama dengan satu keputusan. NIST mengingatkan bahwa ukuran yang dilaporkan tanpa konteks dapat menimbulkan akibat yang tidak diinginkan atau keraguan. Laporan karena itu dapat memuat risiko

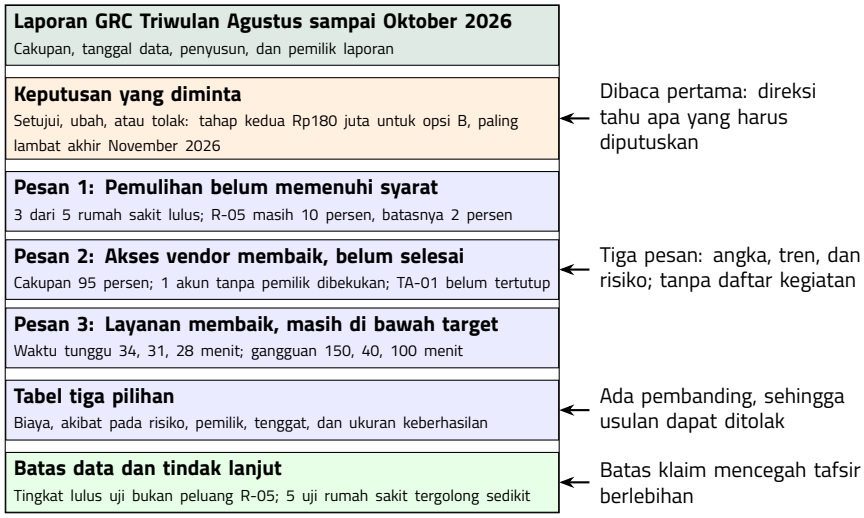
yang ditunjukkan ukuran, kesesuaiannya dengan *risk appetite*, tindakan atau keputusan yang diperlukan, masalah kepatuhan, dan dampaknya pada kesiapan audit [145]. COSO menambahkan bahwa frekuensi mengikuti pembacanya. Pengelola operasi cocok dengan laporan seketika, manajemen senior dengan laporan yang lebih jarang, dan direksi dengan laporan yang lebih agregat [13]. Pada Medikara, *dashboard* dibahas bulanan pada komite pengarah TI, dan laporan satu halaman terbit triwulanan sesuai 4 laporan pada Bab 2.

Analogi ringkasan rapat membedakan informasi dan keputusan. Daftar kejadian menjelaskan masa lalu. Usulan dengan pemilik, anggaran, tenggat, dan risiko sisa memberi dasar bertindak.

Dua contoh tentang isi laporan:

1. Misalkan laporan menyebut 7 kegiatan selesai. Direksi belum mengetahui dampak, pengecualian, dan keputusan yang diperlukan. Membaca 7 baris itu pun tidak mengubah apa pun.
2. Misalkan laporan meminta direksi menyetujui Rp60 juta untuk rekonsiliasi akun. Permintaan itu salah alamat. Bab 2 menempatkan biaya sampai Rp100 juta pada kepala TI, sehingga cukup dilaporkan. Waktu direksi dipakai untuk Rp180 juta tahap kedua opsi B, karena keputusan bersyarat itu milik direksi pada Bab 10.

Gambar 13.6 memperlihatkan susunan satu halaman. Keputusan ditaruh di atas, karena itu hal pertama yang perlu diketahui pembaca.



Gambar 13.6: Susunan laporan GRC satu halaman (misalkan)

Laporan Medikara: triwulan Agustus sampai Oktober 2026

Hubungan antarangka berjalan seperti ini. IK-08 memperlihatkan 3 dari 5 rumah sakit lulus. Dua kegagalan data berasal dari 9 uji akun terpisah. Kedua syarat Bab 10 belum terpenuhi. Peluang R-05 tetap dicatat 0,1, sehingga IK-04 merah. Tingkat lulus uji bukan peluang R-05, sehingga angka 80,6 persen tidak dibaca sebagai peluang apa pun. Tabel 13.12 menyusun pilihannya.

Tabel 13.12: Tiga pilihan untuk tahap kedua opsi B (misalkan)

Pilihan	Biaya	Akibat pada R-05	Risiko pilihan
1. Tahan tahap kedua; uji ulang 2 rumah sakit dan 9 uji akun terpisah	Rp0 tambahan saat ini	Peluang tetap 0,1; harapan kerugian sekitar Rp40 juta lebih tinggi per triwulan	Direksi menerima tertulis paparan di atas batas selama satu triwulan
2. Cairkan Rp180 juta sekarang	Rp180 juta	Peluang tetap dicatat 0,1 sampai uji lulus	Syarat direksi hilang; uang keluar sebelum bukti
3. Hentikan opsi B, kembali ke opsi A	Hemat Rp180 juta	SIMRS pulih 480 menit; batas 2 persen dilanggar	Sudah ditolak pada Bab 10

Kasus Medikara Health: Laporan yang Meminta Satu Keputusan

Misalkan kepala risiko menyusun laporan triwulan pada November 2026.
Pesan 1. Pemulihan belum memenuhi syarat. Sebanyak 29 dari 36 uji lulus, tetapi hanya 3 dari 5 rumah sakit. Dua kegagalan data berasal dari 9 uji akun terpisah. R-05 masih 10 persen, batasnya 2 persen.
Pesan 2. Akses vendor membaik, tetapi belum selesai. Cakupan AC-01 naik 85, 90, 95 persen. Satu akun tanpa pemilik sudah dibekukan. TA-01 selesai menurut manajemen, dan belum lolos uji ulang. Tidak ada keputusan yang diminta, karena biayanya berada dalam wewenang kepala TI.
Pesan 3. Layanan membaik, dan masih di bawah target. Waktu tunggu 34, 31, 28 menit, dengan target 25 menit. Gangguan pendaftaran Oktober 100 menit, di dalam batas 120 menit, tetapi di atas RTO 90 menit.
Keputusan yang diminta. Setujui pilihan 1 paling lambat akhir November 2026. Pemilik tindakan kepala operasi TI. Ukuran keberhasilan: 5 dari 5 rumah sakit lulus uji SIMRS di bawah 120 menit, dan 9 dari 9 uji akun terpisah berhasil, paling lambat akhir Januari 2027.
Selisih harapan kerugian R-05 antara 0,1 dan 0,02 adalah Rp160 juta per tahun, atau sekitar Rp40 juta per triwulan. Angka itu harga menunggu bukti. Direksi dapat menolaknya, asalkan penolakan beserta risiko sisanya dicatat.

Bab 14 memasukkan opsi B Rp480 juta ke peta jalan.

Laporan yang lebih pendek juga mengubah beban kerja. Tabel 13.13 menghitungnya pada tarif Rp60.000 per jam dari Bab 7. Misalkan laporan lama melibatkan 8 unit dengan 6 jam per bulan, ditambah penyunting 16 jam. Rancangan baru memerlukan 2 jam per indikator per bulan dan 24 jam per laporan triwulan.

Tabel 13.13: Beban laporan lama dan rancangan baru (misalkan)

Unsur	Laporan 40 halaman	Satu halaman
Penyusunan per tahun	$(8 \times 6 + 16) \times 12 = 768$ jam	$12{\times}2{\times}12{+}4{\times}24 = 384$ jam
Biaya per tahun	Rp46,08 juta	Rp23,04 juta
Waktu baca per pembaca	80 menit, 12 kali	Sekitar 5 menit, 4 kali

Keputusan mengganti laporan punya dua konsekuensi. Pertama, penghematan 384 jam atau Rp23,04 juta per tahun berarti indikator ini tidak menambah beban 3.046 jam yang harus dimuat Bab 14. Kedua, sebagian pembaca kehilangan rincian yang biasa diterima. Rincian itu tetap tersedia di *dashboard* dan katalog, dan dibaca oleh pihak yang memang bertugas memakainya.

13.9 Aktivitas: Dashboard KPI dan KRI serta Laporan Satu Halaman

Tujuan. Tim menyediakan laporan yang memicu tindakan: katalog 8 sampai 12 indikator, *dashboard* sederhana, dan laporan satu halaman untuk direksi Medikara atau organisasi tim.

Pembagian peran. Analis risiko memimpin penetapan ambang dan memastikan KRI memakai batas Bab 5. Anggota berlatar bisnis menyusun narasi untuk direksi. Analis teknologi memeriksa ketersediaan dan mutu data. Pemilik konteks memastikan penerima laporan memiliki kewenangan atas keputusan yang diminta.

Langkah kerja.

1. Pilih 8 sampai 12 indikator yang mencakup tata kelola, risiko, keamanan, privasi, dan kelangsungan layanan. Tulis keputusan yang didukung tiap ukuran. Ukuran tanpa keputusan dikeluarkan.
2. Isi katalog mengikuti kolom `sources/chapter13/katalog-indikator.csv`. Tetapkan rumus, sumber, frekuensi, pemilik, serta ambang tiga warna yang tidak tumpang tindih.

3. Hitung tiga periode dari `sources/chapter13/data-indikator.csv`, atau dari data organisasi yang sudah dianonimkan. Bedakan nol yang sah, tidak berlaku, dan data tidak tersedia.
4. Bandingkan hasil dengan `sources/chapter13/dashboard-contoh.csv`, lalu susun *dashboard* pada spreadsheet. Cantumkan angka, kata status, tren, dan perubahan definisi.
5. Tulis tiga pesan dan satu keputusan melalui `sources/chapter13/templat-laporan-direksi.md`. Nyatakan pilihan, biaya, pemilik, tenggat, dan risiko bila ditunda.
6. Tinjau silang rumus antaranggota, lalu simulasikan rapat 5 menit. Catat apakah direksi fiktif dapat memilih tindakan tanpa bertanya apa yang diminta.

Luaran. Katalog indikator, *dashboard*, dan laporan satu halaman.

Kaitan dengan capstone. Luaran masuk tonggak C4 Peta Jalan dan Tata Kelola. Bab 14 memakai indikator ini sebagai ukuran keberhasilan peta jalan. Metrik layanan diselaraskan dengan IT40713, dan nilai platform diselaraskan dengan IT40613.

Kriteria penilaian. Kaitan risiko dan keputusan 30 persen; ketepatan definisi dan hitungan 30 persen; ambang dan eskalasi 20 persen; kejelasan permintaan keputusan 20 persen. Hasil tiap tim boleh berbeda dari contoh. Penilaian berfokus pada penalaran.

Berkas pendukung. Daftar lengkap ada di `sources/chapter13/README.md`. Data organisasi nyata wajib seizin organisasi dan dianonimkan. Data pribadi pasien atau karyawan tidak boleh dipakai.

Pendalaman Teknis (opsional)

Skrip `hitung_indikator.py` menghitung 12 indikator dari data sintetis secara lokal. Listing 13.1 memperlihatkan aturan penyebut nol dan pembulatan. Nilai penuh dibandingkan dengan ambang, lalu baru dibulatkan untuk tampilan.

Listing 13.1: Status rasio, tersedia di `sources/chapter13/hitung_indikator.py`

```
def status_rasio(pembilang, penyebut, batas_hijau, batas_kuning):
  """Bandingkan nilai penuh sebelum pembulatan agar ambang tidak bergeser."""
  if pembilang is None or penyebut is None:
    return None, DATA_TIDAK_TERSEDIA
  if pembilang > penyebut:
    raise ValueError("Pembilang melebihi penyebut")
  if penyebut == 0:
    return None, TIDAK_BERLAKU
  nilai = pembilang / penyebut * 100
  if nilai >= batas_hijau:
```

```
  return nilai, HIJAU
if nilai >= batas_kuning:
  return nilai, KUNING
return nilai, MERAH
```

Tim dapat mengotomasi pengambilan dua indikator dari sumber data nyata, misalnya sistem tiket atau *log*, ke alat *dashboard* sumber terbuka seperti Metabase atau Grafana. Otomasi memerlukan definisi dan pemeriksaan mutu yang sama. Pengambilan data hanya untuk sistem sendiri atau yang sudah berizin tertulis. Keberhasilan mengambil data belum membuktikan indikator tepat untuk keputusan.

13.10 Ringkasan

KPI, KRI, dan KCI menjawab pertanyaan tentang hasil, paparan, dan kontrol. Data yang sama dapat mendukung beberapa keputusan bila definisi dan batas tafsirnya jelas. Cakupan AC-01 yang naik sampai 95 persen tidak meniadakan 1 akun tanpa pemilik. Indikator yang mendahului memberi waktu untuk bertindak, sedangkan indikator yang tertinggal mencatat hasil yang tetap perlu dipertanggungjawabkan secara terbuka.

Indikator yang baik memiliki pembilang, penyebut, cakupan, tanggal, sumber, pemilik, dan tindakan. Perbedaan 108 dari 108 dengan 108 dari 120 berasal dari penyebut, bukan dari pekerjaan. Data tidak tersedia dan penyebut nol tidak boleh diperlakukan sebagai kinerja sempurna. Mutu data diperiksa oleh pihak di luar penghasil angka, karena ukuran dengan target mendorong orang menyesuaikan catatan.

Ambang diturunkan dari batas Bab 5 dan memberi waktu merespons. Tidak semua indikator memerlukan tiga warna. Toleransi nol tetap merah sampai nol, sehingga peringatan dini berpindah ke indikator lain. Pada IK-03, RTO 90 menit dan batas 120 menit membentuk zona kuning yang berasal dari keputusan terdahulu. Jalur eskalasi mengikuti batas delegasi Bab 2, sehingga indikator tidak menciptakan wewenang baru.

Portofolio 12 indikator dipilih dari 46 usulan pada contoh Medikara, dan bahan Bab 8 sampai Bab 12 dipilah menurut pembacanya. *Dashboard* menunjukkan keadaan, tren, dan pengecualian pada satu halaman, tanpa skor gabungan. Skor 63,6 pada Oktober terlihat membaik, padahal dua KRI merah pada ketiga bulan dan satu KCI gagal pada rumah sakit.

Laporan direksi mengajukan pilihan yang dapat diputuskan. Medikara tidak meminta persetujuan Rp60 juta yang berada dalam wewenang kepala TI, tetapi meminta keputusan atas Rp180 juta tahap kedua opsi B, dengan harga menunggu

sekitar Rp40 juta per triwulan. Pesan utama bab ini: indikator berguna ketika mengubah keputusan dan tindakan, bukan ketika memenuhi halaman laporan.

13.11 Latihan

Latihan 1: Aktivitas atau Risiko

"Jumlah pelatihan keamanan yang diselenggarakan" diusulkan sebagai KRI. Kritisi usulan ini dan tawarkan indikator yang lebih baik. Latihan ini membuktikan bahwa ukuran kegiatan belum tentu menggambarkan paparan risiko. NIST memberi arah serupa: pelatihan kesadaran keamanan dinilai dari tingkat penyelesaian dan hasil kuis, bukan dari label partisipasi rendah, sedang, atau tinggi [145].

1. Tetapkan risiko dan perilaku yang hendak diubah.
2. Bandingkan jumlah acara dengan cakupan dan hasil uji.
3. Usulkan rumus, ambang, dan keputusan yang dipicunya.

Tabel 13.14 memberi contoh terisi, dan Tabel 13.15 menjadi lembar isian.

Tabel 13.14: Contoh terisi Latihan 1 (misalkan)

Ukuran	Nilai contoh	Batas tafsir
Pelatihan diselenggarakan	12 acara	Tidak menunjukkan siapa belajar
Cakupan pegawai prioritas	$30/100 = 30$ persen	Hadir belum berarti paham
Peserta lulus uji	$24/30 = 80$ persen	Hanya berlaku bagi peserta
Usulan KRI: pegawai prioritas belum lulus dalam 12 bulan	$100 - 24 = 76$ pegawai	Memicu penjadwalan; belum membuktikan perilaku

Tabel 13.15: Lembar isian Latihan 1

Ukuran	Nilai	Batas tafsir
...	...	...
...	...	...
...	...	...

Hasil dapat berbeda. Penilaian bertumpu pada alasan dan perbandingan bukti.

1. Pada contoh, mengapa 80 persen lulus uji tidak berarti 80 persen pegawai prioritas terlindungi?
2. Data apa yang diperlukan sebelum menyimpulkan risiko turun?
3. Bagaimana mencegah target mendorong manipulasi jumlah peserta?

Latihan 2: Menurunkan Ambang Akses

Turunkan ambang KRI untuk risiko kontrol akses dari pernyataan *risk appetite* yang dibuat pada Pertemuan 5. Latihan ini membuktikan bahwa toleransi, ambang, dan eskalasi harus konsisten.

1. Salin pernyataan toleransi dan cakupannya dari luaran Pertemuan 5.
2. Tentukan nilai yang melewati toleransi, pemilik, dan tindakan.
3. Tetapkan indikator pendamping yang memberi peringatan dini.
4. Uji ambang pada tiga periode.

Tabel 13.16 memberi contoh terisi dari batas nol akun pada Bab 5, dan Tabel 13.17 menjadi lembar isian.

Tabel 13.16: Contoh terisi Latihan 2 (misalkan)

Periode	IK-01	IK-02	IK-07	Status dan tindakan
Agustus	3 akun	2 akun	85 persen	Semua merah; bekukan akun, periksa daftar
September	2 akun	1 akun	90 persen	IK-07 kuning; IK-01 dan IK-02 tetap merah
Oktober	1 akun	0 akun	95 persen	IK-07 dan IK-02 hijau; IK-01 tetap merah

Tabel 13.17: Lembar isian Latihan 2

Periode	KRI	Pendamping	KCI	Status dan tindakan
…	…	…	…	…
…	…	…	…	…
…	…	…	…	…

Hasil dapat berbeda. Penilaian bertumpu pada alasan dan perbandingan bukti.

1. Mengapa tren 3, 2, 1 belum berarti risiko diterima?
2. Apa status bila nol akun terlapor tetapi ekstrak satu rumah sakit tidak lengkap?
3. Pada Oktober, IK-02 hijau dan IK-01 merah. Apa yang dibaca pemilik Medikara+ dari pasangan itu?

Latihan 3: Laporan yang Memicu Keputusan

Jelaskan apa yang membuat sebuah laporan direksi berujung pada keputusan, bukan sekadar dibaca. Latihan ini membuktikan bahwa opsi dan konsekuensi yang jelas lebih berguna dari daftar kegiatan.

1. Pilih satu pengecualian penting dari *dashboard*.
2. Periksa batas delegasi Bab 2, lalu pastikan keputusannya memang milik penerima laporan.
3. Tulis rekomendasi dan pembanding, lengkap dengan biaya dan risiko.
4. Nyatakan pemilik, tenggat, dan ukuran keberhasilan.

Tabel 13.18 memberi contoh terisi, dan Tabel 13.19 menjadi lembar isian.

Tabel 13.18: Contoh terisi Latihan 3 (misalkan)

Unsur	**Usulan contoh**	**Bukti**
Keputusan	Tahan tahap kedua opsi B, uji ulang satu triwulan	3 dari 5 rumah sakit lulus; 2 data gagal dari 9 uji
Pembanding	Cairkan Rp180 juta sekarang	Peluang R-05 tetap dicatat 0,1 sampai uji lulus
Harga menunggu	Sekitar Rp40 juta per triwulan	(Rp200 juta dikurangi Rp40 juta) dibagi 4
Keberhasilan	5 dari 5 rumah sakit; 9 dari 9 uji akun terpisah	Hasil uji yang disahkan pemilik layanan

Tabel 13.19: Lembar isian Latihan 3

Unsur	**Usulan**	**Bukti**
…	…	…
…	…	…
…	…	…

Hasil dapat berbeda. Penilaian bertumpu pada alasan dan perbandingan bukti.

1. Apa yang hilang dari laporan bila baris biaya dihapus?
2. Bagaimana mencatat penolakan direksi beserta risiko sisanya?
3. Pada contoh, apa yang berubah bila uji ulang hanya meluluskan 4 dari 5 rumah sakit?

Bab 14

Alat GRC dan Peta Jalan Tata Kelola Terpadu

Tujuan Pembelajaran

- Membandingkan pilihan alat GRC, dari spreadsheet sampai platform terintegrasi, berdasarkan kebutuhan dan kematangan organisasi.
- Menyusun peta jalan GRC bertahap yang selaras dengan peta jalan transformasi digital.
- Mempertahankan rekomendasi tata kelola, risiko, dan kepatuhan di depan pemangku kepentingan.

14.1 Pendahuluan

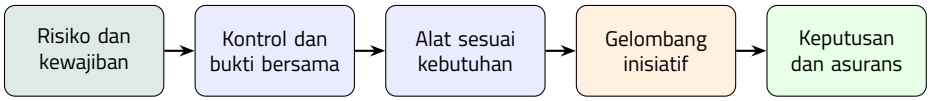
Misalkan register risiko, daftar kepatuhan, dan temuan audit Medikara tersimpan dalam 20 spreadsheet. Satu akun vendor dicatat sebagai tiga masalah dengan pemilik berbeda. Unit teknologi informasi (TI) melaporkan 108 dari 108 akun sudah ditinjau, padahal populasinya 120 akun. Direksi menerima jumlah temuan yang berubah menurut unit pelapor. Membeli aplikasi baru belum menyelesaikan perbedaan definisi dan tanggung jawab.

Bab 1 sampai Bab 13 menghasilkan banyak angka yang benar di babnya masing-masing. Bab 8 dan Bab 10 menghitung Rp720 juta per tahun untuk target kapabilitas. Bab 10 meminta opsi B seharga Rp480 juta per tahun. Bab 11 menghitung 3.046 jam ditambah alat alternatif Rp240 juta. Belum ada yang menjumlahkan semuanya, memeriksa tumpang tindihnya, lalu membandingkannya dengan anggaran modernisasi Rp10 miliar. Bab penutup ini mengerjakan

ketiganya. Hasil kerjanya adalah peta jalan tiga tahun, pilihan alat GRC, dan paket keputusan yang menutup tonggak C4 capstone.

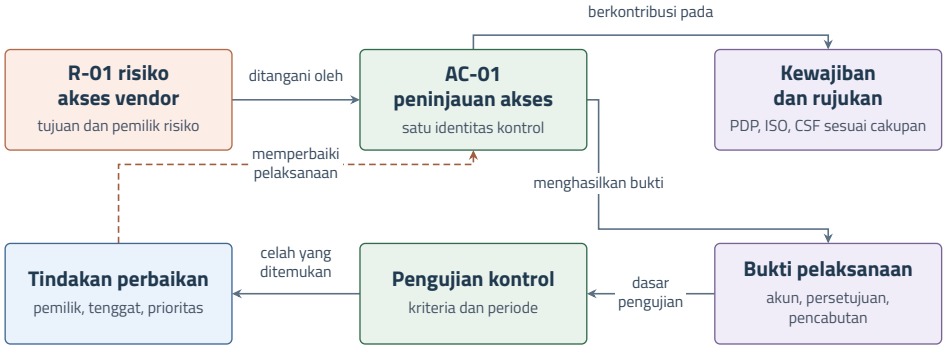
Bab ini memakai rumusan GRC terpadu dari Racz dan rekan, langkah profil pada Cybersecurity Framework (CSF) 2.0 dari National Institute of Standards and Technology (NIST), serta COBIT 2019 sebagai sistem tata kelola. Open Security Controls Assessment Language (OSCAL) dibahas sebagai format pertukaran informasi kontrol. Semua rujukan itu memberi kerangka. Seluruh angka, pemetaan, dan anggaran Medikara merupakan pengandaian pembelajaran [129, 104, 64, 62, 107].

Gambar 14.1 menunjukkan urutan keputusan dalam bab ini.



Gambar 14.1: Alur keputusan alat GRC dan peta jalan tata kelola terpadu

Gambar 14.2 merangkum hubungan komponen dan konsep utama bab ini.



Gambar 14.2: Satu kontrol terhubung ke risiko, kewajiban, dan bukti

14.2 GRC Terpadu

Satu identitas untuk satu objek

GRC terpadu menghubungkan tujuan, risiko, kewajiban, kontrol, bukti, pengujian, dan tindakan. Bab 1 sudah memakai rumusan Racz dan rekan: pendekatan terpadu di seluruh organisasi, lewat penyelarasan strategi, proses, teknologi, dan orang [129]. Integrasi memakai satu pustaka kontrol dan hubungan ke berbagai

kewajiban. Setiap objek punya satu kode, satu pemilik, dan hubungan yang tercatat. Pekerjaan utamanya karena itu bukan menggabungkan berkas, melainkan menyepakati apa yang dihitung sebagai satu objek.

Analogi katalog perpustakaan menjelaskan identitas bersama. Satu buku dapat muncul pada beberapa kategori tanpa dicatat sebagai tiga buku fisik. Nomor unik menghubungkan kategorinya dengan objek yang sama.

Dua contoh penerapan:

1. Bab 1 memisalkan audit internal, kepatuhan, dan keamanan informasi masing-masing meminta daftar akun kepada 23 fasilitas setiap triwulan. Jumlahnya $3 \times 23 \times 4 = 276$ permintaan per tahun. Dengan satu register dan satu jadwal, permintaan turun menjadi 92. Selisih 184 permintaan kali 2 jam adalah 368 jam per tahun, atau Rp22,08 juta pada tarif Rp60.000 per jam dari Bab 7.
2. Misalkan R-01 terkait akses vendor. Satu bukti tinjauan AC-01 ditautkan ke risiko, kewajiban, dan pengujian. Tiga baris tindakan dengan tiga pemilik menjadi satu tindakan, ACT-AC01-01, sehingga tidak ada pemilik yang saling menunggu.

Tabel 14.1 menghitung objek yang perlu diberi identitas pada Medikara. Kode mengikuti bab asalnya dan tidak diubah. AI berarti kecerdasan artifisial. Jumlahnya 196 objek. Bukti tumbuh lebih cepat: 60 catatan AC-01, 144 uji pemulihan, dan 260 tinjauan catatan aktivitas menghasilkan 464 bukti per tahun.

Tabel 14.1: Objek GRC bersama pada Medikara (misalkan)

Objek	Kode	Jumlah	Asal
Risiko	R-01 sampai R-12	12	Bab 5
Kewajiban	K-01 sampai K-16	16	Bab 3
Kebijakan	KB-01 sampai KB-09	9	Bab 8, Bab 11
Target	T-01 sampai T-24	24	Bab 8, Bab 10
Celah	G-01 sampai G-06, CP-01 sampai CP-07	13	Bab 6, Bab 7
Hubungan pemasok	Register, termasuk V-01 sampai V-06	40	Bab 9
Sistem AI	AI-01 sampai AI-06	6	Bab 11
Baris catatan pemrosesan	Enam proses inti	28	Bab 7
Baris Business Impact Analysis (BIA)	Lima rumah sakit dan fasilitas lain	36	Bab 10
Indikator	IK-01 sampai IK-12	12	Bab 13
Jumlah		**196**	

Keputusan memakai satu pustaka punya dua konsekuensi. Pertama, penyamaan punya biaya. Misalkan satu objek diperiksa 30 menit, sehingga 196 objek memakan 98 jam, atau Rp5,88 juta. Kedua, satu kesalahan kode kini terbaca oleh semua unit. Register karena itu memerlukan satu pemilik dan aturan perubahan. Peta jalan bab ini menunjuk kepala risiko sebagai pemilik register.

Kasus Medikara Health: Satu Masalah Akses, Tiga Catatan

Misalkan satu akun vendor yang penugasannya sudah berakhir tercatat pada tiga berkas. Register risiko mencatatnya pada R-01, milik pemilik Medikara+. Register kewajiban mencatat K-01 belum terpenuhi. Audit internal mencatat TA-01, dengan kepala operasi TI sebagai pemilik tindakan. Ketiga pihak menunggu jawaban yang sama.
Integrasi dimulai dari identitas, pemilik, dan bukti yang sama. Risikonya tetap R-01, kontrolnya AC-01, dan tindakannya ACT-AC01-01. Pemilik risiko dan pemilik tindakan tetap dipisahkan seperti Bab 6. Fungsi kepatuhan dan audit internal membaca satu bukti, EV-AC01-2026-10, tanpa meminta daftar baru.

Memeriksa tiga acuan AC-01

Bab 1 menyebut AC-01 mendukung tiga acuan, dan menjanjikan tiap acuan diperiksa pada bab ini. Dua hal pada pemetaan sering tertukar, yaitu kontribusi dan pemenuhan. Pembagiannya begini. Kontribusi berarti kontrol menjawab sebagian isi acuan. Pemenuhan berarti seluruh isi acuan sudah terjawab dan terbukti. Tabel 14.2 membaca isi tiap acuan, lalu memisahkan yang dijawab AC-01 dari yang belum.

Isi Undang-Undang (UU) 27/2022 dibaca dari naskah resmi [136], dan isi PR.AA-05 dibaca dari CSF 2.0 [104]. Nomor Annex A pada kolom terakhir mengikuti pemetaan NIST yang dipakai Bab 6 [105]. K-01 berasal dari Pasal 39 pada Bab 3, dan Pasal 37 mengatur pengawasan pihak yang terlibat dalam pemrosesan. Register karena itu memuat keempat pasal, seperti contoh Bab 1, dengan Pasal 39 sebagai acuan utama.

Dua contoh batas klaim:

1. PR.AA-05 memuat enam unsur: kebijakan, pengelolaan, penegakan, peninjauan, hak paling kecil, dan pemisahan tugas. KB-02 dan KB-03 menjawab unsur kebijakan. AC-01 menjawab peninjauan dan sebagian penegakan. Hak paling kecil dan pemisahan tugas menunggu G-04 pada gelombang kedua. Status terbukti pada T-15 hanya berlaku untuk 120 akun vendor pada cakupan Bab 8.

Tabel 14.2: Isi acuan dan batas kontribusi AC-01

Acuan	Isi yang diminta	Dijawab AC-01	Belum dijawab
UU 27/2022 Pasal 39, K-01	Mencegah data pribadi diakses secara tidak sah, antara lain dengan sistem keamanan	Akun tanpa dasar dicabut	Autentikasi, jejak aktivitas, akun bersama
UU 27/2022 Pasal 35, 36, 37	Langkah teknis operasional, kerahasiaan, dan pengawasan pihak yang terlibat	Sebagian pengawasan akun vendor	Tingkat keamanan menurut risiko; 11 butir perjanjian vendor
ISO/IEC 27001:2022 Annex A 5.18	Pengelolaan hak akses; naskah berbayar, uraian ini ringkas	Peninjauan dan pencabutan berkala	Baris *Statement of Applicability* (SoA), penilaian risiko, kontrol 5.15, 8.2, 8.3, 8.18
NIST CSF 2.0 PR.AA-05	Izin akses ditetapkan dalam kebijakan, dikelola, ditegakkan, ditinjau, serta memuat hak paling kecil dan pemisahan tugas	Ditinjau, dan sebagian ditegakkan	Hak paling kecil dan pemisahan tugas

2. Pasal 39 ayat (2) menyebut sistem elektronik yang andal, aman, dan bertanggung jawab. Satu peninjauan bulanan tidak menjawab ketiganya. Multi-Factor Authentication (MFA) pada 108 dari 120 akun, misalnya, tetap menjadi bukti terpisah pada T-14.

Kapan bukti boleh dipakai ulang

Pertanyaan kemudian muncul: apakah bukti dapat selalu dipakai ulang? Periode, cakupan sistem, kriteria, dan keandalan bukti perlu cocok. Hasil peninjauan satu rumah sakit tidak otomatis berlaku bagi empat lainnya. Pemetaan yang rapi tidak membuktikan efektivitas kontrol.

Dua contoh penerapan:

1. Misalkan EV-AC01-2026-10 mencatat 114 dari 120 akun ditinjau pada Oktober 2026. Bukti itu sah untuk IK-07 bulan Oktober, yaitu 95 persen. Bukti yang sama belum cukup untuk menutup TA-01, karena kriteria penutupan meminta 120 dari 120 akun.
2. Laporan unit TI berbunyi 108 dari 108, atau tampak 100 persen. Audit memakai populasi 120 dari daftar penugasan, sehingga 12 akun luput. Bukti

dengan penyebut yang salah tidak dipakai ulang untuk acuan apa pun.

Diagram konsep pada awal bab meringkas alur yang sama. R-01 ditangani AC-01. AC-01 berkontribusi pada kewajiban sesuai cakupannya dan menghasilkan bukti pelaksanaan. Bukti menjadi dasar pengujian. Celah yang ditemukan menjadi tindakan dengan pemilik, tenggat, dan prioritas, lalu tindakan itu memperbaiki pelaksanaan AC-01.

14.3 Fungsi dan Pilihan Alat GRC

Empat fungsi yang dicari

Alat GRC mendukung register, alur kerja, pengelolaan bukti, dan pelaporan, disertai jejak perubahan. Spreadsheet terstruktur sesuai untuk ruang lingkup terbatas dengan kontrol versi dan pemilik yang jelas. Platform khusus membantu koordinasi lebih luas, tetapi memerlukan konfigurasi, pengelolaan akses, data yang bersih, dan dukungan. Papazafeiropoulou dan Spanaki menyusun karakteristik sistem GRC dari literatur dan pandangan pakar: tujuan, fungsi sistem, pemangku kepentingan utama, metodologi dan persyaratan sebelum penerapan, faktor keberhasilan, serta hambatan [122]. Bab ini memakai susunan itu sebagai daftar pertanyaan sebelum alat dipilih.

Analogi pergudangan menjelaskan pilihan alat. Rak sederhana dapat cukup untuk puluhan barang. Gudang besar membutuhkan pelacakan terpusat. Namun sistem mahal tetap menghasilkan kesalahan jika nomor barang dan penanggung jawabnya tidak tertib.

Dua contoh penerapan:

1. Register Medikara memuat 196 objek dan 464 bukti per tahun. Jumlah itu masih tertampung spreadsheet. Masalahnya bukan ukuran. Data Protection Impact Assessment (DPIA) dan kertas kerja audit tidak boleh dibaca semua pemakai, dan satu lembar bersama sulit membatasi akses per baris.
2. Bab 12 menemukan 12 akun luput karena daftar diambil dari sistem yang diperiksa. Platform yang membaca daftar yang sama tetap melaporkan 108 dari 108. Alat mempercepat hitungan, sedangkan penyebut tetap keputusan proses.

Tabel 14.3 merangkum pilihan alat menurut kebutuhan.

Biaya total pada periode yang sama

Total Cost of Ownership (TCO), atau biaya total kepemilikan, mencakup lisensi, implementasi, migrasi, waktu pegawai, pelatihan, operasi, dan keluar dari sistem.

Tabel 14.3: Pilihan alat menurut kebutuhan

Pilihan	Kekuatan	Kebutuhan pengelolaan	Cocok bila
Spreadsheet terstruktur	Cepat dimulai dan mudah ditinjau	Versi, akses, validasi data	Definisi baru disepakati; objek ratusan
Sumber terbuka	Dapat disesuaikan	Operasi, pembaruan, keahlian	Ada pengelola tetap dan server yang aman
Platform komersial	Dukungan dan fungsi terintegrasi	Lisensi, kontrak, portabilitas	Alur lintas unit sudah stabil

Pilihan hanya dapat dibandingkan pada periode dan cakupan yang sama. Angka berikut merupakan asumsi tiga tahun, tanpa klaim harga produk tertentu.

Dua contoh penerapan:

1. Misalkan spreadsheet memerlukan biaya awal Rp20 juta dan Rp30 juta per tahun, sedangkan platform memerlukan Rp150 juta awal dan Rp100 juta per tahun. Biaya tiga tahunnya Rp110 juta dan Rp450 juta. Selisih Rp340 juta harus dijelaskan oleh manfaat dan kebutuhan.
2. Lisensi nol bukan biaya nol. CISO Assistant edisi Community memakai GNU Affero General Public License (AGPL) versi 3, menyebut lebih dari 200 kerangka, dan menyediakan pemasangan Docker serta REST Application Programming Interface (API) [59]. Eramba menyediakan edisi Community tanpa biaya untuk pemasangan sendiri, di samping edisi Enterprise berbayar [33]. Misalkan pengelola memerlukan 1.000 jam per tahun, atau Rp60 juta, ditambah Rp60 juta biaya awal. Biaya tiga tahunnya $60 + 3 \times 60 = 240$, atau Rp240 juta.

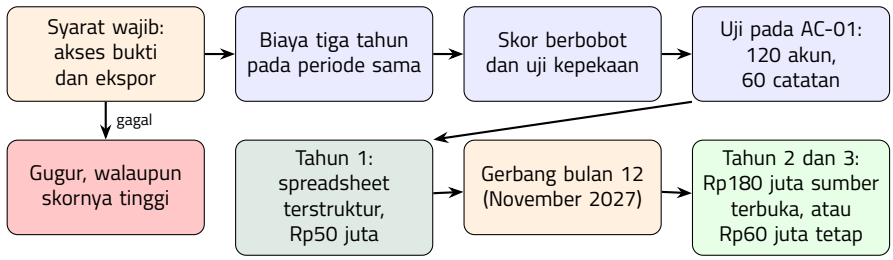
Tabel 14.4 menyusun keempat jalur pada periode yang sama. Jalur bertahap memakai spreadsheet pada Tahun 1, lalu pindah ke sumber terbuka bila gerbang bulan 12 lulus. Bila tetap memakai spreadsheet, biayanya kembali ke Rp110 juta. Bila pindah ke platform pada Tahun 2, biayanya $50 + 250 + 100 = 400$, atau Rp50 juta lebih murah daripada membeli platform sejak awal.

Syarat wajib lebih dahulu, skor kemudian

Perbandingan memakai kebutuhan wajib sebelum skor berbobot. Pilihan gagal bila tidak dapat mengekspor data atau membatasi bukti sensitif sesuai kebutuhan. Skor tinggi pada kriteria lain tidak dapat menebusnya. Gambar 14.3 memperlihatkan urutan itu, dan Tabel 14.5 memuat skor sementara dari `sources/chapter14/kriteria-alat-grc.csv`.

Tabel 14.4: Biaya alat selama tiga tahun dalam juta rupiah (misalkan)

Jalur	Tahun 1	Tahun 2	Tahun 3	Jumlah	Hitungan
Spreadsheet	50	30	30	110	$20 + 3 \times 30$
Sumber terbuka	120	60	60	240	$60 + 3 \times 60$
Platform	250	100	100	450	$150 + 3 \times 100$
Bertahap	**50**	**120**	**60**	**230**	$(20 + 30) + (60 + 60) + 60$



Gambar 14.3: Urutan memilih alat GRC pada Medikara (misalkan)

Tabel 14.5: Syarat wajib dan skor berbobot alat (misalkan)

Kriteria	Bobot	Spreadsheet	Sumber terbuka	Platform
Pembatasan akses bukti	Wajib	Ya, bersyarat	Belum diuji	Belum diuji
Ekspor data lengkap	Wajib	Ya	Belum diuji	Belum diuji
Kecocokan proses	25	3	4	5
Biaya tiga tahun	25	5	3	2
Kemudahan pengelolaan	20	4	2	3
Jejak perubahan	15	2	4	5
Portabilitas	15	4	4	3
Skor berbobot	100	**3,70**	**3,35**	**3,55**

Dua contoh cara membaca skor:

1. Spreadsheet memperoleh $(25 \times 3 + 25 \times 5 + 20 \times 4 + 15 \times 2 + 15 \times 4)/100 = 3{,}70$. Sumber terbuka memperoleh 3,35, dan platform 3,55. Selisih 0,15 antara spreadsheet dan platform terlalu kecil untuk memilih pemenang.
2. Misalkan bobot biaya turun 10 poin dan bobot jejak perubahan naik 10 poin, menjadi 15 dan 25. Skornya berubah menjadi 3,40, 3,45, dan 3,85. Platform kini teratas. Urutan yang berbalik karena 10 poin bobot berarti keputusan belum boleh bersandar pada skor saja.

Keputusan memakai syarat wajib punya dua konsekuensi. Pertama, dua pilihan belum dapat dinilai sebelum diuji. Kedua, alat GRC menyimpan daftar kelemahan

Medikara, sehingga penyedianya masuk register pemasok Bab 9 dan diuji ekspornya seperti V-01. Bab 9 menghitung sisa 4 persen rekam yang tidak terbaca mesin sebagai 1.120 jam kerja manual. Pelajaran yang sama berlaku bagi vendor alat.

Kasus Medikara Health: Alat Dipilih Bertahap

Misalkan kepala risiko mengusulkan spreadsheet terstruktur pada Tahun 1. Biayanya Rp50 juta, terdiri atas Rp20 juta biaya awal dan Rp30 juta pengelola, atau 500 jam. Dua puluh berkas lama dibekukan, dan 196 objek masuk satu register. Bukti sensitif disimpan terpisah dengan akses per peran.

Gerbang pada bulan 12, November 2027, memakai tiga pertanyaan. Apakah 196 objek punya pemilik? Apakah pembatasan akses bersyarat itu pernah gagal? Apakah pengelola melewati 500 jam? Bila dua jawaban menunjukkan spreadsheet tidak cukup lagi, Medikara menguji CISO Assistant atau eramba di lingkungan lokal, lalu pindah ke sumber terbuka dengan cadangan Rp180 juta untuk Tahun 2 dan 3.

Pilihan ini punya *tradeoff*. Selama setahun, jejak perubahan tetap lemah, dengan skor 2 dari 5. Sebaliknya, Medikara tidak mengotomasi definisi yang belum stabil. Bila gerbang menyatakan spreadsheet masih cukup, Rp120 juta tidak terpakai.

Pendalaman Teknis (opsional)

OSCAL memakai format terbaca mesin, yaitu Extensible Markup Language (XML), JavaScript Object Notation (JSON), dan YAML [107]. Situs NIST membagi modelnya ke tiga lapisan: kontrol (*catalog*, *profile*, *control mapping*), implementasi (*system security plan*, *component definition*), dan penilaian (*assessment plan*, *assessment results*, *plan of action and milestones*) [108]. Padanan terdekat pada capstone, menurut pembacaan bab ini: `sources/chapter14/pemetaan-kontrol.csv` dengan *control mapping*, program audit Bab 12 dengan *assessment plan*, serta TA-01 dengan *plan of action and milestones*. Berkas Comma-Separated Values (CSV) pada Aktivitas bukan dokumen OSCAL. Model *catalog* dirancang untuk kerangka berbasis kontrol, sehingga cara menuliskan kewajiban hukum seperti K-01 tetap perlu keputusan tim.

14.4 Menyusun Peta Jalan GRC

Urutan mengikuti ketergantungan

Peta jalan mengurutkan inisiatif berdasarkan pengurangan risiko, kewajiban, ketergantungan, biaya, dan kapasitas perubahan. Setiap inisiatif memiliki pemilik, luaran, syarat mulai, kriteria selesai, ukuran keberhasilan, serta risiko sisa. CSF 2.0 menggambarkan langkah yang serupa: organisasi menganalisis celah antara profil saat ini dan profil target, menyusun rencana tindakan berprioritas, menjalankannya, memperbarui profil, lalu mengulanginya [104]. ISACA juga menerbitkan COBIT 2019 Implementation Guide sebagai peta jalan perbaikan tata kelola yang berkelanjutan [62]. *Quick win* adalah perbaikan awal yang bernilai dan layak, bukan sekadar pekerjaan paling mudah.

Analogi renovasi gedung menunjukkan urutan ketergantungan. Pengecatan tidak didahulukan dari perbaikan kebocoran. Jadwal yang mengabaikan ketergantungan menghasilkan pekerjaan ulang.

Dua contoh penerapan:

1. IT40513 menjadwalkan P1 kontrol akses terpusat selesai Maret 2027, titik keputusan K2 pada Oktober 2027, dan portal dan API mitra P8 mulai Januari 2029. Penilaian risiko vendor harus selesai sebelum K2. Register 40 hubungan memakan 484 jam. Misalkan tersedia sekitar 60 jam per bulan, sehingga pekerjaan itu memerlukan sekitar 8 bulan dan harus dimulai paling lambat Februari 2027.
2. Latihan terpadu Rp180 juta bergantung pada tahap kedua opsi B. Pada triwulan pertama, baru 3 dari 5 rumah sakit lulus. Bila latihan dimajukan, 2 rumah sakit melatih pemulihan yang belum terbukti, dan uangnya habis untuk mengulang temuan lama. Bab 10 karena itu menjadwalkannya sesudah tahap kedua.

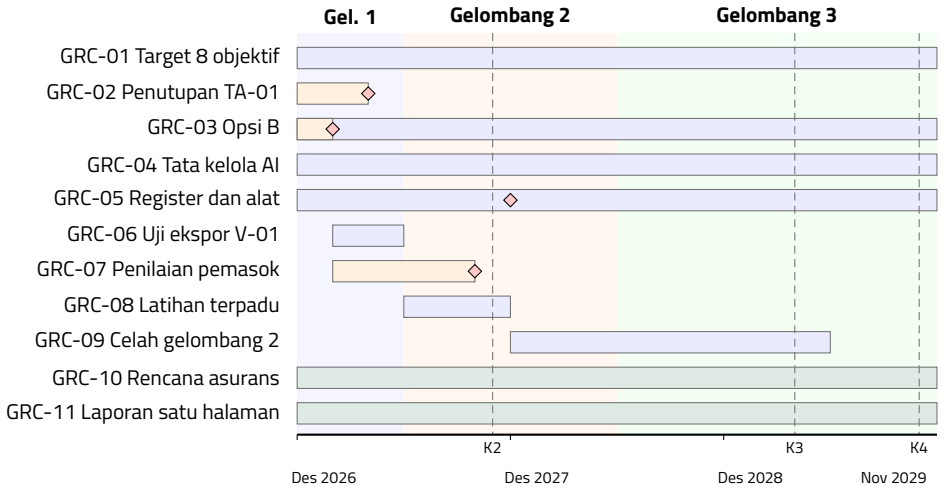
Peta jalan dihitung sejak keputusan direksi pada November 2026. Bulan 1 adalah Desember 2026, dan bulan 36 adalah November 2029, masih di dalam Strategi 2026 sampai 2030. Pembelian alat besar sebelum definisi dan proses stabil berisiko mengotomasi kebingungan. Karena itu, urutannya dibagi menjadi tiga gelombang.

1. Gelombang 1, bulan 1 sampai 6, menutup yang sudah jatuh tempo: TA-01, keputusan tahap kedua opsi B, satu register, dan uji ekspor. Bulan 2 juga memuat pemantauan Peraturan Pemerintah (PP) 33/2026 yang berlaku 16 Januari 2027. Naskah resminya belum diperoleh, sehingga peraturan itu belum menjadi baris kewajiban baru.
2. Gelombang 2, bulan 7 sampai 18, menguji kemampuan: latihan terpadu,

penilaian pemasok sebelum K2, gerbang alat, dan audit pemulihan.

3. Gelombang 3, bulan 19 sampai 36, memperluas: celah gelombang kedua selesai, lalu asurans mengikuti P8, K3 pada Maret 2029, dan K4 pada Oktober 2029.

Gambar 14.4 memperlihatkan seluruh jadwal. Warna oranye menandai pekerjaan dengan tenggat keras, dan warna hijau menandai pekerjaan yang memakai kapasitas yang sudah ada. Belah ketupat menandai gerbang, dan garis putus-putus menandai titik keputusan IT40513. Tabel 14.6 merinci pemilik dan gerbangnya. SIMRS pada tabel itu adalah Sistem Informasi Manajemen Rumah Sakit. Berkas lengkapnya ada di `sources/chapter14/peta-jalan-grc.csv`.



Gambar 14.4: Peta jalan GRC tiga tahun Medikara (misalkan)

Hitungan biaya tiga tahun

Dua angka pada peta jalan sering tertukar karena nilainya sama. Pembagiannya begini. Rp180 juta pada Bab 10 adalah tiap tahap pencairan tambahan opsi B. Rp180 juta pada GRC-08 adalah latihan terpadu dua layanan. Peta jalan versi lama hanya memuat latihan itu. Padahal Bab 10 dan Bab 13 meminta opsi B Rp480 juta masuk peta jalan. Tabel 14.7 memuat keduanya sebagai baris terpisah. Dua baris terakhirnya dibahas pada subbagian tentang anggaran.

Asal tiap baris dapat ditelusuri:

1. GRC-01 berasal dari Bab 8 dan Bab 10: 4 objektif tingkat 3 dengan Rp120 juta (DSS05, APO10, APO13, DSS04) ditambah 4 objektif tingkat 2 dengan Rp60 juta (APO14, APO12, MEA03, BAI06), atau Rp720 juta. AC-01 Rp60 juta sudah berada di dalam DSS05, sehingga tidak ditambahkan lagi.

Tabel 14.6: Inisiatif, ketergantungan, pemilik, dan gerbang (misalkan)

Kode	Inisiatif	Bulan	Bergantung pada	Pemilik tindakan	Gerbang selesai
GRC-01	Target delapan objektif, Paket A sampai D dan DSS04	1 sampai 36	Keputusan direksi	Pemilik tiap objektif	T-01 sampai T-24 diterima
GRC-02	Penutupan TA-01, AC-01 pada 5 rumah sakit	1 sampai 4	Perpanjangan tenggat	Kepala operasi TI	120 dari 120 akun, 60 dari 60 catatan, 30 dari 30 sampel
GRC-03	Opsi B: cadangan terpisah, pemulihan prioritas	1 sampai 36	Keputusan November 2026	Kepala operasi TI	Bulan 2: 5 dari 5 rumah sakit, 9 dari 9 uji akun terpisah
GRC-04	Tata kelola AI, KB-09, alat alternatif	1 sampai 36	KB-09 disetujui direksi	Direktur pelayanan	6 baris inventaris ditinjau tiap triwulan
GRC-05	Satu register dan alat GRC	1 sampai 36	Kode bersama	Kepala risiko	Bulan 3: 196 objek berpemilik; bulan 12: gerbang alat
GRC-06	Uji ekspor V-01 dan pendampingan	3 sampai 6	Klausul kontrak Bab 9	Pengelola vendor	Rekam sintetis terbaca; sisa manual dihitung
GRC-07	Penilaian 40 hubungan pemasok	3 sampai 10	Skala Bab 9	Pengelola vendor	40 dari 40 dinilai sebelum K2
GRC-08	Latihan terpadu dua layanan	7 sampai 12	Tahap kedua opsi B	Kepala operasi TI	Dua layanan memenuhi Recovery Time Objective (RTO) dan kapasitas minimum
GRC-09	Celah G-04, G-06, CP-02, CP-07	13 sampai 30	GRC-02, GRC-05	Pemilik SIMRS	Peran baku 5 rumah sakit; satu inventaris
GRC-10	Rencana asurans	1 sampai 36	Kapasitas audit	Kepala audit internal	Temuan lolos uji ulang
GRC-11	Laporan satu halaman, 12 indikator	1 sampai 36	GRC-05	Kepala risiko	Direksi memutuskan dari laporan

2. GRC-03 berasal dari Bab 10: dasar Rp120 juta, tahap pertama Rp180 juta yang sudah cair, dan tahap kedua Rp180 juta yang ditahan, atau Rp480 juta. Bab 10 menyatakannya sebagai biaya per tahun, sehingga Tahun 2 dan Tahun 3 tetap Rp480 juta.

Tabel 14.7: Biaya penuh dan uang baru dalam juta rupiah (misalkan)

Baris	Tahun 1	Tahun 2	Tahun 3	Jumlah
GRC-01 Target delapan objektif	720,00	720,00	720,00	2.160,00
GRC-03 Opsi B	480,00	480,00	480,00	1.440,00
GRC-04 Waktu staf tata kelola AI	182,76	1,92	1,92	186,60
GRC-04 Alat alternatif	240,00	240,00	240,00	720,00
GRC-05 Register dan alat GRC	50,00	120,00	60,00	230,00
GRC-06 Uji ekspor V-01	60,00	0,00	0,00	60,00
GRC-08 Latihan terpadu	180,00	0,00	0,00	180,00
Biaya penuh	**1.912,76**	**1.561,92**	**1.501,92**	**4.976,60**
Dikurangi nilai jam kerja, Tabel 14.8	412,38	197,94	197,94	808,26
Uang baru	**1.500,38**	**1.363,98**	**1.303,98**	**4.168,34**

3. GRC-04 berasal dari Bab 11: 3.046 jam kali Rp60.000 adalah Rp182,76 juta. Ditambah alat alternatif Rp240 juta, Tahun 1 menjadi Rp422,76 juta. Lisensi AI-01 belum termasuk. Pada Tahun 2 dan Tahun 3, baris berulang pada tabel Bab 11 tinggal tinjauan inventaris 24 jam dan tinjauan KB-09 8 jam, atau 32 jam senilai Rp1,92 juta.
4. Bab 11 tidak menyebut apakah alat alternatif dibayar sekali atau tiap tahun. Bab ini memakai anggapan yang lebih hati-hati, yaitu langganan tahunan. Bila dibayar sekali, jumlah tiga tahun turun Rp480 juta menjadi Rp4.496,60 juta.
5. GRC-05 mengikuti jalur bertahap pada Tabel 14.4. GRC-06 memakai Rp60 juta sebagai biaya sekali seperti Bab 9, dan uji tahunan berikutnya mengikuti klausul kontrak. GRC-08 adalah Rp180 juta sekali seperti Bab 10.

Hitungan ini punya dua konsekuensi. Pertama, GRC-01 dan GRC-03 berjumlah Rp3.600 juta, atau 72,3 persen dari seluruh biaya, dan keduanya berulang tiap tahun. Program ini sebagian besar berupa kemampuan yang harus terus dibayar, bukan proyek yang selesai. Kedua, Tahun 1 paling berat, yaitu 38,4 persen dari jumlah, karena memuat pekerjaan sekali jalan seperti pengenalan AI dan latihan.

Hitungan jam tiga tahun

Jam dihitung terpisah dari rupiah. Bab 8 sudah mengingatkan bahwa waktu staf sebagian termasuk dalam biaya kontrol, sehingga kedua angka tidak dijumlahkan begitu saja. Tabel 14.8 memuat tiap baris dari bab asalnya, dan `sources/chapter14/beban-jam-peta-jalan.csv` menyalin isinya. BIA, DPIA, dan register pemasok dihitung sebagai pekerjaan Tahun 1. Pembaruannya pada Tahun 2 dan Tahun 3 masuk tinjauan berkala.

Misalkan seluruh 3.327 jam Tahun 1 berada di dalam GRC-01, sehingga tidak

Tabel 14.8: Beban jam peta jalan dan pembebanannya ke objektif (misalkan)

Baris	**Asal**	**Objektif**	**Tahun 1**	**Tahun 2**	**Tahun 3**	**Jumlah**
AC-01 pada 120 akun, G-01	Bab 6	DSS05	144	144	144	432
144 uji pemulihan, G-03	Bab 6	DSS04	432	432	432	1.296
Latihan pemberitahuan	Bab 7, Bab 8	MEA03	96	96	96	288
260 tinjauan catatan aktivitas	Bab 8	DSS05	520	520	520	1.560
BIA 36 baris	Bab 10	DSS04	216	0	0	216
Tabletop 5 kali per tahun	Bab 10	DSS04	35	35	35	105
Beban Bab 8 sesudah Bab 10			**1.443**	**1.227**	**1.227**	**3.897**
Rapat tiga forum	Bab 8	APO12	400	400	400	1.200
5 DPIA	Bab 7	APO14	360	0	0	360
Register 40 pemasok	Bab 9	APO10	484	0	0	484
Tinjauan 5 pemasok terperinci	Bab 9	APO10	160	160	160	480
Pembaruan 40 server, Infrastructure as a Service	Bab 9	APO13	480	480	480	1.440
Di dalam GRC-01			**3.327**	**2.267**	**2.267**	**7.861**
Tata kelola AI, GRC-04	Bab 11		3.046	32	32	3.110
Pengelola alat, GRC-05	Bab ini		500	1.000	1.000	2.500
Jumlah jam			**6.873**	**3.299**	**3.299**	**13.471**
Nilai, juta rupiah	Rp60.000 per jam		**412,38**	**197,94**	**197,94**	**808,26**

ditambahkan lagi ke rupiah. Anggapan itu masuk akal, karena tiap objektif masih di bawah anggarannya. Pada Tahun 1, DSS05 memakai 664 jam, DSS04 683, APO10 644, APO13 480, APO12 400, APO14 360, MEA03 96, dan BAI06 0. Beban terbesar, DSS04, bernilai Rp40,98 juta dari Rp120 juta, sedangkan APO12 bernilai Rp24 juta dari Rp60 juta. Pembebanan ini juga pengandaian. Nilainya Rp199,62 juta, atau 27,7 persen dari Rp720 juta. Sisa Rp520,38 juta membiayai hal di luar waktu staf, seperti perbaikan prosedur, pelatihan, dan perangkat.

Jumlah 6.873 jam setara 3,58 orang penuh waktu pada 1.920 jam kerja per tahun. Namun, 2.400 jam di antaranya tersebar pada 4.800 karyawan, masing-masing 30 menit. Beban kelompok kerja tinggal 4.473 jam, atau 2,33 orang penuh waktu. Bab 6 mengingatkan beban ini tidak boleh bergantung pada tim platform 6 orang, karena 38,8 persen dari 11.520 jam kapasitasnya akan habis. Bila dibagi merata pada 52 staf TI, bebannya sekitar 4,5 persen dari 99.840 jam.

Baris yang sengaja tidak dijumlahkan

Pertanyaan berikutnya: angka besar mana yang tidak masuk jumlah, dan mengapa? Tabel 14.9 menjawabnya. Baris itu tetap ditulis, supaya direksi tidak mengira angkanya terlupa.

Tabel 14.9: Baris di luar jumlah peta jalan (misalkan)

Baris	Nilai	Asal	Alasan
Rencana asurans, GRC-10	1.800 jam, Rp108 juta per tahun	Bab 12	Kapasitas yang sudah ada
Laporan satu halaman, GRC-11	384 jam, Rp23,04 juta per tahun	Bab 13	Menggantikan 768 jam, sehingga beban berkurang
Lisensi AI-01	Rp150 juta per tahun	Bab 11	Belum diputuskan; mandat komite pengarah TI
Pemeriksaan AI-01 penuh	8.000 jam, Rp480 juta per tahun	Bab 11	Dihitung sebelum perluasan disetujui
Dukungan vendor dalam negeri	Rp25 juta per bulan, Rp300 juta per tahun	Bab 7, Bab 9	Keputusan terpisah; bandingkan dengan izin Pasal 972
Investasi Medikara+	Rp8.400 juta	Bab 2	Program lain; dibandingkan pada subbagian berikut

Rencana asurans Bab 12 masuk peta jalan sebagai jadwal, bukan sebagai biaya baru. Kapasitasnya 1.800 jam per tahun, dengan cadangan 20 persen, atau 360 jam, sehingga 1.440 jam terencana.

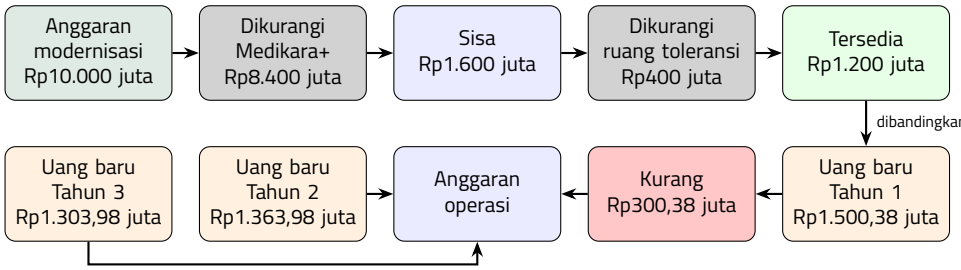
1. Tahun 1: AC-01 600, pemulihan 480, insiden 240, saran KB-09 dan bacaan laporan 120, atau 1.440 jam.
2. Tahun 2: AI 480, jejak aktivitas 240, privasi 200, vendor 320, integrasi Badan Penyelenggara Jaminan Sosial (BPJS) Kesehatan 200, atau 1.440 jam.
3. Tahun 3 belum dirancang Bab 12. Bab ini mencadangkan 480 jam untuk R-04 dan R-07 yang ditunda, lalu 960 jam disusun dari hasil Tahun 2.

Membaca anggaran terhadap Rp10 miliar

Biaya penuh belum sama dengan uang yang harus disediakan. Dua hal ini sering tertukar. Pembagiannya begini. Biaya penuh menghitung semua sumber daya, termasuk waktu staf yang sudah digaji. Uang baru hanya menghitung uang yang harus keluar di luar gaji. Dua baris terakhir Tabel 14.7 menurunkan yang kedua dari yang pertama: Rp1.500,38 juta pada Tahun 1, Rp1.363,98 juta pada Tahun 2, dan Rp1.303,98 juta pada Tahun 3.

Analogi tabungan renovasi rumah menjelaskan masalah sumber dana. Tabungan renovasi dapat membayar pemasangan atap baru. Tabungan itu tidak dapat terus membayar tagihan listrik setiap bulan. Tagihan berulang harus masuk pengeluaran rutin.

Gambar 14.5 membandingkan uang baru dengan anggaran modernisasi Rp10 miliar. Bab 2 memisalkan Rp8 miliar disetujui untuk Medikara+, lalu ditambah Rp400 juta menjadi Rp8,4 miliar, dengan batas Rp8,8 miliar. Sisanya Rp1.600 juta. Rp400 juta di antaranya masih menjadi ruang toleransi Medikara+, sehingga yang benar-benar tersedia adalah Rp1.200 juta.



Gambar 14.5: Uang baru peta jalan dibandingkan anggaran modernisasi (misalkan)

Dua contoh pembacaan:

1. Misalkan seluruh sisa Rp1.600 juta dipakai. Tahun 1 tertutup, dan tersisa Rp99,62 juta. Namun, ruang toleransi Medikara+ ikut terpakai Rp300,38 juta. Bab 2 juga mencatat bila biaya Rp8 miliar naik 27 persen, nilainya Rp10,16 miliar. Pada keadaan itu, peta jalan dan Medikara+ berebut uang yang sudah tidak ada.
2. Bila peta jalan dan Medikara+ dihitung penuh, jumlahnya $8.400 + 4.976{,}60 = 13.376{,}60$, atau Rp13.376,60 juta. Angka itu melewati Rp10 miliar sebesar 33,8 persen, jauh di atas toleransi 10 persen.

Bacaan ini punya tiga konsekuensi. Pertama, peta jalan tidak muat dalam Rp10 miliar, dan hal itu harus ditulis terus terang. Bab ini mengusulkan Rp1.200 juta dari sisa modernisasi untuk Tahun 1, Rp300,38 juta dari anggaran operasi 2027, serta seluruh uang baru Tahun 2 dan Tahun 3 dari anggaran operasi. Kedua, biaya penuh Rp4.976,60 juta berada pada rentang keputusan direksi di Bab 2, tetapi hanya Rp23,40 juta di bawah batas Rp5 miliar. Bila lisensi AI-01 berjalan pada Tahun 2 dan Tahun 3, jumlahnya Rp5.276,60 juta, sehingga Bab 2 meminta persetujuan dewan komisaris. Memecahnya menjadi keputusan kecil tidak menghapus kewajiban itu. Ketiga, kenaikan di atas 10 persen, yaitu di atas Rp5.474,26 juta, kembali ke pemutus awal.

Dua angka anggaran antarmata kuliah juga perlu dipisahkan. Rp10 miliar

adalah pengandaian mata kuliah ini untuk latihan kewenangan keputusan, dengan Medikara+ Rp8,4 miliar. IT40513 Bab 13 memisalkan pagu Rp60 miliar untuk delapan inisiatif 2026 sampai 2030, dengan cadangan risiko Rp7 miliar dan inisiatif kontrol akses I2. Rp10 miliar bukan baris di dalam Rp60 miliar, sehingga kedua angka tidak dijumlahkan. Saat peta jalan dilebur ke portofolio IT40513, tim menulis baris GRC sebagai pengeluaran operasi dan memeriksa hubungannya dengan I2, supaya pekerjaan AC-01 tidak dihitung dua kali.

Apakah biayanya sepadan?

Pertanyaan yang jujur muncul berikutnya: apakah penurunan kerugian menutup biaya? Tabel 14.10 menjawabnya pada tiga skenario yang sudah dihitung bab sebelumnya.

Tabel 14.10: Harapan kerugian per tahun sebelum dan sesudah (misalkan)

Skenario dan tindakan	Sebelum	Sesudah	Turun	Asal
R-01 dengan AC-01 penuh	Rp100 juta	Rp25 juta	Rp75 juta	Bab 5
R-05 dengan opsi B	Rp200 juta	Rp40 juta	Rp160 juta	Bab 10
R-10 dengan uji ekspor	Rp80 juta	Rp30 juta	Rp50 juta	Bab 9
Jumlah	**Rp380 juta**	**Rp95 juta**	**Rp285 juta**	

Jawabannya tidak. Penurunan Rp285 juta per tahun jauh di bawah uang baru Tahun 2 sebesar Rp1.363,98 juta. Selama tiga tahun, angkanya paling banyak Rp855 juta, atau 17,2 persen dari biaya penuh. Hitungan ini hanya mencakup 3 dari 12 skenario, tetapi kesimpulannya tidak boleh ditutupi. Peta jalan tidak dibela sebagai investasi yang kembali modal.

Pembelaannya ada pada empat hal lain. Pertama, R-05 harus turun dari peluang 10 persen ke batas 2 persen, karena batas itu sudah ditetapkan pada Bab 5. Kedua, K-01, K-02, K-04, dan K-05 adalah kewajiban, bukan pilihan untung rugi. Ketiga, harapan kerugian tidak mengukur cedera pasien pada R-11. Keempat, IT40513 menjadikan penutupan temuan akses dan penilaian vendor sebagai syarat K2 dan P8. Direksi tetap boleh menolak sebagian peta jalan, asalkan penolakan beserta risiko sisanya dicatat.

Indikator sebagai ukuran keberhasilan

Peta jalan memakai indikator Bab 13, bukan ukuran baru. Pemiliknya mengikuti `sources/chapter13/katalog-indikator.csv`. Tabel 14.11 memuat posisi Oktober 2026, yaitu 3 merah, 2 kuning, 6 hijau, dan 1 tidak berlaku, lalu menyebut inisiatif yang diukur.

Dua contoh pemakaiannya:

Tabel 14.11: Indikator keberhasilan peta jalan (misalkan)

Kode	Pemilik tindakan	Oktober 2026	Sasaran	Inisiatif
IK-01	Kepala operasi TI	1 akun, merah	0 akun	GRC-02
IK-02	Kepala operasi TI	0 akun, hijau	0 akun	GRC-02
IK-03	Kepala operasi TI	100 menit, kuning	Paling lama 90 menit	GRC-03, GRC-08
IK-04	Kepala risiko	1 skenario, merah	0 skenario	GRC-03
IK-05	Fungsi kepatuhan	0 baris, hijau	0 baris	GRC-01, GRC-07
IK-06	Pimpinan klinis	0 laporan, hijau	0 laporan	GRC-04
IK-07	Kepala operasi TI	95 persen, hijau	Minimal 95; TA-01 100	GRC-02
IK-08	Kepala operasi TI	83,33 persen, merah	100 persen	GRC-03, GRC-08
IK-09	Petugas pelindungan data	100 persen, hijau	100 persen	GRC-01
IK-10	Pemilik tiap temuan	90 persen, hijau	Minimal 90 persen	GRC-02, GRC-10
IK-11	Petugas pelindungan data	Tidak berlaku	100 persen	GRC-01
IK-12	Kepala pendaftaran	28 menit, kuning	Paling lama 25 menit	Dipantau GRC-11

1. IK-04 baru menjadi 0 skenario bila peluang R-05 turun ke 0,02. Peluang itu tetap dicatat 0,1 sampai syarat opsi B terpenuhi. Pembelian cadangan saja tidak mengubah warnanya.
2. IK-12 turun dari 34 ke 28 menit, dan bab ini tidak mengklaimnya sebagai hasil peta jalan GRC. Waktu tunggu dipengaruhi jadwal dokter dan alur pendaftaran pada program Medikara+. Mengklaimnya membuat peta jalan tampak berhasil tanpa dasar, dan Bab 13 sudah membahas bahaya *gaming* [15].

Perpanjangan tenggat TA-01

Bab 12 menyepakati tenggat 30 hari untuk TA-01, dan Bab 13 mencatat statusnya pada Oktober 2026: selesai menurut manajemen, belum lolos uji ulang. Tenggat itu sudah lewat. Standar 15.2 meminta auditor menanyakan keterlambatan, dan kepala audit internal menilai apakah manajemen senior sudah menerima risiko di atas toleransinya [150]. Keterlambatan tanpa keputusan berarti risiko diterima tanpa disebut. Tabel 14.12 karena itu mencatat perpanjangannya sebagai keputusan.

Tabel 14.12: Catatan perpanjangan TA-01 (misalkan)

Unsur	Isi
Tenggat lama	30 hari; temuan bertanggal acuan 31 Maret 2026; sudah lewat
Status Oktober 2026	Selesai menurut manajemen; belum lolos uji ulang; 114 dari 120 akun
Tenggat baru	Uji ulang dengan tanggal acuan 31 Maret 2027
Alasan	Kriteria 60 catatan memerlukan 5 rumah sakit selama 12 bulan; P1 IT40513 selesai pada bulan yang sama
Kriteria penutupan	120 dari 120 akun, 60 dari 60 catatan, 30 dari 30 akun sampel; tidak berubah
Pemilik	Risiko: pemilik Medikara+. Tindakan: kepala operasi TI. Uji ulang: audit internal
Penerima risiko sisa	Direksi, tertulis, atas laporan kepala audit internal
Harga menunggu	Peluang R-01 0,0575, bukan 0,05: Rp28,75 juta, bukan Rp25 juta per tahun
Beban	Memakai 600 jam audit AC-01 Tahun 1; tidak menambah jam
Bila gagal	Kembali ke direksi; IK-10 tetap menghitung TA-01 belum tertutup

Kasus Medikara Health: Mengapa Tenggat 30 Hari Terlalu Pendek

Misalkan kepala audit internal membawa TA-01 ke direksi pada November 2026. Tenggat 30 hari cukup untuk memperbaiki daftar akun. Tenggat itu tidak cukup untuk menghasilkan 60 catatan, karena satu rumah sakit hanya menghasilkan satu catatan per bulan. Kesalahannya ada pada rancangan temuan: tenggat tindakan disamakan dengan tenggat pembuktian.

Perpanjangan punya harga yang dapat dihitung. Selisih harapan kerugian R-01 adalah Rp3,75 juta per tahun, atau Rp1,25 juta selama 4 bulan. Peluang kerugian Rp1,5 miliar atau lebih masih 1,15 persen, di bawah batas 2 persen. Namun, batas nol akun vendor tanpa pemilik belum terpenuhi, karena IK-01 masih 1 akun. Akun itu sudah dibekukan. Direksi menerima perpanjangan dengan syarat tidak ada catatan susulan. Bila satu catatan bulan lampau memang tidak ada, angka 60 tidak tercapai, dan hasilnya dilaporkan apa adanya.

14.5 Manajemen Perubahan dan Budaya

Perubahan GRC berhasil ketika perilaku dan keputusan ikut berubah. Dokumen baru tidak cukup bila staf tidak memiliki waktu, alat, atau kewenangan. Pimpinan memberi teladan melalui keputusan yang mengikuti aturan, termasuk ketika biaya dan tenggat menekan. Beautement, Sasse, dan Wonham mengusulkan gagasan

anggaran kepatuhan. Orang menimbang biaya dan manfaat dari mematuhi aturan keamanan, dan kesediaannya terbatas. Organisasi karena itu perlu mengarahkan kepatuhan pada tujuan keamanan yang utama dan menghapus kewajiban yang kurang penting [14].

Analogi antrean layanan menunjukkan dampak aturan yang tidak praktis. Jalur resmi yang lambat mendorong orang mencari jalan pintas. Memperbaiki alur dan memberi bantuan dapat lebih efektif daripada menambah larangan.

Resistensi perlu diurai menurut penyebab: beban kerja, ketidakjelasan manfaat, konflik insentif, atau keterbatasan kemampuan. Pelatihan ditujukan pada keputusan tertentu. Keberhasilan dinilai melalui pelaksanaan kontrol dan pengurangan pengecualian, bukan jumlah peserta saja.

Dua contoh penerapan:

1. Misalkan persetujuan akses memerlukan 12 hari, dan ada 30 permintaan per bulan. Staf yang mengejar layanan tergoda memakai akun bersama, seperti contoh 12 petugas bangsal pada Bab 6. Tim memperjelas pemilik dan batas waktu, sehingga persetujuan menjadi 2 hari. Waktu tunggu berkurang 300 hari per bulan.
2. Misalkan penutupan temuan dinilai dari banyaknya tiket selesai. Dari 10 temuan yang dilaporkan selesai, 9 lolos uji ulang. Status pertama memberi 100 persen, dan status kedua memberi 90 persen. IK-10 memakai status kedua, sehingga penutupan administratif tidak menggantikan perbaikan nyata.

Tabel 14.13 merangkum hambatan, tindakan, dan ukuran hasilnya.

Tabel 14.13: Hambatan dan tindakan perubahan

Hambatan	Tindakan	Ukuran hasil
Tidak ada waktu	Masukkan tugas ke kapasitas kerja; 6.873 jam dibagi per unit	Tinjauan selesai tepat waktu, IK-07
Alur tidak jelas	Tetapkan pemilik dan jalur bantuan	Akun tanpa pemilik turun, IK-01
Insentif salah	Uji ulang hasil penutupan	Temuan lolos uji ulang, IK-10
Larangan tanpa alternatif	Alat alternatif Rp240 juta dan pelaporan tanpa hukuman	Baris AI-06 berkurang; laporan sendiri naik

Dua hal pada perubahan juga sering tertukar, yaitu menambah aturan dan menambah kepatuhan. Pembagiannya begini. Sembilan dokumen kebijakan belum tentu dijalankan bila beban kerja terus bertambah. Peta jalan ini sudah mengurangi dua beban: 368 jam dari permintaan bukti ganda, dan 384 jam dari laporan yang

lebih pendek. Jumlahnya 752 jam per tahun, atau 10,9 persen dari 6.873 jam. Penghematan itu tidak dikurangkan dari tabel jam, karena baru nyata bila jadwal kerja benar-benar diubah.

Penundaan juga perlu pemilik. Misalkan G-04 baru selesai paling lambat bulan 30, Mei 2029. Akun bersama masih ada selama itu, dan R-02 berskor 12 tetap terbuka. Bab 8 meminta pemilik SIMRS menyetujui penundaan secara tertulis. Selama menunggu, T-13 meminta nol akun bersama pada sampel 2 rumah sakit.

14.6 Mempresentasikan Rekomendasi kepada Direksi

Susunan yang meminta keputusan

Presentasi akhir mengajukan keputusan yang beralasan. Susunannya meliputi masalah, bukti, pilihan, rekomendasi, biaya, ketergantungan, risiko bila ditunda, dan keputusan yang diminta. Ketidakpastian dilaporkan sebagai asumsi dengan rencana validasi, bukan disembunyikan dalam skor.

Analogi permohonan anggaran menunjukkan perlunya pilihan konkret. Pernyataan organisasi perlu lebih aman belum memberi dasar persetujuan. Usulan sumber daya untuk menutup kesenjangan tertentu pada tanggal tertentu dapat dinilai dan diputuskan.

Pertanyaan sulit dijawab dengan bukti dan batas klaim. Tim tidak menjanjikan risiko nol atau kepatuhan sempurna. Jika anggaran dikurangi, tim menjelaskan inisiatif yang ditunda serta konsekuensinya. Keempat mata kuliah menyampaikan satu rancangan organisasi dengan keputusan yang konsisten. Tabel 14.14 merangkum isi keputusan C4.

Tabel 14.14: Pertanyaan direksi dan jawaban C4 (misalkan)

Pertanyaan direksi	Bukti	Jawaban yang dapat ditinjau
Mengapa sekarang?	3 indikator merah; TA-01 lewat tenggat; R-05 10 persen, batas 2 persen	Harga menunggu opsi B sekitar Rp40 juta per triwulan
Berapa biayanya?	Tabel biaya dan tabel jam	Rp4.976,60 juta biaya penuh; Rp4.168,34 juta uang baru
Dari mana uangnya?	Sisa modernisasi Rp1.200 juta	Tahun 1 kurang Rp300,38 juta; sisanya anggaran operasi
Bagaimana tahu berhasil?	IK-01 sampai IK-12; rencana asurans	Gerbang hasil, diuji audit internal
Apa yang tetap berisiko?	R-02, R-04, R-07	Pemilik dan tanggal tinjau tercatat

Menjawab bila anggaran dipotong

Dua contoh pertanyaan sulit:

1. Misalkan direksi hanya memberi Rp1.200 juta uang baru pada Tahun 1, sehingga Rp300,38 juta harus dipangkas. Tabel 14.15 menilai pilihannya. Baris pertama dan kedua dipilih, dengan penghematan Rp300 juta. Sisa Rp0,38 juta diserap anggaran operasi. Total tiga tahun turun Rp120 juta menjadi Rp4.856,60 juta, dan uang baru Tahun 2 naik Rp180 juta menjadi Rp1.543,98 juta. Jadwal ikut diperbarui, bukan hanya totalnya.
2. Misalkan direksi meminta bukti semua vendor aman. Tim menyebut cakupan yang sudah diuji, yaitu 40 hubungan pada tiga tingkat. Laporan System and Organization Controls (SOC) 2 Type 2 pada Bab 9 memuat 3 pengecualian dari 25 sampel pencabutan akses, dan 9 dari 14 kontrol pelengkap berjalan. Tim menjawab bahwa bukti itu tidak mendukung kata "aman", lalu menyebut audit vendor 320 jam pada Tahun 2.

Tabel 14.15: Pilihan pemotongan uang baru Tahun 1 (misalkan)

Pilihan	Hemat, juta	Akibat	Putusan
GRC-08 digeser ke Tahun 2	180	Audit pemulihan Tahun 1 berjalan tanpa hasil latihan	Dipilih
Alat alternatif mulai 6 bulan lebih lambat	120	AI-06 lebih lama tanpa alternatif kerja	Dipilih
GRC-06 digeser setahun	60	R-10 tetap Rp80 juta; K-05 tetap tidak memenuhi	Ditolak
Tahap kedua opsi B dibatalkan	180	R-05 tetap 10 persen, melewati batas	Ditolak
AC-01 dikurangi	60	TA-01 gagal; syarat P1 IT40513 gagal	Ditolak

Satu keputusan bersama empat mata kuliah

Peta jalan GRC menempel pada peta jalan transformasi IT40513, sehingga direksi menerima satu cetak biru. Tabel 14.16 mencatat titik temu tanggalnya. Bila satu gerbang gagal, kedua jadwal ditinjau bersama. Gambar 14.6 memperlihatkan asal angka dari seluruh tonggak.

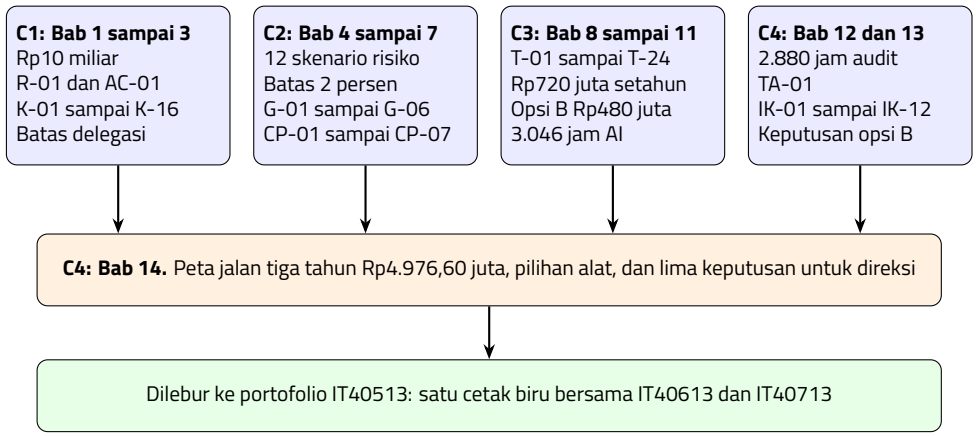
Kasus Medikara Health: Lima Keputusan yang Diminta

Misalkan kepala risiko dan kepala audit internal membawa satu halaman ke rapat direksi akhir November 2026. Halaman itu meminta lima keputusan.

1. Setujui peta jalan tiga tahun dengan biaya penuh Rp4.976,60 juta dan

Tabel 14.16: Titik temu peta jalan GRC dengan tiga mata kuliah lain

Mata kuliah	Titik temu	Syarat dari peta jalan GRC	Bulan
IT40513	P1 selesai Maret 2027	TA-01 lolos uji ulang	4
IT40513	K2 Oktober 2027	Penilaian risiko vendor selesai, GRC-07	11
IT40513	K3 Maret 2029, K4 Oktober 2029	Uji pemulihan lulus pada rumah sakit yang pindah	28, 35
IT40613	P8 portal dan API mitra, masa rilis mulai Januari 2029	Penilaian vendor; KB-05; gerbang agen memakai KB-09	26
IT40713	Rancangan cloud dan pemulihan	BIA, RTO sistem 120 menit, profil target keamanan	1 sampai 12



Gambar 14.6: Asal angka peta jalan dari tonggak C1 sampai C4 (misalkan)

uang baru Rp4.168,34 juta, bertahap menurut gerbang. Laporkan ke dewan komisaris tiap triwulan.

2. Tetapkan sumber dana. Tahun 1 memakai Rp1.200 juta dari sisa modernisasi dan Rp300,38 juta dari anggaran operasi 2027. Tahun 2 dan Tahun 3 masuk anggaran operasi. Ruang toleransi Medikara+ Rp400 juta tidak disentuh.
3. Tahan tahap kedua opsi B Rp180 juta sampai uji ulang akhir Januari 2027: 5 dari 5 rumah sakit di bawah 120 menit, dan 9 dari 9 uji akun terpisah berhasil.
4. Catat perpanjangan TA-01 sampai tanggal acuan 31 Maret 2027, dan terima risiko sisa R-01 secara tertulis selama masa itu.

5. Pakai spreadsheet terstruktur pada Tahun 1, dengan gerbang alat pada November 2027.

Direksi dapat memilih lain. Bila keputusan 2 ditolak, Tabel 14.15 menjadi jadwal baru. Bila keputusan 3 ditolak, uang keluar sebelum bukti. Tim tidak menjanjikan risiko nol. Tim menjanjikan bahwa setiap risiko sisa punya pemilik, tanggal tinjau, dan bukti.

Tonggak C4 selesai bila enam luaran tersedia dan angkanya saling cocok: rencana asurans 2.880 jam dan contoh uji 24 dari 30 akun; *dashboard* dan laporan satu halaman dengan 12 indikator; pemetaan kontrol 196 objek; pilihan alat Rp230 juta; peta jalan Rp4.976,60 juta dengan 13.471 jam dan 11 inisiatif; serta materi presentasi dengan 5 keputusan.

14.7 Aktivitas: Peta Jalan GRC dan Gladi Presentasi C4

Tujuan. Tim memadukan seluruh luaran semester menjadi peta jalan GRC tiga tahun yang menempel pada peta jalan transformasi di IT40513, memilih pendekatan alat GRC, dan berlatih presentasi C4 dalam format rapat direksi.

Pembagian peran. Pemilik konteks memastikan rekomendasi realistis bagi organisasinya. Analis risiko menjaga batas risiko dan risiko sisa. Analis regulasi menandai kewajiban yang belum tertangani dan memeriksa isi acuan. Analis teknologi menilai ketergantungan serta kemampuan alat. Semua anggota mempertahankan rekomendasi.

Langkah kerja.

1. Kumpulkan luaran Bab 1 sampai Bab 13, lalu tetapkan identitas bersama untuk risiko, kewajiban, kontrol, bukti, serta tindakan. Hitung objek seperti Tabel 14.1.
2. Isi `sources/chapter14/pemetaan-kontrol.csv` untuk satu kontrol. Baca isi tiap acuan, lalu tulis yang dijawab dan yang belum dijawab kontrol itu.
3. Susun tiga tahun melalui `sources/chapter14/peta-jalan-grc.csv`. Cantumkan ketergantungan, biaya per tahun, pemilik, indikator, dan gerbang selesai.
4. Isi `sources/chapter14/beban-jam-peta-jalan.csv`. Tandai baris yang berada di dalam biaya lain, supaya jam dan rupiah tidak dijumlahkan dua kali.
5. Bandingkan biaya dengan anggaran. Pisahkan biaya penuh dari uang baru, dan biaya sekali dari biaya berulang.
6. Bandingkan alat dengan `sources/chapter14/kriteria-alat-grc.csv`.

Pisahkan syarat wajib dari skor, hitung biaya pada periode sama, lalu uji kepekaan bobot.

7. Selaraskan gerbang dengan tiga mata kuliah lain, dan catat perpanjangan temuan memakai `sources/chapter14/catatan-perpanjangan-ta01.md`.
8. Lakukan gladi menggunakan `sources/chapter14/templat-presentasi-c4.md`. Anggota lain berperan sebagai direksi dan menguji bukti, biaya, serta konsekuensi penundaan.

Luaran. Peta jalan terpadu, alasan pilihan alat, pemetaan kontrol, dan materi presentasi.

Kaitan dengan capstone. Luaran menutup tonggak C4 Peta Jalan dan Tata Kelola, yang dipresentasikan menjelang Ujian Akhir Semester (UAS). Peta jalan GRC dilebur ke peta jalan dan portofolio inisiatif di IT40513.

Kriteria penilaian. Integrasi dan keterlacakan 30 persen; urutan serta kelayakan biaya 30 persen; pembandingan alat 20 persen; kualitas pembelaan keputusan 20 persen. Hasil tiap tim boleh berbeda dari contoh. Penilaian berfokus pada penalaran.

Berkas pendukung. Daftar lengkap ada di `sources/chapter14/README.md`. Data organisasi nyata wajib seizin organisasi dan dianonimkan. Data pribadi pasien atau karyawan tidak boleh dipakai.

Pendalaman Teknis (opsional)

Pendalaman teknis ini opsional. Jalankan `sources/chapter14/periksa_peta_jalan.py` untuk menghitung ulang semua jumlah biaya dan jam dari baris CSV. Tim juga dapat memasang CISO Assistant atau eramba pada lingkungan lokal, memuat kerangka ISO/IEC 27001 dan NIST CSF, lalu mengimpor register semester. Catat versi, lisensi, dukungan ekspor, dan biaya operasi sebelum memilih. Lisensi AGPL perlu dibaca fungsi hukum bila kode diubah. Pakai data sintetis saja. Pasang pada komputer sendiri, dan jangan memindai sistem milik orang lain tanpa izin tertulis.

14.8 Ringkasan

GRC terpadu menghubungkan tujuan, risiko, kewajiban, kontrol, bukti, pengujian, dan tindakan. Identitas bersama mencegah duplikasi tanpa menghapus perbedaan persyaratan. Pada Medikara, 196 objek memerlukan satu kode dan satu pemilik. AC-01 berkontribusi pada empat pasal UU 27/2022, Annex A 5.18, dan PR.AA-05, tetapi tidak memenuhi seluruh isinya. Bukti hanya dipakai ulang bila periode, cakupan, kriteria, dan keandalannya cocok.

Alat dipilih setelah kebutuhan, pemilik, dan mutu data jelas. Biaya total mencakup perubahan proses dan operasi, bukan lisensi saja. Syarat wajib diuji sebelum skor, dan skor 3,70, 3,35, serta 3,55 berbalik bila bobot bergeser 10 poin. Medikara memilih jalur bertahap Rp230 juta: spreadsheet terstruktur pada Tahun 1, lalu gerbang pada bulan 12.

Peta jalan mempertimbangkan pengurangan risiko, kewajiban, ketergantungan, kapasitas, serta biaya. Sebelas inisiatif berjalan dalam tiga gelombang, dan biaya penuhnya Rp4.976,60 juta dengan 13.471 jam. Baris AC-01, BIA, rencana asurans, dan laporan tidak dijumlahkan dua kali. Uang barunya Rp4.168,34 juta, sehingga peta jalan tidak muat dalam sisa Rp1.200 juta dari anggaran Rp10 miliar. Penurunan harapan kerugian Rp285 juta per tahun juga tidak menutup biaya, sehingga pembelaannya bertumpu pada batas risiko, kewajiban, keselamatan pasien, dan syarat lintas mata kuliah.

Perubahan berhasil bila perilaku berubah. Jalur resmi yang lambat mendorong jalan pintas, dan kesediaan patuh terbatas. Karena itu, peta jalan juga mengurangi beban, yaitu 752 jam per tahun. Indikator IK-01 sampai IK-12 mengukur hasilnya, dan perpanjangan TA-01 sampai 31 Maret 2027 ditulis sebagai keputusan, bukan dibiarkan sebagai keterlambatan.

Presentasi akhir meminta lima keputusan konkret dengan pilihan serta konsekuensinya, lalu tonggak C4 ditutup dan dilebur ke portofolio IT40513. Pesan utama bab ini adalah bahwa tata kelola menjadi nyata ketika tanggung jawab, sumber daya, dan bukti perbaikan bertemu dalam keputusan organisasi.

14.9 Latihan

Latihan 1: Kelayakan Platform GRC

Organisasi dengan 300 karyawan ingin membeli platform GRC yang mahal. Argumen apa yang mendukung dan menolak keputusan itu? Latihan ini membuktikan bahwa keputusan alat bertumpu pada kebutuhan dan biaya yang sepadan, bukan pada jumlah karyawan saja.

1. Daftar kebutuhan wajib dan kapasitas pengelola.
2. Hitung biaya tiga tahun pada dua opsi, pada periode yang sama.
3. Hitung biaya per karyawan per tahun, lalu bandingkan dengan Medikara.
4. Nyatakan syarat yang membuat platform layak atau belum layak.

Tabel 14.17 memuat contoh terisi, dengan angka biaya dari Tabel 14.4. Angka merupakan skenario pembelajaran. Tabel 14.18 adalah lembar isian.

Pertanyaan analisis:

Tabel 14.17: Contoh terisi Latihan 1 (misalkan)

Opsi	Rumus tiga tahun	Biaya	Per karyawan per tahun, 300 orang	Per karyawan per tahun, 4.800 orang
Spreadsheet	$20 + 3 \times 30$ juta	Rp110 juta	Rp122.222	Rp7.639
Platform	$150 + 3 \times 100$ juta	Rp450 juta	Rp500.000	Rp31.250

Tabel 14.18: Lembar isian Latihan 1

Opsi	Rumus tiga tahun	Biaya	Per karyawan per tahun	Syarat layak
...	...	...	...	...
...	...	...	...	...

1. Manfaat apa yang harus menjelaskan selisih Rp340 juta?
2. Misalkan organisasi 300 karyawan mengelola data kesehatan pada banyak lokasi, sedangkan organisasi 4.800 karyawan hanya punya satu lokasi. Mengapa jumlah pegawai saja tidak cukup menentukan alat?

Latihan 2: Satu Kontrol untuk Banyak Kewajiban

Jelaskan gagasan "satu kontrol untuk banyak kewajiban" dengan contoh kontrol peninjauan hak akses yang sekaligus memenuhi UU PDP, ISO/IEC 27001, dan NIST CSF. UU PDP adalah UU 27/2022 tentang Pelindungan Data Pribadi. Latihan ini membuktikan bahwa kata "memenuhi" pada kalimat itu perlu diuji, karena pemetaan menunjukkan kontribusi dan batasnya.

1. Tuliskan tujuan AC-01 dan cakupan buktinya.
2. Baca isi tiap acuan dari sumbernya.
3. Petakan kontribusi AC-01 ke keamanan data, kontrol akses, serta hasil CSF.
4. Nyatakan bagian acuan yang belum tertutup oleh AC-01.

Tabel 14.19 memuat contoh terisi dari Tabel 14.2, dan Tabel 14.20 adalah lembar isian.

Pertanyaan analisis:

1. EV-AC01-2026-10 mencatat 114 dari 120 akun. Untuk acuan mana bukti itu cukup, dan untuk keputusan mana tidak?
2. Mengapa pemetaan yang rapi tidak membuktikan efektivitas kontrol?

Tabel 14.19: Contoh terisi Latihan 2 (misalkan)

Acuan	Kontribusi AC-01	Bukti	Batas
UU PDP Pasal 39	Mendukung pencegahan akses tidak sah	114 dari 120 akun, Oktober 2026	Bukan seluruh kewajiban PDP
ISO/IEC 27001 Annex A 5.18	Mendukung pengelolaan hak akses	Catatan peninjauan bulanan	Perlu konteks, SoA, dan bukti lain
NIST CSF PR.AA-05	Mendukung peninjauan izin akses	Tiket pencabutan	Hak paling kecil belum terjawab; bukan sertifikasi

Tabel 14.20: Lembar isian Latihan 2

Acuan	Kontribusi AC-01	Bukti	Batas
…	…	…	…
…	…	…	…
…	…	…	…

Latihan 3: Urutan Quick Win

Susun tiga inisiatif *quick win* GRC untuk Medikara Health pada enam bulan pertama, lalu jelaskan alasan urutannya. Latihan ini membuktikan bahwa urutan mengikuti ketergantungan dan dampak, serta dapat dihitung terhadap anggaran.

1. Pilih tiga kesenjangan yang memiliki bukti.
2. Susun ketergantungan, pemilik, biaya enam bulan, dan gerbang selesai.
3. Jumlahkan biaya, lalu uji urutan terhadap batas anggaran dan kapasitas.

Tabel 14.21 memuat contoh terisi. Pengelola register dan AC-01 dihitung setengah biaya tahunannya. AC-01 sudah berada di dalam GRC-01. Tabel 14.22 adalah lembar isian.

Pertanyaan analisis:

1. Apa akibat menempatkan *dashboard* sebelum definisi data?
2. Uji ekspor Rp60 juta menurunkan harapan kerugian R-10 sebesar Rp50 juta per tahun. Berapa lama biayanya tertutup? Apa yang berubah bila peluang R-10 hanya 0,05?
3. Inisiatif mana yang harus dipertahankan bila anggaran dikurangi?

Tabel 14.21: Contoh terisi Latihan 3 (misalkan)

Urutan	Inisiatif	Pemilik	Biaya, juta	Gerbang selesai
1	Satu register	Kepala risiko	$20 + 15 = 35$	196 objek berpemilik
2	Penutupan TA-01	Kepala operasi TI	30	120 dari 120 akun, 60 dari 60 catatan, 30 dari 30 sampel
3	Uji ekspor V-01	Pengelola vendor	60	Rekam sintetis terbaca; sisa manual dihitung
	Jumlah		**125**	

Tabel 14.22: Lembar isian Latihan 3

Urutan	Inisiatif	Pemilik	Biaya, juta	Gerbang selesai
…	…	…	…	…
…	…	…	…	…
…	…	…	…	…

Bibliografi

[1] AICPA & CIMA. System and organization controls: SOC suite of services, 2026. URL https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2. Halaman tanpa tanggal terbit. Diakses 1 November 2026.

[2] Amazon Web Services. Shared responsibility model, 2026. URL https://aws.amazon.com/compliance/shared-responsibility-model/. Halaman tanpa tanggal terbit. Diakses 1 November 2026.

[3] American Hospital Association. AHA survey: Change healthcare cyberattack significantly disrupts patient care, hospitals' finances. Hasil survei, Maret 2024, 2024. URL https://www.aha.org/node/692736. Diakses 1 November 2026.

[4] Christopher Anoruo. Employing COBIT 2019 for enterprise governance strategy. ISACA Industry News, 28 Oktober 2019, 2019. URL https://www.isaca.org/resources/news-and-trends/industry-news/2019/employing-cobit-2019-for-enterprise-governance-strategy. Diakses 31 Oktober 2026.

[5] Article 29 Data Protection Working Party. Guidelines on data protection impact assessment (DPIA) and determining whether processing is "likely to result in a high risk" for the purposes of regulation 2016/679, WP 248 rev.01. Diadopsi 4 April 2017, direvisi 4 Oktober 2017, 2017. URL https://ec.europa.eu/newsroom/article29/items/611236. Pembanding, tidak mengikat di Indonesia. Diakses 1 November 2026.

[6] Elham Asgari, Nina Montaña-Brown, Magda Dubois, Saleh Khalil, Jasmine Balloch, Joshua Au Yeung, and Dominic Pimenta. A framework to assess clinical safety and hallucination rates of LLMs for medical text summarisation. *npj Digital Medicine*, 8(1):274, 2025. doi: 10.1038/s41746-025-01670-7. URL https://doi.org/10.1038/s41746-025-01670-7.

[7] AXELOS. *ITIL Foundation: ITIL 4 Edition*. TSO, London, 2019. URL https://www.peoplecert.org/Frameworks-Professionals/ITIL-framework.

ITIL (Version 5) diterbitkan PeopleCert pada 2026. Diakses 30 Oktober 2026.

[8] Badan Pengawas Obat dan Makanan. BPOM perkuat kesiapan penerapan pelindungan data pribadi, 2026. URL https://pusdatin.pom.go.id/berita/bpom-perkuat-kesiapan-penerapan-pelindungan-data-pribadi. Publikasi informasi, bukan naskah peraturan. Diakses 30 Oktober 2026.

[9] Badan Siber dan Sandi Negara. Peraturan badan siber dan sandi negara nomor 1 tahun 2024 tentang pengelolaan insiden siber, 2024. URL https://www.peraturan.go.id/files/peraturan-bssn-no-1-tahun-2024.pdf. Diakses 30 Oktober 2026.

[10] Badan Siber dan Sandi Negara. Peraturan BSSN Nomor 2 Tahun 2024 tentang Manajemen Krisis Siber, 2024. URL https://peraturan.go.id/files/peraturan-bssn-no-2-tahun-2024.pdf. Diakses 2 November 2026.

[11] Badan Standardisasi Nasional. RSNI3 ISO/IEC 27001:2022/Amd.1:2024 keamanan informasi, keamanan siber dan proteksi privasi: Sistem manajemen keamanan informasi: Persyaratan. amendemen 1: Perubahan aksi iklim. Rancangan adopsi identik dari ISO/IEC 27001:2022/Amd 1:2024, 2024. URL https://bsn.go.id/uploads/attachment/rsni_iso_iec_27001-2022-amd1_1.pdf. Diakses 31 Oktober 2026.

[12] Basel Committee on Banking Supervision. Principles for effective risk data aggregation and risk reporting. Technical report, Bank for International Settlements, 2013. URL https://www.bis.org/publ/bcbs239.htm. Diakses 2 November 2026.

[13] Mark S. Beasley, Bruce C. Branson, and Bonnie V. Hancock. Developing key risk indicators to strengthen enterprise risk management: How key risk indicators can sharpen focus on emerging risks. Thought leadership in erm, Committee of Sponsoring Organizations of the Treadway Commission, 2010. URL https://www.coso.org/_files/ugd/3059fc_6b2928dffbdf481dbf32971b3e9b9c85.pdf. Diakses 2 November 2026.

[14] Adam Beautement, M. Angela Sasse, and Mike Wonham. The compliance budget: Managing security behaviour in organisations. In *Proceedings of the 2008 New Security Paradigms Workshop*, pages 47–58. ACM, 2008. doi: 10.1145/1595676.1595684. URL https://doi.org/10.1145/1595676.1595684. Naskah penulis tersedia di UCL Discovery. Diakses 2 November 2026.

[15] Gwyn Bevan and Christopher Hood. What's measured is what matters: Tar-

gets and gaming in the English public health care system. *Public Administration*, 84(3):517–538, 2006. doi: 10.1111/j.1467-9299.2006.00600.x. URL https://doi.org/10.1111/j.1467-9299.2006.00600.x. Metadata dan abstrak dicocokkan melalui Crossref. Diakses 2 November 2026.

[16] Jon Boyens, Angela Smith, Nadya Bartol, Kris Winkler, Alex Holbrook, and Matthew Fallon. Cybersecurity supply chain risk management practices for systems and organizations. Special Publication NIST SP 800-161 Rev. 1, NIST, Gaithersburg, MD, 2022. URL https://doi.org/10.6028/NIST.SP.800-161r1-upd1. Terbit Mei 2022, dengan pembaruan sampai 1 November 2024. Diakses 1 November 2026.

[17] Graciela Braga. COBIT 2019 and the IIA 2019 guiding principles of corporate governance. ISACA Industry News, 13 Juli 2020, 2020. URL https://www.isaca.org/resources/news-and-trends/industry-news/2020/cobit-2019-and-the-iia-2019-guiding-principles-of-corporate-governance. Diakses 31 Oktober 2026.

[18] Travis D. Breaux and Annie I. Antón. Analyzing regulatory rules for privacy and security requirements. *IEEE Transactions on Software Engineering*, 34 (1):5–20, 2008. doi: 10.1109/TSE.2007.70746. URL https://doi.org/10.1109/TSE.2007.70746. Abstrak dibaca lewat OpenAlex. Diakses 2 November 2026.

[19] Center for Internet Security. CIS benchmarks. Halaman daftar panduan konfigurasi, 2026. URL https://www.cisecurity.org/cis-benchmarks. Diakses 31 Oktober 2026.

[20] Victoria Chiu, Qi Liu, and Miklos A. Vasarhelyi. The development and intellectual structure of continuous auditing research. *Journal of Accounting Literature*, 33(1-2):37–57, 2014. doi: 10.1016/j.acclit.2014.08.001. URL https://doi.org/10.1016/j.acclit.2014.08.001. Dicocokkan di Crossref; hanya abstrak dan kata kunci yang dibaca. Diakses 2 November 2026.

[21] Sung J. Choi, M. Eric Johnson, and Christoph U. Lehmann. Data breach remediation efforts and their implications for hospital quality. *Health Services Research*, 54(5):971–980, 2019. doi: 10.1111/1475-6773.13203. URL https://doi.org/10.1111/1475-6773.13203. Abstrak dibaca lewat PubMed. Diakses 1 November 2026.

[22] Cloud Security Alliance. Cloud controls matrix and consensus assessments initiative questionnaire, 2026. URL https://cloudsecurityalliance.org/research/cloud-controls-matrix. Halaman resmi menyajikan versi 4.1; catat versi unduhan untuk asesmen. Diakses 1 November 2026.

[23] Committee of Sponsoring Organizations of the Treadway Commission. *Enterprise Risk Management: Integrating with Strategy and Performance*. COSO, 2017. URL https://www.coso.org/erm-framework. Diakses 30 Oktober 2026.

[24] Louis Anthony (Tony) Cox, Jr. What's wrong with risk matrices? *Risk Analysis*, 28(2):497–512, 2008. URL https://doi.org/10.1111/j.1539-6924.2008.01030.x. Diakses 31 Oktober 2026.

[25] Cuatrecasas. Digital Omnibus on AI: Key Changes to the Artificial Intelligence Act. Legal Flash, Juli 2026, 2026. URL https://www.cuatrecasas.com/resources/ai-omnibus-regulation-eng-txt-6a6c91679b13e331880996.pdf. Ringkasan firma hukum, bukan naskah resmi. Diakses 2 November 2026.

[26] Giovanna Culot, Guido Nassimbeni, Matteo Podrecca, and Marco Sartor. The ISO/IEC 27001 information security management standard: literature review and theory-based research agenda. *The TQM Journal*, 33(7):76–105, 2021. doi: 10.1108/TQM-09-2020-0202. URL https://doi.org/10.1108/TQM-09-2020-0202. Diakses 31 Oktober 2026.

[27] Christian Dameff, Jeffrey Tully, Theodore C. Chan, Edward M. Castillo, Stefan Savage, Patricia Maysent, Thomas M. Hemmen, Brian J. Clay, and Christopher A. Longhurst. Ransomware attack associated with disruptions at adjacent emergency departments in the US. *JAMA Network Open*, 6(5): e2312270, 2023. URL https://doi.org/10.1001/jamanetworkopen.2023.12270. Diakses 2 November 2026.

[28] Steven De Haes and Wim Van Grembergen. An exploratory study into IT governance implementations and its impact on business/IT alignment. *Information Systems Management*, 26(2):123–137, 2009. doi: 10.1080/10580530902794786. URL https://doi.org/10.1080/10580530902794786. Diakses 31 Oktober 2026.

[29] Steven De Haes, Wim Van Grembergen, Anant Joshi, and Tim Huygh. *Enterprise Governance of Information Technology: Achieving Alignment and Value in Digital Organizations*. Management for Professionals. Springer, Cham, third edition, 2020. doi: 10.1007/978-3-030-25918-1. URL https://doi.org/10.1007/978-3-030-25918-1. Diakses 30 Oktober 2026.

[30] Deloitte. Providing assurance through SOC reports, t.t. URL https://www.deloitte.com/content/dam/assets-zone3/us/en/docs/services/risk-advisory/2024/us-rfa-providing-assurance-through-soc-reports.pdf. Sumber sekunder dari kantor akuntan; naskah tanpa tanggal terbit. Diakses 1 November 2026.

[31] DNV. Revision of ISO/IEC 27701: Privacy information management system. Halaman informasi lembaga sertifikasi, t.t. URL https://www.dnv.com/assurance/Management-Systems/new-iso/transition/revision-of-iso-iec-27701/. Ringkasan pihak ketiga, bukan naskah standar. Diakses 1 November 2026.

[32] Mark T. Edmead. Using COBIT 2019 to plan and execute an organization transformation strategy. ISACA Industry News, 28 September 2020, 2020. URL https://www.isaca.org/resources/news-and-trends/industry-news/2020/using-cobit-2019-to-plan-and-execute-an-organization-transformation-strategy. Diakses 31 Oktober 2026.

[33] eramba. eramba: Open and enterprise GRC, 2026. URL https://www.eramba.org/. Diakses 2 November 2026.

[34] European Data Protection Board. Guidelines 07/2020 on the concepts of controller and processor in the GDPR, version 2.1. Diadopsi 7 Juli 2021, 2021. URL https://www.edpb.europa.eu/system/files/documents/2023-10/EDPB_guidelines_202007_controllerprocessor_final_en.pdf. Pembanding, tidak mengikat di Indonesia. Diakses 1 November 2026.

[35] European Data Protection Board. Guidelines 9/2022 on personal data breach notification under GDPR, version 2.0. Diadopsi 28 Maret 2023, 2023. URL https://www.edpb.europa.eu/system/files/documents/2023-04/edpb_guidelines_202209_personal_data_breach_notification_v2.0_en.pdf. Pembanding, tidak mengikat di Indonesia. Diakses 1 November 2026.

[36] European Parliament and Council. Regulation (EU) 2026/1744: Digital Omnibus on AI. Official Journal of the European Union, 24 Juli 2026, 2026. URL https://eur-lex.europa.eu/eli/reg/2026/1744/oj. Diakses 30 Oktober 2026.

[37] European Parliament and Council of the European Union. Regulation (EU) 2022/2554 on digital operational resilience for the financial sector. Official Journal of the European Union, L 333, 27 Desember 2022, 2022. URL https://eur-lex.europa.eu/eli/reg/2022/2554/oj. Diakses 2 November 2026.

[38] European Parliament and Council of the European Union. Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (artificial intelligence act). Official Journal of the European Union, L series, 12 Juli 2024, 2024. URL https://eur-lex.europa.eu/eli/reg/2024/1689/oj. Diubah dengan Regulation (EU) 2026/1744. Diakses 30 Oktober 2026.

[39] Christophe Feltus, Michaël Petit, and Eric Dubois. Strengthening employee's responsibility to enhance governance of IT: COBIT RACI chart case study. In *Proceedings of the First ACM Workshop on Information Security Governance*, pages 23–32, New York, NY, 2009. ACM. doi: 10.1145/1655168.1655174. URL https://doi.org/10.1145/1655168.1655174. Abstrak dibaca lewat OpenAlex. Diakses 2 November 2026.

[40] Stephen Few. Dashboard confusion. Perceptual Edge, 2004. URL https://www.perceptualedge.com/articles/ie/dashboard_confusion.pdf. Diakses 2 November 2026.

[41] Bent Flyvbjerg and Alexander Budzier. Why your IT project may be riskier than you think. *Harvard Business Review*, September 2011. URL https://hbr.org/2011/09/why-your-it-project-may-be-riskier-than-you-think. Versi praterbit: arXiv 1304.0265, https://arxiv.org/abs/1304.0265. Diakses 31 Oktober 2026.

[42] R. Edward Freeman. *Strategic Management: A Stakeholder Approach*. Cambridge University Press, Cambridge, 2010. doi: 10.1017/CBO9781139192675. URL https://doi.org/10.1017/CBO9781139192675. Diakses 31 Oktober 2026.

[43] Future of Life Institute. EU Artificial Intelligence Act: AI Act Explorer, 2026. URL https://artificialintelligenceact.eu/ai-act-explorer/. Salinan pasal oleh pihak ketiga, bukan naskah resmi. Diakses 2 November 2026.

[44] Jennifer E. Gerow, Varun Grover, Jason Thatcher, and Philip L. Roth. Looking toward the future of IT-business strategic alignment through the past: A meta-analysis. *MIS Quarterly*, 38(4):1159–1186, 2014. doi: 10.25300/MISQ/2014/38.4.10. URL https://doi.org/10.25300/MISQ/2014/38.4.10. Diakses 31 Oktober 2026.

[45] S. Ghafur, S. Kristensen, K. Honeyford, G. Martin, A. Darzi, and P. Aylin. A retrospective impact analysis of the WannaCry cyberattack on the NHS. *npj Digital Medicine*, 2:98, 2019. doi: 10.1038/s41746-019-0161-6. URL https://pmc.ncbi.nlm.nih.gov/articles/PMC6775064/. Diakses 31 Oktober 2026.

[46] Kate Goddard, Abdul Roudsari, and Jeremy C. Wyatt. Automation bias: A systematic review of frequency, effect mediators, and mitigators. *Journal of the American Medical Informatics Association*, 19(1):121–127, 2012. doi: 10.1136/amiajnl-2011-000089. URL https://doi.org/10.1136/amiajnl-2011-000089.

[47] Adam Griffith. ITIL 4 management practices 2023: A new level of se-

rvice management capability. PeopleCert. Halaman tidak mencantumkan tanggal terbit, 2023. URL https://www.peoplecert.org/news-and-announcements/2023/itil-4-management-practices-2023. Diakses 1 November 2026.

[48] Stefanie Grijp. Designing your organization's custom COBIT. ISACA Industry News, 4 Maret 2019, 2019. URL https://www.isaca.org/resources/news-and-trends/industry-news/2019/designing-your-organizations-custom-cobit. Diakses 1 November 2026.

[49] Kumaragunta Harisaiprasad. COBIT 2019 and COBIT 5 comparison. ISACA Industry News, 27 April 2020, 2020. URL https://www.isaca.org/resources/news-and-trends/industry-news/2020/cobit-2019-and-cobit-5-comparison. Diakses 31 Oktober 2026.

[50] Yudi Hartono, Winda Nur Cahyo, and Taufiq Immawan. The assignment of risk mitigation tasks based on the RACI matrix and key risk indicator. *Jurnal Ilmiah Teknik Industri*, 23(2):235–244, 2024. doi: 10.23917/jiti.v23i02.4756. URL https://doi.org/10.23917/jiti.v23i02.4756. Diakses 1 November 2026.

[51] Agus Tri Haryanto. 'wasit' perlindungan data pribadi segera dibentuk secara independen. detikInet, 23 Juli 2026, 2026. URL https://inet.detik.com/law-and-policy/d-8587033/wasit-perlindungan-data-pribadi-segera-dibentuk-secara-independen. Berita, bukan naskah peraturan. Diakses 1 November 2026.

[52] J. C. Henderson and N. Venkatraman. Strategic alignment: Leveraging information technology for transforming organizations. *IBM Systems Journal*, 38(2.3):472–484, 1999. doi: 10.1147/sj.1999.5387096. URL https://doi.org/10.1147/sj.1999.5387096. Terbit ulang. Terbit pertama 1993. Diakses 31 Oktober 2026.

[53] HL7 International. FHIR release 4 (v4.0.1): Consent, 2019. URL https://hl7.org/fhir/R4/consent.html. Diakses 1 November 2026.

[54] Rui Huang, Robert W. Zmud, and R. Leon Price. Influencing the effectiveness of IT governance practices through steering committees and communication policies. *European Journal of Information Systems*, 19(3):288–302, 2010. doi: 10.1057/ejis.2010.16. URL https://doi.org/10.1057/ejis.2010.16. Diakses 31 Oktober 2026.

[55] Douglas W. Hubbard and Richard Seiersen. *How to Measure Anything in Cybersecurity Risk*. Wiley, Hoboken, NJ, second edition, 2023. URL https://www.oreilly.com/library/view/-/9781119892304/. Diakses 30 Oktober 2026.

[56] IBM. Cost of a data breach report 2026. Ringkasan resmi di IBM Newsroom, 29 Juli 2026, 2026. URL https://newsroom.ibm.com/2026-07-29-ibm-study-one-in-four-malicious-breaches-are-ai-enabled,-costing-companies-6-million-on-average. Diakses 30 Oktober 2026.

[57] International Auditing and Assurance Standards Board. Staff overview: International standard on assurance engagements (ISAE) 3402, assurance reports on controls at a service organization. International Federation of Accountants, Desember 2009, 2009. URL https://www.iaasb.org/publications/staff-overview-international-standard-assurance-engagements-isae-3402-assurance-reports-controls. Ringkasan staf yang tidak mengikat, bukan naskah standar. Diakses 2 November 2026.

[58] International Organization for Standardization. ISO 37301:2021: Compliance management systems: Requirements with guidance for use, 2021. URL https://www.iso.org/standard/75080.html. Teks standar berbayar. Diakses 30 Oktober 2026.

[59] intuitem. CISO assistant community. Repositori GitHub, lisensi AGPL v3, 2026. URL https://github.com/intuitem/ciso-assistant-community. Diakses 2 November 2026.

[60] ISACA. *COBIT 2019 Framework: Governance and Management Objectives*. ISACA, Schaumburg, IL, 2018. URL https://www.isaca.org/resources/cobit. Judul dipastikan dari halaman resmi; isi rinci belum dibaca langsung. Diakses 31 Oktober 2026.

[61] ISACA. *COBIT 2019 Implementation Guide: Implementing and Optimizing an Information and Technology Governance Solution*. ISACA, Schaumburg, IL, 2018. URL https://www.isaca.org/resources/cobit. Judul dipastikan dari halaman resmi; isi rinci belum dibaca langsung. Diakses 31 Oktober 2026.

[62] ISACA. New COBIT 2019 resources help organizations design and implement tailored governance systems for their information and technology. Siaran pers ISACA, 11 Desember 2018, 2018. URL https://www.isaca.org/why-isaca/about-us/newsroom/press-releases/2018/new-cobit-2019-resources-help-organizations-design-and-implement-tailored-governance-systems. Isi COBIT 2019 Implementation Guide berbayar dan tidak dicocokkan. Diakses 2 November 2026.

[63] ISACA. *COBIT 2019 Design Guide: Designing an Information and Technology Governance Solution*. ISACA, Schaumburg, IL, 2018. URL https://www.

isaca.org/resources/cobit. Diakses 30 Oktober 2026.

[64] ISACA. *COBIT 2019 Framework: Introduction and Methodology*. ISACA, Schaumburg, IL, 2018. URL https://www.isaca.org/resources/cobit. Diakses 30 Oktober 2026.

[65] ISACA. COBIT: Control objectives for information technologies. Halaman sumber daya COBIT di situs ISACA, 2026. URL https://www.isaca.org/resources/cobit. Halaman ini menampilkan judul publikasi COBIT 2019, judul *focus area*, dan tautan toolkit; saat diakses belum menyebut COBIT 7. Diakses 31 Oktober 2026.

[66] ISACA. COBIT 7 foundation exam, 2026. URL https://www.isaca.org/store2/product/COBIT7-EXAM?category=shop-all. Diakses 31 Oktober 2026.

[67] ISACA. IT Audit Framework (ITAF). Edisi kelima, naskah berbayar, 2026. URL https://www.isaca.org/store2/product/WITAF5. Keberadaan edisi dicocokkan pada halaman produk; isi naskah belum diperiksa. Diakses 2 November 2026.

[68] ISACA Sydney Chapter. Latest news and updates: Updates coming to COBIT, 2026. URL https://engage.isaca.org/sydneychapter/events/newpage. Pengumuman debut COBIT 7 pada 27 Oktober; tahun disimpulkan dari daftar tanggal pada halaman yang sama, yang memakai 2026 dan 2027. Diakses 31 Oktober 2026.

[69] ISO. ISO 31000:2018 risk management: Guidelines, 2018. URL https://www.iso.org/standard/31000. Revisi sedang berjalan. Diakses 30 Oktober 2026.

[70] ISO. ISO 22301:2019 security and resilience: Business continuity management systems: Requirements. Beserta Amd 1:2024 Climate action changes, 2019. URL https://www.iso.org/standard/75106.html. Diakses 30 Oktober 2026.

[71] ISO. ISO 22301:2019/Amd 1:2024: Climate action changes, 2024. URL https://www.iso.org/standard/88412.html. Diakses 30 Oktober 2026.

[72] ISO. ISO 27799:2025 health informatics: Information security controls in health based on ISO/IEC 27002. Edisi ketiga, 2025. URL https://www.iso.org/standard/84647.html. Diakses 30 Oktober 2026.

[73] ISO/IEC. ISO/IEC 27036-4:2016 information technology: Security techniques: Information security for supplier relationships: Part 4: Guidelines for security of cloud services. Edisi 1.0, 28 September 2016, 2016. URL https://webstore.iec.ch/en/publication/25980. Standar berbayar;

dibaca dari abstrak penerbit. Diakses 1 November 2026.

[74] ISO/IEC. ISO/IEC 27036-2:2022 cybersecurity: Supplier relationships: Part 2: Requirements, 2022. URL https://www.iso.org/standard/82060.html. Standar berbayar; isi ditulis secara umum. Diakses 30 Oktober 2026.

[75] ISO/IEC. ISO/IEC 27001:2022 information security, cybersecurity and privacy protection: Information security management systems: Requirements. Beserta Amd 1:2024 Climate action changes, 2022. URL https://www.iso.org/standard/27001. Diakses 30 Oktober 2026.

[76] ISO/IEC. ISO/IEC 27002:2022 information security, cybersecurity and privacy protection: Information security controls, 2022. URL https://www.iso.org/standard/75652.html. Diakses 30 Oktober 2026.

[77] ISO/IEC. ISO/IEC 27005:2022 information security, cybersecurity and privacy protection: Guidance on managing information security risks, 2022. URL https://www.iso.org/standard/80585.html. Diakses 30 Oktober 2026.

[78] ISO/IEC. ISO/IEC 42001:2023 information technology: Artificial intelligence: Management system, 2023. URL https://www.iso.org/standard/42001. Diakses 30 Oktober 2026.

[79] ISO/IEC. ISO/IEC 38500:2024 information technology: Governance of IT for the organization. Edisi ketiga, menggantikan ISO/IEC 38500:2015, 2024. URL https://www.iso.org/standard/81684.html. Diakses 30 Oktober 2026.

[80] ISO/IEC. ISO/IEC 27701:2025 privacy information management systems: Requirements and guidance, 2025. URL https://www.iso.org/standard/27701. Diakses 30 Oktober 2026.

[81] ISO/IEC. ISO/IEC 42005:2025: AI system impact assessment, 2025. URL https://www.iso.org/standard/42005. Diakses 30 Oktober 2026.

[82] Markus Jegelka. Key changes of the new ISO/IEC 27001:2022. DQS, 21 September 2023. Sumber sekunder dari lembaga sertifikasi, 2023. URL https://www.dqsglobal.com/blog/new-iso-27001-2022-key-changes. Diakses 31 Oktober 2026.

[83] Joint Task Force Transformation Initiative. Managing information security risk: Organization, mission, and information system view. NIST Special Publication 800-39, National Institute of Standards and Technology, 2011. URL https://doi.org/10.6028/NIST.SP.800-39. Diakses 31 Oktober 2026.

[84] Joint Task Force Transformation Initiative. Guide for conducting risk as-

sessments. NIST Special Publication 800-30 Rev. 1, National Institute of Standards and Technology, 2012. URL https://doi.org/10.6028/NIST.SP.800-30r1. Diakses 31 Oktober 2026.

[85] Roman Jouravlev and Adam Griffith. ITIL foundation (Version 5), what's new? PeopleCert. Halaman tidak mencantumkan tanggal terbit, 2026. URL https://www.itil.com/Itil-News-and-Announcements/itil-version-5-foundation-whats-new-guide. Diakses 1 November 2026.

[86] Avinash Kadam. Evaluating business service continuity and availability using COBIT 2019. ISACA Industry News, 1 Juni 2020, 2020. URL https://www.isaca.org/resources/news-and-trends/industry-news/2020/evaluating-business-service-continuity-and-availability-using-cobit-2019. Diakses 31 Oktober 2026.

[87] Robert S. Kaplan and David P. Norton. The balanced scorecard: Measures that drive performance. *Harvard Business Review*, January–February 1992. URL https://hbr.org/1992/01/the-balanced-scorecard-measures-that-drive-performance-2. Judul dan penerbitan dipastikan dari halaman resmi; teks utuh tidak terbuka. Diakses 2 November 2026.

[88] Kementerian Kesehatan Republik Indonesia. Peraturan menteri kesehatan nomor 24 tahun 2022 tentang rekam medis. Berita Negara Republik Indonesia Tahun 2022 Nomor 829, 2022. URL https://peraturan.bpk.go.id/Details/245544. Diakses 30 Oktober 2026.

[89] Kementerian Komunikasi dan Informatika. Surat Edaran Menteri Komunikasi dan Informatika Nomor 9 Tahun 2023 tentang Etika Kecerdasan Artifisial. Ditetapkan di Jakarta, 19 Desember 2023, 2023. URL https://jdih.komdigi.go.id/produk_hukum/view/id/883/t/surat+edaran+menteri+komunikasi+dan+informatika+nomor+9+tahun+2023. Diakses 30 Oktober 2026.

[90] Kementerian Komunikasi dan Informatika Republik Indonesia. Peraturan menteri komunikasi dan informatika nomor 5 tahun 2020 tentang penyelenggara sistem elektronik lingkup privat. Berita Negara Republik Indonesia Tahun 2020 Nomor 1376, 2020. URL https://jdih.komdigi.go.id/produk_hukum/view/id/759/t/peraturan+menteri+komunikasi+dan+informatika+nomor+5+tahun+2020. Ketentuan peralihan Pasal 47 diubah dengan Permenkominfo 10/2021. Diakses 31 Oktober 2026.

[91] Omer F. Keskin, Kevin Matthe Caramancion, Irem Tatar, Owais Raza, and Unal Tatar. Cyber third-party risk management: A comparison of non-intrusive risk scoring reports. *Electronics*, 10(10):1168, 2021. doi: 10.3390/electronics10101168. URL https://doi.org/10.3390/

electronics10101168. Diakses 1 November 2026.

[92] Ethan Larsen, Allan Fong, Christian Wernz, and Raj M. Ratwani. Implications of electronic health record downtime: an analysis of patient safety event reports. *Journal of the American Medical Informatics Association*, 25(2):187–191, 2018. URL https://doi.org/10.1093/jamia/ocx057. Diakses 2 November 2026.

[93] Joseph J. Lazzarotti and Maya Atrakchi. OCR releases report summarizing HIPAA privacy and security compliance failures. The National Law Review, 7 Januari 2021, 2021. URL https://natlawreview.com/article/ocr-releases-report-summarizing-hipaa-privacy-and-security-compliance-failures. Sumber sekunder dari kantor hukum atas laporan audit OCR 2016 sampai 2017. Diakses 2 November 2026.

[94] John Linford and Corinne Brouch. Exciting updates for the open FAIR body of knowledge and certification program. The Open Group Blog, 22 Mei 2025, 2025. URL https://blog.opengroup.org/2025/05/22/exciting-updates-for-the-open-fair-body-of-knowledge-and-certification-program. Diakses 31 Oktober 2026.

[95] Mahkamah Konstitusi Republik Indonesia. Putusan nomor 151/puu-xxii/2024 mengenai pengujian pasal 53 ayat (1) uu pelindungan data pribadi. Diucapkan 30 Juli 2025, 2025. URL https://s.mkri.id/simpp/ds/6889d006383b1.pdf. Diakses 30 Oktober 2026.

[96] Aaron K. Massey, Paul N. Otto, Lauren J. Hayward, and Annie I. Antón. Evaluating existing security and privacy requirements for legal compliance. *Requirements Engineering*, 15(1):119–137, 2010. doi: 10.1007/s00766-009-0089-5. URL https://doi.org/10.1007/s00766-009-0089-5. Abstrak belum terbaca; uraian pada bab ditulis umum dari judul. Diakses 2 November 2026.

[97] Thomas H. McCoy, Jr and Roy H. Perlis. Temporal trends and characteristics of reportable health data breaches, 2010-2017. *JAMA*, 320(12):1282, 2018. doi: 10.1001/jama.2018.9222. URL https://pmc.ncbi.nlm.nih.gov/articles/PMC6233611/. Diakses 1 November 2026.

[98] Peter Mell and Tim Grance. The NIST definition of cloud computing. Special Publication NIST SP 800-145, NIST, Gaithersburg, MD, 2011. URL https://doi.org/10.6028/NIST.SP.800-145. Diakses 1 November 2026.

[99] Meridian Hukum. Peraturan pemerintah (PP) nomor 33 tahun 2026 tentang peraturan pelaksanaan undang-undang nomor 27 tahun 2022 tentang pelindungan data pribadi. Basis data peraturan nonresmi, 2026. URL https://meridianhukum.com/peraturan/pp-no-33-tahun-2026. Pe-

tunjuk penelusuran, bukan pengganti naskah resmi. Diakses 31 Oktober 2026.

[100] Natalia Michałek. Design and validation of a RACI matrix for responsibility management in matrix project organisations. In *Proceedings of the 34th International Conference on Information Systems Development*, 2026. doi: 10.62036/isd.2026.118. URL https://aisel.aisnet.org/isd2014/proceedings2026/transformation/11. Poster. Diakses 1 November 2026.

[101] Microsoft. Shared responsibility in the cloud. Microsoft Learn, diperbarui 24 Agustus 2026, 2026. URL https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility. Panduan ilustratif, tidak mengubah perjanjian layanan. Diakses 1 November 2026.

[102] National Institute of Standards and Technology. Framework for improving critical infrastructure cybersecurity. Versi 1.1, NIST, 2018. URL https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf. Diakses 31 Oktober 2026.

[103] National Institute of Standards and Technology. NIST cybersecurity framework 2.0: Quick-start guide for creating and using organizational profiles. NIST Special Publication 1301, NIST, 2024. URL https://csrc.nist.gov/pubs/sp/1301/final. Diakses 31 Oktober 2026.

[104] National Institute of Standards and Technology. The NIST cybersecurity framework (CSF) 2.0. Cybersecurity White Paper NIST CSWP 29, NIST, Gaithersburg, MD, 2024. URL https://doi.org/10.6028/NIST.CSWP.29. Diakses 30 Oktober 2026.

[105] National Institute of Standards and Technology. CSF 2.0 informative references. Halaman diperbarui 15 Oktober 2026; berkas unduhan CSF 2.0 Reference Tool dibuat 31 Oktober 2026, 2026. URL https://www.nist.gov/informative-references. Diakses 31 Oktober 2026.

[106] National Institute of Standards and Technology. NIST cybersecurity framework 2.0: Informative references quick-start guide. NIST Special Publication 1347, NIST, 2026. URL https://tsapps.nist.gov/publication/get_pdf.cfm?pub_id=962506. Diakses 31 Oktober 2026.

[107] National Institute of Standards and Technology. OSCAL: Open security controls assessment language, 2026. URL https://pages.nist.gov/OSCAL/. Halaman diperbarui 2 Juni 2026. Diakses 2 November 2026.

[108] National Institute of Standards and Technology. Layers and models. Dokumentasi OSCAL, 2026. URL https://pages.nist.gov/OSCAL/learn/concepts/layer/. Diakses 2 November 2026.

[109] NC State ERM Initiative. COSO's ERM framework. Arsip Enterprise Risk Management Initiative, North Carolina State University, 2020. URL https://erm.ncsu.edu/library/article/cosos-erm-framework. Rujukan sekunder. Diakses 31 Oktober 2026.

[110] NC State ERM Initiative. ISO's risk management framework. Arsip Enterprise Risk Management Initiative, North Carolina State University, 2020. URL https://erm.ncsu.edu/resource-center/isos-risk-management-framework. Rujukan sekunder. Diakses 31 Oktober 2026.

[111] NHS England London. Update on cyber incident: clinical impact in south east london, thursday 8 august, 2024. URL https://www.england.nhs.uk/london/2024/08/08/update-on-cyber-incident-clinical-impact-in-south-east-london-thursday-8-august/. Data manajemen yang belum diverifikasi. Halaman tidak dapat dibaca utuh pada pemeriksaan 2 November 2026, sehingga angka rinci tidak dikutip. Diakses 1 November 2026.

[112] Michael Nieles, Kelley Dempsey, and Victoria Yan Pillitteri. An introduction to information security. NIST Special Publication 800-12 Rev. 1, NIST, 2017. URL https://doi.org/10.6028/NIST.SP.800-12r1. Diakses 1 November 2026.

[113] NIST. Artificial Intelligence Risk Management Framework (AI RMF 1.0), 2023. URL https://doi.org/10.6028/NIST.AI.100-1. Diakses 30 Oktober 2026.

[114] NIST. NIST AI RMF to ISO/IEC FDIS 42001 AI Management System Crosswalk, 2023. URL https://airc.nist.gov/docs/NIST_AI_RMF_to_ISO_IEC_42001_Crosswalk.pdf. Memetakan ke rancangan akhir standar, bukan naskah terbit. Diakses 2 November 2026.

[115] NIST. Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, 2024. URL https://doi.org/10.6028/NIST.AI.600-1. Diakses 30 Oktober 2026.

[116] Ziad Obermeyer, Brian Powers, Christine Vogeli, and Sendhil Mullainathan. Dissecting racial bias in an algorithm used to manage the health of populations. *Science*, 366(6464):447–453, 2019. doi: 10.1126/science.aax2342. URL https://doi.org/10.1126/science.aax2342.

[117] OCEG. What is GRC (governance, risk, and compliance)?, t.t. URL https://www.oceg.org/ideas/what-is-grc. Halaman tanpa tanggal terbit. Diakses 31 Oktober 2026.

[118] Oluwaseyi Ojo. Achieving operational excellence using COBIT 2019. ISACA Industry News, 24 Agustus 2020, 2020. URL https://www.isaca.

org/resources/news-and-trends/industry-news/2020/achieving-operational-excellence-using-cobit-2019. Diakses 31 Oktober 2026.

[119] Open Policy Agent. Open policy agent (OPA). Dokumentasi resmi proyek, 2026. URL https://www.openpolicyagent.org/docs/latest/. Diakses 1 November 2026.

[120] Otoritas Jasa Keuangan. Peraturan otoritas jasa keuangan nomor 4/pojk.05/2021 tentang penerapan manajemen risiko dalam penggunaan teknologi informasi oleh lembaga jasa keuangan nonbank. Lembaran Negara Republik Indonesia Tahun 2021 Nomor 78, 2021. URL https://www.ojk.go.id/id/regulasi/Pages/Penerapan-Manajemen-Risiko-dalam-Penggunaan-Teknologi-Informasi-oleh-Lembaga-Jasa-Keuangan-Nonbank.aspx. Diakses 31 Oktober 2026.

[121] OWASP GenAI Security Project. OWASP top 10 for LLM applications 2025, 2025. URL https://genai.owasp.org/llm-top-10/. Diakses 2 November 2026.

[122] Anastasia Papazafeiropoulou and Konstantina Spanaki. Understanding governance, risk and compliance information systems (GRC IS): The experts view. *Information Systems Frontiers*, 18(6):1251–1263, 2015. doi: 10.1007/s10796-015-9572-3. URL https://doi.org/10.1007/s10796-015-9572-3. Diakses 2 November 2026.

[123] PeopleCert. ITIL certifications: ITIL 4 practices. Halaman modul praktik ITIL 4, 2026. URL https://www.peoplecert.org/browse-certifications/it-governance-and-service-management/ITIL-1. Alamat akhir setelah pengalihan dari peoplecert.org/ITIL4-practices. Diakses 2 November 2026.

[124] Ryan Peterson. Crafting information technology governance. *Information Systems Management*, 21(4):7–22, 2004. doi: 10.1201/1078/44705.21.4.20040901/84183.2. URL https://doi.org/10.1201/1078/44705.21.4.20040901/84183.2. Diakses 31 Oktober 2026.

[125] Stephen Quinn, Cherilyn Pascoe, Matthew Barrett, Karen Scarfone, and Gregory Witte. NIST cybersecurity framework 2.0: Quick-start guide for using the CSF tiers. NIST Special Publication 1302, NIST, 2024. URL https://www.nist.gov/publications/nist-cybersecurity-framework-20-quick-start-guide-using-csf-tiers. Diakses 31 Oktober 2026.

[126] Stephen Quinn, Julie Chua, Nahla Ivy, Robert Gardner, Karen Kent, Matthew

Smith, and Gregory Witte. Integrating cybersecurity and enterprise risk management (ERM). NIST Interagency Report 8286 Rev. 1, National Institute of Standards and Technology, 2025. URL https://doi.org/10.6028/NIST.IR.8286r1. Menggantikan NIST IR 8286 tahun 2020. Diakses 31 Oktober 2026.

[127] Stephen Quinn, Nahla Ivy, Matthew Barrett, Larry Feldman, Greg Witte, and R. K. Gardner. Identifying and estimating cybersecurity risk for enterprise risk management. NIST Interagency Report 8286A Rev. 1, National Institute of Standards and Technology, 2025. URL https://doi.org/10.6028/NIST.IR.8286Ar1. Menggantikan NIST IR 8286A tahun 2021. Diakses 31 Oktober 2026.

[128] Nicolas Racz. *Governance, Risk & Compliance (GRC) for Information Systems: Towards an Integrated Approach*. PhD thesis, Technische Universität Wien, 2011. URL https://repositum.tuwien.at/handle/20.500.12708/14816. Diakses 31 Oktober 2026.

[129] Nicolas Racz, Edgar Weippl, and Andreas Seufert. A frame of reference for research of integrated governance, risk and compliance (GRC). In *Communications and Multimedia Security*, volume 6109 of *Lecture Notes in Computer Science*, pages 106–117. Springer, 2010. doi: 10.1007/978-3-642-13241-4_11. URL https://doi.org/10.1007/978-3-642-13241-4_11. Diakses 31 Oktober 2026.

[130] Abdul Rafeq and Narasimhan Elangovan. A systematic approach to implementing a governance system using COBIT 2019. ISACA Industry News, 26 Mei 2021, 2021. URL https://www.isaca.org/resources/news-and-trends/industry-news/2021/a-systematic-approach-to-implementing-a-governance-system-using-cobit-2019. Diakses 31 Oktober 2026.

[131] Republik Indonesia. Undang-undang nomor 40 tahun 2007 tentang perseroan terbatas, 2007. URL https://peraturan.bpk.go.id/Details/39965/uu-no-40-tahun-2007. Dibaca bersama perubahan yang berlaku. Diakses 31 Oktober 2026.

[132] Republik Indonesia. Undang-undang nomor 12 tahun 2011 tentang pembentukan peraturan perundang-undangan, 2011. URL https://peraturan.bpk.go.id/Details/39188/uu-no-12-tahun-2011. JDIH BPK mencatat perubahan dengan UU 15/2019, UU 13/2022, dan UU 1/2026. Diakses 31 Oktober 2026.

[133] Republik Indonesia. Peraturan presiden nomor 95 tahun 2018 tentang sistem pemerintahan berbasis elektronik. Lembaran Negara Republik Indonesia Tahun 2018 Nomor 182, 2018. URL https://peraturan.bpk.go.

id/Details/96913. Diakses 30 Oktober 2026.

[134] Republik Indonesia. Peraturan pemerintah nomor 71 tahun 2019 tentang penyelenggaraan sistem dan transaksi elektronik, 2019. URL https://peraturan.bpk.go.id/Details/122030/pp-no-71-tahun-2019. Diakses 30 Oktober 2026.

[135] Republik Indonesia. Peraturan presiden nomor 82 tahun 2022 tentang pelindungan infrastruktur informasi vital, 2022. URL https://peraturan.go.id/files/ps82-2022.pdf. Diakses 30 Oktober 2026.

[136] Republik Indonesia. Undang-undang nomor 27 tahun 2022 tentang pelindungan data pribadi. Lembaran Negara Republik Indonesia Tahun 2022 Nomor 196, 2022. URL https://peraturan.bpk.go.id/Details/229798/uu-no-27-tahun-2022. Diakses 30 Oktober 2026.

[137] Republik Indonesia. Undang-undang nomor 17 tahun 2023 tentang kesehatan. Lembaran Negara Republik Indonesia Tahun 2023 Nomor 105, 2023. URL https://peraturan.bpk.go.id/Details/258028/uu-no-17-tahun-2023. Diakses 31 Oktober 2026.

[138] Republik Indonesia. Undang-undang nomor 1 tahun 2024 tentang perubahan kedua atas undang-undang nomor 11 tahun 2008 tentang informasi dan transaksi elektronik, 2024. URL https://peraturan.bpk.go.id/Details/274494/uu-no-1-tahun-2024. Diakses 31 Oktober 2026.

[139] Republik Indonesia. Peraturan pemerintah nomor 28 tahun 2024 tentang peraturan pelaksanaan undang-undang nomor 17 tahun 2023 tentang kesehatan. Lembaran Negara Republik Indonesia Tahun 2024 Nomor 135, 2024. URL https://peraturan.bpk.go.id/Details/294077. Diakses 30 Oktober 2026.

[140] Luc Rocher, Julien M. Hendrickx, and Yves-Alexandre de Montjoye. Estimating the success of re-identifications in incomplete datasets using generative models. *Nature Communications*, 10:3069, 2019. doi: 10.1038/s41467-019-10933-3. URL https://pmc.ncbi.nlm.nih.gov/articles/PMC6650473/. Diakses 1 November 2026.

[141] Ioannis Routsis. Lost in the woods: COBIT 2019 and the IT balanced scorecard. ISACA Journal, Volume 3, 2021, 2021. URL https://www.isaca.org/resources/isaca-journal/issues/2021/volume-3/lost-in-the-woods-cobit-2019-and-the-it-balanced-scorecard. Diakses 31 Oktober 2026.

[142] RSM Indonesia. PP 33/2026: Six implementation priorities before 16 january 2027. Client Alert, 18 September 2026, 2026. URL https://www.rsm.global/indonesia/sites/default/files/

media/publications/Client%20Alert/2026/RSM%20Indonesia%20Client%20Alert%20-%20PP%20332026%20Six%20Implementation%20Priorities%20before%2016%20January%202027.pdf. Ringkasan pihak ketiga, bukan naskah peraturan. Diakses 1 November 2026.

[143] Ni Putu Sukma Paramita Sari, I Gede Putu Krisna Juliharta, and I Made Dwi Hita Darmawan. Analysis of information technology governance audit using COBIT 2019 framework: A case study at general hospital denpasar. *JATI (Jurnal Mahasiswa Teknik Informatika)*, 9(3):4053–4059, 2025. doi: 10.36040/jati.v9i3.13540. URL https://doi.org/10.36040/jati.v9i3.13540. Diakses 31 Oktober 2026.

[144] Sindy Rosita Sari and I Kadek Dwi Nuryana. Risk assessment on Wilujeng hospital IT process using COBIT 2019 framework. *Journal of Emerging Information Systems and Business Intelligence*, 6(4):461–475, 2026. URL https://ejournal.unesa.ac.id/index.php/JEISBI/article/view/71189. Terbitan berlabel Vol. 6 No. 4 (2025), dipublikasikan 2 Februari 2026. Diakses 31 Oktober 2026.

[145] Katherine Schroeder, Hung Trinh, and Victoria Yan Pillitteri. Measurement guide for information security: Volume 1, identifying and selecting measures. NIST Special Publication 800-55v1, National Institute of Standards and Technology, 2024. URL https://doi.org/10.6028/NIST.SP.800-55v1. Diakses 2 November 2026.

[146] Katherine Schroeder, Hung Trinh, and Victoria Yan Pillitteri. Measurement guide for information security: Volume 2, developing an information security measurement program. NIST Special Publication 800-55v2, National Institute of Standards and Technology, 2024. URL https://doi.org/10.6028/NIST.SP.800-55v2. Diakses 2 November 2026.

[147] Max Shanahan. White paper on the differences between ISO/IEC 38500:2015 and ISO/IEC 38500:2024. Situs ISO/IEC JTC 1/SC 40, 13 April 2024, 2024. URL https://committee.iso.org/sites/jtc1sc40/home/projects/wg-1/published-wg1/content-left-area/isoiec-sc-40-wg-1-develops-the-s/white-paper-on-the-differences-b.html. Bukan teks standar. Diakses 31 Oktober 2026.

[148] Joao Souza Neto, Rafael Almeida, and Miguel Mira da Silva. Defining target capability levels in COBIT 2019: A proposal for refinement. ISACA Industry News, 18 Maret 2019, 2019. URL https://www.isaca.org/resources/news-and-trends/industry-news/2019/defining-target-capability-levels-in-cobit-2019-a-proposal-for-refinement. Ringkasan tingkat dirujuk pada bagian karakteristik model; usulan metode alternatif artikel tidak dijadikan aturan asesmen. Diakses 31 Oktober 2026.

[149] Marianne Swanson, Pauline Bowen, Amy Wohl Phillips, Dean Gallup, and David Lynes. Contingency planning guide for federal information systems. NIST Special Publication 800-34 Revision 1, Mei 2010, 2010. URL https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-34r1.pdf. Diakses 2 November 2026.

[150] The Institute of Internal Auditors. Global internal audit standards. Berlaku sejak 9 Januari 2025, 2024. URL https://www.theiia.org/en/standards/2024-standards/global-internal-audit-standards/. Diakses 30 Oktober 2026.

[151] The Institute of Internal Auditors. Three lines model: Assurance and advice in support of effective governance. Statement of Position, Juli 2026, 2026. URL https://www.theiia.org/globalassets/site/resources/statements-of-position/tlm_assurance_advice_support_effective_gov_en.pdf. Diakses 30 Oktober 2026.

[152] The Open Group. The open FAIR body of knowledge. Laman The Open Group, t.t. URL https://www.opengroup.org/open-fair. Diakses 31 Oktober 2026.

[153] Mark Thomas. A new COBIT is in town and I really like how it looks. ISACA Industry News, 10 Desember 2018, 2018. URL https://www.isaca.org/resources/news-and-trends/industry-news/2018/a-new-cobit-is-in-town-and-i-really-like-how-it-looks. Diakses 31 Oktober 2026.

[154] Philip Thomas, Reidar B. Bratvold, and J. Eric Bickel. The risk of using risk matrices. *SPE Economics & Management*, 6(2):56–66, 2014. URL https://doi.org/10.2118/166269-PA. Diakses 31 Oktober 2026.

[155] Ofir Turel, Peng Liu, and Chris Bart. Board-level information technology governance effects on organizational performance: The roles of strategic alignment and authoritarian governance style. *Information Systems Management*, 34(2):117–136, 2017. doi: 10.1080/10580530.2017.1288523. URL https://doi.org/10.1080/10580530.2017.1288523. Diakses 31 Oktober 2026.

[156] Pernita Hestin Untari. Pembentukan badan PDP dipercepat, implementasi UU PDP dinilai belum efektif. Bisnis.com, 13 September 2026, 2026. URL https://teknologi.bisnis.com/read/20260913/84/2003698/pembentukan-badan-pdp-dipercepat-implementasi-uu-pdp-dinilai-belum-efektif. Berita, bukan naskah peraturan. Diakses 1 November 2026.

[157] Pernita Hestin Untari. Peta jalan dan etika AI nasional masih

diproses menuju perpres. Bisnis.com, 16 Juli 2026, 2026. URL https://teknologi.bisnis.com/read/20260716/84/1988624/peta-jalan-dan-etika-ai-nasional-masih-diproses-menuju-perpres. Berita, bukan naskah peraturan. Diakses 2 November 2026.

[158] U.S. Government Accountability Office. Government auditing standards: 2024 revision. Technical Report GAO-24-106786, U.S. Government Accountability Office, February 2024. URL https://www.gao.gov/products/gao-24-106786. Diakses 2 November 2026.

[159] U.S. Government Accountability Office and Council of the Inspectors General on Integrity and Efficiency. Federal information system controls audit manual (FISCAM). Technical Report GAO-26-108633, U.S. Government Accountability Office, June 2026. URL https://www.gao.gov/products/gao-26-108633. Menggantikan revisi September 2024. Diakses 2 November 2026.

[160] Verizon. 2026 data breach investigations report, 2026. URL https://www.verizon.com/business/resources/reports/dbir/. Diakses 31 Oktober 2026.

[161] Leni Wandira. Dua perpres AI tinggal tunggu tanda tangan prabowo. Kontan, 4 September 2026, 2026. URL https://nasional.kontan.co.id/news/dua-perpres-ai-tinggal-tunggu-tanda-tangan-prabowo. Berita, bukan naskah peraturan. Diakses 2 November 2026.

[162] WaterISAC. (TLP:CLEAR) verizon's 2026 data breach investigations report (DBIR). Ringkasan pihak ketiga, 21 Mei 2026, 2026. URL https://www.waterisac.org/tlpclear-verizons-2026-data-breach-investigations-report-dbir. Ringkasan, bukan naskah laporan. Diakses 1 November 2026.

[163] Peter Weill. Don't just lead, govern: How top-performing firms govern IT. *MIS Quarterly Executive*, 3(1), 2004. URL https://aisel.aisnet.org/misqe/vol3/iss1/3/. Diakses 31 Oktober 2026.

[164] Peter Weill and Jeanne W. Ross. *IT Governance: How Top Performers Manage IT Decision Rights for Superior Results*. Harvard Business School Press, Boston, MA, 2004. URL https://cisr.mit.edu/publication/it-governance-how-top-performers-manage-it-decision-rights-superior-results. Diakses 30 Oktober 2026.

[165] Andrew Wong, Erkin Otles, John P. Donnelly, Andrew Krumm, Jeffrey McCullough, Olivia DeTroyer-Cooley, Justin Pestrue, Marie Phillips, Judy Konye, Carleen Penoza, Muhammad Ghous, and Karandeep Singh. External validation of a widely implemented proprietary sepsis prediction model in

hospitalized patients. *JAMA Internal Medicine*, 181(8):1065–1070, 2021. doi: 10.1001/jamainternmed.2021.2626. URL https://doi.org/10.1001/jamainternmed.2021.2626.

[166] World Health Organization. Ethics and governance of artificial intelligence for health. ISBN 9789240029200, terbit 28 Juni 2021, 2021. URL https://www.who.int/publications/i/item/9789240029200. Diakses 2 November 2026.

[167] World Health Organization. WHO issues first global report on AI in health and six guiding principles for its design and use. Rilis berita, 28 Juni 2021, 2021. URL https://www.who.int/news/item/28-06-2021-who-issues-first-global-report-on-ai-in-health-and-six-guiding-principles-for-its-design-and-use. Diakses 2 November 2026.

[168] World Health Organization. WHO releases AI ethics and governance guidance for large multi-modal models. Rilis berita, 18 Januari 2024, 2024. URL https://www.who.int/news/item/18-01-2024-who-releases-ai-ethics-and-governance-guidance-for-large-multi-modal-models. Diakses 2 November 2026.

[169] World Health Organization. Ethics and governance of artificial intelligence for health: Guidance on large multi-modal models. ISBN 9789240084759, terbit 25 Maret 2025, 2025. URL https://www.who.int/publications/i/item/9789240084759. Diakses 2 November 2026.

[170] Shelly Ping-Ju Wu, Detmar W. Straub, and Ting-Peng Liang. How information technology governance mechanisms and strategic alignment influence organizational performance: Insights from a matched survey of business and IT managers. *MIS Quarterly*, 39(2):497–518, 2015. URL https://aisel.aisnet.org/misq/vol39/iss2/12. Diakses 30 Oktober 2026.